

eRules

PART-IS

(IR/DR + AMC/GM)



Easy Access Rules for Information Security

EASA eRules: aviation rules for the 21st century

Rules are the core of the EU civil aviation system. The aim of the **EASA eRules** project is to make them **accessible** to stakeholders in an efficient and reliable way.

EASA eRules is a comprehensive, single system for structuring, sharing, and storing of rules. It is the single, easy-access online database for all aviation safety rules applicable to European airspace users.

The **Easy Access Rules (EAR)** are the output of the eRules project. They are consolidated versions of those rules, combining EU regulations with EASA acceptable means of compliance (AMC), and guidance material (GM) in an easy-to-read format with advanced navigation features through links and bookmarks. EAR are regularly updated, following the adoption of an official publication.

The **EAR** are also available as dynamic online publications (online format) with a wide range of functionalities, such as filters to obtain regulatory material tailored to one's needs, a search function through the table of contents to quickly access the relevant sections, and easy navigation for computers, tablets, and mobiles.

The **EASA eRules** system is developed and implemented in close cooperation with the Member States and aviation industry to ensure that all its capabilities are relevant and effective.

Published December 2025¹

Copyright notice

© European Union, 1998-2023

Unless otherwise specified, you can re-use the legal documents published in EUR-Lex for commercial or non-commercial purposes [...] ('© European Union, <http://eur-lex.europa.eu/>, 1998-2023')².

¹ The published date represents the date when the consolidated version of the document was generated.

² Euro-Lex, Important Legal Notice: <http://eur-lex.europa.eu/content/legal-notice/legal-notice.html>.

EASA eRULES

EASA eRules: aviation rules for the 21st century

Rules are the core of the EU civil aviation system. The aim of the EASA eRules project is to make them accessible to stakeholders in an efficient and reliable way.

EASA eRules is a comprehensive, single system for structuring, sharing, and storing of rules. It is the single, easy-access online database for all aviation safety rules applicable to persons and organisations subject to Basic Regulation (Regulation (EU) 2018/1139).

The Easy Access Rules (EAR) are the output of the eRules project. The EAR books are consolidated versions of those rules, combining EU regulations with the related EASA Executive Director (ED) decisions in an easy-to-read format with advanced navigation features through links and bookmarks. The EAR books are regularly updated, following the adoption of an official publication.

The EAR books are available:

- in PDF format;
- as dynamic online publications (online format) with a wide range of functionalities, such as filters to obtain regulatory material tailored to one's needs, a search function through the table of contents to quickly access the relevant sections, and easy navigation for computers, tablets, and mobiles; and
- in XML (machine-readable) format that can be easily processed and automated by recipients, producing output that is compatible and can be synchronised with local applications, search databases, etc.

The EASA eRules system is developed and implemented in close cooperation with the Member States and aviation industry to ensure that all its capabilities are relevant and effective.

Published December 2025¹

Copyright notice

© European Union, 1998-2025

Unless otherwise specified, you can re-use the legal documents published in EUR-Lex for commercial or non-commercial purposes [...] ('© European Union, <http://eur-lex.europa.eu>, 1998-2025')².

¹ The published date represents the date when the consolidated version of the EAR book was generated.

² Euro-Lex, Important Legal Notice: <http://eur-lex.europa.eu/content/legal-notice/legal-notice.html>.

DISCLAIMER

This document is issued by the European Union Aviation Safety Agency (referred to as both 'EASA' and 'the Agency') to provide its stakeholders with an updated, consolidated, and easy-to-read publication. It has been prepared by putting together the officially published EU regulations with the related EASA acceptable means of compliance (AMC) and guidance material (GM) (including their amendments) adopted so far. However, this document is not an official publication, and EASA accepts no liability for damage of any kind resulting from the risks inherent in its use.

LIST OF REVISIONS

Published	Reason for revision
October 2023	First Easy Access Rules document powered by eRules. The EAR incorporate: — Commission Implementing Regulation (EU) 2023/203 laying down rules for the application of Regulation (EU) 2018/1139 of the European Parliament and of the Council, as regards requirements for the management of information security risks with a potential impact on aviation safety for organisations covered by Commission Regulations (EU) No 1321/2014, (EU) No 965/2012, (EU) No 1178/2011, (EU) 2015/340, Commission Implementing Regulations (EU) 2017/373 and (EU) 2021/664, and for competent authorities covered by Commission Regulations (EU) No 748/2012, (EU) No 1321/2014, (EU) No 965/2012, (EU) No 1178/2011, (EU) 2015/340 and (EU) No 139/2014, Commission Implementing Regulations (EU) 2017/373 and (EU) 2021/664 and amending Commission Regulations (EU) No 1178/2011, (EU) No 748/2012, (EU) No 965/2012, (EU) No 139/2014, (EU) No 1321/2014, (EU) 2015/340, and Commission Implementing Regulations (EU) 2017/373 and (EU) 2021/664; — Commission Delegated Regulation (EU) 2022/1645 laying down rules for the application of Regulation (EU) 2018/1139, as regards requirements for the management of information security risks with a potential impact on aviation safety for organisations covered by Commission Regulations (EU) No 748/2012 and (EU) No 139/2014, and amending said Regulations; — ED Decision 2023/008/R ‘Management of information security risks’ that provides for AMC & GM to the Articles of Regulation (EU) 2022/1645 and Regulation (EU) 2023/203; — ED Decision 2023/009/R ‘Management of information security risks’ that provides for AMC & GM to support the Part-IS regulatory package implementation - Part-IS.D.OR and Part-IS.I.OR; and — ED Decision 2023/010/R ‘Management of information security risks’ that provides for AMC & GM to support the Part-IS regulatory package implementation - Part-IS.AR.
June 2024	This Revision incorporates: — Commission Implementing Regulation (EU) 2023/1769 amending Articles 2 and 6 of Commission Implementing Regulation (EU) 2023/203; — Commission Implementing Regulation (EU) 2024/1109 amending Articles 2 and 4 of Commission Implementing Regulation (EU) 2023/203; and — editorial changes to: — Article 15 and Annexes III, IV, V, VI, VII, VIII and IX to Commission Implementing Regulation (EU) 2023/203; and — Articles 6 and 7 of Commission Delegated Regulation 2022/1645.
December 2025	This Revision includes: — Commission Implementing Regulation (EU) 2025/2293 amending Implementing Regulation (EU) 2023/203 as regards the requirements

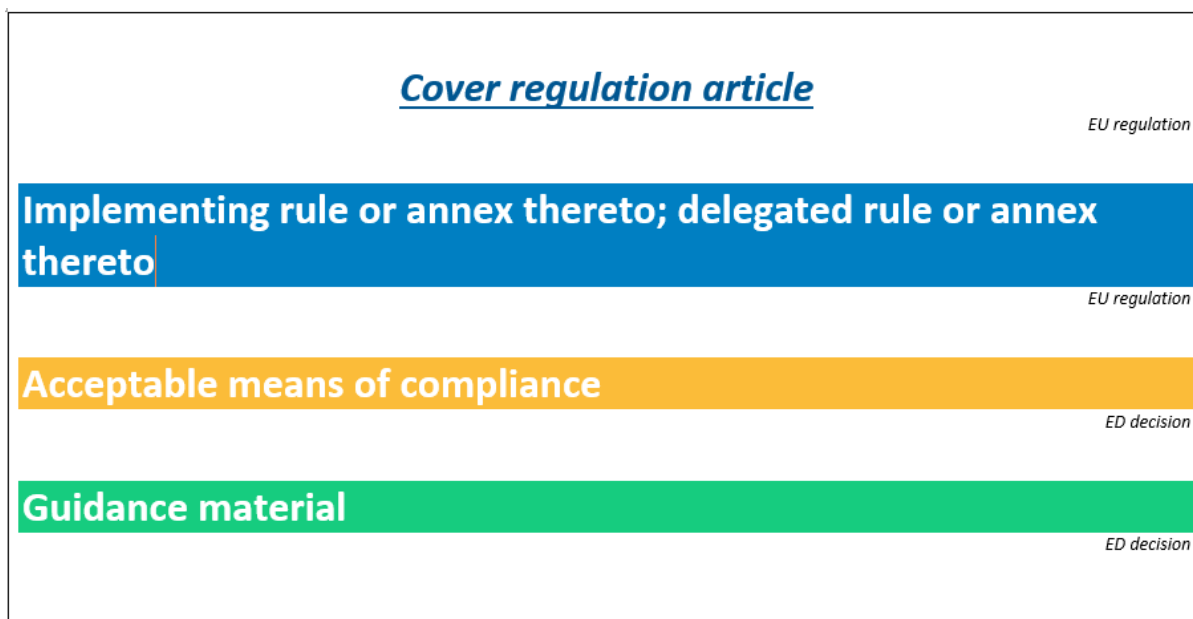
applicable to organisations subject to a declaration, and correcting Regulations (EU) No 1178/2011, (EU) No 748/2012, (EU) No 965/2012, (EU) No 139/2014, (EU) No 1321/2014, (EU) 2015/340, and Implementing Regulation (EU) 2017/373;

- [Commission Delegated Regulation \(EU\) 2025/22](#) amending Articles 2 and 5 of, and the Annex to, Commission Delegated Regulation 2022/1645 as regards requirements on information security for organisations providing ground handling services;
- [ED Decision 2025/013/R](#) on the management of information security risks, amending the AMC & GM to the Articles of Regulations (EU) 2022/1645 and 2023/203;
- [ED Decision 2025/014/R](#) on the management of information security risks, amending the AMC & GM to Part-IS.I.OR and Part-IS.D.OR;
- [Corrigendum to ED Decision 2025/014/R](#);
- [ED Decision 2025/015/R](#) on the management of information security risks, amending the AMC & GM to Part-IS.AR;
- [Corrigendum to ED Decision 2025/015/R](#); and
- a 'List of acronyms and abbreviations'.

NOTE FROM THE EDITOR

The content of this document is arranged as follows: the cover regulation (recitals and articles) of the implementing rule (IR) appears first, then the IR annex points, followed by the cover regulation of the delegated rule (DR) and DR annex points. The IR and DR and the annexes thereto are consolidated with the related acceptable means of compliance (AMC) and guidance material (GM).

All elements (i.e. articles, IRs, DRs, AMC, and GM) are colour-coded and can be identified according to the illustration below. The EU regulation or EASA Executive Director (ED) decision through which the recitals, article, IR, DR, AMC, or GM was introduced or last amended is indicated below the recitals, article, IR, DR, AMC, or GM title in *italics*.



Note:

The regulatory material introduced by **ED Decisions 2025/008/R, 2025/009/R, and 2025/010/R, ED Decisions 2025/013/R, 2025/014/R, and 2025/015/R**, as well as **Regulation (EU) 2023/203** and **Regulation (EU) 2025/2293** is **applicable from 22 February 2026**.

The regulatory material introduced by **Regulation (EU) 2025/22** amending Regulation (EU) 2022/1645 is **applicable from 27 March 2031** and marked with purple; its applicability date is indicated below the rule text in purple, in square brackets '[]', and in *italics*.

This document will be updated regularly to incorporate further amendments.

The format of this document has been adjusted to make it user-friendly and for reference purposes. Any comments should be sent to erules@easa.europa.eu.

INCORPORATED AMENDMENTS

IMPLEMENTING RULES (IRs) (COMMISSION REGULATIONS)

Incorporated Regulation	Affected part	Applicability date ¹
Commission Implementing Regulation (EU) 2023/203	Initial issue of Annex I (Part-IS.AR) ‘Information Security — Authority Requirements’	22/2/2026 ²
	Initial issue of Annex II (Part-IS.I.OR) ‘Information Security — Organisation Requirements’	
	Part-145, Part-66, and Part-CAMO of Regulation (EU) No 1321/2014	
	Part-ARO and Part-ORO of Regulation (EU) No 965/2012	
	Part-ARA and Part-ORA of Regulation (EU) No 1178/2011	
	Part ATCO.AR and Part ATCO.OR of Regulation (EU) 2015/340	
	Part-ATM/ANS.AR and Part-ATM/ANS.OR of Regulation (EU) 2017/373	
	Articles of Regulation (EU) 2021/664 (U-space)	
	Part 21 of Regulation (EU) No 748/2012	
	Part-ADR.AR of Regulation (EU) No 139/2014	
Commission Implementing Regulation (EU) 2023/1769	Articles of Regulation (EU) 2023/203	5/10/2023
	Initial issue of Annex I (Part-DPO.AR) ‘Requirements for the Agency’ (see the Easy Access Rules for ATM/ANS Equipment)	
	Initial issue of Annex II (Part-DPO.OR) ‘Requirements for organisations involved in the design or production of ATM/ANS equipment’ (see the Easy Access Rules for ATM/ANS Equipment)	
Commission Implementing Regulation (EU) 2025/2293	Part-IS.I.OR	22/02/2026
	Part-ARA of Regulation (EU) No 1178/2011	
	Part 21 of Regulation (EU) No 748/2012	
	Part-ARO of Regulation (EU) No 965/2012	
	Part-ADR.AR of Regulation (EU) No 139/2014	

¹ This is the main date of application (i.e. the date from which an act or a provision in an act produces its full legal effects) as defined in the relevant regulation article. Some provisions of the regulations though may be applicable at a later date (deferred applicability). Besides, there may be some opt-outs (derogations from certain provisions) notified by the Member States.

² ‘As regards the case of the EGNOS air navigation service provider subject to Implementing Regulation (EU) 2017/373 it shall apply from 1 January 2026.’.

	Part-145 and Part-CAMO of Regulation (EU) No 1321/2014	
	Part ATCO.AR of Regulation (EU) 2015/340	
	Part ATM/ANS.AR of Regulation (EU) 2017/373	

DELEGATED RULES (DRs) (COMMISSION REGULATIONS)

Incorporated Regulation	Affected part	Applicability date
Commission Delegated Regulation (EU) 2022/1645	Initial issue of the Annex I (Part-IS.D.OR) 'Information security — Organisation requirements'	16/10/2025
	Part 21 of Regulation (EU) No 748/2012	
	Part-ADR.AR of Regulation (EU) No 139/2014	
Commission Delegated Regulation (EU) 2025/22	Articles of Regulation (EU) 2022/1645	27/03/2031
	Part-IS.D.OR	16/10/2025
Commission Implementing Regulation (EU) 2025/2293	Part-IS.I.OR	22/02/2026

ACCEPTABLE MEANS OF COMPLIANCE AND GUIDANCE MATERIAL (AMC AND GM) TO IRs AND DRs (ED DECISIONS)

Incorporated ED Decisions	AMC/GM Issue No, Amendment No	Applicability date
ED Decision 2023/008/R	AMC & GM to the Articles of Regulations (EU) 2022/1645 and 2023/203 Annex — Issue 1	22/2/2026
ED Decision 2023/009/R	AMC & GM to Part-IS.D.OR — Issue 1	22/2/2026
ED Decision 2023/010/R	AMC & GM to Part-IS.AR — Issue 1	22/2/2026
ED Decision 2025/013/R	AMC & GM to the Articles of Regulations (EU) 2022/1645 and 2023/203 — Issue 1, Amendment 1	22/2/2026
ED Decision 2025/014/R Corrigendum to EDD 2025/014/R	AMC & GM to Part-IS.I.OR — Issue 1, Amendment 1 AMC & GM to Part-IS.D.OR — Issue 1, Amendment 1	22/2/2026
ED Decision 2025/015/R Corrigendum to EDD 2025/015/R	AMC & GM to Part-IS.AR — Issue 1, Amendment 1	22/2/2026

Note: To access the official versions, please click on the hyperlinks provided above.

LIST OF ACRONYMS AND ABBREVIATIONS

Acronym/Abbreviation	Means / Stands for
ACC	area control centre
ACMS	aircraft conditioning management system
AD	airworthiness directive
AIM	aeronautical information management
AIREP	air report [typically, about an in-flight event needed to be reported]
A-ISAC	Aviation Information Sharing and Analysis Center
AISP	aeronautical information service provider
AMC	acceptable means of compliance
AOC	air operator certificate
APP	approach [autopilot mode], approach control [radio telephony]
ARINC	aeronautical radio, incorporated [standard]
ASM	airspace management
ATC	air traffic control
ATCO	air traffic controller
ATCO TO	air traffic controller training organisation
ATFCM	air traffic flow and capacity management
ATM/ANS	air traffic management / air navigation services
ATO	approved training organisation
ATS	air traffic services
ATSP	air traffic services provider
AU	airspace user
BPM	baggage processed message

CAMO	continuing airworthiness management organisation
CDM	collaborative decision-making
CERT	computer emergency response team
CIP	continuous improvement process
CISO	chief information security officer
CMS	centralised maintenance system [of an aircraft]
COBIT	control objectives for information and related technology [framework]
CRP	common responsible person [delegate of the accountable manager to implement information security provisions across organisation parts (ref. point IS.I.OR.240(d))]
CSIRT	computer security incident response team
DCB	demand–capacity balancing
DLP	data loss prevention
DMAIC	define–measure–analyse–improve–control
DOA	design organisation approval
DoS	denial of service
DR	delegated regulation
EAR	easy access rules
EASA	European Union Aviation Safety Agency
ECCSA	European Centre for Cyber Security in Aviation
E-CF	[European] e-Competence Framework
ECSF	European Cybersecurity Skills Framework
ED (EASA)	Executive Director (of the European Union Aviation Safety Agency)
EDR	endpoint detection and response
ED-XXX (EUROCAE)	EUROCAE document [standard]
EFB	electronic flight bag

EGNOS	European Geostationary Navigation Overlay Service
ELA2	aeroplane with a maximum take-off mass (MTOM) of 2000 kg or less, which is not classified as 'complex motor-powered aircraft'; [ref. FAQ: When is an organisation, designing a product (aircraft, engine, propeller), exempt from having a DOA?]
ENISA	European Union Agency for Cybersecurity
ER ACC	en-route area control centre
EU	European Union
EUROCAE	European Organisation for Civil Aviation Equipment
EUSPA	European Union Agency for the Space Programme
FDR	flight data recorder
FIS	flight information service
FSTD	flight simulation training device
GM	guidance material
GRC	governance, risk [management] and compliance
ICAO	International Civil Aviation Organization
ICT	information and communication technology
IEC	International Electrotechnical Commission
IFPS	integrated initial flight plan processing system [at EUROCONTROL]
IOC	indicator of compromise
IR	implementing regulation
ISAP	information security assessment process
ISMM	information security management manual
ISMS	information security management system
ISO	International Organisation for Standardisation
ISP	internet service provider
IT	information technology

KPI	key performance indicator
MET	meteorological services
NICE	National Initiative for Cybersecurity Education
NIS (2)	Network and Information Systems Directive (2)
NIST CSF	National Institute of Standards and Technology Cybersecurity Framework
NISTIR	NIST interagency/internal report
NOTAM	notice to airmen; notice to air missions; notice to aviators
OT	operational technology
PDCA	plan–do–check–act [cycle]
PDF	portable document format
PHMR	passagers handicapés ou à mobilité réduite [EN: passengers with disabilities or limited mobility]
PNR	passenger name record
POA	production organisation approval
QAR	quick-access recorder
QNH	altimeter setting equal to local average sea-level pressure
RBAC	role-based access control
RF	radio frequency
RPAS	remotely piloted aircraft system
SAB	Security Accreditation Board [EUSPA]
SAP	safety assessment process
SIEM	security information and event management
SMM	safety management manual
SMS	safety management system
SOA	statement of applicability
SOC	security operations centre

SW	software
TIS	traffic information service
TMA	terminal manoeuvring area
TOBT	target off-block time
TTPS	tactics, techniques and procedures
TWR	tower
UAS	unmanned aircraft system
VFR	visual flight rules
XML	extensible markup language

TABLE OF CONTENTS

EASA eRules.....	3
Disclaimer.....	4
List of revisions	5
Note from the editor	7
Incorporated amendments.....	8
List of acronyms and abbreviations	10
Table of contents	15
Implementing Regulation (EU) 2023/203	25
Cover Regulation.....	25
Article 1 – Subject matter	27
GM1 Article 1 — Subject matter	28
Article 2 – Scope.....	28
Article 3 – Definitions	30
GM1 Article 3 — Definitions	30
Article 4 – Requirements for organisations and competent authorities	33
Article 5 – Requirements arising from other Union legislation.....	33
GM1 Article 5(1) Requirements arising from other Union legislation	33
GM1 Article 5(2) Requirements arising from other Union legislation	34
Article 6 – Competent authority	34
GM1 Article 6(2) Competent authority.....	35
Article 7 – Submission of relevant information to NIS competent authorities	35
Article 8 – Amendment to Regulation (EU) No 1178/2011	36
Article 9 – Amendment to Regulation (EU) No 748/2012	36
Article 10 – Amendment to Regulation (EU) No 965/2012	36
Article 11 – Amendment to Regulation (EU) No 139/2014	36
Article 12 – Amendment to Regulation (EU) No 1321/2014	36
Article 13 – Amendment to Regulation (EU) 2015/340	36
Article 14 – Amendment to Regulation (EU) 2017/373	36

Article 15 – Amendment to Regulation (EU) 2021/664	36
Article 16	36
ANNEX I — AUTHORITY REQUIREMENTS (PART-IS.AR)	38
IS.AR.100 Scope	38
IS.AR.200 Information security management system (ISMS)	38
GM1 IS.AR.200 Information security management system (ISMS)	39
AMC1 IS.AR.200(a)(1) Information security management system	46
GM1 IS.AR.200(a)(1) Information security management system (ISMS)	47
AMC1 IS.AR.200(a)(8) Information security management system (ISMS)	47
GM1 IS.AR.200(a)(8) Information security management system (ISMS)	48
AMC1 IS.AR.200(a)(9) Information security management system (ISMS)	48
AMC1 IS.AR.200(a)(11) Information security management system (ISMS)	48
AMC1 IS.AR.200(c) Information security management system (ISMS)	49
GM1 IS.AR.200(c) Information security management system (ISMS)	49
GM1 IS.AR.200(d) Information security management system (ISMS)	50
IS.AR.205 Information security risk assessment	51
GM1 IS.AR.205 Information security risk assessment	51
AMC1 IS.AR.205(a) Information security risk assessment	52
GM1 IS.AR.205(a) Information security risk assessment	52
AMC1 IS.AR.205(b) Information security risk assessment	53
GM1 IS.AR.205(b) Information security risk assessment	53
GM2 IS.AR.205(b) Information security risk assessment	54
AMC1 IS.AR.205(c) Information security risk assessment	54
GM1 IS.AR.205(c) Information security risk assessment	55
AMC1 IS.AR.205(d) Information security risk assessment	60
GM1 IS.AR.205(d) Information security risk assessment	60
GM2 IS.AR.205(d) Information security risk assessment	61
IS.AR.210 Information security risk treatment	62
GM1 IS.AR.210 Information security risk treatment	62
AMC1 IS.AR.210(a) Information security risk treatment	63
IS.AR.215 Information security incidents — detection, response and recovery ...	64
GM1 IS.AR.215 Information security incidents — detection, response and recovery .	64
AMC1 IS.AR.215(a) Information security incidents — detection, response and recovery	65
GM1 IS.AR.215(a) Information security incidents — detection, response and recovery	65
AMC1 IS.AR.215(b) Information security incidents — detection, response and recovery	66
GM1 IS.AR.215(b) Information security incidents — detection, response and recovery	67
AMC1 IS.AR.215(c) Information security incidents — detection, response and recovery	67
GM1 IS.AR.215(b)&(c) Information security incidents — detection, response and recovery	67
GM1 IS.AR.215(c) Information security incidents— detection, response and recovery	69

IS.AR.220 Contracting of information security management activities.....	70
AMC1 IS.AR.220 Contracting of information security management activities	70
GM1 IS.AR.220 Contracting of information security management activities	71
GM2 IS.AR.220 Contracting of information security management activities	71
GM3 IS.AR.220 Contracting of information security management activities	72
GM4 IS.AR.220 Contracting of information security management activities	73
GM5 IS.AR.220 Contracting of information security management activities	74
IS.AR.225 Personnel requirements.....	74
GM1 IS.AR.225 Personnel requirements	75
AMC1 IS.AR.225(a) Personnel requirements	75
GM1 IS.AR.225(a) Personnel requirements	75
AMC1 IS.AR.225(b) Personnel requirements	75
GM1 IS.AR.225(b) Personnel requirements	76
AMC1 IS.AR.225(c) Personnel requirements.....	76
GM1 IS.AR.225(c) Personnel requirements.....	76
AMC1 IS.AR.225(d) Personnel requirements	77
GM1 IS.AR.225(d) Personnel requirements	77
AMC1 IS.AR.225(e) Personnel requirements	77
GM1 IS.AR.225(e) Personnel requirements	78
IS.AR.230 Record-keeping.....	79
GM1 IS.AR.230 Record-keeping	79
AMC1 IS.AR.230(a)(1)(iv)&(a)(4) Record-keeping	80
GM1 IS.AR.230(a)(1)(iv)&(a)(4) Record-keeping	80
AMC1 IS.AR.230(c)&(d) Record-keeping.....	80
GM1 IS.AR.230(c)&(d) Record-keeping.....	81
IS.AR.235 Continuous improvement	81
AMC1 IS.AR.235 Continuous improvement	81
GM1 IS.AR.235 Continuous improvement	82
AMC1 IS.AR.235(a) Continuous improvement	84
GM1 IS.AR.235(a) Continuous improvement.....	85
AMC1 IS.AR.235(b) Continuous improvement.....	86
GM1 IS.AR.235(b) Continuous improvement.....	87
Appendix I — Examples of threat scenarios with a potential harmful impact on safety.....	87
Appendix II — Main tasks stemming from the implementation of Part-IS mapped to the EU e-CF and the NIST CSF 2.0	94
Appendix III — Examples of aviation services and interfaces	99
Appendix IV — Part-IS requirements mapping to ISO/IEC 27001:2022 clauses and controls, and considerations on differences	102
ANNEX II — ORGANISATION REQUIREMENTS (PART-IS.I.OR).....	120
IS.I.OR.100 Scope	120
IS.I.OR.200 Information security management system (ISMS)	120
GM1 IS.I.OR.200 Information security management system (ISMS)	121
AMC1 IS.I.OR.200(a)(1) Information security management system (ISMS)	128

GM1 IS.I.OR.200(a)(1) Information security management system (ISMS)	129
AMC1 IS.I.OR.200(a)(12) Information security management system (ISMS)	130
GM1 IS.I.OR.200(a)(12) Information security management system (ISMS)	130
AMC1 IS.I.OR.200(a)(13) Information security management system (ISMS)	130
AMC1 IS.I.OR.200(c) Information security management system (ISMS).....	131
GM1 IS.I.OR.200(c) Information security management system (ISMS)	131
GM1 IS.I.OR.200(d) Information security management system (ISMS)	132
AMC1 IS.I.OR.200(e) Information security management system (ISMS)	133
GM1 IS.I.OR.200(e) Information security management system (ISMS)	134
IS.I.OR.205 Information security risk assessment	137
GM1 IS.I.OR.205 Information security risk assessment	138
AMC1 IS.I.OR.205(a) Information security risk assessment	138
GM1 IS.I.OR.205(a) Information security risk assessment	138
AMC1 IS.I.OR.205(b) Information security risk assessment	139
GM1 IS.I.OR.205(b) Information security risk assessment.....	139
GM2 IS.I.OR.205(b) Information security risk assessment	140
AMC1 IS.I.OR.205(c) Information security risk assessment	140
GM1 IS.I.OR.205(c) Information security risk assessment	141
AMC1 IS.I.OR.205(d) Information security risk assessment	146
GM1 IS.I.OR.205(d) Information security risk assessment	146
GM2 IS.I.OR.205(d) Information security risk assessment	147
AMC1 IS.I.OR.205(e) Information security risk assessment	148
GM1 IS.I.OR.205(e) Information security risk assessment	148
IS.I.OR.210 Information security risk treatment	149
GM1 IS.I.OR.210 Information security risk treatment	150
AMC1 IS.I.OR.210(a) Information security risk treatment	150
IS.I.OR.215 Information security internal reporting scheme	151
AMC1 IS.I.OR.215(a)&(b) Information security internal reporting scheme.....	152
GM1 IS.I.OR.215(a)&(b) Information security internal reporting scheme	152
GM2 IS.I.OR.215(a)&(b) Information security internal reporting scheme	152
GM3 IS.I.OR.215(a)&(b) Information security internal reporting scheme	153
GM1 IS.I.OR.215(c) Information security internal reporting scheme	153
GM1 IS.I.OR.215(d) Information security internal reporting scheme	153
IS.I.OR.220 Information security incidents — detection, response and recovery	154
GM1 IS.I.OR.220 Information security incidents — detection, response and recovery	154
AMC1 IS.I.OR.220(a) Information security incidents — detection, response and recovery	155
GM1 IS.I.OR.220(a) Information security incidents — detection, response and recovery	155
AMC1 IS.I.OR.220(b) Information security incidents — detection, response and recovery	156
GM1 IS.I.OR.220(b) Information security incidents — detection, response and recovery	157
AMC1 IS.I.OR.220(c) Information security incidents — detection, response and recovery	157
GM1 IS.I.OR.220(b)&(c) Information security incidents — detection, response and recovery	158

GM1 IS.I.OR.220(c) Information security incidents — detection, response and recovery	159
IS.I.OR.225 Response to findings notified by the competent authority	160
AMC1 IS.I.OR.225 Response to findings notified by the competent authority.....	160
GM1 IS.I.OR.225 Response to findings notified by the competent authority	160
IS.I.OR.230 Information security external reporting scheme	161
GM1 IS.I.OR.230 Information security external reporting scheme.....	161
AMC1 IS.I.OR.230(a)&(b) Information security external reporting scheme	162
GM1 IS.I.OR.230(a)&(b) Information security external reporting scheme.....	162
AMC1 IS.I.OR.230(c) Information security external reporting scheme	163
GM1 IS.I.OR.230(c) Information security external reporting scheme	163
IS.I.OR.235 Contracting of information security management activities	164
GM1 IS.I.OR.235 Contracting of information security management activities.....	164
GM2 IS.I.OR.235 Contracting of information security management activities.....	165
GM3 IS.I.OR.235 Contracting of information security management activities.....	165
AMC1 IS.I.OR.235(a) Contracting of information security management activities....	167
GM1 IS.I.OR.235(a) Contracting of information security management activities.....	168
GM2 IS.I.OR.235(a) Contracting of information security management activities.....	169
AMC1 IS.I.OR.235(b) Contracting of information security management activities....	169
GM1 IS.I.OR.235(b) Contracting of information security management activities.....	169
IS.I.OR.240 Personnel requirements	170
GM1 IS.I.OR.240 Personnel requirements	171
AMC1 IS.I.OR.240(a)(2) Personnel requirements	171
AMC1 IS.I.OR.240(a)(3) Personnel requirements	171
GM1 IS.I.OR.240(a)(3) Personnel requirements	171
AMC1 IS.I.OR.240(b) Personnel requirements	171
GM1 IS.I.OR.240(b) Personnel requirements	172
GM1 IS.I.OR.240(b)&(c) Personnel requirements	172
GM1 IS.I.OR.240(c) Personnel requirements	172
AMC1 IS.I.OR.240(d) Personnel requirements	172
GM1 IS.I.OR.240(e) Personnel requirements	173
AMC1 IS.I.OR.240(f) Personnel requirements	173
GM1 IS.I.OR.240(f) Personnel requirements.....	173
AMC1 IS.I.OR.240(g) Personnel requirements	174
GM1 IS.I.OR.240(g) Personnel requirements	174
AMC1 IS.I.OR.240(h) Personnel requirements	175
GM1 IS.I.OR.240(h) Personnel requirements	175
AMC1 IS.I.OR.240(i) Personnel requirements	175
GM1 IS.I.OR.240(i) Personnel requirements	175
IS.I.OR.245 Record-keeping	176
GM1 IS.I.OR.245 Record-keeping	177
AMC1 IS.I.OR.245(a)(1)(vi)&(a)(5) Record-keeping	177
GM1 IS.I.OR.245(a)(1)(vi)&(a)(5) Record-keeping	178
AMC1 IS.I.OR.245(c)&(d) Record-keeping.....	178
GM1 IS.I.OR.245(c)&(d) Record-keeping	178
IS.I.OR.250 Information security management manual (ISMM)	179
GM1 IS.I.OR.250(a) Information security management manual (ISMM)	180

IS.I.OR.255 Changes to the information security management system	181
AMC1 IS.I.OR.255 Changes to the information security management system.....	181
GM1 IS.I.OR.255 Changes to the information security management system.....	182
GM2 IS.I.OR.255 Changes to the information security management system.....	182
IS.I.OR.260 Continuous improvement	183
AMC1 IS.I.OR.260 Continuous improvement	184
GM1 IS.I.OR.260 Continuous improvement.....	184
AMC1 IS.I.OR.260(a) Continuous improvement	186
GM1 IS.I.OR.260(a) Continuous improvement.....	187
AMC1 IS.I.OR.260(b) Continuous improvement.....	188
GM1 IS.I.OR.260(b) Continuous improvement.....	189
Appendix I — Examples of threat scenarios with a potential harmful impact on safety.....	189
Appendix II — Main tasks stemming from the implementation of Part-IS mapped to the EU e-CF and NIST CSF 2.0	196
Appendix III — Examples of aviation services and interfaces	203
Appendix IV — Part-IS requirements mapping to ISO/IEC 27001:2022 clauses and controls, and considerations on differences	206
Appendix V — Proportionality considerations related to indicators of complexity	230
Appendix VI — Adaptation of the EU Cybersecurity Skills Framework (ECSF)	235
ANNEX III — Annexes VI (Part-ARA) and VII (Part-ORA) to Regulation (EU) No 1178/2011	252
ANNEX IV — Annex I (Part 21) to Regulation (EU) No 748/2012	253
ANNEX V — Annexes II (Part-ARO) and III (Part-ORO) to Regulation (EU) No 965/2012	254
ANNEX VI — Annex II (Part-ADR.AR) to Regulation (EU) No 139/2014.	255
ANNEX VII — Annexes II (Part-145), III (Part-66) and Vc (Part-CAMO) to Regulation (EU) No 1321/2014	256
ANNEX VIII — Annexes II (Part ATCO.AR) and III (Part ATCO.OR) to Regulation (EU) 2015/340	257
ANNEX IX — Annexes II (Part-ATM/ANS.AR) and III (Part-ATM/ANS.OR) to Implementing Regulation (EU) 2017/373	258
Delegated Regulation (EU) 2022/1645	259
Cover Regulation.....	259
EXPLANATORY MEMORANDUM	259

Article 1 – Subject matter	262
GM1 Article 1 — Subject matter	262
Article 2 – Scope.....	262
Article 3 – Definitions	263
GM1 Article 3 — Definitions	263
Article 4 – Requirements arising from other Union legislation	265
GM1 Article 4(1) Requirements arising from other Union legislation	266
GM1 Article 4(2) Requirements arising from other Union legislation	266
Article 5 – Competent authority	267
GM1 Article 5(2) Competent authority.....	267
Article 6 – Amendment to Regulation (EU) No 748/2012	267
Article 7 – Amendment to Regulation (EU) No 139/2014	268
Article 8	268
ANNEX — ORGANISATION REQUIREMENTS (PART-IS.D.OR)	269
IS.D.OR.100 Scope	269
IS.D.OR.200 Information security management system (ISMS)	269
GM1 IS.D.OR.200 Information security management system (ISMS)	270
AMC1 IS.D.OR.200(a)(1) Information security management system (ISMS)	277
GM1 IS.D.OR.200(a)(1) Information security management system (ISMS)	278
AMC1 IS.D.OR.200(a)(12) Information security management system (ISMS)	279
GM1 IS.D.OR.200(a)(12) Information security management system (ISMS)	279
AMC1 IS.D.OR.200(a)(13) Information security management system (ISMS)	279
AMC1 IS.D.OR.200(c) Information security management system (ISMS)	280
GM1 IS.D.OR.200(c) Information security management system (ISMS)	280
GM1 IS.D.OR.200(d) Information security management system (ISMS)	281
AMC1 IS.D.OR.200(e) Information security management system (ISMS)	283
GM1 IS.D.OR.200(e) Information security management system (ISMS)	283
IS.D.OR.205 Information security risk assessment.....	286
GM1 IS.D.OR.205 Information security risk assessment.....	287
AMC1 IS.D.OR.205(a) Information security risk assessment.....	288
GM1 IS.D.OR.205(a) Information security risk assessment.....	288
AMC1 IS.D.OR.205(b) Information security risk assessment.....	289
GM1 IS.D.OR.205(b) Information security risk assessment	289
GM2 IS.D.OR.205(b) Information security risk assessment	290
AMC1 IS.D.OR.205(c) Information security risk assessment	290
GM1 IS.D.OR.205(c) Information security risk assessment	291
AMC1 IS.D.OR.205(d) Information security risk assessment.....	295
GM1 IS.D.OR.205(d) Information security risk assessment	296
GM2 IS.D.OR.205(d) Information security risk assessment	297
IS.D.OR.210 Information security risk treatment.....	298
GM1 IS.D.OR.210 Information security risk treatment.....	298
AMC1 IS.D.OR.210(a) Information security risk treatment.....	299
IS.D.OR.215 Information security internal reporting scheme	300

AMC1 IS.D.OR.215(a)&(b) Information security internal reporting scheme	300
GM1 IS.D.OR.215(a)&(b) Information security internal reporting scheme	301
GM2 IS.D.OR.215(a)&(b) Information security internal reporting scheme	301
GM3 IS.D.OR. 215(a)&(b) Information security internal reporting scheme	301
GM1 IS.D.OR.215(c) Information security internal reporting scheme	302
GM1 IS.D.OR.215(d) Information security internal reporting scheme.....	302
IS.D.OR.220 Information security incidents — detection, response and recovery	302
GM1 IS.D.OR.220 Information security incidents — detection, response and recovery	303
AMC1 IS.D.OR.220(a) Information security incidents — detection, response and recovery	303
GM1 IS.D.OR.220(a) Information security incidents — detection, response and recovery	304
AMC1 IS.D.OR.220(b) Information security incidents — detection, response and recovery	304
GM1 IS.D.OR.220(b) Information security incidents — detection, response and recovery	305
AMC1 IS.D.OR.220(c) Information security incidents — detection, response and recovery	306
GM1 IS.D.OR.220(b)&(c) Information security incidents — detection, response and recovery	306
GM1 IS.D.OR.220(c) Information security incidents — detection, response and recovery	308
IS.D.OR.225 Response to findings notified by the competent authority	308
AMC1 IS.D.OR.225 Response to findings notified by the competent authority	309
GM1 IS.D.OR.225 Response to findings notified by the competent authority	309
IS.D.OR.230 Information security external reporting scheme	309
GM1 IS.D.OR.230 Information security external reporting scheme	310
AMC1 IS.D.OR.230(a)&(b) Information security external reporting scheme.....	310
GM1 IS.D.OR.230(a)&(b) Information security external reporting scheme	311
AMC1 IS.D.OR.230(c) Information security external reporting scheme.....	312
GM1 IS.D.OR.230(c) Information security external reporting scheme.....	312
IS.D.OR.235 Contracting of information security management activities	312
GM1 IS.D.OR.235 Contracting of information security management activities	312
GM2 IS.D.OR.235 Contracting of information security management activities	313
GM3 IS.D.OR.235 Contracting of information security management activities	313
GM1 IS.D.OR.235(a) Contracting of information security management activities	316
AMC1 IS.D.OR.235(a) Contracting of information security management activities...	317
GM2 IS.D.OR.235(a) Contracting of information security management activities	318
AMC1 IS.D.OR.235(b) Contracting of information security management activities ..	318
GM1 IS.D.OR.235(b) Contracting of information security management activities	318
IS.D.OR.240 Personnel requirements	319
GM1 IS.D.OR.240 Personnel requirements.....	320
AMC1 IS.D.OR.240(a)(2) Personnel requirements.....	320
AMC1 IS.D.OR.240(a)(3) Personnel requirements.....	320
GM1 IS.D.OR.240(a)(3) Personnel requirements.....	320

AMC1 IS.D.OR.240(b) Personnel requirements.....	320
GM1 IS.D.OR.240(b) Personnel requirements.....	321
GM1 IS.D.OR.240(b)&(c) Personnel requirements	321
GM1 IS.D.OR.240(c) Personnel requirements	321
AMC1 IS.D.OR.240(d) Personnel requirements.....	322
GM1 IS.D.OR.240(e) Personnel requirements.....	322
AMC1 IS.D.OR.240(f) Personnel requirements.....	323
GM1 IS.D.OR.240(f) Personnel requirements	323
AMC1 IS.D.OR.240(g) Personnel requirements	323
GM1 IS.D.OR.240(g) Personnel requirements	324
AMC1 IS.D.OR.240(h) Personnel requirements.....	324
GM1 IS.D.OR.240(h) Personnel requirements.....	325
AMC1 IS.D.OR.240(i) Personnel requirements.....	325
GM1 IS.D.OR.240(i) Personnel requirements.....	325
IS.D.OR.245 Record-keeping	326
GM1 IS.D.OR.245 Record-keeping.....	327
AMC1 IS.D.OR.245(a)(1)(vi)&(a)(5) Record-keeping.....	327
GM1 IS.D.OR.245(a)(1)(vi)&(a)(5) Record-keeping.....	327
AMC1 IS.D.OR.245(c)&(d) Record-keeping	328
GM1 IS.D.OR.245(c)&(d) Record-keeping	328
IS.D.OR.250 Information security management manual (ISMM).....	329
GM1 IS.D.OR.250(a) Information security management manual (ISMM).....	330
IS.D.OR.255 Changes to the information security management system	330
AMC1 IS.D.OR.255 Changes to the information security management system	331
GM1 IS.D.OR.255 Changes to the information security management system	331
GM2 IS.D.OR.255 Changes to the information security management system	332
IS.D.OR.260 Continuous improvement.....	333
AMC1 IS.D.OR.260 Continuous improvement.....	333
GM1 IS.D.OR.260 Continuous improvement.....	334
AMC1 IS.D.OR.260(a) Continuous improvement.....	336
GM1 IS.D.OR.260(a) Continuous improvement	336
AMC1 IS.D.OR.260(b) Continuous improvement	338
GM1 IS.D.OR.260(b) Continuous improvement	338
Appendix I — Examples of threat scenarios with a potential harmful impact on safety.....	339
Appendix II — Main tasks stemming from the implementation of Part-IS mapped to the EU e-CF and the NIST CSF 2.0	345
Appendix III — Examples of aviation services and interfaces	352
Appendix IV — Part-IS requirements mapping to ISO/IEC 27001:2022 clauses and controls, and considerations on differences.....	356
Appendix V — Proportionality considerations related to safety relevance and aspects of complexity.....	380
Appendix VI — Adaptation of the EU Cybersecurity Skills Framework (ECSF)	385

IMPLEMENTING REGULATION (EU) 2023/203

COVER REGULATION

COMMISSION IMPLEMENTING REGULATION (EU) 2023/203

of 27 October 2022

laying down rules for the application of Regulation (EU) 2018/1139 of the European Parliament and of the Council, as regards requirements for the management of information security risks with a potential impact on aviation safety for organisations covered by Commission Regulations (EU) No 1321/2014, No 965/2012, No 1178/2011, 2015/340, 2017/373 and 2021/664, and for competent authorities covered by Commission Regulations (EU) No 748/2012, No 1321/2014, No 965/2012, No 1178/2011, 2015/340, 2017/373, No 139/2014 and 2021/664 and amending Commission Regulations (EU) No 1178/2011, No 748/2012, No 965/2012, No 139/2014, No 1321/2014, 2015/340, 2017/373 and 2021/664

Regulation (EU) 2023/203

THE EUROPEAN COMMISSION,

Having regard to the Treaty on the Functioning of the European Union,

Having regard to Regulation (EU) 2018/1139 of the European Parliament and of the Council of 4 July 2018 on common rules in the field of civil aviation and establishing a European Union Aviation Safety Agency, and amending Regulations (EC) No 2111/2005, (EC) No 1008/2008, (EU) No 996/2010, (EU) No 376/2014 and Directives 2014/30/EU and 2014/53/EU of the European Parliament and of the Council, and repealing Regulations (EC) No 552/2004 and (EC) No 216/2008 of the European Parliament and of the Council and Council Regulation (EEC) No 3922/91¹, and in particular Articles 17(1) point (b), 27(1) point (a), 31(1) point (b), 43(1) point (b), 53(1) point (a) and 62(15) point (c) thereof

Whereas:

- (1) In accordance with the essential requirements set out in Annex II, point 3.1(b), to Regulation (EU) 2018/1139, continuing airworthiness management organisations and maintenance organisations are to implement and maintain a management system to manage safety risks.
- (2) In addition, in accordance with the essential requirements set out in Annex IV, point 3.3(b) and point 5(b), to Regulation (EU) 2018/1139, pilot training organisations, cabin crew training organisations, aero-medical centres for aircrew and operators of flight simulation training devices are to implement and maintain a management system to manage safety risks.
- (3) Moreover, in accordance with the essential requirements set out in Annex V, point 8.1(c), to Regulation (EU) 2018/1139, air operators are to implement and maintain a management system to manage safety risks.
- (4) Furthermore, in accordance with the essential requirements set out in Annex VIII, point 5.1(c) and point 5.4(b), to Regulation (EU) 2018/1139, air traffic management and air navigation service providers, U-space service providers and single common information service providers, and training organisations and aero-medical centres for air traffic controllers are to implement and maintain a management system to manage safety risks.
- (5) Those safety risks may derive from different sources, such as design and maintenance flaws, human performance aspects, environmental threats and information security threats.

¹ OJ L 212, 22.8.2018, p. 1.

Therefore, the management systems implemented by the European Union Aviation Safety Agency ('the Agency') and the national competent authorities and organisations referred to in the recitals above, should take into account not only safety risks stemming from random events, but also safety risks deriving from information security threats where existing flaws may be exploited by individuals with a malicious intent. Those information security risks are constantly increasing in the civil aviation environment as the current information systems are becoming more and more interconnected, and increasingly becoming the target of malicious actors.

- (6) The risks associated with those information systems are not limited to possible attacks to the cyberspace, but encompass also threats, which may affect processes and procedures as well as the performance of human beings.
- (7) A significant number of organisations already use international standards, such as ISO 27001, in order to address the security of digital information and data. Those standards may not fully address all the specificities of civil aviation. Therefore, it is appropriate to set out requirements for the management of information security risks with a potential impact on aviation safety.
- (8) It is essential that those requirements cover all aviation domains and their interfaces, since aviation is a highly interconnected system of systems. Therefore, they should apply to all the organisations and competent authorities covered by Regulation (EU) No 748/2012, Regulation (EU) No 1321/2014, Regulation (EU) No 965/2012, Regulation (EU) No 1178/2011, Regulation (EU) 2015/340, Regulation (EU) No 139/2014 and Regulation (EU) 2021/664, also those that are already required to have a management system in accordance with the existing Union aviation safety legislation. However, some organisations should be excluded from the scope of this Regulation in order to ensure appropriate proportionality to the lower information security risks they pose to the aviation system.
- (9) The requirements laid down in this Regulation should ensure a consistent implementation across all aviation domains, while creating a minimal impact on the Union aviation safety legislation already applicable to those domains.
- (10) The requirements laid down in this Regulation should be without prejudice to information security and cybersecurity requirements laid down in Point 1.7 of the Annex to Commission Implementing Regulation (EU) 2015/1998¹ and in Article 14 of Directive (EU) 2016/1148 of the European Parliament and of the Council².
- (11) The security requirements laid down in Articles 33 to 43 of Title V "Security of the Programme" of Regulation (EU) 2021/696 of the European Parliament and of the Council³ are considered to be equivalent with the requirements laid down in this Regulation, except as regards point [IS.I.OR.230](#) of Annex II to this Regulation which should be complied with.
- (12) In order to provide legal certainty, the interpretation of the term 'information security' as defined in this Regulation, reflecting its common use in civil aviation globally, should be considered as being consistent with that of the term 'security of network and information systems' as defined in Article 4(2) of Directive (EU) 2016/1148. The definition of information security used for the purposes of this Regulation should not be interpreted as divergent from

¹ Commission Implementing Regulation (EU) 2015/1998 of 5 November 2015 laying down detailed measures for the implementation of the common basic standards on aviation security ([OJ L 299, 14.11.2015, p. 1](#)).

² Directive (EU) 2016/1148 of the European Parliament and of the Council of 6 July 2016 concerning measures for a high common level of security of network and information systems across the Union ([OJ L 194, 19.7.2016, p. 1](#)).

³ Regulation (EU) 2021/696 of the European Parliament and of the Council of 28 April 2021 establishing the Union Space Programme and the European Union Agency for the Space Programme and repealing Regulations (EU) No 912/2010, (EU) No 1285/2013 and (EU) No 377/2014 and Decision No 541/2014/EU

the definition of security of network and information systems laid down in Directive (EU) 2016/1148.

- (13) In order to avoid duplication of legal requirements, where organisations covered by this Regulation are already subject to security requirements arising from Union acts referred to in recitals (10) and (11) which are in their effect equivalent to the provisions laid down in this Regulation, compliance with those security requirements should be considered to constitute compliance with the requirements laid down in this Regulation.
- (14) Organisations covered by this Regulation that are already subject to security requirements arising from Regulation (EU) 2015/1998 or Regulation (EU) 2021/696, or both, should also comply with the requirements of Annex II (Part [IS.I.OR.230](#) “Information security external reporting scheme”) to this Regulation as neither Regulation contains provisions related to external reporting of information security incidents.
- (15) For the sake of completeness, Regulations (EU) No 1178/2011, No 748/2012, No 965/2012, No 139/2014, No 1321/2014, 2015/340, 2017/373 and 2021/664 should be amended in order to introduce the information security management system requirements prescribed in this Regulation together with the management systems set out therein, and to set out the competent authorities’ requirements as regards the oversight of organisations implementing the aforementioned information security management requirements.
- (16) In order to provide organisations with sufficient time to ensure compliance with the new rules and procedures, this Regulation should apply 3 years after its entry into force, except for the air navigation service provider of the European Geostationary Navigation Overlay Service (EGNOS) defined in Commission Implementing Regulation (EU) 2017/373¹, where due to the ongoing security accreditation of the EGNOS system and services in line with Regulation (EU) 2021/696, it should become applicable from 1 January 2026.
- (17) The requirements laid down in this Regulation are based on Opinion No 03/2021⁽²⁾, issued by the Agency in accordance with Article 75(2) points (b) and (c) and Article 76(1) of Regulation (EU) 2018/1139.
- (18) The requirements laid down in this Regulation are in accordance with the opinion of the Committee for the application of common safety rules in the field of civil aviation established by Article 127 of Regulation (EU) 2018/1139,

HAS ADOPTED THIS REGULATION:

Article 1 – Subject matter

Regulation (EU) 2023/203

This Regulation sets out the requirements to be met by the organisations and competent authorities in order:

- (a) to identify and manage information security risks with potential impact on aviation safety which could affect information and communication technology systems and data used for civil aviation purposes,

¹ Commission Implementing Regulation (EU) 2017/373 of 1 March 2017 laying down common requirements for providers of air traffic management/air navigation services and other air traffic management network functions and their oversight, repealing Regulation (EC) No 482/2008, Implementing Regulations (EU) No 1034/2011, (EU) No 1035/2011 and (EU) 2016/1377 and amending Regulation (EU) No 677/2011, (OJ L 062 8.3.2017, p. 1)

² <https://www.easa.europa.eu/document-library/opinions>

- (b) to detect information security events and identify those which are considered information security incidents with potential impact on aviation safety,
- (c) to respond to, and recover from, those information security incidents.

GM1 Article 1 — Subject matter

ED Decision 2023/008/R

When taking measures under this Regulation, affected entities — irrespective of their size — are encouraged to ensure that the measures they take are proportionate to the nature and safety risk of their activities.

Article 2 – Scope

Regulation (EU) 2024/1109

1. This Regulation applies to the following organisations:
 - (a) maintenance organisations subject to Section A of Annex II (Part-145) to [Regulation \(EU\) No 1321/2014](#)⁽¹⁾, except those solely involved in the maintenance of aircraft in accordance with Annex Vb (Part-ML) to Regulation (EU) No 1321/2014;
 - (b) continuing airworthiness management organisations (CAMOs) subject to Section A of Annex Vc (Part-CAMO) to Regulation (EU) No 1321/2014, except those solely involved in the continuing airworthiness management of aircraft in accordance with Annex Vb (Part-ML) to Regulation (EU) No 1321/2014;
 - (c) air operators subject to Annex III (Part-ORO) to Regulation (EU) No 965/2012⁽²⁾, except those solely involved in the operation of any of the following:
 - (i) an ELA 2 aircraft as defined in Article 1(2), point (j) of Regulation (EU) No 748/2012⁽³⁾;
 - (ii) single-engine propeller-driven aeroplanes with a Maximum Operational Passenger Seating Configuration of 5 or less that are not classified as complex motor-powered aircraft, when taking off and landing at the same aerodrome or operating site and operating under Visual Flight Rules (VFR) by day rules;
 - (iii) single-engine helicopters with a Maximum Operational Passenger Seating Configuration of 5 or less that are not classified as complex motor-powered aircraft, when taking off and landing at the same aerodrome or operating site and operating under VFR by day rules.
 - (d) approved training organisations (ATOs) subject to Annex VII (Part-ORA) to Regulation (EU) No 1178/2011⁽⁴⁾, except those solely involved in training activities of ELA2 aircraft as

¹ Commission Regulation (EU) No 1321/2014 of 26 November 2014 on the continuing airworthiness of aircraft and aeronautical products, parts and appliances, and on the approval of organisations and personnel involved in these tasks ([OJ L 362, 17.12.2014, p. 1](#)).

² Commission Regulation (EU) No 965/2012 of 5 October 2012 laying down technical requirements and administrative procedures related to air operations pursuant to Regulation (EC) No 216/2008 of the European Parliament and of the Council ([OJ L 296, 25.10.2012, p. 1](#)).

³ Commission Regulation (EU) No 748/2012 of 3 August 2012 laying down implementing rules for the airworthiness and environmental certification of aircraft and related products, parts and appliances, as well as for the certification of design and production organisations ([OJ L 224, 21.8.2012, p. 1](#)).

⁴ Commission Regulation (EU) No 1178/2011 of 3 November 2011 laying down technical requirements and administrative procedures related to civil aviation aircrew pursuant to Regulation (EC) No 216/2008 of the European Parliament and of the Council ([OJ L 311, 25.11.2011, p. 1](#)).

- defined in Article 1(2), point (j) of Regulation (EU) No 748/2012, or solely involved in theoretical training;
- (e) aircrew aero-medical centres subject to Annex VII (Part-ORA) to Regulation (EU) No 1178/2011;
 - (f) flight simulation training device (FSTD) operators subject to Annex VII (Part-ORA) to Regulation (EU) No 1178/2011, except those solely involved in the operation of FSTDs for ELA2 aircraft as defined in Article 1(2), point (j) of Regulation (EU) No 748/2012;
 - (g) air traffic controller training organisations (ATCO TOs) and ATCO aero-medical centres subject to Annex III (Part ATCO.OR) to Regulation (EU) 2015/340⁽¹⁾;
 - (h) organisations subject to Annex III (Part-ATM/ANS.OR) to Regulation (EU) 2017/373⁽²⁾, except the following service providers:
 - (i) air navigation service providers holding a limited certificate in accordance with point ATM/ANS.OR.A.010 of that Annex;
 - (ii) flight information service providers declaring their activities in accordance with point ATM/ANS.OR.A.015 of that Annex;
 - (i) U-space service providers and single common information service providers subject to Regulation (EU) 2021/664⁽³⁾.
 - (j) approved organisations involved in the design or production of ATM/ANS systems and ATM/ANS constituents subject to Commission Implementing Regulation (EU) 2023/1769⁴.
2. This Regulation applies to the competent authorities, including the European Union Aviation Safety Agency ('the Agency'), referred to [Article 6](#) of this Regulation and in [Article 5](#) of [Delegated Regulation \(EU\) 2022/1645](#).
3. This Regulation also applies to the competent authority responsible for the issuance, continuation, change, suspension or revocation of aircraft maintenance licences in accordance with Annex III (Part-66) to Regulation (EU) No 1321/2014.
- 3a. This Regulation also applies to the competent authority designated in accordance with Annex I (Part-AR.UAS) to Commission Implementing Regulation (EU) 2024/1109⁵.

¹ Commission Regulation (EU) 2015/340 of 20 February 2015 laying down technical requirements and administrative procedures relating to air traffic controllers' licences and certificates pursuant to Regulation (EC) No 216/2008 of the European Parliament and of the Council, amending Commission Implementing Regulation (EU) No 923/2012 and repealing Commission Regulation (EU) No 805/2011 (OJ L 63, 6.3.2015, p. 1).

² Commission Implementing Regulation (EU) 2017/373 of 1 March 2017 laying down common requirements for providers of air traffic management/air navigation services and other air traffic management network functions and their oversight, repealing Regulation (EC) No 482/2008, Implementing Regulations (EU) No 1034/2011, (EU) No 1035/2011 and (EU) 2016/1377 and amending Regulation (EU) No 677/2011 (OJ L 62, 8.3.2017, p. 1).

³ Commission Implementing Regulation (EU) No 2021/664 of 22 April 2021 on a regulatory framework for the U-space (OJ L 139, 23.4.2021, p. 161).

⁴ Commission Implementing Regulation (EU) 2023/1769 of 12 September 2023 laying down technical requirements and administrative procedures for the approval of organisations involved in the design or production of air traffic management/air navigation services systems and constituents and amending Implementing Regulation (EU) 2023/203 (OJ L 228, XX.9.2023, p. 19).

⁵ Commission Implementing Regulation (EU) 2024/1109 of 10 April 2024 laying down rules for the application of Regulation (EU) 2018/1139 of the European Parliament and of the Council as regards competent authority requirements and administrative procedures for the certification, oversight and enforcement of the continuing airworthiness of certified unmanned aircraft systems, and amending Implementing Regulation (EU) 2023/203 (OJ L, 2024/1109, 17.5.2024, ELI: http://data.europa.eu/eli/reg_impl/2024/1109/oj).

4. This Regulation is without prejudice to information security and cybersecurity requirements laid down in point 1.7 of the Annex to Regulation (EU) 2015/1998⁽¹⁾ and in Article 14 of Directive (EU) 2016/1148 of the European Parliament and of the Council⁽²⁾.

Article 3 – Definitions

Regulation (EU) 2023/203

For the purpose of this Regulation, the following definitions shall apply:

- (1) ‘information security’ means the preservation of confidentiality, integrity, authenticity and availability of network and information systems;
- (2) ‘information security event’ means an identified occurrence of a system, service or network state indicating a possible breach of the information security policy or failure of information security controls, or a previously unknown situation that can be relevant for information security;
- (3) ‘incident’ means any event having an actual adverse effect on the security of network and information systems as defined in Article 4(7) of Directive (EU) 2016/1148;
- (4) ‘information security risk’ means the risk to organisational civil aviation operations, assets, individuals, and other organisations due to the potential of an information security event. Information security risks are associated with the potential that threats will exploit vulnerabilities of an information asset or group of information assets;
- (5) ‘threat’ means a potential violation of information security which exists when there is an entity, circumstance, action or event that could cause harm;
- (6) ‘vulnerability’ means a flaw or weakness in an asset or a system, procedures, design, implementation, or information security measures that could be exploited and results in a breach or violation of the information security policy.

GM1 Article 3 — Definitions

ED Decision 2023/008/R

For the sake of common understanding, the following is a description of the terms used in the AMC & GM to Part-IS.D.OR of Commission Delegated Regulation (EU) 2022/1645 as well as in the AMC & GM to Part-IS.AR and Part-IS.I.OR of Commission Implementing Regulation (EU) 2023/203:

Assessment	In the context of management system performance monitoring, continuous improvement and oversight, it refers to a planned and documented activity performed by competent personnel to evaluate and analyse the achieved level of performance, effectiveness and maturity, as well as compliance in relation to the organisation’s policy and objectives. Note: An assessment focuses on required outcomes and the overall performance, looking at the organisation as a whole. The main objective
-------------------	--

¹ Commission Implementing Regulation (EU) 2015/1998 of 5 November 2015 laying down detailed measures for the implementation of the common basic standards on aviation security (OJ L 299, 14.11.2015, p. 1).

² Directive (EU) 2016/1148 of the European Parliament and of the Council of 6 July 2016 concerning measures for a high common level of security of network and information systems across the Union (OJ L 194, 19.7.2016, p. 1).

	of the assessment is to identify the strengths and weaknesses to drive continuous improvement. Remark: For 'risk assessment', please refer to the definition below.
Attack vector (or attack path)	The path, interface, and actions by which an attacker executes an attack, as defined in EUROCAE ED-202.
Audit	It refers to a systematic, independent, and documented process for obtaining evidence, and evaluating it objectively to determine the extent to which requirements are complied with. Note: Audits may include inspections.
Competency	It is a combination of individual skills, practical and theoretical knowledge, attitude, training, and experience.
Correction	It is the action to eliminate a detected non-compliance.
Corrective action	It is the action taken to eliminate or mitigate the root cause(s) and prevent the recurrence of an existing detected non-compliance or other undesirable conditions or situations. Proper determination of the root cause(s) is crucial for defining effective corrective actions to prevent reoccurrence.
Deficiency	It is as a deviation from compliance with or a non-fulfilment of any requirement or objectives, either from a regulatory or an organisation's perspective, either completely or partially.
Experience	It is the fact or state of having been affected by or gained knowledge and skills through observation, participation or doing.
Functional chain	The concept of functional chain dictates that information security risks are shared along organisations due to their respective interfaces, such as supplier-customer relationships. Safety effects caused by information security threats primarily materialise at aircraft level, originating upstream of the aircraft. In the functional chain concept, each organisation assesses its information security risks, which it may not be able to address and hence may expose other organisations to risks. It should pass related information to the immediate partner(s) downstream for well-informed risk management purposes and to ensure that the whole chain is adequately protected, even when no organisation has full visibility or control.
Hazard	It is a condition or an object with the potential to cause or contribute to an aircraft incident or accident.
Information security control	It is a measure that reduces risk.
Intentional unauthorised electronic interaction	It refers to the deliberate act of engaging in electronic activities or communications (e.g. access to, or modification of, computer systems, networks, or data) without proper authorisation or permission and with the intent to disclose sensitive information, modify data, disrupt normal operations, or deny access to legitimate users.

Just culture	It means a culture in which front-line operators or other persons are not punished for actions, omissions or decisions taken by them that are commensurate with their experience and training, but in which gross negligence, wilful violations and destructive acts are not tolerated, as defined in Article 2 of Regulation (EU) No 376/2014 ¹ .
Knowledge	Content of information needed to perform adequately in the job at an acceptable level, usually obtained through formal education and on-the-job experience. This knowledge is necessary for job performance but is not sufficient on its own.
Management (activity)	In the general organisational context, it refers to the activities aimed at directing, controlling, and continually improving the organisation within appropriate structures. In the context of Commission Delegated Regulation (EU) 2022/1645 and Commission Implementing Regulation (EU) 2023/203 it means, more specifically, the supervision and making of decisions necessary to achieve the organisation's safety and information security objectives.
Management system	It refers to a set of interrelated or interacting system elements to establish policies, objectives and processes to achieve those objectives, where the system elements include the organisational structure, roles and responsibilities, planning and operations.
Risk assessment	It is an evaluation that is based on engineering and operational judgement and/or analysis methods in order to establish whether the achieved or perceived risk is acceptable.
Risk register	It refers to a physical or digital means of documentation used as a risk management tool that acts as a repository for all identified risks and contains additional information about each risk, such as the nature of the risk, mitigation measures, ownership, status, etc.
Safety	It refers to the state in which risks associated with aviation activities, related to, or in direct support of the operation of aircraft, are reduced and controlled to an acceptable level, as defined in ICAO Annex 19.
Safety risk	It refers to the predicted likelihood and severity of the consequences or outcomes of a hazard. Note: The term 'likelihood' is used instead of the term 'probability' to reflect a subjective analysis of the possibility of occurrence rather than a purely statistical assessment.

¹ Regulation (EU) No 376/2014 of the European Parliament and of the Council of 3 April 2014 on the reporting, analysis and follow-up of occurrences in civil aviation, amending Regulation (EU) No 996/2010 of the European Parliament and of the Council and repealing Directive 2003/42/EC of the European Parliament and of the Council and Commission Regulations (EC) No 1321/2007 and (EC) No 1330/2007 (OJ L 122, 24.4.2014, p. 18) (<https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX%3A32014R0376&qid=1669377456448>).

Article 4 – Requirements for organisations and competent authorities

Regulation (EU) 2024/1109

1. The organisations referred to in [Article 2](#)(1) shall comply with the requirements of [Annex II](#) (Part-IS.I.OR) to this Regulation.
2. The competent authorities referred to in [Article 2](#)(2), (3) and (3a) shall comply with the requirements of [Annex I](#) (Part-IS.AR) to this Regulation.

Article 5 – Requirements arising from other Union legislation

Regulation (EU) 2023/203

1. Where an organisation referred to in [Article 2](#)(1) complies with security requirements laid down in accordance with Article 14 of Directive (EU) 2016/1148 that are equivalent to the requirements laid down in this Regulation, compliance with those security requirements shall be considered to constitute compliance with the requirements laid down in this Regulation.
2. Where an organisation referred to in [Article 2](#)(1) is an operator or an entity referred to in the national civil aviation security programmes of Member States laid down in accordance with Article 10 of Regulation (EC) No 300/2008 of the European Parliament and of the Council¹, the cybersecurity requirements contained in point 1.7 of the Annex to Regulation (EU) 2015/1998 shall be considered to be equivalent with the requirements laid down in this Regulation, except as regards point [IS.I.OR.230](#) of [Annex II](#) to this Regulation that shall be complied with as such.
3. Where the organisation referred to in [Article 2](#)(1) is the air navigation service provider of the European Geostationary Navigation Overlay Service (EGNOS) referred to in Regulation (EU) 2021/696², the security requirements contained in Articles 33 to 43 of Title V of that Regulation are considered to be equivalent with the requirements laid down in this Regulation, except as regards point [IS.I.OR.230](#) of [Annex II](#) to this Regulation that shall be complied with as such.
4. The Commission, after consulting the Agency and the Cooperation Group referred to in Article 11 of Directive (EU) 2016/1148, may issue guidelines for the assessment of the equivalence of requirements laid down in this Regulation and Directive (EU) 2016/1148.

GM1 Article 5(1) Requirements arising from other Union legislation

ED Decision 2025/013/R

Pursuant to Article 44 of [Directive \(EU\) 2022/2555](#) (the NIS 2 Directive), the previous Directive (EU) 2016/1148 (the NIS Directive) was repealed with effect from 18 October 2024. In accordance with the NIS 2 Directive, references to the repealed Directive shall be construed as references to Directive (EU) 2022/2555 and shall be read in accordance with the correlation table set out in its Annex III.

In accordance with this table, references to Article 14 of Directive (EU) 2016/1148 shall be now read as references to Article 21 and Article 23 of Directive (EU) 2022/2555. For an exact correlation, please refer to Annex III to Directive (EU) 2022/2555.

¹ Regulation (EC) No 300/2008 of the European Parliament and of the Council of 11 March 2008 on common rules in the field of civil aviation security and repealing Regulation (EC) No 2320/2002, (OJ L 97, 9.4.2008, p. 72).

² Regulation (EU) 2021/696 of the European Parliament and of the Council of 28 April 2021 establishing the Union Space Programme and the European Union Agency for the Space Programme and repealing Regulations (EU) No 912/2010, (EU) No 1285/2013 and (EU) No 377/2014 and Decision No 541/2014/EU (OJ L 170, 12.5.2021, p. 69).

To ensure legal certainty, the equivalence of any requirements should be assessed by the competent authority against the requirements of the national legislation when Directive (EU) 2022/2555 is transposed.

When utilising this equivalence, organisations should consider the following:

- The equivalence between [Regulation \(EU\) 2023/203](#) and Directive (EU) 2022/2555 requirements as assessed by the competent authority.
- Possible differences in the perimeter of applicability of the rules, in particular as regards the elements that are within the scope under the two different frameworks.

The competent authority will decide whether or not the measures implemented by the organisation under the NIS framework can be considered sufficient for satisfying requirements of similar nature under this rule.

GM1 Article 5(2) Requirements arising from other Union legislation

ED Decision 2025/013/R

Even though the provisions in [Regulation \(EU\) 2023/203](#) are equivalent to the cybersecurity requirements in point 1.7 of the Annex to [Regulation \(EU\) 2015/1998](#), in order to ensure effective management of safety consequences by leveraging the requirements of Regulation (EU) 2015/1998, organisations need to consider the differences in the scope of the rules in terms of which elements are covered under the two different regulatory frameworks.

Taking the example of an airport operator, elements such as body scanners, X-ray machines and anti-RPAS systems fall under the scope of the requirements of point 1.7 of the Annex to Regulation (EU) 2015/1998. Elements such as runway lighting control systems and safety training databases fall under the scope of aviation safety rules. On the other hand, the protection of information and the verification of trustworthiness and identity can be considered elements that overlap between the two frameworks.

Consequently, an organisation that has developed a system in accordance with point 1.7 of the Annex to Regulation (EU) 2015/1998 can use it to address safety issues by extending the scope of the system, where necessary, to ensure that all safety-related elements are included. Moreover, compliance with point [IS.I.OR.230](#) has to be ensured.

Article 6 – Competent authority

Regulation (EU) 2023/1769

1. Without prejudice to the tasks entrusted to the Security Accreditation Board (SAB) referred to in Article 36 of Regulation (EU) 2021/696, the authority responsible for certifying and overseeing compliance with this Regulation shall be:
 - (a) with regard to organisations referred to in [Article 2](#)(1), point (a), the competent authority designated in accordance with Annex II (Part-145) to Regulation (EU) No 1321/2014;
 - (b) with regard to organisations referred to in Article 2(1), point (b), the competent authority designated in accordance with Annex Vc (Part-CAMO) to Regulation (EU) No 1321/2014;
 - (c) with regard to organisations referred to in Article 2(1), point (c), the competent authority designated in accordance with Annex III (Part-ORO) to Regulation (EU) No 965/2012;
 - (d) with regard to organisations referred to in Article 2(1), points (d) to (f), the competent authority designated in accordance with Annex VII (Part-ORA) to Regulation (EU) No 1178/2011;

- (e) with regard to organisations referred to in Article 2(1), point (g), the competent authority designated in accordance with Article 6(2) of Regulation (EU) 2015/340;
 - (f) with regard to organisations referred to in Article 2(1), point (h), the competent authority designated in accordance with Article 4(1) of Regulation (EU) 2017/373;
 - (g) with regard to organisations referred to in Article 2(1), point (i), the competent authority designated in accordance with Article 14(1) or 14(2), as applicable, of Regulation (EU) 2021/664.
 - (h) with regard to organisations referred to in Article 2(1), point (j), the competent authority designated in accordance with Article 3(1) of Implementing Regulation (EU) 2023/1769.
2. Member States may, for the purposes of this Regulation, designate an independent and autonomous entity to fulfil the assigned role and responsibilities of the competent authorities referred to in paragraph 1. In that case, coordination measures shall be established between that entity and the competent authorities, as referred to in paragraph 1, to ensure effective oversight of all the requirements to be met by the organisation.
3. The Agency shall cooperate in full compliance with the applicable rules on secrecy, protection of personal data and protection of classified information with the European Union Agency for the Space Programme (EUSPA), and the SAB referred to in Article 36 of Regulation (EU) 2021/696 in order to ensure effective oversight of the requirements applicable to EGNOS air navigation service provider.

GM1 Article 6(2) Competent authority

ED Decision 2025/013/R

The applicability of [Annex I](#) (Part-IS.AR) to [Implementing Regulation \(EU\) 2023/203](#) to competent authorities is specified in [Article 4\(2\)](#) and called for under the authority requirements for a management system in the implementing or delegated acts for each domain. Therefore, the Part-IS.AR requirements apply to the competent authority under [Article 6\(1\)](#) irrespective of the allocation of roles and responsibilities to an independent and autonomous entity designated by the State under Article 6(2).

At the same time, this independent and autonomous entity designated by the State is not subject to the Part-IS.AR requirements; this entity has only to fulfil the responsibilities for certifying and overseeing organisations' compliance with Implementing Regulation (EU) 2023/203.

This entity typically holds the role of a national information security body within the Member State and is normally subject to similar requirements to those existing in Part-IS.AR.

Article 7 – Submission of relevant information to NIS competent authorities

Regulation (EU) 2023/203

Competent authorities under this Regulation shall inform, without undue delay, the single point of contact designated in accordance with Article 8 of Directive (EU) 2016/1148 of any relevant information included in notifications submitted pursuant to point IS.I.OR.230 of Annex II to this Regulation and point [IS.D.OR.230](#) of [Annex I](#) to [Delegated Regulation \(EU\) 2022/1645](#) by operators of essential services identified in accordance with Article 5 of Directive (EU) 2016/1148.

Article 8 – Amendment to Regulation (EU) No 1178/2011

Regulation (EU) 2023/203

Annexes VI (Part-ARA) and VII (Part-ORA) to Regulation (EU) No 1178/2011 are amended in accordance with Annex III to this Regulation.

Article 9 – Amendment to Regulation (EU) No 748/2012

Regulation (EU) 2023/203

Annex I (Part 21) to Regulation (EU) No 748/2012 is amended in accordance with Annex IV to this Regulation.

Article 10 – Amendment to Regulation (EU) No 965/2012

Regulation (EU) 2023/203

Annexes II (Part-ARO) and III (Part-ORO) to Regulation (EU) No 965/2012 are amended in accordance with Annex V to this Regulation.

Article 11 – Amendment to Regulation (EU) No 139/2014

Regulation (EU) 2023/203

Annex II (Part-ADR.AR) to Regulation (EU) No 139/2014 is amended in accordance with Annex VI to this Regulation.

Article 12 – Amendment to Regulation (EU) No 1321/2014

Regulation (EU) 2023/203

Annexes II (Part-145), III (Part-66) and Vc (Part-CAMO) to Regulation (EU) No 1321/2014 are amended in accordance with Annex VII to this Regulation.

Article 13 – Amendment to Regulation (EU) 2015/340

Regulation (EU) 2023/203

Annexes II (Part ATCO.AR) and III (Part ATCO.OR) to Regulation (EU) 2015/340 are amended in accordance with Annex VIII to this Regulation.

Article 14 – Amendment to Regulation (EU) 2017/373

Regulation (EU) 2023/203

Annexes II (Part-ATM/ANS.AR) and III (Part-ATM/ANS.OR) to Regulation (EU) 2017/373 are amended in accordance with Annex IX to this Regulation.

Article 15 – Amendment to Regulation (EU) 2021/664

Regulation (EU) 2023/203

For the consolidated version of [Regulation \(EU\) 2021/664](#), please refer to the [Easy Access Rules for U-space \(Regulation \(EU\) 2021/664\)](#).

Article 16

Regulation (EU) 2023/203

This Regulation shall enter into force on the twentieth day following that of its publication in the *Official Journal of the European Union*.

It shall apply from 22 February 2026.

However, as regards the case of the EGNOS air navigation service provider subject to Regulation (EU) 2017/373 it shall apply from 1 January 2026.

Regulation (EU) 2023/203

This Regulation shall be binding in its entirety and directly applicable in all Member States.

Done at Brussels,

For the Commission

The President

Ursula VON DER LEYEN

ANNEX I — AUTHORITY REQUIREMENTS (PART-IS.AR)

IS.AR.100 Scope

Regulation (EU) 2023/203

This Part establishes the management requirements to be met by the competent authorities referred to in [Article 2\(2\)](#) of this Regulation.

The requirements to be met by those competent authorities for the performance of their certification, oversight and enforcement activities are contained in the Regulations referred to in [Article 2\(1\)](#) of this Regulation and in [Article 2](#) of [Delegated Regulation \(EU\) 2022/1645](#).

IS.AR.200 Information security management system (ISMS)

Regulation (EU) 2023/203

- (a) In order to achieve the objectives set out in [Article 1](#), the competent authority shall set up, implement and maintain an information security management system (ISMS) which ensures that the competent authority:
- (1) establishes a policy on information security setting out the overall principles of the competent authority with regard to the potential impact of information security risks on aviation safety;
 - (2) identifies and reviews information security risks in accordance with point [IS.AR.205](#);
 - (3) defines and implements information security risk treatment measures in accordance with point [IS.AR.210](#);
 - (4) defines and implements, in accordance with point [IS.AR.215](#), the measures required to detect information security events, identifies those which are considered incidents with a potential impact on aviation safety, and responds to, and recovers from, those information security incidents;
 - (5) complies with the requirements contained in point [IS.AR.220](#) when contracting any part of the activities described in point [IS.AR.200](#) to other organisations;
 - (6) complies with the personnel requirements contained in point [IS.AR.225](#);
 - (7) complies with the record-keeping requirements contained in point [IS.AR.230](#);
 - (8) monitors compliance of its own organisation with the requirements of this Regulation and provides feedback on findings to the person referred to in point [IS.AR.225](#) (a) to ensure effective implementation of corrective actions;
 - (9) protects the confidentiality of any information that the competent authority may have related to organisations subject to its oversight and the information received through the organisation's external reporting schemes established in accordance with point [IS.I.OR.230](#) of [Annex II \(Part-IS.I.OR\)](#) to this Regulation and point IS.I.OR.230 of Annex I (Part-IS.I.OR) to [Delegated Regulation \(EU\) 2022/1645](#);
 - (10) notifies the Agency of changes that affect the capacity of the competent authority to perform its tasks and discharge its responsibilities as defined in this Regulation;
 - (11) defines and implements procedures to share, as appropriate and in a practical and timely manner, relevant information to assist other competent authorities and agencies, as well

as organisations subject to this Regulation, to conduct effective security risk assessments relating to their activities.

- (b) In order to continuously meet the requirements referred to in [Article 1](#), the competent authority shall implement a continuous improvement process in accordance with point [IS.AR.235](#).
- (c) The competent authority shall document all key processes, procedures, roles and responsibilities required to comply with point [IS.AR.200\(a\)](#) and establish a process for amending this documentation.
- (d) The processes, procedures, roles and responsibilities established by the competent authority in order to comply with point [IS.AR.200\(a\)](#) shall correspond to the nature and complexity of its activities, based on an assessment of the information security risks inherent to those activities, and may be integrated within other existing management systems already implemented by the competent authority.

GM1 IS.AR.200 Information security management system (ISMS)

ED Decision 2025/015/R

An **information security management system (ISMS)** is a systematic approach to establish, implement, operate, monitor, review, maintain and continuously improve the state of information security of an organisation. Its objective is to protect the information assets, such that the operational and safety objectives of an organisation can be reached in a risk-aware, effective and efficient manner.

Generally speaking, an ISMS establishes an information security risk management process, based upon the results of information security impact analyses, which basically determine its scope. If information security breaches may cause or contribute to aviation safety consequences, information security requirements need to limit the impact or influence of information security breaches on levels of aviation safety, which are deemed acceptable. Hence, all roles, processes, or information systems, which may cause or contribute to aviation safety consequences, are within the scope of [Regulation \(EU\) 2023/203](#). The ISMS provides for means to decide on needed information security controls for all architectural layers (governance, business, application, technology, data) and domains (organisational, human, physical, technical). It further allows to manage the selection, implementation, and operation of information security controls. Finally, it allows to manage the governance, risk management and compliance (GRC) within the ISMS scope.

The overall risk assessment considers safety consequences influenced by information security risks. These may emerge as threats, hazards, escalation factors that weaken barriers, or direct triggers of existing hazards. When conducting this assessment, both aspects, information security and safety need to be coordinated throughout the process. This ensures mutual understanding of the objectives and the implementation of preventive measures against of all types of threats or weaknesses, as well as mitigating measures.

The risk management process is thus based on aviation safety risk assessments and derived information security risk acceptance levels, which are designed to effectively treat and manage information security risks with a potential impact on aviation safety caused by threats exploiting vulnerabilities of information assets in aeronautical systems.

Interacting bow-ties is one possible way that allows for a higher-level and non-exhaustive illustration of how different disciplines of risk assessment may need to collaborate to establish a common risk perspective. The below Figure 1 from ICAO Doc 10204 'Manual on Aviation Information Security' illustrates these interactions.

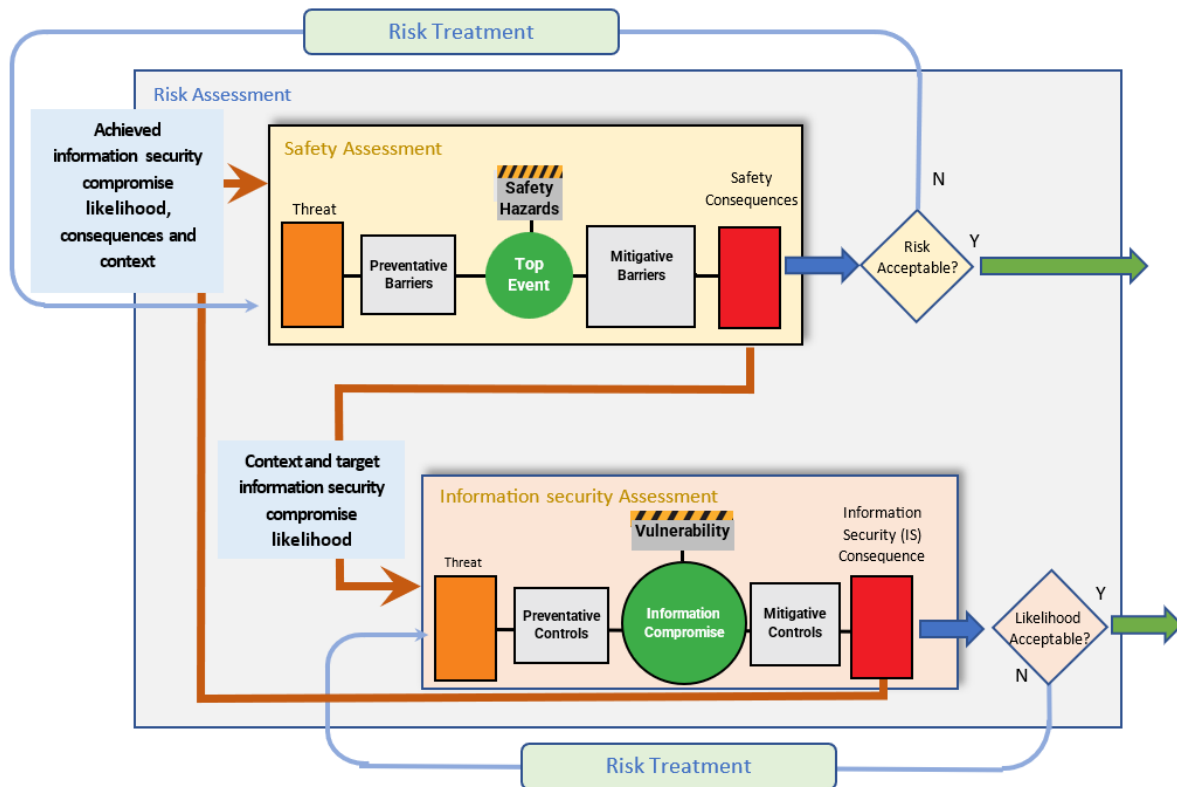


Figure 1: Bow-tie representation of management of aviation safety risks posed by information security threats

In the drawing, the term ‘context’ in the communication between the safety assessment process (SAP) and the information security assessment process (ISAP) carries slightly different notions, which need to be understood and distinguished.

In order to satisfy the safety requirements, the SAP will provide **context information**, such as:

- the architecture of the systems and the functional descriptions of the elements within the scope, including those related to the barriers. Systems should be understood as the dynamic interaction between people, processes, and products, or services;
- all identified relevant safety hazards;
- the top events and their relations (e.g. triggers) to those hazards.

In addition to context information, it provides the target likelihood of the related information security successful compromise. This target likelihood is commensurate with the safety objectives related to the severity of the safety consequence. However, it needs to be complemented to include information about the acceptable level of uncertainty, in order to be able to rely adequately on the results of the ISAP.

In turn, the ISAP will return **context information** such as:

- modification to the architecture of the systems and functional descriptions of the elements modified or added, whether those were safety barriers or other items;
- additional threats;
- potentially additional safety hazards;

- additional direct triggers of hazards;
- additional escalating factors affecting barriers.

In addition to context information, it provides the achieved likelihood of an information security successful compromise. While this likelihood is consistent with the safety objectives set by the SAP, the achieved level of uncertainty also needs to be considered.

The interaction between SAP and ISAP is iterative and continues until the safety risk is acceptable, i.e. the target likelihood of the related information security successful compromise has been achieved. The interaction can start from safety consequences identified through the SAP that fall within the scope of the ISMS risk analysis, or from existing information security assessments.

ISMS implementation and maintenance

An ISMS, as defined in this Regulation, employs the perspectives of governance, risk and compliance, and an approach that combines the safety risk and performance dimensions to determine the information security controls that are appropriate to and compliant with the specific context and can effectively provide the level of protection required to achieve the aviation safety objectives by:

- **Governance** perspective refers to providing management direction and leadership aimed to achieve the entity's own overarching objectives:
 - leadership and commitment of the senior management defining and ensuring the close involvement of the management and a 'top-down' ISMS implementation
 - information security and safety objectives aligned and consistent with the entity's business objectives and monitored by, e.g., management reviews
 - information security policies stating the principles and objectives to be achieved
 - roles, responsibilities, competencies and resources required for an effective ISMS
 - effective, target-group-oriented communication to internal and external stakeholders
- **Risk** perspective refers to a key aspect of an ISMS in an aviation safety context according to this Regulation, and serves as a basis for transparent decision-making and prioritisation of controls and risk treatment options. It further refers to the assessment, treatment and monitoring of information security risks in support of the management of aviation safety risks for the key processes and information assets upon which they depend. This includes protection requirements, risk exposure, attitude towards risks and risk acceptance criteria, methods and industry standards.
- **Compliance** perspective refers to the compliance with regulatory, legal and contractual requirements. This includes:
 - this Regulation,
 - the entity's own policies and standards and may further include international or industry standards adopted by the entity from ISO, EUROCAE, etc.

This perspective comprises the definition, implementation and maintenance of the required information security provisions whose effectiveness and compliance should be regularly monitored and assured by, e.g., (internal) audits.

Based on these perspectives, we may identify the following processes and subject areas that have been shown to be relevant for the establishment of an effective ISMS. These ISMS processes and subject areas can be summarised as follows:

- (a) context establishment defining the scope, interfaces, dependencies and requirements of interested parties;
- (b) leadership and commitment of the senior management;
- (c) information security and safety objectives;
- (d) information security policies;
- (e) roles, responsibilities, competencies and resources required for an effective ISMS;
- (f) communication to internal and external stakeholders to achieve a sufficient level of information security awareness and training of all involved parties;
- (g) information security risk management including risk assessment and treatment;
- (h) information security incident management establishing processes for the handling of information security incidents and vulnerabilities;
- (i) performance & effectiveness monitoring, measurement and evaluation;
- (j) internal audits and management reviews;
- (k) corrections and corrective actions;
- (l) continuous improvement;
- (m) relationship with suppliers;
- (n) documentation, record-keeping, and evidence collection.

Additional critical success factors for the implementation and operation of an ISMS include the following:

- The ISMS should be integrated with the entity's processes and overall management structure or even — at least partially, with safeguards for their respective integrity, and as reasonably applicable — with an overarching management system comprising information security, aviation safety and quality management.
- Information security has to be considered at an early stage in the overall design of processes and procedures, of systems and of information security controls, to be seamlessly integrated, for maximum effectiveness, minimal functional interference and optimised cost. None of these benefits can be achieved by integrating it later.
- The risk management process determines appropriate characteristics of preventive controls to reach and maintain acceptable risk levels.
- The incident management process ensures that the organisation detects, reacts and responds to information security incidents in a timely manner. This is achieved by defining responsibilities, procedures, scenarios and response plans in advance to ensure a coordinated, targeted and efficient response.
- Continuous monitoring and reassessment are undertaken and improvements are made in response.

The above-mentioned core components are related to the requirements in this Regulation, for which Figure 2 provides a high-level depiction of the aspects that are more prominent in the implementation phase and those that characterise the operational phase, as well as the review and possible improvement, if the functions do not perform as planned.

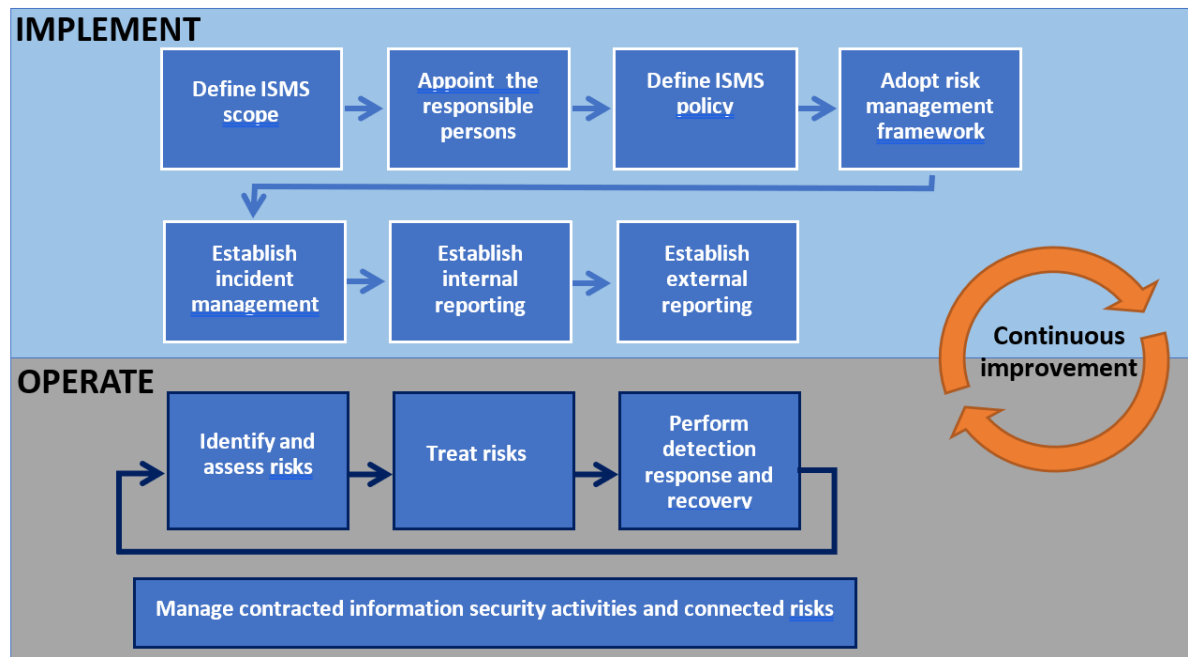


Figure 2: Representation of the Part-IS requirements from an ISMS's life cycle perspective

Plan-Do-Check-Act approach

The Plan-Do-Check-Act (PDCA) refers to a process approach that is often used to establish, implement, operate, monitor, review and improve management systems. Figure 3 depicts the PDCA applied to an ISMS.

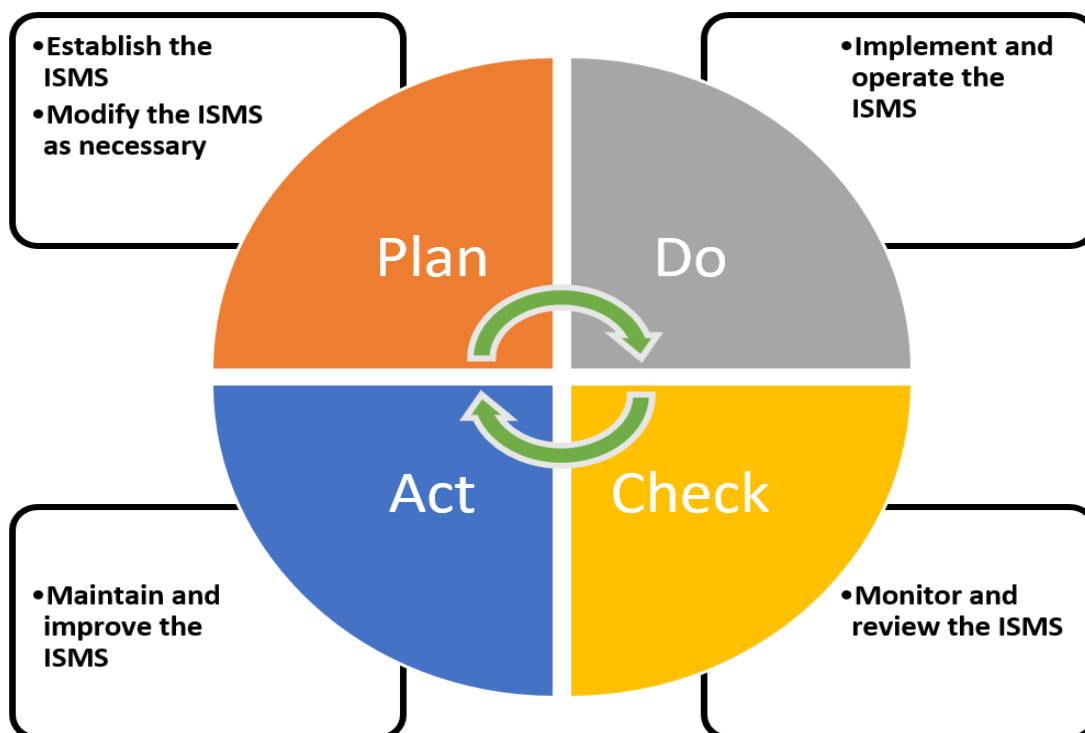


Figure 3: Plan-Do-Check-Act approach applied to an ISMS

Benefits of an ISMS

The benefits of a management system operating in a dynamic, uncertain or unpredictable risk environment are realised in the long term only when the organisation improves existing controls, processes and solutions based on the assessments of risks, performance and maturity as well as the learnings from incidents, audits, non-conformities and their root causes. A successful adoption and deployment of an ISMS allows an entity to:

- achieve greater assurance to the management and interested parties that its information assets are adequately protected against threats on a continual basis;
- increase its trustworthiness and credibility providing confidence to interested parties that information security risks with an impact on aviation safety are adequately managed;
- increase the resilience of the entity's key processes against unauthorised electronic interactions and maintains the entity's ability to decide and act;
- support the timely detection of control gaps, vulnerabilities or deficiencies aimed to prevent information security incidents or at least to minimise their impact;
- detect and timely react to changes in the entity's environment including system architecture and threat landscape or the adoption of new technologies;
- provide a foundation for effective and efficient implementation of a comprehensive information security strategy in times of digital transformation, increasing interconnectivity of systems, emerging information security threats and new technologies.

Relation to ISO/IEC 27001

The international standard ISO/IEC 27001 is a widely adopted standard for ISMS which specifies generic requirements for establishing, implementing, maintaining and continually improving an ISMS. It also includes requirements for the assessment and treatment of information security risks. The requirements are applicable to all entities, regardless of type, size or nature. The conformity of an ISMS with the ISO/IEC 27001 standard can be certified by an accredited certification body. ISO/IEC 27001 is compatible with other management system standards (quality, safety, etc.) that have also adopted the structure and terms defined in Annex SL to ISO/IEC Directives, Part 1, Consolidated ISO Supplement. This compatibility allows an entity to operate a single management system that meets the requirements of multiple management system standards.

ISO/IEC 27001 allows entities to define their own scope of audit and their own organisational risk appetite. This, in turn, leads to information security requirements that provide the ISMS with criteria for the acceptability of information security risks in line with the entity's risk appetite (see Figure4).

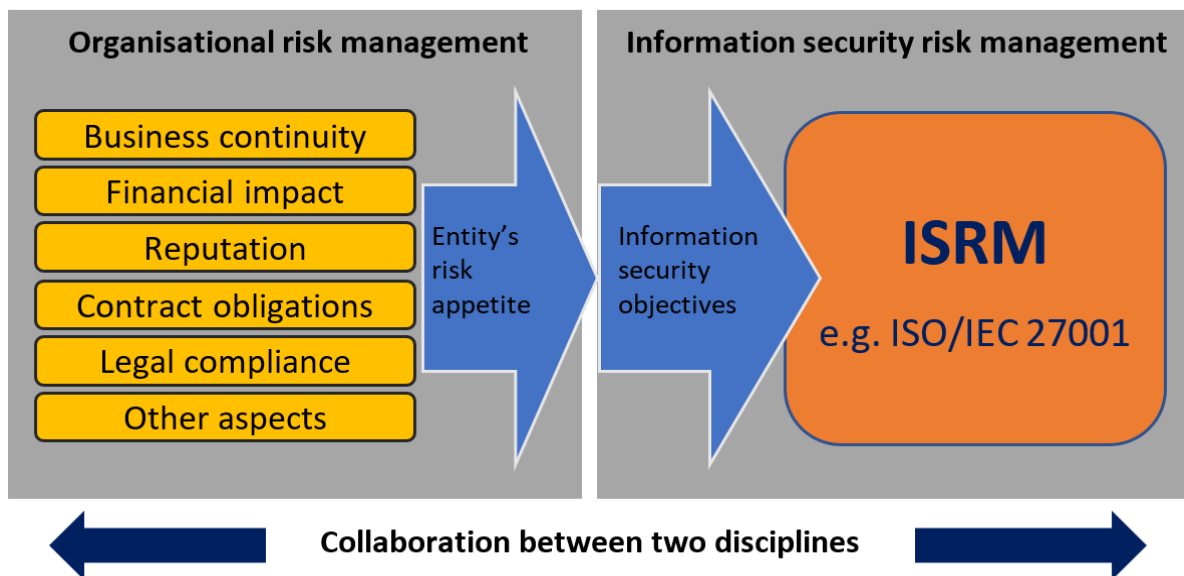


Figure 4: Relation between the entity's risk appetite and the information security objectives

The requirements for an ISMS specified by this Regulation are in most parts consistent and aligned with ISO/IEC 27001; however, this Regulation introduces provisions specific to the context of aviation safety. If an ISO/IEC 27001-based ISMS is already operated by an entity for a different scope and context, it can be adapted and extended to the scope and context of this Regulation in a straightforward manner based on an analysis of the scope and the gaps. In order to take credit from ISO/IEC 27001 certifications to achieve compliance with Part-IS, aviation safety needs to be included in the organisational risk management, with the relevant risk acceptance level determined by the applicable regulation (see Figure 5). Therefore, careful determination of the scope of the ISMS related to aviation safety risks is needed, as it might differ from the one related to the other organisational risks. To allow demonstration of compliance with Regulation (EU) 2023/203, careful delineation between aspects of the ISMS related to aviation safety risks and other organisational risks may be required. This could have an influence upon the decision to integrate ISMSs.

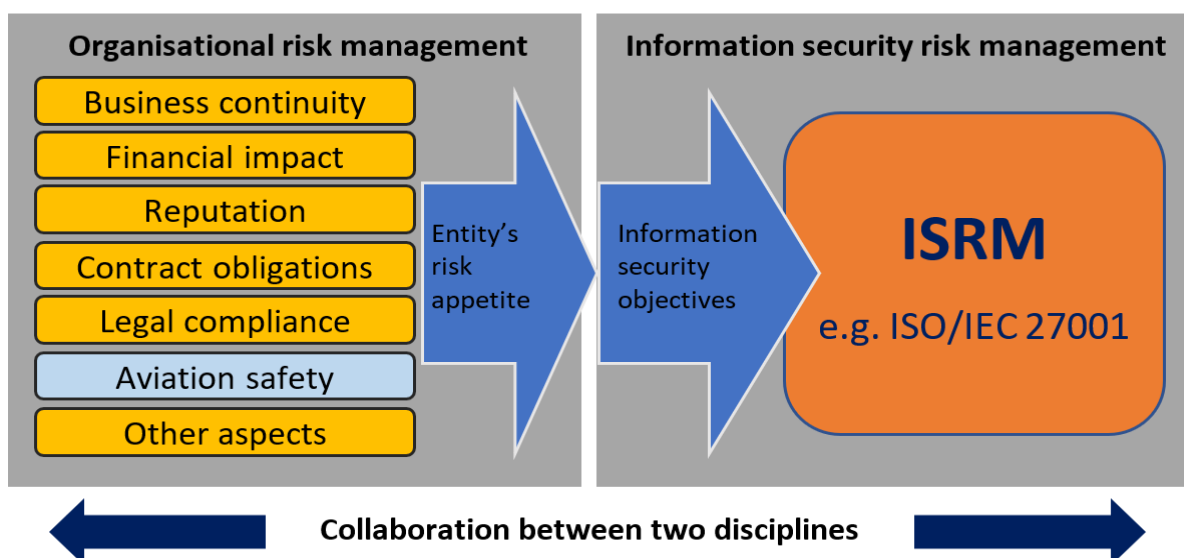


Figure 5: Introduction of aviation safety aspects in the entity's risk appetite

PART-IS versus ISO/IEC 27001:2022 cross reference table

For a mapping between the Part-IS provisions and the clauses and associated controls in ISO/IEC 27001:2022, refer to [Appendix IV](#).

AMC1 IS.AR.200(a)(1) Information security management system

ED Decision 2023/010/R

The competent authority should define and document the scope of the ISMS, by determining activities, processes, supporting systems, and identifying those which may have an impact on aviation safety.

The information security policy should be endorsed by the person identified as per [IS.AR.225\(a\)](#) and reviewed at planned intervals or if significant changes occur. Moreover, the policy should cover at least the following aspects with a potential impact on aviation safety by:

- (a) committing to comply with applicable legislation, consider relevant standards and best practices;
- (b) setting objectives and performance measures for managing information security;
- (c) defining general principles, activities, processes for the competent authority to appropriately secure information and communication technology systems and data;
- (d) committing to apply ISMS requirements into the processes of the competent authority;
- (e) committing to continually improve towards higher levels of information security process maturity as per [IS.AR.235](#);
- (f) committing to satisfy applicable requirements regarding information security and its proactive and systematic management and to the provision of appropriate resources for its implementation and operation;
- (g) assigning information security as one of the essential responsibilities for all managers;
- (h) committing to promote the information security policy through training or awareness sessions within the competent authority to all personnel on a regular basis or upon modifications;
- (i) encouraging the implementation of a 'Just-Culture' and the reporting of vulnerabilities, suspicious/anomalous events and/or information security incidents;
- (j) committing to communicate the information security policy to all relevant parties, as appropriate.

Note: A significant change is a notable alteration or modification that has a meaningful impact on the competent authority operations, such as a structural change within the authority due to reorganisations, a change in the business processes (e.g. working from home, use of personal devices), a technological evolution (e.g. distributed computing resources, artificial intelligence/machine learning) or an evolution in the threat landscape.

GM1 IS.AR.200(a)(1) Information security management system (ISMS)

ED Decision 2023/010/R

INFORMATION SECURITY POLICY AND OBJECTIVES

The information security policy should suit the competent authority's purpose and direct its own information security activities. Such policy should contain the needs for information security in the competent authority's context, a high-level statement of direction and intent of the information security activities, the principles and most important strategic and tactical objectives to be achieved by the ISMS, as well as the general information security objectives or a specification of a framework (who, how) for setting information security objectives. The information security policy should also contain a description of the established ISMS, including roles, responsibilities and references to topic-specific policies and standards.

The information security objectives should be:

- consistent and aligned with the information security policy and consider the applicable information security requirements, derived from the overarching competent authority's objectives, and the results from the risk assessment and treatment (which, in turn, supports the implementation of the competent authority's strategic goals and information security policy);
- regularly reviewed to ensure that they are up to date and still appropriate;
- measurable if practicable (to be able to determine whether the objective has been met), aimed to be SMART (specific, measurable, attainable, realistic, timely) and aligned with all affected responsible persons.

When defining information security objectives, e.g., based on the overarching competent authority's objectives, the information security requirements or the results of risk assessments, it should be determined how these objectives will be achieved. The degree to which information security objectives are achieved must be measurable. If possible, it should be measured by key performance indicators (KPIs) which have been defined in advance (refer to resources such as COBIT 5 for Information Security). It is recommended to start with the definition of a limited number of information security objectives which are relevant for the competent authority, more of a long-term nature and measurable with a reasonable effort relative to the delivered benefits.

AMC1 IS.AR.200(a)(8) Information security management system (ISMS)

ED Decision 2023/010/R

COMPLIANCE MONITORING

When establishing compliance with the provisions under point [IS.AR.200\(a\)\(8\)](#), the competent authority should implement a function to periodically monitor compliance of the management system with the relevant requirements and adequacy of the procedures including the establishment of an internal audit process and an information security risk management process. Compliance monitoring should include a feedback mechanism of audit findings to the person of the competent authority as identified in [IS.AR.225\(a\)](#) to ensure implementation of corrective actions as necessary.

GM1 IS.AR.200(a)(8) Information security management system (ISMS)

ED Decision 2023/010/R

COMPLIANCE MONITORING

For the purpose of compliance monitoring, internal audits should be conducted at planned intervals to provide assurance on the status of the ISMS to the management and to provide information on the following:

- conformity of the ISMS to the requirements of this Regulation and the competent authority's own requirements either stated in the information security policy, procedures and contracts or derived from information security objectives or outcomes of the risk treatment process;
- effective implementation and maintenance of the ISMS.

Internal audits should follow an independent approach and a decision-making process based on evidence. Moreover, when setting up an audit programme, the importance of the processes concerned, and definitions of the audit criteria and scopes should be considered. Documented information should be retained evidencing the audit results, their reporting to the relevant management and the audit programme.

AMC1 IS.AR.200(a)(9) Information security management system (ISMS)

ED Decision 2023/010/R

When establishing compliance with the provisions under points [IS.AR.200\(a\)\(9\)](#), the competent authority should implement and maintain information security controls that are sufficiently robust and effective to protect information and ensure the need-to-know principle (i.e. limiting access to information to only those who need it to perform their duties). It should protect the source of information in accordance with the relevant provisions established in Regulation (EU) 2018/1139. It should also comply with Regulation (EU) No 376/2014.

AMC1 IS.AR.200(a)(11) Information security management system (ISMS)

ED Decision 2023/010/R

When establishing compliance with the provisions under point [IS.AR.200\(a\)\(11\)](#), the competent authority should implement and maintain a process to proactively share applicable and relevant information for performing information security risk assessments with other competent authorities, the Agency and other affected organisations within the scope of this Regulation, as soon as it becomes aware of such information. The competent authority should define and document which kind of information needs to be shared and with whom.

AMC1 IS.AR.200(c) Information security management system (ISMS)

ED Decision 2023/010/R

When establishing compliance with the provisions under point [IS.AR.200\(c\)](#), the competent authority should:

- (a) provide an outline of the structure of the specific information security personnel (internal and external), including their roles and responsibilities that will be used to manage and maintain the elements included within the scope of the ISMS and will be approved by the person identified in [IS.AR.225\(a\)](#). The competent authority should review the outline of the structure at planned intervals or if significant changes occur (see the Note in [AMC1 IS.AR.200\(a\)\(1\)](#));
- (b) identify and categorise all relevant contracted organisations or qualified entities used to implement the ISMS. The competent authority should define and document procedures for the management of interfaces with all other entities and coordination between the competent authority and other national authorities, contracted organisations or qualified entities;
- (c) identify and define all key processes and procedures, and internal and external reporting schemes that will be used to maintain compliance with the objectives of this Regulation over the life cycle of the ISMS. The competent authority may adjust existing processes or procedures for compliance;
- (d) identify and document any other information that will be used to maintain compliance with the objectives of this Regulation;
- (e) when creating and updating documented information, ensure appropriate identification and description (e.g. a title, date, author, or reference number) as well as a review and an approval for suitability and adequacy;
- (f) control the documented information required by the ISMS to ensure that it is:
 - (1) available and suitable for use, where and when it is needed;
 - (2) adequately protected (e.g. from loss of confidentiality, improper use, or loss of integrity).

GM1 IS.AR.200(c) Information security management system (ISMS)

ED Decision 2023/010/R

The amount of documented information that should be developed to maintain compliance with the objectives of this Regulation may vary between competent authorities due to various factors, such as size and complexity, or the need for harmonisation with other management processes already in place. As general guidance, taking into account the documents required to comply with point [IS.AR.200\(a\)](#) and the record-keeping requirements referred to in [IS.AR.230](#), the following is a non-exhaustive list of information that should be documented:

- (a) information security policy that should include the authority's information security objectives — see [IS.AR.200\(a\)\(1\)](#);
- (b) responsibilities and accountabilities for roles relevant to information security — see the personnel requirements referred to in points [IS.AR.225\(a\)](#) and (b) and the related AMC and GM;
- (c) scope of the ISMS and the interfaces with, and dependencies on, other parties — see [IS.AR.200\(a\)\(2\)](#) and the information security requirements referred to in points [IS.AR.205\(a\)](#) and (b);

- (d) information security risk management process — see the information security requirements referred to in points [IS.AR.205](#) and [IS.AR.210](#);
- (e) archive of the risks identified in the information security risk assessment along with the associated risk treatment measures (often referred to as ‘risk register’ or ‘risk ledger’) — see [IS.AR.230](#);
- (f) evidence of the competencies necessary for the personnel performing the activities required under this Regulation — see [IS.AR.225](#)(c) and the related AMC and GM;
- (g) evidence of the current competencies of the personnel performing the activities required under this Regulation — see [IS.AR.230](#)(b)(1);
- (h) (key) performance indicators derived from evidence of the monitoring and measurement of the ISMS processes.

GM1 IS.AR.200(d) Information security management system (ISMS)

ED Decision 2023/010/R

PROPORTIONALITY IN ISMS IMPLEMENTATION

When implementing the processes and procedures, as well as establishing the roles and responsibilities required under point [IS.AR.200](#)(d), the competent authority should primarily consider the risks that it may be posing to other organisations, as well as its own risk exposure. Other aspects that may be relevant include the authority’s needs and objectives, information security requirements, its own processes, and the size, complexity and structure of the authority, all of which may change over time.

INTEGRATION OF ISMS UNDER THIS REGULATION WITH EXISTING MANAGEMENT SYSTEMS

A competent authority may take advantage of existing management systems when implementing an ISMS by integrating it with those existing systems.

By integrating the ISMS with existing management systems, the competent authority may reduce the effort and costs required to implement and maintain the ISMS, while also ensuring consistency and alignment with the authority’s overall management approach. Below is a non-exhaustive list of potential synergies that can be exploited when integrating the ISMS with an existing management system:

- Leverage existing policies and procedures: an authority may use its existing policies and procedures as a foundation for its ISMS. This may help to ensure consistency and minimise the need for additional documentation.
- Align the ISMS with other management systems: an authority may align the ISMS with other management systems, such as safety management systems (SMSs), to ensure that the ISMS is consistent with the authority’s overall management approach.
- Use existing risk management processes: an authority may use their existing risk management processes to identify and assess the information security risks potentially leading to aviation safety risks.
- Reuse existing controls: an authority may reuse existing controls, such as access controls or incident management process, to implement the information security controls required by the ISMS.
- Continuous improvement process: an authority may use the continuous improvement process of existing management systems to improve the ISMS over time.

IS.AR.205 Information security risk assessment

Regulation (EU) 2023/203

- (a) The competent authority shall identify all the elements of its own organisation which could be exposed to information security risks. This shall include:
- (1) the competent authority's activities, facilities and resources, and the services the competent authority operates, provides, receives or maintains;
 - (2) the equipment, systems, data and information that contribute to the functioning of the elements referred to in point (1)
- (b) The competent authority shall identify the interfaces that its own organisation has with other organisations, and which could result in the mutual exposure to information security risks.
- (c) For the elements and interfaces referred to in points (a) and (b), the competent authority shall identify the information security risks which may have a potential impact on aviation safety.

For each identified risk, the competent authority shall:

- (1) assign a risk level according to a predefined classification established by the competent authority;
- (2) associate each risk and its level with the corresponding element or interface identified in accordance with points (a) and (b).

The predefined classification referred to in point (1) shall take into account the potential of occurrence of the threat scenario and the severity of its safety consequences. Through this classification, and taking into account whether the competent authority has a structured and repeatable risk management process for operations, the competent authority shall be able to establish whether the risk is acceptable or needs to be treated in accordance with point [IS.AR.210](#).

In order to facilitate the mutual comparability of risks assessments, the assignment of the risk level per point (1) shall take into account relevant information acquired in coordination with the organisations referred to in point (b).

- (d) The competent authority shall review and update the risk assessment carried out in accordance with points (a), (b) and (c) in any of the following cases:
- (1) there is a change in the elements subject to information security risks;
 - (2) there is a change in the interfaces between the competent authority's organisation and other organisations, or in the risks communicated by the other organisations;
 - (3) there is a change in the information or knowledge used for the identification, analysis and classification of risks;
 - (4) there are lessons learnt from the analysis of information security incidents.

GM1 IS.AR.205 Information security risk assessment

ED Decision 2023/010/R

Part-IS does not require the use of any specific information security framework, such as ISO, NIST or others to develop the risk assessment or in general to implement risk management. Each framework offers different benefits and none of these frameworks is perfect for an individual competent

authority, and should be customised and tailored to meet the overall needs of a competent authority as well as the specific need to consider aviation safety aspects.

Competent authorities whose information security frameworks have achieved industry certifications can provide this information as supporting artefacts; however, these competent authorities should show the applicability of the industry certification to the scope of this Regulation (see [GM1 IS.AR.200](#)).

General guidance on risk management, including risk assessment, can be found in ISO/IEC 27005 and ISO/IEC 31000 as well as NIST SP 800-30. Competent authorities may also wish to consider aviation-specific guidance as defined in the risk management chapter of the latest version of EUROCAE ED-201A and, as appropriate to the specific operating environment, in the chapters of EUROCAE ED-204A, EUROCAE ED-205A and EUROCAE ED-206 covering risk management.

AMC1 IS.AR.205(a) Information security risk assessment

ED Decision 2023/010/R

When conducting an information security risk assessment, the competent authority should ensure that all relevant aviation safety elements are identified and included in the ISMS scope as per [IS.AR.200](#) and related AMC.

A means to comply with the requirement in point [IS.AR.205\(a\)](#) is to perform a preliminary high-level risk assessment or impact assessment, carried out in accordance with a documented methodology and following precise criteria for the inclusion in and exclusion from the ISMS scope of the elements listed in [IS.AR.205\(a\)](#).

GM1 IS.AR.205(a) Information security risk assessment

ED Decision 2023/010/R

SCOPE AND BOUNDARIES IDENTIFICATION

The competent authority should develop clear and comprehensive understanding of its aviation activities and services, the related processes and associated information systems, and the relevant data flows and information exchanges that define the scope of the ISMS and the boundaries for risk assessment. Therefore, the competent authority should develop corresponding documentation on resources and dependencies related to computing, networking and contracted services which have the potential to affect the information security and safety of the functions, services or capabilities within the scope of the risk assessment.

The following non-exhaustive list provides examples of items that may be considered for the identification of the aforementioned scope and boundaries. The level of detail of the analysis can be an iterative process, with the effort commensurate with the expected level of risk. As stated above, the purpose is to establish understanding of all relevant assets, resources and dependencies that are directly a part of the functions, services and capabilities through the following activities:

- (a) Identification of operational inputs and outputs relevant to the functions, services and capabilities of the authority; these can be related to:
 - internal or external sources;
 - internal or external leased or managed services, or other dependencies;
- (b) Identification of all relevant assets (i.e. hardware, software, network and computing resources) used to create, process, transmit, store or receive the aforementioned operational inputs and outputs;

- (c) Identification of the operating environments (e.g. office, public access area, access-controlled room, etc.) and locations for all relevant assets;
- (d) For each asset included in the scope, identification of the specific methods, processes and resources that will be used to manage, operate and maintain each asset throughout its life cycle, including:
 - internal or contracted resources;
 - contracted companies remotely managing the assets (i.e. provider of managed services).

AMC1 IS.AR.205(b) Information security risk assessment

ED Decision 2023/010/R

The competent authority should, as part of the information security risk assessment, identify the interfaces it has with other parties such as service providers, supply chains and other third parties, based on the exchange of data and information and the assets used for that exchange, which could lead to a situation where information security risks, as a result of mutual exposure, may either:

- increase aviation safety risks faced by other parties; and/or
- increase aviation safety risks faced by the organisation.

GM1 IS.AR.205(b) Information security risk assessment

ED Decision 2023/010/R

RISK INFORMATION SHARING

Interfacing parties should share information with each other about the potential exposure to information security risks by following, for instance, the approach detailed in EUROCAE ED-201A Appendix B — B.1, B.2 and B.3. The purpose of this exchange of information is to enable the parties to establish a matching mapping for the services identified under [IS.AR.205\(a\)](#), including information and data flows, in order to:

- (a) illustrate (e.g. through a functional diagram) the relationships of logical and physical paths connecting the different parts involved;
- (b) clearly identify all assets (i.e. hardware, software, network and computing resources) that will be used in the exchange;
- (c) identify all functions, activities and processes, including their respective information and data, which will be created, transmitted, processed, received and stored, and associate those with the responsible party which provides or performs those functions, activities and processes;
- (d) determine for these paths, constituting the so-called functional chains, the role of the interfacing party as a producer, processor, dispatcher, or consumer of the information or data involved;
- (e) determine whether one interfacing party acts as an originator or receiver of a flow across such path.

TWO CATEGORIES OF INTERFACING ORGANISATIONS

There are two categories of interfacing organisations: those that are subject to Regulation (EU) 2023/203 or Regulation (EU) 2022/1645, and those that are not.

Where the competent authority has interfaces with an organisation that is subject to Regulation (EU) 2023/203 or Regulation (EU) 2022/1645, each entity:

- is responsible for the identification of the interfaces that its own organisation has with other organisations, and which could result in the mutual exposure to information security risks. The entity may benefit from the sharing of risk information as this exchange allows for a more accurate assessment of those risks.
- remains accountable for the proper management of the information security risks within the scope of its own ISMS.

In all other cases, the competent authority is accountable for the proper management of the information security risks that may arise from its exposure to the interfacing entity. Where these risks need to be treated, the competent authority always has the option of implementing mitigating measures and controls within its own boundaries. In the specific case where the interfacing entity is a supplier, the competent authority may decide to manage the risks through contractual arrangements and require the supplier to implement mitigating measures and controls within its own organisation.

GM2 IS.AR.205(b) Information security risk assessment

ED Decision 2023/010/R

EXAMPLES OF AVIATION SERVICES

Examples of aviation services that may be considered when determining the ISMS scope and interfaces are provided in [Appendix III](#).

AMC1 IS.AR.205(c) Information security risk assessment

ED Decision 2023/010/R

The competent authority should use a risk management framework that includes a methodology for assigning risks with a risk level and establishing criteria for determining risk acceptance or further treatment.

The competent authority should provide documented evidence of assessment of risks which have a potential impact on aviation safety including the level of risks. The competent authority should associate each risk with the relevant elements and interfaces identified under [IS.AR.205](#) (a) and (b), and document whether the risk is acceptable or requires further treatment.

The competent authority should provide the assurance that the risk assessment process is carried out with the necessary rigour and discipline by documenting the process and its robustness. By doing so, the competent authority should consider:

- (a) reproducibility of the assessment's inputs and results;
- (b) repeatability of the assessment over time in a way that the results of the different prior assessments can be compared to determine the changes;
- (c) the gathering of inputs that are relevant and valid, in particular:
 - (1) the information that allows the determination of the safety consequences;
 - (2) the information that allows the determination of the potential of occurrence of the threat scenario;

- (d) iterative refinement over time allowing for more fine-grained threat scenarios as inputs to become available, with the aim of reducing uncertainty regarding threats, vulnerabilities, effectiveness of existing controls, and dependencies on external entities, in particular by:
- (1) refining initial high-level threat scenarios with greater detail and specificity as more data is gathered;
 - (2) refining data on known vulnerabilities by continuously updating information about their exploitability and the associated consequences;
 - (3) reviewing the effectiveness of existing controls, and consider newly available controls;
 - (4) refining the understanding of the dependencies on external entities and their implications for the competent authority's risk profile.

GM1 IS.AR.205(c) Information security risk assessment

ED Decision 2023/010/R

RISK ASSESSMENT

The risk classification levels for potential of occurrence of the threat scenario and severity of the safety consequences listed below may be applied; however, this does not prevent the competent authority from developing additional intermediate categories if it deems this necessary for risk assessments. The competent authority should specify and document the applied, entity-specific classification levels with an accurate qualitative or quantitative definition in terms of a range or interval of numerical values in order to enable a sufficiently calibrated, consistent estimation, evaluation and communication within the competent authority or with the interfacing entities. The potential of occurrence of the threat scenario may be expressed as an interval of likelihoods including the duration of the observation. Supporting documentation and methods can be found in EUROCAE ED-203A, Chapter 3.6 which references the evaluation of the potential of occurrence of the threat scenario in the Security Risk Assessment of EUROCAE ED-202A.

Note 1: The phrase 'duration of the observation' refers to the time period during which a threat scenario is observed or monitored. It is essential in determining the likelihood of the threat scenario occurring, since the probability of occurrence may vary depending on the length of the observation period.

Note 2: EUROCAE ED-202A and EUROCAE ED-203A were originally developed for aircraft information security risk assessment, but the generic principles developed in those documents can be adapted to other frameworks when deemed useful by the authority.

In order to facilitate the mutual comparability of risks assessment methodologies between interfacing entities, the competent authority may associate the assessment of the potential of occurrence of the threat scenario with one of the following categories:

- High potential of occurrence: the threat scenario is likely to occur. The attack related to the threat scenario is feasible and similar threat scenarios have occurred many times in the past.
- Medium potential of occurrence: the threat scenario is unlikely to occur. The attack related to the threat scenario is possible and a similar threat scenario may have occurred in the past.
- Low potential of occurrence: the threat scenario is very unlikely to occur. The materialisation of the threat scenario is theoretically possible; however, it is not known to have occurred.

The evaluation of the potential of occurrence of the threat scenario may be based on the following aspects:

Protection (as defined in EUROCAE ED-203A)

- Security measures and architecture that deny access to assets: the degree to which an asset is open to access from compromised systems
- Access to security measures: the degree to which a security measure prevents access/attack to itself from compromised systems
- Failure of mechanism: the degree to which the known implementation of a security measure will fail to prevent an attack
- Detection methods or procedures to recognise the attack and appropriately respond to reduce the potential of occurrence of the threat scenario

Exposure reduction (as defined in EUROCAE ED-203A)

- Conditions under which an external access connection can be used by a user or attacker
- Limits on the functionality of an external access connection
- Organisational policies that control the time-to-feasibility for developing attack tools specific to the product
- Vulnerability management including intelligence, scanning, treatment and retesting aimed to discover, detect and treat reported or detected vulnerabilities in a fast, risk-prioritised manner with high assurance in order to reduce the attack surface
- Reduction of the severity of a successful attack (i.e. through a redundant system that can maintain the continuity of service in case of a denial of service of a system critical for aviation safety)

Attack attempt (as defined in EUROCAE ED-203A)

- The capability of the attackers which is determined by the resources and expertise required for their attack

The capability of the attackers can be assessed through several ways, for instance:

- information from computer emergency response teams (CERTs) / computer security incident response teams (CSIRTs), information sharing and analysis centres (ISACs);
- analyses of past activities, tactics, techniques and procedures (TTPs) and success rate of attacks.

For the same reason, the competent authority may associate the outcome of the evaluation of the severity of the safety consequences with one of the following categories:

- High severity: those immediate or delayed scenarios that can cause or contribute to an unsafe condition where an unsafe condition means an occurrence associated with the operation of an aircraft in which:
 - a person is fatally or seriously injured;
 - the aircraft sustains damage or structural failure;
 - the aircraft is either missing or completely inaccessible;
- Moderate severity: those immediate or delayed scenarios that can cause or contribute to safety incidents where an incident means any occurrence other than an accident, associated with the operation of an aircraft, which affects or could affect the safety of operations;

- Low severity: those immediate or delayed scenarios that can cause or contribute to negligible safety consequences.

Examples for high, moderate, and low severity can be found in EUROCAE ED-201A, Appendix B for products, ATM systems and airspace.

If the competent authority cannot determine the safety effect, the assessment should identify assumptions from the risk-sharing information at interfaces with other organisations along the functional chain, leading up to the safety effect.

Some of those assumptions can be granted with the certification of products: where assets are subject to product certification from other aviation regulations addressing product information security, the organisation performing the risk assessment may consider the perimeter of the product certification as already covered. This should be acceptable under the condition that this certification is up to date and that the instructions provided by the OEM to maintain the certification validity are implemented by the organisation.

Additional information can also be found in Regulation (EU) 2015/1018 on mandatory reporting of occurrences. Further examples of impact severity classifications for aviation domains can be found in EUROCAE ED-201A, Appendix B — Tables B-5, B-6 and B-7.

Risk acceptance criteria

Risk acceptance criteria are critical and should be developed, specified and documented. The criteria may define multiple thresholds, with a desired target risk level, but allowing also for the person identified in [IS.AR.225\(a\)](#) to accept risks above this level under defined circumstances and conditions.

In order to facilitate the mutual comparability of risk assessments between interfacing entities, the competent authority should classify the risks in the following categories:

- unacceptable risk;
- conditionally acceptable risk;
- acceptable risk.

For what concerns the conditional acceptance of risks, the criteria for acceptance should take into account how long a risk is expected to exist (temporary or short-term activity or exposure), or may include requirements for the commitment of future treatments to reduce the risk at an acceptable level within a defined time duration, and show how the risk will be managed over time through the authority's risk governance processes.

Moreover, risks should be conditionally accepted only under the condition that the competent authority demonstrates the presence of a comprehensive risk management structure that includes risk assessment, risk treatment and risk monitoring processes for operations. The risk management should consider the variability and consistency of threat likelihood, vulnerability, existing controls, external dependencies, and safety impact. This is typically achieved when the competent authority reaches a higher level of maturity that is representative of functionality and repeatability of information security risk management — see [GM1 IS.AR.235\(a\)](#).

The following Figure 1 depicts a risk acceptance matrix based on the aforementioned categories that can be used by interfacing organisations for mutual comparability.

ICAO Annex 13 >	Negligible effect	Incident	Accident
Threat scenario potential of occurrence	Low safety consequences	Moderate safety consequences	High safety consequences
High	Conditionally acceptable	Not acceptable	Not acceptable
Medium	Acceptable	Conditionally acceptable	Not acceptable
Low	Acceptable	Acceptable	Conditionally acceptable*

Figure 1: Example of a risk acceptance matrix for comparison purposes

* The potential of occurrence of the threat scenario is reassessed in a timely manner (refer to [IS.AR.205\(d\)](#)) and monitored to ensure that it remains low and that if the risk materialises, it is early detected and dealt with.

A comprehensive risk management structure typically entails the following aspects and processes:

- a repeatable and reproduceable risk assessment. If the risk factors are considered fairly uncertain and within some wide value range or not sufficiently precise, further iterations of the risk assessment are performed involving additionally gathered or detailed information and a more in-depth assessment in order to reduce uncertainty and increase precision;
- a thorough review of those risks proposed to be conditionally acceptable that is performed by the person identified in [IS.AR.225\(a\)](#) who may impose additional conditions for the risk retention, including risk treatment measure and the timeline for its implementation;
- strict monitoring of the key risk indicators that includes a defined, reliable detection of the potentially evolving risk materialisation;
- an incident response scheme is in place with reactive measures that are triggered by detection mechanisms in order to immediately contain the consequences, in particular, for risk scenarios involving a high severity level.

Note: As detailed in NIST SP-800 Rev.1, repeatability refers to the ability to repeat the assessment in the future, in a manner that is consistent with and hence comparable to prior assessments —enabling the organisation to identify trends. Therefore, a risk assessment process can be classified as ‘repeatable’ when under similar conditions an entity or a person delivers consistent results.

As detailed in NIST SP-800 Rev.1, reproducibility refers to the ability of different experts to produce the same results from the same data. Therefore, a risk assessment process can be classified as ‘reproducible’ when another entity or person, given the same inputs, assumptions, information security context and threat environment can replicate the same steps and reach the same conclusions.

Threat scenario identification

A threat scenario is one of the possible ways a threat could materialise. Typically, a threat scenario describes a potential attack targeting one or more vulnerabilities of assets, as well as processes.

The purpose of the threat scenario identification under this Regulation is to develop a list of scenarios that may lead to an information security threat having an impact on aviation safety.

A threat scenario, in general, is characterised by the following:

- a threat source of the information security attack;
- an attack vector and a path through the organisation up to the asset;
- the information security controls that would mitigate the attack;
- the consequence of the attack including the affected safety aspects.

Threat scenario identification guidance can be found in EUROCAE ED-202A, Chapter 3.4. This is not the only source where guidance can be found, and the competent authority may refer to different guidance more appropriate for their application.

Additional methods to identify relevant threat scenarios

When conducting this analysis, both information security and safety aspects should be coordinated throughout the process to ensure mutual understanding of the threat preventive measures and mitigating measures being applied. In the following Figure 2 the interactions between information security and aviation safety are depicted through a ‘bow-tie’ diagram that highlights the links between risk controls and the underlying management system.

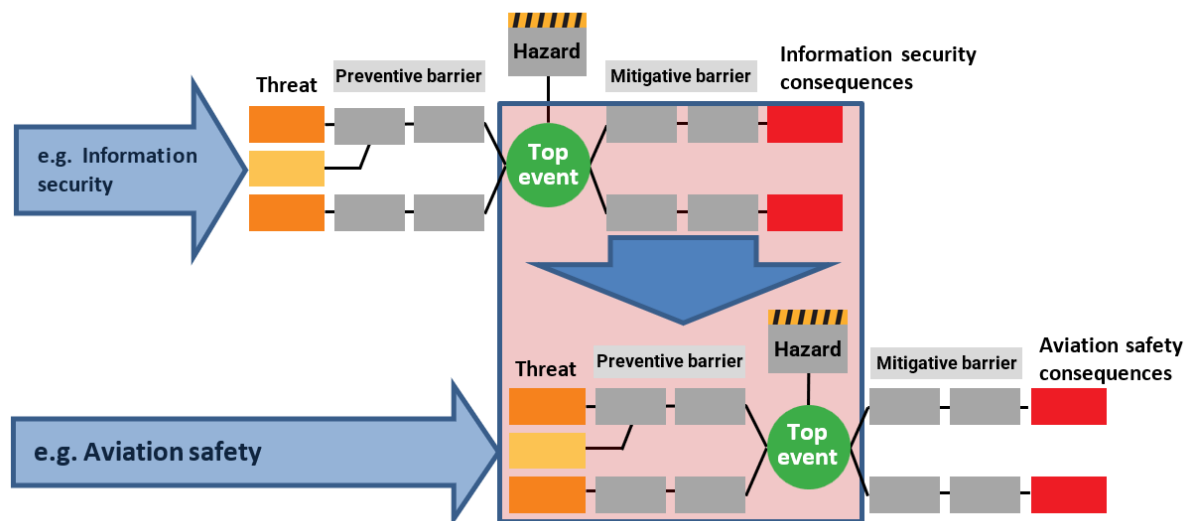


Figure 2: Interactions between information security and aviation safety risk management areas

Note: A preventive barrier or measure is a proactive action or control implemented to reduce the likelihood of a risk, hazard, or threat materialising, while a mitigating measure is an action or control designed to reduce the severity or impact of an undesired event, would it occur.

Examples of threat scenarios

Threat catalogues may provide guidance and elements for the elaboration of threat scenarios that are relevant for the organisation. References can be found in ARINC 811 – Att. 3 – Tables 3-7 and 3-8 for the threat catalogue examples and other threat catalogue examples as they are provided by EU institutions — for example, the ENISA threat taxonomy. However, this is not an exhaustive list of examples, and the identification of threat scenarios should therefore not be limited to those examples

only. In addition, other relevant resources containing information on information security threats and the information security threat landscape should be consulted to support the risk assessment process with relevant inputs.

A set of examples of threat scenarios can be found in [Appendix I](#).

AMC1 IS.AR.205(d) Information security risk assessment

ED Decision 2023/010/R

The competent authority should take into account the following criteria when establishing compliance with the objectives contained in point [IS.AR.205\(d\)](#):

- (a) The risk assessment performed under points [IS.AR.205](#) (a), (b) and (c) should be reviewed at regular intervals to identify and account for relevant changes. The periodicity at which potential changes have to be evaluated should be determined by the authority performing the assessment considering the criticality of the assets within the scope of the risk assessment, levels of residual risk of the assets within the scope of the risk assessment and any contractual or regulatory requirements. A higher criticality or level of risk will require more frequent review.
- (b) The periodicity of risk assessment reviews should be documented by the competent authority and include the justification, date of approval and information about the risk owner.

GM1 IS.AR.205(d) Information security risk assessment

ED Decision 2023/010/R

The criteria to consider for the frequency of the risk assessment review may be the risk level as well as the criticality and complexity of the assets concerned. The objective of a risk assessment review is to trigger the revaluation of risks, their likelihood and impact in case of relevant changes. One possible way is to have a tiered approach to risk assessment, with a higher-level risk assessment being used for the identification of changes. The higher-level risk assessment could allow the identification of the detailed risks that should be reviewed in a next step. Risk assessments should be subject to regular reviews to:

- (a) allow for continuous improvement of the quality of risk assessment;
- (b) ensure efficiency and effectiveness of risk controls and mitigating measures in both their design and operation;
- (c) review plans and actions for risk treatment;
- (d) identify any organisational change which may require a review of the priorities as well as of the treatment of risks;
- (e) maintain an overview of the complete risk picture; and
- (f) identify any emerging risks.

Risk assessment reviews should involve the risk owners, project teams and other stakeholders as applicable. Evidence of risk assessment review should be documented and should include:

- evidence of approval of the review by the designated risk owner; and
- the rationale behind or basis for the risk owner's approval of the review.

Such evidence may comprise, but is not limited to:

- reports which constitute a form of documentation to track information security risks potentially impacting an organisation;
- the documentation of the information security risk assessment;
- exerts from a business or security risk registry.

The periodicity of risk assessment reviews should be documented by the authority in information security manuals, processes or procedures and should align with wider change management activities and management reviews of information security. Further guidance on criteria and frequency of risk assessment review can be found in EUROCAE ED-201A Chapter 4, as well as in EUROCAE ED-205A, Chapter 3.2 (for ATMS/ANS).

GM2 IS.AR.205(d) Information security risk assessment

ED Decision 2023/010/R

The following are examples of changes that should be identified during the risk assessment review as they may trigger an update of the risk assessments:

- (a) there is a change in the elements subject to information security risks as identified in [IS.AR.205\(a\)](#); a change in the elements will include:
 - additions to, or removals from, the scope of the risk assessment of individual elements;
 - changes to design or configuration of elements within the scope of the risk assessment that have the potential to alter the risk assessment outcomes; or
 - changes to values, which would potentially trigger changes to impact levels, of elements within the scope of the risk assessment;
- (b) there is a change in the interfaces between the authority and other parties with which the authority shares information security risks or relies upon to mitigate information security risks (e.g. supply chains, service providers, cloud providers and customers), as identified in [IS.AR.205\(b\)](#), or between the system within the scope of the risk assessment and any other interconnected systems, or in the risks notified to the authority by other parties, as identified in [IS.AR.205\(b\)](#), or owners or managers of the other systems including:
 - establishment of new interfaces;
 - removal of existing interfaces;
 - changes to existing interfaces that would have the potential to alter the risk assessment outcomes.

Note: Some organisational or system interconnections may be with entities that are not within the scope of this Regulation as defined in [Article 2](#) and therefore are not subject to the requirements of Part-IS. Where this is the case, these entities should be informed of their responsibility to report such changes as listed above, through contractual arrangements and reporting requirements between the affected entities on a case-by-case basis and where applicable;

- (c) there is a change in the information or knowledge used for the identification, analysis and classification of risks including:
 - changes to threats and their values or addition of new threats that have not previously been assessed;

- changes to vulnerabilities or addition of new vulnerabilities that have not previously been assessed;
 - changes in impacts or consequences of assessed threats or vulnerabilities;
 - changes in aggregation of risks that may result in unacceptable levels of risks;
 - changes or improvements in the risk management process, risk assessment approach and related activities;
 - changes or improvements in the treatments of risks;
 - changes in the criteria used to determine acceptance and treatments of risks;
- (d) there are lessons learned from the analysis of information security incidents including:
- understanding why and how incidents have occurred; and
 - reviewing all types of incidents including those due to external factors, technical reasons or human errors (inadvertent behaviour). For human intentional acts, a distinction can be made between malign and benign actions.

IS.AR.210 Information security risk treatment

Regulation (EU) 2023/203

- (a) The competent authority shall develop measures to address unacceptable risks identified in accordance with point [IS.AR.205](#), shall implement them in a timely manner and shall check their continued effectiveness. Those measures shall enable the competent authority to:
- (1) control the circumstances that contribute to the effective occurrence of the threat scenario;
 - (2) reduce the consequences to aviation safety associated with the materialisation of the threat scenario;
 - (3) avoid the risks.

Those measures shall not introduce any new potential unacceptable risks to aviation safety.

- (b) The person referred to in point [IS.AR.225](#)(a) and other affected personnel of the competent authority shall be informed of the outcome of the risk assessment carried out in accordance with point [IS.AR.205](#), the corresponding threat scenarios and the measures to be implemented.

The competent authority shall also inform organisations with which it has an interface in accordance with point [IS.AR.205](#)(b) of any risk shared between competent authority and the organisation.

GM1 IS.AR.210 Information security risk treatment

ED Decision 2023/010/R

Unacceptable risks identified in accordance with point [IS.I.OR.205](#) require a risk treatment process that may lead to the introduction of information security measures, often referred to as information security controls.

For each identified risk, the competent authority should define the specific risk treatment measures, methods or resources that will be used over the life cycle of each asset to:

- manage risk reduction;

- monitor and maintain each asset;
- update and fulfil activities for configuration management;
- manage supply chain;
- manage contracted services or service provider.

The review of risk treatment measures should include life cycle considerations which are introduced by equipment, procedures and personnel.

A risk treatment plan as an outcome of the risk management process should include a prioritisation of risks, the corresponding information on the objectives and means for risk treatment to reach an acceptable level of risk, as well as agreed timelines specifying by when responsible personnel should have implemented the risk treatment measures. The timelines for the implementation of a risk treatment measure should be agreed by the personnel responsible for the implementation and should be communicated to and accepted by the person identified in [IS.AR.225\(a\)](#).

Any subsequent implementation delay, together with its cause, reason, rationale or necessity, should be documented in the risk treatment plan, for risks that may lead to an unsafe condition. The delay is also subject to the acceptance by the person identified in [IS.AR.225\(a\)](#). The identified person may condition such acceptance on the implementation or availability of compensating controls or reactive measures to monitor, early detect and timely respond to the materialisation of the risk in treatment. In order to timely respond, the incident response team may be informed to trigger their preparedness.

The risk treatment plan can act as a means of communication with the Agency to demonstrate effective treatment of unacceptable risks. Similarly, this plan can be utilised to communicate to interfacing organisations how shared risks are controlled.

In accordance with [IS.AR.205\(d\)](#), a regular or conditional review of the risk assessment is necessary, and this includes the review of the risk treatment measures developed under [IS.AR.210\(a\)](#) to identify whether they are still effective or they require adaptations.

In addition, the competent authority should also consider the potential impact on the effectiveness of risk treatment measures where a shared information security risk may arise as a result of the interaction between interfacing entities (see [IS.AR.220](#) and related AMC).

AMC1 IS.AR.210(a) Information security risk treatment

ED Decision 2023/010/R

- (a) The risk treatment process should reach at least one of the objectives listed under [IS.AR.210\(a\)](#).
- (b) When establishing compliance with the objectives under points [IS.AR.210\(a\)\(1\)](#) and [IS.AR.210\(a\)\(2\)](#), the competent authority should take into account that:
 - (1) the measures developed under these points should be implemented according to a risk treatment plan with defined, risk-based priorities, objectives and agreed timelines and owners;
 - (2) life cycle considerations should be identified and associated to ensure continuous effectiveness of the information security measures including exchange of data with other entities;
 - (3) it should review and update the risk assessment, according to [IS.AR.205\(d\)](#), to evaluate whether the measures developed under these points introduce new unacceptable risks or modify existing risks into a way that they become unacceptable.

- (c) Risk treatment should be documented and recorded, for example, in a risk registry, even if the risk has been avoided.

IS.AR.215 Information security incidents — detection, response and recovery

Regulation (EU) 2023/203

- (a) Based on the outcome of the risk assessment carried out in accordance with point [IS.AR.205](#) and the outcome of the risk treatment performed in accordance with point [IS.AR.210](#), the competent authority shall implement measures to detect events that indicate the potential materialisation of unacceptable risks and which may have a potential impact on aviation safety. Those detection measures shall enable the competent authority to:
- (1) identify deviations from predetermined functional performance baselines;
 - (2) trigger warnings to activate proper response measures, in case of any deviation.
- (b) The competent authority shall implement measures to respond to any event conditions identified in accordance with point (a) that may develop or have developed into an information security incident. Those response measures shall enable the competent authority to:
- (1) initiate the reaction of its own organisation to the warnings referred to in point (a)(2) by activating predefined resources and course of actions;
 - (2) contain the spread of an attack and avoid the full materialisation of a threat scenario;
 - (3) control the failure mode of the affected elements defined in point [IS.AR.205\(a\)](#).
- (c) The competent authority shall implement measures aimed at recovering from information security incidents, including emergency measures, if needed. Those recovery measures shall enable the competent authority to:
- (1) remove the condition that caused the incident, or constrain it to a tolerable level;
 - (2) restore a safe state of the affected elements defined in point [IS.AR.205\(a\)](#) within a recovery time previously defined by its own organisation.

GM1 IS.AR.215 Information security incidents — detection, response and recovery

ED Decision 2023/010/R

Without prejudice to the definition of ‘information security event’ in [Article 3](#) of Regulation (EU) 2023/203, those events that indicate the potential materialisation of unacceptable risks include both occurrences (i.e. anything that causes harm or has the potential to cause harm) and discovery of vulnerabilities. In fact, information security risks are associated with the potential that threats will exploit vulnerabilities, therefore the discovery of an exploitable vulnerability is an information security event.

In light of this, in the context of this Regulation:

- detection activities required under [IS.AR.215\(a\)](#) include vulnerability discovery;
- response activities required under [IS.AR.215\(b\)](#) include vulnerability management.

AMC1 IS.AR.215(a) Information security incidents — detection, response and recovery

ED Decision 2023/010/R

DETECTION

When complying with the requirement in [IS.AR.215\(a\)](#), the competent authority should define and implement a strategy to detect information security incidents which may have a potential impact on safety.

This should be done in a way to ensure that at least the detection strategy is able to cover all known information security threats to their assets that may materialise in a safety hazard having an unacceptable consequence.

DETECTION STRATEGY

In order to determine the scope of the event detection, the competent authority should:

- (a) identify a list of threat scenarios from the risks identified under [IS.AR.205](#);
- (b) identify, as a minimum, those assets that, if compromised, contribute to the scenario(s) that may materialise in an unsafe condition. For this identification of the assets, the measures introduced under [IS.AR.210](#) should also be considered.

Note: The contribution of an asset to the threat scenario and the materialisation of an unsafe condition should be assessed also by considering the whole functional chain. In some cases, the asset may be at the end of a functional chain and if it is compromised, the effect on safety is direct and may be immediate; conversely, if the asset is far from the end of a functional chain and it is compromised, the effect should propagate and may be delayed.

GM1 IS.AR.215(a) Information security incidents — detection, response and recovery

ED Decision 2023/010/R

DETECTION STRATEGY

When developing the detection strategy, for those items within the scope of event detection, the competent authority should define the conditions that trigger a process that, for example, would require personnel intervention and further analysis. These conditions on the items may be defined using elements from the:

- (a) expected functional baseline: engage in the identification of deviations from the expected functional operation of the system (excluding information security functions/controls);
- (b) expected information security baseline: engage in the identification of deviations from the expected information security operation of information security controls.

These conditions should consider both abnormal behaviour and substantial deviations from the baselines and relevant correlation of multiple independent events.

Further guidance on the objectives for the establishment of a detection strategy can be found in EUROCAE ED-206, Chapter 4.

AMC1 IS.AR.215(b) Information security incidents — detection, response and recovery

ED Decision 2023/010/R

(a) INCIDENTS

The competent authority should take into account the following aspects when establishing compliance with the objectives contained in point [IS.AR.215\(b\)](#) relative to incidents:

- (1) Preparation of procedures and delineation of roles and responsibilities to respond in a timely, effective and orderly manner to any relevant information security incidents.
- (2) The response procedure should:
 - (i) consider the warnings, unitary or combined, from [IS.AR.215\(a\)\(2\)](#), and assess their potential impacts on aviationsafety;
 - (ii) establish, in accordance with [IS.AR.215\(b\)\(2\)](#), a containment strategy for each asset category considering the potential worst-case effect and the mission constraints, and provide criteria indicating when the incident is contained;
 - (iii) define, in accordance with [IS.AR.215\(b\)\(3\)](#), the acceptable impact on safety and information security of each asset in scope when they fail due to the materialisation of a threat scenario.
- (3) The response time should be commensurate with the impact level assessed in (2)(iii).
- (4) The response measures implemented under [IS.AR.215\(b\)](#) should be based on the response procedure referred to in the above point (a)(2) and they should, in particular, consider the following:
 - (i) the maximum acceptable safety level degradation of the assets within the scope of the incident;
 - (ii) the actions, such as resistance, containment, deception and control of the possible ways systems can fail, which will contribute to achieving the acceptable safety level degradation identified in point (i) while minimising impact on operations;
 - (iii) the resources required to implement the actions specified in point (ii).
- (5) The response time and the measures should take into account the potential immediate negative impact on safety if the measure is taken before it has been fully verified that it would not cause additional immediate safety impacts.

(b) VULNERABILITIES

The competent authority should take into account the following aspects when establishing compliance with the objectives contained in point [IS.AR.215\(b\)](#) relative to vulnerabilities:

- (1) Establishment of a vulnerability management strategy defining procedures, roles and responsibilities to respond in a timely, effective and orderly manner to any detected relevant vulnerabilities.
- (2) The response measures implemented under point [IS.AR.215\(b\)](#) should be based on the maximum acceptable risk of the items within the scope of the vulnerability, considering the worst-case scenario of the vulnerability being exploited.
- (3) The response time should be commensurate with the pre-triage done on the warnings and with the assessment of the potential impact of the vulnerability, if it is exploited.

GM1 IS.AR.215(b) Information security incidents — detection, response and recovery

ED Decision 2023/010/R

An attack is considered contained (i.e. it is not spreading any further) when the boundaries of the incident have been identified and the threat does not propagate beyond these boundaries. Further guidance can be found in EUROCAE ED-206 – Chapter 5.

The term ‘warning’ as used in [IS.AR.215](#) should be understood as an alert that would require timely awareness and response from the information security events management team.

In the context of information security response, ‘deception’ refers to a range of techniques that aim to mislead potential attackers or malicious users, thereby protecting the system and its data. Deception techniques, such as honeypots or breadcrumb trails, are designed to confuse, slow down, or divert attackers, increasing their cost and risk while providing defenders with valuable time and intelligence.

Guidance regarding the vulnerability management strategy can be found in EUROCAE ED-206, Chapter 3.4 — Vulnerability management considerations. This is not the only source where guidance can be found, and the organisation may refer to different guidance more appropriate for their application.

AMC1 IS.AR.215(c) Information security incidents — detection, response and recovery

ED Decision 2023/010/R

When complying with the requirement in [IS.AR.215\(c\)](#), the competent authority should develop an incident recovery procedure including at least the following:

- (a) a list of those assets that enable safe operations, as well as the dependencies among them, constituting the scope of the recovery;
- (b) a description of the process with the necessary priority actions to be executed for a return to a safe and secure state for the assets within the scope of the recovery;
- (c) the resources required to execute the actions defined in point (b) to ensure that these resources are readily available after an incident has occurred;
- (d) the objectives for recovery time that should be set in relation to the safety criticality of the assets within the scope of the recovery.

GM1 IS.AR.215(b)&(c) Information security incidents — detection, response and recovery

ED Decision 2023/010/R

RECOVERY OBJECTIVES AND TIMING

Point [IS.AR.215\(b\)](#) addresses event conditions which may develop or have developed into information security incidents, that may have a potential impact on aviation safety, and require response and recovery measures to be in place to ensure that operational safety remains above a minimum acceptable level.

The level of operations and safety may be interrelated, so in some cases when the level of operations is compromised by an information security incident and drops, the level of safety does the same. This

is, for instance, the case of air traffic control; if air traffic services are reduced or became unreliable, the safety of flights is reduced too.

However, in other cases the relation between the level of operations and safety may be the inverse, or they may be decoupled, so when an incident occurs and the level of operations drops, the level of safety is preserved. One example is the compromise of the software loading process on board the aircraft. In this case, a detected incident followed by the decision to interrupt the software loading operations would preserve the existing level of safety.

The following Figure 1 depicts a conceptual framework that may be considered for the definition of the response and recovery objectives, including the recovery time. It represents, in the worst-case scenario, how the expected level of operational safety (safety level) for a process or an activity may vary over time when an information security incident occurs. In this scenario, the safety level is first reduced by the incident and then it degrades as long as the time passes. The figure also shows the expected effect that mitigating measures and controls should have, respectively: in containing the operational safety drop as soon as an incident occurs, and in improving the recovery, i.e. the return to the expected safety level.

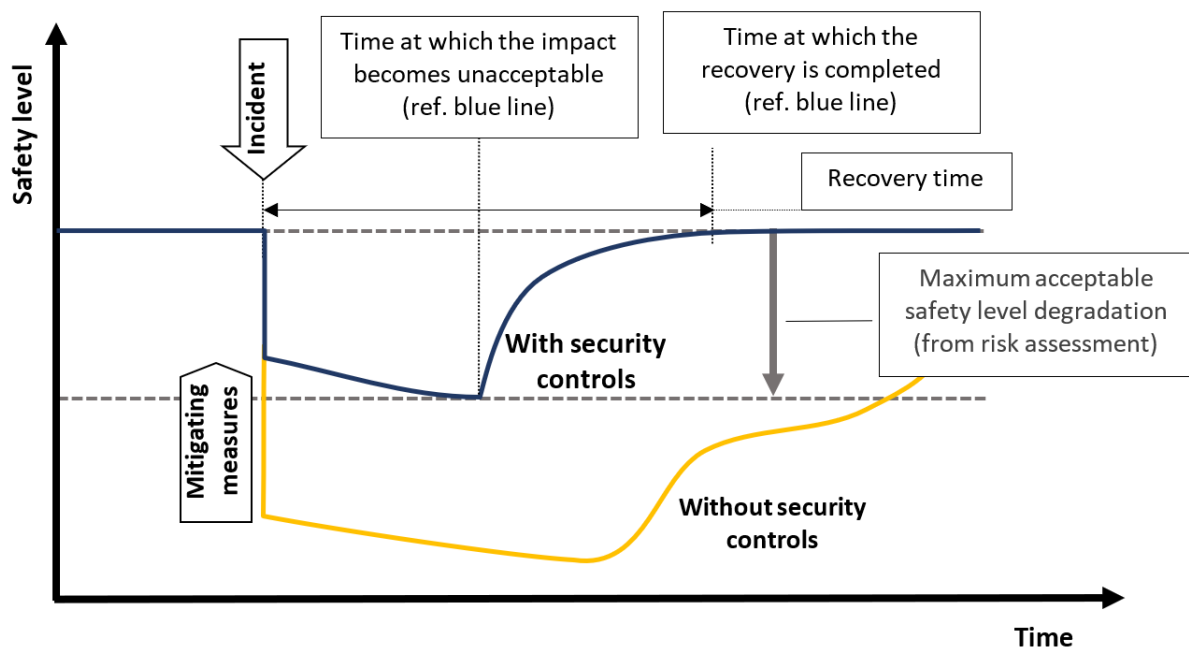


Figure 1: Conceptual framework for the definition of the response and recovery objectives

As mentioned, there might be different relations between the level of operations and safety that would lead to a different representation of the above figure. In certain cases, an incident may have a delayed effect on the safety level (e.g. a compromised development environment) as depicted in Figure 2, or it may have no impact if properly controlled, as in the case of the compromised software loading process mentioned before, which is depicted in Figure 3.

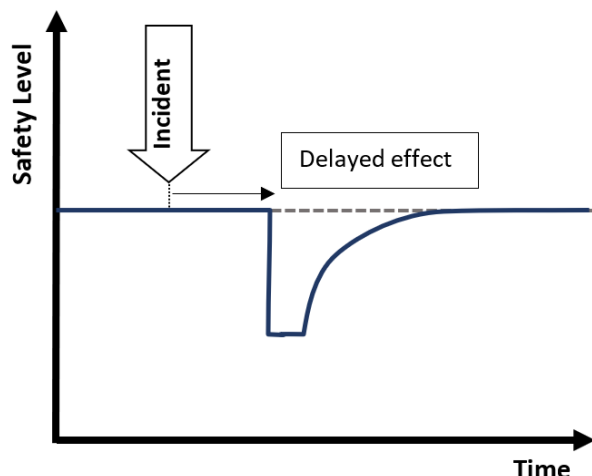


Figure 2: Incident with a delayed effect on safety

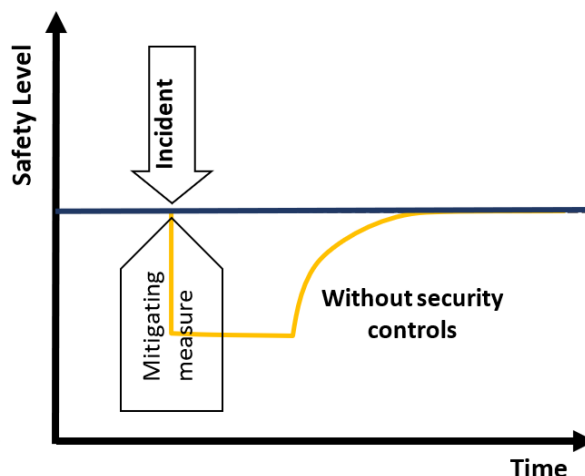


Figure 3: Incident with a fully mitigated effect on safety

Moreover, it should be noticed that there might be different ways the same incident can be dealt with since there are several factors that may affect safety.

In practical terms, the objectives for recovery time under [AMC1 IS.AR.215\(c\)](#) may be expressed as a list of resources and services to be restored by order of priority, within the scope of the recovery. Guidance about objectives for recovery time can be found in EUROCAE ED-206, Chapter 7.3.5.

GM1 IS.AR.215(c) Information security incidents— detection, response and recovery

ED Decision 2023/010/R

A recovery procedure or recovery plan should describe incident recovery actions and the internal or external resources that are involved (e.g. staff, IT, buildings, providers). Guidance about incident recovery plan can be found in ED 206, Chapter 7 – Recover.

The resources required to apply the recovery measures should be available in order to implement the recovery actions in a timely manner after an incident has occurred. Those resources may be internally available or provided by contracted organisations as provided for in [IS.AR.220](#). The contracting of recovery activities should be established before an incident occurs (proactive) and the contract should include provisions for the contracted party to react in a timely manner.

The return to a safe and secure state may initially require emergency measures, which are actions that are initiated based on the best information available at the time, before complete understanding of the situation is achieved and these measures can potentially degrade the level of service or functionalities. The return to a safe and secure state should be evaluated against the initial risk assessment and may only temporarily differ from the normal operational conditions. However, any increase of residual risk and the duration of this risk increase, i.e. due to the implementation of emergency measures, should be documented and accepted at the right level of accountability.

The recovery activities mentioned here may also be the outcome of the response to incidents for which the authority has received information that requires the implementation of adequate measures in order to react to information security incidents or vulnerabilities with a potential impact on aviation safety.

In such context the authority may not have a process or a recovery plan covering the specific occurrence. Therefore, the definition from the authority of a specific recovery plan is usually required.

IS.AR.220 Contracting of information security management activities

Regulation (EU) 2023/203

The competent authority shall ensure that when contracting any part of the activities referred to in point [IS.AR.200](#) to other organisations, the contracted activities comply with the requirements of this Regulation and the contracted organisation works under its oversight. The competent authority shall ensure that the risks associated with the contracted activities are appropriately managed.

AMC1 IS.AR.220 Contracting of information security management activities

ED Decision 2023/010/R

(a) OVERSIGHT OF THE CONTRACTED ORGANISATION

In order to exercise oversight of the contracted organisation, the competent authority should have:

- (1) a process to ensure compliance with the provisions regarding contracted activities contained in this Regulation;
- (2) a structured process to follow the expected execution of the contract that includes:
 - (i) definition and agreement of the scope of the activities;
 - (ii) definition of the roles and responsibilities of the parties (i.e. competent authority and contracted organisation);
 - (iii) definition and review of KPIs;
 - (iv) reaction to deviation from contractual obligations;
 - (v) performance of compliance audits, according to predefined scope and objectives, with the aim of evaluating operational and associated assurance activities;
 - (vi) provision of feedback on the result of the compliance audits both within the competent authority and to the contracted organisation, and response to findings. The feedback on the outcome of the compliance audits within the competent authority should reach the person of the competent authority as identified in [IS.AR.225](#)(a) to ensure proper monitoring of the response to findings (i.e. implementation of corrective actions) or, if deemed necessary, termination of the contract.

Note: The right of the competent authority to conduct compliance audits of the contracted organisation should be included in the contract between the parties.

(b) MANAGEMENT OF THE RISKS ASSOCIATED WITH THE CONTRACTED ACTIVITIES

In order to properly manage the risks associated with the contracted activities, the competent authority should meet the following criteria:

- (1) A prior assessment of the suppliers is conducted before outsourcing any information security management activities. The assessment should evaluate suppliers'

competencies, sustainability as well as qualifications in relation to the activities to be contracted.

- (2) There is an assessment of the risks associated with the provision of the contracted activities that has been agreed between the competent authority and the contracted organisation.
- (3) The competent authority establishes and maintains appropriate information security communication channels with the contracted organisation.

GM1 IS.AR.220 Contracting of information security management activities

ED Decision 2023/010/R

Competent authorities may decide to outsource certain activities to suppliers, both for their own operational needs and for the purpose of complying with this Regulation (information security management activities). Activities contracted for operational needs may fall within the scope of Part-IS and therefore the relevant information security risks have to be managed in accordance with the requirements in points [IS.AR.205](#) and [IS.AR.210](#). Instead, information security management activities are subject to the specific provisions of [IS.AR.220](#) because matters relating to these activities can have a major impact on the competent authority.

Therefore the objectives of point [IS.AR.220](#) are:

- (a) to protect critical and sensitive information and assets when being handled by organisations contracted for the provision of information security management activities (including organisations in the supply chain) at either their facilities or the competent authority facilities, or when being transmitted between the competent authority and contracted organisations, or being remotely accessed by contracted organisations;
- (b) to prevent information security risks from being introduced through products and services developed or provided by the contracted organisations to the competent authority, in the frame of the provision of information security management activities;
- (c) to ensure that information security risks are managed throughout all the stages of the relation with the contracted organisations.

GM2 IS.AR.220 Contracting of information security management activities

ED Decision 2023/010/R

- (a) The contracting of information security management activities is a means to allocate tasks from the competent authority to third parties (contracted organisations). The competent authority remains responsible for the oversight of the contracted organisation(s) and accountable for compliance with this Regulation.
- (b) A contract could take the form of a written agreement, letter of agreement, service letter agreement, memorandum of understanding, etc. as appropriate for the contracted activities.

GM3 IS.AR.220 Contracting of information security management activities

ED Decision 2023/010/R

EXAMPLES

The following Table 1 provides some examples of information security management activities that may be contracted in relation to the provisions referred to as in [IS.AR.200](#).

Table 1: Examples of information security management activities that may be contracted

IS.AR.200 points related to activities	Example of contracted activity
(a)(1): establishes a policy on information security setting out the overall principles of the competent authority with regard to the potential impact of information security risks on aviation safety;	Information security policy drafting and consultancy
(a)(2): identifies and reviews information security risks in accordance with point IS.AR.205;	Identify activities, facilities and resources. Identify interfaces with other organisations which could be exposed to information security risks. Perform risk analysis or part of it, e.g. identify and classify information security risks.
(a)(3): defines and implements information IS.AR.215 security risk treatment measures in accordance with point IS.AR.210 ;	Define, develop and implement measures. Verify the initial and the continued effectiveness of the implemented measures (e.g. red-team/blue-team exercises, penetration testing, vulnerability scanning, etc.). Communicate to the involved stakeholders the outcome of the risk assessment and their responsibilities as part of the risk treatment process.
(a)(4): defines and implements, in accordance with point IS.AR.215 , the measures required to detect information security events, identifies those which are considered incidents with a potential impact on aviation safety, and responds to, and recovers from, those information security incidents;	Define, develop and implement measures to detect events. Define, develop and implement measures to respond to any event conditions. Define, develop and implement measures aimed at recovering from information security incidents.
(a)(5): complies with the requirements contained in point IS.AR.220 when contracting any part of the activities described in point IS.AR.200 to other organisations;	Not applicable
(a)(6): complies with the personnel requirements contained in point IS.AR.225 ;	Contracted organisation to ensure that sufficient personnel is on duty to perform the activities related to this Regulation Define, develop and deliver adequate training to achieve the competencies required by the staff. Perform pre-employment checks.
(a)(7): complies with the record-keeping requirements contained in point IS.AR.230 ;	Define, develop and implement secured archiving. Provision of secure data centre (as a service) Provision of records updates

IS.AR.200 points related to activities	Example of contracted activity
(a)(8): monitors compliance of its own organisation with the requirements of this Regulation and provides feedback on findings to the person referred to in point IS.AR.225(a) to ensure effective implementation of corrective actions;	Compliance monitoring activities including the planning and the execution of independent audits
(a)(9): protects the confidentiality of any information that the competent authority may have related to organisations subject to its oversight and the information received through the organisation's external reporting schemes established in accordance with point IS.I.OR.230 of Annex II (Part-IS.I.OR) to this Regulation and point IS.D.OR.230 of the Annex (Part-IS.D.OR) to Delegated Regulation (EU) 2022/1645;	Define, develop and implement solutions to protect the confidentiality of any information.
(a)(10): notifies the Agency of changes that affect the capacity of the competent authority to perform its tasks and discharge its responsibilities as defined in this Regulation;	Not applicable
(a)(11): defines and implements procedures to share, as appropriate and in a practical and timely manner, relevant information to assist other competent authorities and agencies, as well as organisations subject to this Regulation, to conduct effective information security risk assessments relating to their activities.	Not applicable
(b): In order to continuously meet the requirements referred to in Article 1, the competent authority shall implement a continuous improvement process in accordance with point IS.AR.235 .	Execute independent effectiveness and maturity assessments. Define, develop and implement the necessary improvement measures.
(c): The competent authority shall document all key processes, procedures, roles and responsibilities required to comply with point IS.AR.200(a)	Production of documentation to detail all key processes, procedures, roles and responsibilities required to comply with point IS.AR.200(a) (e.g. information security policies, general description of the staff, procedures to specify compliance). Define, develop and implement processes for approving amendments and changes.

GM4 IS.AR.220 Contracting of information security management activities

ED Decision 2023/010/R

PRIOR ASSESSMENT

The purpose of the prior assessment is to evaluate suppliers' competencies, sustainability as well as qualifications in relation to the information security activities to be contracted. This prior assessment may need to be carried out taking into account other legal requirements or procurement procedures that apply to the competent authority, and may therefore be carried out in different ways, such as:

- (a) in case of public bids, inclusion of eligibility requirements in the procurement documents for the potential suppliers;
- (b) review of the information security certifications granted by external and impartial auditors to the potential suppliers;
- (c) review of self-assessment questionnaires compiled by the potential suppliers.

RISK ASSESSMENT ASSOCIATED WITH THE PROVISION OF THE CONTRACTED ACTIVITIES

The risk assessment should take into account the maturity level of the contracted organisation, and should consider the following:

- (a) identification and assessment of critical and sensitive information and assets that may be shared with, or provided by, external suppliers;
- (b) identification of the information security requirements of the authority that are applicable to the contracted organisation;
- (c) evaluation, by means of a supplier assessment, of the ability of the contracted organisation (both existing and new contracted organisations) to meet the information security requirements of the authority;
- (d) assessment of risks that may be introduced by the contracted organisation.

This agreed risk assessment should also consider the roles and responsibilities of the parties (i.e. competent authority and contracted organisation) as well as their interfaces.

GM5 IS.AR.220 Contracting of information security management activities

*ED Decision 2023/010/R***AUDIT OF CONTRACTED ORGANISATIONS**

The following aspects should be considered by the authority when auditing a supplier contracted to perform information security management activities:

- the scope of the audit as well as the objective should be limited to processes, resources (i.e. contracted organisation personnel, systems/equipment, networks) and data used for the execution of Part-IS contracted activities;
- compliance and/or implementation audits should be done at the authority's discretion;
- findings identified during an audit should be addressed through a remediation plan with a time frame to be validated by the authority.

IS.AR.225 Personnel requirements

Regulation (EU) 2023/203

The competent authority shall:

- (a) have a person who has the authority to establish and maintain the organisational structures, policies, processes, and procedures necessary to implement this Regulation.

This person shall:

- (1) have authority to fully access the resources necessary for the competent authority to perform all the tasks required by this Regulation;

- (2) possess the delegation of power required to perform the assigned duties;
- (b) have a process in place to ensure that they have sufficient personnel on duty to perform the activities covered by this Annex;
- (c) have a process in place to ensure that the personnel referred to in point (b) have the necessary competence to perform their tasks;
- (d) have a process in place to ensure that personnel acknowledge the responsibilities associated with the assigned roles and tasks;
- (e) ensure that the identity and trustworthiness of the personnel who have access to information systems and data subject to the requirements of this Regulation are appropriately established.

GM1 IS.AR.225 Personnel requirements

ED Decision 2023/010/R

The objectives of the requirements contained in point [IS.AR.225](#) are:

- (a) to ensure that an effective organisational structure is in place in order to comply with the requirements of this Regulation;
- (b) to provide trust to other organisations with whom they share risks.

AMC1 IS.AR.225(a) Personnel requirements

ED Decision 2023/010/R

The person referred to in point [IS.AR.225\(a\)](#) is normally intended to be a manager in the authority who, by virtue of his or her position, has overall responsibility for information security management and has sufficient authority to plan and allocate the relevant budgetary resources and initiatives in accordance with the financial control model of the Member State. This person is not necessarily required to be knowledgeable on technical matters; however, he or she should be aware of the overarching objectives of this Regulation and its implications for the authority. The authority should make sure that this person has direct access to the highest-ranking executive in the authority and has the necessary funding allocation for the activities under this Regulation.

GM1 IS.AR.225(a) Personnel requirements

ED Decision 2023/010/R

The person referred to in point [IS.AR.225 \(a\)](#) should be capable of managing the authority's information security strategy and its implementation to ensure the achievement of the objectives described in Article 1. According to the European Cybersecurity Skills Framework (ECSF) published by ENISA in September 2022, this person may be described for instance as: (Chief) Information Security Officer, Cybersecurity Programme Director or Information Security Manager. However, it should be noticed that these descriptions and the related skills do not consider the aviation safety perspective that is required in [Article 1](#).

AMC1 IS.AR.225(b) Personnel requirements

ED Decision 2023/010/R

SUFFICIENT PERSONNEL

To determine the sufficiency of the personnel, the following elements should be taken into consideration:

- (a) the organisational structures, policies, processes and procedures subject to information security management;
- (b) the amount of coordination required with other organisations, contractors and suppliers;
- (c) the level of risk associated with the activities performed by the authority.

GM1 IS.AR.225(b) Personnel requirements

ED Decision 2023/010/R

SUFFICIENT PERSONNEL

For the purpose of this Regulation, personnel refers to the combination of the personnel directly employed by the authority, as well as the personnel contracted as specified in [IS.AR.220](#).

The activities reported in Appendix II, on the main tasks stemming from the implementation of Part-IS, should be considered when establishing the organisational structure necessary to comply with the requirements of this Regulation.

AMC1 IS.AR.225(c) Personnel requirements

ED Decision 2023/010/R

NECESSARY COMPETENCE

- (a) To determine the competence needed by the personnel performing the activities, the following elements should be taken into consideration:
 - (1) work roles and the associated tasks;
 - (2) required knowledge, skills and abilities.
- (b) As part of the process to ensure that personnel maintain the necessary competence, the Member State, or the competent authority on its behalf, should:
 - (1) assess the personnel qualifications and experience with respect to the required competence for the assigned work roles to identify gaps;
 - (2) align the personnel qualifications and experience to the expected competence to fulfil their roles by organising adequate learning programmes for existing members of personnel, by recruiting new resources, or by a combination thereof;
 - (3) maintain the personnel competence during the time they are assigned to the work role.

GM1 IS.AR.225(c) Personnel requirements

ED Decision 2025/015/R

NECESSARY COMPETENCE AND TRAINING PROGRAMME

A training programme should start from the identification of the competence required by the personnel for each role, followed by the identification of the gaps between the existing competence and the required one.

In order to develop the list of competencies, a competent authority may use, as initial guidance, an existing cybersecurity competence framework such as the European e-Competence Framework (e-CF) or the NICE (National Initiative for Cybersecurity Education) based on the NIST Cybersecurity Framework (NIST CSF).

In [Appendix II](#), the main tasks of this Regulation are listed and mapped to the competencies derived from the EU e-CF or, for ease of mapping, to the functions and categories of the NIST CSF. This mapping may be used to establish a baseline to identify the aforementioned competence gaps. However, it should be noticed that existing cybersecurity/information security competence frameworks typically focus primarily on the protection of standard information technologies; therefore, the proposed list of competencies may need to be adapted to the technologies or integrated with and processes used in the organisation.

The bridging of the identified gaps should be seen as the objective of the training programme, which should further include the scope, content, methods of delivery (e.g. classroom training, e-learning, notifications, on-the-job training) and frequency of training that best meet the authority's needs considering the size, scope, required competencies, and complexity of the organisation.

The competent authority may also identify professional certification schemes that cover a number of necessary competencies; therefore, it may decide to recognise these certifications as sufficient to cover the establishment of proper qualifications and experience for the certified personnel.

Finally, as information security/cybersecurity evolves due to the rise of new threats, the authority should periodically review the adequacy of the training programme.

AMC1 IS.AR.225(d) Personnel requirements

ED Decision 2023/010/R

ACKNOWLEDGEMENT OF RESPONSIBILITIES

Regarding any assigned role and task, the authority should specify all information security responsibilities an employee has in a clear and transparent manner.

As part of this, all personnel performing the activities required under this Regulation should acknowledge, in a traceable and verifiable manner, understanding of the assigned roles and the associated information security responsibilities.

GM1 IS.AR.225(d) Personnel requirements

ED Decision 2023/010/R

ACKNOWLEDGEMENT OF RESPONSIBILITIES

Acknowledgement of receipt such as a valid electronic or wet signature, confirmation email, etc., is a traceable proof of acceptance.

AMC1 IS.AR.225(e) Personnel requirements

ED Decision 2023/010/R

IDENTITY AND TRUSTWORTHINESS

For the personnel who have access to information systems and data subject to the requirements of Part-IS, the identity should be determined on the basis of documentary evidence.

To establish the trustworthiness of such personnel, the competent authority should have a documented process and appropriate criteria to ensure that individuals can be trusted to perform their role.

GM1 IS.AR.225(e) Personnel requirements

ED Decision 2023/010/R

IDENTITY AND TRUSTWORTHINESS

- (a) Trustworthiness may be established, for example, by:
- (1) prior to employment, a background check carried out in accordance with the applicable rules of Union and national law. This check may include verification of:
 - (i) education, previous employment and any gaps in the previous years;
 - (ii) absence of criminal record;
 - (iii) any other relevant information or intelligence considered relevant to the suitability of a person to work in the expected role;
 - (2) during employment, monitoring the employee's commitment and conduct.

Note: The absence of criminal record may be verified by means of a certificate issued by the responsible authority in the Member State in accordance with Regulation (EU) 2016/1191. In the case of prospective foreign employees, the above checks may be carried out on the basis of equivalent certificates issued by the country of origin, such as a 'certificate of good conduct'.

- (b) Furthermore, the process and criteria to establish personnel's trustworthiness may have to consider whether:
- (1) the information systems and data to be accessed have been associated with a high severity of the safety consequences with the risk assessment process under IS.AR.205;
 - (2) controls or mitigating measures for risk treatment identified during the risk analysis rely on organisational/operational procedures — for instance, correct configuration and administration of information technologies, database operations, information security monitoring, etc.

In such cases, the personnel who have administrator rights or unsupervised and unlimited access to the systems and data mentioned above in (a)(1), or the personnel who applies the measures under above point (b)(2), may be subject to more stringent criteria.

- (c) Intelligence and any other relevant information may be gathered by screening and analysing public sources such as social media and websites, within the limits set by relevant national laws and regulations.
- (d) Competent authorities may also be subject to Regulation (EU) 2015/1998 that requires successful completion of background checks for personnel in certain roles, as well as a mechanism for the ongoing review of these checks. In such cases the organisation may be considered suitable for the establishment of the personnel's identity and trustworthiness required under Part-IS, in relation to their role, the process and the relevant criteria defined in Regulation (EU) 2015/1998 for standard and enhanced background checks. However, it should be noted that compliance with the provisions for the establishment of identity and trustworthiness under Part-IS does not constitute compliance with the provisions on background checks as defined in Regulation (EU) 2015/1998.

IS.AR.230 Record-keeping

Regulation (EU) 2023/203

- (a) The competent authority shall keep records of its information security management activities
 - (1) The competent authority shall ensure that the following records are archived and traceable:
 - (i) contracts for activities referred to in point [IS.AR.200\(a\)\(5\)](#);
 - (ii) records of the key processes referred to in point [IS.AR.200\(d\)](#);
 - (iii) records of the risks identified in the risk assessment referred to in point [IS.AR.205](#) along with the associated risk treatment measures referred to in point [IS.AR.210](#);
 - (iv) records of information security events which may need to be reassessed to reveal undetected information security incidents or vulnerabilities.
 - (2) The records referred to in point (1)(i) shall be retained at least until 5 years after the contract has been amended or terminated.
 - (3) The records referred to in point (1)(ii) and (iii) shall be retained at least for a period of 5 years.
 - (4) The records referred to in point (1)(iv) shall be retained until those information security events have been reassessed in accordance with a periodicity defined in a procedure established by the competent authority.
- (b) The competent authority shall keep records of qualification and experience of its own staff involved in information security management activities
 - (1) The personnel's qualification and experience records shall be retained for as long as the person works for the competent authority, and for at least 3 years after the person has left the competent authority.
 - (2) Members of the staff shall, upon their request, be given access to their individual records. In addition, upon their request, the competent authority shall provide them with a copy of their individual records on leaving the competent authority.
- (c) The format of the records shall be specified in the competent authority's procedures.
- (d) Records shall be stored in a manner that ensures protection from damage, alteration and theft, with information being identified, when required, according to its security classification level. The competent authority shall ensure that the records are stored using means to ensure integrity, authenticity and authorised access.

GM1 IS.AR.230 Record-keeping

ED Decision 2023/010/R

Records are required to document results achieved or to provide evidence of activities performed. Records become factual when recorded and cannot be modified. Therefore, they are not subject to version control. Even when a new record is produced covering the same issue, the previous record remains valid.

AMC1 IS.AR.230(a)(1)(iv)&(a)(4) Record-keeping

ED Decision 2023/010/R

When complying with the requirements under points (a)(1)(iv) and (a)(4), the competent authority should establish a data retention policy defining procedures to:

- (a) manage relevant information security data files;
- (b) establish the periodical assessment of their content; and
- (c) define the criteria to allow deletion of records of information security events when the objective of requirement (a)(4) has been met.

GM1 IS.AR.230(a)(1)(iv)&(a)(4) Record-keeping

ED Decision 2023/010/R

The objective of the requirement (a)(1)(iv) is to ensure detection of possible indication of information security incidents or vulnerabilities which are not obvious by normal operation (e.g. previously unknown situations), while the objective of the requirement under (a)(4) is to allow the necessary flexibility to control the volume of the stored information security events.

Records of information security events include those events identified within the scope of the detection activities under [IS.AR.215\(a\)](#), as well as other information security data produced by assets that have been identified under [IS.AR.205](#).

A data retention policy clarifies what information should be stored or archived and for how long. Some guidance about data retention can be found in EUROCAE ED-206, Chapter 2.6.

Once a data set completes its retention period, it can be deleted or moved as permanent historical data to a secondary or tertiary storage.

AMC1 IS.AR.230(c)&(d) Record-keeping

ED Decision 2023/010/R

When complying with the requirements under points (c) and (d) for all the records required by points [IS.AR.230](#) (a) and (b), the competent authority should consider the following:

- (a) Records should be kept in paper form or in electronic format or a combination of both media. The records should remain accessible whenever needed within a reasonable time and usable throughout the required retention period. The retention period starts when the record has been created.
- (b) Records data integrity, availability and authenticity should be protected in consistency with protection of corresponding operational data, and as such, should be within the scope of the ISMS.
- (c) Storage systems should be protected against unauthorised access (i.e. data leakage attempts against personal data/modification of records) and thus should have information security measures implemented in consistency with the level of information security risk associated with them.
- (d) Once records are not required to be retained anymore, the destruction of records and decommissioning of assets used for their storage should be implemented appropriately.

GM1 IS.AR.230(c)&(d) Record-keeping

ED Decision 2023/010/R

RECORDS ACCESSIBILITY THROUGHOUT THE RETENTION PERIOD

It is recommended to follow best practices for data retention, for data that may need to be restored, backup strategies, such as the use of automated backup tools, segregation or geographic separation of backup storage location(s), and to consider offline backups to prevent ransomware risks. These practices should be considered also when record-keeping is contracted to service providers with distributed resources.

Special attention should be paid to significant hardware and software changes, ensuring that stored digital records remain accessible and readable (e.g. file system, application file format, forward compatible database versions, etc.). Paper-based information needs to be archived in an adequate environment, in which records are protected against degradation factors (e.g. excessive heat, light or humidity).

RECORDS DATA INTEGRITY AND PROTECTION FROM UNAUTHORISED ACCESS

A commonly used method to achieve authenticity and integrity protection is the use of digital signatures at document level. Digital signatures can be added to the document's file (e.g. PDF) to ensure that a record has not been modified by someone other than its author (integrity) and that the author is who is expected to be (authenticity).

Moreover, to prevent unauthorised access, records can be protected, for example, by implementing a role-based access control (RBAC) approach, or certain records can be password protected at the file level. Commercial applications feature built-in basic password protection functions for their file formats. Access protection can also be achieved by protecting the environment where the individual records are stored (e.g. access protection on databases, file shares, directories, etc.).

IS.AR.235 Continuous improvement

Regulation (EU) 2023/203

- (a) The competent authority shall assess, using adequate performance indicators, the effectiveness and maturity of its own ISMS. The assessment shall be performed on a predefined calendar basis defined by the competent authority or following an information security incident.
- (b) If deficiencies are found following the assessment carried out in accordance with point (a), the competent authority shall take the necessary improvement measures to ensure that the ISMS continues to comply with the applicable requirements and maintains the information security risks at an acceptable level. In addition, the competent authority shall reassess those elements of the ISMS affected by the adopted measures.

AMC1 IS.AR.235 Continuous improvement

ED Decision 2023/010/R

The continuous improvement process (CIP), as required by [IS.AR.200\(b\)](#), should aim to continuously improve the effectiveness, suitability and adequacy of the ISMS. This should be achieved by a proactive and systematic assessment of the ISMS and all its elements — including its maturity. The assessment should take into account the outcomes and conclusions of other information security and assurance processes including audits, management reviews, evaluation of performance, effectiveness and maturity, as well as the outcomes of the derived corrective actions and corrections.

The steps to be performed should be at least the following:

- (a) Identification of improvement opportunities based on the outcomes of the assessment of the ISMS with respect to its suitability, effectiveness, adequacy and, if deemed necessary, efficiency, as well as on any other suggestion for improvement. The assessment should consider performance indicators which reflect its processes and elements and the defined objectives for effectiveness and maturity.
- (b) Evaluation of the identified opportunities regarding cost benefit, absence or reduction of undesired effects and achievement of the targeted objectives and intended outcomes.
- (c) Proposal on the evaluated improvement opportunities to the management and recommendation of actions to support their review and decision-making.
- (d) According to the decision taken under point (c) above, planning, development and implementation of actions and changes to the ISMS, its processes or elements to achieve the improvements.
- (e) Evaluation of the effectiveness of the implemented actions and ISMS changes as well as, as applicable, verification that the root cause of identified deficiencies has been eliminated.

The management should assess and review the outcomes of the CIP at planned intervals to ensure the continuing effectiveness, adequacy and suitability of the ISMS, to decide on the prioritisation of the implementation of actions and changes, as well as to revise or set new objectives, or targets for continuous improvement.

GM1 IS.AR.235 Continuous improvement

ED Decision 2025/015/R

Point [IS.AR.235](#) covers assurance processes for the ISMS in a manner that can be considered equivalent to the safety assurance in ICAO Doc 9859 'Safety Management Manual (SMM)', which includes performance monitoring and measurement, management of change and continuous improvement of the SMS.

In this Regulation:

- IS.AR.235(a) addresses, using adequate performance indicators, the effectiveness and maturity assessment of the ISMS;
- IS.AR.235(b) addresses the improvement measures, i.e. corrections and corrective actions, for the deficiencies detected in IS.AR.235(a) and the continuous improvement process.

Similar provisions for continuous improvement are provided for in other information management systems such as ISO/IEC 27001 (see [Appendix IV](#) to this document).

The context and risk environment of competent authorities are never static and therefore require a dynamic adaptation, evolution and change of the competent authority's objectives, architectures, organisational structures and processes to maintain the information security risks at an acceptable level. Consequently, the ISMS should be considered as an evolving and learning part/element of the competent authority which needs to be continuously monitored and improved to ensure alignment with the competent authority's safety objectives and effectiveness.

The CIP aims to continuously improve the effectiveness, suitability, adequacy and, if deemed necessary, the efficiency of the ISMS. A competent authority may integrate the Part-IS CIP in some other already operated CIP and may apply methods such as Plan-Do-Check-Act (PDCA) Cycle or Define-Measure-Analyse-Improve-Control (DMAIC) (see also [GM1 IS.AR.200](#)).

The CIP is based on a proactive and systematic assessment of the ISMS and all its elements including the information security processes and controls driven by the ISMS. The assessment should be carried out against organisational targets for desired levels of performance, effectiveness, and maturity. These targets, besides ensuring the achievement of compliance with the requirements under this Regulation, may also aim to include objectives established by the competent authority's policy or standards and by management decisions.

The above-mentioned assessment is based on the outcome of performance evaluations, audits, risk and incident processes, as well as already applied corrective actions and corrections. Some factors that should be considered when performing the assessment are the following:

- **Adequacy** refers to whether the system establishes the disciplines needed to manage information security, e.g. by using broadly accepted industry standards, in a sufficient manner with regard to compliance with the requirements of this Regulation.
- **Effectiveness of the ISMS** and the effective implementation of processes and controls driven by the ISMS is assessed by analysing whether:
 - the information security risks are managed to achieve the safety objectives;
 - the intended outcomes of the ISMS are achieved, and the requirements or objectives are met;
 - all types of deficiencies, including failures, are managed to fulfil or correctly implement a requirement or control.
- **Efficiency** of the ISMS refers to the implementation of streamlined processes; however, efficiency improvements should not adversely impact effectiveness.

Identification of improvement opportunities

Improvement opportunities may be identified from the results of the CIP assessment or may be introduced as suggestions from other sources. The identification often involves deviations or corrective actions as well as ineffective processes or controls which are not remediated.

Suggestions for improvements stem from sources including:

- Risk management: the results of regularly conducted risk analyses and the subsequent risk treatment are a primary factor in improving the ISMS, where the risk treatment process involves monitoring of the implemented security measures and evaluating their effectiveness.
- Performance & effectiveness evaluation: conclusions from (key) performance indicators, their measurement, analysis and continued monitoring as well as the result of the assessment of the effectiveness including the outcomes of the subsequently applied corrections and corrective actions
- Evaluation of maturity including the results of the subsequent corrections and corrective actions
- Lessons learned from information security incident detection, handling and response process and a potential treatment of a root cause
- Results of (internal) audits may be used to verify whether the ISMS and controls within the audit scope meet the competent authority's requirements and to determine where there are potential areas for improvements.
- Review and evaluation by management of the current action plan, setting or revision of the objectives or decision on improvement opportunities and actions

- Competent authority's suggestion programme (suggestions for improvement), reviews, surveys or assessments with employees or feedback from suppliers or interfacing parties

Any outcome of this process should be documented. The resulting actions may be integrated into an overarching action plan which is centrally consolidated and periodically reviewed according to the relevant policies. The resulting action plan may be further divided into a tactical, short-/mid-term action plan and a strategic, long-term action plan.

AMC1 IS.AR.235(a) Continuous improvement

ED Decision 2023/010/R

(a) ISMS EFFECTIVENESS EVALUATION

When complying with [IS.AR.235\(a\)](#), the competent authority should have a process in place to monitor, measure, evaluate and review the effectiveness of its ISMS that defines:

- (1) who monitors, measures, analyses and evaluates the results and takes accountable decisions;
- (2) when the above steps should be performed;
- (3) which methods for monitoring, measurement, analysis and evaluation are applied to ensure comparable and reproducible results.

The calendar basis of the assessments should be commensurate with the maximum level of risk established under [IS.AR.205](#).

The process to monitor, measure, evaluate and review the effectiveness of its ISMS referred to under [AMC1 IS.AR.235\(a\)](#) should include as a minimum:

- (1) the gathering and retention of metrics of the activities, and additional information that could be useful for monitoring purposes;
- (2) the analysis of the metrics in order to identify trends and deviations from predefined performance targets.

(b) ISMS MATURITY ASSESSMENT

The competent authority should assess the maturity of its ISMS using a suitable maturity model in order to identify areas for improvement to the ISMS. To do so, the competent authority should:

- (1) define or adopt a maturity model which represents a set of important and relevant processes and capabilities that are expected to be implemented and maintained;
 - (2) for each assessed process or capability, ensure that the model defines criteria against which specific aspects, characteristics and effectiveness should be assessed and evaluated when determining a maturity level;
 - (3) define for each assessed process or capability its desired target maturity level.
- (c) For each assessed information security process or capability contained in the maturity model, the competent authority should:
- (1) evaluate and justify the current maturity level;
 - (2) identify any area for improvement it should make to reach the targeted maturity level;

- (3) collect and record the evidence regarding strengths and weaknesses of the implemented ISMS and its evaluated maturity.

GM1 IS.AR.235(a) Continuous improvement

ED Decision 2023/010/R

- (a) As general guidance, the elements of the ISMS that should be monitored, measured and evaluated should be, as a minimum:
 - (1) the risk assessment and treatment process (including risks at the interfaces with other entities);
 - (2) the management of non-conformities and corrective actions;
 - (3) the incident and vulnerability management;
 - (4) the personnel competence management.

- (b) Existing maturity models for ISMS maturity evaluation

As general guidance, for the definition or the adoption of a maturity model (MM), the following existing models may be considered:

- Cybersecurity Capability Maturity Model (C2M2), version 1.1: this model was published by the US Department of Energy in 2014. It introduces the notion of Maturity Indicator Levels (MIL) ranging from 0 to 3 and addresses not only performance levels but also performance practices (under Approach Objectives and approach progression) as well as assurance practices (under Management Objectives and institutionalization progression).
- Systems Security Engineering – Capability Maturity Model (SSE-CMM): published by ISO as ISO 21827 in 2008. It focuses on engineering practices, much less on operational practices that are split in 11 ‘Security Base Practices’, and 11 ‘Project and Organizational Base Practices’. It introduces the notion of five Capability Levels, from ‘Performed Informally’ to ‘Continuously Improving’.
- NIST Cybersecurity Framework (NIST CSF), version 1.1: published by NIST in April 2018. Although it is not proposed as a MM, the framework defines four ‘Implementation Tiers’, from ‘Partial’ to ‘Adaptive’, which are a qualitative measure of organisational cybersecurity risk management practices. It focuses on the functionality and repeatability of cybersecurity risk management.
- ATM Cybersecurity Maturity Model, edition 1: published in February 2019 by the EUROCONTROL NM for organisations in the ATM domain. Whilst not being designed for wider application, it can be adapted as necessary. It defines five maturity levels, ranging from ‘Non-existent’ to ‘Adaptive’ inspired by the ‘Tier’ terminology from the NIST CSF. In fact, the model is founded on NIST CSF, together with some elements of ISO/IEC 27001.

The following Table 1 maps the MM mentioned above to a hypothetical five-level MM.

Table 1: Mapping matrix of an existing MM to a hypothetical five-level MM

Mapping to a five-level MM	C2M2	Eurocontrol NM	ISO 21827	NIST CSF 1.1	
Initial	MIL 0	Non-Existent	Performed Informally		
Defined	MIL 1 (Initial)	Partial	Planned & Tracked	Partial	
Implemented	MIL 2 (Identified)	Defined	Well defined	Risk-Informed	
Managed	MIL 3 (Managed)	Assured	Quantitatively Controlled	Repeatable	
Improved		Adaptive	Continuously Improving	Adaptive	

No specific maturity level is required. However, if and when compliance is achieved, entities will determine which requirements of which models have already been met (mandatory) and can opt to reach a level that is beneficial to the competent authority (voluntary). In the longer term, achieving higher maturity levels may increase the confidence of oversight authorities, which can have an impact upon the level of oversight activities regarding such competent authority.

AMC1 IS.AR.235(b) Continuous improvement

ED Decision 2023/010/R

When a deficiency is identified, the competent authority should react in a timely manner following a defined process leading to a managed status regarding the deficiency, its associated consequences and, if needed, the prevention of its future recurrence or occurrence elsewhere.

Based on an evaluation of the impact and extent of the deficiency and the potential consequences on the ISMS, the process should include as criteria for compliance:

- (a) deciding on corrections and their implementation without undue delay in order to limit the impact of the deficiency and deal with its consequences as well as, as applicable, to control or eliminate it;
- (b) deciding on the need for, and the implementation of, corrective actions to eliminate the cause(s) of, and contributing factors to, the deficiency based on a root cause analysis and an evaluation of actions remediating the cause aimed at being proportionate to the consequences and impact of the deficiency;
- (c) verifying the implemented actions:
 - (1) to be effective and to result in acceptable residual risks;
 - (2) not to have unintended side effects leading to other deficiencies, new risks, or an ISMS not aligned with the applicable requirements; as well as
 - (3) for corrective actions, to effectively remediate or eliminate the root cause;

- (d) reporting to and reviewing the identified deficiencies, action plan and results of the action taken with the person identified in [IS.AR.225\(a\)](#) and, as necessary, with other involved or affected roles and parties;
- (e) documenting as evidence the detected deficiencies, the planned and implemented corrections and/or corrective actions with deadlines and responsible persons, the management feedback, the outcomes of the process step under point (c) above and, if necessary, the change decisions made for the ISMS itself.

GM1 IS.AR.235(b) Continuous improvement

ED Decision 2023/010/R

The ‘necessary improvement measures’ referred to in [IS.AR.235\(b\)](#) refer to correction or corrective actions to eliminate deficiencies, or actions aimed at improving the effectiveness as well as the maturity of the ISMS.

A process satisfying the criteria defined in [AMC1 IS.AR.235](#) should include the following aspects:

- (a) identifying the extent, impact, context and triggers of the deficiency, evaluating it according to some established criteria, analysing potential consequences for the ISMS including a potential existence in other areas;
- (b) deciding on corrections and their implementation to immediately limit the impact and manage the consequences of the deficiency as well as, as applicable, to control or eliminate it;
- (c) deciding on corrective actions required to eliminate the (root) cause(s) of the deficiency that are proportionate to the consequences;
- (d) reassessing the elements of the ISMS which may be affected by the implemented actions to ensure that no further risk is introduced;
- (e) verifying the implemented actions referred to in [AMC1 IS.AR.235\(b\)](#);
- (f) reporting to and reviewing the outcomes of the process steps with the management (see point (d) of [AMC1 IS.AR.235\(b\)](#));
- (g) documenting and evidencing the result of the process steps above (see point (e) of [AMC1 IS.AR.235\(b\)](#)).

Appendix I — Examples of threat scenarios with a potential harmful impact on safety

ED Decision 2023/010/R

The following is a non-exhaustive list of examples of information security threat scenarios with a potential harmful impact on safety that may be considered by authorities and organisations.

Example 1: Aircraft to ATC digital communications

- **Threat vector assets/domain**
 - ATC voice and ground automation systems
 - ground communications providers
 - air-ground/ground-air RF communications service providers

-
- aircraft and the assets used for voice and datalink communications
 - **Non-exhaustive summary of potential threats**
 - threat (availability): exceeding system performance, saturation of communication channel
 - threat (integrity): man-in-the-middle or injection attacks
 - threat (confidentiality): passive listening to communication, spying on hardware device
 - **Summary of threats scenarios and their potential harmful impacts on safety**
 - Disruption of services prevent ATC communication with a single or multiple aircraft and/or ATC ground system.
 - Manipulation of data through a man-in-the-middle attack would present false information to the pilot and/or ATC system with the potential of creating a safety hazard or injection of data to the aircraft or ground systems to disrupt the service and capability.
 - There are no specific regulatory requirements for encryption of data or voice for datalink communications; however, for confidentiality purposes, the assets used to provide and deliver the services should be controlled and limited to only those resources that require access to ensure that the services cannot be disrupted and manipulated in any way.

Example 2: Tampered air traffic data

- **Threat vector assets/domain**
 - Internet service provider (ISP)
 - ATM services network(s)
 - surveillance data
 - ATC systems
- **Non-exhaustive summary of potential threats**
 - ISP compromise (confidentiality): An attacker gains unauthorised access to the systems or infrastructure of the ISP providing network services to ATM system.
 - data tampering (integrity): Once the ISP is compromised, an attacker could manipulate data in transit. This could involve injecting false data or removing/modifying legitimate data.
 - denial of service (availability): an attacker could also potentially disrupt the communication of data entirely, resulting in a denial of service (DoS) to the ATM system.
 - malware injection (integrity/availability): An attacker could potentially use the compromised ISP as a launching pad to inject malware into the systems, causing further disruptions or enabling additional attacks.
- **Summary of threats scenarios and their potential harmful impacts on safety**
 - ISP compromise: interception and/or manipulation of sensitive data, impacting the safe management of air traffic.
 - data tampering: incorrect situational awareness, potentially resulting in reduced separation between aircrafts, and incorrect air traffic control decisions.

- denial of service: reduction of the ATC's ability to ensure separation leading to the activation of contingency procedures, including capacity reduction, with the eventual possibility of large areas of airspace being closed.

Example 3: Aircraft operator, CAMOs' and aircraft maintenance organisations' software supply chain and ground infrastructure, including equipment used to support aircraft management, operations and maintenance

- **Threat vector assets/domain**
 - aircraft operators', CAMOs' and maintenance organisations' supply chain
 - aircraft operator or maintenance internal ground infrastructure used to manage aircraft and operations (hardware/software) and other information technology assets
 - information technology assets used to update systems on an aircraft (software and hardware) used for maintenance activities
- **Non-exhaustive summary of potential threats**
 - threat (availability): hardware/software/system disruption
 - threat (integrity): compromised hardware/software/system
 - threat (confidentiality): compromised hardware/software/system
- **Summary of threats scenarios and their potential harmful impacts on safety**
 - Disruption to the dissemination of meteorological information while the aircraft is airborne, may reduce the ability of the flight crew to avoid potentially hazardous meteorological conditions (e.g. severe storms/fog at night).
 - Manipulation of navigation data/database will have the effect that flight plans and navigation displays cannot be trusted.
 - Lack of control and access to information such as fleet maintenance programme or flight crew planning affects the ability of organisations to maintain safe operations.

Application of bow-tie analysis to this example

Two coordinated bow-tie analyses of different risk dimensions are combined, as the ultimate interest lies only in the aviation safety consequence.

Information security bow-tie analysis element	Aviation safety bow-tie analysis element
Information security threats 1) hardware/software vulnerability exploitation: disturbed system function 2) hardware/software vulnerability exploitation: system integrity compromised 3) hardware/software vulnerability exploitation: confidentiality of information processed by system(s) compromised	
Information security preventive barriers	

Information security hazards & top events 1) disturbed system functionality (hazard) → disrupted/unreliable system functionality 2) system integrity compromised (hazard) → system function unpredictable 3) information disclosable (hazard) → undetectable information exfiltration	Safety threats 1) disrupted/unreliable system functionality 2) system function unpredictable 3) undetectable information exfiltration
Information security mitigating barriers	Safety preventive barriers 1) Use of access controls for system administration 2) etc.
Information security consequences 1) loss of system function (= production system down) 2) loss of system function integrity (= some system function wrong/inoperative) 3) loss of confidentiality of information (= some information can leak)	Safety hazards & top events: 1) loss of system function (hazard) → <i>in operational maintenance system</i> 2) loss of system function integrity (hazard) → <i>systems operate with wrong information</i> 3) loss of information confidentiality (hazard) → <i>confidential maintenance and aircraft internals information leaks</i>
	Safety mitigating barriers 1) use of back-up procedures to prevent faulty maintenance actions 2) use of procedures to secure aircraft software integrity
	Safety consequences 1) faulty maintenance actions 2) incorrectly completed maintenance actions 3) exfiltration of information allows for identification of vulnerabilities 4) disruption of aircraft systems, unpredictable system function, loss of major aircraft systems (such as engine control)

Example 4: Design and production organisations' software, supply chain, design and manufacturing ground infrastructure

- **Threat vector assets/domain**
 - design and production organisations' supply chain for parts, hardware and software
 - design and production organisations' ground internal infrastructure used to manage software/hardware used in the manufacturing and development of products that will be used by aircraft manufacturers, operators or ATM/ANS ground automation systems (hardware/software) information technology assets
 - design and production organisations' information technology assets used by their customers to update systems on an aircraft (software/hardware) used for maintenance operations or ATM/ANS ground automation systems
- **Non-exhaustive summary of potential threats**
 - threat (availability): systems used to store, transmit and exchange information are rendered unavailable for essential operations through DoS attacks

- threat (integrity): systems used to store, transmit and exchange information are compromised through man-in-the middle attacks
- threat (confidentiality): systems used to store, transmit and exchange information are accessed by insider or external threats
- **Summary of threats scenarios and their potential harmful impacts on safety**
 - Disruption of systems used to store, transmit and exchange information in a manner that would prevent the proper management of the aircraft and its systems and adversely affect the operations of the aircraft
 - Systems used to store, transmit and exchange information can no longer be considered trusted. If they are not maintained at a level to ensure that all information exchange, data and software can be considered trusted, both ground and aircraft operations are disrupted.
 - Uncontrolled access to systems used to store, transmit and exchange information (including information that is received and exchanged with the supply chain) can provide technical details that could be used to craft more sophisticated attacks targeting safety-critical systems.

Example 5: Training system

- **Threat vector assets/domain**
 - supply chain of all software and hardware that will be used in the training systems or training devices (including flight simulators) used to train pilot or ATM/ANS ground systems personnel
 - internal infrastructure used in of all software and hardware that will be used in the design, manufacturing or production of products (hardware or software) that will be used in aircraft or ATM/ANS ground systems
 - management of internal operating domains and system of all software and hardware that will be used in the design, manufacturing or production of products (hardware or software) that will be used in aircraft or ATM/ANS ground systems
- **Non-exhaustive summary of potential threats**
 - threat (availability): training systems or training devices are rendered unavailable by means of DoS attacks when they are needed to be used
 - threat (integrity): training systems or training devices are compromised through man-in-the middle attacks
 - threat (confidentiality): functional models, information and data that are embedded in training systems or training devices are accessed by insider or external threats
- **Summary of threats scenarios and their potential harmful impacts on safety**
 - Disruption of training systems (hardware and software) will have an impact on the organisations' ability to maintain qualified staff. It would also prevent the aircraft and its systems from being properly operated and affect maintenance operations for ATM/ANS ground systems.

- The training model or the failure modes and associated emergency conditions differ from the real aviation system behaviour and therefore induce inappropriate responses. If the training systems cannot be trusted, this will affect the ability of organisations to maintain sufficiently qualified staff for their operations (pilots, maintenance or ATM/ANS ground personnel who have been exposed to improper training should be re-qualified).
- Lack of control and access to training systems affects the ability of organisations to maintain a training system that is known to be in a trusted state. In addition, uncontrolled access to training systems that embed functional models, information and data can provide technical details that could be used to craft more sophisticated attacks on the training system itself or on the real-world safety-critical system.

Example 6: Airport's fuel delivery system and associated infrastructure

- **Threat vector assets/domain**
 - ground fuel storage and distribution infrastructure
 - digital systems used to control fuel pumping and metering
 - supply chain for fuel delivery, including third-party fuel suppliers
 - airport information technology assets used for fuel inventory management and scheduling deliveries
- **Non-exhaustive summary of potential threats**
 - threat (availability): disruption of fuel supply or delivery systems
 - threat (integrity): tampering with fuel control systems or measurement devices
 - threat (confidentiality): unauthorised access to fuel supply and delivery data
- **Summary of threats scenarios and their potential harmful impacts on safety**
 - Disruption to fuel delivery can lead to flight delays or cancellations, causing operational disruptions and potential safety issues if fuel reserves become critically low.
 - Tampering with fuel control systems or measurement devices could lead to incorrect fuel loads being delivered to aircraft, impacting aircraft weight and balance calculations, and potentially causing fuel exhaustion incidents.
 - Unauthorised access to fuel supply data could allow threat actors to manipulate fuel scheduling or inventory data, potentially causing disruptions to airport operations and fuel availability for aircraft.

Example 7: National competent authority's NOTAM system and associated infrastructure

- **Threat vector assets/domain**
 - National NOTAM system infrastructure and digital interface
 - Supply chain for NOTAM system maintenance and updates
 - National competent authority's IT assets used for NOTAM creation, distribution, and storage

-
- **Non-exhaustive summary of potential threats**
 - threat (availability): disruption of the NOTAM system or its access
 - threat (integrity): tampering with NOTAM data or unauthorised NOTAM creation
 - threat (confidentiality): unauthorised access to NOTAM data
 - **Summary of threats scenarios and their potential harmful impacts on safety**
 - Disruption to the NOTAM system could prevent the dissemination of critical aeronautical information to pilots and air traffic controllers, potentially leading to safety issues.
 - Tampering with NOTAM data or unauthorised creation of NOTAMs could lead to incorrect information being disseminated, potentially resulting in pilots making decisions based on false or misleading data.
 - Unauthorised access to NOTAM data could lead to information leakage, potentially revealing sensitive operational information.

Example 8: Aviation authority's airworthiness directive (AD) system and associated infrastructure

- **Threat vector assets/domain**
 - EASA AD system infrastructure and digital interface
 - supply chain for AD system maintenance and updates
 - EASA IT assets used for AD creation, distribution, and storage
- **Non-exhaustive summary of potential threats**
 - threat (availability): Disruption of the AD system or its access
 - threat (integrity): tampering with AD data or unauthorised AD creation
 - threat (confidentiality): unauthorised access to AD data
- **Summary of threats and their potential harmful impacts on safety**
 - Disruption to the AD system could prevent the dissemination of critical airworthiness information to aircraft operators and maintenance organisations, potentially leading to safety issues.
 - Tampering with AD data or unauthorised creation of ADs could lead to incorrect information being disseminated, potentially resulting in aircraft operators and maintenance organisations making decisions based on false or misleading data.
 - Unauthorised access to AD data could lead to information leakage, potentially revealing sensitive operational information.

Appendix II — Main tasks stemming from the implementation of Part-IS mapped to the EU e-CF and the NIST CSF 2.0

ED Decision 2025/015/R

Part-IS main task	Activity type	Reference		
		Part-IS	EU e-CF	NIST CSF 2.0
			Competence areas & skills	Functions & categories
Establish and operate an information security management system (ISMS)	Management	IS.AR.200(a)	ISM (E.08)	GV – Govern
Establish the scope of the ISMS in accordance with Part-IS requirements	Management	IS.AR.205(a)	ISM (E.08)	GV.RM – Risk Management Strategy; ID.AM – Asset Management;
Implement and maintain an information security policy	Management	IS.AR.200(a)(1)	ISM (E.08)	GV.PO – Policy
Identify and review information security risks	Management	IS.AR.200(a)(2) IS.AR.205	ISM (E.08), Risk Management (E.02)	GV.SC – Cybersecurity Supply Chain Risk Management; ID.RA – Risk Assessment; ID.IM – Improvement
Implement information security risk treatment measures	Management	IS.AR.200(a)(3) IS.AR.210	ISM (E.08), Risk Management (E.02)	ID.RA – Risk Assessment
Set up measures to detect information security events, identify those that may develop to incidents with a potential impact on aviation safety, and respond to, and recover from, such incidents	Management	IS.AR.200(a)(4) IS.AR.215	Incident Management (C.04)	DE – Detect; RE – Respond; RC – Recover; PR – Protect (as per Risk Assessment)
Monitor compliance with this Regulation and report findings to top management	Operational	IS.AR.200(a)(8)	Compliance (E.09)	GV.RR – Roles, Responsibilities and Authorities; GV.RM – Risk Management; GV.OV – Oversight; ID.IM – Improvement

Part-IS main task	Activity type	Reference		
	Management, Operational	Part-IS	EU e-CF	NIST CSF 2.0
			Competence areas & skills	Functions & categories
Protect confidentiality of exchanged information	Operational	IS.AR.200(a)(9)	Information Security Management (E.08)	PR.DS – Data Security; Other PR – Protect categories as applicable
Implement and maintain a continuous improvement process to measure the effectiveness and maturity of the ISMS and strive to improve it	Management	IS.AR.200(b) IS.AR.235	Information Security Management (E.08)	GV.OV – Oversight; ID.IM – Improvement
Communicate to the Agency changes regarding capability and responsibilities	Operational	IS.AR.200(a)(10)	Risk Management (E.02), ISM (E.08)	GV.OC – Organisational Context (03)
Share information to assist other competent authorities, agencies and organisations	Operational	IS.AR.200(a)(11)	Risk Management (E.02), ISM (E.08)	ID.RA – Risk Assessment (02); RS.CO – Incident Response Reporting and Communication
Document and maintain all key processes, procedures, roles and responsibilities	Management	IS.AR.200(c)	ISM (E.08), Compliance (E.09)	GV.RR – Roles, Responsibilities and Authorities; Other functions and categories as applicable
Identify all elements which could be exposed to information security risks	Management	IS.AR.205(a)	Risk Management (E.02)	ID.AM – Asset Management
Identify the interfaces with other organisations which could result in exposure to information security risks	Management	IS.AR.205(b)	Risk Management (E.02), Business Change Management (E.07)	ID.AM – Asset Management; GV.SC – Cybersecurity Supply Chain Risk Management

Part-IS main task	Activity type	Reference		
	Management, Operational	Part-IS	EU e-CF	NIST CSF 2.0
			Competence areas & skills	Functions & categories
Identify information security risks and assign a risk level	Management	IS.AR.205(c)	Risk Management (E.02)	GV.RM – Risk Management Strategy; ID.RA – Risk Assessment
Review and update the risk assessment based on certain criteria	Operational	IS.AR.205(d)	Risk Management (E.02)	GV.RM – Risk Management Strategy; GV.PO – Policy; GV.OV – Oversight; GV.SC – Cybersecurity Supply Chain Risk Management; ID.IM – Improvement
Develop and implement measures to address risks and verify their effectiveness	Operational	IS.AR.210(a)	Risk Management (E.02)	GV.RM – Risk Management Strategy; ID.RA – Risk Assessment
Communicate the outcome of the risk assessment to management, other personnel and other organisations sharing an interface	Operational	IS.AR.210(b)	Risk Management (E.02), ISM (E.08)	GV.RM – Risk Management Strategy; GV.SC – Cybersecurity Supply Chain Risk Management
Implement measures to detect in processes and operations information security events which may have a potential impact on aviation safety	Operational	IS.AR.215(a)	ISM (E.08)	DE.CM – Continuous Monitoring; DE.AE – Adverse Event Analysis; ID.RA – Risk Assessment; PR – Protect (selection of relevant controls as per Risk Assessment)

Part-IS main task	Activity type	Reference		
	Management, Operational	Part-IS	EU e-CF	NIST CSF 2.0
			Competence areas & skills	Functions & categories
Implement measures to respond to information security events that may cause an information security incident	Operational	IS.AR.215(b)	Incident Management (C.04)	RS.MA – Incident Management; RS.AN – Incident Analysis; RS.MI – Incident Mitigation; RS.CO – Incident Response Reporting and Communication (where applicable); PR – Protect (selection of relevant controls as per Risk Assessment)
Implement measures to recover from information security incidents	Operational	IS.AR.215(c)	Incident Management (C.04)	RC.RP – Incident Recovery Plan Execution; RC.CO – Incident Recovery Communication; PR – Protect (selection of relevant controls as per Risk Assessment)
Manage risks associated with contracted activities with regard to the management of information security	Management	IS.AR.220	Supplier Relationship Management (E.10)	GV.SC – Cybersecurity Supply Chain Risk Management
Define a person with the authority to establish and maintain the organisational structures, policies, processes, and procedures necessary to implement this Regulation	Management	IS.AR.225(a)	ISM (E.08), Compliance (E.09)	GV.RR – Roles, Responsibilities, and Authorities
Create and maintain a process to ensure that there is sufficient personnel to perform all activities regarding information security management	Management	IS.AR.225(b)	Personnel Development (D.11)	GV.RR – Roles, Responsibilities, and Authorities

Part-IS main task	Activity type	Reference		
	Management, Operational	Part-IS	EU e-CF	NIST CSF 2.0
			Competence areas & skills	Functions & categories
Create and maintain a process to ensure that the personnel have the necessary competence for activities regarding information security management	Management	IS.AR.225(c)	Personnel Development (D.11)	GV.RR – Roles, Responsibilities, and Authorities; PR.AT – Awareness and Training (02)
Create and maintain a process to ensure that the personnel acknowledge the responsibilities associated with the assigned roles and tasks	Management	IS.AR.225(d)	Personnel Development (D.11)	GV.RR – Roles, Responsibilities, and Authorities
Verify the identity and trustworthiness of personnel who have access to information systems	Management	IS.AR.225(e)	ISM (E.08)	GV.RR – Roles, Responsibilities, and Authorities; GV.PO – Policy; PR.AA – Entity Management, Authentication, and Access Control
Archive, protect and retain records and ensure they are traceable for a specified time	Operational	IS.AR.230	ISM (E.08), Compliance (E.09)	GV.OV – Oversight; GV.RR – Roles, Responsibilities, and Authorities; PR.DS – Data Security; PR.PS – Platform Security; RS.AN – Incident Analysis; GV.SC – Cybersecurity Supply Chain Risk Management; ID.RA – Risk Assessment
Regularly assess the effectiveness and maturity of the ISMS	Operational	IS.AR.235(a)	ISM (E.08)	GV.OV – Oversight; ID.IM – Improvement
Take actions to improve the ISMS if required. Reassess the ISMS elements	Operational	IS.AR.235(b)	ISM (E.08)	GV.OV – Oversight;

Part-IS main task	Activity type	Reference		
	Management, Operational	Part-IS	EU e-CF	NIST CSF 2.0
			Competence areas & skills	Functions & categories
affected by the implemented measures.				ID.IM – Improvement

Appendix III — Examples of aviation services and interfaces

ED Decision 2025/015/R

AVIATION SERVICES

The following is a non-exhaustive and non-complete list of aviation services that can be used as a basis to identify the scope of risk assessment for the organisation.

- aerodrome & ATM-MET service providers
- aeronautical digital mapping services
- aeronautical information management (AIM) – external, national, regional
- airports
- air traffic control (ATC) – external, superior
- air traffic management (ATM)
- approach (APP) & area control (ACC) Services – ER ACC, APP ACC
- cargo and passenger loading
- civil & state airspace user (AU) operations centres
- communication infrastructure
- flight information services / traffic information services (FIS/TIS) data integrator
- fuel calculation
- navigation infrastructure – ground-based, satellite-based
- non-ATM meteorological (MET) service providers
- mass & balance calculation
- non-aviation users (external)
- regional & sub-regional airspace management (ASM) and air traffic flow & capacity management (ATFCM)
- static aeronautical data services
- sub-regional demand & capacity balancing (DCB) common service providers
- surveillance infrastructure – airport, en-route, terminal manoeuvring area (TMA)

- route planning
- time reference services (external)
- tower (TWR) services

INTERFACES

Below are some examples of data exchange at the interfaces between organisations interacting in different functional chains, which can be used as a basis for identifying the scope of the risk assessment for the organisation.

Note 1: These examples are graphical representations based on the ‘**Examples of ecosystem data exchange**’ provided in **EUROCAE ED-201A, Appendix B - Tables B-14**, which can be consulted for further information.

Note 2: Although it is not an organisation, an aircraft has been included in all these examples for the sake of completeness of the description of the data exchange. The aircraft should be considered as an element within the scope of the ISMS of the organisation to which it belongs (typically the airline). Any data exchange between aircraft and other systems within the organisation should take into account existing security measures that may have been evaluated as part of aircraft certification (see also [GM1 IS.AR.205\(c\)](#)).

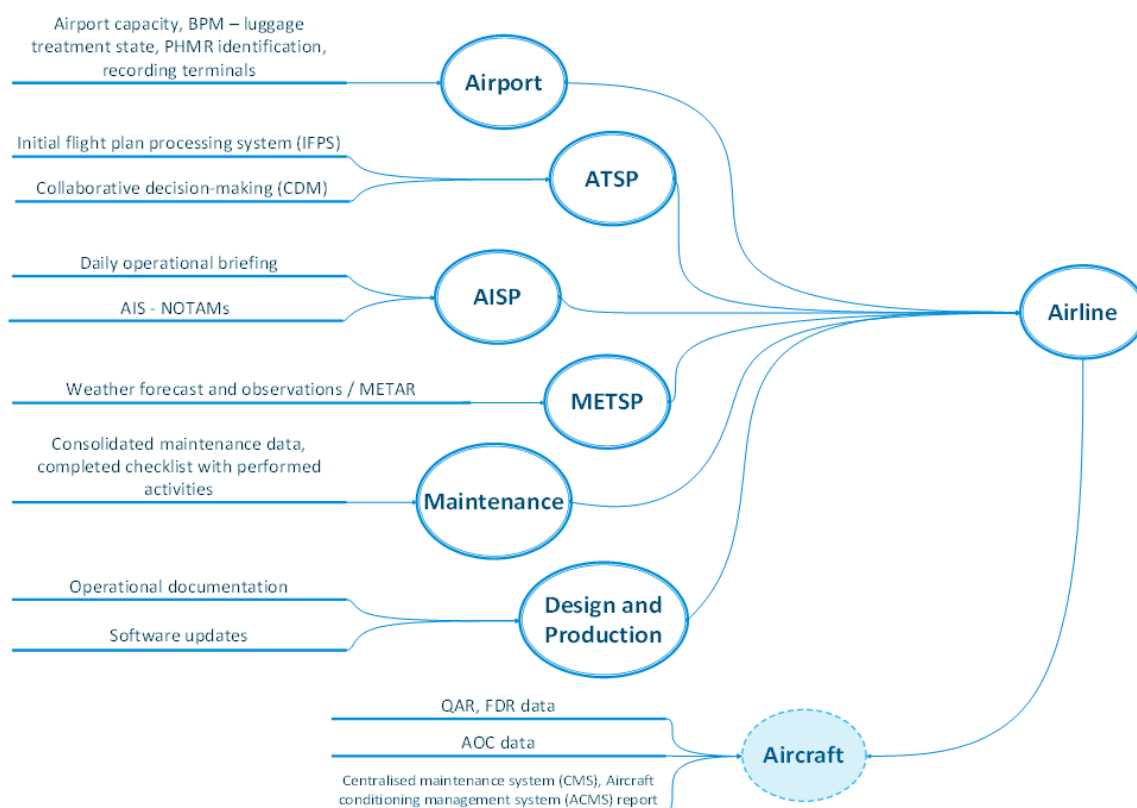


Figure 1: Interfaces of other organisations with an airline operator

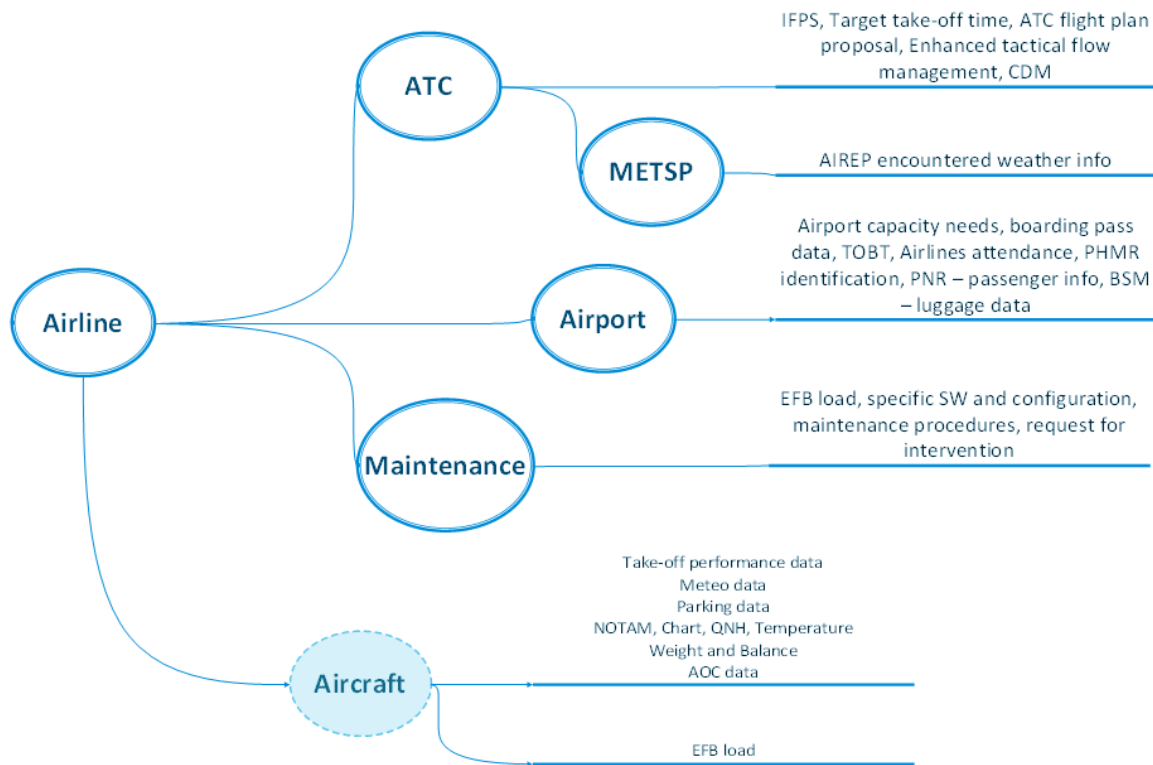


Figure 2: Interfaces of an airline operator with other organisations

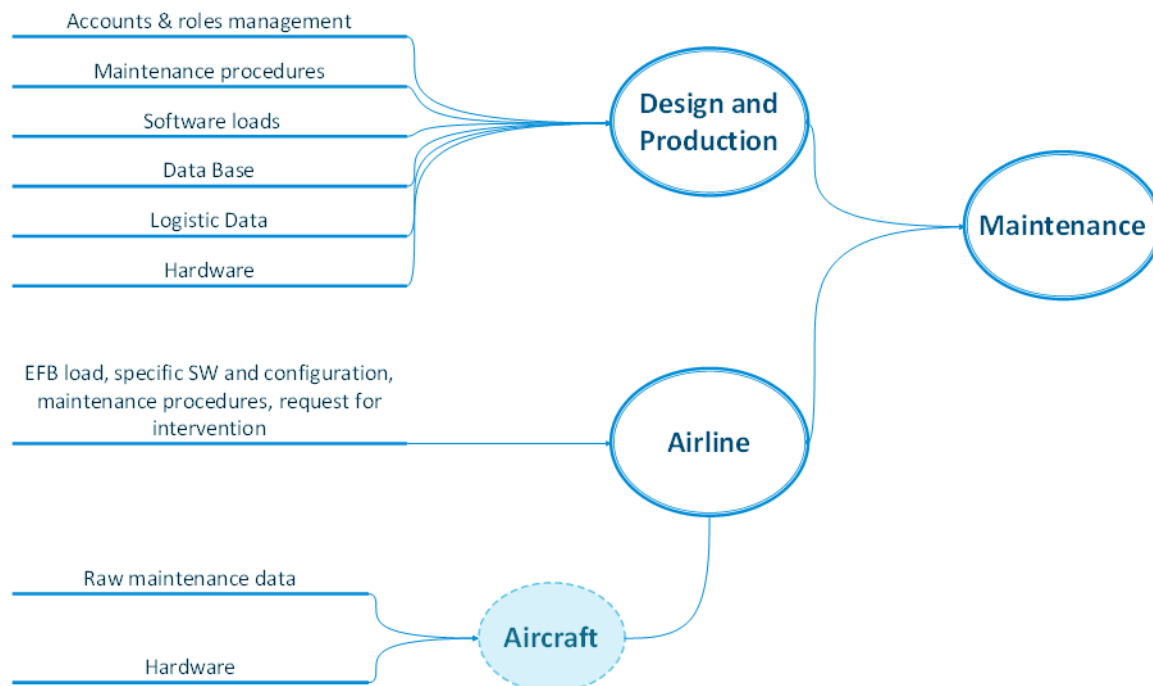


Figure 3: Interfaces of other organisations with a maintenance service provider

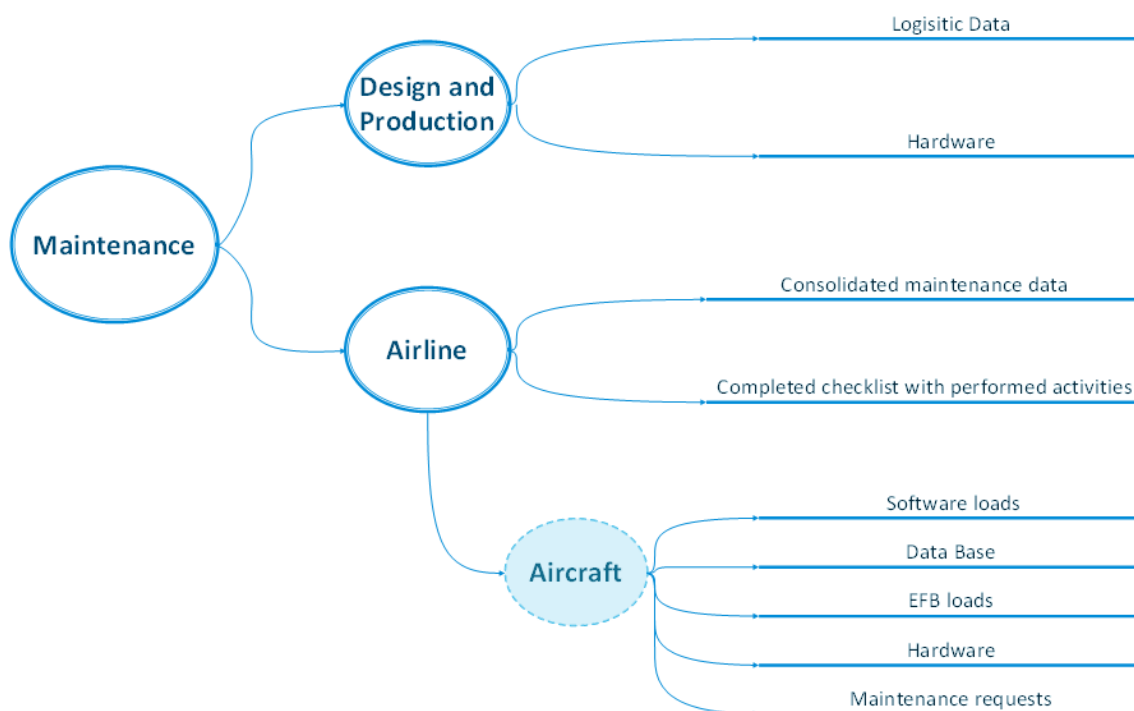


Figure 4: Interfaces of a maintenance service provider with other organisations

Appendix IV — Part-IS requirements mapping to ISO/IEC 27001:2022 clauses and controls, and considerations on differences

ED Decision 2025/015/R

Although Part-IS does not credit ISO/IEC 27001 certification, the practices and methods typically adopted for implementing and maintaining an ISMS under ISO/IEC 27000 largely align with the objectives of this regulation. Therefore, entities that have already implemented an ISMS under ISO/IEC 27001 can use this as a basis for Part-IS compliance.

The following provides guidance on how competent authorities that have already implemented an ISMS compliant with ISO/IEC 27001:2022 can integrate Part-IS requirements into their existing ISMS. Specifically, the table below illustrates how to incorporate the ‘Part-IS particularity’ of each requirement into an existing ISO/IEC 27001-based ISMS in order to achieve Part-IS compliance. This is referred to as ‘Guidance on Part-IS implementation’.

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
IS.AR.200(a)	Related ISO/IEC 27001:2022 clauses and controls
	4. Context of the organisation
	6.1.1 Actions to address risks and opportunities - General
	Part-IS particularity
	An ISMS designed in the context of an ISO/IEC 27001:2022 ISMS, which is currently not connected to the management systems required by the delegated and implementing acts of Regulation (EU) 2018/1139, including Part-IS, may differ if these different systems do not address the same goals. Part-IS focuses on information security requirements meeting the applicable aviation safety objectives, which have an influence on elements of the ISMS. Also, the ‘interested parties’ and the ‘internal and external issues’ as laid down in Chapter 4 of ISO/IEC 27001:2022 may be adapted to address the requirements of Part-IS for the competent authority.
IS.AR.200(a)(1)	Guidance on Part-IS implementation
	<i>Please note that the point IS.AR.200 requirement points to many other Part-IS requirements that the ISMS has to comply with, namely points 205, 210, 215, 220, 225, 230 and 235. Further details are provided in the specific chapters on the particular requirement.</i>
	Regarding the other remaining requirements, not pointing out to other Part-IS requirements, and comparing them with ISO/IEC 27001:2022, there are five requirements left, namely points IS.AR.200(a)(1), IS.AR.200(a)(8), IS.AR.200(a)(9), IS.AR.200(a)(10) and IS.AR.200(a)(11).
	Related ISO/IEC 27001:2022 clauses and controls
	5.2 Policy
IS.AR.200(a)(1)	A.5.1 Policies for information securities
	Part-IS particularity
	An ISMS designed in the context of an ISO/IEC 27001:2022 ISMS, which is currently not connected to the management systems required by the delegated and implementing acts of Regulation (EU) 2018/1139, may differ as these different systems do often not address the same goals. Part-IS focuses on information security requirements influencing the applicable aviation safety objectives, which in their turn have an influence on the elements of the ISMS.
	Guidance on Part-IS implementation
	The policy on information security established in an ISO/IEC 27001:2022 context has to be updated with regard to the potential impact of the risks on aviation safety . At least the elements of AMC1 IS.AR.200(a)(1) have to be mentioned in the policy. Therefore, the following elements may need to be added to an existing ISMS policy. The elements in bold and <i>italics</i> are additional guidance that might also be considered.
IS.AR.200(a)(1)	(a) committing to complying with applicable legislation, considering relevant standards and best practices, <i>including safety- and cybersecurity-related standards and guidance published or prescribed by ICAO or EASA;</i>

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	(b) setting objectives and performance measures for managing information security, updated to ensure meeting the applicable aviation safety objectives; (c) defining general principles, activities, processes for the competent authority to appropriately secure information and communication technology systems and data, in relation to the information security / safety risk assessment required by point IS.AR.205; (d) committing to applying ISMS requirements into the processes of the competent authority; (e) committing to continually improving towards higher levels of information security process maturity as per point IS.AR.235; (f) committing to satisfying applicable requirements regarding information security and its proactive and systematic management and to providing appropriate resources for its implementation and operation; (g) assigning information security as one of the essential responsibilities for all managers; (h) committing to promoting the information security policy through training or awareness sessions within the competent authority to all personnel on a regular basis or upon modifications; (i) encouraging the implementation of a ‘just culture’ and the reporting of vulnerabilities, suspicious/anomalous events and/or information security incidents; (j) committing to communicating the information security policy to all relevant parties, as appropriate.
IS.AR.200(a)(8)	Related ISO/IEC 27001:2022 clauses and controls 9.2. Internal audit 9.3. Management review 10.2. Non-conformity and corrective action - A5.36. Compliance with policies, rules and standards for information security Part-IS particularity This requirement is strongly related to the internal audit system and the independent checking function of ISO/IEC 27001:2022. The required feedback system to the person referred to in point IS.AR.225(a) fits into the requirement of 9.3. In addition, all delegated and implementing acts for the specific domains require a similar ‘compliance monitoring function’, where information security should be integrated as described in AMC1 IS.AR.200(a)(8). Guidance on Part-IS implementation The requirements of ISO/IEC 27001:2022 and the delegated and implementing acts of Regulation (EU) 2018/1139 are compatible. Therefore, it will be easy to integrate Part-IS into the audit scope of the ISO/IEC 27001:2022 internal audit system.

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	The role of the the person referred to in point IS.AR.225(a) has to be addressed accordingly in the feedback loop if the role is not already addressed in the management review process. This person is required to be personally briefed on the key findings so that appropriate decisions can be made. Refer also to GM1 IS.AR.200(a)(8). <i>Note: ISO 19011:2018 provides guidance on the establishment of an internal audit system. Specifically, Chapter A.7 ‘Auditing compliance within a management system’ provides useful guidance on how to integrate a compliance monitoring function into an internal audit system.</i>
IS.AR.200(a)(9)	Related ISO/IEC 27001:2022 clauses and controls 7.5.3. Control of documented information (Note) A5.12 Classification of information A5.34 Privacy and protection of personal identifiable information (PII) A8.12 Data leakage prevention Part-IS particularity This requirement is limited to ‘information related to oversight activities and received through the organisation’s external reporting scheme’ and to confidentiality. ISO/IEC 27001:2022 does not differentiate between type of information (as laid down e.g. in ISO 9001:2015 Chapter 8.5.3). The only reference is made in the note in Chapter 7.5.3. Part-IS stresses protection of information-related oversight activities and external information received due to the sensitivity it may have regarding incidents and vulnerabilities disclosure. Insufficient confidentiality protection may result in exploitation of vulnerabilities affecting safety that the original provider of information may not have perceived. Guidance on Part-IS implementation The protection of information, specifically regarding confidentiality (as in ISO/IEC 27002:2022), is related to a set of controls that can be found in Table A.1 (Matrix of controls and attribute values) of ISO/IEC 27002:2022. See also the definition in ISO/IEC 27002:2022: <i>3.1.7 Confidential information</i> <i>Information that is not intended to be made available or disclosed to unauthorized individuals, entities or processes.</i> The competent authority having implemented these controls should take special care that they apply to external information that may result in information security threats if known by unauthorised actors. When this kind of information is further shared with other entities, appropriate confidentiality procedures must be put in place and followed (TLP marking for instance).
IS.AR.200(a)(10) and IS.AR.200(11)	Related ISO/IEC 27001:2022 clauses and controls A5.5 Contact with authorities

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	Part-IS particularity
	These requirements are not directly addressed in ISO/IEC 27001:2022.
	Guidance on Part-IS implementation
	This is not covered by the requirements of ISO/IEC 27001:2022, so it is not possible to adapt existing policies and procedures under ISO/IEC 27001:2022 for these provisions. To ensure compliance with these requirements, please refer exclusively to the related AMC and GM.
IS.AR.200(b)	Related ISO/IEC 27001:2022 clauses and controls
	10.1 Continual improvement
	Part-IS particularity
	Part-IS and ISO/IEC 27001:2022 are very similar regarding this requirement. See points IS.AR.235 (a) and (b) for subtle differences.
	Guidance on Part-IS implementation
	See point IS.AR.235 in this table.
IS.AR.200(c)	Related ISO/IEC 27001:2022 clauses and controls
	6.3 Planning of changes
	7.5.3 Control of documented information
	Part-IS particularity
	Control of documented information is one of the key processes in each ISO management system standard, following the ISO ‘high-level structure’ (ISO/IEC Directives part 1 Annex SL), such as ISO/IEC 27001:2022.
	In addition, most of the delegated and implementing acts for the specific domains require a similar need to document, where information security should be integrated.
	Guidance on Part-IS implementation
IS.AR.200(d)	Additional guidance is provided under GM1 IS.AR.200(c) .
	Related ISO/IEC 27001:2022 clauses and controls
	4.3 Determining the scope of the information security management system.
	Part-IS particularity
	The scope statement and the ‘statement of applicability’ (SOA) are the best references to apply the ‘nature and complexity’.
	In addition, most of the delegated and implementing acts for the specific domains require a similar need to document, where information security should be integrated.
	Guidance on Part-IS implementation
	When determining the scope, it should be noted that Part-IS is delimited to the subject matter as defined in Article 1 of the Regulation(s), which refers to

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	<i>identification and management of information security risks with potential impact on aviation safety.</i> Considering this, the scope of an ISMS under ISO/IEC 27001:2022 may be broader than that required by Part-IS. Some organisational units, processes or locations may fall under what is covered by the ISMS under ISO/IEC 27001:2022, but not within the scope of Part-IS. The opposite may happen too: the scope under ISO/IEC 27001:2022 may be narrower than the one Part-IS would require (e.g. the ISO/IEC 27001:2022 scope covers only the IT department). In both situations, scope definitions have to be compared and adjusted when necessary. <i><u>Note:</u> See also guidance on point IS.AR.205(a) in this table.</i> The scope statement in the ISO/IEC 27001:2022 context is the right place where this clarification is made.
IS.AR.205(a)	Related ISO/IEC 27001:2022 clauses and controls 4.3 Determining the scope of the information security management system 6.1.2 Information security risk assessment Part-IS particularity This requirement of Part-IS is in line with ISO/IEC 27001:2022, however ISO/IEC 27001:2022 allows a wider focus, whereas Part-IS puts the focus on safety already from the element's identification stage. In addition, all of the delegated and implementing acts for the specific domains require a risk assessment process, where information security can be integrated. Guidance on Part-IS implementation AMC1 IS.AR.205(a) explains that when conducting an information security risk assessment, the competent authority should ensure that each relevant aviation safety impact is identified and included in the ISMS scope, which might not be the case when using ISO/IEC 27001:2022. On the other hand, an ISO/IEC 27001:2022 ISMS focuses its security risk assessment mainly on the business impact of infringement on confidentiality, integrity and availability, their risks and the impact on assets (e.g. loss of IT infrastructure, breach of data). This means that, starting from an ISMS based on ISO/IEC 27001:2022, a complementary analysis has to be made to take into account all the elements related to aviation safety. To bridge the two approaches of management systems (SMS and ISMS), an identified information security risk may be entered as a 'cause' or 'contributing event' in the aviation-safety-focused risk assessment required by the domain-specific implementing or delegated act. The figure in GM1 IS.AR.205(c) provides a good indication of how this bridge could be built.

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
IS.AR.205(b)	Related ISO/IEC 27001:2022 clauses and controls
	4.1 Understanding the organisation and its context
	4.3 Determining the scope of the information security management system
	A5.19 Information security in supplier relationships
	A5.21 Managing information security in the information and communication technology (ICT) supply chain
	Part-IS particularity
IS.AR.205(c)	Point IS.AR.205(b) focuses on the identification of interfaces with the other parties. ISO/IEC 27001:2022 4.3 requires considering in point c) the interfaces at and dependencies between activities performed by the competent authority and those that are performed by other parties. So, there is more in Part-IS than that required by ISO/IEC 27001:2022, provided that the scope considered includes safety, as required by point IS.AR.205(a).
	Controls A5.19 and A5.21 are a profound foundation for the requirements of point IS.AR.205(b).
	Guidance on Part-IS implementation
	ISO/IEC 27001:2022 A5.19 requires the identification of risks associated with the use of suppliers' products or services. ISO 27002 A5.19 contains additional guidance in points f) to j) on how to manage the risk exposure.
	ISO/IEC 27001:2022 A5.21 requires the management of information security risks associated with the ICT products and services supply chain. ISO 27002 A5.21 contains additional guidance in points f), k), l) and m) on how to manage risks through the supply chain.
	The Part-IS notion about interfaces and supply chain goes beyond the respective ISO/IEC 27001:2022 notion. GM1 IS.AR.205(b) requests interfacing entities to share information about mutual risk exposure (including all data flows) and urges competent authorities to use ED-201A for that. Point IS.AR.205(c) also requires accounting for information acquired by interfacing entities, which underlines the two-way nature of the considerations.
IS.AR.205(c)	Related ISO/IEC 27001:2022 clauses and controls
	6.1.2 Information security risk assessment
	Part-IS particularity
	Point IS.AR.205(c) is the 'heart' of Part-IS. ISO/IEC 27001:2022 6.1.2 opens a 'framework' where the requirements of point IS.AR.205 may fit in.
	It has to be assured that the risk management systems of the ISMS and those required by the SMS-regulations (see point IS.AR.205(a)) do NOT operate independently, as there might be difficulties in connecting the two systems.
	Guidance on Part-IS implementation
IS.AR.205(c)	Further to this provision, a proper risk assessment has to be made, taking into account the scope and interfaces described in points IS.AR.205(a) and IS.AR.205(b). It has to

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	be noted (see also GM1 IS.AR.205(c)) that point IS.AR.205 does not require the use of any specific information security risk assessment framework, such as ISO31000, NIST or others to develop the risk assessment. ISO/IEC 27001:2022 tends to lean towards using ISO 27005 as a risk assessment standard; however, it does not make it mandatory. The key point is that the risk assessment carried out in the application of ISO/IEC 27001:2022 6.1.2 does not necessarily consider safety risks, and may focus on different types of risks. With respect to safety, conditions that may lead to safety consequences are identified as hazards. Their materialisation may be either directly triggered or caused by information security threats which have not been successfully prevented. Information security can thus cause or contribute to a safety consequence in four different ways: (1) it can act as a safety threat; (2) it can have a negative effect on a safety barrier, rendering it less effective than before; (3) it can directly trigger the materialisation of an already identified hazard; or (4) it can constitute a new, not yet identified, hazard, which can obviously also materialise. By using e.g. the ‘bow-tie method’ regarding information security, a ‘hazard’ would be replaced by a ‘vulnerability’, which can be exploited resulting in information security consequences (e.g. lack or reduction of confidentiality, integrity, availability, authenticity properties). Hence, from a methodology perspective, both considerations are very similar and can be designed to interact (e.g. consequences of the information security bow-tie may connect as causes of the ‘safety bow-tie’). Where the authority has implemented an SMS and operates an ISMS under voluntary compliance with ISO/IEC 27001:2022, it may operate two risk management systems, one for safety and one for information security. The latter may ultimately be certified by an ISO/IEC 27001:2022-accredited body. Each potential risk identified by the ISMS risk management has to be systematically assessed for its potential impact on safety. To establish the connection between the systems, the following approach should be used: (1) If a safety risk assessment is available, it should be able to provide its context and determined target likelihoods for acceptable information security risks to the information security risk assessment process. The context consists of the system architecture, including its preventative and mitigative barriers, the hazards assessed and the safety risks identified. Based upon the information provided, the information security risk assessment can be conducted. Modifications to the system architecture, or any modifications of properties of the preventative or mitigative barriers, as well as the achieved risk properties need to be communicated back to the safety risk assessment process. Based upon this communication, the safety risk assessment has to be updated. In other words: mitigation measures put in place as a result of the information security risk assessment should also be considered as they may not only mitigate, but possibly also create a negative safety impact. (2) If a safety risk assessment is available, but the information security assessment process identifies a new hazard that was previously unknown to the safety risk assessment, a full hazard assessment of all safety aspects has to be conducted

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	to ensure that the safety risk assessment contains the ‘full picture’ of the newly addressed hazard. (3) The safety risk and the information security risk assessments need to be repeated as described above until all acceptability requirements for all aspects are met.
IS.AR.205(d)	Related ISO/IEC 27001:2022 clauses and controls
	6.3 Planning of changes
	8.2 Information security risk assessment
	Part-IS particularity
	Point IS.AR.205(d) is about the subsequent changes to the original risk assessment, due to a change of context or interfaces or knowledge about the risks or lessons learnt. This is equivalent to ISO/IEC 27001:2022 8.2. In both frameworks the reviews are planned and documented.
	Guidance on Part-IS implementation The same process as that already in place in an ISO/IEC 27001:2022 context can be used to implement point IS.AR.205(d), provided that this process has been updated to include safety criteria evaluation of changes that trigger an unplanned update of the risk assessment. Those competent authorities that have most experienced risk assessment updates at planned intervals will need to be proactive to trigger such updates more often in the situations listed in points IS.AR.205(d) (1), (2), (3), and (4) that could affect safety. The triggering criteria and the process should be documented and tested before implementation, for example through table-top exercises. The change management process is key to keep a management system in a solid and stable condition. Considering an established ISMS according to ISO/IEC 27001:2022, the regular updates of the risk assessment based on changes and lessons learned should be effective. The essential focus, introduced by Part-IS, is the ‘impact on safety’, which drives the update assessment. Change management processes focusing on changes that may have impact on safety are also set out in all domain-specific implementing and delegated acts. Without the ‘bridge’ of Part-IS, both systems (ISMS and SMS) are implemented independently, often without considering interdependencies. Part-IS implies the need (and provides the opportunity) to interlink the systems to provide a common risk picture for the competent authority, with a focus on safety, but also opening the horizon to information security.
IS.AR.210 (a)	Related ISO/IEC 27001:2022 clauses and controls
	6.1.3 Information security risk treatment
	8.3 Information security risk treatment
	Part-IS particularity

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	Point IS.AR.210(a) is about information security risk treatment, which is widely covered by ISO/IEC 27001:2022, its Appendix A, and ISO/IEC 27002. Point IS.AR.210(a) provides however some additional inputs related to the risks that may have a safety impact. Guidance on Part-IS implementation ISO/IEC 27001:2022 6.1.3 is about the definition of the risk treatment plan, while ISO/IEC 27001:2022 8.3 deals with the implementation of the plan, and both are relevant. ISO/IEC 27001:2022 Annex A contains a list of possible information security controls, and therefore should also be used in addition to the already existing controls, to mitigate information security risks having an impact of safety. All the controls of Annex A are detailed in ISO/IEC 27002. Point IS.AR.210(a) specifies that the measures selected in the plan have to reduce the consequences on aviation safety associated with the materialisation of the threat scenario. This is in line with IS.AR.205 since the risk treatment phase is a consequence of the risk assessment phase and has to address all the risks that have been evaluated. Point IS.AR.210(a) also stipulates that those (protection) measures shall not introduce any new potential unacceptable risks to aviation safety. This is an area that is not directly covered by either ISO/IEC 27001:2022 or ISO/IEC 27002. The requirement addresses the so-called ‘side effects’ when introducing measures into a system (a well-known issue in software development which is also very relevant for information security measures). Preventive or mitigative measures specifically (e.g. physical security, access control) could lead to unintended side effects. Also, the risk treatment of the identified risks should focus on addressing safety via the same linkage/integration of ISMS and safety management.
IS.AR.210(b)	Related ISO/IEC 27001:2022 clauses and controls 6.1.3.f Information security risk treatment 7.3 Awareness 9.3 Management review A5.19 Information security in supplier relationships A5.21 Managing information security in the ICT supply chain Part-IS particularity Point IS.AR.210(b) requires key personnel in the competent authority to be informed about the risks, the corresponding threat scenarios and the security risk treatment measures, which result in specific controls covered by Annex A to ISO/IEC 27001:2022 and ISO/IEC 27002. It partially covers point IS.AR.210(b) by the following requirement: obtain risk owners’ approval of the information security risk treatment plan and acceptance of the residual information security risks. Point IS.AR.210(b) has two specific requirements that also have equivalent requirements in ISO/IEC 27001:2022 and ISO/IEC 27002:

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	— Inform the person referred to in point IS.AR.225(a) of the risk treatment plan — which is a mandatory input to the management review. — Inform the interfacing entities (the same as in point IS.AR.205(b)) of all risks shared with them — which is stated in A5.19 Guidance point I). Guidance on Part-IS implementation In addition to the risk owner's approval requested by ISO/IEC 27001:2022 6.1.3.f, the competent authority will need to inform: — the person referred to in point IS.AR.225(a) of the risk treatment plan. ISO/IEC 27001:2022 9.3. f) defines 'results of risk assessment and status of risk treatment plan' as mandatory input for the management review which is the vehicle to inform the person referred to in point IS.AR.225(a); — the interfacing entities (the same as in point IS.AR.205(b)) of all risks shared with them. ISO/IEC 27002 A5.21 states in point f) 'defining rules for sharing of information and any potential issues and compromises between the organisations'. GM1 IS.AR.205(b) and ED-201A may also be used as guidance on risk sharing.
IS.AR.215(a)	Related ISO/IEC 27001:2022 clauses and controls A5.24 Information security incident management planning and preparation A5.25 Assessment and decision on information security events A5.26 Response to information security incidents A5.27 Learning from information security incidents A5.28 Collection of evidence A5.29 Information security during disruption A7.5 Physical security monitoring A8.16 Monitoring activities Part-IS particularity Fully covered by the requirements of A5.24 to A5.29, and A7.5 for physical security and A8.16 for technical monitoring. Guidance on Part-IS implementation The requirements of the controls (both reactive and proactive) mentioned above and the guidance in ISO/IEC 27002:2022 are comprehensive to fulfil the requirements of point IS.AR.215(a). Again, the impact on safety needs to be assessed, and measures shall be taken to ensure safety. Part-IS refers to 'unsafe conditions', which have to be mitigated to an acceptable level. A re-assessment of risks that are related to incidents that have occurred or to a vulnerability that has been identified is mandatory in Part-IS to ensure that no risk becomes unacceptable. <i>Note: Due to historical reasons, information security and safety management use different wording when referring to situations which are more or less the same. The</i>

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	<i>term ‘incident’ is used in a similar way (an event which already happened and infringes safety/security). A vulnerability in the sense of information security could be mapped to the term ‘hazard’ in the area of safety (a situation identified, which is possible to happen, but has not happened so far).</i>
IS.AR.215(b)	Related ISO/IEC 27001:2022 clauses and controls
	A5.26 Response to information security incidents
	A5.29 Information security during disruption
	A7.5 Physical security monitoring
	A8.8 Management of technical vulnerabilities
	Part-IS particularity
IS.AR.215(c)	Fully covered by the requirements of A5.26 and A5.29.
	Guidance on Part-IS implementation
	The requirements of the control A5.26 and the guidance in ISO/IEC 27002:2022 are comprehensive to fulfil the requirements of point IS.AR.215(b).
	Related ISO/IEC 27001:2022 clauses and controls
	A5.26 Response to information security incidents
	A5.29 Information security during disruption
IS.AR.220	Part-IS particularity
	This requirement is covered by the requirements of A5.26 and A5.29, with the difference that the recovery here is not intended to continuously ensure confidentiality, integrity, availability and integrity; instead, it is intended to maintain or return to an acceptable level of safety.
	Guidance on Part-IS implementation
	Coupled with the requirements of controls A5.26 and A5.28 and the guidance in ISO/IEC 27002:2022, AMC1.IS.AR.215(c) should be applied in order to revert as quickly as possible to a safe state.
	Related ISO/IEC 27001:2022 clauses and controls
	A5.19 Information security in supplier relationships
IS.AR.220	A5.21 Managing information security in the information and communication technology (ICT) supply chain
	A5.22 Monitoring, review and change management of supplier services
	Part-IS particularity
	ISO/IEC 27001:2022 controls A5.19, A5.21 and A5.29 may cover this requirement. The difference in the requirements of point IS.AR.220 is that they are limited to those activities directly related to the ISMS (e.g. internal audits, consultancy for risk assessments, etc.).

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	Guidance on Part-IS implementation This requirement relates only to ISMS activities (e.g. internal audits, risk assessments), not to those activities not directly related to ISMS itself (e.g. hardware, software, IT and OT). The difference in the requirements of point IS.AR.220 is that they are limited to those activities directly related to the ISMS (e.g. internal audits, consultancy for risk assessments, etc.). The controls in ISO/IEC 27001:2022 do not exclude those kinds of services, but sometimes they will not be in the focus of the competent authority. Therefore, there is no need to establish an independent system for those contractors referred to in point IS.AR.220. The list of suppliers should be reviewed to ensure that the suppliers providing the services mentioned in point IS.AR.220 are covered.
IS.AR.225(a)	Related ISO/IEC 27001:2022 clauses and controls 5.1 Leadership and commitment 5.3 Organisational roles, responsibilities and authorities 7.1 Resources A5.2 Information security roles and responsibilities Part-IS particularity ISO/IEC 27001:2022 does not require a specific role. Guidance on Part-IS implementation The implementation of the requirements of point IS.AR.225(a) can be covered by the implementation of ISO/IEC 27001:2022 requirements mentioned above, provided that the role of the person referred to in point IS.AR.225(a) is clearly defined and meets the requirements in point IS.AR.225(a).
IS.AR.225(b)	Related ISO/IEC 27001:2022 clauses and controls 7.1 Resources Part-IS particularity The requirements of 7.1 should be implemented. Guidance on Part-IS implementation A systematic capacity planning of human resources is a key element of any management system. Therefore, such a process should be established in an ISMS. The possible additional requirement stemming from Part-IS has to be assessed and the capacity planning updated accordingly. The targeted safety levels set in the safety/information security assessment should never be jeopardised by a lack of resources, even temporarily. AMC1 IS.AR.225(b) should be considered.
IS.AR.225(c)	Related ISO/IEC 27001:2022 clauses and controls

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	7.2 Competency
	A6.3 Information security awareness, education and training
	Part-IS particularity
	The implementation of the requirements of 7.2 and A6.3 is sufficient to cover the requirement.
	Guidance on Part-IS implementation A systematic competency management process of staff is a key element of any management system. Therefore, such a process should have been established in an ISMS. The possible additional requirement stemming from Part-IS has to be assessed and the competency requirements updated accordingly. AMC1 IS.AR.225(c) should be considered.
IS.AR.225(d)	Related ISO/IEC 27001:2022 clauses and controls
	A6.2 Terms and conditions of employment
	Part-IS particularity
	The implementation of the requirements of A6.2 with some adaptation would be sufficient to cover the provision of point IS.AR.225(d).
	Guidance on Part-IS implementation Point IS.AR.225(d) is (at least partially) covered by ISO/IEC 27001:2022 A.6.2 ‘The employment contractual agreements should state the personnel’s and the organisation’s responsibilities for information security.’ and A.6.4 ‘disciplinary process’ (see ‘Just Culture’). It depends on the organisational culture and on whether job descriptions or role assignments need to be formally acknowledged. In many cases, the assigned jobs and roles are mutually acknowledged by performing the tasks assigned.
IS.AR.225(e)	Related ISO/IEC 27001:2022 clauses and controls
	A5.19 Information security in supplier relationships
	A6.1 Screening
	A7.2 Physical entry
	A8.3 Information access restriction
	A8.5 Secure authentication
	Part-IS particularity
	The implementation of the requirements of A5.19, A6.1, A7.2, A8.3 and A8.5 might be sufficient controls to cover this requirement for the personnel of the competent authority, as well as for contractors and suppliers.
	Guidance on Part-IS implementation All the controls established in an ISO/IEC 27001:2022-compliant ISMS are designed to ensure the confidentiality and integrity of information. The implementation of those

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	controls will provide sufficient protection to ensure compliance with this requirement. AMC1 IS.AR.225(e) should be considered.
IS.AR.230(a)	Related ISO/IEC 27001:2022 clauses and controls 7.5 Documented information A5.9 Inventory of information and other associated assets A5.13 Labelling of information A8.10 Information deletion A8.13 Information backup Part-IS particularity Record-keeping and retention are an inherent part of the document control system under 7.5 of ISO/IEC 27001:2022. Controls A5.9, A5.13, A8.10 and A8.13 also apply. Guidance on Part-IS implementation Chapter 7.5.1 b) states that the ISMS has to include ‘documented information determined by the competent authority as being necessary for the effectiveness of the information security management system.’ This includes the records defined in point IS.AR.230(a)(1). Chapter 7.5.3 requires, under f), also document control for retention and disposition. Part-IS requirements have to be integrated into the existing system, especially the minimum duration of record-keeping of five years. The minimum set of records, as defined in point IS.AR.230(a)(1) should be covered in the inventory of assets. For the coverage, the content of GM1 IS.AR.230 also applies. As records are not only information assets, the requested ‘record retention policy’ may be integrated into a wider policy as recommended by ISO/IEC 27002:2022 above. AMC1 IS.AR.230(a)(1)(iv)&(a)(4) should be implemented.
IS.AR.230(b)	Related ISO/IEC 27001:2022 clauses and controls 7.5 Documented information A5.9 Inventory of information and other associated assets A5.10 Acceptable use of information and other associated assets A5.13 Labelling of information A5.34 Privacy and protection of personal identifiable information (PII) A8.10 Information deletion A8.13 Information backup Part-IS particularity Record-keeping and retention are an inherent part of the document control system under 7.5 of ISO/IEC 27001:2022. Controls A5.9, A5.13, A8.10 and A8.13 will also apply and, due to GDPR issues specifically, also A5.10 and A5.34.

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	Guidance on Part-IS implementation
	Chapter 7.5.1 b) states that the ISMS has to include ‘documented information determined by the competent authority as being necessary for the effectiveness of the information security management system.’ This includes the records defined in point IS.AR.230(a)(1). Chapter 7.5.3 requires, under f), also document control for retention and disposition. Part-IS requirements have to be integrated into the existing system, especially the minimum duration of record-keeping of five years.
	However, whereas there is no retention duration specified in ISO/IEC 27001:2022, point IS.AR.230(b) specifies three years after the person has left the competent authority.
	As these records fall under the GDPR Regulation, each competent authority has to ensure that they are handled accordingly. It is recommended that the procedures are used not only for records related to ISMS, but also for the entire HR personnel files of the staff.
IS.AR.230(c)	Related ISO/IEC 27001:2022 clauses and controls
	7.5 Documented information
	A5.13 Labelling of information
	Part-IS particularity
	Record-keeping and retention are an inherent part of the document control system under 7.5 of ISO/IEC 27001:2022 as well as control A5.13.
	Guidance on Part-IS implementation
	Chapter 7.5.3, under a), requires for the information that ‘it is available and suitable for use, where and when it is needed’. Part-IS requirements have to be integrated into the existing system.
	ISO/IEC 27002:2022 A5.13 states ‘Procedures for information labelling should cover information and other associated assets in all formats.’; therefore, the Part-IS requirement is fulfilled with control A5.13.
IS.AR.230(d)	Related ISO/IEC 27001:2022 clauses and controls
	7.5 Documented information
	A5.10 Acceptable use of information and other associated assets
	A5.12 Classification of information
	A5.33 Protection of records
	A8.12 Data leakage prevention
	Part-IS particularity
	Record-keeping and retention are an inherent part of the document control system under 7.5 of ISO/IEC 27001:2022. Controls A5.10, A5.12, A5.33 and A8.12 will also apply.
	Guidance on Part-IS implementation

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	Chapter 7.5.3, under d), requires ‘storage and preservation, including the preservation of legibility’. Part-IS requirements have to be integrated into the existing system. The application of A5.33 and A8.12 has a strong relationship to A7.5 (Protecting against physical and environmental threats), A7.10 (Storage media), A8.3 (Information access restriction), A8.13 (Information backup), A8.14 (Redundancy of information processing facilities), A8.15 (Logging), A8.17 (Clock synchronization) and A8.24 (Use of cryptography).
IS.AR.235(a)	Related ISO/IEC 27001:2022 clauses and controls
	9.3 Management review 10.1 Continual improvement A5.35 Independent review of information security
	Part-IS particularity
	This requirement reflects a combination of requirements 9.3 and 10.1 of ISO/IEC 27001:2022 with references to requirements 4.4 and 5.2. While ISO/IEC 27001:2022 focuses on ISMS suitability, adequacy and effectiveness, point IS.AR.235(a) requires also a periodical maturity assessment of the ISMS.
	Guidance on Part-IS implementation ISO/IEC 27001:2022, 4.4 shows a clear requirement (‘shall’) for ISMS maintenance and improvement. The top management has a responsibility for continuous ISMS improvement as per ISO/IEC 27001:2022 5.2(d). The planning section also requires continuous improvement (ISO/IEC 27001:2022 6.1.1(c)). Point IS.AR.235(a) requires an assessment of the effectiveness and maturity of the ISMS on a calendar basis or following an information security incident. This assessment should be performed by using indicators. ISO/IEC 27001:2022 Chapter 9.3.1 defines a very similar approach for the management review process. Chapter 10.1 indicates a more independent process to improve the ISMS. The process in Chapter 10.1 is seen as more of a bottom-up approach, whereas that in Chapter 9.3 is intended to be top-down. The results from A5.35 should all be used as inputs for continuous improvement. Point IS.AR.235(a) requires also a maturity assessment of the ISMS. Each competent authority should establish which maturity model will be followed and which targeted maturity level is expected to be reached and by when. For the maturity assessment, point (b) of AMC1 IS.AR.235(a) and GM1 IS.AR.235(a) provide guidance on how to ensure compliance with point IS.AR.235(a).
IS.AR.235(b)	Related ISO/IEC 27001:2022 clauses and controls
	10.2 Non-conformity and corrective action A5.7 Threat intelligence
	Part-IS particularity

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	Point IS.AR.235(b) addresses the improvement measures, i.e. corrections and corrective actions for the deficiencies detected in point IS.AR.235(a) and the continuous improvement process. This requirement reflects mainly requirement 10.2 of ISO/IEC 27001:2022, even if the term used is ‘non-conformity’, while point IS.AR.235(b) uses the term ‘deficiencies’. Deficiency has a broader meaning than non-conformity. It encompasses the case of a targeted maturity level that would not be reached at the planned date; that would be a deficiency but not necessarily a non-conformity. Guidance on Part-IS implementation The provisions listed in ISO/IEC 27001:2022 10.2 can be used to take corrective actions, to resolve both non-conformities and maturity level gaps.

ANNEX II — ORGANISATION REQUIREMENTS (PART-IS.I.OR)

IS.I.OR.100 Scope

Regulation (EU) 2023/203

This Part establishes the requirements to be met by the organisations referred to in [Article 2\(1\)](#) of this Regulation.

IS.I.OR.200 Information security management system (ISMS)

Regulation (EU) 2023/203

- (a) In order to achieve the objectives set out in [Article 1](#), the organisation shall set up, implement and maintain an information security management system (ISMS) which ensures that the organisation:
- (1) establishes a policy on information security setting out the overall principles of the organisation with regard to the potential impact of information security risks on aviation safety;
 - (2) identifies and reviews information security risks in accordance with point [IS.I.OR.205](#);
 - (3) defines and implements information security risk treatment measures in accordance with point [IS.I.OR.210](#);
 - (4) implements an information security internal reporting scheme in accordance with point [IS.I.OR.215](#);
 - (5) defines and implements, in accordance with point [IS.I.OR.220](#), the measures required to detect information security events, identifies those events which are considered incidents with a potential impact on aviation safety except as permitted by point [IS.I.OR.205\(e\)](#), and responds to, and recovers from, those information security incidents;
 - (6) implements the measures that have been notified by the competent authority as an immediate reaction to an information security incident or vulnerability with an impact on aviation safety;
 - (7) takes appropriate action, in accordance with point [IS.I.OR.225](#), to address findings notified by the competent authority;
 - (8) implements an external reporting scheme in accordance with point [IS.I.OR.230](#) in order to enable the competent authority to take appropriate actions;
 - (9) complies with the requirements contained in point [IS.I.OR.235](#) when contracting any part of the activities referred to in point [IS.I.OR.200](#) to other organisations;
 - (10) complies with the personnel requirements laid down in point [IS.I.OR.240](#);
 - (11) complies with the record-keeping requirements laid down in point [IS.I.OR.245](#);
 - (12) monitors compliance of the organisation with the requirements of this Regulation and provides feedback on findings to the accountable manager to ensure effective implementation of corrective actions;
 - (13) protects, without prejudice to applicable incident reporting requirements, the confidentiality of any information that the organisation may have received from other organisations, according to its level of sensitivity.

- (b) In order to continuously meet the requirements referred to in Article 1, the organisation shall implement a continuous improvement process in accordance with point [IS.I.OR.260](#).
- (c) The organisation shall document, in accordance with point [IS.I.OR.250](#), all key processes, procedures, roles and responsibilities required to comply with point IS.I.OR.200(a), and shall establish a process for amending that documentation. Changes to those processes, procedures, roles and responsibilities shall be managed in accordance with point [IS.I.OR.255](#).
- (d) The processes, procedures, roles and responsibilities established by the organisation in order to comply with point IS.I.OR.200(a) shall correspond to the nature and complexity of its activities, based on an assessment of the information security risks inherent to those activities, and may be integrated within other existing management systems already implemented by the organisation.
- (e) Without prejudice to the obligation to comply with the reporting requirements laid down in [Regulation \(EU\) No 376/2014](#) and the requirements laid down in point IS.I.OR.200(a)(13), the organisation may be approved by the competent authority not to implement the requirements referred to in points (a) to (d) and the related requirements contained in points IS.I.OR.205 through IS.I.OR.260, if it demonstrates to the satisfaction of that authority that its activities, facilities and resources, as well as the services it operates, provides, receives and maintains, do not pose any information security risks with a potential impact on aviation safety neither to itself nor to other organisations. The approval shall be based on a documented information security risk assessment carried out by the organisation or a third party in accordance with point IS.I.OR.205 and reviewed and approved by its competent authority.

The continued validity of that approval will be reviewed by the competent authority following the applicable oversight audit cycle and whenever changes are implemented in the scope of work of the organisation.

GM1 IS.I.OR.200 Information security management system (ISMS)

ED Decision 2025/014/R

An **information security management system (ISMS)** is a systematic approach to establish, implement, operate, monitor, review, maintain and continuously improve the state of information security of an organisation. Its objective is to protect the information assets, such that the operational and safety objectives of an organisation can be reached in a risk-aware, effective and efficient manner.

Generally speaking, an ISMS establishes an information security risk management process, based upon the results of information security impact analyses, which basically determine its scope. If information security breaches may cause or contribute to aviation safety consequences, information security requirements need to limit the impact or influence of information security breaches on levels of aviation safety, which are deemed acceptable. Hence, all roles, processes, or information systems, which may cause or contribute to aviation safety consequences, are within the scope of [Regulation \(EU\) 2023/203](#). The ISMS provides for means to decide on needed information security controls for all architectural layers (governance, business, application, technology, data) and domains (organisational, human, physical, technical). It further allows to manage the selection, implementation, and operation of information security controls. Finally, it allows to manage the governance, risk management and compliance (GRC) within the ISMS scope.

The overall risk assessment considers safety consequences influenced by information security risks. These may emerge as threats, hazards, escalation factors that weaken barriers, or direct triggers of existing hazards. When conducting this assessment, both aspects, information security and safety need to be coordinated throughout the process. This ensures mutual understanding of the objectives

and the implementation of preventive measures against all types of threats or weaknesses, as well as mitigating measures.

The risk management process is thus based on aviation safety risk assessments and derived information security risk acceptance levels, which are designed to effectively treat and manage information security risks with a potential impact on aviation safety caused by threats exploiting vulnerabilities of information assets in aeronautical systems.

Interacting bow-ties is one possible way that allows for a higher-level and non-exhaustive illustration of how different disciplines of risk assessment may need to collaborate to establish a common risk perspective. The below Figure 1 from ICAO Doc 10204 ‘Manual on Aviation Information Security’ illustrates these interactions.

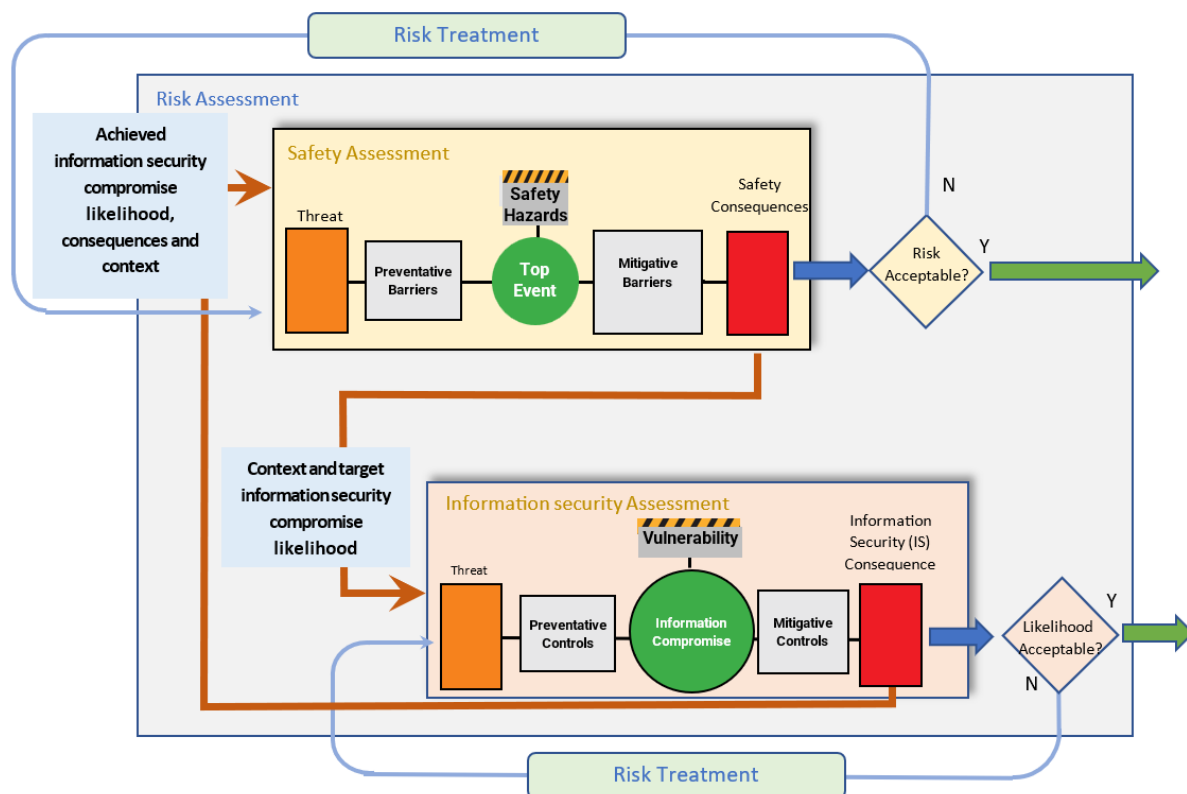


Figure 1: Bow-tie representation of management of aviation safety risks posed by information security threats

In the drawing, the term ‘context’ in the communication between the safety assessment process (SAP) and the information security assessment process (ISAP) carries slightly different notions, which need to be understood and distinguished.

In order to satisfy the safety requirements, the SAP will provide **context information** such as:

- the architecture of the systems and the functional descriptions of the elements within the scope, including those related to the barriers. Systems should be understood as the dynamic interaction between people, processes, and products or services;
- all identified relevant safety hazards;
- the top events and their relations (e.g. triggers) to those hazards.

In addition to context information, it provides the target likelihood of the related information security successful compromise. This target likelihood is commensurate with the safety objectives related to the severity of the safety consequence. However, it needs to be complemented to include information about the acceptable level of uncertainty, in order to be able to rely adequately on the results of the ISAP.

In turn, the ISAP will return **context information** such as:

- modification to the architecture of the systems and functional descriptions of the elements modified or added, whether those were safety barriers or other items;
- additional threats;
- potentially additional safety hazards;
- additional direct triggers of hazards;
- additional escalating factors affecting barriers.

In addition to context information, it provides the achieved likelihood of an information security successful compromise. While this likelihood is consistent with the safety objectives set by the SAP, the achieved level of uncertainty also needs to be considered.

The interaction between SAP and ISAP is iterative and continues until the safety risk is acceptable, i.e. the target likelihood of the related information security successful compromise has been achieved. The interaction can start from safety consequences identified through the SAP that fall within the scope of the ISMS risk analysis, or from existing information security assessments.

ISMS implementation and maintenance

An ISMS, as defined in this Regulation, employs the perspectives of governance, risk and compliance, and an approach that combines the safety risk and performance dimensions to determine the information security controls that are appropriate to and compliant with the specific context and can effectively provide the level of protection required to achieve the aviation safety objectives by:

- **Governance** perspective refers to providing management direction and leadership aimed to achieve the entity's own overarching objectives:
 - leadership and commitment of the senior management defining and ensuring the close involvement of the management and a 'top-down' ISMS implementation
 - information security and safety objectives aligned and consistent with the entity's business objectives and monitored by, e.g., management reviews
 - information security policies stating the principles and objectives to be achieved
 - roles, responsibilities, competencies and resources required for an effective ISMS
 - effective, target-group-oriented communication to internal and external stakeholders
- **Risk** perspective refers to a key aspect of an ISMS in an aviation safety context according to this Regulation, and serves as a basis for transparent decision-making and prioritisation of controls and risk treatment options. It further refers to the assessment, treatment and monitoring of information security risks in support of the management of aviation safety risks for the key processes and information assets upon which they depend. This includes protection requirements, risk exposure, attitude towards risks and risk acceptance criteria, methods and industry standards.

- **Compliance** perspective refers to the compliance with regulatory, legal and contractual requirements. This includes:
 - this Regulation,
 - the entity's own policies and standards and may further include international or industry standards adopted by the entity from ISO, EUROCAE, etc.

This perspective comprises the definition, implementation and maintenance of the required information security provisions whose effectiveness and compliance should be regularly monitored and assured by, e.g., (internal) audits.

Based on these perspectives, we may identify the following processes or subject areas that have been shown to be relevant for the establishment of an effective ISMS. These ISMS processes and subject areas can be summarised as follows:

- (a) context establishment defining the scope, interfaces, dependencies and requirements of interested parties;
- (b) leadership and commitment of the senior management;
- (c) information security and safety objectives;
- (d) information security policies;
- (e) roles, responsibilities, competencies and resources required for an effective ISMS;
- (f) communication to internal and external stakeholders to achieve a sufficient level of information security awareness and training of all involved parties;
- (g) information security risk management including risk assessment and treatment;
- (h) information security incident management establishing processes for the handling of information security incidents and vulnerabilities;
- (i) performance & effectiveness monitoring, measurement and evaluation;
- (j) internal audits and management reviews;
- (k) corrections and corrective actions;
- (l) continuous improvement;
- (m) relationship with suppliers;
- (n) documentation, record-keeping, and evidence collection.

Additional critical success factors for the implementation and operation of an ISMS include the following:

- The ISMS should be integrated with the entity's processes and overall management structure or even — at least partially, with safeguards for their respective integrity, and as reasonably applicable — with an overarching management system comprising information security, aviation safety and quality management.
- Information security has to be considered at an early stage in the overall design of processes and procedures, of systems and of information security controls, to be seamlessly integrated, for maximum effectiveness, minimal functional interference and optimised cost. None of these benefits can be achieved by integrating it on later.

- The risk management process determines appropriate characteristics of preventive controls to reach and maintain acceptable risk levels.
- The incident management process ensures that the organisation detects, reacts and responds to information security incidents in a timely manner. This is achieved by defining responsibilities, procedures, scenarios and response plans in advance to ensure a coordinated, targeted and efficient response.
- Continuous monitoring and reassessment are undertaken and improvements are made in response.

The above-mentioned core components are related to the requirements in this Regulation, for which Figure 2 provides a high-level depiction of the aspects that are more prominent in the implementation phase and those that characterise the operational phase, as well as the review and possible improvement, if the functions do not perform as planned.

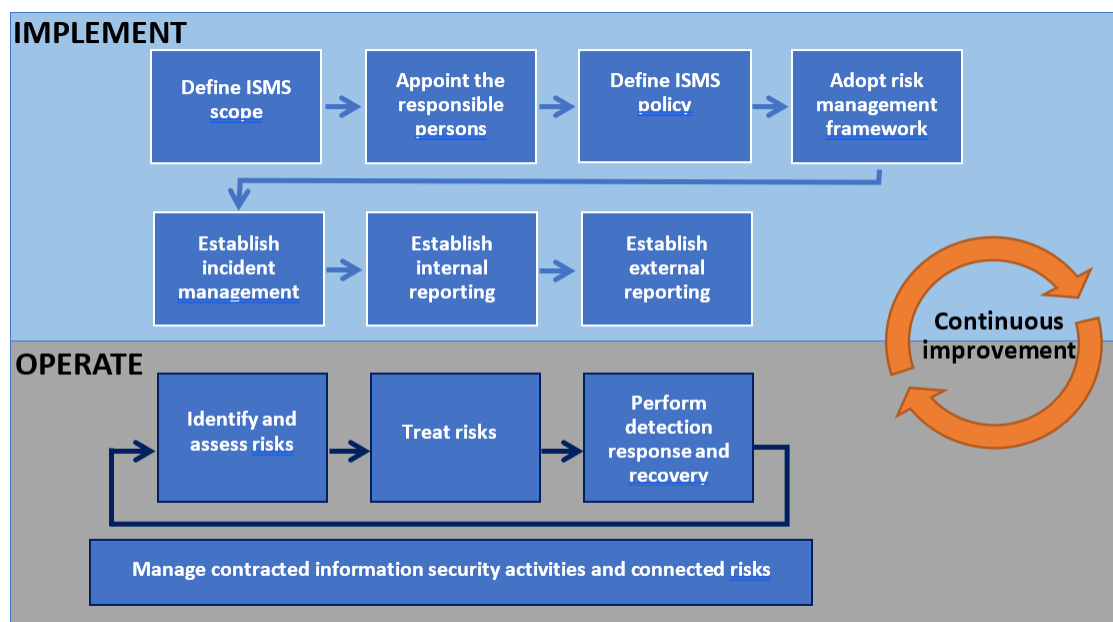


Figure 2: Representation of the Part-IS requirements from an ISMS's life cycle perspective

Plan-Do-Check-Act approach

The Plan-Do-Check-Act (PDCA) refers to a process approach that is often used to establish, implement, operate, monitor, review and improve management systems. Figure 3 depicts the PDCA applied to an ISMS.

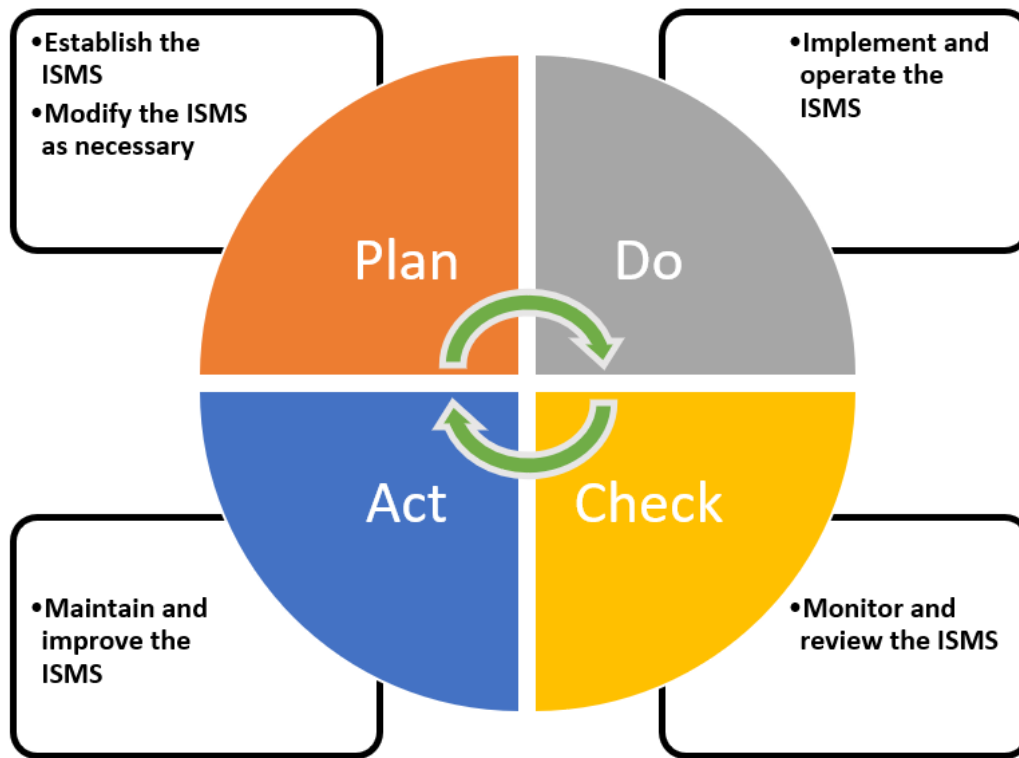


Figure 3: Plan-Do-Check-Act approach applied to an ISMS

Benefits of an ISMS

The benefits of a management system operating in a dynamic, uncertain or unpredictable risk environment are realised in the long term only when the organisation improves existing controls, processes and solutions based on the assessments of risks, performance and maturity as well as on the learnings from incidents, audits, non-conformities and their root causes. A successful adoption and deployment of an ISMS allows an entity to:

- achieve greater assurance to the management and interested parties that its information assets are adequately protected against threats on a continual basis;
- increase its trustworthiness and credibility providing confidence to interested parties that information security risks with an impact on aviation safety are adequately managed;
- increase the resilience of the entity's key processes against unauthorised electronic interactions and maintains the entity's ability to decide and act;
- support the timely detection of control gaps, vulnerabilities or deficiencies aimed to prevent information security incidents or at least to minimise their impact;
- detect and timely react to changes in the entity's environment including system architecture and threat landscape or the adoption of new technologies;
- provide a foundation for effective and efficient implementation of a comprehensive information security strategy in times of digital transformation, increasing interconnectivity of systems, emerging information security threats and new technologies.

Relation to ISO/IEC 27001

The international standard ISO/IEC 27001 is a widely adopted standard for ISMS which specifies generic requirements for establishing, implementing, maintaining and continually improving an ISMS. It also includes requirements for the assessment and treatment of information security risks. The requirements are applicable to all entities, regardless of type, size or nature. The conformity of an ISMS with the ISO/IEC 27001 standard can be certified by an accredited certification body. ISO/IEC 27001 is compatible with other management system standards (quality, safety, etc.) that have also adopted the structure and terms defined in Annex SL to ISO/IEC Directives, Part 1, Consolidated ISO Supplement. This compatibility allows an entity to operate a single management system that meets the requirements of multiple management system standards.

ISO/IEC 27001 allows entities to define their own scope of audit and their own organisational risk appetite. This, in turn, leads to information security requirements that provide the ISMS with criteria for the acceptability of information security risks in line with the entity's risk appetite (see Figure4).

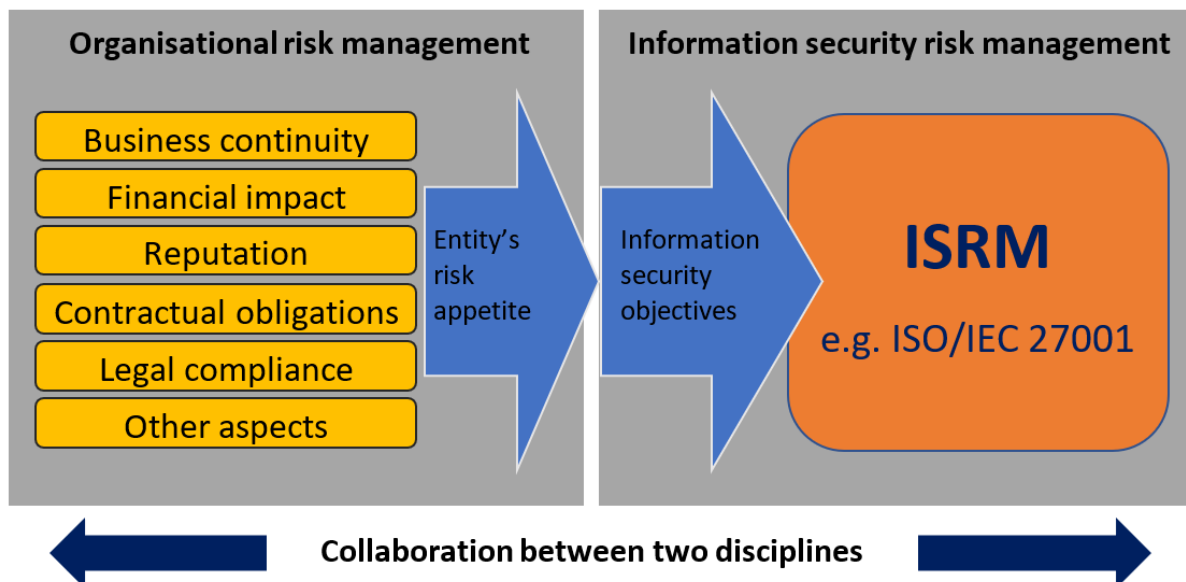


Figure 4: Relation between the entity's risk appetite and the information security objectives

The requirements for an ISMS specified by this Regulation are in most parts consistent and aligned with ISO/IEC 27001; however, this Regulation introduces provisions specific to the context of aviation safety. If an ISO/IEC 27001-based ISMS is already operated by an entity for a different scope and context, it can be adapted and extended to the scope and context of this Regulation in a straightforward manner based on an analysis of the scope and the gaps. In order to take credit from ISO/IEC 27001 certifications to achieve compliance with Part-IS, aviation safety needs to be included in the organisational risk management, with the relevant risk acceptance level determined by the applicable regulation (see Figure 5). Therefore, careful determination of the scope of the ISMS related to aviation safety risks is needed, as it might differ from the one related to the other organisational risks. To allow demonstration of compliance with Regulation (EU) 2023/203, careful delineation between aspects of the ISMS related to aviation safety risks and other organisational risks may be required. This could have an influence upon the decision to integrate ISMSs.

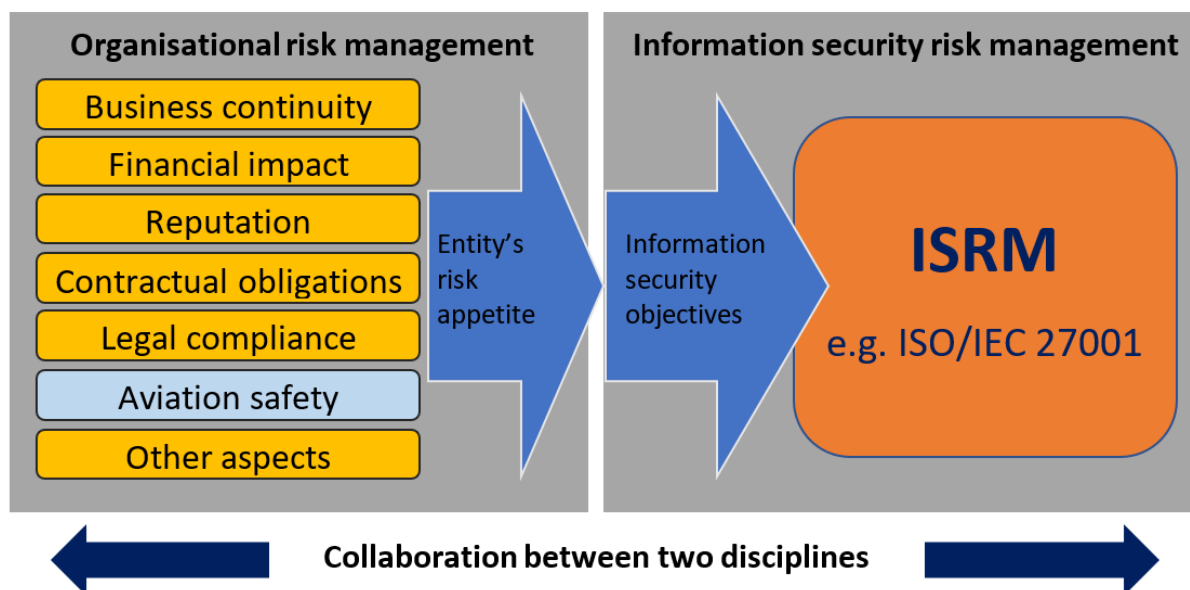


Figure 5: Introduction of aviation safety aspects in the entity's risk appetite

PART-IS versus ISO/IEC 27001:2022 cross reference table

For a mapping between the Part-IS provisions and the clauses and associated controls in ISO/IEC 27001:2022, refer to [Appendix IV](#).

AMC1 IS.I.OR.200(a)(1) Information security management system (ISMS)

ED Decision 2023/009/R

The organisation should define and document the scope of the ISMS, by determining activities, processes, supporting systems, and identifying those which may have an impact on aviation safety.

The information security policy should be endorsed by the accountable manager and reviewed at planned intervals or if significant changes occur. Moreover, the policy should cover at least the following aspects with a potential impact on aviation safety by:

- committing to comply with applicable legislation, consider relevant standards and best practices;
- setting objectives and performance measures for managing information security;
- defining general principles, activities, processes for the organisation to appropriately secure information and communication technology systems and data;
- committing to apply ISMS requirements into the processes of the organisation;
- committing to continually improve towards higher levels of information security process maturity as per [IS.I.OR.260](#);
- committing to satisfy applicable requirements regarding information security and its proactive and systematic management and to the provision of appropriate resources for its implementation and operation;
- assigning information security as one of the essential responsibilities for all managers;

- (h) committing to promote the information security policy through training or awareness sessions within the organisation to all personnel on a regular basis or upon modifications;
- (i) encouraging the implementation of a 'just-culture' and the reporting of vulnerabilities, suspicious/anomalous events and/or information security incidents;
- (j) committing to communicate the information security policy to all relevant parties, as appropriate.

Note: A significant change is a notable alteration or modification that has a meaningful impact on the organisation's operations, such as a structural change within the organisation due to reorganisations, a change in the business processes (e.g. working from home, use of personal devices), a technological evolution (e.g. distributed computing resources, artificial intelligence/machine learning) or an evolution in the threat landscape.

GM1 IS.I.OR.200(a)(1) Information security management system (ISMS)

ED Decision 2023/009/R

INFORMATION SECURITY POLICY AND OBJECTIVES

The information security policy should suit the organisation's purpose and direct its own information security activities. Such policy should contain the needs for information security in the organisation's context, a high-level statement of direction and intent of the information security activities, the principles and most important strategic and tactical objectives to be achieved by the ISMS, as well as the general information security objectives or a specification of a framework (who, how) for setting information security objectives. The information security policy should also contain a description of the established ISMS, including roles, responsibilities and references to topic-specific policies and standards.

The information security objectives should be:

- consistent and aligned with the information security policy and consider the applicable information security requirements, derived from the overarching organisation's objectives, and the results from the risk assessment and treatment (which, in turn, supports the implementation of the organisation's strategic goals and information security policy);
- regularly reviewed to ensure that they are up to date and still appropriate;
- measurable if practicable (to be able to determine whether the objective has been met), aimed to be SMART (specific, measurable, attainable, realistic, timely) and aligned with all affected responsible persons.

When defining information security objectives, e.g., based on the overarching organisation's objectives, the information security requirements or the results of risk assessments, it should be determined how these objectives will be achieved. The degree to which information security objectives are achieved must be measurable. If possible, it should be measured by key performance indicators (KPIs) which have been defined in advance (refer to resources such as COBIT 5 for Information Security). It is recommended to start with the definition of a limited number of information security objectives which are relevant for the organisation, more of a long-term nature and measurable with a reasonable effort relative to the delivered benefits.

AMC1 IS.I.OR.200(a)(12) Information security management system (ISMS)

ED Decision 2023/009/R

COMPLIANCE MONITORING

When establishing compliance with the provisions under point [IS.I.OR.200\(a\)\(12\)](#), the organisation should implement a function to periodically monitor compliance of the management system with the relevant requirements and adequacy of the procedures including the establishment of an internal audit process and an information security risk management process. When the organisation has already established a compliance monitoring function under the implementing regulation for its domain, such function should include the monitoring of the management system with the relevant requirements within the scope of its activities. Compliance monitoring should include a feedback mechanism of audit findings to the accountable manager or delegated person(s) to ensure implementation of corrective actions as necessary.

GM1 IS.I.OR.200(a)(12) Information security management system (ISMS)

ED Decision 2023/009/R

COMPLIANCE MONITORING

For the purpose of compliance monitoring, internal audits should be conducted at planned intervals to provide assurance on the status of the ISMS to the management and to provide information on the following:

- conformity of the ISMS to the requirements of this Regulation and the organisation's own requirements either stated in the information security policy, procedures and contracts or derived from information security objectives or outcomes of the risk treatment process;
- effective implementation and maintenance of the ISMS.

Internal audits should follow an independent approach and a decision-making process based on evidence. Moreover, when setting up an audit programme, the importance of the processes concerned, and definitions of the audit criteria and scope should be considered. Documented information should be retained evidencing the audit results, their reporting to the relevant management and the audit programme.

AMC1 IS.I.OR.200(a)(13) Information security management system (ISMS)

ED Decision 2023/009/R

When establishing compliance with the provisions under points [IS.I.OR.200\(a\)\(13\)](#), the organisation should implement and maintain information security controls that are sufficiently robust and effective to protect information and ensure the need-to-know principle (i.e. limiting access to information to only those who need it to perform their duties). It should protect the source of information in accordance with the relevant provisions established in Regulation (EU) 2018/1139. It should also comply with Regulation (EU) No 376/2014.

AMC1 IS.I.OR.200(c) Information security management system (ISMS)

ED Decision 2023/009/R

When establishing compliance with the provisions under point [IS.I.OR.200\(c\)](#), the organisation should:

- (a) provide an outline of the structure of the specific information security personnel (internal and external), including their roles and responsibilities. This outline of the structure will be used to manage and maintain the elements included within the scope of the ISMS and will be approved by the accountable manager. The organisation should review the outline of the structure at planned intervals or if significant changes occur (see the Note in [AMC1 IS.I.OR.200\(a\)\(1\)](#));
- (b) identify and categorise all relevant contracted organisations used to implement the ISMS. The organisation should define and document procedures for the management of interfaces and coordination between the organisation and other organisations, including contracted organisations;
- (c) identify and define all key processes and procedures, and internal and external reporting schemes, that will be used to maintain compliance with the objectives of this Regulation over the life cycle of the ISMS. The organisation may adjust existing processes or procedures for compliance;
- (d) identify and document any other information that will be used to maintain compliance with the objectives of this Regulation;
- (e) when creating and updating documented information, ensure appropriate identification and description (e.g. a title, date, author, or reference number) as well as a review and an approval for suitability and adequacy;
- (f) control the documented information required by the ISMS to ensure that it is:
 - (1) available and suitable for use, where and when it is needed;
 - (2) adequately protected (e.g. from loss of confidentiality, improper use, or loss of integrity).

GM1 IS.I.OR.200(c) Information security management system (ISMS)

ED Decision 2023/009/R

The amount of information that should be documented to maintain compliance with the objectives of this Regulation may vary between organisations due to various factors, such as size and complexity, or the need for harmonisation with other management processes already in place. As general guidance, taking into account the documents required to comply with point [IS.I.OR.200\(a\)](#), the record-keeping requirements referred to in [IS.I.OR.245](#) and the information security management manual requirements referred to in [IS.I.OR.250](#), the following is a non-exhaustive list of information that should be documented:

- (a) information security policy that should include the organisation's information security objectives — see [IS.I.OR.200\(a\)\(1\)](#);
- (b) responsibilities and accountabilities for roles relevant to information security — see [IS.I.OR.250\(a\)\(2\)](#), (3), (6) and (7) and the personnel requirements referred to in points [IS.I.OR.240\(a\)](#), (b), (c), (d) and (f) and the related AMC and GM;

- (c) scope of the ISMS and the interfaces with, and dependencies on, other parties — see [IS.I.OR.200\(a\)\(2\)](#) and the information security requirements referred to in points [IS.I.OR.205\(a\)](#) and (b);
- (d) information security risk management process — see the information security requirements referred to in points [IS.I.OR.205](#) and [IS.I.OR.210](#);
- (e) archive of the risks identified in the information security risk assessment along with the associated risk treatment measures (often referred to as ‘risk register’ or ‘risk ledger’) — see [IS.I.OR.245](#);
- (f) evidence of the competencies necessary for the personnel performing the activities required under this Regulation — see [IS.I.OR.240\(g\)](#) and the related AMC and GM;
- (g) evidence of the current competencies of the personnel performing the activities required under this Regulation — see [IS.I.OR.245\(b\)\(1\)](#);
- (h) (key) performance indicators derived from evidence of the monitoring and measurement of the ISMS processes.

GM1 IS.I.OR.200(d) Information security management system (ISMS)

ED Decision 2025/014/R

PROPORTIONALITY IN ISMS IMPLEMENTATION

When implementing the processes and procedures, as well as establishing the roles and responsibilities required under point [IS.I.OR.200\(d\)](#), the organisation should primarily consider the risks that it may be posing to other organisations, as well as its own risk exposure. Other aspects that may be relevant include the organisation’s needs and objectives, information security requirements, its own processes and the size, complexity and structure of the organisation, all of which may change over time.

As a general guide, the following aspects of the degree of safety relevance and organisational complexity could be taken into account when defining the ISMS. Each of these influences the implementation of the ISMS in certain areas:

- (a) The organisation’s position in the functional chain and the number and degree of safety relevance of the interfacing organisations/stakeholders.
- (b) The complexity of the organisational structure and hierarchies (e.g. number of staff, departments, hierarchical layers, external location, subsidiaries, etc.)
- (c) The complexity of the information and communication technology systems and data used by the organisation and their connection to external parties.

More details on the influence on the proportionate implementation of Part-IS for each aspect of safety relevance and organisational complexity are provided in [Appendix V](#).

SUPPORTED IMPLEMENTATION OF THE ISMS

In the context of Part-IS, all organisations initiate the implementation of an ISMS with determining its scope, which in turn is based upon at least an assessment of aviation safety impacts for which information security incidents are a cause or a contributing factor. Organisations, irrespective of their size, may not have yet sufficient knowledge about their information security risks, and may consider seeking support by a service provider that can also provide additional personnel and expertise during

this implementation phase of the ISMS. The same may apply to later phases of the ISMS implementation, and to this end organisations may want to consider the provision of [IS.I.OR.235](#) and related AMC. Outsourcing specific ISMS functions, such as information security monitoring or incident response to service providers, may help ensure that the organisation has access to experienced personnel and expertise. Similarly, organisations may want to be supported by a service provider in performing risk assessments.

Regarding the establishment of the appropriate personnel to implement and comply with the provisions of this Regulation, organisations should always refer to [AMC1 IS.I.OR.240\(f\)](#) and [GM1 IS.I.OR.240\(f\)](#), by considering that multiple responsibilities may be assigned to one person, while always ensuring the independence of the compliance monitoring.

As an introduction to the nature of information security risks and their management, organisations may use, as initial guidance, the NIST Interagency Report (NISTIR 7621 Rev.1) ‘Small Business Information Security: The Fundamentals’.

INTEGRATION OF ISMS UNDER THIS REGULATION WITH EXISTING MANAGEMENT SYSTEMS

An organisation may take advantage of existing management systems when implementing an ISMS by integrating it with those existing systems.

By integrating the ISMS with existing management systems, the organisation may reduce the effort and costs required to implement and maintain the ISMS, while also ensuring consistency and alignment with the organisation’s overall management approach. Below is a non-exhaustive list of potential synergies that can be exploited when integrating the ISMS with an existing management system:

- Leverage existing policies and procedures: an organisation may use its existing policies and procedures as a foundation for its ISMS. This may help to ensure consistency and minimise the need for additional documentation.
- Align the ISMS with other management systems: an organisation may align the ISMS with other management systems, such as safety management systems (SMSs), to ensure that the ISMS is consistent with the organisation’s overall management approach.
- Use existing risk management processes: an organisation may use their existing risk management processes to identify and assess the information security risks potentially leading to aviation safety risks.
- Reuse existing controls: an organisation may reuse existing controls, such as access controls or incident management process, to implement the information security controls required by the ISMS.
- Continuous improvement process: an organisation may use the continuous improvement process of existing management systems to improve the ISMS over time.

AMC1 IS.I.OR.200(e) Information security management system (ISMS)

ED Decision 2023/009/R

DEROGATION

Organisations should follow the directions provided in [AMC1 IS.I.OR.205\(a\)](#) and [AMC1 IS.I.OR.205\(b\)](#) to perform a documented information security risk assessment to seek the approval by the competent authority of a derogation under point [IS.I.OR.200\(e\)](#). In order to justify the grounds for a derogation,

the risk assessment is expected to provide explanations for the exclusion of all elements from the scope of the ISMS. It is up to the authority to determine whether this assessment is deemed satisfactory for a derogation to be granted.

Organisations that would like to have the risk assessment performed by a third party should consider the requirements of [IS.I.OR.235](#) and the related AMC.

GM1 IS.I.OR.200(e) Information security management system (ISMS)

ED Decision 2025/014/R

Any organisation that believes that it does not pose any information security risk with a potential impact on aviation safety, either to itself or to other organisations, may consider requesting an approval for a derogation by the competent authority following the procedure outlined in [AMC1 IS.I.OR.200\(e\)](#).

Existing safety risk assessments, such as those carried out as part of the SMS, can form the basis of enhanced assessments considering safety risks arising from information security threats.

It should be noted that applications for partial exemption from individual articles are not possible.

APPLICATION FOR A DEROGATION

In order to ensure a consistent approach by organisations when submitting a derogation request, the competent authority may establish an official derogation request application form.

The application for a derogation, based on the application form where one exists or in a format decided by the organisation, will need to be signed by the accountable manager of the applicant organisation and submitted to the appropriate competent authority for review and consideration.

The application for a derogation should contain preliminary information used for a pre-assessment by the competent authority, including:

- Company information and contact information;
- Affected approval(s);
- Detailed justification for the exclusion of the provisions;
- Overview of services that the organisation provides and receives;
- Architecture overview of information systems used for business operation;
- Summary of the high-level information security risk assessment aligned with the above architecture;
- Methodology used to perform the information security risk assessment;
- List of people and roles involved in the information security risk assessment process;
- Date and signature.

Note: At this stage, the high-level risk assessment needs to properly document the absence of information security risks that may impact safety. To do so, it should at least cover the identification of the scope and boundaries, as required under points [IS.I.OR.205](#) (a) and (b), and the analysis of safety impact, as required under point IS.I.OR.205(c).

EVALUATION OF THE REQUEST FOR A DEROGATION

The competent authority reviews the information security risk assessment and other supporting documentation, normally assessing whether:

- the documentation is sufficient for a proper analysis and assessment;
- the repository or asset inventory of digital systems, data flows and processes is comprehensive;
- the high-level information security risk assessment has been conducted in accordance with the organisation's methodology and with the appropriate diligence;
- the relevant stakeholders have been involved in the assessment process;
- the assessment has been performed by people with sufficient expertise in information security and aviation safety;
- the organisation has assigned and indicated a point of contact for enquiries.

Figure 1 below depicts the process, including the pre-assessment. If the pre-assessment provides the competent authority with sufficient evidence that the derogation request is legitimate and that the organisation meets the expected criteria, the process will proceed to the exchange of more detailed information.

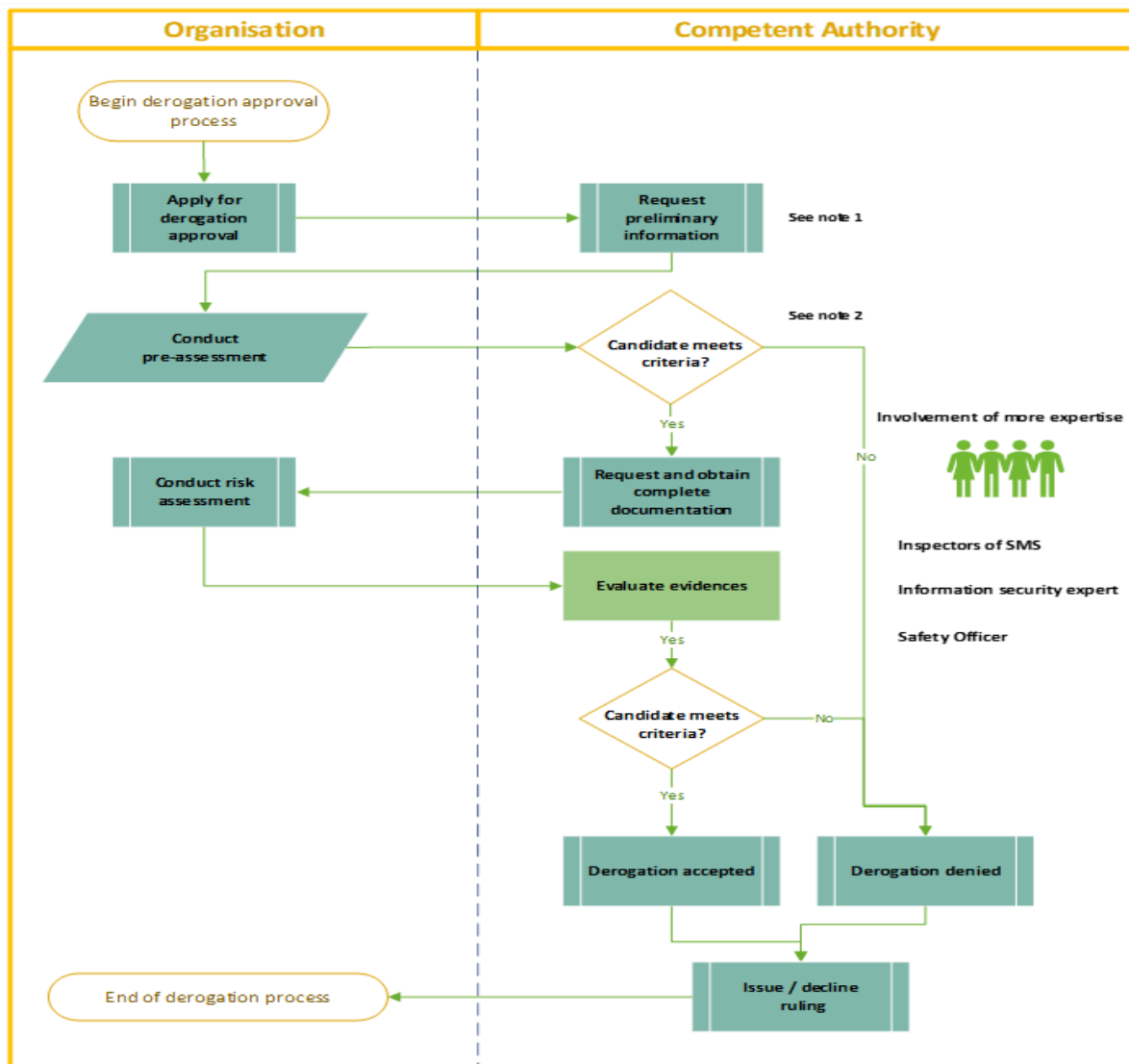


Figure 1: Representation of the derogation process

Note 1 to Figure 1: The objective of this step is to obtain preliminary information about the organisation risk profile by using suitable means (e.g. questionnaire, self-assessment template, request tool, etc.)

Note 2 to Figure 1: The objective of this step is to conduct a pre-evaluation to check whether the organisation has the possibility to be granted a derogation. The pre-assessment allows to avoid a detailed assessment if the prerequisites for a derogation are not met.

EXPECTATIONS AND RECOMMENDATION AFTER DEROGATION APPROVAL

Once a derogation approval has been granted, the organisation is expected to undertake the following on a continuous basis:

- Comply with all provisions of the regulation which are not exempted, in particular point [IS.I.OR.200\(a\)\(13\)](#) which should not be limited to only protection of the received information. When transmitting information with confidential nature, the organisation needs to have secure means in place as well;
- Comply with [Regulation \(EU\) No 376/2014](#) to take into account the obligation to comply with the reporting requirements.
- Monitor any changes in the organisation's scope of work and identify those which may have a potential impact on the documented information, which supports the derogation approval. Where such changes are identified, the organisation should ensure that they are brought to the attention of the competent authority without delay and notified in accordance with the applicable implementing rule.
- Monitor the risk picture for any variation due to changes in the safety and security environment over time. To this end, point IS.I.OR.205(d) should be considered.
- Ensure that the accountable manager can demonstrate an understanding of the derogation process and the terms on which the approval has been granted. This means that at least one person in the organisation needs to have a basic understanding of the Regulation. To this end, point [IS.I.OR.240\(a\)\(3\)](#) and the related AMC and GM should be considered.
- Implement basic protection against information security risks according to industry best practices.
- Remain up to date with the latest information security threat landscape and consult the respective national authority for additional guidance.

EXAMPLES

Some examples of organisations that may consider asking for a derogation might include:

- An air operator that performs non-high-risk commercial specialised operations (SPO) with non-complex aircraft, if the nature of the operations justifies the grounds for a derogation.
- An air operator that operates ELA2 aircraft as defined in Article 1(2)(j) of [Regulation \(EU\) No 748/2012](#) with the exception of one aircraft that is operated in predefined operational conditions or under certain operational limitations.
- A maintenance organisation approved under Part-145 dealing only with maintenance of components or maintenance activities that do not contribute to ensuring the structural integrity of the aircraft nor any major safety-related functionalities — for instance, undertaking activities such as washing, removing coatings, painting, etc.

The aforementioned examples are not exhaustive and are only indicative of potential scenarios that might provide an initial basis for the preparation of an information security risk assessment that justifies the exclusion of all elements of an organisation from the scope of the ISMS.

IS.I.OR.205 Information security risk assessment

Regulation (EU) 2023/203

- (a) The organisation shall identify all its elements which could be exposed to information security risks. That shall include:
 - (1) the organisation's activities, facilities and resources, as well as the services the organisation operates, provides, receives or maintains;
 - (2) the equipment, systems, data and information that contribute to the functioning of the elements listed in point (1).
- (b) The organisation shall identify the interfaces that it has with other organisations, and which could result in the mutual exposure to information security risks.
- (c) With regard to the elements and interfaces referred to in points (a) and (b), the organisation shall identify the information security risks which may have a potential impact on aviation safety. For each identified risk, the organisation shall:
 - (1) assign a risk level according to a predefined classification established by the organisation;
 - (2) associate each risk and its level with the corresponding element or interface identified in accordance with points (a) and (b).

The predefined classification referred to in point (1) shall take into account the potential of occurrence of the threat scenario and the severity of its safety consequences. Based on that classification, and taking into account whether the organisation has a structured and repeatable risk management process for operations, the organisation shall be able to establish whether the risk is acceptable or needs to be treated in accordance with point [IS.I.OR.210](#).

In order to facilitate the mutual comparability of risks assessments, the assignment of the risk level pursuant to point (1) shall take into account relevant information acquired in coordination with the organisations referred to in point (b).

- (d) The organisation shall review and update the risk assessment carried out in accordance with points (a), (b) and, as applicable, points (c) or (e), in any of the following situations:
 - (1) there is a change in the elements subject to information security risks;
 - (2) there is a change in the interfaces between the organisation and other organisations, or in the risks communicated by the other organisations;
 - (3) there is a change in the information or knowledge used for the identification, analysis and classification of risks;
 - (4) there are lessons learnt from the analysis of information security incidents.
- (e) By derogation from point (c), organisations required to comply with Subpart C of Annex III (Part-ATM/ANS.OR) to Regulation (EU) 2017/373 shall replace the analysis of the impact on aviation safety by an analysis of the impact on their services as per the safety support assessment required by point ATM/ANS.OR.C.005. This safety support assessment shall be made available to the air traffic service providers to whom they provide services and those air traffic service providers shall be responsible for evaluating the impact on aviation safety.

GM1 IS.I.OR.205 Information security risk assessment

ED Decision 2023/009/R

Part-IS does not require the use of any specific information security framework, such as ISO, NIST or others to develop the risk assessment or in general to implement risk management. Each framework offers different benefits and none of these frameworks is perfect for an individual organisation, and should be customised and tailored to meet the overall needs of an organisation as well as the specific need to consider aviation safety aspects.

Organisations whose information security frameworks have achieved industry certifications can provide this information as supporting artefacts; however, these organisations should show the applicability of the industry certification to the scope of this Regulation (see [GM1 IS.I.OR.200](#)).

General guidance on risk management, including risk assessment, can be found in ISO/IEC 27005 and ISO/IEC 31000 as well as NIST SP 800-30. Aviation organisations may also wish to consider aviation-specific guidance as defined in the risk management chapter of the latest version of EUROCAE ED-201A and, as appropriate to the specific operating environment, in the chapters of EUROCAE ED-204A, EUROCAE ED-205A and EUROCAE ED-206 covering risk management.

AMC1 IS.I.OR.205(a) Information security risk assessment

ED Decision 2023/009/R

When conducting an information security risk assessment, the organisation should ensure that all relevant aviation safety elements are identified and included in the ISMS scope as per [IS.I.OR.200](#) and related AMC.

A means to comply with the requirement in point [IS.I.OR.205\(a\)](#) is to perform a preliminary high-level risk assessment or impact assessment, carried out in accordance with a documented methodology and following precise criteria for the inclusion in and exclusion from the ISMS scope of the elements listed in [IS.I.OR.205\(a\)](#).

GM1 IS.I.OR.205(a) Information security risk assessment

ED Decision 2023/009/R

SCOPE AND BOUNDARIES IDENTIFICATION

The organisation should develop clear and comprehensive understanding of its aviation activities and services, the related processes and associated information systems, and the relevant data flows and information exchanges that define the scope of the ISMS and the boundaries for risk assessment. Therefore, the organisation should develop corresponding documentation on resources and dependencies related to computing, networking and contracted services which have the potential to affect the information security and safety of the functions, services or capabilities within the scope of the risk assessment.

The following non-exhaustive list provides examples of items that may be considered for the identification of the aforementioned scope and boundaries. The level of detail of the analysis can be an iterative process, with the effort commensurate with the expected level of risk. As stated above, the purpose is to establish understanding of all relevant assets, resources and dependencies that are directly a part of the functions, services and capabilities through the following activities:

- (a) Identification of operational inputs and outputs relevant to the functions, services and capabilities of the organisation; these can be related to:
 - internal or external sources;

- internal or external leased or managed services, or other dependencies;
- (b) Identification of all relevant assets (i.e. hardware, software, network and computing resources) used to create, process, transmit, store or receive the aforementioned operational inputs and outputs;
- (c) Identification of the operating environments (e.g. office, public access area, access-controlled room, etc.) and locations for all relevant assets;
- (d) For each asset included in the scope, identification of the specific methods, processes and resources that will be used to manage, operate and maintain each asset throughout its life cycle, including:
 - internal or contracted resources;
 - contracted companies remotely managing the assets (i.e. provider of managed services).

AMC1 IS.I.OR.205(b) Information security risk assessment

ED Decision 2023/009/R

The organisation should, as part of the information security risk assessment, identify the interfaces it has with other parties such as service providers, supply chains and other third parties, based on the exchange of data and information and the assets used for that exchange, which could lead to a situation where information security risks, as a result of mutual exposure, may either:

- increase aviation safety risks faced by other parties; and/or
- increase aviation safety risks faced by the organisation.

GM1 IS.I.OR.205(b) Information security risk assessment

ED Decision 2023/009/R

RISK INFORMATION SHARING

Interfacing organisations should share information with each other about the potential exposure to information security risks by following, for instance, the approach detailed in EUROCAE ED-201A, Appendix B — B.1, B.2 and B.3. The purpose of this exchange of information is to enable organisations to establish a matching mapping for the services identified under [IS.I.OR.205\(a\)](#), including all information and data flows, in order to:

- (a) illustrate (e.g. through a functional diagram) the relationships of logical and physical paths connecting the different parts involved;
- (b) clearly identify all assets (i.e. hardware, software, network and computing resources) that will be used in the exchange;
- (c) identify all functions, activities and processes, including their respective information and data, which will be created, transmitted, processed, received and stored, and associate those with the responsible party which provides or performs those functions, activities and processes;
- (d) determine for these paths, constituting the so-called functional chains, the role of the interfacing party as a producer, processor, dispatcher or consumer of the information or data involved;
- (e) determine whether one interfacing party acts as an originator or receiver of a flow across such path.

TWO CATEGORIES OF INTERFACING ORGANISATIONS

There are two categories of interfacing organisations: those that are subject to Regulation (EU) 2023/203 or Regulation (EU) 2022/1645, and those that are not.

Where the organisation has interfaces with an organisation that is subject to Regulation (EU) 2023/203 or Regulation (EU) 2022/1645, each entity:

- is responsible for the identification of the interfaces that its own organisation has with other organisations, and which could result in the mutual exposure to information security risks. The entity may benefit from the sharing of risk information as this exchange allows for a more accurate assessment of those risks;
- remains accountable for the proper management of the information security risks within the scope of its own ISMS.

In all other cases, the organisation is accountable for the proper management of the information security risks that may arise from its exposure to the interfacing entity. Where these risks need to be treated, the organisation always has the option of implementing mitigating measures and controls within its own boundaries. In the specific case where the interfacing entity is a supplier, the organisation may decide to manage the risks through contractual arrangements and require the supplier to implement mitigating measures and controls within its own organisation.

GM2 IS.I.OR.205(b) Information security risk assessment

ED Decision 2023/009/R

EXAMPLES OF AVIATION SERVICES

Examples of aviation services that may be considered when determining the ISMS scope and interfaces are provided in [Appendix III](#).

AMC1 IS.I.OR.205(c) Information security risk assessment

ED Decision 2023/009/R

The organisation should use a risk management framework that includes a methodology for assigning risks with a risk level and establishing criteria for determining risk acceptance or further treatment.

The organisation should provide documented evidence of assessment of risks which have a potential impact on aviation safety including the level of risks. The organisation should associate each risk with the relevant elements and interfaces identified under [IS.I.OR.205](#) (a) and (b), and document whether the risk is acceptable or requires further treatment.

The organisation should provide the assurance that the risk assessment process is carried out with the necessary rigour and discipline by documenting the process and its robustness. By doing so, the organisation should consider:

- (a) reproducibility of the assessment's results for similar inputs;
- (b) repeatability of the assessment over time in a way that the results of the different prior assessments can be compared to determine the changes;
- (c) the gathering of inputs that are relevant and valid, in particular:
 - (1) the information that allows the determination of the safety consequences;
 - (2) the information that allows the determination of the potential of occurrence of the threat scenario;

- (d) iterative refinement over time allowing for more fine-grained threat scenarios as inputs to become available, with the aim of reducing uncertainty regarding threats, vulnerabilities, effectiveness of existing controls, and dependencies on external entities, in particular by:
- (1) refining initial high-level threat scenarios with greater detail and specificity as more data is gathered;
 - (2) refining data on known vulnerabilities by continuously updating information about their exploitability and the associated consequences;
 - (3) reviewing the effectiveness of existing controls, and consider newly available controls;
 - (4) refining the understanding of the dependencies on external entities and their implications for the organisation's risk profile.

GM1 IS.I.OR.205(c) Information security risk assessment

ED Decision 2023/009/R

RISK ASSESSMENT

The risk classification levels for the potential of occurrence of the threat scenario and severity of the safety consequences listed below may be applied; however, this does not prevent the organisation from developing additional intermediate categories if it deems this necessary for risk assessments. The organisation should specify and document the applied, organisation-specific classification levels with an accurate qualitative or quantitative definition in terms of a range or interval of numerical values in order to enable a sufficiently calibrated, consistent estimation, evaluation and communication within the organisation or with the interfacing entities. The potential of occurrence of the threat scenario may be expressed as an interval of likelihoods including the duration of the observation. Supporting documentation and methods can be found in EUROCAE ED-203A, Chapter 3.6 which references the evaluation of the potential of occurrence of the threat scenario in the Security Risk Assessment of EUROCAE ED-202A.

Note 1: The phrase 'duration of the observation' refers to the time period during which a threat scenario is observed or monitored. It is essential in determining the likelihood of the threat scenario occurring, since the probability of occurrence may vary depending on the length of the observation period.

Note 2: EUROCAE ED-202A and EUROCAE ED-203A were originally developed for aircraft information security risk assessment, but the generic principles developed in those documents can be adapted to other frameworks when deemed useful by the organisation.

In order to facilitate the mutual comparability of risk assessment methodologies between interfacing organisations, the organisation may associate the assessment of the potential of occurrence of the threat scenario with one of the following categories:

- High potential of occurrence: the threat scenario is likely to occur. The attack related to the threat scenario is feasible and similar threat scenarios have occurred many times in the past.
- Medium potential of occurrence: the threat scenario is unlikely to occur. The attack related to the threat scenario is possible and a similar threat scenario may have occurred in the past.
- Low potential of occurrence: the threat scenario is very unlikely to occur. The materialisation of the threat scenario is theoretically possible; however, it is not known to have occurred.

The evaluation of the potential of occurrence of the threat scenario may be based on the following aspects:

Protection (as defined in EUROCAE ED-203A)

- Security measures and architecture that deny access to assets: the degree to which an asset is open to access from compromised systems
- Access to security measures: the degree to which a security measure prevents access/attack to itself from compromised systems
- Failure of mechanism: the degree to which the known implementation of a security measure will fail to prevent an attack
- Detection methods or procedures to recognise the attack and appropriately respond to reduce the potential of occurrence of the threat scenario

Exposure reduction (as defined in EUROCAE ED-203A)

- Conditions under which an external access connection can be used by a user or attacker
- Limits on the functionality of an external access connection
- Organisational policies that control the time-to-feasibility for developing attack tools specific to the product
- Vulnerability management including intelligence, scanning, treatment and retesting aimed to discover, detect and treat reported or detected vulnerabilities in a fast, risk-prioritised manner with high assurance in order to reduce the attack surface
- Reduction of the severity of a successful attack (i.e. through a redundant system that can maintain the continuity of service in case of a denial of service of a system critical for aviation safety)

Attack attempt (as defined in EUROCAE ED-203A)

- The capability of the attackers which is determined by the resources and expertise required for their attack

The capability of the attackers can be assessed through several ways, for instance:

- information from computer emergency response teams (CERTs) / computer security incident response teams (CSIRTs), information sharing and analysis centres (ISACs);
- analyses of past activities, techniques and procedures (TTPs) and success rate of attacks.

For the same reason the organisation may associate the outcome of the evaluation of the severity of the safety consequences with one of the following categories:

- High severity: those immediate or delayed scenarios that can cause or contribute to an unsafe condition where an unsafe condition means an occurrence associated with the operation of an aircraft in which:
 - a person is fatally or seriously injured;
 - the aircraft sustains damage or structural failure;
 - the aircraft is either missing or completely inaccessible;
- Moderate severity: those immediate or delayed scenarios that can cause or contribute to safety incidents where an incident means any occurrence other than an accident, associated with the operation of an aircraft, which affects or could affect the safety of operations;

- Low severity: those immediate or delayed scenarios that can cause or contribute to negligible safety consequences.

Examples for high, moderate, and low severity can be found in EUROCAE ED-201A, Appendix B for products, ATM systems and airspace.

If the organisation cannot determine the safety effect, the assessment should identify assumptions from the risk-sharing information at interfaces with other organisations along the functional chain, leading up to the safety effect.

Some of those assumptions can be granted with the certification of products: where assets are subject to product certification from other aviation regulations addressing product information security, the organisation performing the risk assessment may consider the perimeter of the product certification as already covered. This should be acceptable under the condition that this certification is valid and that the instructions provided by the OEM to maintain the certification validity are implemented by the organisation.

Additional information can also be found in Regulation (EU) 2015/1018 on mandatory reporting of occurrences in civil aviation. Further examples of impact severity classifications for aviation domains can be found in EUROCAE ED-201A, Appendix B — Tables B-5, B-6 and B-7.

Risk acceptance criteria

Risk acceptance criteria are critical and should be developed, specified and documented. The criteria may define multiple thresholds, with a desired target risk level, but allowing also for the accountable manager or delegated person(s) to accept risks above this level under defined circumstances and conditions.

In order to facilitate the mutual comparability of risk assessments between interfacing entities, the organisation should classify the risks in the following categories:

- unacceptable risk;
- conditionally acceptable risk;
- acceptable risk.

For what concerns the conditional acceptance of risks, the criteria for acceptance should take into account how long a risk is expected to exist (temporary or short-term activity or exposure), or may include requirements for the commitment of future treatments to reduce the risk at an acceptable level within a defined time duration and show how the risk will be managed over time through the organisation's risk governance processes.

Moreover, risks should be conditionally accepted only under the condition that the organisation demonstrates the presence of a comprehensive risk management structure that includes risk assessment, risk treatment and risk monitoring processes for operations. The risk management should consider the variability and consistency of threat likelihood, vulnerability, existing controls, external dependencies and safety impact. This is typically achieved when the organisation reaches a higher level of maturity that is representative of functionality and repeatability of information security risk management — see [GM1 IS.I.OR.260\(a\)](#).

The following Figure 1 depicts a risk acceptance matrix based on the aforementioned categories that can be used by interfacing organisations for mutual comparability.

ICAO Annex 13 >	Negligible effect	Incident	Accident
Threat scenario — potential of occurrence	Low consequences safety	Moderate consequences safety	High consequences safety
High	Conditionally acceptable	Not acceptable	Not acceptable
Medium	Acceptable	Conditionally acceptable	Not acceptable
Low	Acceptable	Acceptable	Conditionally acceptable*

Figure 1: Example of a risk acceptance matrix for comparison purposes

* The potential of occurrence of the threat scenario is reassessed in a timely manner (refer to [IS.I.OR.205\(d\)](#)) and monitored to ensure that it remains low and that if the risk materialises, it is early detected and dealt with.

A comprehensive risk management structure typically entails the following aspects and processes:

- a repeatable and reproduceable risk assessment. If the risk factors are considered fairly uncertain and within some wide value range or not sufficiently precise, further iterations of the risk assessment are performed involving additionally gathered or detailed information and a more in-depth assessment in order to reduce uncertainty and increase precision;
- a thorough review of those risks proposed to be conditionally acceptable that is performed by the accountable manager or delegated person(s) who may impose additional conditions for the risk retention, including risk treatment measure and the timeline for its implementation;
- strict monitoring of the key risk indicators that includes a defined, reliable detection of the potentially evolving risk materialisation;
- an incident response scheme is in place with reactive measures that are triggered by detection mechanisms in order to immediately contain the consequences, in particular, for risk scenarios involving a high severity level.

Note: As detailed in NIST SP-800 Rev.1, repeatability refers to the ability to repeat the assessment in the future, in a manner that is consistent with and hence comparable to prior assessments — enabling the organisation to identify trends. Therefore, a risk assessment process can be classified as ‘repeatable’ when under similar conditions an entity or a person delivers consistent results.

As detailed in NIST SP-800 Rev.1, reproducibility refers to the ability of different experts to produce the same results from the same data. Therefore, a risk assessment process can be classified as ‘reproducible’ when another entity or person, given the same inputs, assumptions, information security context and threat environment can replicate the same steps and reach the same conclusions.

Threat scenario identification

A threat scenario is one of the possible ways a threat could materialise. Typically, a threat scenario describes a potential attack targeting one or more vulnerabilities of assets, as well as processes.

The purpose of the threat scenario identification under this Regulation is to develop a list of scenarios that may lead to an information security threat having an impact on aviation safety.

A threat scenario, in general, is characterised by the following:

- a threat source of the information security attack;
- an attack vector and a path through the organisation up to the asset;
- the information security controls that would mitigate the attack;
- the consequence of the attack including the affected safety aspects.

Threat scenario identification guidance can be found in EUROCAE ED-202A, Chapter 3.4. This is not the only source where guidance can be found, and the organisation may refer to different guidance more appropriate for their application.

Additional methods to identify relevant threat scenarios

When conducting this analysis, both information security and safety aspects should be coordinated throughout the process to ensure mutual understanding of the threat preventive measures and mitigating measures being applied. In the following Figure 2 the interactions between information security and aviation safety are depicted through a ‘bow-tie’ diagram that highlights the links between risk controls and the underlying management system.

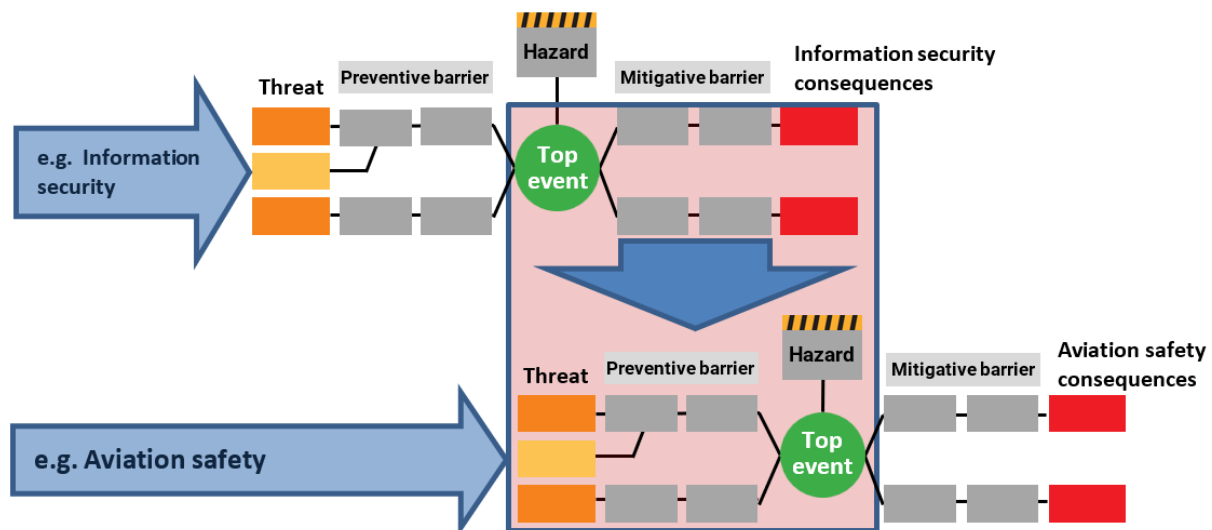


Figure 2: Interactions between information security and aviation safety risk management areas

Note: A preventive barrier or measure is a proactive action or control implemented to reduce the likelihood of a risk, hazard, or threat materialising, while a mitigating measure is an action or control designed to reduce the severity or impact of an undesired event, would it occur.

Examples of threat scenarios

Threat catalogues may provide guidance and elements for the elaboration of threat scenarios that are relevant for the organisation. References can be found in ARINC 811 – Att. 3 – Tables 3-7 and 3-8 for the threat catalogues examples and other threat catalogue examples as they are provided by EU institutions — for example, the ENISA threat taxonomy. However, this is not an exhaustive list of examples, and the identification of threat scenarios should therefore not be limited to those examples only. In addition, other relevant resources containing information on information security threats and the information security threat landscape should be consulted to support the risk assessment process with relevant inputs.

A set of examples of threat scenarios can be found in [Appendix I](#).

AMC1 IS.I.OR.205(d) Information security risk assessment

ED Decision 2023/009/R

The organisation should take into account the following criteria when establishing compliance with the objectives contained in point [IS.I.OR.205](#)(d):

- (a) The risk assessment performed under points [IS.I.OR.205](#) (a), (b) and (c) should be reviewed at regular intervals to identify and account for relevant changes. The periodicity at which potential changes have to be evaluated should be determined by the organisation performing the assessment considering the criticality of the assets within the scope of the risk assessment, levels of residual risk of the assets within the scope of the risk assessment and any contractual or regulatory requirements. A higher criticality or level of risk will require more frequent review.
- (b) The periodicity of risk assessment reviews should be documented by the organisation and include the justification, date of approval and information about the risk owner.

GM1 IS.I.OR.205(d) Information security risk assessment

ED Decision 2023/009/R

The criteria to consider for the frequency of the risk assessment review may be the risk level as well as the criticality and complexity of the assets concerned. The objective of a risk assessment review is to trigger the revaluation of risks, their likelihood and impact in case of relevant changes. One possible way is to have a tiered approach to risk assessment, with a higher-level risk assessment being used for the identification of changes. The higher-level risk assessment could allow the identification of the detailed risks that should be reviewed in a next step. Risk assessments should be subject to regular reviews to:

- (a) allow for continuous improvement of the quality of risk assessment;
- (b) ensure efficiency and effectiveness of risk controls and mitigating measures in both their design and operation;
- (c) review plans and actions for risk treatment;
- (d) identify any organisational change which may require a review of the priorities as well as of the treatment of risks;
- (e) maintain an overview of the complete risk picture; and
- (f) identify any emerging risks.

Risk assessment reviews should involve the risk owners, project teams and other stakeholders as applicable. Evidence of risk assessment review should be documented and should include:

- evidence of approval of the review by the designated risk owner; and
- the rationale behind or basis for the risk owner's approval of the review.

Such evidence may comprise, but is not limited to:

- reports which constitute a form of documentation to track information security risks potentially impacting an organisation;
- the documentation of the information security risk assessment;
- excerpts from a business or security risk register.

The periodicity of risk assessment reviews should also be documented by the organisation in information security manuals, processes or procedures and should align with wider change management activities and management reviews of information security. Further guidance on criteria and frequency of risk assessment review can be found in EUROCAE ED-201A, Chapter 4, as well as in EUROCAE ED-205A, Chapter 3.2 (for ATMS/ANS).

GM2 IS.I.OR.205(d) Information security risk assessment

ED Decision 2023/009/R

The following are examples of changes that should be identified during the risk assessment review as they may trigger an update of the risk assessments:

- (a) there is a change in the elements subject to information security risks as identified in [IS.I.OR.205\(a\)](#); a change in the elements will include:
 - additions to, or removals from, the scope of the risk assessment of individual elements;
 - changes to design or configuration of elements within the scope of the risk assessment that have the potential to alter the risk assessment outcomes; or
 - changes to values, which would potentially trigger changes to impact levels, of elements within the scope of the risk assessment;
 - (b) there is a change in the interfaces between the organisation and other organisations with which the organisation shares information security risks or relies upon to mitigate information security risks (e.g. supply chains, service providers, cloud providers and customers), as identified in IS.I.OR.205(b), or between the system within the scope of the risk assessment and any other interconnected systems, or in the risks notified to the organisation by other organisations, as identified in IS.I.OR.205(b), or owners or managers of the other systems including:
 - establishment of new interfaces;
 - removal of existing interfaces;
 - changes to existing interfaces that would have the potential to alter the risk assessment outcomes.
- Note: Some organisational or system interconnections may be with organisations that are not within the scope of this Regulation as defined in [Article 2](#) and therefore are not subject to the requirements of Part-IS. Where this is the case, these organisations should be informed of their responsibility to report such changes as listed above through contractual arrangements and reporting requirements between the affected organisations on a case-by-case basis and where applicable;
- (c) there is a change in the information or knowledge used for the identification, analysis and classification of risks including:
 - changes to threats and their values or addition of new threats that have not previously been assessed;
 - changes to vulnerabilities or addition of new vulnerabilities that have not previously been assessed;
 - changes in impacts or consequences of assessed threats or vulnerabilities;
 - changes in aggregation of risks that may result in unacceptable levels of risks;

- changes or improvements in the risk management process, risk assessment approach and related activities;
 - changes or improvements in the treatments of risks;
 - changes in the criteria used to determine acceptance and treatments of risks;
- (d) there are lessons learned from the analysis of information security incidents including:
- understanding why and how incidents have occurred; and
 - reviewing all types of incidents including those due to external factors, technical reasons, human errors (inadvertent behaviour). For human intentional acts, a distinction can be made between malign and benign actions.

AMC1 IS.I.OR.205(e) Information security risk assessment

ED Decision 2023/009/R

SAFETY SUPPORT ASSESSMENT

Non-ATS providers should conduct a safety support assessment as it is described in [Regulation \(EU\) 2017/373](#) to assess the information security risk on their assets in regard to the service specification, e.g. integrity and availability, and to identify the residual risk.

The non-ATS provider should share with the ATS provider, in an appropriate form, information on the residual risk and the impact on the services it provides to that ATS provider.

The residual risk should be used to assess the potential impact on services and products that a non-ATS provider offers to an ATS provider.

The ATS provider can use this as an input for its security risk assessment and, more importantly, to evaluate the potential impacts of these residual risks on safety.

GM1 IS.I.OR.205(e) Information security risk assessment

ED Decision 2023/009/R

SAFETY SUPPORT ASSESSMENT

Table 1 below shows the non-ATS providers which shall comply with Subpart C of Annex III to Regulation (EU) 2017/373. These are the organisations having to conduct the safety support assessment in order to provide the required information to ATS providers.

The information on the impact on products and services could be shared between non-ATS providers and ATS providers through agreed means, e.g. service level agreement, external agreement (in line with EUROCAE ED-201A), etc.

Shared information should enable ATS providers to perform an accurate assessment of the residual risk for their services. For instance, if the non-ATS providers identified a risk which could affect the availability of data provided to an ATS provider, the impact on the availability should be described in a way that allows the ATS provider to assess whether the resulting latency or delay in data transmissions could have a safety impact. This is relevant because only the ATS provider through its assessment can either accept or decline a residual risk.

Table 1: Non-ATS providers which shall comply with Subpart C of Annex III to Regulation (EU) 2017/373

	Annex III (Part-ATM/ANS.OR)				Annex IV (Part- ATS)	Annex V (Part- MET)	Annex VI (Part- AIS)	Annex VII (Part- DAT)	Annex VIII (Part- CNS)	Annex IX (Part- ATFM)	Annex X (Part- ASM)	Annex XI (Part- FPD)	Annex XII (Part- NM)
	Subpart A	Subpart B	Subpart C	Subpart D									
Air traffic services providers	X	X		X	X								
Meteorological services providers	X	X	X	X		X							
Aeronautical information services providers	X	X	X	X			X						
Data services providers	X	X	X					X					
Communication, navigation and surveillance service providers	X	X	X	X					X				
Air traffic flow management service providers	X	X	X	X						X			
Airspace management service providers	X	X	X								X		
Flight procedure design services providers	X	X	X									X	
Network Manager	X	X	X	X									X

IS.I.OR.210 Information security risk treatment

Regulation (EU) 2023/203

- (a) The organisation shall develop measures to address unacceptable risks identified in accordance with point [IS.I.OR.205](#), implement them in a timely manner and check their continued effectiveness. Those measures shall enable the organisation to:
- (1) control the circumstances that contribute to the effective occurrence of the threat scenario;
 - (2) reduce the consequences on aviation safety associated with the materialisation of the threat scenario;
 - (3) avoid the risks.

Those measures shall not introduce any new potential unacceptable risks to aviation safety.

- (b) The person referred to in point [IS.I.OR.240](#)(a) and (b) and other affected personnel of the organisation shall be informed of the outcome of the risk assessment carried out in accordance with point [IS.I.OR.205](#), the corresponding threat scenarios and the measures to be implemented.

The organisation shall also inform organisations with which it has an interface in accordance with point [IS.I.OR.205](#)(b) of any risk shared between both organisations.

GM1 IS.I.OR.210 Information security risk treatment

ED Decision 2025/014/R

Unacceptable risks identified in accordance with point [IS.I.OR.205](#) require a risk treatment process that may lead to the introduction of information security measures, often referred to as information security controls.

For each identified risk, the organisation defines the specific risk treatment measures, methods or resources that will be used over the life cycle of each asset to:

- manage risk reduction;
- monitor and maintain each asset;
- update and fulfil activities for configuration management;
- manage supply chain;
- manage contracted services or service provider.

The review of risk treatment measures includes life cycle considerations which are introduced by equipment, procedures and personnel.

A risk treatment plan as an outcome of the risk management process includes a prioritisation of risks, the corresponding information on the objectives and means for risk treatment to reach an acceptable level of risk, as well as agreed timelines specifying when responsible personnel should have implemented the risk treatment measures. The timelines for the implementation of a risk treatment measure are subject to agreement by the personnel responsible for the implementation and are communicated to and accepted by the accountable manager of the organisation or delegated person(s).

Any subsequent implementation delay, together with its cause, reason, rationale or necessity, is documented in the risk treatment plan, for risks that may lead to an unsafe condition. The delay is also subject to the acceptance by the accountable manager of the organisation or delegated person(s). This person may condition such acceptance on the implementation or availability of compensating controls or reactive measures to monitor, early detect and timely respond to the materialisation of the risk in treatment. In order to timely respond, the incident response team may be informed to trigger their preparedness.

The risk treatment plan can act as a means of communication with the competent authority to demonstrate effective treatment of unacceptable risks. Similarly, this plan can be utilised to communicate to interfacing organisations how shared risks are controlled.

In accordance with IS.I.OR.205(d), a regular or conditional review of the risk assessment is necessary, and this includes the review of the risk treatment measures developed under [IS.I.OR.210\(a\)](#) to identify whether they are still effective or they require adaptations.

In addition, the organisation should also consider the potential impact on the effectiveness of risk treatment measures where a shared information security risk may arise as a result of the interaction between interfacing entities (see [IS.I.OR.235](#) and related AMC).

AMC1 IS.I.OR.210(a) Information security risk treatment

ED Decision 2023/009/R

- (a) The risk treatment process should reach at least one of the objectives listed under [IS.I.OR.210\(a\)](#).

- (b) When establishing compliance with the objectives under points [IS.I.OR.210\(a\)\(1\)](#) and [IS.I.OR.210\(a\)\(2\)](#), the organisation should take into account that:
- (1) the measures developed under these points should be implemented according to a risk treatment plan with defined, risk-based priorities, objectives and agreed timelines and owners;
 - (2) life cycle considerations should be identified and associated to ensure continuous effectiveness of the information security measures including exchange of data with other entities;
 - (3) it should review and update the risk assessment, according to [IS.I.OR.205\(d\)](#), to evaluate whether the measures developed under these points introduce new unacceptable risks or modify existing risks in a way that they become unacceptable.
- (c) Risk treatment should be documented and recorded, for example, in a risk registry, even if the risk has been avoided.

IS.I.OR.215 Information security internal reporting scheme

Regulation (EU) 2023/203

- (a) The organisation shall establish an internal reporting scheme to enable the collection and evaluation of information security events, including those to be reported pursuant to point [IS.I.OR.230](#).
- (b) That scheme and the process referred to in point [IS.I.OR.220](#) shall enable the organisation to:
- (1) identify which of the events reported pursuant to point (a) are considered information security incidents or vulnerabilities with a potential impact on aviation safety;
 - (2) identify the causes of, and contributing factors to, the information security incidents and vulnerabilities identified in accordance with point (1), and address them as part of the information security risk management process in accordance with points [IS.I.OR.205](#) and [IS.I.OR.220](#);
 - (3) ensure an evaluation of all known, relevant information relating to the information security incidents and vulnerabilities identified in accordance with point (1);
 - (4) ensure the implementation of a method to distribute internally the information as necessary.
- (c) Any contracted organisation which may expose the organisation to information security risks with a potential impact on aviation safety shall be required to report information security events to the organisation. Those reports shall be submitted using the procedures established in the specific contractual arrangements and shall be evaluated in accordance with point (b).
- (d) The organisation shall cooperate on investigations with any other organisation that has a significant contribution to the information security of its own activities.
- (e) The organisation may integrate that reporting scheme with other reporting schemes it has already implemented.

AMC1 IS.I.OR.215(a)&(b) Information security internal reporting scheme

ED Decision 2023/009/R

Organisations should use as a source the incidents detected during activities performed to show compliance with [IS.I.OR.220\(a\)](#). Organisations should have a mechanism to collect notifications of events by personnel and by sources outside the company including suppliers, partners, customers, open-source software, and information security researchers. The mechanism for collecting information by personnel and external sources should be easily accessible and communicated.

The organisation should collect all events gathered through the detection means for internal analysis. Each event should be analysed to identify whether it is reportable and if so, what potential or actual impact on aviation safety has occurred. Information security events should be considered in combination with other events to provide correlation to identify incidents or vulnerabilities with a potential impact on aviation safety.

The organisation should consider the outcome of the risk assessment and the exploitability of new vulnerabilities discovered during the detection activities conducted according to the measures required in [IS.I.OR.220\(a\)](#).

The organisation should identify all internal stakeholders that require notification of a specific incident or vulnerability and ensure that these stakeholders receive all necessary information on the incident or vulnerability in order to act effectively and in a timely manner to support the required detection and response periods.

GM1 IS.I.OR.215(a)&(b) Information security internal reporting scheme

ED Decision 2023/009/R

RELATIONSHIP BETWEEN INTERNAL AND EXTERNAL REPORTING

Organisations should collect and report internally incidents and vulnerabilities aiming at covering all items within the scope of this Regulation. Both internal and external reporting are necessary for a complete and effective reporting system. Internal reports should be assessed in a timely manner and where the potential impact on safety is an unsafe condition, organisations should initiate reporting of these internal reports according to [IS.I.OR.230](#).

GM2 IS.I.OR.215(a)&(b) Information security internal reporting scheme

ED Decision 2023/009/R

ORGANISATION OF COLLECTION AND EVALUATION OF INFORMATION SECURITY EVENTS

It is a common practice in large organisations to centralise information security operations in a security operations centre (SOC) and make use of an information security information and event management (SIEM) system. A SIEM system collects all events from sources such as log files in a common database and allows the analysts and responders in a joint SOC to review and act on these events. Organisations may choose to use a SOC for events relevant to Part-IS in isolation or in combination with events not subject to Part-IS but of interest to the organisation, such as events relating to business interests. Events can be automatically aggregated, correlated and analysed in order to detect abnormal behaviour leading to information security incidents.

Organisations that do not have a SOC capability and do not use a SIEM system need to consider how to establish processes to meet the required collection and evaluation capabilities as well as detection and response times.

GM3 IS.I.OR.215(a)&(b) Information security internal reporting scheme

ED Decision 2023/009/R

RELEVANT INFORMATION FOR INCIDENTS AND VULNERABILITIES

Understanding the causes of, and contributing factors to, information security incidents and vulnerabilities relevant to Part-IS allows lessons learned to be gained and to introduce corrections to processes and asset design. However, understanding causes and contributing factors may not always be possible or may not aid in continuous improvement of aviation safety. Where vulnerabilities arise from assets developed solely or primarily for aviation, it is expected to be possible to perform the necessary investigation on the root causes. These root causes will inform the affected organisation(s) to improve processes and asset design to remediate vulnerability and to ensure that such vulnerabilities are not introduced in other assets. Understanding the root causes of vulnerabilities also allows the aviation community to learn and thus avoid similar vulnerabilities in the future.

GM1 IS.I.OR.215(c) Information security internal reporting scheme

ED Decision 2023/009/R

If contracted organisations are also subject to this Regulation, the exchange of information and reporting should be covered under the management of shared risks and through the establishment of an external agreement between the organisations. Guidance regarding the development of external agreements can be found in EUROCAE ED-201A, Chapter 4.4 External agreements.

More in general, and in all other cases, any service contract should include standard clauses concerning obligations for the contracted organisation to:

- report within an agreed time information security incidents that may have an impact on the contracting organisation. Incidents and vulnerabilities which could lead to unsafe conditions should be reported as soon as possible and in such a manner that the external reporting obligation under [IS.I.OR.230](#) can be ensured;
- designate a point of contact for the incident management and possible crisis management.

In some cases contracted organisations, such as service providers with distributed resources, may not be able to offer any ad hoc reporting. In these cases the internal reporting requirement may be fulfilled through other means that satisfy the objective of this provision. For instance, the contracted organisations may provide an up-to-date list of vulnerabilities affecting the systems within the scope of the contracted services. This list should be monitored by the contracting organisation as part of the internal reporting of information security events.

GM1 IS.I.OR.215(d) Information security internal reporting scheme

ED Decision 2023/009/R

The cooperation under point [IS.I.OR.215\(d\)](#) can be substantiated by sharing elements from incident records that can support other organisations' information security activities. In case the organisations are bound by contractual obligations, this contract may also include commitment to cooperate. Organisations may consider developing formal agreements (e.g. a memorandum of understanding)

outlining roles and responsibilities for information security collaboration such as governance meetings, joint development activities, and real-time indicators of compromise (IoC) sharing.

Moreover, commitment to cooperate may also be achieved through the active participation of the organisation in information security sharing initiatives; for instance, ISAC(s). Additionally, for their own awareness, organisations may also subscribe to receive vulnerability and threat alerts, like those distributed by CERTs.

IS.I.OR.220 Information security incidents — detection, response and recovery

Regulation (EU) 2023/203

- (a) Based on the outcome of the risk assessment carried out in accordance with point [IS.I.OR.205](#) and the outcome of the risk treatment performed in accordance with point [IS.I.OR.210](#), the organisation shall implement measures to detect incidents and vulnerabilities that indicate the potential materialisation of unacceptable risks and which may have a potential impact on aviation safety. Those detection measures shall enable the organisation to:
 - (1) identify deviations from predetermined functional performance baselines;
 - (2) trigger warnings to activate proper response measures, in case of any deviation.
- (b) The organisation shall implement measures to respond to any event conditions identified in accordance with point (a) that may develop or have developed into an information security incident. Those response measures shall enable the organisation to:
 - (1) initiate the reaction to the warnings referred to in point (a)(2) by activating predefined resources and course of actions;
 - (2) contain the spread of an attack and avoid the full materialisation of a threat scenario;
 - (3) control the failure mode of the affected elements defined in point [IS.I.OR.205\(a\)](#).
- (c) The organisation shall implement measures aimed at recovering from information security incidents, including emergency measures, if needed. Those recovery measures shall enable the organisation to:
 - (1) remove the condition that caused the incident, or constrain it to a tolerable level;
 - (2) reach a safe state of the affected elements defined in point [IS.I.OR.205\(a\)](#) within a recovery time previously defined by the organisation.

GM1 IS.I.OR.220 Information security incidents — detection, response and recovery

ED Decision 2023/009/R

Without prejudice to the definition of ‘information security event’ in [Article 3](#) of Regulation (EU) 2023/203, those events that indicate the potential materialisation of unacceptable risks include both occurrences (i.e. anything that causes harm or have the potential to cause harm) and discovery of vulnerabilities. In fact, information security risks are associated with the potential that threats will exploit vulnerabilities, therefore the discovery of an exploitable vulnerability is an information security event.

In light of this, in the context of this Regulation:

- detection activities required under [IS.I.OR.220\(a\)](#) include vulnerability discovery;
- response activities under [IS.I.OR.220\(b\)](#) include vulnerability management.

AMC1 IS.I.OR.220(a) Information security incidents — detection, response and recovery

ED Decision 2023/009/R

DETECTION

When complying with the requirement in [IS.I.OR.220\(a\)](#), the organisation should define and implement a strategy to detect information security incidents which may have a potential impact on safety.

This should be done in a way to ensure that at least the detection strategy is able to cover all known information security threats to their assets that may materialise in a safety hazard having unacceptable consequences.

DETECTION STRATEGY

In order to determine the scope of the event detection, the organisation should:

- (a) identify a list of threat scenarios from the risks identified under [IS.I.OR.205](#);
- (b) identify, as a minimum, those assets that, if compromised, contribute to the scenario(s) that may materialise in an unsafe condition. For this identification of the assets, the measures introduced under [IS.I.OR.210](#) should also be considered.

Note: The contribution of an asset to the threat scenario and the materialisation of an unsafe condition should be assessed by considering also the whole functional chain. In some cases, the asset may be at the end of a functional chain and if it is compromised, the effect on safety is direct and may be immediate; conversely, if the asset is far from the end of a functional chain and it is compromised, the effect should propagate and may be delayed.

GM1 IS.I.OR.220(a) Information security incidents — detection, response and recovery

ED Decision 2023/009/R

DETECTION STRATEGY

When developing the detection strategy, for those items within the scope of event detection, the organisation should define the conditions that trigger a process that, for example, would require personnel intervention and further analysis. These conditions on the items may be defined using elements from the:

- (a) expected functional baseline: engage in the identification of deviations from the expected functional operation of the system (excluding information security functions/controls);
- (b) expected information security baseline: engage in the identification of deviations from the expected information security operation of information security controls.

These conditions should consider both abnormal behaviour and substantial deviations from the baselines and relevant correlation of multiple independent events.

Further guidance on the objectives for the establishment of a detection strategy can be found in EUROCAE ED-206, Chapter 4.

AMC1 IS.I.OR.220(b) Information security incidents — detection, response and recovery

ED Decision 2023/009/R

(a) INCIDENTS

The organisation should take into account the following aspects when establishing compliance with the objectives contained in point [IS.I.OR.220\(b\)](#) relative to incidents:

- (1) Preparation of procedures and delineation of roles and responsibilities to respond in a timely, effective and orderly manner to any relevant information security incidents.
- (2) The response procedure should:
 - (i) consider the warnings, unitary or combined, from IS.I.OR.220(a)(2), and in collaboration with appropriate personnel assess their potential impact on aviationsafety;
 - (ii) establish, in accordance with IS.I.OR.220(b)(2), a containment strategy for each asset category considering the potential worst-case effect and the mission constraints, and provide criteria indicating when the incident is contained;
 - (iii) define, in accordance with IS.I.OR.220(b)(3), the acceptable impact on safety and information security of each asset within the scope when they fail due to the materialisation of a threat scenario.
- (3) The response time should be commensurate with the impact level assessed in (2)(iii).
- (4) The response measures implemented under IS.I.OR.220(b) should be based on the response procedure referred to in the point (a)(2) and they should, in particular, consider the following:
 - (i) the maximum acceptable safety level degradation of the assets within the scope of incident;
 - (ii) the actions, such as resistance, containment, deception and control of the possible ways systems can fail, which will contribute to achieving the acceptable safety level degradation identified in point (i) while minimising the impact on operations;
 - (iii) the resources required to implement the actions specified in point (ii).
- (5) The response time and the measures should take into account the potential immediate negative impact on safety if the measure is taken before it has been fully verified that it would not cause additional immediate safety impacts.

(b) VULNERABILITIES

The organisation should take into account the following aspects when establishing compliance with the objectives contained in point IS.I.OR.220(b) relative to vulnerabilities:

- (1) Establishment of a vulnerability management strategy defining procedures, roles and responsibilities to respond in a timely, effective and orderly manner to any detected relevant vulnerabilities.

- (2) The response measures implemented under point IS.I.OR.220(b) should be based on the maximum acceptable risk of the items within the scope of the vulnerability, considering the worst-case scenario of the vulnerability being exploited.
- (3) The response time should be commensurate with the pre-triage done on the warnings and the assessment of the potential impact of the vulnerability, if it is exploited.

GM1 IS.I.OR.220(b) Information security incidents — detection, response and recovery

ED Decision 2023/009/R

An attack is considered contained (i.e. it is not spreading any further) when the boundaries of the incident have been identified and the threat does not propagate beyond these boundaries. Further guidance can be found in EUROCAE ED-206, Chapter 5.

The term ‘warning’ as used in [IS.I.OR.220](#) should be understood as an alert that would require timely awareness and response from the information security events management team.

In the context of information security response, ‘deception’ refers to a range of techniques that aim to mislead potential attackers or malicious users, thereby protecting the system and its data. Deception techniques, such as honeypots or breadcrumb trails, are designed to confuse, slow down or divert attackers, increasing their cost and risk while providing defenders with valuable time and intelligence.

Guidance regarding the vulnerability management strategy can be found in EUROCAE ED-206, Chapter 3.4 — Vulnerability management considerations. This is not the only source where guidance can be found, and the organisation may refer to different guidance more appropriate for their application.

AMC1 IS.I.OR.220(c) Information security incidents — detection, response and recovery

ED Decision 2023/009/R

When complying with the requirement in [IS.I.OR.220\(c\)](#), the organisation should develop an incident recovery procedure including at least the following:

- (a) a list of those assets that enable safe operations, as well as the dependencies among them, constituting the scope of the recovery;
- (b) a description of the process with the necessary priority actions to be executed for a return to a safe and secure state for the assets within the scope of the recovery;
- (c) the resources required to execute the actions defined in point (b) to ensure that these resources are readily available after an incident has occurred;
- (d) the objectives for recovery time that should be set in relation to the safety criticality of the assets within the scope of the recovery.

GM1 IS.I.OR.220(b)&(c) Information security incidents — detection, response and recovery

ED Decision 2023/009/R

RECOVERY OBJECTIVES AND TIMING

Point [IS.I.OR.220\(b\)](#) addresses event conditions which may develop or have developed into information security incidents, that may have a potential impact on aviation safety, and require response and recovery measures to be in place to ensure that operational safety remains above a minimum acceptable level.

The level of operations and safety may be interrelated, so in some cases when the level of operations is compromised by an information security incident and drops, the level of safety does the same. This is, for instance, the case of air traffic control; if air traffic services are reduced or become unreliable, the safety of flights is reduced too.

However, in other cases the relation between the level of operations and safety may be the inverse, or they may be decoupled, so when an incident occurs and the level of operations drops, the level of safety is preserved. One example is the compromise of the software loading process on board the aircraft. In this case, a detected incident followed by the decision to interrupt the software loading operations would preserve the existing level of safety.

The following Figure 1 depicts a conceptual framework that may be considered for the definition of the response and recovery objectives, including the recovery time. It represents, in the worst-case scenario, how the expected level of operational safety (safety level) for a process or an activity may vary over time when an information security incident occurs. In this scenario, the safety level is first reduced by the incident and then it degrades as long as the time passes. The figure also shows the expected effect that mitigating measures and controls should have, respectively: in containing the operational safety drop as soon as an incident occurs, and in improving the recovery, i.e. the return to the expected safety level.

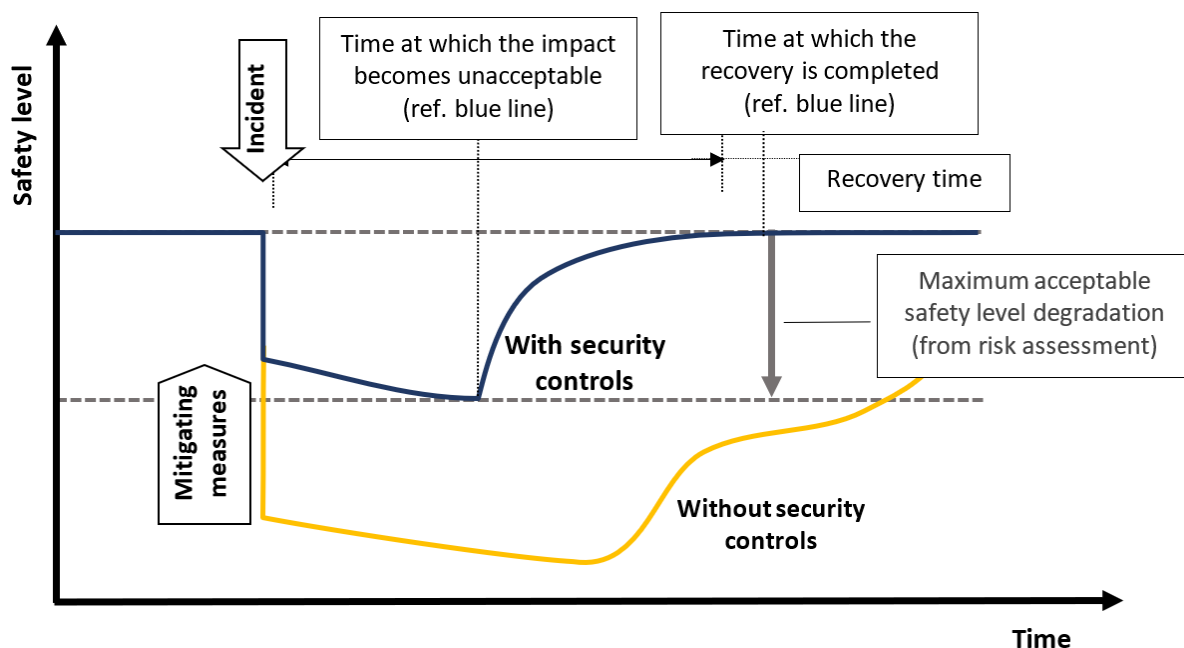


Figure 1: Conceptual framework for the definition of the response and recovery objectives

As mentioned, there might be different relations between the level of operations and safety that would lead to a different representation of the above figure. In certain cases, an incident may have a delayed effect on the safety level (e.g. a compromised development environment) as depicted in Figure 2, or it may have no impact if properly controlled, as in the case of the compromised software loading process mentioned before, which is depicted in Figure 3.

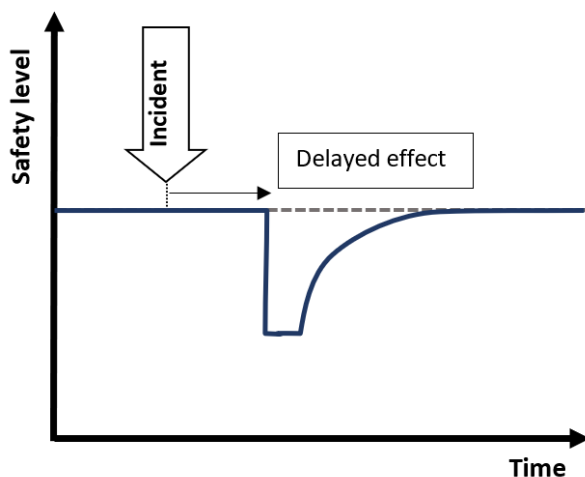


Figure 2: Incident with a delayed effect on safety

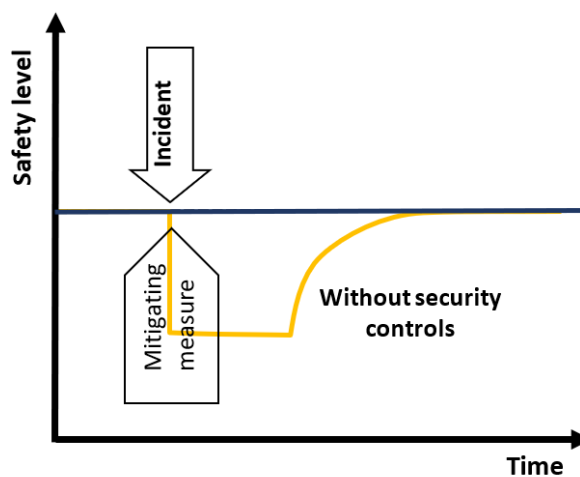


Figure 3: Incident with a fully mitigated effect on safety

Moreover, it should be noticed that there might be different ways the same incident can be dealt with, since there are several factors that may affect safety.

In practical terms, the objectives for recovery time referred to in [AMC1 IS.I.OR.220\(c\)](#) may be expressed as a list of resources and services to be restored by order of priority, within the scope of the recovery. Guidance about objectives for recovery time can be found in EUROCAE ED-206, Chapter 7.3.5.

GM1 IS.I.OR.220(c) Information security incidents — detection, response and recovery

ED Decision 2023/009/R

A recovery procedure or recovery plan should describe incident recovery actions and the internal or external resources that are involved (e.g. staff, IT, buildings, providers). Guidance about incident recovery plan can be found in EUROCAE ED-206, Chapter 7 – Recover.

The resources required to apply the recovery measures should be available in order to implement the recovery actions in a timely manner after an incident has occurred. Those resources may be internally available or provided by contracted organisations as provided for in [IS.I.OR.235](#). The contracting of recovery activities should be established before an incident occurs (proactive), and the contract should include provisions for the contracted party to react in a timely manner.

The return to a safe and secure state may initially require emergency measures, which are actions that are initiated based on the best information available at the time, before complete understanding of the situation is achieved and these measures can potentially degrade the level of service or functionalities. The return to a safe and secure state should be evaluated against the initial risk assessment and may only temporarily differ from the normal operational conditions. However, any

increase of the residual risk and the duration of this risk increase, i.e. due to the implementation of emergency measures, should be documented and accepted at the right level of accountability.

The recovery activities mentioned here may also be the outcome of the response to incidents for which the organisation has received information that requires the implementation of adequate measures in order to react to information security incidents or vulnerabilities with a potential impact on aviation safety.

In such context the organisation may not have a process or a recovery plan covering the specific occurrence. Therefore, the definition from the organisation of a specific recovery plan and its approval by the competent authority is usually required.

IS.I.OR.225 Response to findings notified by the competent authority

Regulation (EU) 2023/203

- (a) After receipt of the notification of findings submitted by the competent authority, the organisation shall:
 - (1) identify the root cause or causes of, and contributing factors to, the non-compliance;
 - (2) define a corrective action plan;
 - (3) demonstrate the correction of the non-compliance to the satisfaction of the competent authority.
- (b) The actions referred to in point (a) shall be carried out within the period agreed with the competent authority.

AMC1 IS.I.OR.225 Response to findings notified by the competent authority

ED Decision 2023/009/R

The compliance with [IS.I.OR.225](#) should be managed as required for each organisation in the corresponding implementing regulation for the domain as identified in point [Article 2](#)(1) of Regulation (EU) 2023/203 concerning the response to findings notified by the competent authority. The domain regulation may require the organisation to respond to the findings in accordance with their categorisation.

GM1 IS.I.OR.225 Response to findings notified by the competent authority

ED Decision 2023/009/R

The requirement for the categorisation of findings and the period within which the actions in [IS.I.OR.225](#)(a) should be performed can be found in the corresponding implementing regulation for the domain, under the authority requirements. For the opening of findings related to this Regulation, the competent authority will follow the above-mentioned requirement.

IS.I.OR.230 Information security external reporting scheme

Regulation (EU) 2023/203

- (a) The organisation shall implement an information security reporting system that complies with the requirements laid down in Regulation (EU) No 376/2014 and its delegated and implementing acts if that Regulation is applicable to the organisation.
- (b) Without prejudice to the obligations of Regulation (EU) 376/2014, the organisation shall ensure that any information security incident or vulnerability, which may represent a significant risk to aviation safety, is reported to their competent authority. Furthermore:
- (1) Where such an incident or vulnerability affects an aircraft or associated system or component, the organisation shall also report it to the design approval holder;
 - (2) Where such an incident or vulnerability affects a system or constituent used by the organisation, the organisation shall report it to the organisation responsible for the design of the system or constituent.
- (c) The organisation shall report the conditions referred to in point (b) as follows:
- (1) a notification shall be submitted to the competent authority and, if applicable, to the design approval holder or to the organisation responsible for the design of the system or constituent, as soon as the condition has been known to the organisation;
 - (2) a report shall be submitted to the competent authority and, if applicable, to the design approval holder or to the organisation responsible for the design of the system or constituent, as soon as possible, but not exceeding 72 hours from the time the condition has been known to the organisation, unless exceptional circumstances prevent this.

The report shall be made in the form defined by the competent authority and shall contain all relevant information about the condition known to the organisation;
 - (3) a follow-up report shall be submitted to the competent authority and, if applicable, to the design approval holder or to the organisation responsible for the design of the system or constituent, providing details of the actions the organisation has taken or intends to take to recover from the incident and the actions it intends to take to prevent similar information security incidents in the future.

The follow-up report shall be submitted as soon as those actions have been identified, and shall be produced in the form defined by the competent authority.

GM1 IS.I.OR.230 Information security external reporting scheme

ED Decision 2023/009/R

Organisations are required to report occurrences to their competent authority.

EXAMPLES

Design organisations approved by EASA: EASA is the competent authority.

Air operators certified by the competent authority of a Member State: the competent authority of the Member State is the competent authority.

SPECIAL CASES

In a situation where an organisation has two air operator certificates (AOCs) under two different EU Member States (State A and B), the occurrences involving aircraft operating under the State A AOC

have to be reported to the State A competent authority; instead, the occurrences involving aircraft operating under the State B AOC have to be reported to the State B competent authority.

For organisations holding multiple approvals, the reporting will be done to the competent authority of the approved part of the organisation where the incident has occurred, or the vulnerability has been discovered. In case the incident/vulnerability affects multiple approvals, the reporting will be done to all the competent authorities.

For organisations holding an approval but operating outside the EU (e.g. Part-145), EASA is the competent authority and they have to report to the Agency.

Dual-use aircraft — a vulnerability may need to be reported through both the military and civil reporting systems if it affects a dual-use function/system. Information reported through the civil reporting system should be sanitised (i.e. all sensitive information should be properly removed).

AMC1 IS.I.OR.230(a)&(b) Information security external reporting scheme

ED Decision 2023/009/R

In order to comply with the provisions under [IS.I.OR.230](#) (a) and (b), the organisation should report:

- (a) any occurrence covered by Regulation (EU) No 376/2014 that originated from intentional unauthorised electronic interactions;
- (b) information security incidents having a potential significant risk to aviation safety not covered under Regulation (EU) No 376/2014;
- (c) vulnerabilities that pose a significant risk to aviation safety and are not yet adequately mitigated in accordance with an approved vulnerability management strategy (see [AMC1 IS.I.OR.220\(b\)](#)).

From the aforementioned reports, it is the responsibility of the competent authorities under Part-IS to ensure compliance with [Article 7](#) of this Regulation and to submit any relevant information that needs to be shared with the information security competent authorities designated under Article 8 of Directive (EU) 2016/1148.

GM1 IS.I.OR.230(a)&(b) Information security external reporting scheme

ED Decision 2023/009/R

RELATION BETWEEN IS.I.OR.230(b) AND REGULATION (EU) No 376/2014

Regulation (EU) No 376/2014 of the European Parliament and of the Council lays down requirements on the reporting, analysis and follow-up of occurrences in civil aviation. Compliance with point [IS.I.OR.230\(b\)](#) does not exempt organisations from compliance with Regulation (EU) No 376/2014.

For each category of reporter, Regulation (EU) 2015/1018 defines the nature of items to be mandatorily reported. Regulation (EU) No 376/2014 also considers voluntary reporting of other items that are perceived by the reporter as a threat to aviation safety.

Furthermore, compliance with Regulation (EU) No 376/2014 does not exempt organisations from compliance with point IS.I.OR.230(b). However, this should not give rise to two parallel reporting systems, and point IS.I.OR.230(b) and Regulation (EU) No 376/2014 should be seen as complementary in that respect.

In practice, this means that reporting obligations under point IS.I.OR.230(b) on the one hand and reporting obligations under Regulation (EU) No 376/2014 on the other hand are compatible. These reporting obligations may be discharged using one reporting channel. In addition, any natural or legal person that has more than one role subject to the obligation to report may discharge all those obligations through a single report. Organisations are encouraged to properly describe this in their organisation manual, to address cases in which the responsibilities are discharged on behalf of the organisation.

FOLLOW-UP ANALYSIS

When the analysis of an occurrence reported under Regulation (EU) No 376/2014 later identifies that the root cause of, or the contributing factor to, the occurrence was an intentional unauthorised electronic interaction, the organisation should update its notification to the competent authority.

SIGNIFICANT RISK TO AVIATION SAFETY

In line with the definition of occurrence under Article 2(7) of Regulation (EU) No 376/2014, any information security incident or vulnerability, which may represent a significant risk to aviation safety, should be considered a reportable occurrence. Significant risk to aviation means unsafe condition, i.e. one that can result in an accident or a serious incident (as defined in ICAO Annex 13).

Note: When assessing the possibility that the effects of an information security incident could lead to an unsafe condition, the organisation should consider the combination of effects if the incident involves multiple systems; indeed, some assumptions about system independence that may be valid for fortuitous occurrences may be violated by deliberate acts.

RELATION BETWEEN IS.I.OR.230(b)(1) AND OTHER REPORTING REQUIREMENTS OF INFORMATION SECURITY OCCURRENCES RELATED TO AVIATION PRODUCTS OR PARTS

For organisations subject to reporting requirements of information security occurrences related to aviation products or parts, compliance with the specific provisions in the implementing regulation for their domain is considered sufficient to achieve compliance with the requirement in point IS.I.OR.230(b)(1). For example, for organisations subject to Regulation (EU) No 748/2012, the reporting can be done in accordance with point 21.A.3A of Annex I (Part 21) to that Regulation.

AMC1 IS.I.OR.230(c) Information security external reporting scheme

ED Decision 2023/009/R

Within the overall limit of 72 hours the degree of urgency for submission of a report should be determined by the level of the safety impact judged to have resulted from the information security incident or discovered vulnerability. Where an occurrence is judged by the person identifying the possible unsafe condition to have resulted in an immediate and particularly significant hazard, the competent authority expects to be advised immediately and by the fastest possible means (telephone, fax, email, telex, etc.) of whatever details are available at that time.

GM1 IS.I.OR.230(c) Information security external reporting scheme

ED Decision 2023/009/R

Guidance regarding the reporting of information security incidents and vulnerabilities can be found in EUROCAE ED-206, Chapter 6.4.2.2 — Reporting timeline and Chapter 6.4.5 — Reporting information content. This is not the only source where guidance can be found, and the organisation may refer to different guidance more appropriate for their application.

Note: The person reporting an occurrence under Regulation (EU) No 376/2014 may not have the capability to determine the nature of the occurrence. This is particularly true for information security and the result can come from forensic analysis that determines the information security nature of the occurrence. The evaluation will be done as part of the initial internal reporting process (see [IS.I.OR.215](#) and related AMC). The evaluation of the occurrence can demonstrate the possibility that it materialises into an unsafe condition taking into account the likelihood of realisation.

IS.I.OR.235 Contracting of information security management activities

Regulation (EU) 2023/203

- (a) The organisation shall ensure that when contracting any part of the activities referred to in point [IS.I.OR.200](#) to other organisations, the contracted activities comply with the requirements of this Regulation and the contracted organisation works under its oversight. The organisation shall ensure that the risks associated with the contracted activities are appropriately managed.
- (b) The organisation shall ensure that the competent authority can have access upon request to the contracted organisation to determine continued compliance with the applicable requirements laid down in this Regulation.

GM1 IS.I.OR.235 Contracting of information security management activities

ED Decision 2023/009/R

Organisations may decide to outsource certain activities to suppliers, both for their own operational needs and for the purpose of complying with this Regulation (information security management activities). Activities contracted for operational needs may fall within the scope of Part-IS and therefore the relevant information security risks have to be managed in accordance with the requirements in points [IS.I.OR.205](#) and [IS.I.OR.210](#). Instead, information security management activities are subject to the specific provisions of [IS.I.OR.235](#) because matters relating to these activities can have a major impact on the organisation.

Therefore the objectives of point [IS.I.OR.235](#) are:

- (a) to protect critical and sensitive information and assets when being handled by organisations contracted for the provision of information security management activities (including organisations in the supply chain) at either their facilities or the organisation facilities, or when being transmitted between the organisation and contracted organisations, or being remotely accessed by contracted organisations;
- (b) to prevent information security risks from being introduced through products and services developed or provided by the contracted organisations to the organisation, in the frame of the provision of information security management activities;
- (c) to ensure that information security risks are managed throughout all the stages of the relation with the contracted organisations.

GM2 IS.I.OR.235 Contracting of information security management activities

ED Decision 2023/009/R

- (a) The contracting of information security management activities is a means to allocate tasks from the contracting organisation to third parties (contracted organisations). The contracting organisation remains responsible for the oversight of the contracted organisation(s) and accountable for compliance with this Regulation.
- (b) A contract could take the form of a written agreement, letter of agreement, service letter agreement, memorandum of understanding, etc. as appropriate for the contracted activities.

GM3 IS.I.OR.235 Contracting of information security management activities

ED Decision 2023/009/R

EXAMPLES

The following Table 1 provides some examples of information security management activities that may be contracted in relation to the provisions referred to as in [IS.I.OR.200](#).

Table 1: Examples of information security management activities that may be contracted

IS.I.OR.200 points related to activities	Example of contracted activity
(a)(1): establishes a policy on information security setting out the overall principles of the organisation with regard to the potential impact of information security risks on aviation safety;	Information security policy drafting and consultancy
(a)(2): identifies and reviews information security risks in accordance with point IS.I.OR.205 ;	Identify activities, facilities and resources. Identify interfaces with other organisations which could be exposed to information security risks. Perform risk analysis or part of it, e.g. identify and classify information security risks.
(a)(3): defines and implements information security risk treatment measures in accordance with point IS.I.OR.210 ;	Define, develop and implement measures. Verify the initial and the continued effectiveness of the implemented measures (e.g. red-team/blue-team exercises, penetration testing, vulnerability scanning, etc.). Communicate to the involved stakeholders the outcome of the risk assessment and their responsibilities as part of the risk treatment process.
(a)(4): implements an information security internal reporting scheme in accordance with point IS.I.OR.215 ;	Define, develop and implement an internal reporting scheme to enable the collection and evaluation of information security events and vulnerabilities of equipment, processes and services.

IS.I.OR.200 points related to activities	Example of contracted activity
(a)(5): defines and implements, in accordance with point IS.I.OR.220 , the measures required to detect information security events, identifies those events which are considered incidents with a potential impact on aviation safety except as permitted by point IS.I.OR.205(e) , and responds to, and recovers from, those information security incidents;	Define, develop and implement measures to detect events. Define, develop and implement measures to respond to any event conditions. Define, develop and implement measures aimed at recovering from information security incidents.
(a)(6): implements the measures that have been notified by the competent authority as an immediate reaction to an information security incident or vulnerability with an impact on aviation safety;	Implement immediate reaction measures to an information security incident or vulnerability as notified by the competent authority.
(a)(7): takes appropriate action, in accordance with point IS.I.OR.225 , to address findings notified by the competent authority;	Identify root cause. Define corrective action plan. Provide evidence of the corrective actions implemented to close the finding.
(a)(8): implements an external reporting scheme in accordance with point IS.I.OR.230 in order to enable the competent authority to take appropriate actions;	Define, develop and implement an external reporting scheme to enable the communication of the information security incidents and vulnerabilities of equipment, processes and services to the competent authority and when required to the design approval holder or the organisation responsible for the design.
(a)(9): complies with the requirements contained in point IS.I.OR.235 when contracting any part of the activities described in point IS.I.OR.200 to other organisations;	Not applicable
(a)(10): complies with the personnel requirements laid down in point IS.I.OR.240 ;	Activities of the accountable manager in the frame of the provisions for a 'common responsible person' as referred to in IS.I.OR.240 Compliance monitoring as foreseen by IS.I.OR.240 Contracted organisation to ensure that sufficient personnel is on duty to perform the activities related to this Regulation Define, develop and deliver adequate training to achieve the competencies required by the staff. Perform pre-employment checks.
(a)(11): complies with the record-keeping requirements contained in point IS.I.OR.245 ;	Define, develop and implement secured archiving. Provision of secure data centre (as a service) Provision of records updates
(a)(12): monitors compliance of the organisation with the requirements of this Regulation and provides feedback on findings to the accountable manager to ensure effective implementation of corrective actions;	Compliance monitoring (as foreseen by IS.I.OR.240) including the execution of independent audits
(a)(13): protects, without prejudice to applicable incident reporting requirements, the confidentiality of any information that the organisation may have received from other organisations, according to its level of sensitivity.	Define, develop and implement solutions to protect the confidentiality of any information.

IS.I.OR.200 points related to activities	Example of contracted activity
(b): In order to continuously meet the requirements referred to in Article 1, the organisation shall implement a continuous improvement process in accordance with point IS.I.OR.260 .	Execute independent effectiveness and maturity assessments. Define, develop and implement the necessary improvement measures.
(c): The organisation shall document, in accordance with point IS.I.OR.250 , all key processes, procedures, roles and responsibilities required to comply with point IS.I.OR.200 (a, and) shall establish a process for amending this documentation. Changes to those processes, procedures, roles and responsibilities shall be managed in accordance with point IS.I.OR.255 .	Production of documentation to detail all key processes, procedures, roles and responsibilities required to comply with point IS.I.OR.200 (a) (e.g. information security policies, general description of the staff, procedures to specify compliance). Define, develop and implement processes for approving amendments and changes.

AMC1 IS.I.OR.235(a) Contracting of information security management activities

ED Decision 2023/009/R

(a) OVERSIGHT OF THE CONTRACTED ORGANISATION

In order to exercise oversight of the contracted organisation, the organisation under Part-IS should have:

- (1) a process to ensure compliance with the provisions regarding contracted activities contained in this Regulation;
- (2) a structured process to follow the expected execution of the contract that includes:
 - (i) definition and agreement of the scope of the activities;
 - (ii) definition of the roles and responsibilities of the parties (i.e. contracting and contracted organisation);
 - (iii) definition and review of KPIs;
 - (iv) reaction to deviation from contractual obligations;
 - (v) performance of compliance audits, according to the predefined scope and objectives, with the aim of evaluating operational and associated assurance activities;
 - (vi) provision of feedback on the result of the compliance audits both within the organisation and to the contracted organisation, and response to findings. The feedback on the outcome of the compliance audits within the contracting organisation should reach the accountable manager or delegated person(s) to ensure proper monitoring of the response to findings (i.e. implementation of corrective actions) or, if deemed necessary, termination of the contract.

Note: The right of the organisation to conduct compliance audits of the contracted organisation should be included in the contract between the parties.

(b) MANAGEMENT OF THE RISKS ASSOCIATED WITH THE CONTRACTED ACTIVITIES

In order to properly manage the risks associated with the contracted activities, the organisation should meet the following criteria:

- (1) A prior assessment of the suppliers is conducted before outsourcing any information security management activities. The assessment should evaluate suppliers' competencies, sustainability as well as qualifications in relation to the activities to be contracted.
- (2) There is an assessment of the risks associated with the provision of the contracted activities that has been agreed between the organisation under Part-IS and the contracted organisation.
- (3) The organisation establishes and maintains appropriate information security communication channels with the contracted organisation.

GM1 IS.I.OR.235(a) Contracting of information security management activities

ED Decision 2023/009/R

PRIOR ASSESSMENT

The purpose of the prior assessment is to evaluate suppliers' competencies, sustainability as well as qualifications in relation to the information security activities to be contracted. This prior assessment may need to be carried out taking into account other legal requirements or procurement procedures that apply to the organisation, and may therefore be carried out in different ways, such as:

- (a) in case of public bids, inclusion of eligibility requirements in the procurement documents for the potential suppliers;
- (b) review of the information security certifications granted by external and impartial auditors to the potential suppliers;
- (c) review of self-assessment questionnaires compiled by the potential suppliers.

RISK ASSESSMENT ASSOCIATED WITH THE PROVISION OF THE CONTRACTED ACTIVITIES

The risk assessment should take into account the maturity level of the contracted organisation, and should consider the following:

- (a) identification and assessment of critical and sensitive information and assets that may be shared with, or provided by, external suppliers;
- (b) identification of the information security requirements of the organisation that are applicable to the contracted organisation;
- (c) evaluation, by means of a supplier assessment, of the ability of the contracted organisation (both existing and new contracted organisations) to meet the information security requirements of the contracting organisation;
- (d) assessment of risks that may be introduced by the contracted organisation.

This agreed risk assessment should also consider the roles and responsibilities of the contracting and contracted organisation as well as their interfaces.

GM2 IS.I.OR.235(a) Contracting of information security management activities

ED Decision 2023/009/R

AUDIT OF CONTRACTED ORGANISATIONS

The following aspects should be considered by the organisation when auditing a supplier contracted to perform information security management activities:

- the scope of the audit as well as the objective should be limited to processes, resources (i.e. contracted organisation personnel, systems/equipment, networks) and data used for the execution of Part-IS contracted activities;
- compliance and/or implementation audits should be done at the contracting organisation's discretion;
- findings identified during an audit should be addressed through a remediation plan within a time frame to be validated by the contracting organisation.

AMC1 IS.I.OR.235(b) Contracting of information security management activities

ED Decision 2023/009/R

In order to ensure access by the competent authority to the contracted organisation upon request, the organisation under Part-IS should ensure that such a requirement or clause is included in the contractual documentation.

The competent authority's access to the contracted organisations should be at least equivalent to that granted to the contracting organisation and, in any case, sufficient to ensure the assessment of continued compliance of the contracted activities with the applicable requirements.

GM1 IS.I.OR.235(b) Contracting of information security management activities

ED Decision 2023/009/R

Access to the contracted organisation means to have visibility of evidence for compliance of the contracted activities (such as artefacts, documents, independent certifications).

Evidence of compliance could be achieved either by transfer of documents and/or access to information at the premises in accordance with the 'audit scope' as defined in the contract.

In those cases where the organisation would use commercial off-the-shelf services with standard contractual clauses as part of the contracted information security management activities, the organisation should consider whether these clauses provide sufficient access to the required information.

The opportunity to visit the premises should be evaluated considering different aspects such as the sensitivity of the related information or the practical accessibility to the contracted organisation (e.g. the contracted organisation is a service provider with distributed resources).

IS.I.OR.240 Personnel requirements

Regulation (EU) 2023/203

- (a) The accountable manager of the organisation designated in accordance with Regulations [\(EU\) No 1321/2014](#), [\(EU\) No 965/2012](#), [\(EU\) No 1178/2011](#), [\(EU\) 2015/340](#), Implementing Regulation [\(EU\) 2017/373](#) or Implementing Regulation [\(EU\) 2021/664](#) as applicable referred to in [Article 2](#)(1) of this Regulation shall have corporate authority to ensure that all activities required by this Regulation can be financed and carried out. That person shall:
- (1) ensure that all necessary resources are available to comply with the requirements of this Regulation;
 - (2) establish and promote the information security policy referred to in point [IS.I.OR.200\(a\)\(1\)](#);
 - (3) demonstrate a basic understanding of this Regulation.
- (b) The accountable manager shall appoint a person or group of persons to ensure that the organisation complies with the requirements of this Regulation, and shall define the extent of their authority. That person or group of persons shall report directly to the accountable manager, and shall have the appropriate knowledge, background and experience to discharge their responsibilities. It shall be determined in the procedures who deputises for a particular person in the case of lengthy absence of that person.
- (c) The accountable manager shall appoint a person or group of persons with the responsibility to manage the compliance monitoring function referred to in point [IS.I.OR.200\(a\)\(12\)](#).
- (d) Where the organisation shares information security organisational structures, policies, processes and procedures with other organisations or with areas of their own organisation which are not part of the approval or declaration, the accountable manager may delegate its activities to a common responsible person.
- In such a case, coordination measures shall be established between the accountable manager of the organisation and the common responsible person to ensure adequate integration of the information security management within the organisation.
- (e) The accountable manager or the common responsible person referred to in (d) shall have corporate authority to establish and maintain the organisational structures, policies, processes and procedures necessary to implement point [IS.I.OR.200](#).
- (f) The organisation shall have a process in place to ensure that they have sufficient personnel on duty to carry out the activities covered by this Annex.
- (g) The organisation shall have a process in place to ensure that the personnel referred to in point (f) have the necessary competence to perform their tasks.
- (h) The organisation shall have a process in place to ensure that personnel acknowledge the responsibilities associated with the assigned roles and tasks.
- (i) The organisation shall ensure that the identity and trustworthiness of the personnel who have access to information systems and data subject to the requirements of this Regulation are appropriately established.

GM1 IS.I.OR.240 Personnel requirements

ED Decision 2023/009/R

The objectives of the requirements contained in points (a) through (e) are:

- (a) to ensure that an effective organisational structure is in place in order to comply with the requirements of this Regulation;
- (b) to provide trust to other organisations with whom they share risks.

AMC1 IS.I.OR.240(a)(2) Personnel requirements

ED Decision 2023/009/R

PROMOTION OF INFORMATION SECURITY POLICY

The accountable manager of the organisation should make sure that the information security policy is known and easily accessible for staff members as appropriate to their duties.

AMC1 IS.I.OR.240(a)(3) Personnel requirements

ED Decision 2023/009/R

BASIC UNDERSTANDING OF THE REGULATION

In order to demonstrate a basic understanding of this Regulation, the accountable manager of the organisation should have the ability to explain the overarching objectives of the Regulation and its implications for the organisation.

GM1 IS.I.OR.240(a)(3) Personnel requirements

ED Decision 2023/009/R

BASIC UNDERSTANDING OF THE REGULATION

In the event that the accountable manager has no previous experience in the areas of activity pertinent to Part-IS, he or she may gain the necessary understanding by attending a training covering the content the Regulation and the technical basis for compliance. In particular, the training material should cover the overarching objectives of Part-IS, and the assessment should evaluate the understanding of these regulatory objectives.

AMC1 IS.I.OR.240(b) Personnel requirements

ED Decision 2023/009/R

APPOINTMENT OF A PERSON OR GROUP OF PERSONS

The person or group of persons appointed under point [IS.I.OR.240\(b\)](#) with the responsibility to ensure compliance with the requirements of this Regulation should represent the management structure of the organisation.

The person or group of persons has direct access to the accountable manager (or the common responsible person, if appointed) to provide guidance, direction and support for the planning, implementation and operation of the process and standards to comply with the Regulation. They should have direct access to keep the accountable manager (or the common responsible person) properly informed on compliance and information security matters (for instance, through meetings organised on a regular basis).

Appointments should take into account the possibility that a person may not be able to carry out the organisational tasks assigned to them for a period of time, and thus also identify the necessary deputies.

These appointed persons should demonstrate a complete understanding of the requirements of this Regulation, to be able to ensure that the organisation's processes and standards accurately reflect the applicable requirements. It is their role to ensure that compliance is proactively managed, and that any early warning signs of non-compliance are documented and acted upon.

A description of the functions and the responsibilities of the appointed persons and deputies, including their names, should be contained in the ISMM (see point [IS.I.OR.250\(a\)\(2\)](#)).

GM1 IS.I.OR.240(b) Personnel requirements

ED Decision 2023/009/R

A condition of a lengthy absence of an appointed person occurs when that person is unable to perform the assigned organisational duties. For example, if an information security management activity is required to be carried out by appointed persons at a specified interval, an absence is considered lengthy when it exceeds this interval and therefore a vulnerability in the management activity may arise.

GM1 IS.I.OR.240(b)&(c) Personnel requirements

ED Decision 2023/009/R

Appointments may be made by email, organisational chart, roles & responsibilities table, etc. usually in use by the organisation. The organisation may adopt any titles for the foregoing information security management positions, but it should identify to the competent authority the titles and the persons chosen to carry out these functions.

GM1 IS.I.OR.240(c) Personnel requirements

ED Decision 2023/009/R

COMPLIANCE MONITORING FUNCTION

The person appointed under point [IS.I.OR.240\(c\)](#) with the responsibility to manage the compliance monitoring function required under point [IS.I.OR.200\(a\)\(12\)](#) may be the same person as, or report to, the person responsible for the compliance monitoring function required under the implementing regulation for the domain.

AMC1 IS.I.OR.240(d) Personnel requirements

ED Decision 2023/009/R

COORDINATION

The criteria to establish coordination that ensures adequate integration of the information security management within the organisation are the following:

- (a) the scope and boundaries of the organisations have been established and communicated to the common responsible person;
- (b) the requirements of this Regulation have been communicated to and shared with the common responsible person;
- (c) the common responsible person has direct access to the accountable manager;

- (d) issues are proactively managed and any early warning signs of non-compliance are documented and acted upon.

GM1 IS.I.OR.240(e) Personnel requirements

ED Decision 2023/009/R

COMMON RESPONSIBLE PERSON

If a common responsible person (CRP) is delegated by the accountable manager for the activities under this Regulation, this person should also be given the appropriate delegation that is necessary to implement the provisions of [IS.I.OR.200](#), including the authority and the financial means to mobilise and control the resources across the organisations, or parts of the organisation involved. This delegation may also include the appointment of the person or group of persons referred to in [IS.I.OR.240\(b\)](#) and (c) and, in general, the CRP may be assisted in the performance of his or her duties by additional personnel.

The possibility of delegating a CRP applies to an organisation that shares information security organisational structures, policies, processes and procedures with other organisations or with parts of its own organisation that are not part of the authorisation or declaration, and therefore this CRP is expected to have information security responsibilities and competencies. In particular, the CRP should be capable of managing the organisation's information security strategy and its implementation to ensure the achievement of the objectives described in Article 1. According to the European Cybersecurity Skills Framework (ECSF) published by ENISA in September 2022, this person may be described, for instance, as (Chief) Information Security Officer, Cybersecurity Programme Director or Information Security Manager. However, it should be noticed that these descriptions and the related skills do not consider the aviation safety perspective that is required in Article 1.

Where an entity holds multiple authorisations or declarations, the relevant accountable managers may delegate to the same CRP, who will therefore be responsible for implementing the provisions of [IS.I.OR.200](#) for a functional cluster sharing information security structures, policies, processes and procedures.

AMC1 IS.I.OR.240(f) Personnel requirements

ED Decision 2023/009/R

SUFFICIENT PERSONNEL

To determine the sufficiency of the personnel, the following elements should be taken into consideration:

- (a) the organisational structures, policies, processes and procedures subject to information security management;
- (b) the amount of coordination required with other organisations, contractors and suppliers;
- (c) the level of risk associated with the activities performed by the organisation.

GM1 IS.I.OR.240(f) Personnel requirements

ED Decision 2023/009/R

SUFFICIENT PERSONNEL

For the purpose of this Regulation, personnel refers to the combination of the personnel directly employed by the organisation, as well as the personnel contracted as specified in [IS.I.OR.235](#).

The activities reported in Appendix II, on the main tasks stemming from the implementation of Part-IS, should be considered when establishing the organisational structure necessary to comply with the requirements of this Regulation.

AMC1 IS.I.OR.240(g) Personnel requirements

ED Decision 2023/009/R

NECESSARY COMPETENCE

- (a) To determine the competence needed by the personnel performing the activities, the following elements should be taken into consideration:
 - (1) work roles and the associated tasks;
 - (2) required knowledge, skills and abilities.
- (b) As part of the process to ensure that personnel maintain the necessary competence, the organisation should:
 - (1) assess the personnel qualifications and experience with respect to the competence required for the assigned work roles to identify gaps;
 - (2) align the personnel qualifications and experience with the competence expected to fulfil their roles by organising adequate learning programmes for existing members of personnel, by recruiting new resources, or by a combination thereof;
 - (3) maintain the personnel competence during the time they are assigned to the work role.

GM1 IS.I.OR.240(g) Personnel requirements

ED Decision 2025/014/R

NECESSARY COMPETENCE AND TRAINING PROGRAMME

A training programme should start with the identification of the competence required by the personnel for each role, followed by the identification of the gaps between the existing competence and the required one.

In order to develop the list of competencies, an organisation may use, as initial guidance, an existing cybersecurity competence framework such as the European e-Competence Framework (e-CF) or the NICE (National Initiative for Cybersecurity Education) based on the NIST Cybersecurity Framework (NIST CSF).

In Appendix II, the main tasks of this Regulation are listed and mapped to the competencies derived from the EU e-CF or, for ease of mapping, to the functions and categories of the NIST CSF. This mapping may be used to establish a baseline to identify the aforementioned competence gaps. However, it should be noticed that existing cybersecurity/information security competence frameworks typically focus primarily on the protection of standard information technologies; therefore, the proposed list of competencies may need to be adapted to the technologies or integrated with processes used in the organisation.

The bridging of the identified gaps should be seen as the objective of the training programme, which should further include the scope, content, methods of delivery (e.g. classroom training, e-learning, notifications, on-the-job training) and frequency of training that best meet the organisation's needs considering the size, scope, required competencies, and complexity of the organisation.

Finally, as information security/cybersecurity evolves due to the rise of new threats, the organisation should periodically review the adequacy of the training programme.

ROLE-BASED COMPETENCE FRAMEWORK

Although under this Regulation there are no provisions for specific roles, besides the optional nomination of a CRP, for organisations characterised by a large number of staff members and hierarchical layers, it may be convenient to identify some roles and the related required competencies. To this end, EASA has developed an adaptation of the European Cybersecurity Skills Framework (ECSF) published by ENISA in September 2022 that can be found in [Appendix VI](#).

AMC1 IS.I.OR.240(h) Personnel requirements

ED Decision 2023/009/R

ACKNOWLEDGEMENT OF RESPONSIBILITIES

Regarding any assigned role and task, the organisation should specify all information security responsibilities an employee has in a clear and transparent manner.

As part of this, all personnel performing the activities required under this Regulation should acknowledge, in a traceable and verifiable manner, understanding of the assigned roles and the associated information security responsibilities.

GM1 IS.I.OR.240(h) Personnel requirements

ED Decision 2023/009/R

ACKNOWLEDGEMENT OF RESPONSIBILITIES

Acknowledgement of receipt such as a valid electronic or wet signature, confirmation email, etc., is a traceable proof of acknowledgement.

AMC1 IS.I.OR.240(i) Personnel requirements

ED Decision 2023/009/R

IDENTITY AND TRUSTWORTHINESS

For the personnel who have access to information systems and data subject to the requirements of Part-IS, the identity should be determined on the basis of documentary evidence.

To establish the trustworthiness of such personnel, the organisation should have a documented process and appropriate criteria to ensure that individuals can be trusted to perform their role.

GM1 IS.I.OR.240(i) Personnel requirements

ED Decision 2023/009/R

IDENTITY AND TRUSTWORTHINESS

(a) Trustworthiness may be established, for example, by:

- (1) prior to employment, a background check carried out in accordance with the applicable rules of Union and national law. This check may include verification of:
 - (i) education, previous employment and any gaps in the previous years;
 - (ii) absence of criminal record;

- (iii) any other relevant information or intelligence considered relevant to the suitability of a person to work in the expected role;
 - (2) during employment, monitoring the employee's commitment and conduct.
- Note: The absence of criminal record may be verified by means of a certificate issued by the responsible authority in the Member State in accordance with Regulation (EU) 2016/1191. In the case of prospective foreign employees, the above checks may be carried out on the basis of equivalent certificates issued by the country of origin, such as a 'certificate of good conduct'.
- (b) Furthermore, the process and criteria to establish personnel's trustworthiness may have to consider whether:
 - (1) the information systems and data to be accessed have been associated with a high severity of the safety consequences with the risk assessment process under [IS.I.OR.205](#);
 - (2) controls or mitigating measures for risk treatment identified during the risk analysis rely on organisational/operational procedures — for instance, correct configuration and administration of information technologies, database operations, information security monitoring, etc.
- In such cases, the personnel who have administrator rights or unsupervised and unlimited access to the systems and data mentioned in (a)(1), or the personnel who applies the measures under above point (b)(2), may be subject to more stringent criteria.
- (c) Intelligence and any other relevant information may be gathered by screening and analysing public sources such as social media and websites, within the limits set by relevant national laws and regulations.
 - (d) Some organisations subject to Part-IS may also be subject to Regulation (EU) 2015/1998 that requires successful completion of background checks for personnel in certain roles, as well as a mechanism for the ongoing review of these checks. In such cases the organisation may consider suitable for the establishment of the personnel's identity and trustworthiness required under Part-IS, in relation to their role, the process and the relevant criteria defined in Regulation (EU) 2015/1998 for standard and enhanced background checks. However, it should be noted that compliance with the provisions for the establishment of identity and trustworthiness under Part-IS does not constitute compliance with the provisions on background checks as defined in Regulation (EU) 2015/1998.

IS.I.OR.245 Record-keeping

Regulation (EU) 2023/203

- (a) The organisation shall keep records of its information security management activities
 - (1) The organisation shall ensure that the following records are archived and traceable:
 - (i) any approval received and any associated information security risk assessment in accordance with point [IS.I.OR.200](#)(e);
 - (ii) contracts for activities referred to in point [IS.I.OR.200](#)(a)(9);
 - (iii) records of the key processes referred to in point [IS.I.OR.200](#)(d);
 - (iv) records of the risks identified in the risk assessment referred to in point [IS.I.OR.205](#) along with the associated risk treatment measures referred to in point [IS.I.OR.210](#);

- (v) records of information security incidents and vulnerabilities reported in accordance with the reporting schemes referred to in points [IS.I.OR.215](#) and [IS.I.OR.230](#);
 - (vi) records of those information security events which may need to be reassessed to reveal undetected information security incidents or vulnerabilities.
 - (2) The records referred to in point (1)(i) shall be retained at least until 5 years after the approval has lost its validity.
 - (3) The records referred to in point (1)(ii) shall be retained at least until 5 years after the contract has been amended or terminated.
 - (4) The records referred to point (1)(iii), (iv) and (v) shall be retained at least for a period of 5 years.
 - (5) The records referred to in point (1)(vi) shall be retained until those information security events have been reassessed in accordance with a periodicity defined in a procedure established by the organisation.
- (b) The organisation shall keep records of qualification and experience of its own staff involved in information security management activities
- (1) The personnel's qualification and experience records shall be retained for as long as the person works for the organisation, and for at least 3 years after the person has left the organisation.
 - (2) Members of the staff shall, upon their request, be given access to their individual records. In addition, upon their request, the organisation shall provide them with a copy of their individual records on leaving the organisation.
- (c) The format of the records shall be specified in the organisation's procedures.
- (d) Records shall be stored in a manner that ensures protection from damage, alteration and theft, with information being identified, when required, according to its security classification level. The organisation shall ensure that the records are stored using means to ensure integrity, authenticity and authorised access.

GM1 IS.I.OR.245 Record-keeping

ED Decision 2023/009/R

Records are required to document results achieved or to provide evidence of activities performed. Records become factual when recorded and cannot be modified. Therefore, they are not subject to version control. Even when a new record is produced covering the same issue, the previous record remains valid.

The 'approval received' referred to in point (a)(1)(i) includes any 'certificate' received by the organisation when it is provided for by the implementing rule for its domain.

AMC1 IS.I.OR.245(a)(1)(vi)&(a)(5) Record-keeping

ED Decision 2023/009/R

When complying with the requirements under points (a)(1)(vi) and (a)(5), the organisation should establish a data retention policy defining procedures to:

- (a) manage relevant security data files;

- (b) establish the periodical assessment of their content; and
- (c) define the criteria to allow deletion of records of information security events when the objective of the requirement under (a)(5) has been met.

GM1 IS.I.OR.245(a)(1)(vi)&(a)(5) Record-keeping

ED Decision 2023/009/R

The objective of the requirement under (a)(1)(vi) is to ensure detection of possible indication of information security incidents or vulnerabilities which are not obvious by normal operation (e.g. previously unknown situations), while the objective of the requirement under (a)(5) is to allow the necessary flexibility to control the volume of the stored information security events.

Records of information security events include those events identified to be within the scope of the detection activities under [IS.I.OR.220\(a\)](#), as well as other information security data produced by assets that have been identified under [IS.I.OR.205](#).

A data retention policy clarifies what information should be stored or archived and for how long. Some guidance about data retention can be found in EUROCAE ED-206, Chapter 2.6.

Once a data set completes its retention period, it can be deleted or moved as permanent historical data to a secondary or tertiary storage.

AMC1 IS.I.OR.245(c)&(d) Record-keeping

ED Decision 2023/009/R

When complying with the requirements under points (c) and (d) for all the records required by points [IS.I.OR.245](#) (a) and (b), the organisation should consider the following:

- (a) Records should be kept in paper form or in electronic format or a combination of both media. The records should remain accessible whenever needed within a reasonable time and usable throughout the required retention period. The retention period starts when the record has been created.
- (b) Records data integrity, availability and authenticity should be protected in consistency with protection of corresponding operational data, and as such, should be within the scope of the ISMS.
- (c) Storage systems should be protected against unauthorised access (i.e. data leakage attempts against personal data/modification of records) and thus should have information security measures implemented in consistency with the level of information security risk associated with them.
- (d) Once records are not required to be retained anymore, the destruction of records and decommissioning of assets used for their storage should be implemented appropriately.

GM1 IS.I.OR.245(c)&(d) Record-keeping

ED Decision 2023/009/R

RECORDS ACCESSIBILITY THROUGHOUT THE RETENTION PERIOD

It is recommended to follow best practices for data retention and, for data that may need to be restored, backup strategies, such as the use of automated backup tools, segregation or geographic separation of backup storage location(s), and to consider offline backups to prevent ransomware risks.

These practices should be considered also when record-keeping is contracted to service providers with distributed resources.

Special attention should be paid to significant hardware and software changes, ensuring that stored digital records remain accessible and readable (e.g. file system, application file format, forward compatible database versions, etc.). Paper-based information needs to be archived in an adequate environment, in which records are protected against degradation factors (e.g. excessive heat, light or humidity).

RECORDS DATA INTEGRITY AND PROTECTION FROM UNAUTHORISED ACCESS

A commonly used method to achieve authenticity and integrity protection is the use of digital signatures at document level. Digital signatures can be added to the document's file (e.g. PDF) to ensure that a record has not been modified by someone other than its author (integrity) and that the author is who is expected to be (authenticity).

Moreover, to prevent unauthorised access, records can be protected, for example, by implementing a role-based access control (RBAC) approach, or certain records can be password protected at the file level. Commercial applications feature built-in basic password protection functions for their file formats. Access protection can also be achieved by protecting the environment where the individual records are stored (e.g. access protection on databases, file shares, directories, etc.).

IS.I.OR.250 Information security management manual (ISMM)

Regulation (EU) 2025/2293

- (a) The organisation shall make available to the competent authority an information security management manual (ISMM) and, where applicable, any referenced associated manuals and procedures, containing:
- (1) a statement signed by the accountable manager confirming that the organisation will at all times work in accordance with this Annex and with the ISMM. If the accountable manager is not the chief executive officer (CEO) of the organisation, then the CEO shall countersign the statement;
 - (2) the title(s), name(s), duties, accountabilities, responsibilities and authorities of the person or persons defined in point [IS.I.OR.240\(b\)](#) and (c);
 - (3) the title, name, duties, accountabilities, responsibilities and authority of the common responsible person defined in point [IS.I.OR.240\(d\)](#), if applicable;
 - (4) the information security policy of the organisation as referred to in point [IS.I.OR.200\(a\)\(1\)](#);
 - (5) a general description of the number and categories of staff and of the system in place to plan the availability of staff as required by point [IS.I.OR.240](#);
 - (6) the title(s), name(s), duties, accountabilities, responsibilities and authorities of the key persons responsible for the implementation of point [IS.I.OR.200](#), including the person or persons responsible for the compliance monitoring function referred to in point [IS.I.OR.200\(a\)\(12\)](#);
 - (7) an organisation chart showing the associated chains of accountability and responsibility for the persons referred to in points (2) and (6);
 - (8) the description of the internal reporting scheme referred to in point [IS.I.OR.215](#);

- (9) the procedures that specify how the organisation ensures compliance with this Part, and in particular:
 - (i) the documentation referred to in point IS.I.OR.200(c);
 - (ii) the procedures that define how the organisation controls any contracted activities as referred to in point IS.I.OR.200(a)(9);
 - (iii) the ISMM amendment procedure referred to in point (c);
 - (10) the details of currently approved alternative means of compliance.
- (b) The initial issue of the ISMM shall be approved and a copy shall be retained by the competent authority. An approval shall not be required for declared organisations. The ISMM shall be amended as necessary to remain an up-to-date description of the ISMS of the organisation. A copy of any amendments to the ISMM shall be provided to the competent authority;
 - (c) Amendments to the ISMM shall be managed in a procedure established by the organisation. Any amendments that are not included within the scope of that procedure and any amendments related to the changes referred to in point [IS.I.OR.255\(b\)](#), shall be approved by the competent authority. An approval shall not be required for declared organisations.
 - (d) The organisation may integrate the ISMM with other management expositions or manuals it holds, provided there is a clear cross reference that indicates which portions of the management exposition or manual correspond to the different requirements contained in this Annex.

GM1 IS.I.OR.250(a) Information security management manual (ISMM)

ED Decision 2023/009/R

The organisation may choose to document some of the information required under point [IS.I.OR.250\(a\)](#) in separate documents (e.g. procedures). In this case, it should ensure that the manual contains adequate references to any document kept separately. Any such documents are then to be considered an integral part of the organisation's information security management system manual.

In the event where an entity holds multiple authorisations or declarations, the ISMM may apply to one or more organisations at a time based on a common ISMS. This ISMM should include at least an approval document of each organisation and should formally be approved by each organisation's accountable manager or responsible person. A common responsible person may be appointed as per [IS.I.OR.240\(d\)](#) and the guidelines of [GM1 IS.I.OR.240\(e\)](#).

To ensure that all parties involved can fulfil their responsibilities, all manuals, procedures, and communication between them are advised to be, at least, in one common language, e.g. English. Those parties involved include the competent authorities with which that common language should be agreed upon.

IS.I.OR.255 Changes to the information security management system

Regulation (EU) 2025/2293

- (a) Changes to the ISMS may be managed and notified to the competent authority in a procedure developed by the organisation. That procedure shall be approved by the competent authority, except for declared organisations.
- (b) With regard to changes to the ISMS not covered by the procedure referred to in point (a), the organisation shall apply for and obtain an approval issued by the competent authority, except for declared organisations, for which an approval is not required.

With regard to those changes:

- (1) the application shall be submitted before any such change takes place, in order to enable the competent authority to determine continued compliance with this Regulation and to amend, if necessary, the organisation certificate and related terms of approval attached to it;
- (2) the organisation shall make available to the competent authority any information it requests to evaluate the change;
- (3) the change shall be implemented only upon receipt of a formal approval by the competent authority, except for declared organisations, which may implement the change immediately;
- (4) the organisation shall operate under the conditions prescribed by the competent authority during the implementation of such changes.

AMC1 IS.I.OR.255 Changes to the information security management system

ED Decision 2023/009/R

Without prejudice to the communication of changes as required for each organisation in the corresponding implementing regulation for the domain as listed in point Article 2(1) of Regulation (EU) 2023/203, the procedure referred to in [IS.I.OR.255\(a\)](#) should take into account the criticality of the changes when proposing how they will be managed. In particular, those changes that could have an impact on the achievement or maintenance of compliance with the provisions under Part-IS, or which could lead to an unacceptable level of risk (e.g. as per the guidance provided in [GM1 IS.I.OR.205\(c\)](#)), should be subjected to scrutiny. Upon establishment of this procedure, any further changes to it should be subject to approval by the competent authority.

Where prior approval is sought from the competent authority for a change not covered by an approved procedure, or where no such approved procedure exists, the organisation should provide at least the following information:

- the nature and purpose of the change;
- the implementation plan of the change;
- the verification plan of the change;
- the potential impact on aviation safety introduced by the change.

A significant deviation from the original implementation plan during the change process is an event that should be reported to the competent authority as this deviation may require reconsidering the change impact.

GM1 IS.I.OR.255 Changes to the information security management system

ED Decision 2023/009/R

Point [IS.I.OR.255](#) is structured as follows:

Point (a) introduces the possibility for the organisation to agree with the competent authority that changes to the ISMS can be implemented without prior approval as long as these changes are covered in a change procedure.

Point (b) introduces an obligation of prior approval (by the competent authority) for changes not covered by the procedure mentioned above, and indicates how those changes should be handled.

The organisation should consider the establishment of a procedure in order to manage and notify changes to the competent authority as provided for under [IS.I.OR.255](#)(a). In case of lack of any approved procedure, the organisation will have, for any change, to apply for and obtain an approval as required under [IS.I.OR.255](#)(b). In any case, all changes should be notified to the competent authority upon implementation.

GM2 IS.I.OR.255 Changes to the information security management system

ED Decision 2023/009/R

RELATION BETWEEN CHANGES TO THE ISMS AND CONTINUOUS IMPROVEMENT

Changes stemming from the continuous improvement process established by the organisation (see [IS.I.OR.260](#)) should be handled as any other change according to the guidelines in [AMC1 IS.I.OR.255](#) and [GM1 IS.I.OR.255](#).

EXAMPLE OF CHANGES THAT MAY HAVE AN IMPACT ON THE ISMS

Below are some examples of changes that may have an impact on the ISMS, or which could lead to an unacceptable level of risk and therefore should be subject to scrutiny by the competent authority according to the provisions established under [IS.I.OR.255](#):

- (a) Changes to the scope of the ISMS, interfaces or related policies:
- The organisation expands its business functions, and integrates another company within its organisational structure.
 - The organisation has identified non-conformities indicating an incorrect scope.
 - The organisation amends its information security policy and/or information security objectives with a potential impact on aviation safety.
 - Changes to the interfaces of the organisation resulting e.g. from modification in the insourced or outsourced activities.

- (b) Changes in responsibilities and accountability as well as in the organisational structure involving the implementation and continuing monitoring of compliance with this Regulation:
 - The accountable manager has delegated certain responsibilities under Part-IS to a person or a group of persons.
 - The organisation contracts information security management activities as per [IS.I.OR.235](#).
- (c) Changes to the methodology used for risk management:
 - The organisation changes the classification for likelihood or impact in their risk management methodology e.g. to obtain more granularity.
 - The organisation implements changes to their risk treatment methodology.
 - The organisation integrates its information security risk management into existing management systems.
- (d) Changes to the security event management process:
 - The organisation decides to contract security event management activities.
 - The organisation changes the process to notify security events and the criteria to escalate to higher management for a quicker resolution.
 - The organisation changes its policy for mitigating vulnerabilities.
 - The organisation changes its incident recovery procedure.

EXAMPLE OF CHANGES THAT DO NOT HAVE AN IMPACT ON THE ISMS

Not all operational changes related to information security have an impact on the ISMS, therefore not all changes are required to be reported to the competent authority, following the provisions established under [IS.I.OR.255](#). The following scenarios may be representative of such changes:

- After a successfully detected security event which could have easily evolved to an incident, the organisation decides to roll out an extensive cyber security awareness campaign for all employees.
- Update in the staff training programme and/or training content as a result of the continuous improvement processes established within the organisation.
- The organisation replaces the software tool that it uses for encrypting sensitive files with another software solution.
- The organisation has decided to make an internal restructuring for business reasons, changing the names of departments or sections, without making any changes in the responsibilities and accountability (e.g. accountable manager) involving the ISMS of the organisation.
- The organisation decides to update an existing preventive control e.g. configuring a new firewall in its internal network.

IS.I.OR.260 Continuous improvement

Regulation (EU) 2023/203

- (a) The organisation shall assess, using adequate performance indicators, the effectiveness and maturity of the ISMS. That assessment shall be carried out on a calendar basis predefined by the organisation or following an information security incident.

- (b) If deficiencies are found following the assessment carried out in accordance with point (a), the organisation shall take the necessary improvement measures to ensure that the ISMS continues to comply with the applicable requirements and maintains the information security risks at an acceptable level. In addition, the organisation shall reassess those elements of the ISMS affected by the adopted measures.

AMC1 IS.I.OR.260 Continuous improvement

ED Decision 2023/009/R

The continuous improvement process (CIP), as required by [IS.I.OR.200\(b\)](#), should aim to continuously improve the effectiveness, suitability and adequacy of the ISMS. This should be achieved by a proactive and systematic assessment of the ISMS and all its elements — including its maturity. The assessment should take into account the outcomes and conclusions of other information security and assurance processes including audits, management reviews, evaluation of performance, effectiveness and maturity, as well as the outcomes of the derived corrective actions and corrections.

The steps to be performed should be at least the following:

- (a) Identification of improvement opportunities based on the outcomes of the assessment of the ISMS with respect to its suitability, effectiveness, adequacy and, if deemed necessary, efficiency, as well as on any other suggestion for improvement. The assessment should consider performance indicators which reflect its processes and elements and the defined objectives for effectiveness and maturity.
- (b) Evaluation of the identified opportunities regarding cost benefit, absence or reduction of undesired effects and achievement of the targeted objectives and intended outcomes.
- (c) Proposal on the evaluated improvement opportunities to the management, and recommendation of actions to support their review and decision-making.
- (d) According to the decision taken under point (c), planning, development and implementation of actions and changes to the ISMS, its processes or elements to achieve the improvements.
- (e) Evaluation the effectiveness of the implemented actions and ISMS changes, and, as applicable, verification that the root cause of identified deficiencies has been eliminated.

The management should assess and review the outcomes of the CIP at planned intervals to ensure the continuing effectiveness, adequacy and suitability of the ISMS, to decide on the prioritisation of the implementation of actions and changes, as well as to revise or set new objectives or targets for continuous improvement.

GM1 IS.I.OR.260 Continuous improvement

ED Decision 2025/014/R

Point [IS.I.OR.260](#) covers assurance processes for the ISMS in a manner that can be considered equivalent to the safety assurance in ICAO Doc 9859 'Safety Management Manual (SMM)', which includes performance monitoring and measurement, management of change and continuous improvement of the SMS.

In this Regulation:

- IS.I.OR.260(a) addresses, using adequate performance indicators, the effectiveness and maturity assessment of the ISMS;

- IS.I.OR.260(b) addresses the improvement measures, i.e. corrections and corrective actions, for the deficiencies detected in IS.I.OR.260(a) and the continuous improvement process.

Similar provisions for continuous improvement are provided for in other information management systems such as ISO/IEC 27001 (see [Appendix IV](#) to this document).

The context and risk environment of organisations are never static and therefore require a dynamic adaptation, evolution and change of the organisation's objectives, architectures, organisational structures and processes to maintain the information security risks at an acceptable level. Consequently, the ISMS should be considered as an evolving and learning part/element of the organisation which needs to be continuously monitored and improved to ensure alignment with the organisation's safety objectives and effectiveness.

The CIP aims to continuously improve the effectiveness, suitability, adequacy and, if deemed necessary, the efficiency of the ISMS. An organisation may integrate the Part-IS CIP in some other already operated CIP and may apply methods such as Plan-Do-Check-Act (PDCA) Cycle or Define-Measure-Analyse-Improve-Control (DMAIC) (see also [GM1 IS.I.OR.200](#)).

The CIP is based on a proactive and systematic assessment of the ISMS and all its elements including the information security processes and controls driven by the ISMS. The assessment should be carried out against organisational targets for desired levels of performance, effectiveness and maturity. These targets, besides ensuring the achievement of compliance with the requirements under this Regulation, may also aim to include objectives established by the organisation's policy or standards and by management decisions.

The above-mentioned assessment is based on the outcome of performance evaluations, audits, risk and incident processes, as well as already applied corrections and corrective actions. Some factors that should be considered when performing the assessment are the following:

- **Adequacy** refers to whether the system establishes the disciplines needed to manage information security, e.g. by using broadly accepted industry standards, in a sufficient manner with regard to compliance with the requirements of this Regulation.
- **Effectiveness of the ISMS** and the effective implementation of processes and controls driven by the ISMS is assessed by analysing whether:
 - the information security risks are managed to achieve the safety objectives;
 - the intended outcomes of the ISMS are achieved, and the requirements or objectives are met;
 - all types of deficiencies are managed including failures to fulfil or correctly implement a requirement or control.
- **Efficiency** of the ISMS refers to the implementation of streamlined processes; however, efficiency improvements should not adversely impact effectiveness.

Identification of improvement opportunities

Improvement opportunities may be identified from the results of the CIP assessment or may be introduced as suggestions from other sources. The identification often involves deviations or corrective actions as well as ineffective processes or controls which are not remediated.

Suggestions for improvements stem from sources including:

- Risk management: the results of regular risk analysis and subsequent risk treatment are a primary factor in improving the ISMS, where the risk treatment process involves monitoring of the implemented security measures and evaluating their effectiveness.
- Performance & effectiveness evaluation: conclusions from (key) performance indicators, their measurement, analysis and continued monitoring as well as the result of the assessment of the effectiveness including the outcomes of the subsequently applied corrections and corrective actions
- Evaluation of maturity including the results of the subsequent corrections and corrective actions
- Lessons learned from the security incident detection, handling and response process and from a potential treatment of a root cause
- Results of (internal) audits may be used to verify whether the ISMS and controls within the audit scope meet the organisation's requirements, and to determine where there are potential areas for improvement.
- Review and evaluation by management of the current action plan, setting or revision of the objectives or decision on improvement opportunities and actions
- Organisation's suggestion programme (suggestions for improvement), reviews, surveys or assessments with employees or feedback from suppliers or interfacing parties

Any outcome of this process should be documented. The resulting actions may be integrated into an overarching action plan which is centrally consolidated and periodically reviewed according to the relevant policies. The resulting action plan may be further divided into a tactical, short-/mid-term action plan and a strategic, long-term action plan.

AMC1 IS.I.OR.260(a) Continuous improvement

ED Decision 2023/009/R

(a) ISMS EFFECTIVENESS EVALUATION

When complying with [IS.I.OR.260\(a\)](#), the organisation should have a process in place to monitor, measure, evaluate and review the effectiveness of its ISMS that defines:

- (1) who monitors, measures, analyses and evaluates the results and takes accountable decisions;
- (2) when the above steps should be performed;
- (3) which methods for monitoring, measurement, analysis and evaluation are applied to ensure comparable and reproducible results.

The calendar basis of the assessments should be commensurate with the maximum level of risk established under [IS.I.OR.205](#).

The process to monitor, measure, evaluate and review the effectiveness of the organisation's ISMS referred to under AMC1 IS.I.OR.260(a) should include as a minimum:

- (1) the gathering and retention of metrics of the activities, and additional information that could be useful for monitoring purposes;
- (2) the analysis of the metrics in order to identify trends and deviations from predefined performance targets.

(b) ISMS MATURITY ASSESSMENT

The organisation should assess the maturity of its ISMS using a suitable maturity model in order to identify areas for improvement to the ISMS. To do so, the organisation should:

- (1) define or adopt a maturity model which represents a set of important and relevant processes and capabilities that are expected to be implemented and maintained;
 - (2) for each assessed process or capability, ensure that the model defines criteria against which specific aspects, characteristics and effectiveness should be assessed and evaluated when determining a maturity level;
 - (3) define for each assessed process or capability its desired target maturity level.
- (c) For each assessed information security process or capability contained in the maturity model, the organisation should:
- (1) evaluate and justify the current maturity level;
 - (2) identify any area for improvement it should make to reach the targeted maturity level;
 - (3) collect and record the evidence regarding strengths and weaknesses of the implemented ISMS and its evaluated maturity.

GM1 IS.I.OR.260(a) Continuous improvement

ED Decision 2023/009/R

- (a) As general guidance, the elements of the ISMS that should be monitored, measured and evaluated should be, as a minimum:
- (1) the risk assessment and treatment process (including risks at the interfaces with other organisations);
 - (2) the management of non-conformities and corrective actions;
 - (3) the incident and vulnerability management;
 - (4) the personnel competence management.
- (b) Existing maturity models for ISMS maturity evaluation

As general guidance, for the definition or the adoption of a maturity model (MM), the following existing models may be considered:

- Cybersecurity Capability Maturity Model (C2M2), version 1.1: this model was published by the US Department of Energy in 2014. It introduces the notion of Maturity Indicator Levels (MIL) ranging from 0 to 3 and addresses not only performance levels but also performance practices (under Approach Objectives and approach progression) as well as assurance practices (under Management Objectives and institutionalization progression).
- Systems Security Engineering – Capability Maturity Model (SSE-CMM): published by ISO as ISO 21827 in 2008. It focuses on engineering practices, much less on operational practices that are split in 11 ‘Security Base Practices’, and 11 ‘Project and Organizational Base Practices’. It introduces the notion of five Capability Levels, from ‘Performed Informally’ to ‘Continuously Improving’.
- NIST Cybersecurity Framework (NIST CSF), version 1.1: published by NIST in April 2018. Although it is not proposed as a MM, the framework defines four ‘Implementation Tiers’, from ‘Partial’ to ‘Adaptive’, which are a qualitative measure of organisational

cybersecurity risk management practices. It focuses on the functionality and repeatability of cybersecurity risk management.

- ATM Cybersecurity Maturity Model, edition 1: published in February 2019 by the EUROCONTROL NM for organisations in the ATM domain. Whilst not being designed for wider application, it can be adapted as necessary. It defines five maturity levels, ranging from ‘Non-existent’ to ‘Adaptive’ inspired by the ‘Tier’ terminology from the NIST CSF. In fact, the model is founded on NIST CSF, together with some elements of ISO/IEC 27001.

The following Table 1 maps the MM mentioned above to a hypothetical five-level MM.

Table 1: Mapping matrix of an existing MM to a hypothetical five-level MM

Mapping to a five-level MM	C2M2	Eurocontrol NM	ISO 21827	NIST CSF 1.1
Initial	MIL 0	Non-Existent	Performed Informally	
Defined	MIL 1 (Initial)	Partial	Planned & Tracked	Partial
Implemented	MIL 2 (Identified)	Defined	Well defined	Risk-Informed
Managed	MIL 3 (Managed)	Assured	Quantitatively Controlled	Repeatable
Improved		Adaptive	Continuously Improving	Adaptive

No specific maturity level is required. However, if and when compliance is achieved, organisations will determine which requirements of which models have already been met (mandatory) and can opt to reach a level that is beneficial to the organisation (voluntary). In the longer term, achieving higher maturity levels may increase the confidence of oversight authorities, which can have an impact upon the level of oversight activities regarding such organisation.

AMC1 IS.I.OR.260(b) Continuous improvement

ED Decision 2023/009/R

When a deficiency is identified, the organisation should react in a timely manner following a defined process leading to a managed status regarding the deficiency, its associated consequences and, if needed, the prevention of its future recurrence or occurrence elsewhere.

Based on an evaluation of the impact and extent of the deficiency and the potential consequences for the ISMS, the process should include as criteria for compliance:

- (a) deciding on corrections and their implementation without undue delay in order to limit the impact of the deficiency and deal with its consequences as well as, as applicable, to control or eliminate it;
- (b) deciding on the need for, and the implementation of, corrective actions to eliminate the cause(s) of, and contributing factors to, the deficiency based on a root cause analysis and an evaluation of actions remediating the cause aimed at being proportionate to the consequences and impact of the deficiency;

- (c) verifying the implemented actions:
 - (1) to be effective and to result in acceptable residual risks,
 - (2) not to have unintended side effects leading to other deficiencies, new risks, or an ISMS not aligned with the applicable requirements, as well as
 - (3) for corrective actions, to effectively remediate or eliminate the root cause;
- (d) reporting to and reviewing the identified deficiencies, action plan and results of the action taken with the accountable manager of the organisation or delegated person(s) and, as necessary, with other involved or affected roles and parties;
- (e) documenting as evidence the detected deficiencies, the planned and implemented corrections and/or corrective actions with deadlines and responsible persons, the management feedback, the outcomes of the process step under point (c) above and, if necessary, the change decisions made for the ISMS itself.

GM1 IS.I.OR.260(b) Continuous improvement

ED Decision 2023/009/R

The ‘necessary improvement measures’ referred to in [IS.I.OR.260\(b\)](#) refer to correction or corrective actions to eliminate deficiencies or actions aimed at improving the effectiveness as well as the maturity of the ISMS.

A process satisfying the criteria defined in [AMC1 IS.I.OR.260](#) should include the following aspects:

- (a) identifying the extent, impact, context and triggers of the deficiency, evaluating it according to some established criteria, analysing potential consequences for the ISMS including a potential existence in other areas;
- (b) deciding on corrections and their implementation to immediately limit the impact and manage the consequences of the deficiency as well as, as applicable, to control or eliminate it;
- (c) deciding on corrective actions required to eliminate the (root) cause(s) of the deficiency that are proportionate to the consequences;
- (d) reassessing the elements of the ISMS which may be affected by the implemented actions to ensure that no further risk is introduced;
- (e) verifying the implemented actions referred to in point (c) of [AMC1 IS.I.OR.260\(b\)](#);
- (f) reporting to and reviewing the outcomes of the process steps with the management (see point (d) of [AMC1 IS.I.OR.260\(b\)](#));
- (g) documenting and evidencing the result of the process steps above (see point (e) of [AMC1 IS.I.OR.260\(b\)](#)).

Appendix I — Examples of threat scenarios with a potential harmful impact on safety

ED Decision 2023/009/R

The following is a non-exhaustive list of examples of information security threat scenarios with a potential harmful impact on safety that may be considered by authorities and organisations.

Example 1: Aircraft to ATC digital communications

- **Threat vector assets/domain**
 - ATC voice and ground automation systems
 - ground communications providers
 - air-ground/ground-air RF communications service providers
 - aircraft and the assets used for voice and datalink communications
- **Non-exhaustive summary of potential threats**
 - threat (availability): exceeding system performance, saturation of communication channel
 - threat (integrity): man-in-the-middle or injection attacks
 - threat (confidentiality): passive listening to communication, spying on hardware device
- **Summary of threats scenarios and their potential harmful impacts on safety**
 - Disruption of services prevents ATC communication with a single or multiple aircraft and/or ATC ground system.
 - Manipulation of data through a man-in-the-middle attack would present false information to the pilot and/or ATC system with the potential of creating a safety hazard or injection of data to the aircraft or ground systems to disrupt the service and capability.
 - There are no specific regulatory requirements for encryption of data or voice for datalink communications; however, for confidentiality purposes, the assets used to provide and deliver the services should be controlled and limited to only those resources that require access to ensure that the services cannot be disrupted and manipulated in any way.

Example 2: Tampered air traffic data

- **Threat vector assets/domain**
 - Internet service provider (ISP)
 - ATM services network(s)
 - surveillance data
 - ATC systems
- **Non-exhaustive summary of potential threats**
 - ISP compromise (confidentiality): An attacker gains unauthorised access to the systems or infrastructure of the ISP providing network services to ATM system.
 - data tampering (integrity): Once the ISP is compromised, an attacker could manipulate data in transit. This could involve injecting false data or removing/modifying legitimate data.
 - denial of service (availability): an attacker could also potentially disrupt the communication of data entirely, resulting in a denial of service (DoS) to the ATM system.

- malware injection (integrity/availability): An attacker could potentially use the compromised ISP as a launching pad to inject malware into the systems, causing further disruptions or enabling additional attacks.
- **Summary of threats scenarios and their potential harmful impacts on safety**
 - ISP compromise: interception and/or manipulation of sensitive data, impacting the safe management of air traffic.
 - data tampering: incorrect situational awareness, potentially resulting in reduced separation between aircrafts, and incorrect air traffic control decisions.
 - denial of service: reduction of the ATC's ability to ensure separation leading to the activation of contingency procedures, including capacity reduction, with the eventual possibility of large areas of airspace being closed.

Example 3: Aircraft operators', CAMOs' and aircraft maintenance organisations' software supply chain and ground infrastructure, including equipment used to support aircraft management, operations and maintenance

- **Threat vector assets/domain**
 - aircraft operators', CAMOs' and maintenance organisations' supply chain
 - aircraft operator or maintenance internal ground infrastructure used to manage aircraft and operations (hardware/software) and other information technology assets
 - information technology assets used to update systems on an aircraft (software and hardware) used for maintenance activities
- **Non-exhaustive summary of potential threats**
 - threat (availability): hardware/software/system disruption
 - threat (integrity): compromised hardware/software/system
 - threat (confidentiality): compromised hardware/software/system
- **Summary of threats scenarios and their potential harmful impacts on safety**
 - Disruption to the dissemination of meteorological information while the aircraft is airborne, may reduce the ability of the flight crew to avoid potentially hazardous meteorological conditions (e.g. severe storms/fog at night).
 - Manipulation of navigation data/database will have the effect that flight plans and navigation displays cannot be trusted.
 - Lack of control and access to information such as fleet maintenance programme or flight crew planning affects the ability of organisations to maintain safe operations.

Application of bow-tie analysis to this example

Two coordinated bow-tie analyses of different risk dimensions are combined, as the ultimate interest lies only in the aviation safety consequence.

Information security bow-tie analysis element	Aviation safety bow-tie analysis element
Information security threats 1) hardware/software vulnerability exploitation: disturbed system function 2) hardware/software vulnerability exploitation: system integrity compromised 3) hardware/software vulnerability exploitation: confidentiality of information processed by system(s) compromised	
Information security preventive barriers	
Information security hazards & top events 1) disturbed system functionality (hazard) → disrupted/unreliable system functionality 2) system integrity compromised (hazard) → system function unpredictable 3) information disclosable (hazard) → undetectable information exfiltration	Safety threats 1) disrupted/unreliable system functionality 2) system function unpredictable 3) undetectable information exfiltration
Information security mitigating barriers	Safety preventive barriers 1) Use of access controls for system administration 2) etc.
Information security consequences 1) loss of system function (= production system down) 2) loss of system function integrity (= some system function wrong/inoperative) 3) loss of confidentiality of information (= some information can leak)	Safety hazards & top events: 1) loss of system function (hazard) → <i>in operational maintenance system</i> 2) loss of system function integrity (hazard) → <i>systems operate with wrong information</i> 3) loss of information confidentiality (hazard) → <i>confidential maintenance and aircraft internals information leaks</i>
	Safety mitigating barriers 1) use of back-up procedures to prevent faulty maintenance actions 2) use of procedures to secure aircraft software integrity
	Safety consequences 1) faulty maintenance actions 2) incorrectly completed maintenance actions 3) exfiltration of information allows for identification of vulnerabilities 4) disruption of aircraft systems, unpredictable system function, loss of major aircraft systems (such as engine control)

Example 4: Design and production organisations' software, supply chain, design and manufacturing ground infrastructure

- **Threat vector assets/domain**
 - design and production organisations' supply chain for parts, hardware and software
 - design and production organisations' ground internal infrastructure used to manage software/hardware used in the manufacturing and development of products that will be used by aircraft manufacturers, operators or ATM/ANS ground automation systems (hardware/software) information technology assets
 - design and production organisations' information technology assets used by their customers to update systems on an aircraft (software/hardware) used for maintenance operations or ATM/ANS ground automation systems
- **Non-exhaustive summary of potential threats**
 - threat (availability): systems used to store, transmit and exchange information are rendered unavailable for essential operations through DoS attacks
 - threat (integrity): systems used to store, transmit and exchange information are compromised through man-in-the middle attacks
 - threat (confidentiality): systems used to store, transmit and exchange information are accessed by insider or external threats
- **Summary of threats scenarios and their potential harmful impacts on safety**
 - Disruption of systems used to store, transmit and exchange information in a manner that would prevent the proper management of the aircraft and its systems and adversely affect the operations of the aircraft
 - Systems used to store, transmit and exchange information can no longer be considered trusted. If they are not maintained at a level to ensure that all information exchange, data and software can be considered trusted, both ground and aircraft operations are disrupted.
 - Uncontrolled access to systems used to store, transmit and exchange information (including information that is received and exchanged with the supply chain) can provide technical details that could be used to craft more sophisticated attacks targeting safety-critical systems.

Example 5: Training system

- **Threat vector assets/domain**
 - supply chain of all software and hardware that will be used in the training systems or training devices (including flight simulators) used to train pilot or ATM/ANS ground systems personnel
 - internal infrastructure used in of all software and hardware that will be used in the design, manufacturing or production of products (hardware or software) that will be used in aircraft or ATM/ANS ground systems

- management of internal operating domains and system of all software and hardware that will be used in the design, manufacturing or production of products (hardware or software) that will be used in aircraft or ATM/ANS ground systems
- **Non-exhaustive summary of potential threats**
 - threat (availability): training systems or training devices are rendered unavailable by means of DoS attacks when they are needed to be used
 - threat (integrity): training systems or training devices are compromised through man-in-the middle attacks
 - threat (confidentiality): functional models, information and data that are embedded in training systems or training devices are accessed by insider or external threats
- **Summary of threats scenarios and their potential harmful impacts on safety**
 - Disruption of training systems (hardware and software) will have an impact on the organisations' ability to maintain qualified staff. It would also prevent the aircraft and its systems from being properly operated and affect maintenance operations for ATM/ANS ground systems.
 - The training model or the failure modes and associated emergency conditions differ from the real aviation system behaviour and therefore induce inappropriate responses. If the training systems cannot be trusted, this will affect the ability of organisations to maintain sufficiently qualified staff for their operations (pilots, maintenance or ATM/ANS ground personnel who have been exposed to improper training should be re-qualified).
 - Lack of control and access to training systems affects the ability of organisations to maintain a training system that is known to be in a trusted state. In addition, uncontrolled access to training systems that embed functional models, information and data can provide technical details that could be used to craft more sophisticated attacks on the training system itself or on the real-world safety-critical system.

Example 6: Airport's fuel delivery system and associated infrastructure

- **Threat vector assets/domain**
 - ground fuel storage and distribution infrastructure
 - digital systems used to control fuel pumping and metering
 - supply chain for fuel delivery, including third-party fuel suppliers
 - airport information technology assets used for fuel inventory management and scheduling deliveries
- **Non-exhaustive summary of potential threats**
 - threat (availability): disruption of fuel supply or delivery systems
 - threat (integrity): tampering with fuel control systems or measurement devices
 - threat (confidentiality): unauthorised access to fuel supply and delivery data
- **Summary of threats scenarios and their potential harmful impacts on safety**
 - Disruption to fuel delivery can lead to flight delays or cancellations, causing operational disruptions and potential safety issues if fuel reserves become critically low.

- Tampering with fuel control systems or measurement devices could lead to incorrect fuel loads being delivered to aircraft, impacting aircraft weight and balance calculations, and potentially causing fuel exhaustion incidents.
- Unauthorised access to fuel supply data could allow threat actors to manipulate fuel scheduling or inventory data, potentially causing disruptions to airport operations and fuel availability for aircraft.

Example 7: National competent authority's NOTAM system and associated infrastructure

- **Threat vector assets/domain**
 - National NOTAM system infrastructure and digital interface
 - Supply chain for NOTAM system maintenance and updates
 - National competent authority's IT assets used for NOTAM creation, distribution, and storage
- **Non-exhaustive summary of potential threats**
 - threat (availability): disruption of the NOTAM system or its access
 - threat (integrity): tampering with NOTAM data or unauthorised NOTAM creation
 - threat (confidentiality): unauthorised access to NOTAM data
- **Summary of threats scenarios and their potential harmful impacts on safety**
 - Disruption to the NOTAM system could prevent the dissemination of critical aeronautical information to pilots and air traffic controllers, potentially leading to safety issues.
 - Tampering with NOTAM data or unauthorised creation of NOTAMs could lead to incorrect information being disseminated, potentially resulting in pilots making decisions based on false or misleading data.
 - Unauthorised access to NOTAM data could lead to information leakage, potentially revealing sensitive operational information.

Example 8: Aviation authority's airworthiness directive (AD) system and associated infrastructure

- **Threat vector assets/domain**
 - EASA AD system infrastructure and digital interface
 - supply chain for AD system maintenance and updates
 - EASA IT assets used for AD creation, distribution, and storage
- **Non-exhaustive summary of potential threats**
 - threat (availability): Disruption of the AD system or its access
 - threat (integrity): tampering with AD data or unauthorised AD creation
 - threat (confidentiality): unauthorised access to AD data

— Summary of threats and their potential harmful impacts on safety

- Disruption to the AD system could prevent the dissemination of critical airworthiness information to aircraft operators and maintenance organisations, potentially leading to safety issues.
- Tampering with AD data or unauthorised creation of ADs could lead to incorrect information being disseminated, potentially resulting in aircraft operators and maintenance organisations making decisions based on false or misleading data.
- Unauthorised access to AD data could lead to information leakage, potentially revealing sensitive operational information.

Appendix II — Main tasks stemming from the implementation of Part-IS mapped to the EU e-CF and NIST CSF 2.0

ED Decision 2025/014/R

Part-IS main task	Activity type	Reference		
		Part-IS	EU e-CF	NIST CSF 2.0
			Competence areas & skills	Functions & categories
Establish and operate an information security management system (ISMS)	Management	IS.I.OR.200(a)	ISM (E.08)	GV - Govern
Establish the scope of the ISMS in accordance with Part-IS requirements	Management	IS.I.OR.205(a)	ISM (E.08)	GV.RM – Risk Management Strategy; ID.AM – Asset Management;
Implement and maintain an information security policy	Management	IS.I.OR.200(a)(1)	ISM (E.08)	GV.PO – Policy
Identify and review information security risks	Management	IS.I.OR.200(a)(2) IS.I.OR.205	ISM (E.08), Risk Management (E.02)	GV.SC – Cybersecurity Supply Chain Risk Management; ID.RA – Risk Assessment; ID.IM – Improvement
Implement information security risk treatment measures	Management	IS.I.OR.200(a)(3) IS.I.OR.210	ISM (E.08), Risk Management (E.02)	ID.RA – Risk Assessment
Set up measures to detect information security events, identify those that may develop to incidents with a potential impact on aviation safety, and respond to, and recover from, such incidents	Management	IS.I.OR.200(a)(5) IS.I.OR.220	Incident Management (C.04)	DE – Detect; RE – Respond; RC – Recover; PR – Protect (as per Risk Assessment)

Part-IS main task	Activity type	Reference		
	Management, Operational	Part-IS	EU e-CF	NIST CSF 2.0
			Competence areas & skills	Functions categories &
Implement measures that have been notified by the competent authority	Operational	IS.I.OR.200(a)(6)		
Take appropriate remedial actions to address findings notified by the competent authority (non-compliances)	Both	IS.I.OR.200(a)(7) IS.I.OR.225		
Implement an external information security reporting scheme	Management	IS.I.OR.200(a)(8) IS.I.OR.230	Incident Management (C.04)	RS.CO – Incident Response Reporting and Communication; RC.CO – Incident Recovery Communication
Monitor compliance with this Regulation and report findings to top management	Operational	IS.I.OR.200(a)(12)	Compliance (E.09)	GV.RR – Roles, Responsibilities and Authorities; GV.RM – Risk Management; GV.OV – Oversight
Protect confidentiality of exchanged information	Operational	IS.I.OR.200(a)(13)	Information Security Management (E.08)	PR.DS – Data Security; Other PR – Protect categories as applicable
Implement and maintain a continuous improvement process to measure the effectiveness and maturity of the ISMS and strive to improve it	Management	IS.I.OR.200(b) IS.I.OR.260	Information Security Management (E.08)	GV.OV – Oversight; ID.IM – Improvement
Document and maintain all key processes, procedures, roles and responsibilities	Management	IS.I.OR.200(c)	ISM (E.08), Compliance (E.09)	GV.RR – Roles, Responsibilities and Authorities; Other functions and categories as applicable
Identify all elements which could be exposed to information security risks	Management	IS.I.OR.205(a)	Risk Management (E.02)	ID.AM – Asset Management
Identify the interfaces with other organisations which could result in exposure to information security risks	Management	IS.I.OR.205(b)	Risk Management (E.02), Business Change	ID.AM – Asset Management; GV.SC – Cybersecurity

Part-IS main task	Activity type	Reference		
	Management, Operational	Part-IS	EU e-CF	NIST CSF 2.0
			Competence areas & skills	Functions & categories
			Management (E.07)	Supply Chain Risk Management
Identify information security risks and assign a risk level	Management	IS.I.OR.205(c)	Risk Management (E.02)	GV.RM – Risk Management Strategy; ID.RA – Risk Assessment
Review and update the risk assessment based on certain criteria	Operational	IS.I.OR.205(d)	Risk Management (E.02)	GV.RM – Risk Management Strategy; GV.PO – Policy; GV.OV – Oversight; GV.SC – Cybersecurity Supply Chain Risk Management; ID.IM – Improvement
Develop and implement measures to address risks and verify their effectiveness	Operational	IS.I.OR.210(a)	Risk Management (E.02)	GV.RM – Risk Management Strategy; ID.RA – Risk Assessment
Communicate the outcome of the risk assessment to management, other personnel and other organisations sharing an interface	Operational	IS.I.OR.210(b)	Risk Management (E.02), ISM (E.08)	GV.RM – Risk Management Strategy; GV.SC – Cybersecurity Supply Chain Risk Management
Establish an internal information security reporting scheme to enable the collection and evaluation of information security events from personnel	Management	IS.I.OR.200(a)(4) IS.I.OR.215 (a) IS.I.OR.215(e)	Incident Management (C.04)	ID.RA – Risk Assessment; DE.AE – Adverse Event Analysis; RS.CO – Incident Response Reporting and Communication; RC.CO – Incident

Part-IS main task	Activity type	Reference		
	Management, Operational	Part-IS	EU e-CF	NIST CSF 2.0
			Competence areas & skills	Functions categories &
				Recovery Communications
Ensure that contracted organisations report information security events	Management	IS.I.OR.215(c)	Supplier Relationship Management (E.10)	GV.SC – Cybersecurity Supply Chain Risk Management; DE.CM – Continuous Monitoring
Analyse internally reported occurrences to identify information security events, incidents, and vulnerabilities	Operational	IS.I.OR.215(b)(1)- (b)(3)	Incident Management (C.04)	DE.AE – Adverse Event Analysis
Implement measures to detect in processes and operations information security events which may have a potential impact on aviation safety	Operational	IS.I.OR.220(a)	ISM (E.08)	DE.CM – Continuous Monitoring; DE.AE – Adverse Event Analysis; ID.RA – Risk Assessment; PR – Protect (selection of relevant controls as per Risk Assessment)
Implement measures to respond to information security events that may cause an information security incident	Operational	IS.I.OR.220(b)	Incident Management (C.04)	RS.MA – Incident Management; RS.AN – Incident Analysis; RS.MI – Incident Mitigation; RS.CO – Incident Response Reporting and Communication (where applicable); PR – Protect (selection of relevant controls as per Risk Assessment)

Part-IS main task	Activity type	Reference		
	Management, Operational	Part-IS	EU e-CF	NIST CSF 2.0
			Competence areas & skills	Functions categories &
Cooperate on investigations with other organisations that contribute to the information security of its own activities	Management	IS.I.OR.215(d)	Incident Management (C.04), Legal Advice and Compliance (E.09)	DE.CM – Continuous Monitoring; RS.CO – Incident Response Reporting and Communication; RC.CO – Incident Recovery Communication
Implement measures to recover from information security incidents	Operational	IS.I.OR.220(c)	Incident Management (C.04)	RC.RP – Incident Recovery Plan Execution; RC.CO – Incident Recovery Communication; PR – Protect (selection of relevant controls as per Risk Assessment)
Manage risks associated with contracted activities with regard to the management of information security	Management	IS.I.OR.235	Supplier Relationship Management (E.10)	GV.SC – Cybersecurity Supply Chain Risk Management
Create and maintain a process to ensure that there is sufficient personnel to perform all activities regarding information security management	Management	IS.I.OR.240(f)	Personnel Development (D.11)	GV.RR – Roles, Responsibilities, and Authorities
Create and maintain a process to ensure that the personnel have the necessary competence for activities regarding information security management	Management	IS.I.OR.240(g)	Personnel Development (D.11)	GV.RR – Roles, Responsibilities, and Authorities; PR.AT – Awareness and Training (02)
Create and maintain a process to ensure that the personnel acknowledge the responsibilities associated with the assigned roles and tasks	Management	IS.I.OR.240(h)	Personnel Development (D.11)	GV.RR – Roles, Responsibilities, and Authorities

Part-IS main task	Activity type	Reference		
	Management, Operational	Part-IS	EU e-CF	NIST CSF 2.0
			Competence areas & skills	Functions categories & categories
Verify the identity and trustworthiness of personnel who have access to information systems	Management	IS.I.OR.240(i)	ISM (E.08)	GV.RR – Roles, Responsibilities, and Authorities; GV.PO – Policy; PR.AA – entity Management, Authentication, and Access Control
Archive, protect and retain records and ensure they are traceable for a specified time	Operational	IS.I.OR.245	ISM (E.08), Compliance (E.09)	GV.OV – Oversight; GV.RR – Roles, Responsibilities, and Authorities; PR.DS – Data Security; PR.PS – Platform Security; RS.AN – Incident Analysis; GV.SC – Cybersecurity Supply Chain Risk Management; ID.RA – Risk Assessment
Correct non-compliance findings upon notification by the competent authority within the period agreed with the competent authority	Operational	IS.I.OR.225		
Implement an information security reporting system in accordance with Regulation (EU) No 376/2014	Management	IS.I.OR.230(a)		
Report information security incidents or vulnerabilities to the competent authority and, under certain conditions, to others	Operational	IS.I.OR.230(b) IS.I.OR.230(c)	Incident Management (C.04)	GV.OC – Organisational Context; RS.CO – Incident Response Reporting and Communication; RC.CO – Incident Recovery Communications

Part-IS main task	Activity type	Reference		
	Management, Operational	Part-IS	EU e-CF	NIST CSF 2.0
			Competence areas & skills	Functions categories &
Regularly assess the effectiveness and maturity of the ISMS	Operational	IS.I.OR.260(a)	ISM (E.08)	GV.OV – Oversight; ID.IM – Improvement
Take actions to improve the ISMS if required. Reassess the ISMS elements affected by the implemented measures.	Operational	IS.I.OR.260(b)	ISM (E.08)	GV.OV – Oversight; ID.IM – Improvement
Ensure accessibility of the competent authority to the contracted organisation	Management	IS.I.OR.235(b)	ISM (E.08)	GV.OC – Organisational Context
Top management ensures that all necessary resources are available to comply with the Regulation	Management	IS.I.OR.240(a)(1)	ISM (E.08)	GV.RR – Roles, Responsibilities, and Authorities
Top management establishes and promotes the information security policy and demonstrates a basic understanding of the Regulation	Management	IS.I.OR.240(a)(2) IS.I.OR.240(a)(3)	ISM (E.08)	GV.PO – Policy; GV.PO RR – Roles, Responsibilities, and Authorities
Appoint a responsible person or a group of persons with appropriate knowledge to manage compliance with the Regulation	Management	IS.I.OR.240(b) IS.I.OR.240(c) IS.I.OR.240(d)	ISM (E.08), Compliance (E.09)	GV.PO RR – Roles, Responsibilities, and Authorities
Create and maintain an information security management manual (ISMM)	Management	IS.I.OR.250		
Develop a procedure on how to notify the competent authority upon changes to the ISMS	Management	IS.I.OR.255 (a)	Compliance (E.09)	GV.OC – Organizational Context; ID.RA – Risk Assessment; ID.IM – Improvement
Manage changes to the ISMS and notify the competent authority and/or request for approval of changes	Management	IS.I.OR.255(a) IS.I.OR.255(b)	ISM (E.08), Process Improvements (E.05)	GV.OC – Organizational Context; ID.RA – Risk Assessment; ID.IM – Improvement

Appendix III — Examples of aviation services and interfaces

ED Decision 2025/014/R

AVIATION SERVICES

The following is a non-exhaustive and non-complete list of aviation services that can be used as a basis to identify the scope of the risk assessment for the organisation.

- aerodrome & ATM-MET service providers
- aeronautical digital mapping services
- aeronautical information management (AIM) – external, national, regional
- airports
- air traffic control (ATC) – external, superior
- air traffic management (ATM)
- approach (APP) & area control (ACC) Services – ER ACC, APP ACC
- cargo and passenger loading
- civil & state airspace user (AU) operations centres
- communication infrastructure
- flight information services / traffic information services (FIS/TIS) data integrator
- fuel calculation
- navigation infrastructure – ground-based, satellite-based
- non-ATM meteorological (MET) service providers
- mass & balance calculation
- non-aviation users (external)
- regional & sub-regional airspace management (ASM) and air traffic flow & capacity management (ATFCM)
- static aeronautical data services
- sub-regional demand & capacity balancing (DCB) common service providers
- surveillance infrastructure – airport, en-route, terminal manoeuvring area (TMA)
- route planning
- time reference services (external)
- tower (TWR) services

INTERFACES

Below are some examples of data exchange at the interfaces between organisations interacting in different functional chains, which can be used as a basis for identifying the scope of the risk assessment for the organisation.

Note 1: These examples are graphical representations based on the ‘**Examples of ecosystem data exchange**’ provided in **EUROCAE ED-201A, Appendix B - Tables B-14**, which can be consulted for further information.

Note 2: Although it is not an organisation, an aircraft has been included in all these examples for the sake of completeness of the description of the data exchange. The aircraft should be considered as an element within the scope of the ISMS of the organisation to which it belongs (typically the airline). Any data exchange between aircraft and other systems within the organisation should take into account existing security measures that may have been evaluated as part of aircraft certification (see also [GM1 IS.I.OR.205\(c\)](#)).

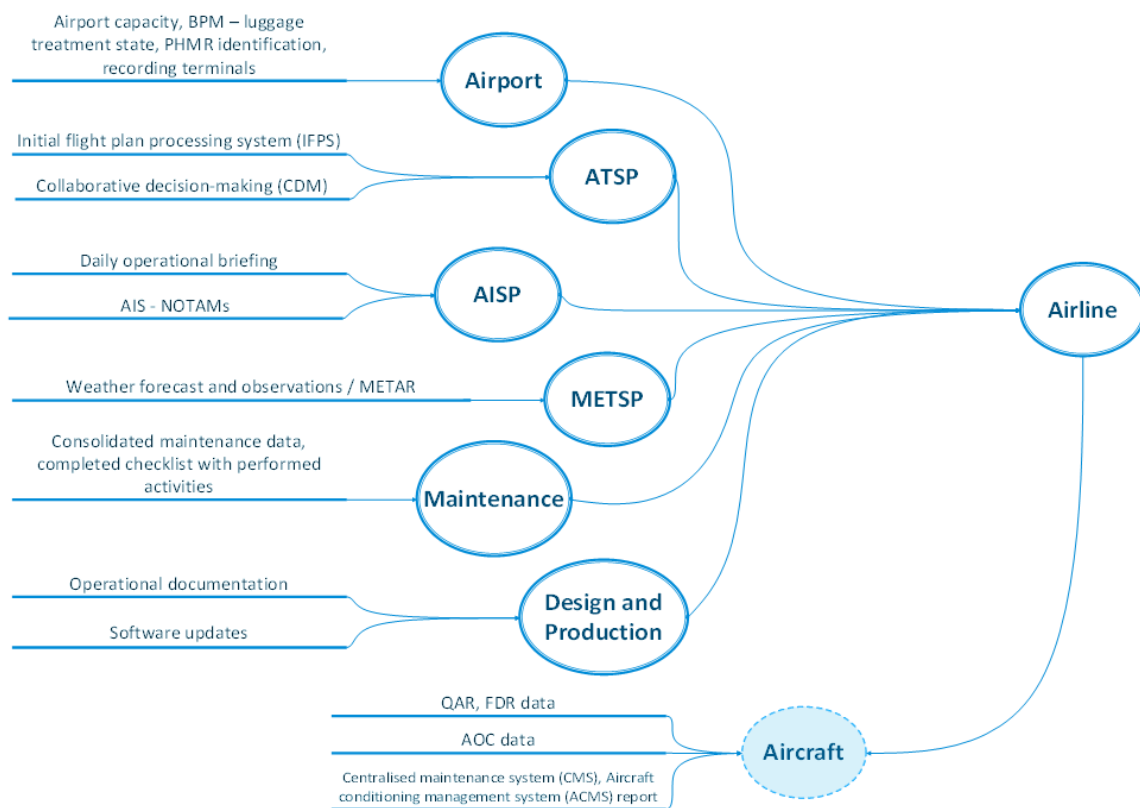


Figure 1: Interfaces of other organisations with an airline operator

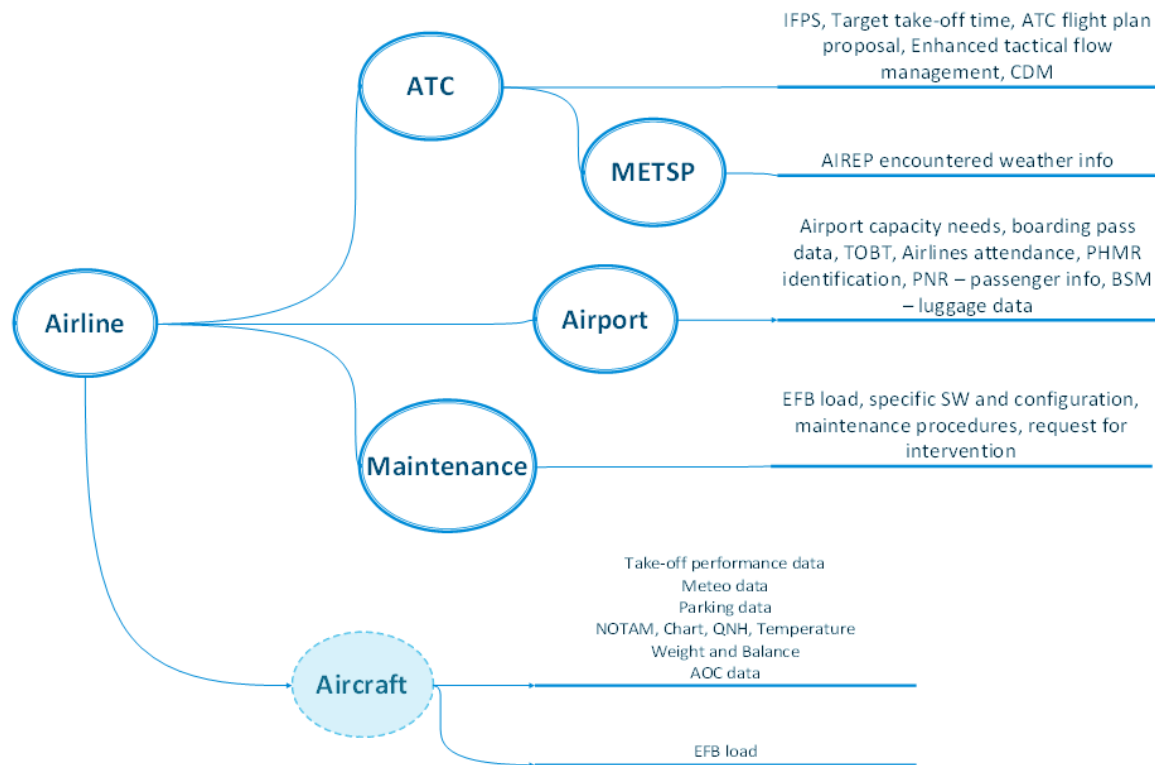


Figure 2: Interfaces of an airline operator with other organisations

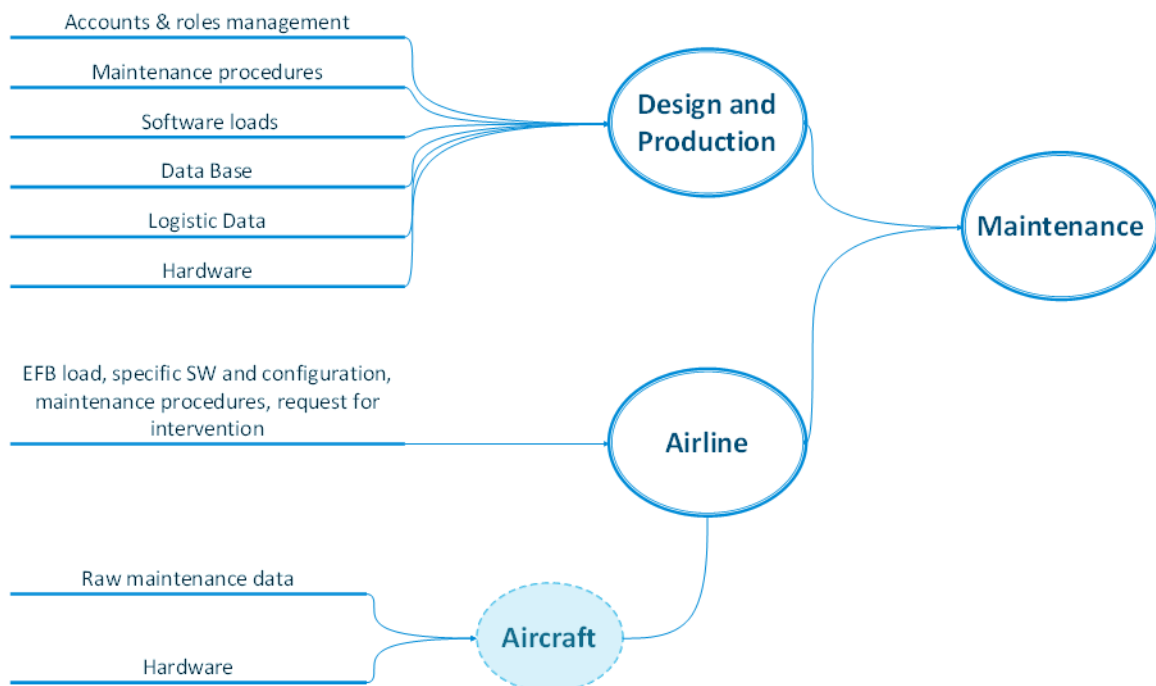


Figure 3: Interfaces of other organisations with a maintenance service provider

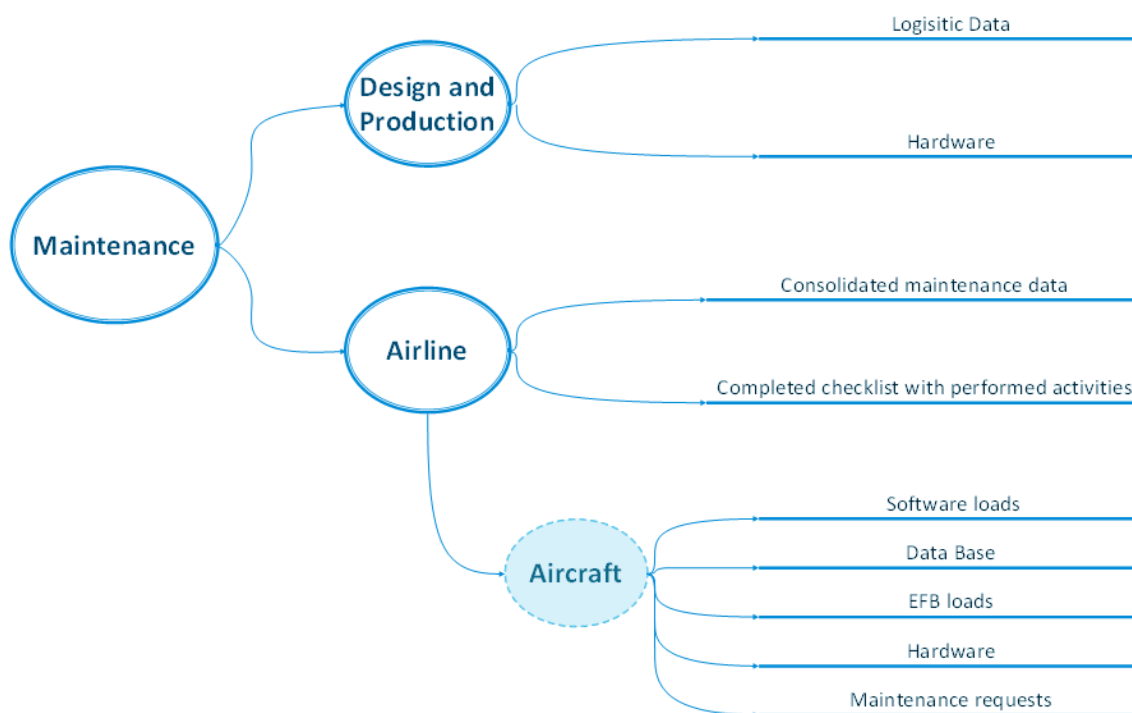


Figure 4: Interfaces of a maintenance service provider with other organisations

Appendix IV — Part-IS requirements mapping to ISO/IEC 27001:2022 clauses and controls, and considerations on differences

ED Decision 2025/014/R

Although Part-IS does not credit ISO/IEC 27001 certification, the practices and methods typically adopted for implementing and maintaining an ISMS under ISO/IEC 27000 largely align with the objectives of this regulation. Therefore, entities that have already implemented an ISMS under ISO/IEC 27001:2022 can use this as a basis for Part-IS compliance.

The following provides guidance on how organisations that have already implemented an ISMS compliant with ISO/IEC 27001:2022 can integrate Part-IS requirements into their existing ISMS. Specifically, the table below illustrates how to incorporate the ‘Part-IS particularity’ of each requirement into an existing ISO/IEC 27001-based ISMS in order to achieve Part-IS compliance. This is referred to as ‘Guidance on Part-IS implementation’.

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
IS.I.OR.200(a)	Related ISO/IEC 27001:2022 clauses and controls
	4. Context of the organisation
	6.1.1 Actions to address risks and opportunities - General
	Part-IS particularity

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	An ISMS designed in the context of an ISO/IEC 27001:2022 ISMS, which is currently not connected to the management systems required by the delegated and implementing acts of Regulation (EU) 2018/1139, including Part-IS, may differ if these different systems do not address the same goals. Part-IS focuses on information security requirements meeting the applicable aviation safety objectives, which have an influence on elements of the ISMS. Also, the ‘interested parties’ and the ‘internal and external issues’ as laid down in Chapter 4 of ISO/IEC 27001:2022 may be adapted to address the requirements of Part-IS for the organisation. Guidance on Part-IS implementation <i>Please note that the point IS.I.OR.200 requirement points to many other Part-IS requirements that the ISMS has to comply with, namely points 205, 210, 215, 220, 225, 230, 235, 240, 245, 255, and 260. Further details are provided in the specific chapters on the particular requirement.</i> Regarding the other remaining requirements, not pointing out to other Part-IS requirements, and comparing them with ISO/IEC 27001:2022, there are four requirements left, namely points IS.I.OR.200(a)(1), IS.I.OR.200(a)(6), IS.I.OR.200(a)(12) and IS.I.OR.200(a)(13).
IS.I.OR.200(a)(1)	Related ISO/IEC 27001:2022 clauses and controls 5.2 Policy A.5.1 Policies for information securities Part-IS particularity An ISMS designed in the context of an ISO/IEC 27001:2022 ISMS, which is currently not connected to the management systems required by the delegated and implementing acts of Regulation (EU) 2018/1139, may differ as these different systems do often not address the same goals. Part-IS focuses on information security requirements influencing the applicable aviation safety objectives, which in their turn have an influence on the elements of the ISMS. In addition, all domain-specific delegated and implementing acts of Regulation (EU) 2018/1139, namely points ORO.GEN.200(a)(2), ORA.GEN.200(a)(2), CAMO.A.200(a)(2), 145.A.200(a)(2), 21.A.139(c)(1), 21.A.239(c)(1), ATM/ANS.OR.B.005(a)(2), ATCO.OC.C.001(b) and ADR.OR.D.005(b)(2), require a ‘safety policy’, where information security may be integrated. Guidance on Part-IS implementation The policy on information security established in an ISO/IEC 27001:2022 context has to be updated with regard to the potential impact of the risks on aviation safety. At least the elements of AMC1 IS.I.OR.200(a)(1) have to be mentioned in the policy. Therefore, the following elements may need to be added to an existing ISMS policy. The elements in bold and <i>italics</i> are additional guidance that might also be considered. (a) committing to complying with applicable legislation, considering relevant standards and best practices, <i>including safety- and cybersecurity-related standards and guidance published or prescribed by ICAO, EASA or the relevant civil aviation authority;</i>

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	(b) setting objectives and performance measures for managing information security, updated to ensure meeting the applicable aviation safety objectives; (c) defining general principles, activities, processes for the organisation to appropriately secure information and communication technology systems and data, in relation to the information security / safety risk assessment required by point IS.I.OR.205; (d) committing to applying ISMS requirements into the processes of the organisation; (e) committing to continually improving towards higher levels of information security process maturity as per point IS.I.OR.260; (f) committing to satisfying applicable requirements regarding information security (including requirements stemming from civil aviation authorities) and its proactive and systematic management and to the provision of appropriate resources for its implementation and operation; (g) assigning information security as one of the essential responsibilities for all managers; (h) committing to promoting the information security policy through training or awareness sessions within the organisation to all personnel on a regular basis or upon modifications; (i) encouraging the implementation of a ‘just culture’ and the reporting of vulnerabilities, suspicious/anomalous events and/or information security incidents; (j) committing to communicating the information security policy to all relevant parties, as appropriate.
IS.I.OR.200(a)(6)	Related ISO/IEC 27001:2022 clauses and controls 10.1 Corrective actions A5.5 Contact with authorities A5.26 Response to information security incidents A8.8 Management of technical vulnerabilities Part-IS particularity This requirement has no specific counterpart in ISO/IEC 27001:2022. Guidance on Part-IS implementation The policies and procedures, defined as means of compliance with the requirements listed above, should be extended to information security measures mandated by the competent authority.
IS.I.OR.200(a)(12)	Related ISO/IEC 27001:2022 clauses and controls 9.2. Internal audit 9.3 Management review

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	10.2 Non-conformity and corrective action A5.36 Compliance with policies, rules and standards for information security
	Part-IS particularity
	This requirement is strongly related to the internal audit system and the independent checking function of ISO/IEC 27001:2022. The required feedback system to the accountable manager or the head of the design organisation fits into the requirement of 9.3. In addition, all delegated and implementing acts for the specific domains require a similar ‘compliance monitoring function’, where information security should be integrated as described in AMC1 IS.I.OR.200(a)(12).
	Guidance on Part-IS implementation
	The requirements of ISO/IEC 27001:2022 and the delegated and implementing acts of Regulation (EU) 2018/1139 are compatible. Therefore, it will be easy to integrate Part-IS into the audit scope of the ISO/IEC 27001:2022 internal audit system. The role of the accountable manager or the head of the design organisation as defined under point IS.I.OR.240(a) has to be addressed accordingly in the feedback loop if the role is not already addressed in the management review process. The accountable manager or the head of the design organisation is required to be personally briefed on the key findings so that appropriate decisions can be made. Refer also to GM1 IS.I.OR.200(a)(12). Note: <i>ISO 19011:2018 provides guidance on the establishment of an internal audit system. Specifically, Chapter A.7 ‘Auditing compliance within a management system’ provides useful guidance on how to integrate a compliance monitoring function into an internal audit system.</i>
IS.I.OR.200(a)(13)	Related ISO/IEC 27001:2022 clauses and controls
	7.5.3. Control of documented information (Note) A5.12 Classification of information A5.34 Privacy and protection of personal identifiable information (PII) A8.12 Data leakage prevention
	Part-IS particularity
	This requirement is limited to ‘information from other organisations’ and to confidentiality. ISO/IEC 27001:2022 does not differentiate between ‘internal’ or ‘external’ information (as laid down e.g. in ISO 9001:2015 Chapter 8.5.3). The only reference is made in the note in Chapter 7.5.3. Part-IS stresses protection of external information received due to the sensitivity it may have regarding incidents and vulnerabilities disclosure. Insufficient confidentiality protection may result in exploitation of vulnerabilities affecting safety that the original provider of information may not have perceived.
	Guidance on Part-IS implementation

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	The protection of information, specifically regarding confidentiality (as in ISO/IEC 27002:2022), is related to a set of controls that can be found in Table A.1 (Matrix of controls and attribute values) of ISO/IEC 27002:2022. See also the definition in ISO/IEC 27002:2022: <i>3.1.7 Confidential information</i> <i>Information that is not intended to be made available or disclosed to unauthorized individuals, entities or processes.</i> The organisation having implemented these controls should take special care that they apply to information received from external information that may result in information security threats if known by unauthorised actors. When this kind of information is further shared with other organisations or authorities, appropriate confidentiality procedures must be put in place and followed (TLP marking, for instance).
IS.I.OR.200(b)	Related ISO/IEC 27001:2022 clauses and controls
	10.1 Continual improvement
	Part-IS particularity
	Part-IS and ISO/IEC 27001:2022 are very similar regarding this requirement. See points IS.I.OR.260 (a) and (b) for subtle differences.
	Guidance on Part-IS implementation
	See point IS.I.OR.260 in this table.
IS.I.OR.200(c)	Related ISO/IEC 27001:2022 clauses and controls
	6.3 Planning of changes
	7.5.3 Control of documented information
	Part-IS particularity
	Control of documented information is one of the key processes in each ISO management system standard, following the ISO 'high-level structure' (ISO/IEC Directives part 1 Annex SL), such as ISO/IEC 27001 :2022. For changes, see point IS.I.OR.255. In addition, most of the delegated and implementing acts for the specific domains require a similar need to document, where information security should be integrated.
	Guidance on Part-IS implementation
	See points IS.I.OR.250 and IS.I.OR.255 in this table.
IS.I.OR.200(d)	Related ISO/IEC 27001:2022 clauses and controls
	4.3 Determining the scope of the information security management system
	Part-IS particularity

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	The scope statement and the ‘statement of applicability’ (SOA) are the best references to apply the ‘nature and complexity’. In addition, most of the delegated and implementing acts for the specific domains require a similar need to document, where information security should be integrated. Guidance on Part-IS implementation When determining the scope, it should be noted that Part-IS is delimited to the subject matter as defined in Article 1 of the Regulation(s), which refers to <i>identification and management of information security risks with potential impact on aviation safety</i>. Considering this, the scope of an ISMS under ISO/IEC 27001:2022 may be broader than that required by Part-IS. Some organisational units, processes or locations may fall under what is covered by the ISMS under ISO/IEC 27001:2022, but not within the scope of Part-IS. The opposite may happen too: the scope under ISO/IEC 27001:2022 may be narrower than the one Part-IS would require (e. g. the ISO/IEC 27001:2022 scope covers only the IT department). In both situations, scope definitions must be compared and adjusted when necessary. <i>Note: See also guidance on point IS.I.OR.205(a) in this table.</i> The scope statement in the ISO/IEC 27001:2022 context is the right place where this clarification is made.
IS.I.OR.200(e)	Related ISO/IEC 27001:2022 clauses and controls 4.1 Understanding the organisation and its context. Part-IS particularity This is a ‘derogation’ for organisations falling under the applicability of Article 2 of this Regulation. This process is independent from an ISO/IEC 27001:2022 certification process. Guidance on Part-IS implementation If an organisation which already has an established ISMS according to ISO/IEC 27001:2022 decides to embark on this process, the full implementation of Part-IS into the ISMS may be put on hold until the decision of the competent authority is made. To demonstrate that an organisation’s activities, facilities and resources, as well as the services it operates, provides, receives and maintains, do not pose any information security risks with a potential impact on aviation safety either to itself or to other organisations, the existing risk assessment methodology according to ISO/IEC 27001:2022 Chapter 6.1.2 may be used if the methodology is enhanced with a focus on the impact on safety. On the other hand, an existing risk assessment methodology used by the existing safety management system (SMS) could be enhanced by addressing potential information security risks.

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	In any case, the competent authority responsible for the organisation will determine which process and methodology shall be used. This demonstration has to be at least verified and reassessed at regular intervals and as a mandatory part of the organisation's change process. In case of any doubt about the conclusion, the appropriate civil aviation authority must be contacted.
IS.I.OR.205(a)	Related ISO/IEC 27001:2022 clauses and controls 4.3 Determining the scope of the information security management system 6.1.2 Information security risk assessment Part-IS particularity This requirement of Part-IS is in line with ISO/IEC 27001:2022, however ISO/IEC 27001:2022 allows a wider focus, whereas Part-IS puts the focus on safety already from the element's identification stage. In addition, all of the delegated and implementing acts for the specific domains require a risk assessment process, where information security can be integrated. Guidance on Part-IS implementation AMC1 IS.I.OR.205(a) explains that when conducting an information security risk assessment, the organisation should ensure that each relevant aviation safety impact is identified and included in the ISMS scope, which might not be the case when using ISO/IEC 27001:2022. On the other hand, an ISO/IEC 27001:2022 ISMS focuses its security risk assessment mainly on the business impact of infringement on confidentiality, integrity and availability, their risks and the impact on assets (e. g. loss of IT infrastructure, breach of data). This means that, starting from an ISMS based on ISO/IEC 27001:2022, a complementary analysis has to be made to take into account all the elements related to aviation safety. To bridge the two approaches of management systems (SMS and ISMS), an identified information security risk may be entered as a 'cause' or 'contributing event' in the aviation-safety-focused risk assessment required by the domain-specific implementing or delegated act. The figure in GM1.IS.I.OR.205(c) provides a good indication of how this bridge could be built.
IS.I.OR.205(b)	Related ISO/IEC 27001:2022 clauses and controls 4.1 Understanding the organisation and its context 4.3 Determining the scope of the information security management system A5.19 Information security in supplier relationships A5.21 Managing information security in the information and communication technology (ICT) supply chain Part-IS particularity Point IS.I.OR.205(b) focuses on the identification of interfaces with the other organisations. ISO/IEC 27001:2022 4.3 requires considering in point c) the interfaces at and dependencies between activities performed by the organisation and those

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	that are performed by other organisations. So, there is more in Part-IS than that required by ISO/IEC 27001:2022, provided that the scope considered includes safety, as required by point IS.I.OR.205(a). Controls A5.19 and A5.21 are a profound foundation for the requirements of point IS.I.OR.205(b). Guidance on Part-IS implementation ISO/IEC 27001:2022 A5.19 requires the identification of risks associated with the use of suppliers' products or services. ISO 27002 A5.19 contains additional guidance in points f) to j) on how to manage the risk exposure. ISO/IEC 27001:2022 A5.21 requires the management of information security risks associated with the ICT products and services supply chain. ISO 27002 A5.21 contains additional guidance in points f), k), l) and m) on how to manage risks through the supply chain. The Part-IS notion about interfaces and supply chain goes beyond the respective ISO/IEC 27001:2022 notion. GM1 IS.I.OR.205(b) requests interfacing organisations to share information about mutual risk exposure (including all data flows) and urges organisations to use ED-201A for that. Point IS.I.OR.205(c) also requires accounting for information acquired by interfacing organisations, which underlines the two-way nature of the considerations. Particular attention should be paid to the Part-IS intent to protect the so-called functional chains. The notion is that while organisations may protect themselves well enough, interfaces between organisations may pose risks to each chain when not accounted for.
IS.I.OR.205(c)	Related ISO/IEC 27001:2022 clauses and controls 6.1.2 Information security risk assessment Part-IS particularity Point IS.I.OR.205(c) is the 'heart' of Part-IS. ISO/IEC 27001:2022 6.1.2 opens a 'framework' where the requirements of point IS.I.OR.205 may fit in. It has to be assured that the risk management systems of the ISMS and those required by the SMS regulations (see point IS.I.OR.205(a)) do NOT operate independently, as there might be difficulties in connecting the two systems. Guidance on Part-IS implementation Further to this provision, a proper risk assessment has to be made, taking into account the scope and interfaces described in points IS.I.OR.205(a) and IS.I.OR.205(b). It has to be noted (see also GM1 IS.I.OR.205(c)) that point IS.I.OR.205 does not require the use of any specific information security risk assessment framework, such as ISO 31000, NIST or others, to develop the risk assessment. ISO/IEC 27001:2022 tends to lean towards using ISO 27005 as a risk assessment standard; however, it does not make it mandatory. The key point is that the risk assessment carried out in the application of ISO/IEC 27001:2022 6.1.2 does not necessarily consider safety risks, and may focus on different types of risks. With respect to safety, conditions that may lead to safety consequences are identified as hazards. Their materialisation may be either directly triggered or caused by information security threats which have not been successfully prevented.

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	Information security can thus cause or contribute to a safety consequence in four different ways: (1) it can act as a safety threat; (2) it can have a negative effect on a safety barrier, rendering it less effective than before; (3) it can directly trigger the materialisation of an already identified hazard; or (4) it can constitute a new, not yet identified, hazard, which can obviously also materialise. By using e.g. the ‘bow-tie method’ regarding information security, a ‘hazard’ would be replaced by a ‘vulnerability’, which can be exploited, resulting in information security consequences (e.g. lack or reduction of confidentiality, integrity, availability, authenticity properties). Hence, from a methodology perspective, both considerations are very similar and can be designed to interact (e. g. consequences of the information security bow-tie may connect as causes of the ‘safety bow-tie’). <u>Guidance on organisations that are NOT required to operate an SMS, including safety risk management</u> Any ISO/IEC 27001:2022 risk assessment has to be reviewed and revised by introducing safety impact (consequence) considerations. Any risk matrix stemming from an ISO/IEC 27001:2022 6.1.2 risk assessment is acceptable, provided that it includes safety impacts (consequences), and the results remain within the limitations of ICAO Annex 19. If two different risk assessment schemes are used, they need to be linked accordingly. <u>Guidance on organisations that are required to operate an SMS, including safety risk management</u> In most of the cases, where an organisation is subject to the domain-specific implementing or delegated acts for SMS and operates an ISMS under voluntary compliance with ISO/IEC 27001:2022, it may operate two risk management systems, one for safety under the oversight of a competent authority, and one for information security. The latter may ultimately be certified by an ISO/IEC 27001:2022 accredited body. Each potential risk identified by the ISMS risk management has to be systematically assessed for its potential impact on safety. To establish the connection between the systems, the following approach should be used: (1) If a safety risk assessment is available, it should be able to provide its context and determined target likelihoods for acceptable information security risks to the information security risk assessment process. The context consists of the system architecture, including its preventative and mitigative barriers, the hazards assessed and the safety risks identified. Based upon the information provided, the information security risk assessment can be conducted. Modifications to the system architecture, or any modifications of properties of the preventative or mitigative barriers, as well as the achieved risk properties need to be communicated back to the safety risk assessment process. Based upon this communication, the safety risk assessment has to be updated. In other words: mitigation measures put in place as a result of

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	the information security risk assessment should also be considered as they may not only mitigate, but possibly also create a negative safety impact. (2) If a safety risk assessment is available, but the information security assessment process identifies a new hazard that was previously unknown to the safety risk assessment, a full hazard assessment of all safety aspects have to be conducted to ensure that the safety risk assessment contains the ‘full picture’ of the newly addressed hazard. (3) The safety risk and the information security risk assessments need to be repeated as described above until all acceptability requirements for all aspects are met.
IS.I.OR.205(d)	Related ISO/IEC 27001:2022 clauses and controls
	6.3 Planning of changes
	8.2 Information security risk assessment
	Part-IS particularity
	Point IS.I.OR.205(d) is about the subsequent changes to the original risk assessment, due to a change of context or interfaces or knowledge about the risks or lessons learnt. This is equivalent to ISO/IEC 27001:2022 8.2. In both frameworks the reviews are planned and documented.
	Guidance on Part-IS implementation The same process as that already in place in an ISO/IEC 27001:2022 context can be used to implement point IS.I.OR.205(d), provided that this process has been updated to include safety criteria evaluation of changes that trigger an unplanned update of the risk assessment. Those organisations that have most experienced risk assessment updates at planned intervals will need to be proactive to trigger such updates more often in the situations listed in points IS.I.OR.205(d) (1), (2), (3), and (4) that could affect safety. The triggering criteria and the process should be documented and tested before implementation, for example through table-top exercises. The change management process is key to keep a management system in a solid and stable condition. Considering an established ISMS according to ISO/IEC 27001:2022, the regular updates of the risk assessment based on changes and lessons learned should be effective. The essential focus, introduced by Part-IS, is the ‘impact on safety’, which drives the update assessment. Change management processes focusing on changes that may have impact on safety are also set out in all domain-specific implementing and delegated acts. Without the ‘bridge’ of Part-IS, both systems (ISMS and SMS) are implemented independently, often without considering interdependencies. Part-IS implies the need (and provides the opportunity) to interlink the systems to provide a common risk picture for the organisation, with a focus on safety, but also opening the horizon to information security.
IS.I.OR.205(e)	Related ISO/IEC 27001:2022 clauses and controls
	6.1.2 Information security risk assessment

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	Part-IS particularity
	This Part-IS requirement is specific to organisations required to comply with Subpart C of Annex III (Part-ATM/ANS.OR) to Regulation (EU) 2017/373 .
	Guidance on Part-IS implementation
	Those organisations falling under Subpart C of Annex III (Part-ATM/ANS.OR) to Regulation (EU) 2017/373, which operate an ISO/IEC 27001:2022-conformed management system, use the safety support assessment instead of the information security risk assessment required in point IS.I.OR.205(c).
IS.I.OR.210(a)	Related ISO/IEC 27001:2022 clauses and controls
	6.1.3 Information security risk treatment
	8.3 Information security risk treatment
	Part-IS particularity
	Point IS.I.OR.210(a) is about information security risk treatment, which is widely covered by ISO/IEC 27001:2022, its Appendix A, and ISO/IEC 27002. Point IS.I.OR.210(a) provides however some additional inputs related to the risks that may have a safety impact.
	Guidance on Part-IS implementation
	ISO/IEC 27001:2022 6.1.3 is about the definition of the risk treatment plan, while ISO/IEC 27001:2022 8.3 deals with the implementation of the plan, and both are relevant.
	ISO/IEC 27001:2022 Annex A contains a list of possible information security controls, and therefore should also be used in addition to the already existing controls, to mitigate information security risks having an impact of safety. All the controls of Annex A are detailed in ISO/IEC 27002.
	Point IS.I.OR.210(a) specifies that the measures selected in the plan have to reduce the consequences on aviation safety associated with the materialisation of the threat scenario. This is in line with point IS.I.OR.205 since the risk treatment phase is a consequence of the risk assessment phase and has to address all the risks that have been evaluated.
	Point IS.I.OR.210(a) also stipulates that those (protection) measures shall not introduce any new potential unacceptable risks to aviation safety.
IS.I.OR.210(b)	This is an area that is not directly covered by either ISO/IEC 27001:2022 or ISO/IEC 27002. The requirement addresses the so-called ‘side effects’ when introducing measures into a system (a well-known issue in software development which is also very relevant for information security measures). Preventive or mitigative measures specifically (e.g. physical security, access control) could lead to unintended side effects.
	Also, the risk treatment of the identified risks should focus on addressing safety via the same linkage/integration of ISMS and safety management.
	Related ISO/IEC 27001:2022 clauses and controls

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	6.1.3.f Information security risk treatment
	7.3 Awareness
	9.3 Management review
	A5.19 Information security in supplier relationships
	A5.21 Managing information security in the ICT supply chain
	Part-IS particularity
	Point IS.I.OR.210(b) requires key personnel in the organisation to be informed about the risks, the corresponding threat scenarios and the security risk treatment measures, which result in specific controls covered by Annex A to ISO/IEC 27001:2022 and ISO/IEC 27002. It partially covers point IS.I.OR.210(b) by the following requirement: obtain risk owners' approval of the information security risk treatment plan and acceptance of the residual information security risks.
	Point IS.I.OR.210(b) has two specific requirements that also have equivalent requirements in ISO/IEC 27001:2022 and ISO/IEC 27002:
	— Inform the accountable manager or the head of the design organisation of the risk treatment plan — which is a mandatory input to the management review.
	— Inform the interfacing entities (the same as in point IS.I.OR.205(b)) of all risks shared with them — which is stated in A5.19 Guidance point I).
	Guidance on Part-IS implementation
	In addition to the risk owner's approval requested by ISO/IEC 27001:2022 6.1.3.f, the organisation will need to inform:
	— the accountable manager or the head of the design organisation of the risk treatment plan. ISO/IEC 27001:2022 9.3. f) defines 'results of risk assessment and status of risk treatment plan' as mandatory input for the management review which is the vehicle to inform the accountable managers/heads of the design organisation;
	— the interfacing entities (the same as in point IS.I.OR.205(b)) of all risks shared with them. ISO/IEC 27002 A5.21 states in point f) 'defining rules for sharing of information and any potential issues and compromises between the organisations'. GM1 IS.I.OR.205(b) and ED-201A may also be used as guidance on risk sharing.
IS.I.OR.215(a)	Related ISO/IEC 27001:2022 clauses and controls
	A5.24 Information security incident management planning and preparation
	A6.8 Information security event reporting
	Part-IS particularity
	Fully covered by the requirements of A5.24 and A6.8. However, the linkage to the external reporting scheme for the incidents with relation to safety (unsafe conditions) has to be established.
	Guidance on Part-IS implementation

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	The linkage to the external reporting scheme for the incidents with relation to safety could be described under A5.5 (contact with authorities) in the ISO structure.
IS.I.OR.215(b)	Related ISO/IEC 27001:2022 clauses and controls A5.25 Assessment and decision on information security events A5.26 Response to information security incidents A5.27 Learning from information security incidents A5.28 Collection of evidence A8.8 Management of technical vulnerabilities Part-IS particularity Fully covered by the requirements from A5.25 to A5.28 and A8.8 with a need to focus on safety impacts. Guidance on Part-IS implementation The requirements of controls A8.8, A5.25 to A5.28 and the guidance in ISO/IEC 27002:2022 are comprehensive to fulfil the requirements of point IS.I.OR.215(b). In accordance with point IS.I.OR.215(b)(1), the impact on safety always needs to be assessed specifically. AMC1 IS.I.OR.215(a)&(b) has to be also considered.
IS.I.OR.215(c)	A5.19 Information security in supplier relationships A5.20 Addressing information security within supplier agreements A5.21 Managing information security in the information and communication technology (ICT) supply chain Part-IS particularity To be covered under the procedures according to A5.19 and A5.21, as well as under the agreements according to A5.20. Guidance on Part-IS implementation However, this depends on whether the supplier is also subject to Part-IS or not. In the latter case, the external reporting shall be done by the contracting organisation. GM1 IS.I.OR.215(c) provides guidance on the relationship with contracted organisations.
IS.I.OR.215(d)	Related ISO/IEC 27001:2022 clauses and controls A5.6 Contact with special interest groups A5.20 Addressing information security within supplier agreements A5.21 Managing information security in the information and communication technology (ICT) supply chain A5.28 Collection of evidence

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	Part-IS particularity
	The requirements of controls A5.20, A5.21 and A5.28 and the guidance in ISO/IEC 27002:2022 are comprehensive to fulfil the requirements of point IS.I.OR.215(d) in terms of process, but Part-IS will require cooperation with a broader range of organisations.
	Guidance on Part-IS implementation
	As ISO/IEC 27001:2022 only focuses on the supply chain and Part-IS requires a broader focus, the process needs to be highlighted to other relevant stakeholders. This may be covered under A5.6. Nevertheless, ISO/IEC 27002 A5.19 has a clear statement under point (i) of the guidance. See also the cooperation in accordance with point IS.I.OR.205(c).
IS.I.OR.215(d)	Related ISO/IEC 27001:2022 clauses and controls
	A5.24 Information security incident management planning and preparation
	A6.8 Information security event reporting
	Part-IS particularity
	Fully covered by the requirements of A5.24 and A6.8.
	Guidance on Part-IS implementation
<u>IS.I.OR.220(a)</u>	However, the linkage to the external reporting scheme for the incidents with relation to safety (unsafe conditions) shall be established. This could be described under A5.5 (contact with authorities) in the ISO structure.
	Related ISO/IEC 27001:2022 clauses and controls
	A5.24 Information security incident management planning and preparation
	A5.25 Assessment and decision on information security events
	A5.26 Response to information security incidents
	A5.27 Learning from information security incidents
	A5.28 Collection of evidence
	A5.29 Information security during disruption
	A7.5 Physical security monitoring
	A8.16 Monitoring activities
	Part-IS particularity
	Fully covered by the requirements of A5.24 to A5.29, and A7.5 for physical security and A8.16 for technical monitoring.
	Guidance on Part-IS implementation
	The requirements of the controls (both reactive and proactive) mentioned above and the guidance in ISO/IEC 27002:2022 are comprehensive to fulfil the requirements of point IS.I.OR.220(a).

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	Again, the impact on safety needs to be assessed, and measures shall be taken to ensure safety. Part-IS refers to ‘unsafe conditions’, which have to be mitigated to an acceptable level. A re-assessment of risks that are related to incidents that have occurred or to a vulnerability that has been identified is mandatory in Part-IS to ensure that no risk becomes unacceptable. <i>Note: Due to historical reasons, information security and safety management use different wording when referring to situations which are more or less the same. The term ‘incident’ is used in a similar way (an event which already happened and infringes safety/security). A vulnerability in the sense of information security could be mapped to the term ‘hazard’ in the area of safety (a situation identified, which is possible to happen, but has not happened so far).</i>
IS.I.OR.220(b)	Related ISO/IEC 27001:2022 clauses and controls
	A5.26 Response to information security incidents
	A5.29 Information security during disruption
	A7.5 Physical security monitoring
	A8.8 Management of technical vulnerabilities
	Part-IS particularity
	Fully covered by the requirements of A5.26 and A5.29.
IS.I.OR.220(c)	Guidance on Part-IS implementation
	The requirements of control A5.26 and the guidance in ISO/IEC 27002:2022 are comprehensive to fulfil the requirements of point IS.I.OR.220(b).
	Related ISO/IEC 27001:2022 clauses and controls
	A5.26 Response to information security incidents
	A5.29 Information security during disruption
	Part-IS particularity
	This requirement is covered by the requirements of A5.26 and A5.29, with the difference that the recovery here is not intended to continuously ensure confidentiality, integrity, availability and integrity; instead, it is intended to maintain or return to an acceptable level of safety. In addition, some domain-specific implementing and delegated acts of Regulation (EU) 2018/1139 (e.g. points ARO.GEN.200, ATM/ANS.OR.A.070, ADR.OR.B.070) require emergency response planning and/or contingency planning, where information security should be integrated.
IS.I.OR.225	Guidance on Part-IS implementation
	Coupled with the requirements of controls A5.26 and A5.28 and the guidance in ISO/IEC 27002:2022, AMC1 IS.I.OR.220(c) should be applied in order to revert as quickly as possible to a safe state.
IS.I.OR.225	Related ISO/IEC 27001:2022 clauses and controls

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	10.2 Non-conformity and corrective action
	Part-IS particularity
	This requirement has no specific counterpart in ISO/IEC 27001:2022.
	Guidance on Part-IS implementation
	This issue is not covered by the requirements of ISO/IEC 27001:2022, so it is not possible to adapt existing policies and procedures under ISO/IEC 27001:2022 for this requirement. To ensure compliance with this requirement, please refer exclusively to the related AMC and GM.
IS.I.OR.230	Related ISO/IEC 27001:2022 clauses and controls
	A5.5 Contact with authorities
	Part-IS particularity
	This requirement is not directly addressed in ISO/IEC 27001:2022.
	Guidance on Part-IS implementation
IS.I.OR.235(a)	Related ISO/IEC 27001:2022 clauses and controls
	A5.19 Information security in supplier relationships
	A5.21 Managing information security in the information and communication technology (ICT) supply chain
	A5.22 Monitoring, review and change management of supplier services
	Part-IS particularity
	ISO/IEC 27001:2022 controls A5.19, A5.21 and A5.29 may cover this requirement. The difference in the requirements of point IS.I.OR.235 is that they are limited to those activities directly related to the ISMS (e. g. internal audits, consultancy for risk assessments, etc.).
	In addition, all domain-specific implementing or delegated acts require procedures to deal with contracted activities in a wider scope, where information security should be integrated.
	Guidance on Part-IS implementation
	This requirement relates only to ISMS activities (e.g. internal audits, risk assessments), not to those activities not directly related to ISMS itself (e. g. hardware, software, IT and OT).
	The difference in the requirements of point IS.I.OR.235 is that they are limited to those activities directly related to the ISMS (e. g. internal audits, consultancy for risk

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	assessments, etc.). The controls in ISO/IEC 27001:2022 do not exclude those kinds of services, but sometimes they will not be in the focus of the organisation. Therefore, there is no need to establish an independent system for those contractors referred to in point IS.I.OR.235(a). The list of suppliers should be reviewed to ensure that the suppliers providing the services mentioned in point IS.I.OR.235 are covered.
IS.I.OR.235(b)	Related ISO/IEC 27001:2022 clauses and controls A5.20 Addressing information security within supplier agreements Part-IS particularity Access provided to the authority is not covered in ISO/IEC 27001:2022. Guidance on Part-IS implementation Organisations subject to Part-IS are required to provide access to the competent authority. If the contracted organisation is approved by an authority of another Member State, the different competent authorities will coordinate on which authority will perform oversight of the organisation according to their authority procedures (e.g. Regulation (EU) No 965/2012, point ARO.GEN.300(e)). For contracted organisations not subject to Part-IS, GM1 IS.I.OR.235(b) provides the content to be introduced either in the ‘general terms and conditions of trade’ of the contracting organisation, or if standard general terms and conditions are used (e. g. for COTS-products), the content of the GM has to be arranged on a contractual basis (e. g. through a side letter). AMC1 IS.I.OR.235(b) should be considered in conjunction with ISO/IEC 27001:2022 A5.20.
IS.I.OR.240(a) IS.I.OR.240(e)	Related ISO/IEC 27001:2022 clauses and controls 5.1 Leadership and commitment 5.3 Organisational roles, responsibilities and authorities 7.1 Resources A5.2 Information security roles and responsibilities Part-IS particularity ISO/IEC 27001:2022 does not require a specific role such as the ‘accountable manager’ or ‘head of the design organisation’. Guidance on Part-IS implementation The implementation of the requirements of point IS.I.OR.240(a) can be covered by the implementation of ISO/IEC 27001:2022 requirements mentioned above, provided that the role of accountable manager/head of the design organisation is clearly defined and meets the requirements in point IS.I.OR.240(a). The requirement of point IS.I.OR.240(a)(3) has to be set in line with the roles in A5.2 (where an accountable manager or the head of the design organisation is not envisaged). However, the measures in A6.3 should be used to ensure the competency of the accountable manager or the head of the design organisation (point IS.I.OR.240(a)(3)).

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
IS.I.OR.240(b) IS.I.OR.240(c)	Related ISO/IEC 27001:2022 clauses and controls
	5.3 Organisational roles, responsibilities and authorities
	7.1 Resources
	A5.2 Information security roles and responsibilities
	A5.3 Segregation of duties
	Part-IS particularity
IS.I.OR.240(d)	This requirement is not directly addressed in ISO/IEC 27001:2022.
	Guidance on Part-IS implementation
	The implementation of the requirements of A5.2 and A5.3 should be used as a basis to fulfil the provisions of points IS.I.OR.240 (b) and (c), but some adaptation may be needed.
	This issue is covered in A5.2, but A5.3 may also be applicable. In addition, similar requirements for the ‘safety roles’ are laid down in the domain-specific ‘safety’ implementing or delegated acts of Regulation (EU) 2018/1139.
	AMC1 IS.I.OR.240(b) should be considered.
	Related ISO/IEC 27001:2022 clauses and controls
IS.I.OR.240(f)	4.3 Determining the scope of the information security management system
	A5.2 Information security roles and responsibilities
	A5.3 Segregation of duties
	Part-IS particularity
	The implementation of the requirements of A5.2 and A5.3, as well as the guidance of ISO/IEC 27002, allow the delegation of responsibility within organisations.
	Guidance on Part-IS implementation
IS.I.OR.240(f)	This option might be useful for large organisations or groups, where the ISMS is implemented as an ‘umbrella function’ over a group of organisations, where not all of them are subject to Part-IS.
	The implementation of a ‘group CISO’ or an enterprise-wide ISMS could make use of this option in Part-IS.
	Nevertheless, the common responsible person has to fulfil the competency requirements of point IS.I.OR.240(a)(3). This might be relevant in cases where the other activities of the organisation or group are not related to aviation.
	Related ISO/IEC 27001:2022 clauses and controls
	7.1 Resources
	Part-IS particularity
IS.I.OR.240(f)	The requirements of 7.1 should be implemented.
	Guidance on Part-IS implementation

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	A systematic capacity planning of human resources is a key element of any management system. Therefore, such a process should be established in an ISMS. The possible additional requirement stemming from Part-IS has to be assessed, and the capacity planning updated accordingly. The targeted safety levels set in the safety/information security assessment should never be jeopardised by a lack of resources, even temporarily. AMC1 IS.I.OR.240(f) should be considered.
IS.I.OR.240(g)	Related ISO/IEC 27001:2022 clauses and controls 7.2 Competency A6.3 Information security awareness, education and training Part-IS particularity The implementation of the requirements of 7.2 and A6.3 is sufficient to cover the requirement. Guidance on Part-IS implementation A systematic competency management process of staff is a key element of any management system. Therefore, such a process should be established in an ISMS. The possible additional requirement stemming from Part-IS has to be assessed and the competency requirements updated accordingly. AMC1 IS.I.OR.240(g) should be considered.
IS.I.OR.240(h)	Related ISO/IEC 27001:2022 clauses and controls A6.2 Terms and conditions of employment Part-IS particularity The implementation of the requirements of A6.2 with some adaptation would be sufficient to cover the provision of point IS.I.OR.240(h). Guidance on Part-IS implementation Point IS.I.OR.240(h) is (at least partially) covered by ISO/IEC 27001:2022 A.6.2 ‘The employment contractual agreements should state the personnel’s and the organisation’s responsibilities for information security.’ and A.6.4 ‘disciplinary process’ (see ‘Just Culture’). It depends on the organisational culture and on whether job descriptions or role assignments need to be formally acknowledged. In many organisations, the assigned jobs and roles are mutually acknowledged by performing the tasks assigned.
IS.I.OR.240(i)	Related ISO/IEC 27001:2022 clauses and controls A5.19 Information security in supplier relationships A6.1 Screening A7.2 Physical entry A8.3 Information access restriction A8.5 Secure authentication

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	Part-IS particularity
	The implementation of the requirements of A5.19, A6.1, A7.2, A8.3 and A8.5 might be sufficient controls to cover this requirement for the personnel of the organisation, as well as for contractors and suppliers.
	Guidance on Part-IS implementation All the controls established in an ISO/IEC 27001:2022-compliant ISMS are designed to ensure the confidentiality and integrity of information. The implementation of those controls will provide sufficient protection to ensure compliance with this requirement. AMC1 IS.I.OR.240(i) should be considered.
IS.I.OR.245(a)	Related ISO/IEC 27001:2022 clauses and controls 7.5 Documented information A5.9 Inventory of information and other associated assets A5.13 Labelling of information A8.10 Information deletion A8.13 Information backup Part-IS particularity Record-keeping and retention are an inherent part of the document control system under 7.5 of ISO/IEC 27001:2022. Controls A5.9, A5.13, A8.10 and A8.13 also apply. Guidance on Part-IS implementation Chapter 7.5.1 b) states that the ISMS has to include ‘documented information determined by the organisation as being necessary for the effectiveness of the information security management system.’ This includes the records defined in point IS.I.OR.245(a)(1). Chapter 7.5.3 requires, under f), also document control for retention and disposition. Part-IS requirements have to be integrated into the existing system, especially the minimum duration of record-keeping of five years. The minimum set of records, as defined in point IS.I.OR.245(a)(1) should be covered in the inventory of assets. For the coverage, the content of GM1 IS.I.OR.245 also applies. As records are not only information assets, the requested ‘record retention policy’ may be integrated into a wider policy as recommended by ISO/IEC 27002:2022 above. AMC1 IS.I.OR.245(a)(1)(vi)&(a)(5) should be implemented.
IS.I.OR.245(b)	Related ISO/IEC 27001:2022 clauses and controls 7.5 Documented information A5.9 Inventory of information and other associated assets A5.10 Acceptable use of information and other associated assets A5.13 Labelling of information

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	A5.34 Privacy and protection of personal identifiable information (PII) A8.10 Information deletion A8.13 Information backup
	Part-IS particularity
	Record-keeping and retention are an inherent part of the document control system under 7.5 of ISO/IEC 27001:2022. Controls A5.9, A5.13, A8.10 and A8.13 will also apply and, due to GDPR issues specifically, also A5.10 and A5.34.
	Guidance on Part-IS implementation
	Chapter 7.5.1 b) states that the ISMS has to include ‘documented information determined by the organisation as being necessary for the effectiveness of the information security management system.’ This includes the records defined in point IS.I.OR.245(a)(1). Chapter 7.5.3 requires, under f), also document control for retention and disposition. Part-IS requirements have to be integrated into the existing system, especially the minimum duration of record-keeping of 5 years. However, whereas there is no retention duration specified in ISO/IEC 27001:2022, point IS.I.OR.245(a) specifies three years after the person has left the organisation. As these records fall under the GDPR Regulation, each organisation has to ensure that they are handled accordingly. It is recommended that the procedures are used not only for records related to ISMS, but also for the entire HR personnel files of the staff.
IS.I.OR.245(c)	Related ISO/IEC 27001:2022 clauses and controls
	7.5 Documented information A5.13 Labelling of information
	Part-IS particularity
	Record-keeping and retention are an inherent part of the document control system under 7.5 of ISO/IEC 27001:2022 as well as control A5.13.
	Guidance on Part-IS implementation
	Chapter 7.5.3, under a), requires for the information that ‘it is available and suitable for use, where and when it is needed’. Part-IS requirements have to be integrated into the existing system. ISO/IEC 27002:2022 A5.13 states ‘Procedures for information labelling should cover information and other associated assets in all formats.’; therefore, the Part-IS requirement is fulfilled with control A5.13. A series of AMC material to the implementing and delegated acts regarding safety (e.g. AMC1 ARA.GEN.220(a), AMC1 145.A.55) also covers this issue.
IS.I.OR.245(d)	Related ISO/IEC 27001:2022 clauses and controls
	7.5 Documented information
	A5.10 Acceptable use of information and other associated assets
	A5.12 Classification of information

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	A5.33 Protection of records A8.12 Data leakage prevention
	Part-IS particularity
	Record-keeping and retention are an inherent part of the document control system under 7.5 of ISO/IEC 27001:2022. Controls A5.10, A5.12, A5.33 and A8.12 will also apply.
	Guidance on Part-IS implementation
	Chapter 7.5.3, under d), requires ‘storage and preservation, including the preservation of legibility’. Part-IS requirements have to be integrated into the existing system. The application of A5.33 and A8.12 has a strong relationship to A7.5 (Protecting against physical and environmental threats), A7.10 (Storage media), A8.3 (Information access restriction), A8.13 (Information backup), A8.14 (Redundancy of information processing facilities), A8.15 (Logging), A8.17 (Clock synchronization) and A8.24 (Use of cryptography).
IS.I.OR.250(a)	Related ISO/IEC 27001:2022 clauses and controls
	7.5 Documented information A5.13 Labelling of information
	Part-IS particularity
	Document control is an inherent part of the ISMS under 7.5 of ISO/IEC 27001:2022. Control A5.13 is also an ‘anchor point’ for this requirement. ISO/IEC 27001:2022 does not specifically request a document called ‘information security management manual’, made available to the authority.
	Guidance on Part-IS implementation
IS.I.OR.250(b) IS.I.OR.250(c)	Chapter 7.5.1 b) states that the ISMS has to include ‘documented information determined by the organisation as being necessary for the effectiveness of the information security management system’ which will allow the inclusion of the ISMS manual in the documentation. Part-IS requires a specific ISMS manual (ISMM), made available to the competent authority. It has to be made clear to the competent authority which set of documented information constitutes the ‘approved manual’. The document ‘statement of applicability’ (SOA), mandatory for all ISO/IEC 27001:2022-certified organisations may be helpful (e.g. by adding an additional column to label specific documents as part of a ‘virtual’ ISMS Manual). GM1 IS.I.OR.250(a) also provides associated guidance. It has to be ensured that all information listed in point IS.I.OR.250(a) is covered.
	Related ISO/IEC 27001:2022 clauses and controls
	7.5 Documented information A5.5 Contact with authorities

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	Part-IS particularity
	Document control is an inherent part of the ISMS under 7.5 of ISO/IEC 27001:2022.
	Guidance on Part-IS implementation
	The use of the same procedure as the one implemented for the ‘safety regulations’ (see above) is recommended also for the approval, update and communication processes with the competent authority. Many organisations have their documented information available via document management systems (e.g. MS SharePoint). The access of the competent authority to these systems has to be managed in accordance with the rules of any other external access in respect of A5.15, A5.18, A6.6, A7.9, A8.3, A8.7, A8.11, and A8.24.
IS.I.OR.250(d)	Related ISO/IEC 27001:2022 clauses and controls
	7.5 Documented information
	Part-IS particularity
	This possibility of ISMM integration with other expositions or manuals has no specific counterpart in ISO/IEC 27001:2022. However, following the ISO ‘Annex SL’ structure, ISO/IEC 27001:2022 enables an easy integration of other management system standards.
	Guidance on Part-IS implementation
	There is a tendency in the aviation industry to integrate different management systems, depending on the structure of the organisation.
IS.I.OR.255(a)	Related ISO/IEC 27001:2022 clauses and controls
	6.3 Planning of changes
	A5.5 Contact with authorities
	Part-IS particularity
	Change management is an inherent part of the ISMS under 6.3 of ISO/IEC 27001:2022, but there is no provision for approval of a procedure by a competent authority.
	Guidance on Part-IS implementation
	The use of the same procedure as the one implemented for the ‘safety regulations’ (see above) is recommended also for the approval of changes not requiring prior approval by the competent authority. This procedure should be extended to Part-IS in agreement with the competent authority. <i>Note:</i> <i>This recommendation will only work if the competent authority is the authority as laid down in Article 6(1) of Regulation (EU) 2023/203 or Article 5(1) of Regulation (EU) 2022/1645.</i> WARNING: An organisation with a derogation approval in accordance with point IS.I.OR.200(e) needs to assess for all changes (also those not requiring prior

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	<i>approval) whether the criteria for the approved derogation are still valid. If not, the change needs the approval of the competent authority/authorities prior to being implemented.</i>
IS.I.OR.255(b)	Related ISO/IEC 27001:2022 clauses and controls
	6.3 Planning of changes A5.5 Contact with authorities
	Part-IS particularity
	Change management is an inherent part of the ISMS under 6.3 of ISO/IEC 27001:2022. However, ISO/IEC 27001:2022 does not require any kind of approval by a competent authority.
	Guidance on Part-IS implementation The use of the same procedure as the one implemented for the ‘safety-regulations’ (see above) is recommended also for the approval of changes in agreement with the competent authority. <i>Note:</i> <i>This recommendation will only work if the competent authority is the authority as laid down in Article 6(1) of Regulation (EU) 2023/203 or Article 5(1) of Regulation (EU) 2022/1645.</i>
IS.I.OR.260(a)	Related ISO/IEC 27001:2022 clauses and controls
	9.3 Management review 10.1 Continual improvement A5.35 Independent review of information security
	Part-IS particularity
	This requirement reflects a combination of requirements 9.3 and 10.1 of ISO/IEC 27001:2022 with references to requirements 4.4 and 5.2. While ISO/IEC 27001:2022 focuses on ISMS suitability, adequacy and effectiveness, point IS.I.OR.260(a) requires also a periodical maturity assessment of the ISMS.
	Guidance on Part-IS implementation ISO/IEC 27001:2022, 4.4 shows a clear requirement (‘shall’) for ISMS maintenance and improvement. The top management has a responsibility for continuous ISMS improvement as per ISO/IEC 27001:2022 5.2(d). The planning section also requires continuous improvement (ISO/IEC 27001:2022 6.1.1(c)). Point IS.I.OR.260(a) requires an assessment of the effectiveness and maturity of the ISMS on a calendar basis or following an information security incident. This assessment should be performed by using indicators. ISO/IEC 27001:2022 Chapter 9.3.1 defines a very similar approach for the management review process. Chapter 10.1 indicates a more independent process to improve the ISMS. The process in Chapter 10.1 is seen as more of a bottom-up approach, whereas that in Chapter 9.3 is intended to be top-down. The results from A5.35 should all be used as inputs for continuous improvement.

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	Point IS.I.OR.260(a) requires also a maturity assessment of the ISMS. Each organisation should establish which maturity model will be followed and which targeted maturity level is expected to be reached and by when. For the maturity assessment, point (b) of AMC1 IS.I.OR.260(a) and GM1 IS.I.OR.260(a) provide guidance on how to ensure compliance with point IS.I.OR.260(a).
IS.I.OR.260(b)	Related ISO/IEC 27001:2022 clauses and controls 10.2 Non-conformity and corrective action A5.7 Threat intelligence Part-IS particularity Point IS.I.OR.260(b) addresses the improvement measures, i.e. corrections and corrective actions for the deficiencies detected in point IS.I.OR.260(a) and the continuous improvement process. This requirement reflects mainly requirement 10.2 of ISO/IEC 27001:2022, even if the term used is ‘non-conformity’, while point IS.I.OR.260(b) uses the term ‘deficiencies’. Deficiency has a broader meaning than non-conformity. It encompasses the case of a targeted maturity level that would not be reached at the planned date; that would be a deficiency but not necessarily a non-conformity. Guidance on Part-IS implementation The provisions listed in ISO/IEC 27001:2022 10.2 can be used to take corrective actions, to resolve both non-conformities and maturity level gaps.

Appendix V — Proportionality considerations related to indicators of complexity

ED Decision 2025/014/R

The following is a non-exhaustive, non-binding, list of activities related to the implementation of the ISMS under this Regulation. These activities are proposed in association with a set of indicators, with activities suggested at the lower and upper ends of the scale. Organisations are encouraged to assess their own level for each indicator, selecting or adapting the proposed activities based on their specific information security risks and organisational context. This approach helps to keep the activities proportionate to the overall safety relevance and complexity of the organisation.

Indicator of the degree of safety relevance: the organisation’s role in the functional chain, and the number and criticality of interfacing organisations

The organisation’s role in the functional chain and its overall contribution to the safety of related functional processes are key indicators of safety relevance. This should impact the depth of risk assessment required and the level of assurance needed to ensure the effectiveness of measures implemented to mitigate unacceptable risks.

Low safety relevance: organisations whose role in the functional chain and their interfaces do not pose a risk of unsafe conditions

The following approach may be adopted:

Risk assessment and treatment

- **Simplified risk assessment:** A streamlined risk assessment process that prioritises risks based on their potential impact on safety is used. The assessment focuses on high-impact areas; more detailed assessments are performed only where and if necessary.
- **Risk treatment prioritisation:** A risk treatment plan that prioritises high-impact risks with cost-effective measures is adopted. In such cases, cost-effective controls that reduce risks to acceptable levels may be used. These controls can often leverage existing processes, physical controls or technology.

High safety relevance: organisations whose role in the functional chain and their interfaces may pose a risk of unsafe conditions

The following approach may be adopted:

Risk assessment and treatment

Detailed risk assessments: Detailed and often more frequent risk assessments are carried out for those elements that have been identified as having a relevant safety impact, i.e. an unsafe condition.

Indicator of complexity 1: complexity of the organisational structure and hierarchies

The complexity of an organisation's structure — typically determined by the number of staff, departments and hierarchical layers — directly influences the level of internal coordination required and the extent to which information exchange needs to be formalised and proceduralised.

Low complexity: organisations characterised by a combination of limited number of staff members, few hierarchical layers and departments

The following approaches may be adopted:

(a) Policy and procedure simplification

- **Streamlined documentation:** Policies and procedures are concise, clear and easy to read. Documents are kept short and simple to make them easily understandable. Templates can be used in order to expedite the creation of the necessary documentation.
- **Focus on key policies:** During the development, the key policies have been prioritised in order to address the most critical aspects of information security, such as management commitment, access control and incident response.

(b) Employee training and awareness

- **Targeted training programmes:** Focused training programmes that target the specific roles and responsibilities of employees are provided. The training is relevant to the organisation's specific risks and operational context.
- **Security culture:** A culture of information security awareness is encouraged throughout the organisation. Short training sessions and awareness campaigns are conducted on a regular basis.

(c) Outsourcing and partnerships

- **Outsourcing:** For areas where the organisation lacks expertise, outsourcing to providers of managed-security services is adopted.

- **Collaboration with peers:** Information-sharing with similar organisations (e.g. through the European Centre for Cyber Security in Aviation (ECCSA)) or industry groups is carried out. Collaboration provides insights to evaluate the evolution of the security environment with limited effort.

(d) Engagement with management

Simplified management reporting: Reports to management are concise and focused on key metrics that demonstrate the effectiveness of the ISMS. Continued support and resource allocation from top management is ensured.

(e) Compliance monitoring and continuous improvement

- **Regular but scaled audits:** Internal audits are regularly conducted, but the effort is scaled to the organisation's size and complexity. The focus is on the most critical areas, and the audit results are provided to the accountable manager or the head of the design organisation and utilised to guide continuous improvement.
- **Agile review process:** The ISMS is regularly reviewed and, if necessary, adapted to ensure that it remains aligned with the organisation's evolving needs and threats.

High complexity: organisations characterised by a combination of large number of staff members, hierarchical layers and departments and interfaces

The following approaches may be adopted:

(a) Robust governance structure

- **Information security governance:** Governance implementation to oversee the ISMS is present. This is to ensure alignment with the organisation's safety and security objectives. This governance should operate through formal committees or working groups that include representatives from senior management, safety, information technology, legal and key business units.
- **Metrics and reporting:** Comprehensive metrics and reporting structures to track the effectiveness of the ISMS are implemented. Report on key performance indicators (KPIs) to senior management and the management board are provided to ensure ongoing support and resource allocation.

(b) Extensive policy and procedure framework

- **Detailed policies and procedures:** Although streamlined documentation is still the overall objective, more complex organisations may require a broader range of policies and procedures to cover different business units and departments, compliance requirements and operational processes.
- **Policy harmonisation:** Policies are harmonised across the organisation to avoid conflicting practices between different departments or regions. This requires a centralised governance model to oversee policy development and enforcement.

(c) Risk assessment and treatment

- **Cross-risk assessments:** Cross-risk assessments include assessing risks across various departments, geographic locations and technological platforms.
- **Risk aggregation and correlation:** With a larger volume of information, risks assessments are aggregated and correlated to identify systemic issues and ensure that risks are managed and escalated at an organisational level, not just within individual silos.

(d) Comprehensive training and awareness programmes

- **Role-based training:** Extensive role-based training programmes tailored to different functions within the organisation are implemented. For example, IT staff, executives and end-users all have different levels of training specific to their roles.
- **Continuous security awareness campaigns:** Security awareness campaigns using various methods (e.g. phishing simulations, workshops and e-learning modules) are continuously deployed to keep security top-of-mind for all employees across the organisation.

(e) Enhanced contracted activities management

- **Supply chain risk management:** Thorough information security assessments of contracted organisations and ongoing monitoring of third-party risks are carried out. Information security requirements are integrated into contracts.

(f) Comprehensive incident management

- **Security monitoring and incident response capability:** In order to monitor security events around the clock, manage incidents and coordinate response efforts across the organisation, structured security operations are established. Depending on the organisation's resources, this can be achieved through a dedicated security operations centre (SOC), a virtual SOC, managed security services or other appropriate solutions that ensure effective coverage.
- **Complex incident response plans:** Detailed incident response plans that cover a variety of scenarios, including cross-departmental coordination, communication strategies and operational continuity planning are developed and maintained.
- **Crisis simulation exercises:** Crisis simulation exercises that involve key stakeholders across the organisation are regularly conducted to test the effectiveness of incident response and operational continuity plans.

(g) Continuous improvement and compliance monitoring programmes

- **Internal audits:** Comprehensive internal audits are regularly conducted to assess compliance with the ISMS and identify areas for improvement.
- **Audits of contracted organisations:** To ensure compliance with the organisation's security and safety objectives, audits of contracted organisations are conducted at a frequency proportionate to the relevance of the contracted activities to security and safety. Using the results of existing relevant audits is also encouraged to reduce the burden.
- **Continuous improvement programmes:** A continuous improvement process to update and refine the ISMS based on audit findings, incident post-mortems and changes in the threat landscape is implemented.

Indicator of complexity 2: complexity of the ICT systems and data used by the organisation

The complexity of the information and communication technology systems and data used by the organisation, and their connection to external parties, directly influences the level of customisation and tailoring required for risk management and incident detection, response and recovery.

Low complexity: organisations characterised by a combination of usage of a few ICT tools and utilisation of standard ICT products

The following approaches may be adopted:

(a) Use of standards and tools

- **Leverage ISO/IEC 27001:2022 controls as a baseline:** ISO/IEC 27001:2022 Annex A provides a catalogue of controls that are selected based on the results of the risk assessment. Similarly, NIST SP 800-53 offers a comprehensive set of controls that can be adapted to specific threats and operational requirements. Aligning control selection with risk assessment outcomes ensures that the controls are suitable for the specific threats and vulnerabilities identified, while reducing the effort involved in designing controls from scratch. Additionally, using the controls as a checklist helps to ensure that critical areas are addressed. To ensure full alignment with aviation-specific information security requirements under Part-IS, it is also recommended to consult the Part-IS versus ISO/IEC 27001:2022 comparison guide.
- **Simplified incident management:** A basic incident management process that allows for quick identification, reporting and response to security incidents is adopted. Lessons learned from incidents are in any case integrated into the ISMS for continuous improvement.
- **Automated tools:** Automated tools for monitoring, logging and managing security incidents are used in order to reduce manual effort while maintaining continuous compliance.

(b) Documentation and record-keeping

- **Essential records:** Only records that are essential to demonstrate compliance and the effectiveness of the ISMS are kept. Excessive documentation that does not add value or is burdensome to maintain is avoided.
- **Use of digital solutions:** Digital tools are used for document management to simplify access and version control, and to ensure the security of records.

High complexity: organisations characterised by a combination of usage of several and diverse ICT tools, amongst which bespoke ICT solutions

The following approaches may be adopted:

(a) Advanced security technologies

- **Integration of advanced security tools:** Security technologies like security information and event management (SIEM), data loss prevention (DLP), and endpoint detection and response (EDR) systems are utilised to help manage the scale and complexity of monitoring, detecting and responding to security incidents across the organisation.
- **Automated threat intelligence:** Automated threat intelligence platforms are used to enable real-time threat detection and response across the broad threat surface.

(b) Documentation and record-keeping

- **Detailed documentation:** Extensive documentation of all ISMS processes, risk assessments, incident reports and compliance activities is carried out.
- **Record retention:** Records and data are widely collected, retained and securely stored, and are accessible over extended periods.

Appendix VI — Adaptation of the EU Cybersecurity Skills Framework (ECSF)

ED Decision 2025/014/R



APPLICATION OF THE EUROPEAN CYBERSECURITY SKILLS FRAMEWORK TO AVIATION

Contents

1. Introduction	2
2. Analysis of the situation and the target environment.....	3
3. Identification of specific objectives to be achieved.....	4
4. Selection of the appropriate ECSF components	4
5. Adapting the selected components according to specific needs	7
5.1 Chief Information Security Officer / Responsible Person under Part-IS.....	8
5.2 Cyber Legal, Policy & Compliance Officer / Compliance monitoring under Part-IS.....	11
5.3 Cybersecurity Auditor / Cybersecurity Auditor within compliance monitoring function.....	12
5.4 Cybersecurity Risk Manager / Appointed person under Part-IS.....	14
5.5 Cybersecurity Incident Responder	16
6. Conclusions	17
7. Possible developments	18



1. Introduction

The European Union Agency for Cybersecurity (ENISA) has developed the European Cybersecurity Skills Framework (ECSF) as a comprehensive tool to address the growing need for cybersecurity expertise across different sectors. The ECSF provides a standardised framework for the assessment and development of cybersecurity skills, knowledge, and competences.

With its increasing reliance on digital technology and interconnected networks, cybersecurity is of paramount importance to ensure the integrity and resilience of aviation system for the safety of the passengers and people on ground. A new aviation regulation, called Part-IS, has recently been introduced in the EU with the aim of implementing a structured approach to managing cybersecurity risks that may have an impact on aviation safety.

Organisations and national authorities subject to this Regulation will need to assess the suitability of their staff to properly apply the Regulation and, where necessary, to adjust staff competences. For this purpose, the ENISA ECSF can provide useful tools and a methodological approach.

In fact, the framework provides a common language and reference point for understanding and categorising cybersecurity roles, facilitating effective recruitment, training, and talent development strategies. By utilising the ECSF, aviation organisations may identify and assess the cybersecurity skills and competencies required for their specific operational needs. It may support the identification of skills gaps and areas for improvement, helping organisations to prioritise training programmes and investments to effectively address cybersecurity challenges.

The objective of this document is to provide a high-level case study of the application of the ECSF in aviation for the purpose of implementing and applying the Part-IS.

2. Analysis of the situation and the target environment

Aviation, like other transport and industrial sectors, is characterised by the coexistence of two primary classes of information technologies within organisations. These classes are:

- **Information and Communication Technologies (ICT):** These are the traditional systems and technologies that support administrative and business functions. ICT systems encompass a wide range of technologies, including computer systems, networks, software applications, databases, and associated infrastructure. They facilitate tasks such as data processing, storage, communication, and information management necessary for the administrative operations within an organisation.
- **Operational Technologies (OT):** OT refers to the specialised technologies and systems designed specifically for the management and control of physical processes and assets. In the context of aviation, OT systems include various components such as manufacturing automation systems, power plant control systems, medical equipment and in the aviation sector aircrafts, air traffic management or even baggage handling, including screening, systems. These technologies are critical to the safe and efficient operation of aviation processes and assets.

While there are technological differences between ICT and OT systems, the gap between them is gradually closing. OT systems are becoming more similar to ICT systems due to technology convergence and the adoption of digitalisation in the aviation sector. This convergence involves the integration of IT practices and technologies into OT systems to improve efficiency, enhance data analysis capabilities and enable better decision making.

However, despite the diminishing technological differences, there are still some distinct characteristics between ICT and OT domains in the aviation industry. These differences have implications for cybersecurity risk policies, availability requirements and change management processes:

- **Cybersecurity Risk Policy:** Risk assessment in the OT domain requires additional considerations due to the critical safety aspects associated with physical processes and assets. In many sectors, including aviation, safety requirements are often incorporated into regulatory frameworks. Therefore, risk assessment for OT systems should include both traditional information security considerations and safety-related risks specific to the aviation industry.
- **Availability requirements:** OT systems are typically required to operate continuously and be resilient to cyber-attacks in order to maintain the availability of safety-critical functions in the event of cyber-security incidents.
- **Change Management Process:** The change management process for OT systems is different from that for ICT systems. In the OT domain, updates, patches, and system changes cannot be implemented in a timely manner as they may affect the safety and operational integrity of aviation processes. Therefore, any changes or updates to OT systems must be carefully planned, extensively tested in advance, and comply with stringent regulatory requirements to ensure safety and reliability.

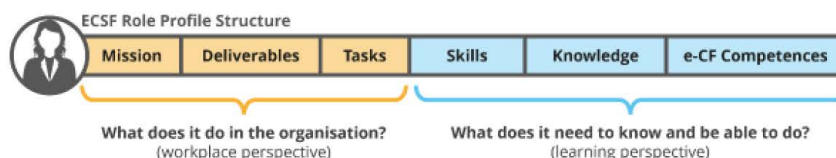
3. Identification of specific objectives to be achieved

OT operations and cybersecurity personnel need to maintain a delicate balance between ensuring robust cybersecurity and maintaining the operational safety of systems. This approach requires a thorough understanding of the specific safety requirements, associated processes, and regulatory standards relevant to the industry in which OT systems are deployed. It involves active engagement with cybersecurity professionals, regulators, and industry experts to ensure that security measures are aligned with safety objectives and comply with applicable safety regulations.

4. Selection of the appropriate ECSF components

The ECSF profiles can be a valid starting point to define the information security competences required in the aeronautical sector, taking into account also the specificity of the OT described above, which characterises this domain.

To this purpose the recently published EU Regulation 2023/203 (Part-IS) for the management of cybersecurity risks with a potential impact on aviation safety will be considered. This Regulation sets out requirements for aviation organisations and relevant competent authorities and allows some roles to be described from a workplace perspective by defining mission, deliverables, and task in accordance with the scheme below.



In particular the aviation regulation and Part-IS delineates some specific roles/functions and their responsibilities, these roles are:

Accountable Manager, or Head of Design, or Responsible Person

The person in this role is responsible for establishing and maintaining the organisational structures, policies, processes, and procedures necessary to meet the requirements of the Regulation. In addition, the person in this role is explicitly required to establish and promote the information security policy.

The role is clearly managerial, and it is expected that a significant degree of delegating to lower management and implementing teams will occur.

Compliance Monitoring (person responsible for)

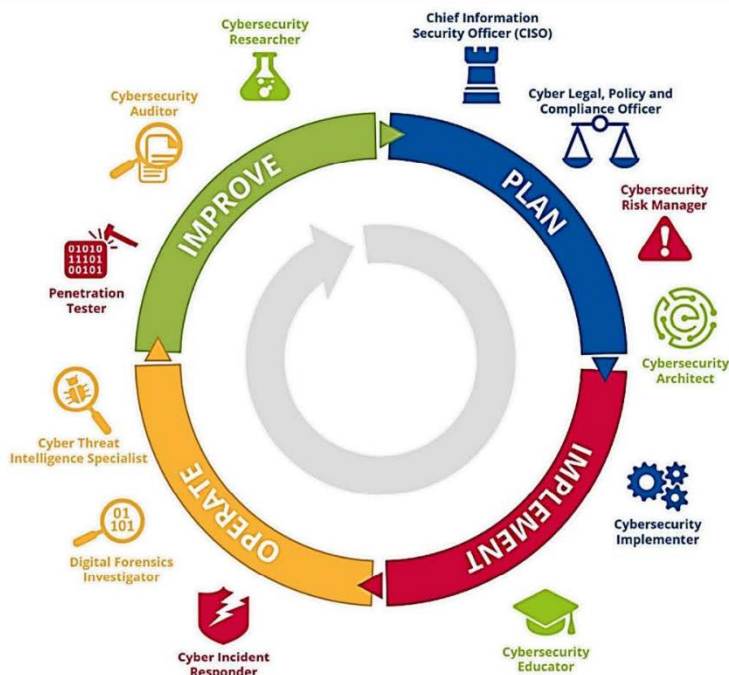
The monitoring of compliance with the requirements of the Regulation is the responsibility of the person(s) in this role.

Appointed person(s)

The Regulation requires the appointment of a person or, more likely, a group of persons, to ensure the compliance of the organisation with the requirements. The extent of authority may vary; however these appointed persons should have responsibilities at management level and in many cases they will coordinate and oversee the activities other staff members.



The ECSF instead proposes 12 standard roles involved in different phases of the management cycle, as illustrated below.



An initial mapping between the ECSF roles and the roles delineated in Part-IS can be performed by **comparing the deliverables expected from the different roles** as reported in the below Table 1. As described above, some roles are well described in Part-IS, others can be considered expected in order to comply with the requirements of the regulation (e.g. incident detection, response and recovery).

The mapping shows that there are different levels of matching between ECSF and Part-IS roles. Four levels have been used, ranging from "high level of match" to "no match". In more details the rationale for the classification of the level of matching is the following:

- **High level of match:** In the Part-IS regulation, both a role and a deliverable can be found that is very close to the one described in the framework.
- **Not Specified, but expected:** In order to comply with the provisions of Part IS, an organisation is expected to produce the deliverable under the ECSF profile, but the Regulation does not mention a specific role associated with this deliverable.
- **Not Specified, may be useful in complex setting:** Same as the previous level of matching, with the addition that this role may only be justified in complex organisations.
- **Not foreseen:** In the Part-IS regulation, both a matching role and a deliverable cannot be found.

According to the level of match between the roles the following colour background has been used in the table rows:

High level of match	Medium level of match	Low level of match	No match
---------------------	-----------------------	--------------------	----------

Table 1 – ECSF and Part-IS roles mapping

Profile Title	Deliverable	Part – IS role considerations
Chief Information Security Officer (CISO)	Cybersecurity Strategy / Policy	Responsible Person
Cyber Legal, Policy & Compliance Officer	Compliance Manual / Compliance Report	Compliance Monitoring
Cybersecurity Auditor	Cybersecurity Audit Plan / Report	Auditor within compliance monitoring function
Cybersecurity Risk Manager	Cybersecurity Risk Assessment Report / Remediation Action Plan	One of the “appointed persons”
Cybersecurity Implementer	Cybersecurity Solutions	Not specified, but expected
Cyber Incident Responder	Incident Response Plan / Incident Report	One of the “appointed persons”
Cyber Threat Intelligence Specialist	Cyber Threat Intelligence Manual / Report	Not specified, but expected
Cybersecurity Architect	Cybersecurity Architecture Diagram / Requirements Report	Not specified, but expected
Cybersecurity Educator	Cybersecurity Awareness Program / Training Material	Not specified, but expected
Cybersecurity Researcher	Publication in Cybersecurity	Not foreseen
Digital Forensics Investigator	Digital Forensics Analysis Results / Electronic Evidence	Not specified, but expected
Penetration Tester	Vulnerability Assessment Results Report / Penetration Testing Report	Not specified, may be useful in complex setting

The resulting mapping applied to the ECSF roles in the phases of the management cycle is depicted in the following figure.



© European Union Aviation Safety Agency. All rights reserved.
Proprietary document. Version 1, July 2023.

Page 6 of 18

5. Adapting the selected components according to specific needs

For the purposes of this exercise, we will focus on the high match roles summarised in the table below. The aim is to take into account the specific objectives arising from the OT considerations described in the earlier section.

Table 2 – ECSF and Part-IS roles mapping – medium and high match

Profile Title	Deliverable	Part – IS role considerations
Chief Information Security Officer (CISO)	Cybersecurity Strategy / Policy	Responsible Person
Cyber Legal, Policy & Compliance Officer	Compliance Manual / Compliance Report	Compliance Monitoring
Cybersecurity Auditor	Cybersecurity Audit Plan / Report	Auditor within the compliance monitoring function
Cybersecurity Risk Manager	Cybersecurity Risk Assessment Report / Remediation Action Plan	One of the "appointed persons"
Cyber Incident Responder	Incident Response Plan / Incident Report	One of the "appointed persons"

The ECSF provides a convenient description of the role profiles through components that include **summary statement, mission, deliverable(s), main task(s) and key skill(s)**. The matching in terms of deliverable(s) have been used in the previous step to identify the appropriate profiles, so this component does not require adaptations. It can also be expected that the summary statement and the mission, being high-level descriptions, may not require significant adaptation, whereas the main tasks associated with the role may need to be adapted with integrations to reflect the specificities of aviation and OT in general.

For the different roles analysed, the modified/added text of the above component is **shown in blue**, removals instead are **shown in red**. The use of the term "safety" in the remainder of this document is in the meaning of "aviation safety".

5.1 Chief Information Security Officer / Responsible Person under Part-IS

Summary statement	Manages an organisation's cybersecurity strategy and its implementation to ensure that digital systems, services and assets are adequately secure and protected, with a strong emphasis on operational safety .
Mission	Defines, maintains and communicates the cybersecurity vision, strategy, policies and procedures. Manages the implementation of the cybersecurity policy across the organisation. Assures information exchange with external authorities and professional bodies.

Main Tasks	
ECSF original	Adapted
Define, implement, communicate and maintain cybersecurity goals, requirements, strategies, policies, aligned with the business strategy to support the organisational objectives	Define, implement, communicate and maintain cybersecurity goals, requirements, strategies and policies that are aligned with the business strategy to support the organisation's objectives ¹ [see note 1], taking into account the safety perspective: In addition to considering cybersecurity objectives, safety perspectives should be integrated into the objectives, requirements, strategies and policies. This will ensure that cybersecurity measures do not compromise the safety of operational systems and processes. Safety considerations should be included in risk assessments, threat modelling and decision-making processes.
Prepare and present cybersecurity vision, strategies and policies for approval by the senior management of the organisation and ensure their execution	Prepare and present cybersecurity vision, strategies and policies for approval by the senior management of the organisation and ensure their execution, considering safety implications: When presenting the cybersecurity vision, strategies and policies to senior management, it is crucial to highlight the safety implications and emphasise the importance of aligning cybersecurity measures with operational safety. This will ensure that senior management understands the potential impact of cybersecurity decisions on the overall safety of the organisation.
Supervise the application and improvement of the Information Security Management System (ISMS)	Supervise the application and improvement of the Information Security Management System (ISMS) with a focus on safety: While supervising the ISMS, OT operations and security personnel should place significant emphasis on the safety aspects. This includes incorporating controls into the ISMS framework, ensuring that safety requirements are met, and monitoring the effectiveness of safety measures implemented alongside cybersecurity practices.

¹ The "business strategy to support the organisation's objectives" could be interpreted as the "entity risk appetite".

Main Tasks	
ECSF original	Adapted
Educate senior management about cybersecurity risks, threats and their impact to the organisation	Educate senior management about cybersecurity risks, threats and their impact to their own organisation, societal safety and interfaced organisations : During education sessions with senior management, it is essential to provide insights into cybersecurity risks and threats from a safety perspective. This helps senior management understand the potential consequences of cyber incidents on operational safety, making informed decisions regarding resource allocation and risk mitigation strategies.
Ensure the senior management approves the cybersecurity risks of the organisation	Ensure senior management approves the cybersecurity risks of the organization, considering safety aspects: When seeking approval for cybersecurity risks, OT operations and security personnel should explicitly address the safety implications associated with these risks. This will ensure that senior management is fully aware of the potential impact on operational safety and can prioritise risk mitigation efforts accordingly.
Develop cybersecurity plans	Develop cybersecurity plans that integrate safety considerations: Cybersecurity plans should not only focus on protecting against cyber threats, but should also include measures to address operational safety. This may include incorporating safety controls, conducting safety impact assessments, and aligning cybersecurity initiatives with safety objectives and industry-specific safety standards.
Develop relationships with cybersecurity-related authorities and communities	Develop relationships with cybersecurity-related authorities and communities, with a focus on safety aspects: When establishing relationships with cybersecurity-related authorities and communities, OT operations and security personnel should actively seek opportunities to discuss cybersecurity aspects of operational safety.
Report cybersecurity incidents, risks, findings to the senior management	Report cybersecurity incidents, risks, findings to the senior management, emphasizing safety implications: When reporting cybersecurity incidents, risks, and findings to senior management, it is essential to highlight the safety implications and articulate the potential impact on operational safety. This helps senior management make informed decisions regarding incident response, risk mitigation, and resource allocation.
Monitor advancement in cybersecurity	Monitor advancements in cybersecurity with a focus on safety-related technologies and practices
Secure resources to implement the cybersecurity strategy	Secure resources to implement the cybersecurity strategy, considering safety needs: When securing resources to implement the cybersecurity strategy, OT operations and security personnel should ensure that adequate resources are allocated for safety-related measures.

Main Tasks	
ECSF original	Adapted
Negotiate the cybersecurity budget with the senior management	Negotiate the cybersecurity budget with senior management, <i>considering safety requirements</i> : During budget negotiations, OT operations and security personnel should advocate for sufficient funding to address both cybersecurity and safety needs. This includes emphasising the importance of investing in cybersecurity measures to protect operational systems and ensure their continued safe operation.
Ensure the organisation's resiliency to cyber incidents	Ensure the organization's resiliency to cyber incidents, <i>incorporating safety-focused incident response plans and business continuity measures</i> . This involves identifying and addressing potential safety risks during incident response and recovery efforts.
Manage continuous capacity building within the organisation	Manage continuous capacity building within the organisation, <i>promoting training and awareness programmes that encompass both cybersecurity and operational safety aspects</i> . This ensures that employees understand the importance of maintaining a safe and secure operational environment.
Review, plan and allocate appropriate cybersecurity resources	Review, plan, and allocate appropriate cybersecurity resources, <i>considering safety requirements and conducting regular assessments of resource needs to effectively protect systems and maintain operational safety</i> .

5.2 Cyber Legal, Policy & Compliance Officer / Compliance monitoring under Part-IS

Summary statement

Manages compliance with cybersecurity-related standards, legal and regulatory frameworks based on the organisation's strategy and legal requirements.

Mission

Oversees and assures compliance with cybersecurity- and data-related legal, regulatory frameworks and policies in line with the organisation's strategy and legal requirements. **Contributes to the organisation's data protection related actions.** Provides legal advice in the development of the organisation's cybersecurity governance processes and recommended remediation strategies/solutions to ensure compliance.

Main Tasks	
ECSF original	Adapted
Ensure compliance with and provide legal advice and guidance on data privacy and data protection standards, laws and regulations	Ensure compliance with and provide advice and guidance on cybersecurity provisions in aviation regulation
Identify and document compliance gaps	No adaptations
Conduct privacy impact assessments and develop, maintain, communicate and train upon the privacy policies, procedures	Not required by the aviation specific regulation
Enforce and advocate organisation's data privacy and protection program	Not required by the aviation specific regulation
Ensure that data owners, holders, controllers, processors, subjects, internal or external partners and entities are informed about their data protection rights, obligations and responsibilities	Not required by the aviation specific regulation
Act as a key contact point to handle queries and complaints regarding data processing	Not required by the aviation specific regulation
Assist in designing, implementing, auditing and compliance testing activities in order to ensure cybersecurity and privacy compliance	Assist in designing, implementing, auditing and compliance testing activities in order to ensure cybersecurity compliance
Monitor audits and data protection related training activities	Not required by the aviation specific regulation
Cooperate and share information with authorities and professional groups	Cooperate and share information with competent authorities
Contribute to the development of the organisation's cybersecurity strategy, policy and procedures	No adaptations
Develop and propose staff awareness training to achieve compliance and foster a culture of data protection within the organization	Not required by the aviation specific regulation
Manage legal aspects of information security responsibilities and third-party relations	No adaptations

5.3 Cybersecurity Auditor / Cybersecurity Auditor within compliance monitoring function

Summary statement	Perform cybersecurity audits on the organisation's ecosystem. Ensuring compliance with statutory, regulatory, policy information, cybersecurity requirements, industry standards and best practices.
Mission	Conducts independent reviews to assess the effectiveness of processes and controls and the overall compliance with the organisation's legal and regulatory frameworks policies. Evaluates, tests and verifies cybersecurity-related products (systems, hardware, software and services), functions and policies ensuring, compliance with guidelines, standards and regulations.

Main Tasks	
ECSF original	Adapted
Develop the organisation's auditing policy, procedures, standards and guidelines	Develop the organisation's audit policies, procedures, standards and guidelines, taking into account the safety requirements specific to the OT environment . Incorporate safety considerations into the audit framework to assess the effectiveness of cybersecurity controls in maintaining operational safety .
Establish the methodologies and practices used for systems auditing	Establish the methodologies and practices used for systems auditing that consider the safety-critical nature of OT systems . Design audit approaches that assess the information security and safety aspects of OT processes, ensuring that both cybersecurity and operational safety objectives are addressed.
Establish the target environment and manage auditing activities	Establish the target environment and manage auditing activities, focusing on the safety-critical components of OT systems . In accordance with the risk assessment, prioritise audit areas that have the greatest impact on operational safety .
Define audit scope, objectives and criteria to audit against	Define the audit scope, objectives, and criteria to audit against with a particular focus on safety requirements . Consider standards, regulations, and industry best practices to assess the effectiveness of cybersecurity controls in maintaining operational safety .
Develop an audit plan describing the frameworks, standards, methodology, procedures and auditing tests	Develop an audit plan describing the frameworks, standards, methodology, procedures and auditing tests and that aligns them with both cybersecurity and operational safety objectives . Include specific tests and assessments to ensure the integrity and safety of OT systems .
Review target of evaluation, security objectives and requirements based on the risk profile	Review the target of evaluation, security objectives, and requirements based on the risk profile, taking into account safety considerations . Evaluate compliance with safety regulations and standards to ensure the operational safety of OT systems.
Audit compliance with cybersecurity-related applicable laws and regulations	Audit compliance with cybersecurity-related applicable laws, regulations, and safety standards. Assess adherence to safety regulations that are critical for maintaining operational safety within the OT environment .
Audit conformity with cybersecurity-related applicable standards	

Main Tasks	
ECSF original	Adapted
Execute the audit plan and collect evidence and measurements	Execute the audit plan, collecting evidence and measurements that validate the effectiveness of cybersecurity controls from a safety perspective. Evaluate the alignment of security practices with operational safety requirements, ensuring that both aspects are adequately addressed.
Maintain and protect the integrity of audit records	Maintain and protect the integrity of audit records, including safety-related findings and recommendations. Safeguarding the accuracy and confidentiality of audit records ensures the preservation of safety-related findings and supports continuous improvement efforts.
Develop and communicate conformity assessment, assurance, audit, certification and maintenance reports	Develop and communicate conformity assessment, assurance, audit, certification, and maintenance reports that highlight the intersection of cybersecurity and operational safety. Highlight the impact of cybersecurity measures on the operational safety of OT systems, providing insight for risk mitigation and improvement initiatives.
Monitor risk remediation activities	Monitor risk remediation activities to ensure that identified vulnerabilities and safety risks are effectively addressed. Track the progress of remediation activities and verify that safety-critical issues are adequately remediated.

5.4 Cybersecurity Risk Manager / Appointed person under Part-IS

Summary statement

Manage the organisation's cybersecurity-related risks aligned to the organisation's strategy. Develop, maintain and communicate the risk management processes and reports.

Mission

Continuously manages (identifies, analyses, assesses, estimates, mitigates) the cybersecurity-related risks of ICT (IT and OT) infrastructures, systems and services by planning, applying, reporting and communicating risk analysis, assessment and treatment. Establishes a risk management strategy for the organisation and ensures that risks remain at an acceptable level for the organisation, and the entities at the interfaces*, by selecting mitigation actions and controls.

* Very specific to Part-IS requirements, may not be relevant in OT domains other than aviation

Main Tasks	
ECSF original	Adapted
Develop an organisation's cybersecurity risk management strategy	Develop an organisation's cybersecurity risk management strategy, incorporating safety considerations, to identify and assess risks that could affect operational safety. This includes assessing potential safety risks arising from cyber threats and vulnerabilities in OT, and prioritising risk treatment options that effectively address both cybersecurity and operational safety risks.
Manage an inventory of organisation's assets	Maintain an inventory of the organisation's assets, taking into account safety critical systems and their dependencies. This involves identifying and categorising assets based on their safety impact to ensure that appropriate cybersecurity measures are applied to protect the integrity and operational safety of critical assets.
Identify and assess cybersecurity-related threats and vulnerabilities of ICT systems	Identify and assess cybersecurity-related threats and vulnerabilities of ICT (IT and OT) systems, focusing on their potential impact on operational safety. When assessing threats and vulnerabilities, consider safety-critical aspects such as system functionality, information and data integrity and availability.
Identification of threat landscape including attackers' profiles and estimation of attacks' potential	Identify the threat landscape, including adversary profiles and estimation of attacks' potential
Assess cybersecurity risks and propose most appropriate risk treatment options, including security controls and risk mitigation and avoidance that best address the organisation's strategy	Assess cybersecurity risks and propose most appropriate risk treatment options, including security controls and risk mitigation and avoidance that best address the organisation's strategy and safety requirements. This involves recommending security controls and risk mitigation strategies that effectively address both cybersecurity and operational safety objectives, ensuring a comprehensive risk management approach.

Main Tasks	
ECSF original	Adapted
Monitor effectiveness of cybersecurity controls and risk levels	Monitor the effectiveness of cybersecurity controls and continually assess risk levels from a safety perspective. Regularly assess the adequacy of controls in place to maintain operational safety, taking into account evolving threats and vulnerabilities.
Ensure that all cybersecurity risks remain at an acceptable level for the organisation's assets	Ensure that all cybersecurity risks remain at an acceptable level for the organisation and its interfaces, with a specific focus on operational safety. Continuously evaluate and reassess risks to ensure that safety-related risks are within acceptable limits and that cybersecurity measures do not compromise operational safety.
Develop, maintain, report and communicate complete risk management cycle	Develop, maintain, report and communicate the full risk management cycle, emphasising the safety implications of identified risks and risk treatment options. This includes providing clear and concise reports that highlight safety risks, control effectiveness, and ongoing efforts to align cybersecurity practices with operational safety objectives.

5.5 Cybersecurity Incident Responder

Summary statement

Monitor the organisation's cybersecurity state, handle incidents during cyber-attacks and assure the continued operations of ICT (IT and OT) systems.

Mission

Monitors and assesses systems' cybersecurity state. Analyses, evaluates and mitigates the impact of cybersecurity incidents. Identifies cyber incidents root causes and malicious actors. According to the organisation's Incident Response Plan, restores systems' and processes' functionalities to a safe and operational state, collecting evidences and documenting actions taken.

Main Tasks	
ECSF original	Adapted
Contribute to the development, maintenance and assessment of the Incident Response Plan	The safety aspect is crucial in any Incident Response Plan. It is essential to prioritise the return to an acceptable level of safety, preserving the integrity of the operations and minimising the potential harm for all individuals who may be affected by an incident or emergency situation.
Develop, implement and assess procedures related to incident handling	Develop, implement and assess procedures related to incident handling, with a strong focus on safety at every stage of the process.
Identify, analyse, mitigate and communicate cybersecurity incidents	Identify, analyse, mitigate and communicate cybersecurity incidents impacting safety
Assess and manage technical vulnerabilities	Assess and manage technical vulnerabilities with a safety-oriented approach. Address vulnerabilities that may pose risks to safety, and prioritise patching or mitigating those vulnerabilities to protect systems and users from potential harm.
Measure cybersecurity incidents detection and response effectiveness	Measure cybersecurity incident detection and response effectiveness, with a clear focus safety indicators. Evaluate how effectively incidents are detected and resolved while controlling the impact on the level of operational safety.
Evaluate the resilience of the cybersecurity controls and mitigation actions taken after a cybersecurity or data breach incident	Evaluate the resilience of cybersecurity controls and mitigating actions taken after a cybersecurity or data breach incident to ensure they maintain the necessary level of safety. Reassess controls from a safety perspective to prevent future incidents that could have safety impacts.
Adopt and develop incident handling testing techniques	Adopt and develop incident handling testing techniques that simulate real-world operational scenarios, including those that may have safety impacts. Test the effectiveness of safety measures and response procedures to continually improve incident handling capabilities.
Establish procedures for incident results analysis and incident handling reporting	Establish procedures for incident results analysis and incident handling reporting, emphasizing the importance of safety impact and lessons learned. Use incident data to enhance safety risk management and ensure better protection against potential future incidents.

Main Tasks	
ECSF original	Adapted
Document incident results analysis and incident handling actions	Document incident results analysis and incident handling actions, highlighting the impact on safety and lessons learned. Maintain detailed records to continuously improve safety measures and response strategies.
Cooperate with Secure Operation Centres (SOCs) and Computer Security Incident Response Teams (CSIRTs)	Cooperate with Secure Operation Centres (SOCs) and Computer Security Incident Response Teams (CSIRTs), while prioritising safety as a common goal. Collaborate to ensure timely and effective responses to incidents that may have an impact on safety.
Cooperate with key personnel for reporting of security incidents according to applicable legal framework	Cooperate with key personnel for reporting of security incidents according to applicable legal framework, ensuring that incidents with potential safety implications are reported promptly and accurately to the competent authorities.

6. Conclusions

The European Cybersecurity Certification Framework (ECSF) of the European Union Agency for Cybersecurity (ENISA) provides a valuable basis for identifying the cybersecurity profiles required in the aviation industry, as well as in other transport and industrial sectors. These sectors are characterised by the co-existence of IT and OT systems, where societal safety considerations significantly influence an organisation's risk appetite and the functioning of the security operations. In fact, the potential consequences of cyber incidents in the aviation, transport and industrial sectors go beyond financial losses and can directly impact lives, critical infrastructure operations and public confidence in the industry.

This exercise has demonstrated that the ECSF provides a professional framework that can be adapted to meet the unique requirements of the aviation and related sectors. By using the ECSF, organisations operating in these sectors may assess and identify specific cybersecurity profiles tailored to their unique environments. These profiles help to define the necessary security measures and controls, aligning them with the organisation's risk appetite and the overriding objective of ensuring societal safety.

The exercise has also shown that there might be cases of ECSF profiles covering more tasks than those resulting from the sector-specific requirements (e.g. Policy & Compliance Officer vs. Compliance Monitoring in Part IS). Such cases may be due to the need to comply with other requirements applicable at European level (e.g. the General Data Protection Regulation), therefore the organisation may decide to continue to consider these tasks for the role even if they are not sector specific.

In conclusion, the ENISA ECSF proves to be a useful tool in navigating the complex cybersecurity landscape of the aviation, transport and industrial sectors. ENISA may also consider the outcome of this exercise to introduce in future revision of the framework initial considerations on operational and safety related aspects.

ANNEX III — ANNEXES VI (PART-ARA) AND VII (PART-ORA) TO REGULATION (EU) No 1178/2011

For the consolidated version of Part-ARA and Part-ORA, please refer to the [Easy Access Rules for Aircrew \(Regulation \(EU\) No 1178/2011\)](#).

ANNEX IV — ANNEX I (PART 21) TO REGULATION (EU) No 748/2012

For the consolidated version of Annex I (Part 21) to Regulation (EU) No 748/2012, please refer to the [Easy Access Rules for Airworthiness and Environmental Certification \(Regulation \(EU\) No 748/2012\)](#).

ANNEX V — ANNEXES II (PART-ARO) AND III (PART-ORO) TO REGULATION (EU) No 965/2012

For the consolidated version of Part-ARO and Part-ORO, please refer to the [Easy Access Rules for Air Operations \(Regulation \(EU\) No 965/2012\)](#).

ANNEX VI — ANNEX II (PART-ADR.AR) TO REGULATION (EU) No 139/2014

For the consolidated version of Part-ADR.AR, please refer to the [Easy Access Rules for Aerodromes \(Regulation \(EU\) No 139/2014\)](#).

ANNEX VII — ANNEXES II (PART-145), III (PART-66) AND Vc (PART-CAMO) TO REGULATION (EU) No 1321/2014

For the consolidated version of Part-145, Part-66, and Part-CAMO, please refer to the [Easy Access Rules for Continuing Airworthiness](#).

ANNEX VIII — ANNEXES II (PART ATCO.AR) AND III (PART ATCO.OR) TO REGULATION (EU) 2015/340

For the consolidated version of Part ATCO.AR and Part ATCO.OR, please refer to [Easy Access Rules for Air Traffic Controllers' Licensing and Certification \(Regulation \(EU\) 2015/340\)](#).

ANNEX IX — ANNEXES II (PART-ATM/ANS.AR) AND III (PART-ATM/ANS.OR) TO IMPLEMENTING REGULATION (EU) 2017/373

For the consolidated version of Part-ATM/ANS.AR and Part-ATM/ANS.OR, please refer to [Easy Access Rules for Air Traffic Management/Air Navigation Services \(Regulation \(EU\) 2017/373\)](#).

DELEGATED REGULATION (EU) 2022/1645

COVER REGULATION

EXPLANATORY MEMORANDUM

Regulation (EU) 2022/1645

1. CONTEXT OF THE DELEGATED ACT

The current European aviation safety regulatory framework contains a series of requirements which are aimed at reducing the likelihood of an accident happening.

This combination of requirements allows that even if an error, mistake and/or deficiency happens, it should not create a hazardous situation that could result in an accident or serious incident. Consequently, an accident or serious incident would only happen in the remote random event of several deficiencies happening simultaneously and, by chance, aligning themselves.

The concern is that not enough focus may have been put in properly addressing the situation where existing flaws in different areas are aligned on purpose and exploited by individuals with a malicious intent, no longer being a random event. Such a risk is constantly increasing in the civil aviation environment as the current information systems are becoming more and more interconnected.

As a consequence, it is necessary to introduce requirements for the management of information security risks which could have a potential impact on aviation safety.

In the particular case of this Delegated Act, the provisions introduced increase the robustness of the management systems and reporting processes and procedures required by Annex II 'Essential requirements for airworthiness' and Annex VII 'Essential requirements for aerodromes' to Regulation (EU) 2018/1139¹ for design and production organisations, and for aerodrome operators and providers of apron management services.

2. CONSULTATIONS PRIOR TO THE ADOPTION OF THE ACT

In accordance with Article 128(4) of Regulation (EU) 2018/1139, before adopting a delegated act, the Commission shall consult experts designated by each Member State in accordance with the principles laid down in the Interinstitutional Agreement of 13 April 2016 on Better Law- Making. The draft delegated act was presented to the Air Safety experts group, which includes representatives from the Member States, at its meetings on 17 February and 29 June 2022. The present delegated act is based on EASA Opinion No 03/2021 which contents had been publicly consulted through Notice of Proposed Amendment (NPA) 2019-07 'Management of information security risks'² (RMT.0720), published by EASA on 27 May 2019.

3. LEGAL ELEMENTS OF THE DELEGATED ACT

Articles 19(1) and 39(1) of Regulation (EU) 2018/1139 empower the Commission to adopt delegated acts, in accordance with Article 128 of that Regulation, laying down detailed rules with regard to organisations responsible for the design and production of products, parts and non-installed equipment, and with regard to organisations responsible for the operation of aerodromes and for the provision of apron management services.

¹ Regulation (EU) 2018/1139 of the European Parliament and of the Council of 4 July 2018 on common rules in the field of civil aviation and establishing a European Union Aviation Safety Agency, and amending Regulations (EC) No 2111/2005, (EC) No 1008/2008, (EU) No 996/2010, (EU) No 376/2014 and Directives 2014/30/EU and 2014/53/EU of the European Parliament and of the Council, and repealing Regulations (EC) No 552/2004 and (EC) No 216/2008 of the European Parliament and of the Council and Council Regulation (EEC) No 3922/91 (OJ L 212, 22.8.2018, p. 1) (<https://eur-lex.europa.eu/legal-content/EN/TXT/?qid=1535612134845&uri=CELEX:32018R1139>).

² <https://www.easa.europa.eu/document-library/notices-of-proposed-amendment/npa-2019-07>

COMMISSION DELEGATED REGULATION (EU) 2022/1645**of 14 July 2022**

laying down rules for the application of Regulation (EU) 2018/1139 of the European Parliament and of the Council, as regards requirements for the management of information security risks with a potential impact on aviation safety for organisations covered by Commission Regulations (EU) No 748/2012 and No 139/2014 and amending Commission Regulations (EU) No 748/2012 and No 139/2014

Regulation (EU) 2022/1645

THE EUROPEAN COMMISSION,

Having regard to the Treaty on the Functioning of the European Union,

Having regard to [Regulation \(EU\) 2018/1139](#) of the European Parliament and of the Council of 4 July 2018 on common rules in the field of civil aviation and establishing a European Union Aviation Safety Agency, and amending Regulations (EC) No 2111/2005, (EC) No 1008/2008, (EU) No 996/2010, (EU) No 376/2014 and Directives 2014/30/EU and 2014/53/EU of the European Parliament and of the Council, and repealing Regulations (EC) No 552/2004 and (EC) No 216/2008 of the European Parliament and of the Council and Council Regulation (EEC) No 3922/91¹, and in particular Articles 19(1) point (g) and 39(1) point (b) thereof.

Whereas:

- (1) In accordance with the essential requirements set out in Annex II, point 3.1(b), to Regulation (EU) 2018/1139, design and production organisations are to implement and maintain a management system to manage safety risks.
- (2) In addition, in accordance with the essential requirements set out in Annex VII, points 2.2.1 and 5.2, to Regulation (EU) 2018/1139, aerodrome operators and organisations responsible for the provision of apron management services are to implement and maintain a management system to manage safety risks.
- (3) The safety risks referred to in recitals (1) and (2) may derive from different sources, including design and maintenance flaws, human performance aspects, environmental threats and information security threats. Therefore, the management systems implemented by the organisations as referred to in recitals (1) and (2), should take into account not only safety risks stemming from random events, but also safety risks deriving from information security threats where existing flaws may be exploited by individuals with a malicious intent. Those information security risks are constantly increasing in the civil aviation environment as the current information systems are becoming more and more interconnected, and increasingly becoming the target of malicious actors.
- (4) The risks associated with those information systems are not limited to possible attacks to the cyberspace, but encompass also threats which may affect processes and procedures as well as the performance of human beings.
- (5) A significant number of organisations already use international standards, such as ISO 27001, in order to address the security of digital information and data. These standards may not fully address all the specificities of civil aviation.
- (6) Therefore, it is appropriate to set out requirements for the management of information security risks with a potential impact on aviation safety.

¹ OJ L 212, 22.8.2018, p. 1.

- (7) It is essential that those requirements cover the different aviation domains and their interfaces since aviation is a highly interconnected system of systems. Therefore, they should apply to all the organisations that are already required to have a management system in accordance with the existing Union aviation safety legislation.
- (8) The requirements laid down in this Regulation should be consistently applied across all aviation domains, while creating a minimal impact on the Union aviation safety legislation already applicable to those domains.
- (9) The requirements laid down in this Regulation should be without prejudice to information security and cybersecurity requirements laid down in Point 1.7 of the Annex to Commission Implementing Regulation (EU) 2015/1998⁽¹⁾ and in Article 14 of Directive (EU) 2016/1148 of the European Parliament and of the Council⁽²⁾.
- (10) The definition on information security used for the purposes of this legal act should not be interpreted as divergent from the definition of security of network and information systems laid down in Directive 2016/1148.
- (11) In order to avoid duplication of legal requirements, where organisations covered by this Regulation are already subject to security requirements arising from other Union acts referred to in recital (9), which are, in their effect equivalent to the provisions laid down in this Regulation, compliance with those security requirements should be considered to constitute compliance with the requirements laid down in this Regulation.
- (12) Organisations covered by this Regulation that are already subject to security requirements arising from Regulation (EU) 2015/1998 should also comply with the requirements of Annex I (Part [IS.D.OR.230](#) "Information security external reporting scheme") to this Regulation as Regulation (EU) 2015/1998 does not contain any provisions related to external reporting of information security incidents.
- (13) Regulations (EU) No 748/2012⁽³⁾ and No 139/2014⁽⁴⁾ should be amended in order to establish the link between the management systems prescribed in the regulations listed above and the information security management requirements prescribed by this Regulation.
- (14) In order to provide organisations with sufficient time to ensure compliance with the new rules and procedures introduced by this Regulation, this Regulation should apply from 3 years after the date of entry into force.
- (15) The requirements laid down by this Regulation are based on Opinion No 03/2021⁽⁵⁾, issued by the Agency in accordance with Article 75(2) points (b) and (c) and Article 76(1) of Regulation (EU) 2018/1139.

¹ Commission Implementing Regulation (EU) 2015/1998 of 5 November 2015 laying down detailed measures for the implementation of the common basic standards on aviation security ([OJ L 299, 14.11.2015, p. 1](#)).

² Directive (EU) 2016/1148 of the European Parliament and of the Council of 6 July 2016 concerning measures for a high common level of security of network and information systems across the Union ([OJ L 194, 19.7.2016, p. 1](#)).

³ Commission Regulation (EU) No 748/2012 of 3 August 2012 laying down implementing rules for the airworthiness and environmental certification of aircraft and related products, parts and appliances, as well as for the certification of design and production organisations

⁴ Commission Regulation (EU) No 139/2014 of 12 February 2014 laying down requirements and administrative procedures related to aerodromes pursuant to Regulation (EC) No 216/2008 of the European Parliament and of the Council

⁵ <https://www.easa.europa.eu/document-library/opinions>

- (16) In accordance with Article 128(4) of Regulation (EU) 2018/1139, the Commission consulted experts designated by each Member State in accordance with the principles laid down in the Inter-institutional Agreement of 13 April 2016 on Better Law-Making¹,

HAS ADOPTED THIS REGULATION:

Article 1 – Subject matter

Regulation (EU) 2022/1645

This Regulation sets out the requirements to be met by the organisations referred to in [Article 2](#) in order to identify and manage information security risks with potential impact on aviation safety which could affect information and communication technology systems and data used for civil aviation purposes and to detect information security events and identify those which are considered information security incidents with potential impact on aviation safety and respond to, and recover from, those information security incidents.

GM1 Article 1 — Subject matter

ED Decision 2023/008/R

When taking measures under this Regulation, affected entities — irrespective of their size — are encouraged to ensure that the measures they take are proportionate to the nature and safety risk of their activities.

Article 2 – Scope

Regulation (EU) 2025/22

1. This Regulation applies to the following organisations:
 - (a) production organisations and design organisations subject to Subparts G and J of Section A of Annex I (Part 21) to [Regulation \(EU\) No 748/2012](#), except design and production organisations that are solely involved in the design and/or production of ELA2 aircraft as defined in Article 1(2), point (j) of Regulation (EU) No 748/2012;
 - (b) aerodrome operators and apron management service providers subject to Annex III ‘Part Organisation Requirements (Part-ADR.OR)’ to [Regulation \(EU\) No 139/2014](#).
 - (c) ground handling organisations subject to [Commission Delegated Regulation \(EU\) 2025/20](#)² that:
 - (i) in order to provide the respective services, have to collect, store, analyse or otherwise process data provided by third parties; or
 - (ii) provide directly to aircraft operators data that will be used for operational purposes.

[point (c) applicable from 27 March 2031 — Regulation (EU) 2025/22]
2. This Regulation is without prejudice to information security and cybersecurity requirements laid down in point 1.7 of the Annex to [Commission Implementing Regulation \(EU\) 2015/1998](#) and in Article 14 of [Directive \(EU\) 2016/1148](#) of the European Parliament and of the Council.

¹ OJ L 123, 12.5.2016, p. 1.

² Commission Delegated Regulation (EU) 2025/20 of 19 December 2024 supplementing Regulation (EU) 2018/1139 of the European Parliament and of the Council by laying down requirements for the safe provision of ground handling services and for organisations providing them ([OJ L, 2025/20, 7.3.2025, EU: \[http://data.europa.eu/eli/reg_del/2025/20/oj\]\(http://data.europa.eu/eli/reg_del/2025/20/oj\)](#)).

Article 3 – Definitions

Regulation (EU) 2022/1645

For the purpose of this Regulation, the following definitions shall apply:

- (1) ‘information security’ means the preservation of confidentiality, integrity, authenticity and availability of network and information systems;
- (2) ‘information security event’ means an identified occurrence of a system, service or network state indicating a possible breach of the information security policy or failure of information security controls, or a previously unknown situation that can be relevant for information security;
- (3) ‘incident’ means any event having an adverse effect on the security of network and information systems as defined in Article 4(7) of Directive (EU) 2016/1148;
- (4) ‘information security risk’ means the risk to organisational civil aviation operations, assets, individuals, and other organisations due to the potential of an information security event. Information security risks are associated with the potential that threats will exploit vulnerabilities of an information asset or group of information assets;
- (5) ‘threat’ means a potential violation of information security which exists when there is an entity, circumstance, action or event that could cause harm;
- (6) ‘vulnerability’ means a flaw or weakness in an asset or a system, procedures, design, implementation, or information security measures that could be exploited and results in a breach or violation of the information security policy.

GM1 Article 3 — Definitions

ED Decision 2023/008/R

For the sake of common understanding, the following is a description of the terms used in the AMC & GM to Part-IS.D.OR of Commission Delegated Regulation (EU) 2022/1645 as well as in the AMC & GM to Part-IS.AR and Part-IS.I.OR of Commission Implementing Regulation (EU) 2023/203:

Assessment	In the context of management system performance monitoring, continuous improvement and oversight, it refers to a planned and documented activity performed by competent personnel to evaluate and analyse the achieved level of performance, effectiveness and maturity, as well as compliance in relation to the organisation’s policy and objectives. Note: An assessment focuses on required outcomes and the overall performance, looking at the organisation as a whole. The main objective of the assessment is to identify the strengths and weaknesses to drive continuous improvement. Remark: For ‘risk assessment’, please refer to the definition below.
Attack vector (or attack path)	The path, interface, and actions by which an attacker executes an attack, as defined in EUROCAE ED-202.
Audit	It refers to a systematic, independent, and documented process for obtaining evidence, and evaluating it objectively to determine the extent to which requirements are complied with.

	Note: Audits may include inspections.
Competency	It is a combination of individual skills, practical and theoretical knowledge, attitude, training, and experience.
Correction	It is the action to eliminate a detected non-compliance.
Corrective action	It is the action taken to eliminate or mitigate the root cause(s) and prevent the recurrence of an existing detected non-compliance or other undesirable conditions or situations. Proper determination of the root cause(s) is crucial for defining effective corrective actions to prevent reoccurrence.
Deficiency	It is as a deviation from compliance with or a non-fulfilment of any requirement or objectives, either from a regulatory or an organisation's perspective, either completely or partially.
Experience	It is the fact or state of having been affected by or gained knowledge and skills through observation, participation or doing.
Functional chain	The concept of functional chain dictates that information security risks are shared along organisations due to their respective interfaces, such as supplier-customer relationships. Safety effects caused by information security threats primarily materialise at aircraft level, originating upstream of the aircraft. In the functional chain concept, each organisation assesses its information security risks, which it may not be able to address and hence may expose other organisations to risks. It should pass related information to the immediate partner(s) downstream for well-informed risk management purposes and to ensure that the whole chain is adequately protected, even when no organisation has full visibility or control.
Hazard	It is a condition or an object with the potential to cause or contribute to an aircraft incident or accident.
Information security control	It is a measure that reduces risk.
Intentional unauthorised electronic interaction	It refers to the deliberate act of engaging in electronic activities or communications (e.g. access to, or modification of, computer systems, networks, or data) without proper authorisation or permission and with the intent to disclose sensitive information, modify data, disrupt normal operations, or deny access to legitimate users.
Just culture	It means a culture in which front-line operators or other persons are not punished for actions, omissions or decisions taken by them that are commensurate with their experience and training, but in which gross negligence, wilful violations and destructive acts are not tolerated, as defined in Article 2 of Regulation (EU) No 376/2014 ¹ .

¹ Regulation (EU) No 376/2014 of the European Parliament and of the Council of 3 April 2014 on the reporting, analysis and follow-up of occurrences in civil aviation, amending Regulation (EU) No 996/2010 of the European Parliament and of the Council and repealing Directive 2003/42/EC of the European Parliament and of the Council and Commission Regulations (EC) No 1321/2007 and (EC) No 1330/2007 (OJ L 122, 24.4.2014, p. 18) (<https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX%3A32014R0376&qid=1669377456448>).

Knowledge	Content of information needed to perform adequately in the job at an acceptable level, usually obtained through formal education and on-the-job experience. This knowledge is necessary for job performance but is not sufficient on its own.
Management (activity)	In the general organisational context, it refers to the activities aimed at directing, controlling, and continually improving the organisation within appropriate structures. In the context of Commission Delegated Regulation (EU) 2022/1645 and Commission Implementing Regulation (EU) 2023/203 it means, more specifically, the supervision and making of decisions necessary to achieve the organisation's safety and information security objectives.
Management system	It refers to a set of interrelated or interacting system elements to establish policies, objectives and processes to achieve those objectives, where the system elements include the organisational structure, roles and responsibilities, planning and operations.
Risk assessment	It is an evaluation that is based on engineering and operational judgement and/or analysis methods in order to establish whether the achieved or perceived risk is acceptable.
Risk register	It refers to a physical or digital means of documentation used as a risk management tool that acts as a repository for all identified risks and contains additional information about each risk, such as the nature of the risk, mitigation measures, ownership, status, etc.
Safety	It refers to the state in which risks associated with aviation activities, related to, or in direct support of the operation of aircraft, are reduced and controlled to an acceptable level, as defined in ICAO Annex 19.
Safety risk	It refers to the predicted likelihood and severity of the consequences or outcomes of a hazard. Note: The term 'likelihood' is used instead of the term 'probability' to reflect a subjective analysis of the possibility of occurrence rather than a purely statistical assessment.

Article 4 – Requirements arising from other Union legislation

Regulation (EU) 2022/1645

1. Where an organisation referred to in [Article 2](#) complies with security requirements laid down in Article 14 of Directive (EU) 2016/1148 of the European Parliament and of the Council that are equivalent to the requirements laid down in this Regulation, compliance with those security requirements shall be considered to constitute compliance with the requirements laid down in this Regulation.
2. Where an organisation referred to in [Article 2](#) is an operator or an entity referred to in the national civil aviation security programmes of Member States laid down in accordance with Article 10 of Regulation (EC) No 300/2008 of the European Parliament and of the Council¹, the

¹ Regulation (EC) No 300/2008 of the European Parliament and of the Council of 11 March 2008 on common rules in the field of civil aviation security and repealing Regulation (EC) No 2320/2002 (OJ L 97, 9.4.2008, p. 72).

cybersecurity requirements contained in Point 1.7 of the Annex to Implementing Regulation (EU) 2015/1998 are considered to be equivalent to the requirements laid down in this Regulation, except as regards point [IS.D.OR.230](#) of the Annex to this Regulation that shall be complied with.

3. The Commission, after consulting EASA and the Cooperation Group referred to in Article 11 of Directive (EU) 2016/1148, may issue guidelines for the assessment of the equivalence of requirements laid down in this Regulation and Directive (EU) 2016/1148.

GM1 Article 4(1) Requirements arising from other Union legislation

ED Decision 2025/013/R

Pursuant to Article 44 of [Directive \(EU\) 2022/2555](#) (the NIS 2 Directive), the previous Directive (EU) 2016/1148 (the NIS Directive) was repealed with effect from 18 October 2024. In accordance with the NIS2 Directive, references to the repealed Directive shall be construed as references to Directive (EU) 2022/2555 and shall be read in accordance with the correlation table set out in its Annex III.

In accordance with this table, references to Article 14 of Directive (EU) 2016/1148 shall be now read as references to Article 21 and Article 23 of Directive (EU) 2022/2555. For an exact correlation, please refer to Annex III to Directive (EU) 2022/2555.

To ensure legal certainty, the equivalence of any requirements should be assessed by the competent authority against the requirements of the national legislation when Directive (EU) 2022/2555 is transposed.

When utilising this equivalence, organisations should consider the following:

- The equivalence between [Regulation \(EU\) 2022/1645](#) and Directive (EU) 2022/2555 requirements as assessed by the competent authority.
- Possible differences in the perimeter of applicability of the rules, in particular as regards the elements that are within the scope under the two different frameworks.

The competent authority will decide whether or not the measures implemented by the organisation under the NIS framework can be considered sufficient for satisfying requirements of similar nature under this rule.

GM1 Article 4(2) Requirements arising from other Union legislation

ED Decision 2025/013/R

Notwithstanding the equivalence between the requirements in [Regulation \(EU\) 2022/1645](#) and the cybersecurity requirements contained in point 1.7 of the Annex to [Regulation \(EU\) 2015/1998](#), in order to ensure effective management of safety consequences by leveraging the requirements of Regulation (EU) 2015/1998, organisations need to consider the differences in the scope of the rules in terms of which elements are covered under the two different regulatory frameworks.

Taking the example of an airport operator, elements such as body scanners, X-ray machines and anti-RPAS systems fall under the scope of the requirements of point 1.7 of the Annex to Regulation (EU) 2015/1998. Elements such as runway lighting control systems and safety training databases fall under the scope of aviation safety rules. On the other hand, the protection of information and the verification of trustworthiness and identity can be considered element that overlap between the two frameworks.

Consequently, an organisation that has developed a system in accordance with point 1.7 of the Annex to Regulation (EU) 2015/1998 can use it to address safety issues by extending the scope of the system,

where necessary, to ensure that all safety-related elements are included. Moreover, compliance with point [IS.D.OR.230](#) has to be ensured.

Article 5 – Competent authority

Regulation (EU) 2025/22

1. The authority responsible for certifying and overseeing compliance with this Regulation shall be:
 - (a) with regard to organisations referred to in [Article 2](#), point (a), the competent authority designated in accordance with Annex I (Part 21) to [Regulation \(EU\) No 748/2012](#);
 - (b) with regard to organisations referred to in [Article 2](#), point (b), the competent authority designated in accordance with Annex III (Part-ADR.OR) to [Regulation \(EU\) No 139/2014](#).
 - (c) with regard to organisations referred to in [Article 2](#) point (c), the competent authority designated in accordance with the Annex (Part-ARGH) to [Commission Implementing Regulation \(EU\) 2025/23](#)¹.
- [point (c) applicable from 27 March 2031 — Regulation (EU) 2025/22]*
2. Member States, may for the purposes of this Regulation, designate an independent and autonomous entity to fulfil the assigned role and responsibilities of the competent authorities referred to in paragraph 1. In that case, coordination measures shall be established between that entity and the competent authorities, as referred to in paragraph 1, to ensure effective oversight of all the requirements to be met by the organisation.

GM1 Article 5(2) Competent authority

ED Decision 2025/013/R

The applicability of [Annex I](#) (Part-IS.AR) to [Implementing Regulation \(EU\) 2023/203](#) to competent authorities is specified in its [Article 4\(2\)](#) and called for under the authority requirements for a management system in the implementing or delegated act for each domain. Therefore, the Part-IS.AR requirements apply to the competent authority under [Article 5\(1\)](#) irrespective of the allocation of roles and responsibilities to an independent and autonomous entity designated by the State under [Article 5\(2\)](#).

At the same time, this independent and autonomous entity designated by the State is not subject to the Part-IS.AR requirements; this entity has only to fulfil the responsibilities for certifying and overseeing organisations' compliance with [Implementing Regulation \(EU\) 2023/203](#).

This entity typically holds the role of a national information security body within the Member State and is normally subject to similar requirements to those existing in Part-IS.AR.

Article 6 – Amendment to Regulation (EU) No 748/2012

Regulation (EU) 2022/1645

For the consolidated version of Annex I (Part 21) to Regulation (EU) No 748/2012, please refer to the [Easy Access Rules for Airworthiness and Environmental Certification \(Regulation \(EU\) No 748/2012\)](#).

¹ Commission Implementing Regulation (EU) 2025/23 of 19 December 2024 laying down rules for the application of Regulation (EU) 2018/1139 of the European Parliament and of the Council, as regards requirements for the oversight of ground handling services and organisations providing them ([OJ L, 2025/23, 7.3.2025, EU: http://data.europa.eu/eli/reg_impl/2025/23/oj](#)).

Article 7 – Amendment to Regulation (EU) No 139/2014

Regulation (EU) 2022/1645

For the consolidated version of Annex III (Part-ADR.OR) to Regulation (EU) No 139/2014¹, please refer to the [Easy Access Rules for Aerodromes \(Regulation \(EU\) No 139/2014\)](#).

Article 8

Regulation (EU) 2022/1645

This Regulation shall enter into force on the twentieth day following that of its publication in the *Official Journal of the European Union*.

It shall apply from 16 October 2025.

Regulation (EU) 2022/1645

This Regulation shall be binding in its entirety and directly applicable in all Member States.

Done at Brussels, 14 July 2022.

For the Commission

The President

Ursula VON DER LEYEN

¹ Commission Regulation (EU) No 139/2014 of 12 February 2014 laying down requirements and administrative procedures related to aerodromes pursuant to Regulation (EC) No 216/2008 of the European Parliament and of the Council ([OJ L 44, 14.2.2014, p. 1](#)).

ANNEX — ORGANISATION REQUIREMENTS (PART-IS.D.OR)

IS.D.OR.100 Scope

Regulation (EU) 2022/1645

This Part establishes the requirements to be met by the organisations referred to in [Article 2](#) of this Regulation.

IS.D.OR.200 Information security management system (ISMS)

Regulation (EU) 2025/22

- (a) In order to achieve the objectives set out in [Article 1](#), the organisation shall set up, implement and maintain an information security management system (ISMS) which ensures that the organisation:
- (1) establishes a policy on information security setting out the overall principles of the organisation with regard to the potential impact of information security risks on aviation safety;
 - (2) identifies and reviews information security risks in accordance with point [IS.D.OR.205](#);
 - (3) defines and implements information security risk treatment measures in accordance with point [IS.D.OR.210](#);
 - (4) implements an information security internal reporting scheme in accordance with point [IS.D.OR.215](#);
 - (5) defines and implements, in accordance with point [IS.D.OR.220](#), the measures required to detect information security events, identifies those events which are considered incidents with a potential impact on aviation safety, and responds to, and recovers from, those information security incidents;
 - (6) implements the measures that have been notified by the competent authority as an immediate reaction to an information security incident or vulnerability with an impact on aviation safety;
 - (7) takes appropriate action, in accordance with point [IS.D.OR.225](#), to address findings notified by the competent authority;
 - (8) implements an external reporting scheme in accordance with point [IS.D.OR.230](#) in order to enable the competent authority to take appropriate actions;
 - (9) complies with the requirements contained in point [IS.D.OR.235](#) when contracting any part of the activities referred to in point [IS.D.OR.200](#) to other organisations;
 - (10) complies with the personnel requirements laid down in point [IS.D.OR.240](#);
 - (11) complies with the record-keeping requirements laid down in point [IS.D.OR.245](#);
 - (12) monitors compliance of the organisation with the requirements of this Regulation and provides feedback on findings to the accountable manager or, in the case of design organisations, to the head of the design organisation, in order to ensure effective implementation of corrective actions;

- (13) protects, without prejudice to applicable incident reporting requirements, the confidentiality of any information that the organisation may have received from other organisations, according to its level of sensitivity.
- (b) In order to continuously meet the requirements referred to in [Article 1](#), the organisation shall implement a continuous improvement process in accordance with point [IS.D.OR.260](#).
- (c) The organisation shall document, in accordance with point [IS.D.OR.250](#), all key processes, procedures, roles and responsibilities required to comply with point IS.D.OR.200(a) and establish a process for amending that documentation. Changes to those processes, procedures, roles and responsibilities shall be managed in accordance with point [IS.D.OR.255](#).
- (d) The processes, procedures, roles and responsibilities established by the organisation in order to comply with point IS.D.OR.200(a) shall correspond to the nature and complexity of its activities, based on an assessment of the information security risks inherent to those activities, and may be integrated within other existing management systems already implemented by the organisation.
- (e) Without prejudice to the obligation to comply with the reporting requirements contained in [Regulation \(EU\) No 376/2014](#)¹ and the requirements of point IS.D.OR.200(a)(13), the organisation may be granted approval by the competent authority not to implement the requirements referred to in points (a) to (d)) and the related requirements contained in points IS.D.OR.205 through IS.D.OR.260, if it demonstrates to the satisfaction of that authority that its activities, facilities and resources, as well as the services it operates, provides, receives and maintains, do not pose any information security risks with a potential impact on aviation safety neither to itself nor to other organisations. The approval shall be based on a documented information security risk assessment carried out by the organisation or a third party in accordance with point IS.D.OR.205 and reviewed and approved by its competent authority.

The continued validity of that approval will be reviewed by the competent authority following the applicable oversight audit cycle and whenever changes are implemented in the scope of work of the organisation.

GM1 IS.D.OR.200 Information security management system (ISMS)

ED Decision 2025/014/R

An **information security management system (ISMS)** is a systematic approach to establish, implement, operate, monitor, review, maintain and continuously improve the state of information security of an organisation. Its objective is to protect the information assets, such that the operational and safety objectives of an organisation can be reached in a risk-aware, effective and efficient manner.

Generally speaking, an ISMS establishes an information security risk management process, based upon the results of information security impact analyses, which basically determine its scope. If information security breaches may cause or contribute to aviation safety consequences, information security requirements need to limit the impact or influence of information security breaches on levels of aviation safety, which are deemed acceptable. Hence, all roles, processes, or information systems, which may cause or contribute to aviation safety consequences, are within the scope of [Regulation \(EU\) 2022/1645](#). The ISMS provides for means to decide on needed information security controls for

¹ Regulation (EU) No 376/2014 of the European Parliament and of the Council of 3 April 2014 on the reporting, analysis and follow-up of occurrences in civil aviation, amending Regulation (EU) No 996/2010 of the European Parliament and of the Council and repealing Directive 2003/42/EC of the European Parliament and of the Council and Commission Regulations (EC) No 1321/2007 and (EC) No 1330/2007 ([OJ L 122, 24.4.2014, p. 18](#)).

all architectural layers (governance, business, application, technology, data) and domains (organisational, human, physical, technical). It further allows to manage the selection, implementation, and operation of information security controls. Finally, it allows to manage the governance, risk management and compliance (GRC) within the ISMS scope.

The overall risk assessment considers safety consequences influenced by information security risks. These may emerge as threats, hazards, escalation factors that weaken barriers, or direct triggers of existing hazards. When conducting this assessment, both aspects, information security and safety need to be coordinated throughout the process. This ensures mutual understanding of the objectives and the implementation of preventive measures against all types of threats or weaknesses, as well as mitigating measures.

The risk management process is thus based on aviation safety risk assessments and derived information security risk acceptance levels, which are designed to effectively treat and manage information security risks with a potential impact on aviation safety caused by threats exploiting vulnerabilities of information assets in aeronautical systems.

Interacting bow-ties is one possible way that allows for a higher level and non-exhaustive illustration of how different disciplines of risk assessment may need to collaborate to establish a common risk perspective. The below Figure 1 from ICAO Doc 10204 ‘Manual on Aviation Information Security’ illustrates these interactions.

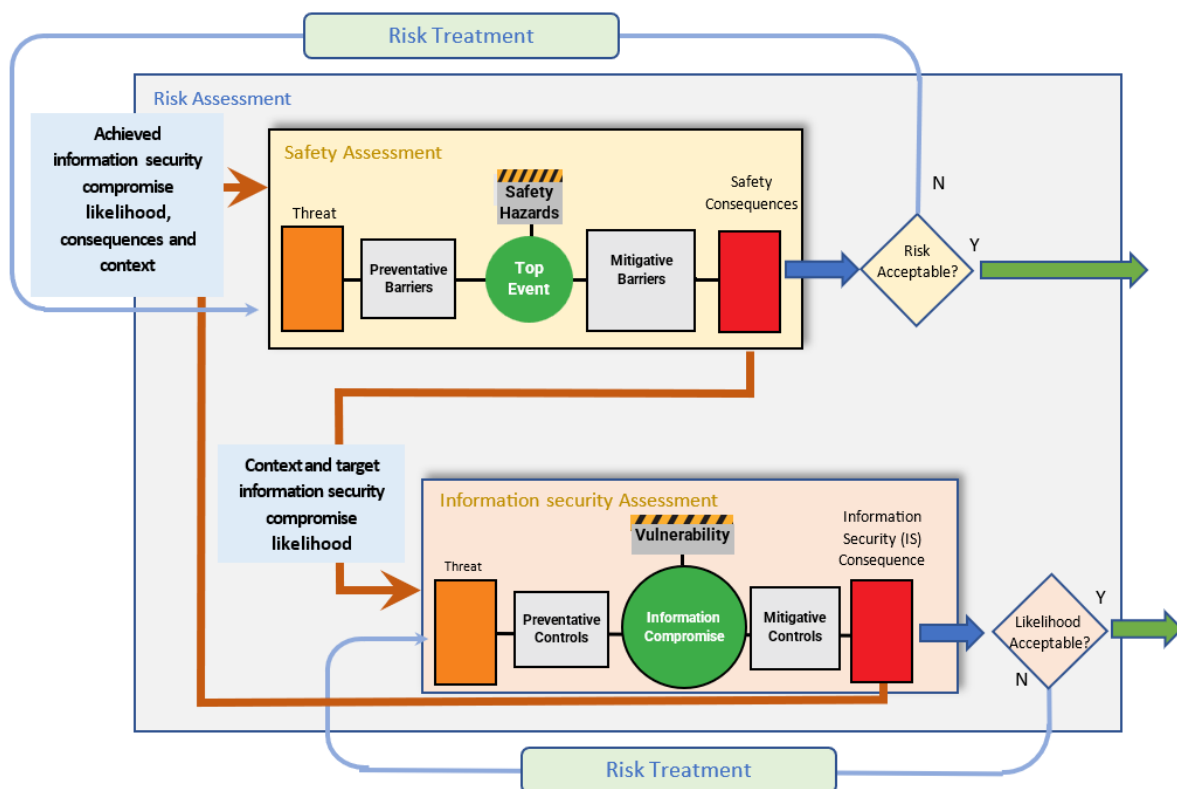


Figure 1: Bow-tie representation of management of aviation safety risks posed by information security threats

In the drawing, the term ‘context’ in the communication between the safety assessment process (SAP) and the information security assessment process (ISAP) carries slightly different notions, which need to be understood and distinguished.

In order to satisfy the safety requirements, the SAP will provide **context information** such as:

- the architecture of the systems and the functional descriptions of the elements within the scope, including those related to the barriers. Systems should be understood as the dynamic interaction between people, processes, and products or services;
- all identified relevant safety hazards;
- the top events and their relations (e.g. triggers) to those hazards.

In addition to context information, it provides the target likelihood of the related information security successful compromise. This target likelihood is commensurate with the safety objectives related to the severity of the safety consequence. However, it needs to be complemented to include information about the acceptable level of uncertainty, in order to be able to rely adequately on the results of the ISAP.

In turn, the ISAP will return **context information** such as:

- modification to the architecture of the systems and functional descriptions of the elements modified or added, whether those were safety barriers or other items;
- additional threats;
- potentially additional safety hazards;
- additional direct triggers of hazards;
- additional escalating factors affecting barriers.

In addition to context information, it provides the achieved likelihood of an information security successful compromise. While this likelihood is consistent with the safety objectives set by the SAP, the achieved level of uncertainty also needs to be considered.

The interaction between SAP and ISAP is iterative and continues until the safety risk is acceptable, i.e. the target likelihood of the related information security successful compromise has been achieved. The interaction can start from safety consequences identified through the SAP that fall within the scope of the ISMS risk analysis, or from existing information security assessments.

ISMS implementation and maintenance

An ISMS, as defined in this Regulation, employs the perspectives of governance, risk and compliance, and an approach that combines the safety risk and performance dimensions to determine the information security controls that are appropriate and compliant with the specific context and can effectively provide the level of protection required to achieve the aviation safety objectives by:

- **Governance** perspective refers to providing management direction and leadership aimed to achieve the entity's own overarching objectives:
 - leadership and commitment of the senior management defining and ensuring the close involvement of the management and a 'top-down' ISMS implementation
 - information security and safety objectives aligned and consistent with the entity's business objectives and monitored by, e.g., management reviews
 - information security policies stating the principles and objectives to be achieved
 - roles, responsibilities, competencies and resources required for an effective ISMS
 - effective, target-group-oriented communication to internal and external stakeholders

- **Risk** perspective refers to a key aspect of an ISMS in an aviation safety context according to this Regulation and serves as a basis for transparent decision-making and prioritisation of controls and risk treatment options. It further refers to the assessment, treatment and monitoring of information security risks in support of the management of aviation safety risks for the key processes and information assets upon which they depend. This includes protection requirements, risk exposure, attitude towards risks and risk acceptance criteria, methods and industry standards.
- **Compliance** perspective refers to the compliance with regulatory, legal and contractual requirements. This includes:
 - this Regulation,
 - the entity's own policies and standards and may further include international or industry standards adopted by the entity from ISO, EUROCAE, etc.

This perspective comprises the definition, implementation and maintenance of the required information security provisions whose effectiveness and compliance should be regularly monitored and assured by, e.g. (internal) audits.

Based on these perspectives we may identify the following processes or subject areas that have been shown to be relevant for the establishment of an effective ISMS. These ISMS processes and subject areas can be summarised as follows:

- (a) context establishment defining the scope, interfaces, dependencies and requirements of interested parties;
- (b) leadership and commitment of the senior management;
- (c) information security and safety objectives;
- (d) information security policies;
- (e) roles, responsibilities, competencies and resources required for an effective ISMS;
- (f) communication to internal and external stakeholders to achieve a sufficient level of information security awareness and training of all involved parties;
- (g) information security risk management including risk assessment and treatment;
- (h) information security incident management establishing processes for the handling of information security incidents and vulnerabilities;
- (i) performance & effectiveness monitoring, measurement and evaluation;
- (j) internal audits and management reviews;
- (k) corrections and corrective actions;
- (l) continuous improvement;
- (m) relationship with suppliers;
- (n) documentation, record-keeping, and evidence collection.

Additional critical success factors for the implementation and operation of an ISMS include the following:

- The ISMS should be integrated with the entity's processes and overall management structure or even — at least partially, with safeguards for their respective integrity, and as reasonably

applicable — with an overarching management system comprising information security, aviation safety and quality management.

- Information security has to be considered at an early stage in the overall design of processes and procedures, of systems and of information security controls, to be seamlessly integrated, for maximum effectiveness, minimal functional interference and optimised cost. None of these benefits can be achieved by integrating it on later.
- The risk management process determines appropriate characteristics of preventive controls to reach and maintain acceptable risk levels.
- The incident management process ensures that the organisation detects, reacts and responds to information security incidents in a timely manner. This is achieved by defining responsibilities, procedures, scenarios and response plans in advance to ensure a coordinated, targeted and efficient response.
- Continuous monitoring and reassessment are undertaken and improvements are made in response.

The above-mentioned core components are related to the requirements in this Regulation, for which Figure 2 provides a high-level depiction of the aspects that are more prominent in the implementation phase and those that characterise the operational phase, as well as the review and possible improvement, if the functions do not perform as planned

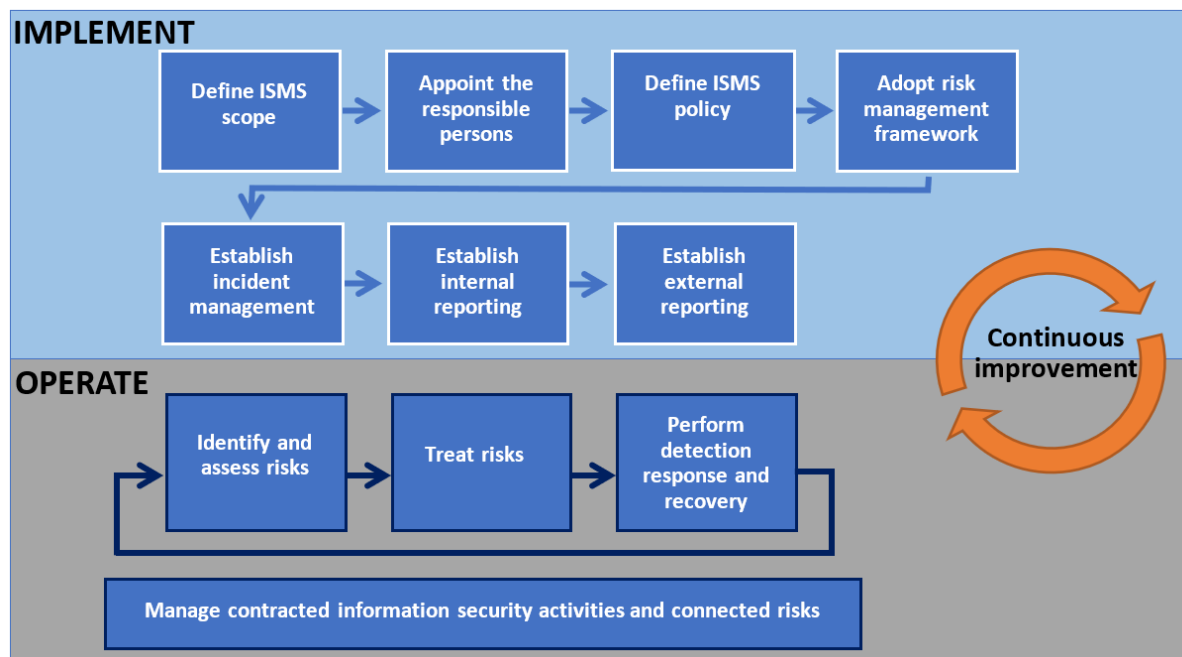


Figure 2: Representation of the Part-IS requirements from an ISMS's life cycle perspective

Plan-Do-Check-Act approach

The Plan-Do-Check-Act (PDCA) refers to a process approach that is often used to establish, implement, operate, monitor, review and improve management systems. Figure 3 depicts the PDCA applied to an ISMS.

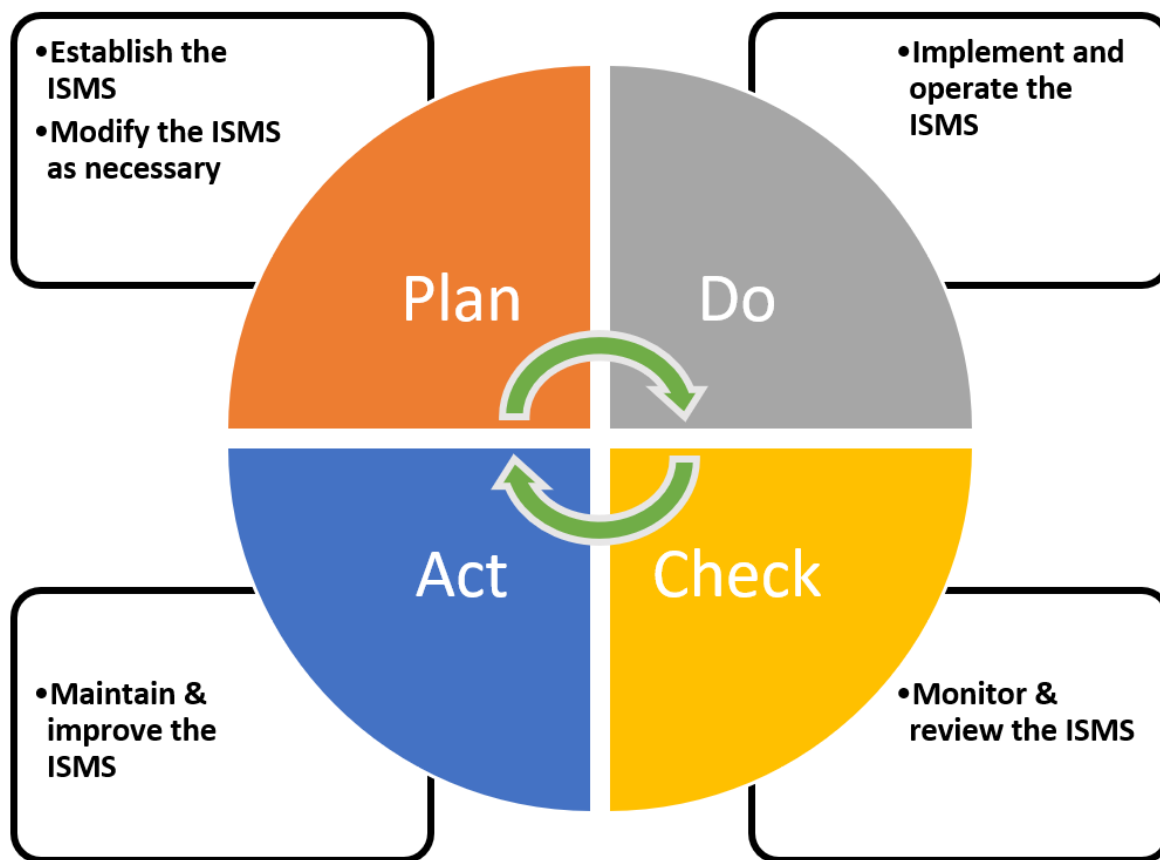


Figure 3: Plan-Do-Check-Act approach applied to an ISMS

Benefits of an ISMS

The benefits of a management system operating in a dynamic, uncertain or unpredictable risk environment are realised in the long term only when the organisation improves existing controls, processes and solutions based on the assessments of risks, performance and maturity as well as on the learnings from incidents, audits, non-conformities and their root causes. A successful adoption and deployment of an ISMS allows an entity to:

- achieve greater assurance to the management and interested parties that its information assets are adequately protected against threats on a continual basis;
- increase its trustworthiness and credibility providing confidence to interested parties that information security risks with an impact on aviation safety are adequately managed;
- increase the resilience of the entity's key processes against unauthorised electronic interactions and maintains the entity's ability to decide and act;
- support the timely detection of control gaps, vulnerabilities or deficiencies aimed to prevent information security incidents or at least to minimise their impact;
- detect and timely react to changes in the entity's environment including system architecture and threat landscape or the adoption of new technologies;

- provide a foundation for effective and efficient implementation of a comprehensive information security strategy in times of digital transformation, increasing interconnectivity of systems, emerging information security threats and new technologies.

Relation to ISO/IEC 27001

The international standard ISO/IEC 27001 is a widely adopted standard for ISMS which specifies generic requirements for establishing, implementing, maintaining and continually improving an ISMS. It also includes requirements for the assessment and treatment of information security risks. The requirements are applicable to all entities, regardless of type, size or nature. The conformity of an ISMS with the ISO/IEC 27001 standard can be certified by an accredited certification body. ISO/IEC 27001 is compatible with other management system standards (quality, safety, etc.) that have also adopted the structure and terms defined in Annex SL to ISO/IEC Directives, Part 1, Consolidated ISO Supplement. This compatibility allows an entity to operate a single management system that meets the requirements of multiple management system standards.

ISO/IEC 27001 allows entities to define their own scope of audit and their own organisational risk appetite. This, in turn, leads to information security requirements that provide the ISMS with criteria for the acceptability of information security risks in line with the entity's risk appetite (see Figure4).

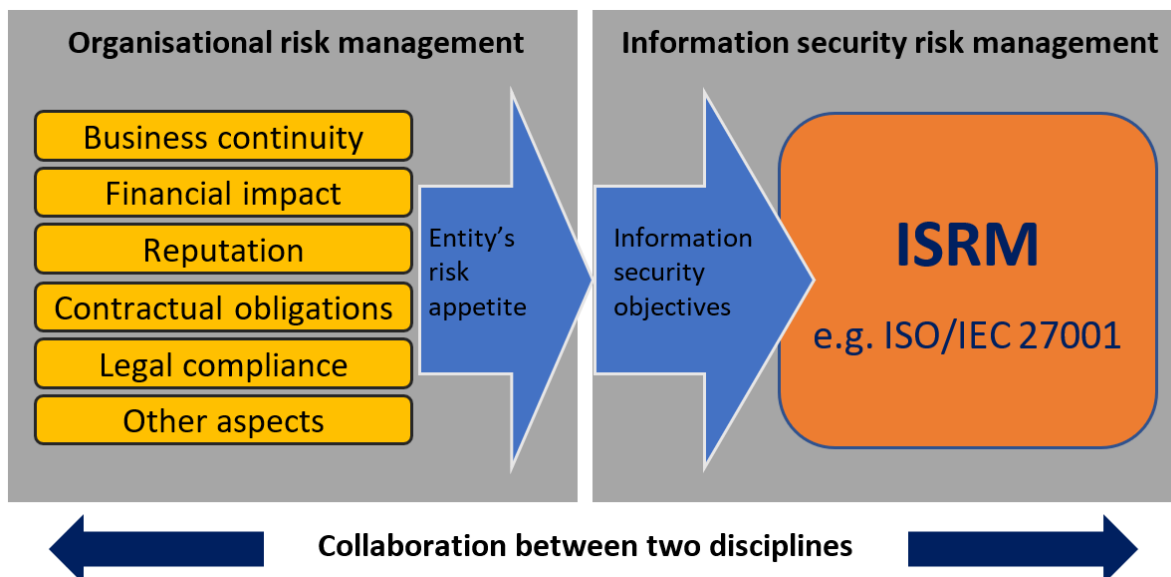


Figure 4: Relation between the entity's risk appetite and the information security objectives

The requirements for an ISMS specified by this Regulation are in most parts consistent and aligned with ISO/IEC 27001; however, this Regulation introduces provisions specific to the context of aviation safety. If an ISO/IEC 27001-based ISMS is already operated by an entity for a different scope and context, it can be adapted and extended to the scope and context of this Regulation in a straightforward manner based on an analysis of the scope and the gaps. In order to take credit from ISO/IEC 27001 certifications to achieve compliance with Part-IS, aviation safety needs to be included in the organisational risk management, with the relevant risk acceptance level determined by the applicable regulation (see Figure 5). Therefore, careful determination of the scope of the ISMS related to aviation safety risks is needed, as it might differ from the one related to the other organisational risks. To allow demonstration of compliance with Regulation (EU) 2022/1645, careful delineation

between aspects of the ISMS related to aviation safety risks and other organisational risks may be required. This could have an influence upon the decision to integrate ISMSs.

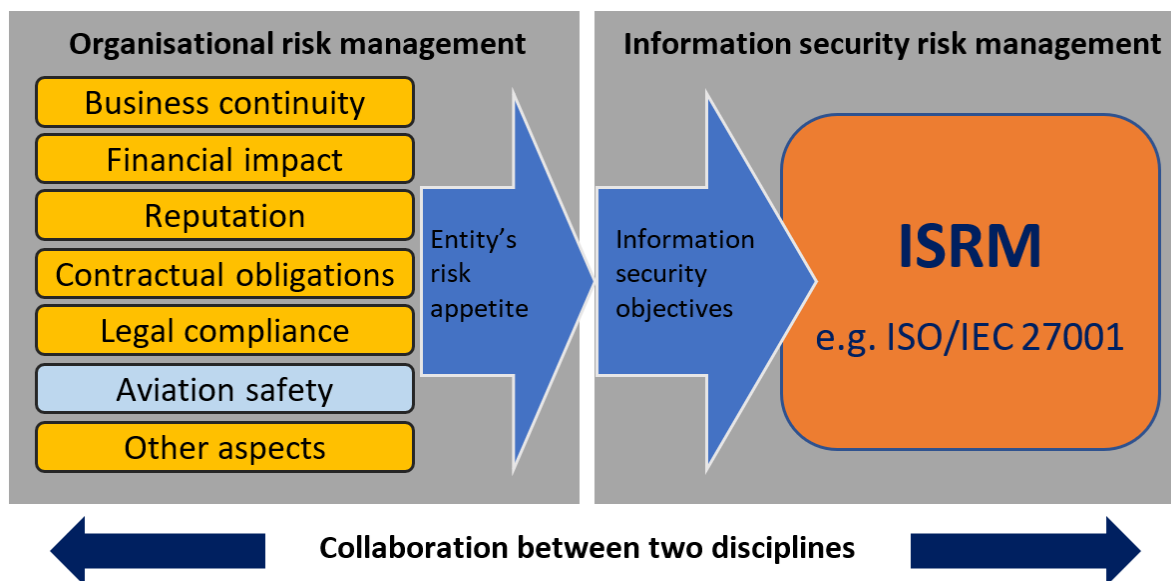


Figure 5: Introduction of aviation safety aspects in the entity's risk appetite

PART-IS versus ISO/IEC 27001 cross reference table

For a mapping between the Part-IS provisions and the clauses and associated controls in ISO/IEC 27001:2022, refer to [Appendix IV](#).

AMC1 IS.D.OR.200(a)(1) Information security management system (ISMS)

ED Decision 2023/009/R

The organisation should define and document the scope of the ISMS, by determining activities, processes, supporting systems, and identifying those which may have an impact on aviation safety.

The information security policy should be endorsed by the accountable manager or, in the case of design organisations, by the head of the design organisation, and reviewed at planned intervals or if significant changes occur. Moreover, the policy should cover at least the following aspects with a potential impact on aviation safety by:

- committing to comply with applicable legislation, consider relevant standards and best practices;
- setting objectives and performance measures for managing information security;
- defining general principles, activities, processes for the organisation to appropriately secure information and communication technology systems and data;
- committing to apply ISMS requirements into the processes of the organisation;
- committing to continually improve towards higher levels of information security process maturity as per [IS.D.OR.260](#);

- (f) committing to satisfy applicable requirements regarding information security and its proactive and systematic management and to the provision of appropriate resources for its implementation and operation;
- (g) assigning information security as one of the essential responsibilities for all managers;
- (h) committing to promote the information security policy through training or awareness sessions within the organisation to all personnel on a regular basis or upon modifications;
- (i) encouraging the implementation of a 'Just-Culture' and the reporting of vulnerabilities, suspicious/anomalous events and/or information security incidents;
- (j) committing to communicate the information security policy to all relevant parties, as appropriate.

Note: A significant change is a notable alteration or modification that has a meaningful impact on the organisation's operations, such as a structural change within the organisation due to reorganisations, a change in the business processes (e.g. working from home, use of personal devices), a technological evolution (e.g. distributed computing resources, artificial intelligence/machine learning) or an evolution in the threat landscape.

GM1 IS.D.OR.200(a)(1) Information security management system (ISMS)

ED Decision 2023/009/R

INFORMATION SECURITY POLICY AND OBJECTIVES

The information security policy should suit to the organisation's purpose and direct its own information security activities. Such policy should contain the needs for information security in the organisation's context, a high-level statement of direction and intent of the information security activities, the principles and most important strategic and tactical objectives to be achieved by the ISMS, as well as the general information security objectives or a specification of a framework (who, how) for setting information security objectives. The information security policy should also contain a description of the established ISMS including roles, responsibilities and references to topic-specific policies and standards.

The information security objectives should be:

- consistent and aligned with the information security policy and consider the applicable information security requirements, derived from the overarching organisation's objectives, and the results from the risk assessment and treatment (which, in turn, supports the implementation of the organisation's strategic goals and information security policy);
- regularly reviewed to ensure that they are up to date and still appropriate;
- measurable if practicable (to be able to determine whether the objective has been met), aimed to be SMART (specific, measurable, attainable, realistic, timely) and aligned with all affected responsible persons.

When defining information security objectives, e.g., based on the overarching organisation's objectives, the information security requirements or the results of risk assessments, it should be determined how these objectives will be achieved. The degree to which IS objectives are achieved must be measurable. If possible, it should be measured by key performance indicators (KPIs) which have been defined in advance (refer to resources such as COBIT 5 for Information Security). It is recommended to start with the definition of a limited number of information security objectives which

are relevant for the entity, more of a long-term nature and measurable with a reasonable effort relative to the delivered benefits.

AMC1 IS.D.OR.200(a)(12) Information security management system (ISMS)

ED Decision 2023/009/R

COMPLIANCE MONITORING

When establishing compliance with the provisions under points [IS.D.OR.200\(a\)\(12\)](#) the organisation should implement a function to periodically monitor compliance of the management system with the relevant requirements and adequacy of the procedures including the establishment of an internal audit process and an information security risk management process. When the organisation has already established a compliance monitoring function under the implementing regulation for its domain, such function should include the monitoring of the management system with the relevant requirements within the scope of its activities. Compliance monitoring should include a feedback mechanism of audit findings to the accountable manager or, in the case of design organisations, to the head of the design organisation, or delegated persons to ensure implementation of corrective actions as necessary.

GM1 IS.D.OR.200(a)(12) Information security management system (ISMS)

ED Decision 2023/009/R

COMPLIANCE MONITORING

For the purpose of compliance monitoring, internal audits should be conducted at planned intervals to provide assurance on the status of the ISMS to the management and to provide information on the following:

- conformity of the ISMS to the requirements of this Regulation and the organisation's own requirements either stated in the information security policy, procedures and contracts or derived from information security objectives or outcomes of the risk treatment process;
- effective implementation and maintenance of the ISMS.

Internal audits should follow an independent approach and a decision-making process based on evidences. Moreover, when setting up an audit programme the importance of the processes concerned, and definitions of the audit criteria and scopes should be considered. Documented information should be retained evidencing the audit results, their reporting to the relevant management and the audit programme.

AMC1 IS.D.OR.200(a)(13) Information security management system (ISMS)

ED Decision 2023/009/R

When establishing compliance with the provisions under points [IS.D.OR.200\(a\)\(13\)](#), the organisation should implement and maintain information security controls that are sufficiently robust and effective to protect information and ensure the need-to-know principle (i.e. limiting access to information to only those who need it to perform their duties). It should protect the source of information in

accordance with the relevant provisions established in Regulation (EU) 2018/1139. It should also comply with Regulation (EU) No 376/2014.

AMC1 IS.D.OR.200(c) Information security management system (ISMS)

ED Decision 2023/009/R

When establishing compliance with the provisions under point [IS.D.OR.200\(c\)](#), the organisation should:

- (a) provide an outline of the structure of the specific information security personnel (internal and external), including their roles and responsibilities. This outline of the structure will be used to manage and maintain the elements included within the scope of the ISMS and will be approved by the accountable manager or, in the case of design organisations, by the head of the design organisation. The organisation should review the outline of the structure at planned intervals or if significant changes occur (see the Note in [AMC1 IS.D.OR.200\(a\)\(1\)](#));
- (b) identify and categorise all relevant contracted organisations used to implement the ISMS. The organisation should define and document procedures for the management of interfaces and coordination between the organisation and other organisations, including contracted organisations;
- (c) identify and define all key processes and procedures, and internal and external reporting schemes that will be used to maintain compliance with the objectives of this Regulation over the life cycle of the ISMS. The organisation may adjust existing processes or procedures for compliance;
- (d) identify and document any other information that will be used to maintain compliance with the objectives of this Regulation;
- (e) when creating and updating documented information, ensure appropriate identification and description (e.g. a title, date, author, or reference number) as well as a review and an approval for suitability and adequacy;
- (f) control the documented information required by the ISMS to ensure that it is:
 - (1) available and suitable for use, where and when it is needed;
 - (2) adequately protected (e.g. from loss of confidentiality, improper use, or loss of integrity).

GM1 IS.D.OR.200(c) Information security management system (ISMS)

ED Decision 2023/009/R

The amount of information that should be documented to maintain compliance with the objectives of this Regulation may vary between organisations due to various factors, such as size and complexity, or the need for harmonisation with other management processes already in place. As general guidance, taking into account the documents required to comply with point [IS.D.OR.200\(a\)](#), the record-keeping requirements referred to in [IS.D.OR.245](#) and the information security management manual requirements referred to in [IS.D.OR.250](#), the following is a non-exhaustive list of information that should be documented:

- (a) information security policy that should include the organisation's information security objectives — see IS.D.OR.200(a)(1);
- (b) responsibilities and accountabilities for roles relevant to information security — see IS.D.OR.250(a)(2), (3), (6) and (7) and the personnel requirements referred to in points [IS.D.OR.240](#)(a), (b), (c), (d) and (f) and the related AMC and GM;
- (c) scope of the ISMS and the interfaces with, and dependencies on, other parties — see IS.D.OR.200(a)(2) and the information security requirements referred to in points [IS.D.OR.205](#)(a) and (b);
- (d) information security risk management process — see the information security requirements referred to in points IS.D.OR.205 and [IS.D.OR.210](#);
- (e) archive of the risks identified in the information security risk assessment along with the associated risk treatment measures (often referred to as 'risk register' or 'risk ledger') — see IS.D.OR.245;
- (f) evidence of the competencies necessary for the personnel performing the activities required under this Regulation — see IS.D.OR.240(g) and the related AMC and GM;
- (g) evidence of the current competencies of the personnel performing the activities required under this Regulation — see IS.D.OR.245(b)(1);
- (h) (key) performance indicators derived from evidence of the monitoring and measurement of the ISMS processes.

GM1 IS.D.OR.200(d) Information security management system (ISMS)

ED Decision 2025/014/R

PROPORTIONALITY IN ISMS IMPLEMENTATION

When implementing the processes and procedures, as well as establishing the roles and responsibilities required under point [IS.D.OR.200](#)(d), the organisation should primarily consider the risks that it may be posing to other organisations, as well as its own risk exposure. Other aspects that may be relevant include the organisation's needs and objectives, information security requirements, its own processes and the size, complexity and structure of the organisation, all of which may change over time.

As a general guide, the following aspects of the degree of safety relevance and organisational complexity could be taken into account when defining the ISMS. Each of these influences the implementation of the ISMS in certain areas:

- (a) The organisation's position in the functional chain and the number and degree of safety relevance of the interfacing organisations/stakeholders.
- (b) The complexity of the organisational structure and hierarchies (e.g. number of staff, departments, hierarchical layers, external location, subsidiaries, etc.)
- (c) The complexity of the information and communication technology systems and data used by the organisation and their connection to external parties.

More details on the influence on the proportionate implementation of Part-IS for each aspect of safety relevance and organisational complexity are provided in [Appendix V](#).

SUPPORTED IMPLEMENTATION OF THE ISMS

In the context of Part-IS, all organisations initiate the implementation of an ISMS with determining its scope, which in turn is based upon at least an assessment of aviation safety impacts for which information security incidents are a cause or a contributing factor. Organisations, irrespective of their size, may not have yet sufficient knowledge about their information security risks, and may consider seeking support by a service provider that can also provide additional personnel and expertise during this implementation phase of the ISMS. The same may apply to later phases of the ISMS implementation, and to this end organisations may want to consider the provision of [IS.D.OR.235](#) and related AMC. Outsourcing specific ISMS functions, such as information security monitoring or incident response to service providers, may help ensure that the organisation has access to experienced personnel and expertise. Similarly, organisations may want to be supported by a service provider in performing risk assessments.

Regarding the establishment of the appropriate personnel to implement and comply with the provisions of this Regulation, organisations should always refer to [AMC1 IS.D.OR.240\(f\)](#) and [GM1 IS.D.OR.240\(f\)](#), by considering that multiple responsibilities may be assigned to one person, while always ensuring the independence of the compliance monitoring.

As an introduction to the nature of information security risks and their management, organisations may use, as initial guidance, the NIST Interagency Report (NISTIR 7621 Rev.1) ‘Small Business Information Security: The Fundamentals’.

INTEGRATION OF ISMS UNDER THIS REGULATION WITH EXISTING MANAGEMENT SYSTEMS

An organisation may take advantage of existing management systems when implementing an ISMS by integrating it with those existing systems.

By integrating the ISMS with existing management systems, the organisation may reduce the effort and costs required to implement and maintain the ISMS, while also ensuring consistency and alignment with the organisation’s overall management approach. Below is a non-exhaustive list of potential synergies that can be exploited when integrating the ISMS with an existing management system:

- Leverage existing policies and procedures: an organisation may use its existing policies and procedures as a foundation for its ISMS. This may help to ensure consistency and minimise the need for additional documentation.
- Align ISMS with other management systems: an organisation may align the ISMS with other management systems, such as safety management systems (SMS), to ensure that the ISMS is consistent with the organisation’s overall management approach.
- Use existing risk management processes: an organisation may use their existing risk management processes to identify and assess the information security risks potentially leading to aviation safety risks.
- Reuse existing controls: an organisation may reuse existing controls, such as access controls or incident management process, to implement the information security controls required by the ISMS.
- Continuous improvement process: an organisation may use the continuous improvement process of existing management systems to improve the ISMS over time.

AMC1 IS.D.OR.200(e) Information security management system (ISMS)

ED Decision 2023/009/R

DEROGATION

Organisations should follow the directions provided in [AMC1 IS.D.OR.205\(a\)](#) and [AMC1 IS.D.OR.205\(b\)](#) to perform a documented information security risk assessment to seek the approval from the competent authority of a derogation under point [IS.D.OR.200\(e\)](#). In order to justify the grounds for an derogation, the risk assessment is expected to provide explanations for the exclusion of all elements from the scope of the ISMS. It is up to the authority to determine whether this assessment is deemed satisfactory for a derogation to be granted.

Organisations that would like to have the risk assessment performed by a third party should consider the requirements of [IS.D.OR.235](#) and the related AMC.

GM1 IS.D.OR.200(e) Information security management system (ISMS)

ED Decision 2025/014/R

Any organisation that believes that it does not pose any information security risk with a potential impact on aviation safety, either to itself or to other organisations, may consider requesting an approval for a derogation by the competent authority following the procedure outlined in [AMC1 IS.D.OR.200\(e\)](#).

Existing safety risk assessments, such as those carried out as part of the SMS, can form the basis of enhanced assessments considering safety risks arising from information security threats.

It should be noted that applications for partial exemption from individual articles are not possible.

APPLICATION FOR A DEROGATION

In order to ensure a consistent approach by organisations when submitting a derogation request, the competent authority may establish an official derogation request application form.

The application for a derogation, based on the application form where one exists or in a format decided by the organisation, will need to be signed by the accountable manager of the applicant organisation and submitted to the appropriate competent authority for review and consideration.

The application for a derogation should contain preliminary information used for a pre-assessment by the competent authority, including:

- Company information and contact information;
- Affected approval(s);
- Detailed justification for the exclusion of the provisions;
- Overview of services that the organisation provides and receives;
- Architecture overview of information systems used for business operation;
- Summary of the high-level information security risk assessment aligned with the above architecture;
- Methodology used to perform the information security risk assessment;
- List of people and roles involved in the information security risk assessment process;

-
- Date and signature.

Note: At this stage, the high-level risk assessment needs to properly document the absence of information security risks that may impact safety. To do so, it should at least cover the identification of the scope and boundaries, as required under points [IS.D.OR.205](#) (a) and (b), and the analysis of safety impact, as required under point [IS.D.OR.205](#)(c).

EVALUATION OF THE REQUEST FOR A DEROGATION

The competent authority reviews the information security risk assessment and other supporting documentation, normally assessing whether:

- the documentation is sufficient for a proper analysis and assessment;
- the repository or asset inventory of digital systems, data flows and processes is comprehensive;
- the high-level information security risk assessment has been conducted in accordance with the organisation's methodology and with the appropriate diligence;
- the relevant stakeholders have been involved in the assessment process;
- the assessment has been performed by people with sufficient expertise in information security and aviation safety;
- the organisation has assigned and indicated a point of contact for enquiries.

Figure 1 below depicts the process, including the pre-assessment. If the pre-assessment provides the competent authority with sufficient evidence that the derogation request is legitimate and that the organisation meets the expected criteria, the process will proceed to the exchange of more detailed information.

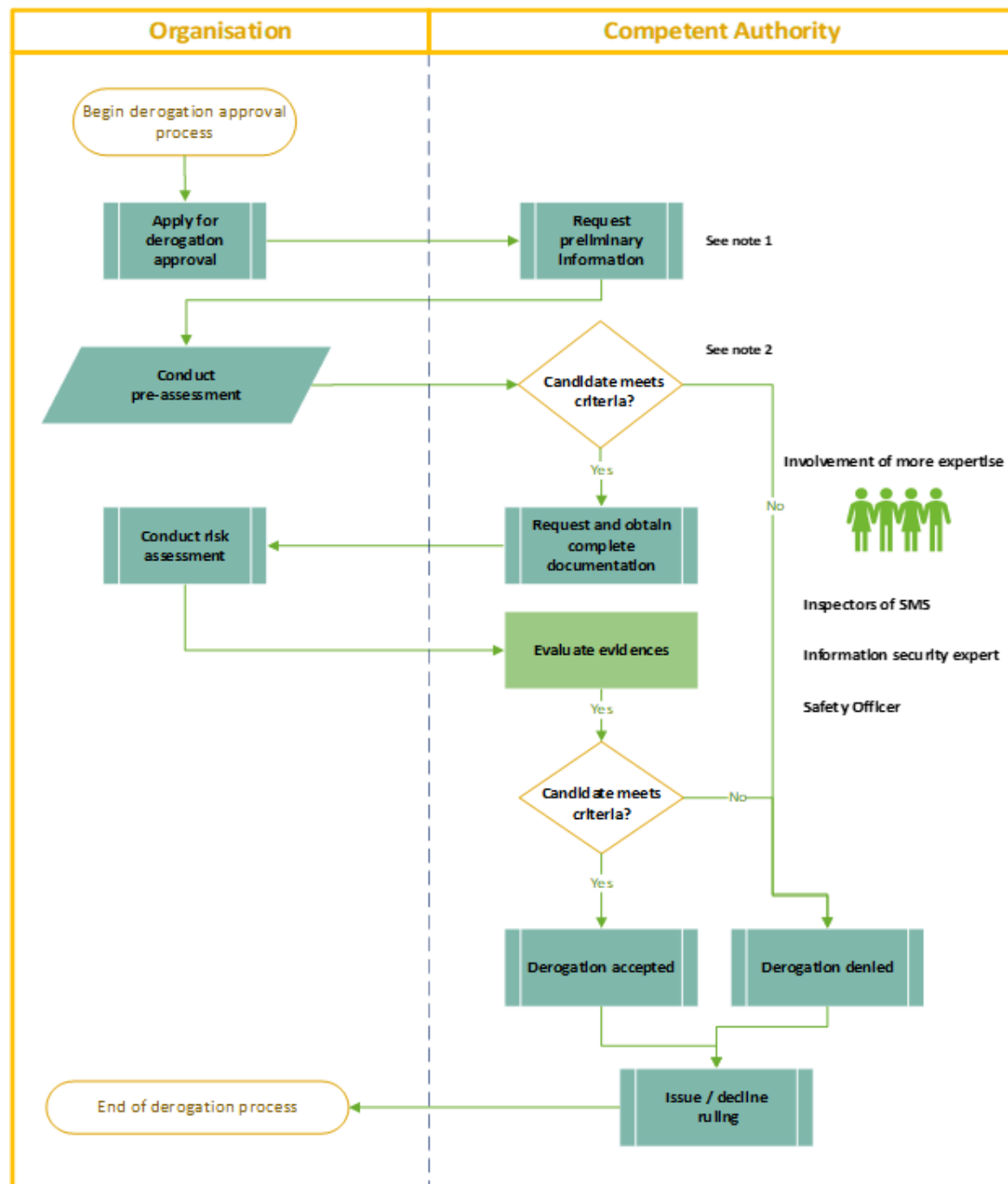


Figure 1: Representation of the derogation process

Note 1 to Figure 1: The objective of this step is to obtain preliminary information about the organisation risk profile by using suitable means (e.g. questionnaire, self-assessment template, request tool, etc.)

Note 2 to Figure 1: The objective of this step is to conduct a pre-evaluation to check whether the organisation has the possibility to be granted a derogation. The pre-assessment allows to avoid a detailed assessment if the prerequisites for a derogation are not met.

EXPECTATIONS AND RECOMMENDATION AFTER DEROGATION APPROVAL

Once a derogation approval has been granted, the organisation is expected to undertake the following on a continuous basis:

- Comply with all provisions of the regulation which are not exempted, in particular point [IS.D.OR.200\(a\)\(13\)](#) which should not be limited to only protection of the received information. When transmitting information with confidential nature, the organisation needs to have secure means in place as well;
- Comply with [Regulation \(EU\) No 376/2014](#) to take into account the obligation to comply with the reporting requirements.
- Monitor any changes in the organisation's scope of work and identify those which may have a potential impact on the documented information, which supports the derogation approval. Where such changes are identified, the organisation should ensure that they are brought to the attention of the competent authority without delay and notified in accordance with the applicable implementing rule.
- Monitor the risk picture for any variation due to changes in the safety and security environment over time. To this end, point [IS.D.OR.205\(d\)](#) should be considered.
- Ensure that the accountable manager or the head of the design of the organisation can demonstrate an understanding of the derogation process and the terms on which the approval has been granted. This means that at least one person in the organisation needs to have a basic understanding of the Regulation. To this end, point [IS.D.OR.240\(a\)\(3\)](#) and the related AMC and GM should be considered.
- Implement basic protection against information security risks according to industry best practices.
- Remain up to date with the latest information security threat landscape and consult the respective national authority for additional guidance.

EXAMPLES

An example of organisations that may consider asking for a derogation might include DOA or POA holders that design or produce only components or parts that either are not involved in ensuring the structural integrity of the aircraft (e.g. carpets, interiors) or have no major safety-related aircraft functionalities, including but not limited to, aircraft software, navigation, avionics, engines, flight control, landing gear, hydraulic, electrical, air, communications, etc.

The aforementioned example is only indicative of a potential scenario that might provide an initial basis for the preparation of an information security risk assessment that justifies the exclusion of all elements of an organisation from the scope of the ISMS.

IS.D.OR.205 Information security risk assessment*Regulation (EU) 2022/1645*

- (a) The organisation shall identify all of its elements, which could be exposed to information security risks. That shall include:
- (1) the organisation's activities, facilities and resources, as well as the services the organisation operates, provides, receives or maintains;
 - (2) the equipment, systems, data and information that contribute to the functioning of the elements listed in point (1).

- (b) The organisation shall identify the interfaces that it has with other organisations, and which could result in the mutual exposure to information security risks.
- (c) With regard to the elements and interfaces referred to in points (a) and (b), the organisation shall identify the information security risks which may have a potential impact on aviation safety. For each identified risk, the organisation shall:
 - (1) assign a risk level according to a predefined classification established by the organisation;
 - (2) associate each risk and its level with the corresponding element or interface identified in accordance with points (a) and (b).

The predefined classification referred to in point (1) shall take into account the potential of occurrence of the threat scenario and the severity of its safety consequences. Based on that classification, and taking into account whether the organisation has a structured and repeatable risk management process for operations, the organisation shall be able to establish whether the risk is acceptable or needs to be treated in accordance with point [IS.D.OR.210](#).

In order to facilitate the mutual comparability of risks assessments, the assignment of the risk level pursuant to point (1) shall take into account relevant information acquired in coordination with the organisations referred to in point (b).

- (d) The organisation shall review and update the risk assessment carried out in accordance with points (a), (b) and (c) in any of the following situations:
 - (1) there is a change in the elements subject to information security risks;
 - (2) there is a change in the interfaces between the organisation and other organisations, or in the risks communicated by the other organisations;
 - (3) there is a change in the information or knowledge used for the identification, analysis and classification of risks;
 - (4) there are lessons learnt from the analysis of information security incidents.

GM1 IS.D.OR.205 Information security risk assessment

ED Decision 2023/009/R

Part-IS does not require the use of any specific information security framework, such as ISO, NIST, or others to develop the risk assessment or in general to implement risk management. Each framework offers different benefits and none of these frameworks is perfect for an individual organisation and should be customised and tailored to meet the overall needs of an organisation as well as the specific need to consider aviation safety aspects.

Organisation whose information security frameworks have achieved industry certifications can provide this information as supporting artefacts; however, these organisations should show the applicability of the industry certification to the scope of this Regulation (see [GM1 IS.D.OR.200](#)).

General guidance on risk management, including risk assessment, can be found in ISO/IEC 27005 and ISO/IEC 31000 as well as NIST SP 800-30. Aviation organisations may also wish to consider aviation-specific guidance as defined in the risk management chapter of the latest version of EUROCAE ED-201A and, as appropriate to the specific operating environment, in the chapters of EUROCAE ED-204A, EUROCAE ED-205A and EUROCAE ED-206 covering risk management.

AMC1 IS.D.OR.205(a) Information security risk assessment

ED Decision 2023/009/R

When conducting an information security risk assessment, the organisation should ensure that all relevant aviation safety elements are identified and included in the ISMS scope as per [IS.D.OR.200](#) and related AMC.

A means to comply with the requirement in point [IS.D.OR.205\(a\)](#) is to perform a preliminary high-level risk assessment or impact assessment, carried out in accordance with a documented methodology and following precise criteria for the inclusion in and exclusion from the ISMS scope of the elements listed in [IS.D.OR.205\(a\)](#).

GM1 IS.D.OR.205(a) Information security risk assessment

ED Decision 2023/009/R

SCOPE AND BOUNDARIES IDENTIFICATION

The organisation should develop clear and comprehensive understanding of its aviation activities and services, the related processes and associated information systems, and the relevant data flows and information exchanges that define the scope of the ISMS and the boundaries for risk assessment. Therefore, the organisation should develop corresponding documentation on resources and dependencies related to computing, networking and contracted services which have the potential to affect the information security and safety of the functions, services, or capabilities within the scope of the risk assessment.

The following non-exhaustive list provides examples of items that may be considered for the identification of the aforementioned scope and boundaries. The level of detail of the analysis can be an iterative process, with the effort commensurate with the expected level of risk. As stated above, the purpose is to establish understanding of all relevant assets, resources and dependencies that are directly a part of the functions, services and capabilities through the following activities:

- (a) Identification of operational inputs and outputs relevant to the functions, services and capabilities of the organisation; these can be related to:
 - Internal or external sources;
 - internal or external leased or managed services, or other dependencies;
- (b) Identification of all relevant assets (i.e. hardware, software, network and computing resources) used to create, process, transmit, store or receive the aforementioned operational inputs and outputs;
- (c) Identification of the operating environments (e.g. office, public access area, access-controlled room etc.) and locations for all relevant assets;
- (d) For each asset included in the scope, identification of the specific methods, processes and resources that will be used to manage, operate and maintain each asset throughout its life cycle, including:
 - internal or contracted resources;
 - contracted companies remotely managing the assets (i.e. provider of managed services).

AMC1 IS.D.OR.205(b) Information security risk assessment

ED Decision 2023/009/R

The organisation should, as part of the information security risk assessment, identify the interfaces it has with other parties such as service providers, supply chains and other third parties, based on the exchange of data and information and the assets used for that exchange, which could lead to a situation where information security risks, as a result of mutual exposure, may either:

- increase aviation safety risks faced by other parties; and/or
- increase aviation safety risks faced by the organisation.

GM1 IS.D.OR.205(b) Information security risk assessment

ED Decision 2023/009/R

RISK INFORMATION SHARING

Interfacing organisations should share information with each other about the potential exposure to information security risks by following, for instance, the approach detailed in EUROCAE ED-201A, Appendix B — B.1, B.2 and B.3. The purpose of this exchange of information is to enable organisations to establish a matching mapping for the services identified under [IS.D.OR.205\(a\)](#), including all information and data flows, in order to:

- illustrate (e.g. through a functional diagram) the relationships of logical and physical paths connecting the different parts involved;
- clearly identify all assets (i.e. hardware, software, network and computing resources) that will be used in the exchange;
- identify all functions, activities and processes, including their respective information and data, which will be created, transmitted, processed, received and stored, and associate those with the responsible party which provides or performs those functions, activities and processes;
- determine for these paths, constituting the so-called functional chains, the role of the interfacing party as a producer, processor, dispatcher or consumer of the information or data involved;
- determine whether one interfacing party acts as an originator or receiver of a flow across such path.

TWO CATEGORIES OF INTERFACING ORGANISATIONS

There are two categories of interfacing organisations: those that are subject to [Regulation \(EU\) 2023/203](#) or [Regulation \(EU\) 2022/1645](#), and those that are not.

Where the organisation has interfaces with an organisation that is subject to Regulation (EU) 2023/203 or Regulation (EU) 2022/1645, each entity:

- is responsible for the identification of the interfaces that its own organisation has with other organisations, and which could result in the mutual exposure to information security risks. The entity may benefit from the sharing of risk information as this exchange allows for a more accurate assessment of those risks.
- remains accountable for the proper management of the information security risks within the scope of its own ISMS.

In all other cases, the organisation is accountable for the proper management of the information security risks that may arise from its exposure to the interfacing entity. Where these risks need to be

treated, the organisation always has the option of implementing mitigating measures and controls within its own boundaries. In the specific case where the interfacing entity is a supplier, the organisation may decide to manage the risks through contractual arrangements and require the supplier to implement mitigating measures and controls within its own organisation.

GM2 IS.D.OR.205(b) Information security risk assessment

ED Decision 2023/009/R

EXAMPLES OF AVIATION SERVICES

Examples of aviation services that may be considered when determining of the ISMS scope and interfaces are provided in [Appendix III](#).

AMC1 IS.D.OR.205(c) Information security risk assessment

ED Decision 2023/009/R

The organisation should use a risk management framework that includes a methodology for assigning risks with a risk level and establishing criteria for determining risk acceptance or further treatment.

The organisation should provide documented evidence of assessment of risks which have a potential impact on aviation safety including the level of risks. The organisation should associate each risk with the relevant elements and interfaces identified under [IS.D.OR.205](#) (a) and (b), and document whether the risk is acceptable or requires further treatment.

The organisation should provide the assurance that the risk assessment process is carried out with the necessary rigour and discipline by documenting the process and its robustness. By doing so, the organisation should consider:

- (a) reproducibility of the assessment's results for similar inputs;
- (b) repeatability of the assessment over time in a way that the results of the different prior assessments can be compared to determine the changes;
- (c) the gathering of inputs that are relevant and valid, in particular:
 - (1) the information that allows the determination of the safety consequences;
 - (2) the information that allows the determination of the potential of occurrence of the threat scenario;
- (d) iterative refinement over time allowing for more fine-grained threat scenarios as inputs become available, with the aim of reducing uncertainty regarding threats, vulnerabilities, effectiveness of existing controls, and dependencies on external entities, in particular by:
 - (1) refining initial high-level threat scenarios with greater detail and specificity as more data is gathered;
 - (2) refining data on known vulnerabilities by continuously updating information about their exploitability and the associated consequences;
 - (3) reviewing the effectiveness of existing controls, and consider newly available controls;
 - (4) refining the understanding of the dependencies on external entities and their implications for the organisation's risk profile.

GM1 IS.D.OR.205(c) Information security risk assessment

ED Decision 2023/009/R

RISK ASSESSMENT

The risk classification levels for the potential of occurrence of the threat scenario and severity of the safety consequences listed below may be applied; however, this does not prevent the organisation from developing additional intermediate categories if it deems this necessary for risk assessments. The organisation should specify and document the applied, organisation-specific, classification levels with an accurate qualitative or quantitative definition in terms of a range or interval of numerical values in order to enable a sufficiently calibrated, consistent estimation, evaluation and communication within the organisation or with the interfacing entities. The potential of occurrence of the threat scenario may be expressed as an interval of likelihoods including the duration of the observation. Supporting documentation and methods can be found in EUROCAE ED-203A, Chapter 3.6 which references the evaluation of the potential of occurrence of the threat scenario in the Security Risk Assessment of EUROCAE ED-202A.

Note 1: The phrase 'duration of the observation' refers to the time period during which a threat scenario is observed or monitored. It is essential in determining the likelihood of the threat scenario occurring, since the probability of occurrence may vary depending on the length of the observation period.

Note 2: EUROCAE ED-202A and EUROCAE ED-203A were originally developed for aircraft information security risk assessment, but the generic principles developed in those documents can be adapted to other frameworks when deemed useful by the organisation.

In order to facilitate the mutual comparability of risk assessment methodologies between interfacing organisations, the organisation may associate the assessment of the potential of occurrence of the threat scenario with one of the following categories:

- High potential of occurrence: the threat scenario is likely to occur. The attack related to the threat scenario is feasible and similar threat scenarios have occurred many times in the past.
- Medium potential of occurrence: the threat scenario is unlikely to occur. The attack related to the threat scenario is possible and a similar threat scenario may have occurred in the past.
- Low potential of occurrence: the threat scenario is very unlikely to occur. The materialisation of the threat scenario is theoretically possible; however, it is not known to have occurred.

The evaluation of the potential of occurrence of the threat scenario may be based on the following aspects:

Protection (as defined in EUROCAE ED-203A)

- Security measures and architecture that deny access to assets: the degree to which an asset is open to access from compromised systems
- Access to security measures: the degree to which a security measure prevents access/attack to itself from compromised systems
- Failure of mechanism: the degree to which the known implementation of a security measure will fail to prevent an attack
- Detection methods or procedures to recognise the attack and appropriately respond to reduce the potential of occurrence of the threat scenario

Exposure reduction (as defined in EUROCAE ED-203A)

- Conditions under which an external access connection can be used by a user or attacker
- Limits on the functionality of an external access connection
- Organisational policies that control the time-to-feasibility for developing attack tools specific to the product
- Vulnerability management including intelligence, scanning, treatment and retesting aimed to discover, detect and treat reported or detected vulnerabilities in a fast, risk-prioritised manner with high assurance in order to reduce the attack surface
- Reduction of the severity of a successful attack (i.e. through a redundant system that can maintain the continuity of service in case of a denial of service of a system critical for aviation safety)

Attack attempt (as defined in EUROCAE ED-203A)

- The capability of the attackers which is determined by the resources and expertise required for their attack

The capability of the attackers can be assessed through several ways, for instance:

- information from computer emergency response teams (CERTs) / computer security incident response teams (CSIRTs), information sharing and analysis centres (ISACs);
- analyses of past activities, techniques and procedures (TTPs) and success rate of attacks.

For the same reason the organisation may associate the outcome of the evaluation of the severity of the safety consequences with one of the following categories:

- High severity: those immediate or delayed scenarios that can cause or contribute to an unsafe condition where an unsafe condition means an occurrence associated with the operation of an aircraft in which:
 - a person is fatally or seriously injured;
 - the aircraft sustains damage or structural failure;
 - the aircraft is either missing or completely inaccessible;
- Moderate severity: those immediate or delayed scenarios that can cause or contribute to safety incidents where an incident means any occurrence other than an accident, associated with the operation of an aircraft, which affects or could affect the safety of operations;
- Low severity: those immediate or delayed scenarios that can cause or contribute to negligible safety consequences.

Examples for high, moderate, and low severity can be found in EUROCAE ED-201A, Appendix B for products, ATM systems and airspace.

If the organisation cannot determine the safety effect, the assessment should identify assumptions from the risk-sharing information at interfaces with other organisations along the functional chain, leading up to the safety effect.

Some of those assumptions can be granted with the certification of products: where assets are subject to product certification from other aviation regulations addressing product information security, the organisation performing the risk assessment may consider the perimeter of the product certification

as already covered. This should be acceptable under the condition that this certification is valid and that the instructions provided by the OEM to maintain the certification validity are implemented by the organisation.

Additional information can also be found in [Regulation \(EU\) 2015/1018](#) on mandatory reporting of occurrences in civil aviation. Further examples of impact severity classifications for aviation domains can be found in EUROCAE ED-201A, Appendix B — Tables B-5, B-6 and B-7.

Risk acceptance criteria

Risk acceptance criteria are critical and should be developed, specified and documented. The criteria may define multiple thresholds, with a desired target risk level, but allowing also for the accountable manager or, in the case of design organisations, for the head of the design organisation, or delegated persons to accept risks above this level under defined circumstances and conditions.

In order to facilitate the mutual comparability of risk assessments between interfacing entities, the organisation should classify the risks in the following categories:

- unacceptable risk;
- conditionally acceptable risk;
- acceptable risk.

For what concerns the conditional acceptance of risks, the criteria for acceptance should take into account how long a risk is expected to exist (temporary or short-term activity or exposure), or may include requirements for the commitment of future treatments to reduce the risk at an acceptable level within a defined time duration and show how the risk will be managed over time through the organisation's risk governance processes.

Moreover, risks should be conditionally accepted only under the condition that the organisation demonstrates the presence of a comprehensive risk management structure that includes risk assessment, risk treatment and risk monitoring processes for operations. The risk management should consider the variability and consistency of threat likelihood, vulnerability, existing controls, external dependencies and safety impact. This is typically achieved when the organisation reaches a higher level of maturity that is representative of functionality and repeatability of information security risk management — see [GM1 IS.D.OR.260\(a\)](#).

The following Figure 1 depicts a risk acceptance matrix based on the aforementioned categories that can be used by interfacing organisations for mutual comparability.

ICAO Annex 13 >	Negligible effect	Incident	Accident
Threat scenario — potential of occurrence	Low safety consequences	Moderate safety consequences	High safety consequences
High	Conditionally acceptable	Not acceptable	Not acceptable
Medium	Acceptable	Conditionally acceptable	Not acceptable
Low	Acceptable	Acceptable	Conditionally acceptable*

Figure 1: Example of a risk acceptance matrix for comparison purposes

* The potential of occurrence of the threat scenario is reassessed in a timely manner (refer to [IS.D.OR.205\(d\)](#)) and monitored to ensure that it remains low and that if the risk materialises, it is early detected and dealt with.

A comprehensive risk management structure typically entails the following aspects and processes:

- a repeatable and reproduceable risk assessment. If the risk factors are considered fairly uncertain and within some wide value range or not sufficiently precise, further iterations of the risk assessment are performed involving additionally gathered or detailed information and a more in-depth assessment in order to reduce uncertainty and increase precision;
- a thorough review of those risks proposed to be conditionally acceptable that is performed by the accountable manager or, in the case of design organisations, by the head of the design organisation, or delegated person(s) who may impose additional conditions for the risk retention, including risk treatment measure and the timeline for its implementation;
- strict monitoring of the key risk indicators that includes a defined, reliable detection of the potentially evolving risk materialisation;
- an incident response scheme is in place with reactive measures that are triggered by detection mechanisms in order to immediately contain the consequences, in particular, for risk scenarios involving a high severity level.

Note: As detailed in NIST SP-800 Rev.1, repeatability refers to the ability to repeat the assessment in the future, in a manner that is consistent with and hence comparable to prior assessments —enabling the organisation to identify trends. Therefore, a risk assessment process can be classified as ‘repeatable’ when under similar conditions an entity or a person delivers consistent results.

As detailed in NIST SP-800 Rev.1, reproducibility refers to the ability of different experts to produce the same results from the same data. Therefore, a risk assessment process can be classified as ‘reproducible’ when another entity or person, given the same inputs, assumptions, information security context and threat environment can replicate the same steps and reach the same conclusions.

Threat scenario identification

A threat scenario is one of the possible ways a threat could materialise. Typically, a threat scenario describes a potential attack targeting one or more vulnerabilities of assets, as well as processes.

The purpose of the threat scenario identification under this Regulation is to develop a list of scenarios that may lead to an information security threat having an impact on aviation safety.

A threat scenario, in general, is characterised by the following:

- a threat source of the information security attack;
- an attack vector and a path through the organisation up to the asset;
- the information security controls that would mitigate the attack;
- the consequence of the attack including the affected safety aspects.

Threat scenario identification guidance can be found in EUROCAE ED-202A, Chapter 3.4. This is not the only source where guidance can be found, and the organisation may refer to different guidance more appropriate for their application.

Additional methods to identify relevant threat scenarios

When conducting this analysis, both information security and safety aspects should be coordinated throughout the process to ensure mutual understanding of the threat preventive measures and mitigating measures being applied. In the following Figure 2 the interactions between information security and aviation safety are depicted through a ‘bow-tie’ diagram that highlights the links between risk controls and the underlying management system.

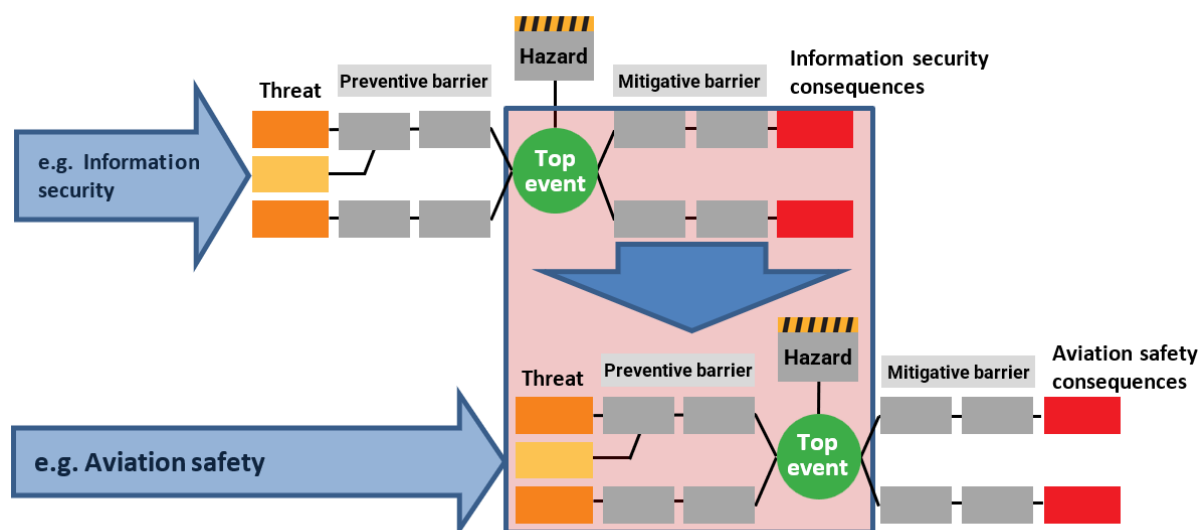


Figure 2: Interactions between information security and aviation safety risk management areas

Note: A preventive barrier or measure is a proactive action or control implemented to reduce the likelihood of a risk, hazard, or threat materialising while a mitigating measure is an action or control designed to reduce the severity or impact of an undesired event, would it occur.

Examples of threat scenarios

Threat catalogues may provide guidance and elements for the elaboration of threat scenarios that are relevant for the organisation. References can be found in ARINC 811 – Att. 3 – Tables 3-7 and 3-8 for the threat catalogues examples and other threat catalogue examples as they are provided by EU institutions — for example, the ENISA threat taxonomy. However, this is not an exhaustive list of examples, and the identification of threat scenarios should therefore not be limited to those examples only. In addition, other relevant resources containing information on information security threats and the information security threat landscape should be consulted to support the risk assessment process with relevant inputs.

A set of examples of threat scenarios can be found in [Appendix I](#).

AMC1 IS.D.OR.205(d) Information security risk assessment

ED Decision 2023/009/R

The organisation should take into account the following criteria when establishing compliance with the objectives contained in point [IS.D.OR.205\(d\)](#):

- The risk assessment performed under points IS.D.OR.205(a), (b) and (c) should be reviewed at regular intervals to identify and account for relevant changes. The periodicity at which potential

changes have to be evaluated should be determined by the organisation performing the assessment considering the criticality of the assets within the scope of the risk assessment, levels of residual risk of the assets within the scope of the risk assessment and any contractual or regulatory requirements. A higher criticality or level of risk will require more frequent review.

- (b) The periodicity of risk assessment reviews should be documented by the organisation and include the justification, date of approval and information about the risk owner.

GM1 IS.D.OR.205(d) Information security risk assessment

ED Decision 2023/009/R

The criteria to consider for the frequency of the risk assessment review may be the risk level as well as the criticality and complexity of the assets concerned. The objective of a risk assessment review is to trigger the revaluation of risks, their likelihood and impact in case of relevant changes. One possible way is to have a tiered approach to risk assessment, with a higher-level risk assessment being used for the identification of changes. The higher-level risk assessment could allow the identification of the detailed risks that should be reviewed in a next step. Risk assessments should be subject to regular reviews to:

- (a) allow for continuous improvement of the quality of risk assessment;
- (b) ensure efficiency and effectiveness of risk controls and mitigating measures in both their design and operation;
- (c) review plans and actions for risk treatment;
- (d) identify any organisational change which may require a review of the priorities as well as of the treatment of risks;
- (e) maintain an overview of the complete risk picture; and
- (f) identify any emerging risks.

Risk assessment reviews should involve the risk owners, project teams and other stakeholders as applicable. Evidence of risk assessment review should be documented and should include:

- evidence of approval of the review by the designated risk owner; and
- the rationale behind or basis for the risk owner's approval of the review.

Such evidence may comprise, but is not limited to:

- reports which constitute a form of documentation to track information security risks potentially impacting an organisation;
- the documentation of the information security risk assessment;
- excerpts from a business or security risk register.

The periodicity of risk assessment reviews should also be documented by the organisation in information security manuals, processes or procedures and should align with wider change management activities and management reviews of information security. Further guidance on criteria and frequency of risk assessment review can be found in EUROCAE ED-201A, Chapter 4, as well as in EUROCAE ED-205A, Chapter 3.2 (for ATMS/ANS).

GM2 IS.D.OR.205(d) Information security risk assessment

ED Decision 2023/009/R

The following are examples of changes that should be identified during the risk assessment review as they may trigger an update of the risk assessments:

- (a) there is a change in the elements subject to information security risks as identified in [IS.D.OR.205\(a\)](#); a change in the elements will include:
 - additions to, or removals from, the scope of the risk assessment of individual elements;
 - changes to design or configuration of elements within the scope of the risk assessment that have the potential to alter the risk assessment outcomes; or
 - changes to values, which would potentially trigger changes to impact levels, of elements within the scope of the risk assessment;
 - (b) there is a change in the interfaces between the organisation and other organisations with which the organisation shares information security risks or relies upon to mitigate information security risks (e.g. supply chains, service providers, cloud providers and customers), as identified in [IS.D.OR.205\(b\)](#), or between the system within the scope of the risk assessment and any other interconnected systems, or in the risks notified to the organisation by other organisations, as identified in [IS.D.OR.205\(b\)](#), or owners or managers of the other systems including:
 - establishment of new interfaces;
 - removal of existing interfaces;
 - changes to existing interfaces that would have the potential to alter the risk assessment outcomes.
- Note: Some organisational or system interconnections may be with organisations that are not within the scope of this Regulation as defined in Article 2 and therefore are not subject to the requirements of Part-IS. Where this is the case, these organisations should be informed of their responsibility to report such changes as listed above through contractual arrangement and reporting requirements between the affected organisations on a case-by-case basis and where applicable;
- (c) there is a change in the information or knowledge used for the identification, analysis and classification of risks including:
 - changes to threats and their values or addition of new threats that have not previously been assessed;
 - changes to vulnerabilities or addition of new vulnerabilities that have not previously been assessed;
 - changes in impacts or consequences of assessed threats or vulnerabilities;
 - changes in aggregation of risks that may result in unacceptable levels of risks;
 - changes or improvements in the risk management process, risk assessment approach and related activities;
 - changes or improvements in the treatments of risks;
 - changes in the criteria used to determine acceptance and treatments of risks;

- (d) there are lessons learned from the analysis of information security incidents including:
- understanding why and how incidents have occurred; and
 - reviewing all types of incidents including those due to external factors, technical reasons, human errors (inadvertent behaviour). For human intentional acts a distinction can be made between malign and benign actions.

IS.D.OR.210 Information security risk treatment

Regulation (EU) 2022/1645

- (a) The organisation shall develop measures to address unacceptable risks identified in accordance with point [IS.D.OR.205](#), implement them in a timely manner and check their continued effectiveness. Those measures shall enable the organisation to:
- (1) control the circumstances that contribute to the effective occurrence of the threat scenario;
 - (2) reduce the consequences on aviation safety associated with the materialisation of the threat scenario;
 - (3) avoid the risks.

Those measures shall not introduce any new potential unacceptable risks to aviation safety.

- (b) The person referred to in point [IS.D.OR.240](#)(a) and (b) and other affected personnel of the organisation shall be informed of the outcome of the risk assessment carried out in accordance with point IS.D.OR.205, the corresponding threat scenarios and the measures to be implemented.

The organisation shall also inform organisations with which it has an interface in accordance with point IS.D.OR.205(b) of any risk shared between both organisations.

GM1 IS.D.OR.210 Information security risk treatment

ED Decision 2025/014/R

Unacceptable risks identified in accordance with point [IS.D.OR.205](#) require a risk treatment process that may lead to the introduction of information security measures, often referred to as information security controls.

For each identified risk, the organisation defines the specific risk treatment measures, methods or resources that will be used over the life cycle of each asset to:

- manage risk reduction;
- monitor and maintain each asset;
- update and fulfil activities for configuration management;
- manage supply chain;
- manage contracted services or service provider.

The review of risk treatment measures includes life cycle considerations which are introduced by equipment, procedures and personnel.

A risk treatment plan as an outcome of the risk management process includes a prioritisation of risks, the corresponding information on the objectives and means for risk treatment to reach an acceptable

level of risk, as well as agreed timelines specifying when responsible personnel should have implemented the risk treatment measures. The timelines for the implementation of a risk treatment measure are subject to agreement by the personnel responsible for the implementation and are communicated to and accepted by the accountable manager or, in the case of design organisations, by the head of the design organisation, of the organisation or delegated person(s).

Any subsequent implementation delay, together with its cause, reason, rationale or necessity, is documented in the risk treatment plan, for risks that may lead to an unsafe condition. The delay is also subject to the acceptance by the accountable manager of the organisation, or by the head of the design organisation, or delegated person(s). This person may condition such acceptance on the implementation or availability of compensating controls or reactive measures to monitor, early detect and timely respond to the materialisation of the risk in treatment. In order to timely respond, the incident response team may be informed to trigger their preparedness.

The risk treatment plan can act as a means of communication with the competent authority to demonstrate effective treatment of unacceptable risks. Similarly, this plan can be utilised to communicate to interfacing organisations how shared risks are controlled.

In accordance with IS.D.OR.205(d), a regular or conditional review of the risk assessment is necessary, and this includes the review of the risk treatment measures developed under [IS.D.OR.210\(a\)](#) to identify whether they are still effective or they require adaptations.

In addition, the organisation should also consider the potential impact on the effectiveness of risk treatment measures where a shared information security risk may arise as a result of the interaction between interfacing entities (see [IS.D.OR.235](#) and related AMC).

AMC1 IS.D.OR.210(a) Information security risk treatment

ED Decision 2023/009/R

- (a) The risk treatment process should reach at least one of the objectives listed under [IS.D.OR.210\(a\)](#).
- (b) When establishing compliance with the objectives under points [IS.D.OR.210\(a\)\(1\)](#) and [IS.D.OR.210\(a\)\(2\)](#), the organisation should take into account that:
 - (1) the measures developed under these points should be implemented according to a risk treatment plan with defined, risk-based priorities, objectives and agreed timelines and owners;
 - (2) life cycle considerations should be identified and associated to ensure continuous effectiveness of the information security measures including exchange of data with other entities;
 - (3) it should review and update the risk assessment, according to [IS.D.OR.205\(d\)](#), to evaluate whether the measures developed under these points introduce new unacceptable risks or modify existing risks in a way that they become unacceptable.
- (c) Risk treatment should be documented and recorded, for example, in a risk registry, even if the risk has been avoided.

IS.D.OR.215 Information security internal reporting scheme

Regulation (EU) 2022/1645

- (a) The organisation shall establish an internal reporting scheme to enable the collection and evaluation of information security events, including those to be reported pursuant to point [IS.D.OR.230](#).
- (b) That scheme and the process referred to in point [IS.D.OR.220](#) shall enable the organisation to:
 - (1) identify which of the events reported pursuant to point (a) are considered information security incidents or vulnerabilities with a potential impact on aviation safety;
 - (2) identify the causes of, and contributing factors to, the information security incidents and vulnerabilities identified in accordance with point (1), and address them as part of the information security risk management process in accordance with points [IS.D.OR.205](#) and [IS.D.OR.220](#);
 - (3) ensure an evaluation of all known, relevant information relating to the information security incidents and vulnerabilities identified in accordance with point (1);
 - (4) ensure the implementation of a method to distribute internally the information as necessary.
- (c) Any contracted organisation which may expose the organisation to information security risks with a potential impact on aviation safety shall be required to report information security events to the organisation. Those reports shall be submitted using the procedures established in the specific contractual arrangements and shall be evaluated in accordance with point (b).
- (d) The organisation shall cooperate on investigations with any other organisation that has a significant contribution to the information security of its own activities.
- (e) The organisation may integrate that reporting scheme with other reporting schemes it has already implemented.

AMC1 IS.D.OR.215(a)&(b) Information security internal reporting scheme

ED Decision 2023/009/R

Organisations should use as a source the incidents detected during activities performed to show compliance with [IS.D.OR.220\(a\)](#). Organisations should have a mechanism to collect notifications of events by personnel and by sources outside the company including suppliers, partners, customers, open-source software, and information security researchers. The mechanism for collecting information by personnel and external sources should be easily accessible and communicated.

The organisation should collect all events gathered through the detection means for internal analysis. Each event should be analysed to identify whether it is reportable and if so, what potential or actual impact on aviation safety has occurred. Information security events should be considered in combination with other events to provide correlation to identify incidents or vulnerabilities with a potential impact on aviation safety.

The organisation should consider the outcome of the risk assessment and the exploitability of new vulnerabilities discovered during the detection activities conducted according to the measures required in [IS.D.OR.220\(a\)](#).

The organisation should identify all internal stakeholders that require notification of a specific incident or vulnerability and ensure that these stakeholders receive all necessary information on the incident or vulnerability in order to act effectively and in a timely manner to support the required detection and response periods.

GM1 IS.D.OR.215(a)&(b) Information security internal reporting scheme

ED Decision 2023/009/R

RELATIONSHIP BETWEEN INTERNAL AND EXTERNAL REPORTING

Organisations should collect and report internally incidents and vulnerabilities aiming at covering all items within the scope of this Regulation. Both internal and external reporting are necessary for a complete and effective reporting system. Internal reports should be assessed in a timely manner and where the potential impact on safety is an unsafe condition, organisations should initiate reporting of these internal reports according to [IS.D.OR.230](#).

GM2 IS.D.OR.215(a)&(b) Information security internal reporting scheme

ED Decision 2023/009/R

ORGANISATION OF COLLECTION AND EVALUATION OF INFORMATION SECURITY EVENTS

It is a common practice in large organisations to centralise information security operations in a security operations centre (SOC) and make use of an information security information and event management (SIEM) system. A SIEM system collects all events from sources such as log files in a common database and allows the analysts and responders in a joint SOC to review and act on these events. Organisations may choose to use a SOC for events relevant to Part-IS in isolation or in combination with events not subject to Part-IS but of interest to the organisation, such as events relating to business interests. Events can be automatically aggregated, correlated and analysed in order to detect abnormal behaviour leading to information security incidents.

Organisations that do not have a SOC capability and do not use a SIEM system need to consider how to establish processes to meet the required collection and evaluation capabilities as well as detection and response times.

GM3 IS.D.OR. 215(a)&(b) Information security internal reporting scheme

ED Decision 2023/009/R

RELEVANT INFORMATION FOR INCIDENTS AND VULNERABILITIES

Understanding the causes of, and contributing factors to, information security incidents and vulnerabilities relevant to Part-IS allows lessons learned to be gained and to introduce corrections to processes and asset design. However, understanding causes and contributing factors may not always be possible or may not aid in continuous improvement of aviation safety. Where vulnerabilities arise from assets developed solely or primarily for aviation, it is expected to be possible to perform the necessary investigation on the root causes. These root causes will inform the affected organisation(s) to improve processes and asset design to remediate vulnerability and to ensure that such vulnerabilities are not introduced in other assets. Understanding the root causes of vulnerabilities also allows the aviation community to learn and thus avoid similar vulnerabilities in the future.

GM1 IS.D.OR.215(c) Information security internal reporting scheme

ED Decision 2023/009/R

If contracted organisations are also subject to this Regulation, the exchange of information and reporting should be covered under the management of shared risks and through the establishment of an external agreement between the organisations. Guidance regarding the development of external agreements can be found in EUROCAE ED-201A, Chapter 4.4 External agreements.

More in general, and in all other cases, any service contract should include standard clauses concerning obligations for the contracted organisation to:

- report within an agreed time information security incidents that may have an impact on the contracting organisation. Incidents and vulnerabilities which could lead to unsafe conditions should be reported as soon as possible and in such a manner that the external reporting obligation under [IS.D.OR.230](#) can be ensured;
- designate a point of contact for the incident management and possible crisis management.

In some cases contracted organisations, such as service providers with distributed resources, may not be able to offer any ad hoc reporting. In these cases the internal reporting requirement may be fulfilled through other means that satisfy the objective of this provision. For instance, the contracted organisations may provide an up-to-date list of vulnerabilities affecting the systems within the scope of the contracted services. This list should be monitored by the contracting organisation as part of the internal reporting of information security events.

GM1 IS.D.OR.215(d) Information security internal reporting scheme

ED Decision 2023/009/R

The cooperation under point [IS.D.OR.215\(d\)](#) can be substantiated by sharing elements from incident records that can support other organisations' information security activities. In case the organisations are bound by contractual obligations, this contract may also include commitment to cooperate. Organizations may consider developing formal agreements (e.g. memorandum of understanding) outlining roles and responsibilities for information security collaboration such as governance meetings, joint development activities, and real-time indicators of compromise (IoC) sharing.

Moreover, commitment to cooperate may also be achieved through the active participation of the organisation in information security sharing initiatives; for instance, ISAC(s). Additionally, for their own awareness, organisations may also subscribe to receive vulnerability and threat alerts, like those distributed by CERTs.

IS.D.OR.220 Information security incidents — detection, response and recovery

Regulation (EU) 2022/1645

- (a) Based on the outcome of the risk assessment carried out in accordance with point [IS.D.OR.205](#) and the outcome of the risk treatment performed in accordance with point [IS.D.OR.210](#), the organisation shall implement measures to detect incidents and vulnerabilities that indicate the potential materialisation of unacceptable risks and which may have a potential impact on aviation safety. Those detection measures shall enable the organisation to:
- (1) identify deviations from predetermined functional performance baselines;
 - (2) trigger warnings to activate proper response measures, in case of any deviation.

- (b) The organisation shall implement measures to respond to any event conditions identified in accordance with point (a) that may develop or have developed into an information security incident. Those response measures shall enable the organisation to:
- (1) initiate the reaction to the warnings referred to in point (a)(2) by activating predefined resources and course of actions;
 - (2) contain the spread of an attack and avoid the full materialisation of a threat scenario;
 - (3) control the failure mode of the affected elements defined in point IS.D.OR.205(a).
- (c) The organisation shall implement measures aimed at recovering from information security incidents, including emergency measures, if needed. Those recovery measures shall enable the organisation to:
- (1) remove the condition that caused the incident, or constrain it to a tolerable level;
 - (2) reach a safe state of the affected elements defined in point IS.D.OR.205(a) within a recovery time previously defined by the organisation.

GM1 IS.D.OR.220 Information security incidents — detection, response and recovery

ED Decision 2023/009/R

Without prejudice to the definition of ‘information security event’ in [Article 3](#) of Regulation (EU) 2022/1645, those events that indicate the potential materialisation of unacceptable risks include both occurrences (i.e. anything that causes harm or have the potential to cause harm) and discovery of vulnerabilities. In fact, information security risks are associated with the potential that threats will exploit vulnerabilities, therefore the discovery of an exploitable vulnerability is an information security event.

In light of this, in the context of this Regulation:

- detection activities required under [IS.D.OR.220\(a\)](#) include vulnerability discovery;
- response activities under [IS.D.OR.220\(b\)](#) include vulnerability management.

AMC1 IS.D.OR.220(a) Information security incidents — detection, response and recovery

ED Decision 2023/009/R

DETECTION

When complying with the requirement in [IS.D.OR.220\(a\)](#), the organisation should define and implement a strategy to detect information security incidents which may have a potential impact on safety.

This should be done in a way to ensure that at least the detection strategy is able to cover all known information security threats to their assets that may materialise in a safety hazard having unacceptable consequences.

DETECTION STRATEGY

In order to determine the scope of the event detection, the organisation should:

- (a) identify a list of threat scenarios from the risks identified under [IS.D.OR.205](#);

- (b) identify, as a minimum, those assets that, if compromised, contribute to the scenario(s) that may materialise in an unsafe condition. For this identification of the assets, the measures introduced under [IS.D.OR.210](#) should also be considered.

Note: The contribution of an asset to the threat scenario and the materialisation of an unsafe condition should be assessed by considering also the whole functional chain. In some cases, the asset may be at the end of a functional chain and if it is compromised, the effect on safety is direct and may be immediate; conversely, if the asset is far from the end of a functional chain and it is compromised, the effect should propagate and may be delayed.

GM1 IS.D.OR.220(a) Information security incidents — detection, response and recovery

ED Decision 2023/009/R

DETECTION STRATEGY

When developing the detection strategy, for those items within the scope of event detection, the organisation should define the conditions that trigger a process that, for example, would require personnel intervention and further analysis. These conditions on the items may be defined using elements from the:

- (a) expected functional baseline: engage in the identification of deviations from the expected functional operation of the system (excluding information security functions/controls);
- (b) expected information security baseline: engage in the identification of deviations from the expected information security operation of information security controls.

These conditions should consider both abnormal behaviour and substantial deviations from the baselines and relevant correlation of multiple independent events.

Further guidance on the objectives for the establishment of a detection strategy can be found in EUROCAE ED-206, Chapter 4.

AMC1 IS.D.OR.220(b) Information security incidents — detection, response and recovery

ED Decision 2023/009/R

(a) INCIDENTS

The organisation should take into account the following aspects when establishing compliance with the objectives contained in point [IS.D.OR.220\(b\)](#) relative to incidents:

- (1) Preparation of procedures and delineation of roles and responsibilities to respond in a timely, effective and orderly manner to any relevant information security incidents.
- (2) The response procedure should:
 - (i) consider the warnings, unitary or combined, from [IS.D.OR.220\(a\)](#)
 - (ii) establish, in accordance with [IS.D.OR.220\(b\)\(2\)](#), a containment strategy for each asset category considering the potential worst-case effect and the mission constraints, and provide criteria indicating when the incident is contained;

- (iii) define, in accordance with [IS.D.OR.220\(b\)\(3\)](#), the acceptable impact on safety and information security of each asset within the scope when they fail due to the materialisation of a threat scenario.
- (3) The response time should be commensurate with the impact level assessed in (2)(iii).
- (4) The response measures implemented under [IS.D.OR.220\(b\)](#) should be based on the response procedure referred to in the point (a)(2) and they should, in particular, consider the following:
 - (i) the maximum acceptable safety level degradation of the assets within the scope of incident;
 - (ii) the actions, such as resistance, containment, deception and control of the possible ways systems can fail, which will contribute to achieving the acceptable safety level degradation identified in point (i) while minimising the impact on operations;
 - (iii) the resources required to implement the actions specified in point (ii).
- (5) The response time and the measures should take into account the potential immediate negative impact on safety if the measure is taken before it has been fully verified that it would not cause additional immediate safety impacts.

(b) VULNERABILITIES

The organisation should take into account the following aspects when establishing compliance with the objectives contained in point [IS.D.OR.220\(b\)](#) relative to vulnerabilities:

- (1) Establishment of a vulnerability management strategy defining procedures, roles and responsibilities to respond in a timely, effective and orderly manner to any detected relevant vulnerabilities.
- (2) The response measures implemented under point [IS.D.OR.220\(b\)](#) should be based on the maximum acceptable risk of the items within the scope of the vulnerability, considering the worst-case scenario of the vulnerability being exploited.
- (3) The response time should be commensurate with the pre-triage done on the warnings and the assessment of the potential impact of the vulnerability, if it is exploited.

GM1 IS.D.OR.220(b) Information security incidents — detection, response and recovery

ED Decision 2023/009/R

An attack is considered contained (i.e. it is not spreading any further) when the boundaries of the incident have been identified and the threat does not propagate beyond these boundaries. Further guidance can be found in EUROCAE ED-206, Chapter 5.

The term ‘warning’ as used in [IS.D.OR.220](#) should be understood as an alert that would require timely awareness and response from the information security events management team.

In the context of information security response, ‘deception’ refers to a range of techniques that aim to mislead potential attackers or malicious users, thereby protecting the system and its data. Deception techniques, such as honeypots or breadcrumb trails, are designed to confuse, slow down, or divert attackers, increasing their cost and risk while providing defenders with valuable time and intelligence.

Guidance regarding the vulnerability management strategy can be found in EUROCAE ED-206, Chapter 3.4 — Vulnerability management considerations. This is not the only source where guidance can be found, and the organisation may refer to different guidance more appropriate for their application.

AMC1 IS.D.OR.220(c) Information security incidents — detection, response and recovery

ED Decision 2023/009/R

When complying with the requirement in [IS.D.OR.220\(c\)](#), the organisation should develop an incident recovery procedure including at least the following:

- (a) a list of those assets that enable safe operations, as well as the dependencies among them, constituting the scope of the recovery;
- (b) a description of the process with the necessary priority actions to be executed for a return to a safe and secure state for the assets within the scope of the recovery;
- (c) the resources required to execute the actions defined in point (b) to ensure that these resources are readily available after an incident has occurred;
- (d) the objectives for recovery time that should be set in relation to the safety criticality of the assets within the scope of the recovery.

GM1 IS.D.OR.220(b)&(c) Information security incidents — detection, response and recovery

ED Decision 2023/009/R

RECOVERY OBJECTIVES AND TIMING

Point [IS.D.OR.220\(b\)](#) addresses event conditions which may develop or have developed into information security incidents, that may have a potential impact on aviation safety, and require response and recovery measures to be in place to ensure that operational safety remains above a minimum acceptable level.

The level of operations and safety may be interrelated, so in some cases when the level of operations is compromised by an information security incident and drops, the level of safety does the same. This is, for instance, the case of air traffic control; if air traffic services are reduced or become unreliable, the safety of flights is reduced too.

However, in other cases the relation between the level of operations and safety may be the inverse, or they may be decoupled, so when an incident occurs and the level of operations drops, the level of safety is preserved. One example is the compromise of the software loading process on board the aircraft. In this case, a detected incident followed by the decision to interrupt the software loading operations would preserve the existing level of safety.

The following Figure 1 depicts a conceptual framework that may be considered for the definition of the response and recovery objectives, including the recovery time. It represents, in the worst-case scenario, how the expected level of operational safety (safety level) for a process or an activity may vary over time when an information security incident occurs. In this scenario, the safety level is first reduced by the incident and then it degrades as long as the time passes. The figure also shows the expected effect that mitigating measures and controls should have, respectively: in containing the operational safety drop as soon as an incident occurs, and in improving the recovery, i.e. the return to the expected safety level.

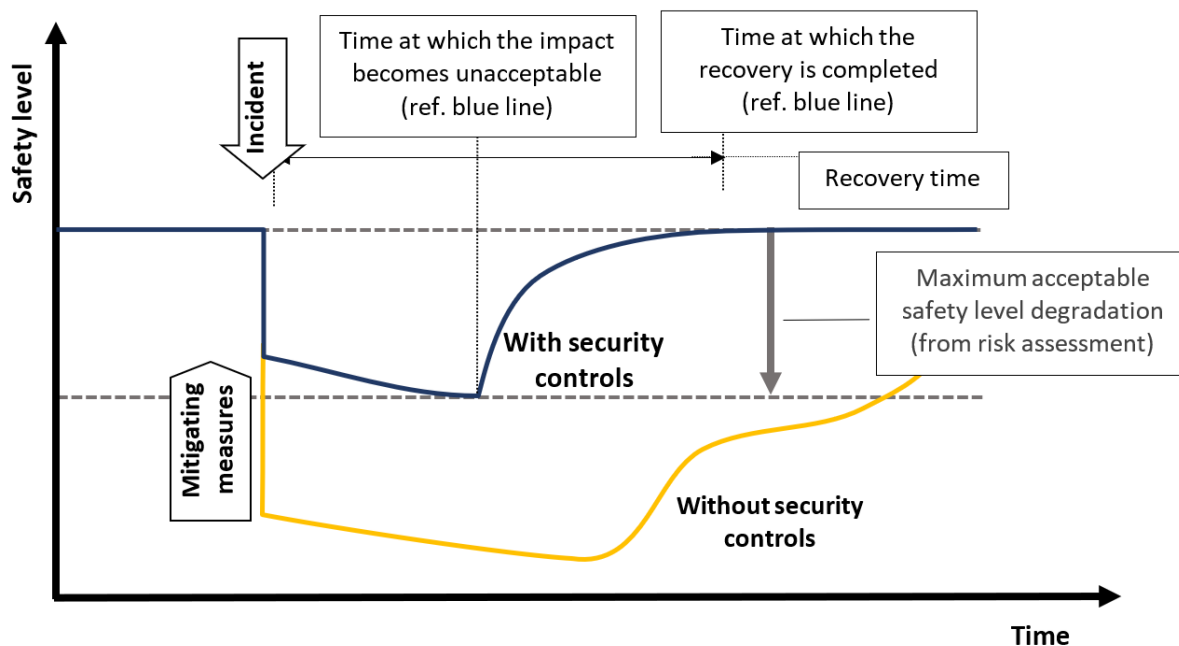


Figure 1: Conceptual framework for the definition of the response and recovery objectives

As mentioned, there might be different relations between the level of operations and safety that would lead to a different representation of the above figure. In certain cases, an incident may have a delayed effect on the safety level (e.g. a compromised development environment) as depicted in Figure 2, or it may have no impact if properly controlled, as in the case of the compromised software loading process mentioned before, which is depicted in Figure 3.

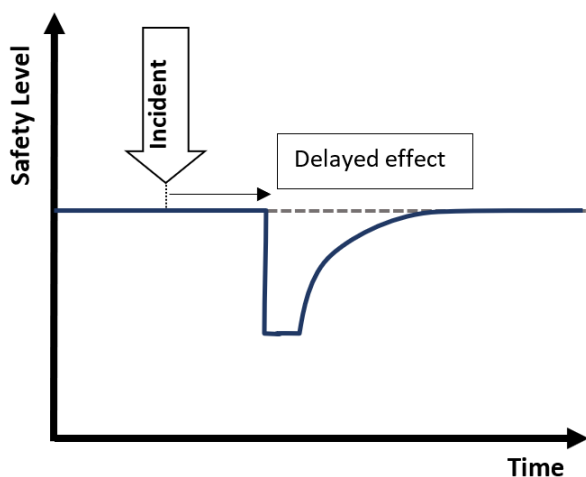


Figure 2: Incident with a delayed effect on safety

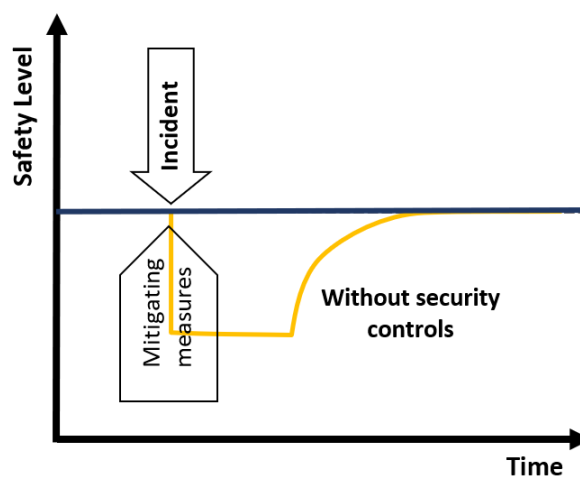


Figure 3: Incident with a fully mitigated effect on safety

Moreover, it should be noticed that there might be different ways the same incident can be dealt with, since there are several factors that may affect safety.

In practical terms, the objectives for recovery time referred to in [AMC1 IS.D.OR.220\(c\)](#) may be expressed as a list of resources and services to be restored by order of priority, within the scope of

the recovery. Guidance about objectives for recovery time can be found in EUROCAE ED-206, Chapter 7.3.5.

GM1 IS.D.OR.220(c) Information security incidents — detection, response and recovery

ED Decision 2023/009/R

A recovery procedure or recovery plan should describe incident recovery actions and the internal or external resources that are involved (e.g. staff, IT, buildings, providers). Guidance about incident recovery plan can be found in EUROCAE ED-206, Chapter 7 – Recover.

The resources required to apply the recovery measures should be available in order to implement the recovery actions in a timely manner after an incident has occurred. Those resources may be internally available or provided by contracted organisations as provided for in [IS.D.OR.235](#). The contracting of recovery activities should be established before an incident occurs (proactive), and the contract should include provisions for the contracted party to react in a timely manner.

The return to a safe and secure state may initially require emergency measures, which are actions that are initiated based on the best information available at the time, before complete understanding of the situation is achieved and these measures can potentially degrade the level of service or functionalities. The return to a safe and secure state should be evaluated against the initial risk assessment and may only temporarily differ from the normal operational conditions. However, any increase of the residual risk and the duration of this risk increase, i.e. due to the implementation of emergency measures, should be documented and accepted at the right level of accountability.

The recovery activities mentioned here may also be the outcome of the response to incidents for which the organisation has received information that requires the implementation of adequate measures in order to react to information security incidents or vulnerabilities with a potential impact on aviation safety.

In such context the organisation may not have a process or a recovery plan covering the specific occurrence. Therefore, the definition from the organisation of a specific recovery plan and its approval by the competent authority is usually required.

IS.D.OR.225 Response to findings notified by the competent authority

Regulation (EU) 2022/1645

- (a) After receipt of the notification of findings submitted by the competent authority, the organisation shall:
 - (1) identify the root cause or causes of, and contributing factors to, the non-compliance;
 - (2) define a corrective action plan;
 - (3) demonstrate the correction of the non-compliance to the satisfaction of the competent authority.
- (b) The actions referred to in point (a) shall be carried out within the period agreed with the competent authority.

AMC1 IS.D.OR.225 Response to findings notified by the competent authority

ED Decision 2023/009/R

The compliance with [IS.D.OR.225](#) should be managed as required for each organisation in the corresponding implementing regulation for the domain as identified in point [Article 2](#)(1) of Regulation (EU) 2022/1645 concerning the response to findings notified by the competent authority. The domain regulation may require the organisation to respond to the findings in accordance with their categorisation.

GM1 IS.D.OR.225 Response to findings notified by the competent authority

ED Decision 2023/009/R

The requirement for the categorisation of findings and the period within which the actions in [IS.D.OR.225](#)(a) should be performed can be found in the corresponding implementing regulation for the domain, under the authority requirements. For the opening of findings related to this Regulation, the competent authority will follow the above-mentioned requirement.

IS.D.OR.230 Information security external reporting scheme

Regulation (EU) 2022/1645

- (a) The organisation shall implement an information security reporting system that complies with the requirements laid down in [Regulation \(EU\) No 376/2014](#) and its delegated and implementing acts if that Regulation is applicable to the organisation.
- (b) Without prejudice to the obligations of Regulation (EU) 376/2014, the organisation shall ensure that any information security incident or vulnerability, which may represent a significant risk to aviation safety, is reported to their competent authority. Furthermore:
 - (1) where such an incident or vulnerability affects an aircraft or associated system or component, the organisation shall also report it to the design approval holder;
 - (2) where such an incident or vulnerability affects a system or constituent used by the organisation, the organisation shall report it to the organisation responsible for the design of the system or constituent.
- (c) The organisation shall report the conditions referred to in point (b) as follows:
 - (1) a notification shall be submitted to the competent authority and, if applicable, to the design approval holder or to the organisation responsible for the design of the system or constituent, as soon as the condition has been known to the organisation;
 - (2) a report shall be submitted to the competent authority and, if applicable, to the design approval holder or to the organisation responsible for the design of the system or constituent, as soon as possible, but not exceeding 72 hours from the time the condition has been known to the organisation, unless exceptional circumstances prevent this.

The report shall be made in the form defined by the competent authority and shall contain all relevant information about the condition known to the organisation;
 - (3) a follow-up report shall be submitted to the competent authority and, if applicable, to the design approval holder or to the organisation responsible for the design of the system

or constituent, providing details of the actions the organisation has taken or intends to take to recover from the incident and the actions it intends to take to prevent similar information security incidents in the future.

The follow-up report shall be submitted as soon as those actions have been identified, and shall be produced in the form defined by the competent authority.

GM1 IS.D.OR.230 Information security external reporting scheme

ED Decision 2023/009/R

Organisations are required to report occurrences to their competent authority.

EXAMPLES

Design organisations approved by EASA: EASA is the competent authority.

Air operators certified by the competent authority of a Member State: the competent authority of the Member State is the competent authority.

SPECIAL CASES

In a situation where an organisation has two air operator certificates (AOCs) under two different EU Member States (State A and B), the occurrences involving aircraft operating under the State A AOC have to be reported to the State A competent authority, instead the occurrences involving aircraft operating under the State B AOC have to be reported to the State B competent authority.

For organisations holding multiple approvals, the reporting will be done to the competent authority of the approved part of the organisation where the incident has occurred, or the vulnerability has been discovered. In case the incident/vulnerability affects multiple approvals, the reporting will be done to all the competent authorities.

For organisations holding an approval but operating outside the EU (e.g. Part-145), EASA is the competent authority and they have to report to the Agency.

Dual-use aircraft — a vulnerability may need to be reported through both the military and civil reporting systems if it affects a dual-use function/system. Information reported through the civil reporting system should be sanitised (i.e. all sensitive information should be properly removed).

AMC1 IS.D.OR.230(a)&(b) Information security external reporting scheme

ED Decision 2023/009/R

In order to comply with the provisions under [IS.ID.OR.230](#) (a) and (b), the organisation should report:

- (a) any occurrence covered by Regulation (EU) No 376/2014 that originated from intentional unauthorised electronic interactions;
- (b) information security incidents having a potential significant risk to aviation safety not covered under Regulation (EU) No 376/2014;
- (c) vulnerabilities that pose a significant risk to aviation safety and are not yet adequately mitigated in accordance with an approved vulnerability management strategy (see [AMC1 IS.D.OR.220\(b\)](#)).

From the aforementioned reports, it is the responsibility of the competent authorities under Part-IS to ensure compliance with [Article 7](#) of this Regulation and to submit any relevant information that

needs to be shared with the information security competent authorities designated under Article 8 of Directive (EU) 2016/1148.

GM1 IS.D.OR.230(a)&(b) Information security external reporting scheme

ED Decision 2023/009/R

RELATION BETWEEN [IS.D.OR.230\(b\)](#) AND REGULATION (EU) No 376/2014

Regulation (EU) No 376/2014 of the European Parliament and of the Council lays down requirements on the reporting, analysis and follow-up of occurrences in civil aviation. Compliance with point [IS.D.OR.230\(b\)](#) does not exempt organisations from compliance with Regulation (EU) No 376/2014.

For each category of reporter, Regulation (EU) No 2015/1018 defines the nature of items to be mandatorily reported. Regulation (EU) No 376/2014 also considers voluntary reporting of other items that are perceived by the reporter as a threat to aviation safety.

Furthermore, compliance with Regulation (EU) No 376/2014 does not exempt organisations from compliance with point [IS.D.OR.230\(b\)](#). However, this should not give rise to two parallel reporting systems, and point [IS.D.OR.230\(b\)](#) and Regulation (EU) No 376/2014 should be seen as complementary in that respect.

In practice, this means that reporting obligations under point [IS.D.OR.230\(b\)](#) on the one hand and reporting obligations under Regulation (EU) No 376/2014 on the other hand are compatible. These reporting obligations may be discharged using one reporting channel. In addition, any natural or legal person that has more than one role subject to the obligation to report may discharge all those obligations through a single report. Organisations are encouraged to properly describe this in their organisation manual, to address cases in which the responsibilities are discharged on behalf of the organisation.

FOLLOW-UP ANALYSIS

When the analysis of an occurrence reported under Regulation (EU) No 376/2014 later identifies that the root cause of, or the contributing factor to, the occurrence was an intentional unauthorised electronic interaction, the organisation should update its notification to the competent authority.

SIGNIFICANT RISK TO AVIATION SAFETY

In line with the definition of occurrence under Article 2(7) of Regulation (EU) No 376/2014 any information security incident or vulnerability, which may represent a significant risk to aviation safety should be considered a reportable occurrence. Significant risk to aviation means unsafe condition, i.e. one that can result in an accident or a serious incident (as defined in ICAO Annex 13).

Note: When assessing the possibility that the effects of an information security incident could lead to an unsafe condition, the organisation should consider the combination of effects if the incident involves multiple systems; indeed, some assumptions about system independence that may be valid for fortuitous occurrences may be violated by deliberate acts.

RELATION BETWEEN [IS.D.OR.230\(b\)\(1\)](#) AND OTHER REPORTING REQUIREMENTS OF information security occurrences RELATED TO AVIATION PRODUCTS OR PARTS

For organisations subject to reporting requirements of information security occurrences related to aviation products or parts, compliance with the specific provisions in the implementing regulation for their domain is considered sufficient to achieve compliance with the requirement in point

[IS.D.OR.230](#)(b)(1). For example, for organisations subject to Regulation (EU) No 748/2012, the reporting can be done in accordance with point 21.A.3A of Annex I (Part 21) to that Regulation.

AMC1 IS.D.OR.230(c) Information security external reporting scheme

ED Decision 2023/009/R

Within the overall limit of 72 hours the degree of urgency for submission of a report should be determined by the level of the safety impact judged to have resulted from the information security incident or discovered vulnerability. Where an occurrence is judged by the person identifying the possible unsafe condition to have resulted in an immediate and particularly significant hazard, the competent authority expects to be advised immediately and by the fastest possible means (telephone, fax, email, telex, etc.) of whatever details are available at that time.

GM1 IS.D.OR.230(c) Information security external reporting scheme

ED Decision 2023/009/R

Guidance regarding the reporting of information security incidents and vulnerabilities can be found in EUROCAE ED-206, Chapter 6.4.2.2 — Reporting timeline and Chapter 6.4.5 — Reporting information content. This is not the only source where guidance can be found, and the organisation may refer to different guidance more appropriate for their application.

Note: The person reporting an occurrence under Regulation (EU) No 376/2014 may not have the capability to determine the nature of the occurrence. This is particularly true for information security and the result can come from forensic analysis that determines the information security nature of the occurrence. The evaluation will be done as part of the initial internal reporting process (see [IS.D.OR.215](#) and related AMC). The evaluation of the occurrence can demonstrate the possibility that it materialises into an unsafe condition taking into account the likelihood of realisation.

IS.D.OR.235 Contracting of information security management activities

Regulation (EU) 2022/1645

- (a) The organisation shall ensure that when contracting any part of the activities referred to in point [IS.D.OR.200](#) to other organisations, the contracted activities comply with the requirements of this Regulation and the contracted organisation works under its oversight. The organisation shall ensure that the risks associated with the contracted activities are appropriately managed.
- (b) The organisation shall ensure that the competent authority can have access upon request to the contracted organisation to determine continued compliance with the applicable requirements laid down in this Regulation.

GM1 IS.D.OR.235 Contracting of information security management activities

ED Decision 2023/009/R

Organisations may decide to outsource certain activities to suppliers, both for their own operational needs and for the purpose of complying with this Regulation (information security management

activities). Activities contracted for operational needs may fall within the scope of Part-IS and therefore the relevant information security risks have to be managed in accordance with the requirements in points [IS.D.OR.205](#) and [IS.D.OR.210](#). Instead, information security management activities are subject to the specific provisions of [IS.D.OR.235](#) because matters relating to these activities can have a major impact on the organisation.

Therefore the objectives of point IS.D.OR.235 are:

- (a) to protect critical and sensitive information and assets when being handled by organisations contracted for the provision of information security management activities (including organisations in the supply chain) at either their facilities or the organisation facilities, or when being transmitted between the organisation and contracted organisations, or being remotely accessed by contracted organisations;
- (b) to prevent information security risks from being introduced through products and services developed or provided by the contracted organisations to the organisation, in the frame of the provision of information security management activities;
- (c) to ensure that information security risks are managed throughout all the stages of the relation with the contracted organisations.

GM2 IS.D.OR.235 Contracting of information security management activities

ED Decision 2023/009/R

- (a) The contracting of information security management activities is a means to allocate tasks from the contracting organisation to third parties (contracted organisations). The contracting organisation remains responsible for the oversight of the contracted organisation(s) and accountable for compliance with this Regulation.
- (b) A contract could take the form of a written agreement, letter of agreement, service letter agreement, memorandum of understanding, etc. as appropriate for the contracted activities.

GM3 IS.D.OR.235 Contracting of information security management activities

ED Decision 2023/009/R

EXAMPLES

The following Table 1 provides some examples of information security management activities that may be contracted in relation to the provisions referred to as in [IS.D.OR.200](#).

Table 1: Examples of information security management activities that may be contracted

IS.D.OR.200 points related to activities	Example of contracted activity
(a)(1): establishes a policy on information security setting out the overall principles of the organisation with regard to the potential impact of information security risks on aviation safety;	Information security policy drafting and consultancy

IS.D.OR.200 points related to activities	Example of contracted activity
(a)(2): identifies and reviews information security risks in accordance with point IS.D.OR.205 ;	Identify activities, facilities and resources. Identify interfaces with other organisations which could be exposed to information security risks. Perform risk analysis or part of it, e.g. identify and classify information security risks.
(a)(3) defines and implements information security risk treatment measures in accordance with point IS.D.OR.210 ;	Define, develop and implement measures. Verify the initial and the continued effectiveness of the implemented measures (e.g. red-team/blue-team exercises, penetration testing, vulnerability scanning, etc.). Communicate to the involved stakeholders the outcome of the risk assessment and their responsibilities as part of the risk treatment process.
(a)(4): implements an information security internal reporting scheme in accordance with point IS.D.OR.215 ;	Define, develop and implement an internal reporting scheme to enable the collection and evaluation of information security events and vulnerabilities of equipment, processes and services.
(a)(5): defines and implements, in accordance with point IS.D.OR.220 , the measures required to detect information security events, identifies those events which are considered incidents with a potential impact on aviation safety except as permitted by point IS.D.OR.205 (e), and responds to, and recovers from, those information security incidents;	Define, develop and implement measures to detect events. Define, develop and implement measures to respond to any event conditions. Define, develop and implement measures aimed at recovering from information security incidents. Implement immediate reaction measures to a information security incident or vulnerability as notified by the competent authority.
(a)(6): implements the measures that have been notified by the competent authority as an immediate reaction to an information security incident or vulnerability with an impact on aviation safety;	
(a)(7): takes appropriate action, in accordance with point IS.D.OR.225 , to address findings notified by the competent authority;	Identify root cause. Define corrective action plan. Provide evidence of the corrective actions implemented to close the finding.

IS.D.OR.200 points related to activities	Example of contracted activity
(a)(8):implements an external reporting scheme in accordance with point IS.D.OR.230 in order to enable the competent authority to take appropriate actions;	Define, develop and implement an external reporting scheme to enable the communication of the information security incidents and vulnerabilities of equipment, processes and services to the competent authority and when required to the design approval holder or the organisation responsible for the design.
(a)(9):complies with the requirements contained in point IS.D.OR.235 when contracting any part of the activities described in point IS.D.OR.200 to other organisations;	Not applicable
(a)(10):complies with the personnel requirements contained in point IS.D.OR.240 ;	Activities of the accountable manager / head of design organisation in the frame of the provisions for a ‘common responsible person’ as referred to in IS.D.OR.240 Compliance monitoring as foreseen by IS.D.OR.240 Contracted organisation to ensure that sufficient personnel is on duty to perform the activities related to this Regulation Define, develop and deliver adequate training to achieve the competencies required by the staff. Perform pre-employment checks
(a)(11):complies with the record-keeping requirements contained in point IS.D.OR.245 ;	Define, develop and implement secured archiving. Provision of secure data centre (as a service) Provision of records updates
(a)(12):monitors compliance of the organisation with the requirements of this Regulation and provides feedback on findings to the accountable manager / head of design organisation to ensure effective implementation of corrective actions;	Compliance monitoring (as foreseen by IS.D.OR.240) including the execution of independent audits
(a)(13):protects, without prejudice to applicable incident reporting requirements, the confidentiality of any information that the organisation may have received from other organisations, according to its level of sensitivity.	Define, develop and implement solutions to protect the confidentiality of any information.

IS.D.OR.200 points related to activities	Example of contracted activity
(b): In order to continuously meet the requirements referred to in Article 1, the organisation shall implement a continuous improvement process in accordance with point IS.D.OR.260 .	Execute independent effectiveness and maturity assessments. Define, develop and implement the necessary improvement measures.
(c): The organisation shall document, in accordance with point IS.D.OR.250 , all key processes, procedures, roles and responsibilities required to comply with point IS.D.OR.200 (a), and shall establish a process for amending this documentation. Changes to those processes, procedures, roles and responsibilities shall be managed in accordance with point IS.D.OR.255 .	Production of documentation to detail all key processes, procedures, roles and responsibilities required to comply with point IS.D.OR.200 (a) (e.g. information security policies, general description of the staff, procedures to specify compliance). Define, develop and implement processes for approving amendments and changes.

GM1 IS.D.OR.235(a) Contracting of information security management activities

ED Decision 2023/009/R

PRIOR ASSESSMENT

The purpose of the prior assessment is to evaluate suppliers' competencies, sustainability as well as qualifications in relation to the information security activities to be contracted. This prior assessment may need to be carried out taking into account other legal requirements or procurement procedures that apply to the organisation, and may therefore be carried out in different ways, such as:

- (a) in case of public bids, inclusion of eligibility requirements in the procurement documents for the potential suppliers;
- (b) review of the information security certifications granted by external and impartial auditors to the potential suppliers;
- (c) review of self-assessment questionnaires compiled by the potential suppliers;

RISK ASSESSMENT ASSOCIATED WITH THE PROVISION OF THE CONTRACTED ACTIVITIES

The risk assessment should take into account the maturity level of the contracted organisation, and should consider the following:

- (a) identification and assessment of critical and sensitive information and assets that may be shared with, or provided by, external suppliers;
- (b) identification of the information security requirements of the organisation that are applicable to the contracted organisation;
- (c) evaluation, by means of a supplier assessment, of the ability of the contracted organisation (both existing and new contracted organisations) to meet the information security requirements of the contracting organisation;
- (d) assessment of risks that may be introduced by the contracted organisation.

This agreed risk assessment should also consider the roles and responsibilities of the contracting and contracted organisation as well as their interfaces.

AMC1 IS.D.OR.235(a) Contracting of information security management activities

ED Decision 2023/009/R

(a) OVERSIGHT OF THE CONTRACTED ORGANISATION

In order to exercise oversight of the contracted organisation, the organisation under Part-IS should have:

- (1) a process to ensure compliance with the provisions regarding contracted activities contained in this Regulation;
- (2) a structured process to follow the expected execution of the contract that includes:
 - (i) definition and agreement of the scope of the activities;
 - (ii) definition of the roles and responsibilities of the parties (i.e. contracting and contracted organisation).
 - (iii) definition and review of key performance indicators;
 - (iv) reaction to deviation from contractual obligations;
 - (v) performance of compliance audits, according to the predefined scope and objectives, with the aim of evaluating operational and associated assurance activities.
 - (vi) provision of feedback on the result of the compliance audits both within the organisation and to the contracted organisation, and response to findings. The feedback on the outcome of the compliance audits within the contracting organisation should reach the accountable manager or, in the case of design organisations, the head of the design organisation, or delegated person(s) to ensure proper monitoring of the response to findings (i.e. implementation of corrective actions) or, if deemed necessary, termination of the contract.

Note: The right of the organisation to conduct compliance audits of the contracted organisation should be included in the contract between the parties.

(b) MANAGEMENT OF THE RISKS ASSOCIATED WITH THE CONTRACTED ACTIVITIES

In order to properly manage the risks associated with the contracted activities, the organisation should meet the following criteria:

- (1) A prior assessment of the suppliers is conducted before outsourcing any information security management activities. The assessment should evaluate suppliers' competencies, sustainability as well as qualifications in relation to the activities to be contracted.
- (2) There is an assessment of the risks associated with the provision of the contracted activities that has been agreed between the organisation under Part-IS and the contracted organisation.
- (3) The organisation establishes and maintains appropriate information security communication channels with the contracted organisation.

GM2 IS.D.OR.235(a) Contracting of information security management activities

ED Decision 2023/009/R

AUDIT OF CONTRACTED ORGANISATIONS

The following aspects should be considered by the organisation when auditing a supplier contracted to perform information security management activities:

- the scope of the audit as well as the objective should be limited to processes, resources (i.e. contracted organisation personnel, systems/equipment, networks) and data used for the execution of Part-IS contracted activities;
- compliance and/or implementation audits should be done at the contracting organisation's discretion;
- findings identified during an audit should be addressed through a remediation plan with a time frame to be validated by the contracting organisation.

AMC1 IS.D.OR.235(b) Contracting of information security management activities

ED Decision 2023/009/R

In order to ensure access by the competent authority to the contracted organisation upon request, the organisation under Part-IS should ensure that such a requirement or clause is included in the contractual documentation.

The competent authority's access to the contracted organisations should be at least equivalent to that granted to the contracting organisation and, in any case, sufficient to ensure the assessment of continued compliance of the contracted activities with the applicable requirements.

GM1 IS.D.OR.235(b) Contracting of information security management activities

ED Decision 2023/009/R

Access to the contracted organisation means to have visibility of evidence for compliance of the contracted activities (such as artefacts, documents, independent certifications).

Evidence of compliance could be achieved either by transfer of documents and/or access to information at the premises in accordance with the 'audit scope' as defined in the contract.

In those cases where the organisation would use commercial off-the-shelf services with standard contractual clauses as part of the contracted information security management activities, the organisation should consider whether these clauses provide sufficient access to the required information.

The opportunity to visit the premises should be evaluated considering different aspects such as the sensitivity of the related information or the practical accessibility to the contracted organisation (e.g. the contracted organisation is a service provider with distributed resources).

IS.D.OR.240 Personnel requirements

Regulation (EU) 2022/1645

- (a) The accountable manager of the organisation or, in the case of design organisations, the head of the design organisation, designated in accordance with [Regulation \(EU\) No 748/2012](#) and [Regulation \(EU\) No 139/2014](#) as referred to in points 1(a) and (b) of [Article 2](#) of this Regulation, shall have corporate authority to ensure that all activities required by this Regulation can be financed and carried out. That person shall:
- (1) ensure that all necessary resources are available to comply with the requirements of this Regulation;
 - (2) establish and promote the information security policy referred to in point [IS.D.OR.200\(a\)\(1\)](#);
 - (3) demonstrate a basic understanding of this Regulation.
- (b) The accountable manager or, in the case of design organisations, the head of the design organisation, shall appoint a person or group of persons to ensure that the organisation is in compliance with the requirements of this Regulation, and shall define the extent of their authority. That person or group of persons shall report directly to the accountable manager or, in the case of design organisations, to the head of the design organisation, and shall have the appropriate knowledge, background and experience to discharge their responsibilities. It shall be determined in the procedures who deputises for a particular person in the case of lengthy absence of that person.
- (c) The accountable manager or, in the case of design organisations, the head of the design organisation shall appoint a person or group of persons with the responsibility to manage the compliance monitoring function referred to in point [IS.D.OR.200\(a\)\(12\)](#).
- (d) Where the organisation shares information security organisational structures, policies, processes and procedures, with other organisations or with areas of their own organisation which are not part of the approval or declaration, the accountable manager or, in the case of design organisations, the head of the design organisation, may delegate its activities to a common responsible person.
- In such a case, coordination measures shall be established between the accountable manager of the organisation or, in the case of design organisations, the head of the design organisation, and the common responsible person to ensure adequate integration of the information security management within the organisation.
- (e) The accountable manager or the head of the design organisation, or the common responsible person referred to in point (d), shall have corporate authority to establish and maintain the organisational structures, policies, processes and procedures necessary to implement point [IS.D.OR.200](#).
- (f) The organisation shall have a process in place to ensure that they have sufficient personnel on duty to carry out the activities covered by this Annex.
- (g) The organisation shall have a process in place to ensure that the personnel referred to in point (f) have the necessary competence to perform their tasks.
- (h) The organisation shall have a process in place to ensure that personnel acknowledge the responsibilities associated with the assigned roles and tasks.

- (i) The organisation shall ensure that the identity and trustworthiness of the personnel who have access to information systems and data subject to the requirements of this Regulation are appropriately established.

GM1 IS.D.OR.240 Personnel requirements

ED Decision 2023/009/R

The objectives of the requirements contained in points (a) through (e) are:

- (a) to ensure that an effective organisational structure is in place in order to comply with the requirements of this Regulation;
- (b) to provide trust to other organisations with whom they share risks.

AMC1 IS.D.OR.240(a)(2) Personnel requirements

ED Decision 2023/009/R

PROMOTION OF INFORMATION SECURITY POLICY

The accountable manager or, in the case of design organisations, the head of the design organisation of the organisation should make sure that the information security policy is known and easily accessible for staff members as appropriate to their duties.

AMC1 IS.D.OR.240(a)(3) Personnel requirements

ED Decision 2023/009/R

BASIC UNDERSTANDING OF THE REGULATION

In order to demonstrate a basic understanding of this Regulation, the accountable manager of the organisation or, in the case of design organisations, the head of the design organisation should have the ability to explain the overarching objectives of the Regulation and its implications for the organisation.

GM1 IS.D.OR.240(a)(3) Personnel requirements

ED Decision 2023/009/R

BASIC UNDERSTANDING OF THE REGULATION

In the event that the accountable manager or, in the case of design organisations, the head of the design organisation has no previous experience in the areas of activity pertinent to Part-IS, he or she may gain the necessary understanding by attending a training covering the content the Regulation and the technical basis for compliance. In particular, the training material should cover the overarching objectives of Part-IS, and the assessment should evaluate the understanding of these regulatory objectives.

AMC1 IS.D.OR.240(b) Personnel requirements

ED Decision 2023/009/R

APPOINTMENT OF A PERSON OR GROUP OF PERSONS

The person or group of persons appointed under point [IS.D.OR.240\(b\)](#) with the responsibility to ensure compliance with the requirements of this Regulation should represent the management structure of the organisation.

The person or group of persons has direct access to the accountable manager or, in the case of design organisations, to the head of the design organisation (or the common responsible person, if appointed) to provide guidance, direction and support for the planning, implementation and operation of the process and standards to comply with the Regulation. They should have direct access to keep the accountable manager or, in the case of design organisations, the head of the design organisation (or the common responsible person) properly informed on compliance and information security matters (for instance, through meetings organised on a regular basis).

Appointments should take into account the possibility that a person may not be able to carry out the organisational tasks assigned to them for a period of time, and thus also identify the necessary deputies.

These appointed persons should demonstrate a complete understanding of the requirements of this Regulation, to be able to ensure that the organisation's processes and standards accurately reflect the applicable requirements. It is their role to ensure that compliance is proactively managed, and that any early warning signs of non-compliance are documented and acted upon.

A description of the functions and the responsibilities of the appointed persons and deputies, including their names, should be contained in the ISMM (see point [IS.D.OR.250\(a\)\(2\)](#)).

GM1 IS.D.OR.240(b) Personnel requirements

ED Decision 2023/009/R

A condition of a lengthy absence of an appointed person occurs when that person is unable to perform the assigned organisational duties. For example, if an information security management activity is required to be carried out by appointed persons at a specified interval, an absence is considered lengthy when it exceeds this interval and therefore a vulnerability in the management activity may arise.

GM1 IS.D.OR.240(b)&(c) Personnel requirements

ED Decision 2023/009/R

Appointments may be made by email, organisational chart, roles & responsibilities table, etc. usually in use by the organisation. The organisation may adopt any titles for the foregoing information security management positions, but it should identify to the competent authority the titles and the persons chosen to carry out these functions.

GM1 IS.D.OR.240(c) Personnel requirements

ED Decision 2023/009/R

COMPLIANCE MONITORING FUNCTION

The person appointed under point [IS.D.OR.240\(c\)](#) with the responsibility to manage the compliance monitoring function required under point [IS.D.OR.200\(a\)\(12\)](#) may be the same person as, or report to, the person responsible for the compliance monitoring function required under the implementing regulation for the domain.

AMC1 IS.D.OR.240(d) Personnel requirements

ED Decision 2023/009/R

COORDINATION

The criteria to establish coordination that ensures adequate integration of the information security management within the organisation are the following:

- (a) the scope and boundaries of the organisations have been established and communicated to the common responsible person;
- (b) the requirements of this Regulation have been communicated to and shared with the common responsible person;
- (c) the common responsible person has direct access to the accountable manager or, in the case of design organisations, to the head of the design organisation;
- (d) issues are proactively managed and any early warning signs of non-compliance are documented and acted upon.

GM1 IS.D.OR.240(e) Personnel requirements

ED Decision 2023/009/R

COMMON RESPONSIBLE PERSON

If a common responsible person (CRP) is delegated by the accountable manager or, in the case of design organisations, by the head of the design organisation for the activities under this Regulation, this person should also be given the appropriate delegation that is necessary to implement the provisions of [IS.D.OR.200](#), including the authority and the financial means to mobilise and control the resources across the organisations, or parts of the organisation involved. This delegation may also include the appointment of the person or group of persons referred to in [IS.D.OR.240\(b\)](#) and (c) and, in general, the CRP may be assisted in the performance of his or her duties by additional personnel.

The possibility of delegating a CRP applies to an organisation that shares information security organisational structures, policies, processes and procedures with other organisations or with parts of its own organisation that are not part of the authorisation or declaration, and therefore this CRP is expected to have information security responsibilities and competencies. In particular, the CRP should be capable of managing the organisation's information security strategy and its implementation to ensure the achievement of the objectives described in Article 1. According to the European Cybersecurity Skills Framework (ECSF) published by ENISA in September 2022, this person may be described, for instance, as (Chief) Information Security Officer, Cybersecurity Programme Director or Information Security Manager. However, it should be noticed that these descriptions and the related skills do not consider the aviation safety perspective that is required in Article 1.

Where an entity holds multiple authorisations or declarations, the relevant accountable managers or, in the case of design organisations, the relevant head of the design organisations may delegate to the same CRP, who will therefore be responsible for implementing the provisions of [IS.D.OR.200](#) for a functional cluster sharing information security structures, policies, processes and procedures.

AMC1 IS.D.OR.240(f) Personnel requirements

ED Decision 2023/009/R

SUFFICIENT PERSONNEL

To determine the sufficiency of the personnel, the following elements should be taken into consideration:

- (a) the organisational structures, policies, processes and procedures subject to information security management;
- (b) the amount of coordination required with other organisations, contractors and suppliers;
- (c) the level of risk associated with the activities performed by the organisation.

GM1 IS.D.OR.240(f) Personnel requirements

ED Decision 2023/009/R

SUFFICIENT PERSONNEL

For the purpose of this Regulation, personnel refers to the combination of the personnel directly employed by the organisation, as well as the personnel contracted as specified in [IS.D.OR.235](#).

The activities reported in Appendix II, on the main tasks stemming from the implementation of Part-IS, should be considered when establishing the organisational structure necessary to comply with the requirements of this Regulation.

AMC1 IS.D.OR.240(g) Personnel requirements

ED Decision 2023/009/R

NECESSARY COMPETENCE

- (a) To determine the competence needed by the personnel performing the activities, the following elements should be taken into consideration:
 - (1) work roles and the associated tasks;
 - (2) required knowledge, skills and abilities.
- (b) As part of the process to ensure that personnel maintain the necessary competence, the organisation should:
 - (1) assess the personnel qualifications and experience with respect to the competence required for the assigned work roles to identify gaps;
 - (2) align the personnel qualifications and experience with the competence expected to fulfil their roles by organising adequate learning programmes for existing members of personnel, by recruiting new resources, or by a combination thereof;
 - (3) maintain the personnel competence during the time they are assigned to the work role.

GM1 IS.D.OR.240(g) Personnel requirements

ED Decision 2025/014/R

NECESSARY COMPETENCE AND TRAINING PROGRAMME

A training programme should start with the identification of the competence required by the personnel for each role, followed by the identification of the gaps between the existing competence and the required one.

In order to develop the list of competencies an organisation may use, as initial guidance, an existing cybersecurity competence framework such as the European e-Competence Framework (e-CF) or the NICE (National Initiative for Cybersecurity Education) based on the NIST Cybersecurity Framework (NIST CSF).

In [Appendix II](#), the main tasks of this Regulation are listed and mapped to the competences derived from the EU e-CF or, for ease of mapping, to the functions and categories of the NIST CSF. This mapping may be used to establish a baseline to identify the aforementioned competence gaps. However, it should be noticed that existing cybersecurity/information security competence frameworks typically focus primarily on the protection of standard information technologies; therefore, the proposed list of competencies may need to be adapted to the technologies or integrated with processes used in the organisation.

The bridging of the identified gaps should be seen as the objective of the training programme, which should further include the scope, content, methods of delivery (e.g. classroom training, e-learning, notifications, on-the-job training) and frequency of training that best meet the organisation's needs considering the size, scope, required competencies, and complexity of the organisation.

Finally, as information security/cybersecurity evolves due to the rise of new threats, the organisation should periodically review the adequacy of the training programme.

ROLE-BASED COMPETENCE FRAMEWORK

Although under this Regulation there are no provisions for specific roles, besides the optional nomination of a CRP, for organisations characterised by a large number of staff members and hierarchical layers it may be convenient to identify some roles and the related required competencies. To this end, EASA has developed an adaptation of the European Cybersecurity Skills Framework (ECSF) published by ENISA in September 2022 that can be found in [Appendix VI](#).

AMC1 IS.D.OR.240(h) Personnel requirements

ED Decision 2023/009/R

ACKNOWLEDGEMENT OF RESPONSIBILITIES

Regarding any assigned role and task, the organisation should specify all information security responsibilities an employee has in a clear and transparent manner.

As part of this, all personnel performing the activities required under this Regulation should acknowledge, in a traceable and verifiable manner, understanding of the assigned roles and the associated information security responsibilities.

GM1 IS.D.OR.240(h) Personnel requirements

ED Decision 2023/009/R

ACKNOWLEDGEMENT OF RESPONSIBILITIES

Acknowledgement of receipt such as a valid electronic or wet signature, confirmation email, etc., is a traceable proof of acknowledgement.

AMC1 IS.D.OR.240(i) Personnel requirements

ED Decision 2023/009/R

IDENTITY AND TRUSTWORTHINESS

For the personnel who have access to information systems and data subject to the requirements of Part-IS, the identity should be determined on the basis of documentary evidence.

To establish the trustworthiness of such personnel, the organisation should have a documented process and appropriate criteria to ensure that individuals can be trusted to perform their role.

GM1 IS.D.OR.240(i) Personnel requirements

ED Decision 2023/009/R

IDENTITY AND TRUSTWORTHINESS

(a) Trustworthiness may be established, for example, by:

- (1) prior to employment, a background check carried out in accordance with the applicable rules of Union and national law. This check may include verification of:
 - (i) education, previous employment and any gaps in the previous years;
 - (ii) absence of criminal record;
 - (iii) any other relevant information or intelligence considered relevant to the suitability of a person to work in the expected role;
- (2) during employment, monitoring the employee's commitment and conduct.

Note: The absence of criminal record may be verified by means of a certificate issued by the responsible authority in the Member State in accordance with Regulation (EU) 2016/1191. In the case of prospective foreign employees, the above checks may be carried out on the basis of equivalent certificates issued by the country of origin, such as a 'certificate of good conduct'.

- (b) Furthermore, the process and criteria to establish personnel's trustworthiness may have to consider whether:
- (1) the information systems and data to be accessed have been associated with a high severity of the safety consequences with the risk assessment process under [IS.D.OR.205](#);
 - (2) controls or mitigating measures for risk treatment identified during the risk analysis rely on organisational/operational procedures — for instance, correct configuration and administration of information technologies, database operations, information security monitoring, etc.

In such cases, the personnel who have administrator rights or unsupervised and unlimited access to the systems and data mentioned in (a) (1), or the personnel who applies the measures under above point (b)(2), may be subject to more stringent criteria.

- (c) Intelligence and any other relevant information may be gathered by screening and analysing public sources such as social media and websites, within the limits set by relevant national laws and regulations.
- (d) Some organisations subject to Part-IS may also be subject to Regulation (EU) 2015/1998 that requires successful completion of background checks for personnel in certain roles, as well as a mechanism for the ongoing review of these checks. In such cases the organisation may consider suitable for the establishment of the personnel's identity and trustworthiness required under Part-IS, in relation to their role, the process and the relevant criteria defined in Regulation (EU) 2015/1998 for standard and enhanced background checks. However, it should be noted that compliance with the provisions for the establishment of identity and trustworthiness under Part-IS does not constitute compliance with the provisions on background checks as defined in Regulation (EU) 2015/1998.

IS.D.OR.245 Record-keeping

Regulation (EU) 2022/1645

- (a) The organisation shall keep records of its information security management activities
 - (1) The organisation shall ensure that the following records are archived and traceable:
 - (i) any approval received and any associated information security risk assessment in accordance with point [IS.D.OR.200](#)(e;)
 - (ii) contracts for activities referred to in point [IS.D.OR.200](#)(a)(9);
 - (iii) records of the key processes referred to in point [IS.D.OR.200](#)(d);
 - (iv) records of the risks identified in the risk assessment referred to in point [IS.D.OR.205](#) along with the associated risk treatment measures referred to in point [IS.D.OR.210](#);
 - (v) records of information security incidents and vulnerabilities reported in accordance with the reporting schemes referred to in points [IS.D.OR.215](#) and [IS.D.OR.230](#);
 - (vi) records of those information security events which may need to be reassessed to reveal undetected information security incidents or vulnerabilities.
 - (2) The records referred to in point (1)(i) shall be retained at least until 5 years after the approval has lost its validity.
 - (3) The records referred to in point (1)(ii) shall be retained at least until 5 years after the contract has been amended or terminated.
 - (4) The records referred to in point (1)(iii), (iv) and (v) shall be retained at least for a period of 5 years.
 - (5) The records referred to in point (1)(vi) shall be retained until those information security events have been reassessed in accordance with a periodicity defined in a procedure established by the organisation.
- (b) The organisation shall keep records of qualification and experience of its own staff involved in information security management activities

- (1) The personnel's qualification and experience records be retained for as long as the person works for the organisation, and for at least 3 years after the person has left the organisation.
 - (2) Members of the staff shall, upon their request, be given access to their individual records. In addition, upon their request, the organisation shall provide them with a copy of their individual records on leaving the organisation.
- (c) The format of the records shall be specified in the organisation's procedures.
- (d) Records shall be stored in a manner that ensures protection from damage, alteration and theft, with information being identified, when required, according to its security classification level. The organisation shall ensure that the records are stored using means to ensure integrity, authenticity and authorised access.

GM1 IS.D.OR.245 Record-keeping

ED Decision 2023/009/R

Records are required to document results achieved or to provide evidence of activities performed. Records become factual when recorded and cannot be modified. Therefore, they are not subject to version control. Even when a new record is produced covering the same issue, the previous record remains valid.

The 'approval received' referred to in point (a)(1)(i) includes any 'certificate' received by the organisation when it is provided for by the implementing rule for its domain.

AMC1 IS.D.OR.245(a)(1)(vi)&(a)(5) Record-keeping

ED Decision 2023/009/R

When complying with the requirements under points (a)(1)(vi) and (a)(5), the organisation should establish a data retention policy defining procedures to:

- (a) manage relevant security data files;
- (b) establish the periodical assessment of their content; and
- (c) define the criteria to allow deletion of records of information security events when the objective of the requirement under (a)(5) has been met.

GM1 IS.D.OR.245(a)(1)(vi)&(a)(5) Record-keeping

ED Decision 2023/009/R

The objective of the requirement under (a)(1)(vi) is to ensure detection of possible indication of information security incidents or vulnerabilities which are not obvious by normal operation (e.g. previously unknown situations), while the objective of the requirement under (a)(5) is to allow the necessary flexibility to control the volume of the stored information security events.

Records of information security events include those events identified to be within the scope of the detection activities under [IS.D.OR.220\(a\)](#), as well as other information security data produced by assets that have been identified under [IS.D.OR.205](#).

A data retention policy clarifies what information should be stored or archived and for how long. Some guidance about data retention can be found in EUROCAE ED-206, Chapter 2.6.

Once a data set completes its retention period, it can be deleted or moved as permanent historical data to a secondary or tertiary storage.

AMC1 IS.D.OR.245(c)&(d) Record-keeping

ED Decision 2023/009/R

When complying with the requirements under points (c) and (d) for all the records required by points [IS.D.OR.245](#) (a) and (b), the organisation should consider the following:

- (a) Records should be kept in paper form or in electronic format or a combination of both media. The records should remain accessible whenever needed within a reasonable time and usable throughout the required retention period. The retention period starts when the record has been created.
- (b) Records data integrity, availability and authenticity should be protected in consistency with protection of corresponding operational data, and as such, should be within the scope of the ISMS.
- (c) Storage systems should be protected against unauthorised access (i.e. data leakage attempts against personal data/modification of records) and thus should have information security measures implemented in consistency with the level of information security risk associated with them.
- (d) Once records are not required to be retained anymore, the destruction of records and decommissioning of assets used for their storage should be implemented appropriately.

GM1 IS.D.OR.245(c)&(d) Record-keeping

ED Decision 2023/009/R

RECORDS ACCESSIBILITY THROUGHOUT THE RETENTION PERIOD

It is recommended to follow best practices for data retention and, for data that may need to be restored, backup strategies, such as the use of automated backup tools, segregation or geographic separation of backup storage location(s), and to consider offline backups to prevent ransomware risks. These practices should be considered also when record-keeping is contracted to service providers with distributed resources.

Special attention should be paid to significant hardware and software changes, ensuring that stored digital records remain accessible and readable. (e.g. file system, application file format, forward compatible database versions, etc.). Paper-based information needs to be archived in an adequate environment, in which records are protected against degradation factors (e.g. excessive heat, light or humidity).

RECORDS DATA INTEGRITY AND PROTECTION FROM UNAUTHORISED ACCESS

A commonly used method to achieve authenticity and integrity protection is the use of digital signatures at document level. Digital signatures can be added to the document's file (e.g. PDF) to ensure that a record has not been modified by someone other than its author (integrity) and that the author is who is expected to be (authenticity).

Moreover, to prevent unauthorised access, records can be protected for example by implementing a role-based access control (RBAC) approach, or certain records can be password protected at the file level. Commercial applications feature built-in basic password protection functions for their file formats. Access protection can also be achieved by protecting the environment where the individual records are stored (e.g. access protection on databases, file shares, directories, etc.).

IS.D.OR.250 Information security management manual (ISMM)

Regulation (EU) 2025/22

- (a) The organisation shall make available to the competent authority an information security management manual (ISMM) and, where applicable, any referenced associated manuals and procedures, containing:
- (1) a statement signed by the accountable manager or, in the case of design organisations, by the head of the design organisation, confirming that the organisation will at all times work in accordance with this Annex and with the ISMM. If the accountable manager or, in the case of design organisations, the head of the design organisation, is not the chief executive officer (CEO) of the organisation, then such CEO shall countersign the statement;
 - (2) the title(s), name(s), duties, accountabilities, responsibilities and authorities of the person or persons referred to in point [IS.D.OR.240](#)(b) and (c);
 - (3) the title, name, duties, accountabilities, responsibilities and authorities of the common responsible person referred to in point IS.D.OR.240(d), if applicable;
 - (4) the information security policy of the organisation as referred to in point [IS.D.OR.200](#)(a)(1);
 - (5) a general description of the number and categories of staff and of the system in place to plan the availability of staff as required by point IS.D.OR.240;
 - (6) the title(s), name(s), duties, accountabilities, responsibilities and authorities of the key persons responsible for the implementation of point IS.D.OR.200, including the person or persons responsible for the compliance monitoring function referred to in point IS.D.OR.200(a)(12);
 - (7) an organisation chart showing the associated chains of accountability and responsibility for the persons referred to in points (2) and (6);
 - (8) the description of the internal reporting scheme referred to in point [IS.D.OR.215](#);
 - (9) the procedures that specify how the organisation ensures compliance with this Part, and in particular:
 - (i) the documentation point IS.D.OR.200(c);
 - (ii) the procedures that define how the organisation controls any contracted activities referred to in point IS.D.OR.200(a)(9);
 - (iii) the ISMM amendment procedure defined in point (c);
 - (10) the details of currently approved alternative means of compliance.
- (b) The initial issue of the ISMM shall be approved and a copy shall be retained by the competent authority. An approval shall not be required for declaring organisations. The ISMM shall be amended as necessary to remain an up-to-date description of the ISMS of the organisation. A copy of any amendments to the ISMM shall be provided to the competent authority.
- (c) Amendments to the ISMM shall be managed in a procedure established by the organisation. Any amendments that are not included within the scope of this procedure and any amendments related to the changes referred to in point [IS.D.OR.255](#)(b), shall be approved by the competent authority. An approval shall not be required for declaring organisations.

- (d) The organisation may integrate the ISMM with other management expositions or manuals it holds, provided there is a clear cross reference that indicates which portions of the management exposition or manual correspond to the different requirements contained in this Annex.

GM1 IS.D.OR.250(a) Information security management manual (ISMM)

ED Decision 2023/009/R

The organisation may choose to document some of the information required under point [IS.D.OR.250\(a\)](#) in separate documents (e.g. procedures). In this case, it should ensure that the manual contains adequate references to any document kept separately. Any such documents are then to be considered an integral part of the organisation's information security management system manual.

In the event where an entity holds multiple authorisations or declarations, the ISMM may apply to one or more organisations at a time based on a common ISMS. This ISMM should include at least an approval document of each organisation and should formally be approved by each organisation's accountable manager or, in the case of design organisations, by each head of the design organisations or responsible person. A common responsible person may be appointed as per [IS.D.OR.240\(d\)](#) and the guidelines of [GM1 IS.D.OR.240\(e\)](#).

To ensure that all parties involved can fulfil their responsibilities, all manuals, procedures, and communication between them are advised to be, at least, in one common language, e.g. English. Those parties involved include the competent authorities with which that common language should be agreed upon.

IS.D.OR.255 Changes to the information security management system

Regulation (EU) 2025/22

- (a) Changes to the ISMS may be managed and notified to the competent authority in a procedure developed by the organisation. This procedure shall be approved by the competent authority, except for declaring organisations.
- (b) With regard to changes to the ISMS not covered by the procedure referred to in point (a), the organisation shall apply for and obtain an approval issued by the competent authority, except for declaring organisations, for which an approval is not required.

With regard to these changes:

- (1) the application shall be submitted before any such change takes place, in order to enable the competent authority to determine continued compliance with this Regulation and to amend, if necessary, the organisation certificate and related terms of approval attached to it;
- (2) the organisation shall make available to the competent authority any information it requests to evaluate the change;
- (3) the change shall be implemented only upon receipt of a formal approval by the competent authority, except for declaring organisations, which may implement the change immediately;

- (4) the organisation shall operate under the conditions prescribed by the competent authority during the implementation of such changes.

AMC1 IS.D.OR.255 Changes to the information security management system

ED Decision 2023/009/R

Without prejudice to the communication of changes as required for each organisation in the corresponding implementing regulation for the domain as listed in point Article 2(1) of [Regulation \(EU\) 2022/1645](#), the procedure referred to in [IS.D.OR.255\(a\)](#) should take into account the criticality of the changes when proposing how they will be managed. In particular, those changes that could have an impact on the achievement or maintenance of compliance with the provisions under Part-IS, or which could lead to an unacceptable level of risk (e.g. as per the guidance provided in GM1 [IS.D.OR.205\(c\)](#)), should be subjected to scrutiny. Upon establishment of this procedure, any further changes to it should be subject to approval by the competent authority.

Where prior approval is sought from the competent authority for a change not covered by an approved procedure, or where no such approved procedure exists, the organisation should provide at least the following information:

- the nature and purpose of the change;
- the implementation plan of the change;
- the verification plan of the change;
- the potential impact on aviation safety introduced by the change.

A significant deviation from the original implementation plan during the change process is an event that should be reported to the competent authority as this deviation may require reconsidering the change impact.

GM1 IS.D.OR.255 Changes to the information security management system

ED Decision 2023/009/R

Point [IS.D.OR.255](#) is structured as follows:

Point (a) introduces the possibility for the organisation to agree with the competent authority that changes to the ISMS can be implemented without prior approval as long as these changes are covered in a change procedure.

Point (b) introduces an obligation of prior approval (by the competent authority) for changes not covered by the procedure mentioned above, and indicates how those changes should be handled.

The organisation should consider the establishment of a procedure in order to manage and notify changes to the competent authority as provided for under [IS.D.OR.255\(a\)](#). In case of lack of any approved procedure, the organisation will have, for any change, to apply for and obtain an approval as required under [IS.D.OR.255\(b\)](#). In any case, all changes should be notified to the competent authority upon implementation.

GM2 IS.D.OR.255 Changes to the information security management system

ED Decision 2023/009/R

RELATION BETWEEN CHANGES TO THE ISMS AND CONTINUOUS IMPROVEMENT

Changes stemming from the continuous improvement process established by the organisation (see [IS.D.OR.260](#)) should be handled as any other change according to the guidelines in [AMC1 IS.D.OR.255](#) and [GM1 IS.D.OR.255](#).

EXAMPLE OF CHANGES THAT MAY HAVE AN IMPACT ON THE ISMS

Below are some examples of changes that may have an impact on the ISMS, or which could lead to an unacceptable level of risk and therefore should be subject to scrutiny by the competent authority according to the provisions established under [IS.D.OR.255](#):

- (a) Changes to the scope of the ISMS, interfaces or related policies:
 - The organisation expands its business functions, and integrates another company within its organisational structure.
 - The organisation has identified non-conformities indicating an incorrect scope.
 - The organisation amends its information security policy and/or information security objectives with a potential impact on aviation safety.
 - Changes to the interfaces of the organisation resulting e.g. from modification in the insourced or outsourced activities.
- (b) Changes in responsibilities and accountability as well as in the organisational structure involving the implementation and continuing monitoring of compliance with this Regulation:
 - The accountable manager has delegated certain responsibilities under Part-IS to a person or a group of persons.
 - The organisation contracts information security management activities as per [IS.D.OR.235](#).
- (c) Changes to the methodology used for risk management:
 - The organisation changes the classification for likelihood or impact in their risk management methodology e.g. to obtain more granularity.
 - The organisation implements changes to their risk treatment methodology.
 - The organisation integrates its information security risk management into existing management systems.
- (d) Changes to the security event management process:
 - The organisation decides to contract security event management activities.
 - The organisation changes the process to notify security events and the criteria to escalate to higher management for a quicker resolution.
 - The organisation changes its policy for mitigating vulnerabilities.
 - The organisation changes its incident recovery procedure.

EXAMPLE OF CHANGES THAT DO NOT HAVE AN IMPACT ON THE ISMS

Not all operational changes related to information security have an impact on the ISMS, therefore not all changes are required to be reported to the competent authority, following the provisions established under [IS.D.OR.255](#). The following scenarios may be representative of such changes:

- After a successfully detected security event which could have easily evolved to an incident, the organisation decides to roll out an extensive cyber security awareness campaign for all employees.
- Update in the staff training programme and/or training content as a result of the continuous improvement processes established within the organisation.
- The organisation replaces the software tool that it uses for encrypting sensitive files with another software solution.
- The organisation has decided to make an internal restructuring for business reasons, changing the names of departments or sections, without making any changes in the responsibilities and accountability (e.g. accountable manager) involving the ISMS of the organisation.
- The organisation decides to update an existing preventive control e.g. configuring a new firewall in its internal network.

IS.D.OR.260 Continuous improvement

Regulation (EU) 2022/1645

- (a) The organisation shall assess, using adequate performance indicators, the effectiveness and maturity of the ISMS. That assessment shall be carried out on a calendar basis predefined by the organisation or following an information security incident.
- (b) If deficiencies are found following the assessment carried out in accordance with point (a), the organisation shall take the necessary improvement measures to ensure that the ISMS continues to comply with the applicable requirements and maintains the information security risks at an acceptable level. In addition, the organisation shall reassess those elements of the ISMS affected by the adopted measures.

AMC1 IS.D.OR.260 Continuous improvement

ED Decision 2023/009/R

The continuous improvement process (CIP), as required by [IS.D.OR.200\(b\)](#), should aim to continuously improve the effectiveness, suitability and adequacy of the ISMS. This should be achieved by a proactive and systematic assessment of the ISMS and all its elements — including its maturity. The assessment should take into account the outcomes and conclusions of other information security and assurance processes including audits, management reviews, evaluation of performance, effectiveness and maturity, as well as the outcomes of the derived corrective actions and corrections.

The steps to be performed should be at least the following:

- (a) Identification of improvement opportunities based on the outcomes of the assessment of the ISMS with respect to its suitability, effectiveness, adequacy and, if deemed necessary, efficiency, as well as on any other suggestion for improvement. The assessment should consider performance indicators which reflect its processes and elements and the defined objectives for effectiveness and maturity.

- (b) Evaluation of the identified opportunities regarding cost benefit, absence or reduction of undesired effects and achievement of the targeted objectives and intended outcomes.
- (c) Proposal of the evaluated improvement opportunities to the management, and recommend actions to support their review and decision-making.
- (d) According to the decision taken under point (c), planning, development and implementation of actions and changes to the ISMS, its processes or elements to achieve the improvements.
- (e) Evaluation the effectiveness of the implemented actions and ISMS changes, and, as applicable, verification that the root cause of identified deficiencies has been eliminated.

The management should assess and review the outcomes of the CIP at planned intervals to ensure the continuing effectiveness, adequacy and suitability of the ISMS, to decide on the prioritisation of the implementation of actions and changes, as well as to revise or set new objectives or targets for continuous improvement.

GM1 IS.D.OR.260 Continuous improvement

ED Decision 2025/014/R

Point [IS.D.OR.260](#) covers assurance processes for the ISMS in a manner that can be considered equivalent to the safety assurance in ICAO Doc 9859 'Safety Management Manual (SMM)', which includes performance monitoring and measurement, management of change and continuous improvement of the SMS.

In this Regulation:

- IS.D.OR.260(a) addresses, using adequate performance indicators, the effectiveness and maturity assessment of the ISMS;
- IS.D.OR.260(b) addresses the improvement measures, i.e. corrections and corrective actions, for the deficiencies detected in IS.D.OR.260(a) and the continuous improvement process.

Similar provisions for continuous improvement are provided for in other information management systems such as ISO/IEC 27001 (see [Appendix IV](#) to this document).

The context and risk environment of organisations are never static and therefore require a dynamic adaptation, evolution and change of the organisation's objectives, architectures, organisational structures and processes to maintain the information security risks at an acceptable level. Consequently, the ISMS should be considered as an evolving and learning part/element of the organisation which needs to be continuously monitored and improved to ensure alignment with the organisation's safety objectives and effectiveness.

The CIP aims to continuously improve the effectiveness, suitability, adequacy and, if deemed necessary, the efficiency of the ISMS. An organisation may integrate the Part-IS CIP in some other already operated CIP and may apply methods such as Plan-Do-Check-Act (PDCA) Cycle or Define-Measure-Analyse-Improve-Control (DMAIC) (see also [GM1 IS.D.OR.200](#)).

The CIP is based on a proactive and systematic assessment of the ISMS and all its elements including the information security processes and controls driven by the ISMS. The assessment should be carried out against organisational targets for desired levels of performance, effectiveness and maturity. These targets, besides ensuring the achievement of compliance with the requirements under this Regulation, may also aim to include objectives established by the organisation's policy or standards and by management decisions.

The above-mentioned assessment is based on the outcome of performance evaluations, audits, risk and incident processes, as well as already applied corrections and corrective actions. Some factors that should be considered when performing the assessment are the following:

- **Adequacy** refers to whether the system establishes the disciplines needed to manage information security, e.g. by using broadly accepted industry standards, in a sufficient manner with regard to compliance with the requirements of this Regulation.
- **Effectiveness of the ISMS** and the effective implementation of processes and controls driven by the ISMS is assessed by analysing whether:
 - the information security risks are managed to achieve the safety objectives;
 - the intended outcomes of the ISMS are achieved, and the requirements or objectives are met;
 - all types of deficiencies are managed including failures to fulfil or correctly implement a requirement or control.
- **Efficiency** of the ISMS refers to the implementation of streamlined processes; however, efficiency improvements should not adversely impact effectiveness.

Identification of improvement opportunities

Improvement opportunities may be identified from the results of the CIP assessment or may be introduced as suggestions from other sources. The identification often involves deviations or corrective actions as well as ineffective processes or controls which are not remediated.

Suggestions for improvements stem from sources including:

- Risk management: the results of regular risk analysis and subsequent risk treatment are a primary factor in improving the ISMS, where the risk treatment process involves monitoring of the implemented security measures and evaluating their effectiveness.
- Performance & effectiveness evaluation: conclusions from (key) performance indicators, their measurement, analysis and continued monitoring as well as the result of the assessment of the effectiveness including the outcomes of the subsequently applied corrections and corrective actions
- Evaluation of maturity including the results of the subsequent corrections and corrective actions
- Lessons learned from the security incident detection, handling and response process and from a potential treatment of a root cause
- Results of (internal) audits may be used to verify whether the ISMS and controls within the audit scope meet the organisation's requirements, and to determine where there are potential areas for improvement.
- Review and evaluation by management of the current action plan, setting or revision of the objectives or decision on improvement opportunities and actions
- Organisation's suggestion programme (suggestions for improvement), reviews, surveys or assessments with employees or feedback from suppliers or interfacing parties

Any outcome of this process should be documented. The resulting actions may be integrated into an overarching action plan which is centrally consolidated and periodically reviewed according to the relevant policies. The resulting action plan may be further divided into a tactical, short-/mid-term action plan and a strategic, long-term action plan.

AMC1 IS.D.OR.260(a) Continuous improvement

ED Decision 2023/009/R

(a) ISMS EFFECTIVENESS EVALUATION

When complying with [IS.D.OR.260\(a\)](#), the organisation should have a process in place to monitor, measure, evaluate and review the effectiveness of its ISMS that defines:

- (1) who monitors, measures, analyses and evaluates the results and takes accountable decisions;
- (2) when the above steps should be performed;
- (3) which methods for monitoring, measurement, analysis and evaluation are applied to ensure comparable and reproducible results.

The calendar basis of the assessments should be commensurate with the maximum level of risk established under [IS.D.OR.205](#).

The process to monitor, measure, evaluate and review the effectiveness of the organisation's ISMS referred to under AMC1 IS.D.OR.260(a) should include as a minimum:

- (1) the gathering and retention of metrics of the activities, and additional information that could be useful for monitoring purposes;
- (2) the analysis of the metrics in order to identify trends and deviations from predefined performance targets.

(b) ISMS MATURITY ASSESSMENT

The organisation should assess the maturity of its ISMS using a suitable maturity model in order to identify areas for improvement to the ISMS. To do so, the organisation should:

- (1) define or adopt a maturity model which represents a set of important and relevant processes and capabilities that are expected to be implemented and maintained;
- (2) for each assessed process or capability, ensure that the model defines criteria against which specific aspects, characteristics and effectiveness should be assessed and evaluated when determining a maturity level;
- (3) define for each assessed process or capability its desired target maturity level.

(c) For each assessed information security process or capability contained in the maturity model, the organisation should:

- (1) evaluate and justify the current maturity level;
- (2) identify any area for improvement it should make to reach the targeted maturity level;
- (3) collect and record the evidence regarding strengths and weaknesses of the implemented ISMS and its evaluated maturity.

GM1 IS.D.OR.260(a) Continuous improvement

ED Decision 2023/009/R

(a) As general guidance, the elements of the ISMS that should be monitored, measured and evaluated should be, as a minimum:

- (1) the risk assessment and treatment process (including risks at the interfaces with other organisations);

- (2) the management of non-conformities and corrective actions;
 - (3) the incident and vulnerability management;
 - (4) the personnel competence management.
- (b) Existing maturity models for ISMS maturity evaluation

As general guidance, for the definition or the adoption of a maturity model (MM), the following existing models may be considered:

- Cybersecurity Capability Maturity Model (C2M2), version 1.1: this model was published by the US Department of Energy in 2014. It introduces the notion of Maturity Indicator Levels (MIL) ranging from 0 to 3 and addresses not only performance levels but also performance practices (under Approach Objectives and approach progression) as well as assurance practices (under Management Objectives and institutionalization progression).
- Systems Security Engineering – Capability Maturity Model (SSE-CMM): published by ISO as ISO 21827 in 2008. It focuses on engineering practices, much less on operational practices that are split in 11 ‘Security Base Practices’, and 11 ‘Project and Organizational Base Practices’. It introduces the notion of five Capability Levels, from ‘Performed Informally’ to ‘Continuously Improving’.
- NIST Cybersecurity Framework (NIST CSF), version 1.1: published by NIST in April 2018. Although it is not proposed as a MM, the framework defines four ‘Implementation Tiers’, from ‘Partial’ to ‘Adaptive’, which are a qualitative measure of organisational cybersecurity risk management practices. It focuses on the functionality and repeatability of cybersecurity risk management.
- ATM Cybersecurity Maturity Model, edition 1: published in February 2019 by the EUROCONTROL NM for organisations in the ATM domain. Whilst not being designed for wider application, it can be adapted as necessary. It defines five maturity levels, ranging from ‘Non-existent’ to ‘Adaptive’ inspired by the ‘Tier’ terminology from the NIST CSF. In fact, the model is founded on NIST CSF, together with some elements of ISO/IEC 27001.

The following Table 1 maps the MM mentioned above to a hypothetical five-level MM.

Table 1: Mapping matrix of an existing MM to a hypothetical five-level MM

Mapping to a five-level MM	C2M2	Eurocontrol NM	ISO 21827	NIST CSF 1.1
Initial	MIL 0	Non-Existent	Performed Informally	
Defined	MIL 1 (Initial)	Partial	Planned & Tracked	Partial
Implemented	MIL 2 (Identified)	Defined	Well defined	Risk-Informed
Managed	MIL 3 (Managed)	Assured	Quantitatively Controlled	Repeatable
Improved		Adaptive	Continuously Improving	Adaptive

No specific maturity level is required. However, if and when compliance is achieved, organisations will determine which requirements of which models have already been met (mandatory) and can opt to reach a level that is beneficial to the organisation (voluntary). In the longer term, achieving higher maturity levels may increase the confidence of oversight authorities, which can have an impact upon the level of oversight activities regarding such organisation.

AMC1 IS.D.OR.260(b) Continuous improvement

ED Decision 2023/009/R

When a deficiency is identified, the organisation should react in a timely manner following a defined process leading to a managed status regarding the deficiency, its associated consequences and, if needed, the prevention of its future recurrence or occurrence elsewhere.

Based on an evaluation of the impact and extent of the deficiency and the potential consequences for the ISMS, the process should include as criteria for compliance:

- (a) deciding on corrections and their implementation without undue delay in order to limit the impact of the deficiency and deal with its consequences as well as, as applicable, to control or eliminate it;
- (b) deciding on the need for, and the implementation of, corrective actions to eliminate the cause(s) of, and contributing factors to, the deficiency based on a root cause analysis and an evaluation of actions remediating the cause aimed at being proportionate to the consequences and impact of the deficiency;
- (c) verifying the implemented actions:
 - (1) to be effective and to result in acceptable residual risks,
 - (2) not to have unintended side effects leading to other deficiencies, new risks, or an ISMS not aligned with the applicable requirements, as well as
 - (3) for corrective actions, to effectively remediate or eliminate the root cause;
- (d) reporting to and reviewing the identified deficiencies, action plan and results of the action taken with the accountable manager of the organisation or, in the case of design organisations, with the head of the design organisation and, as necessary, with other involved or affected roles and parties;
- (e) documenting as evidence the detected deficiencies, the planned and implemented corrections and/or corrective actions with deadlines and responsible persons, the management feedback, the outcomes of the process step under point (c) above and, if necessary, the change decisions made for the ISMS itself.

GM1 IS.D.OR.260(b) Continuous improvement

ED Decision 2023/009/R

The 'necessary improvement measures' referred to in [IS.D.OR.260\(b\)](#) refer to correction or corrective actions to eliminate deficiencies or actions aimed at improving the effectiveness as well as the maturity of the ISMS.

A process satisfying the criteria defined in [AMC1 IS.D.OR.260](#) should include the following aspects:

- (a) identifying the extent, impact, context and triggers of the deficiency, evaluating it according to some established criteria, analysing potential consequences on the ISMS including a potential existence in other areas;
- (b) deciding on corrections and their implementation to immediately limit the impact and manage the consequences of the deficiency as well as, as applicable, to control or eliminate it;
- (c) deciding on corrective actions required to eliminate the (root) cause(s) of the deficiency that are proportionate to the consequences;
- (d) reassessing the elements of the ISMS which may be affected by the implemented actions to ensure that no further risk is introduced;
- (e) verifying the implemented actions referred to in point (c) of [AMC1 IS.D.OR.260\(b\)](#);
- (f) reporting to and reviewing the outcomes of the process steps with the management (see point (d) of AMC1 IS.D.OR.260(b));
- (g) documenting and evidencing the result of the process steps above (see point (e) of AMC1 IS.D.OR.260(b)).

Appendix I — Examples of threat scenarios with a potential harmful impact on safety

ED Decision 2023/009/R

The following is a non-exhaustive list of examples of information security threat scenarios with a potential harmful impact on safety that may be considered by authorities and organisations.

Example 1: Aircraft to ATC digital communications

- **Threat vector assets/domain**
 - ATC voice and ground automation systems
 - ground communications providers
 - air-ground/ground-air RF communications service providers
 - aircraft and the assets used for voice and datalink communications
- **Non-exhaustive summary of potential threats**
 - threat (availability): exceeding system performance, saturation of communication channel
 - threat (integrity): man-in-the-middle or injection attacks
 - threat (confidentiality): passive listening to communication, spying on hardware device
- **Summary of threats scenarios and their potential harmful impacts on safety**
 - Disruption of services prevent ATC communication with a single or multiple aircraft and/or ATC ground system.

- Manipulation of data through a man-in-the-middle attack would present false information to the pilot and/or ATC system with the potential of creating a safety hazard or injection of data to the aircraft or ground systems to disrupt the service and capability.
- There are no specific regulatory requirements for encryption of data or voice for datalink communications; however, for confidentiality purposes, the assets used to provide and deliver the services should be controlled and limited to only those resources that require access to ensure that the services cannot be disrupted and manipulated in any way.

Example 2: Tampered air traffic data

- **Threat vector assets/domain**
 - Internet service provider (ISP)
 - ATM services network(s)
 - surveillance data
 - ATC systems
- **Non-exhaustive summary of potential threats**
 - ISP compromise (confidentiality): An attacker gains unauthorised access to the systems or infrastructure of the ISP providing network services to ATM system.
 - data tampering (integrity): Once the ISP is compromised, an attacker could manipulate data in transit. This could involve injecting false data or removing/modifying legitimate data.
 - denial of service (availability): an attacker could also potentially disrupt the communication of data entirely, resulting in a denial of service (DoS) to the ATM system.
 - malware injection (integrity/availability): An attacker could potentially use the compromised ISP as a launching pad to inject malware into the systems, causing further disruptions or enabling additional attacks.
- **Summary of threats scenarios and their potential harmful impacts on safety**
 - ISP compromise: interception and/or manipulation of sensitive data, impacting the safe management of air traffic.
 - data tampering: incorrect situational awareness, potentially resulting in reduced separation between aircrafts, and incorrect air traffic control decisions.
 - denial of service: reduction of the ATC's ability to ensure separation leading to the activation of contingency procedures, including capacity reduction, with the eventual possibility of large areas of airspace being closed.

Example 3: Aircraft operator, CAMOs' and aircraft maintenance organisations' software supply chain and ground infrastructure, including equipment used to support aircraft management, operations and maintenance

- **Threat vector assets/domain**
 - aircraft operators', CAMOs' and maintenance organisations' supply chain

- aircraft operator or maintenance internal ground infrastructure used to manage aircraft and operations (hardware/software) and other information technology assets
- information technology assets used to update systems on an aircraft (software and hardware) used for maintenance activities
- **Non-exhaustive summary of potential threats**
 - threat (availability): hardware/software/system disruption
 - threat (integrity): compromised hardware/software/system
 - threat (confidentiality): compromised hardware/software/system
- **Summary of threats scenarios and their potential harmful impacts on safety**
 - Disruption to the dissemination of meteorological information while the aircraft is airborne, may reduce the ability of the flight crew to avoid potentially hazardous meteorological conditions (e.g. severe storms/fog at night).
 - Manipulation of navigation data/database will have the effect that flight plans and navigation displays cannot be trusted.
 - Lack of control and access to information such as fleet maintenance programme or flight crew planning affects the ability of organisations to maintain safe operations.

Application of bow-tie analysis to this example

Two coordinated bow-tie analyses of different risk dimensions are combined, as the ultimate interest lies only in the aviation safety consequence.

Information security bow-tie analysis element	Aviation safety bow-tie analysis element
Information security threats 1) hardware/software vulnerability exploitation: disturbed system function 2) hardware/software vulnerability exploitation: system integrity compromised 3) hardware/software vulnerability exploitation: confidentiality of information processed by system(s) compromised	
Information security preventive barriers	
Information security hazards & top events 1) disturbed system functionality (hazard) → disrupted/unreliable system functionality 2) system integrity compromised (hazard) → system function unpredictable 3) information disclosable (hazard) → undetectable information exfiltration	Safety threats 1) disrupted/unreliable system functionality 2) system function unpredictable 3) undetectable information exfiltration
Information security mitigating barriers	Safety preventive barriers 1) Use of access controls for system administration 2) etc.
Information security consequences 1) loss of system function (= production system down)	Safety hazards & top events: 1) loss of system function (hazard) → <i>in operational maintenance system</i>

2) loss of system function integrity (= some system function wrong/inoperative) 3) loss of confidentiality of information (= some information can leak)	2) loss of system function integrity (hazard) → <i>systems operate with wrong information</i> 3) loss of information confidentiality (hazard) → <i>confidential maintenance and aircraft internals information leaks</i>
	Safety mitigating barriers 1) use of back-up procedures to prevent faulty maintenance actions 2) use of procedures to secure aircraft software integrity
	Safety consequences 1) faulty maintenance actions 2) incorrectly completed maintenance actions 3) exfiltration of information allows for identification of vulnerabilities 4) disruption of aircraft systems, unpredictable system function, loss of major aircraft systems (such as engine control)

Example 4: Design and production organisations' software, supply chain, design and manufacturing ground infrastructure

- **Threat vector assets/domain**
 - design and production organisations' supply chain for parts, hardware and software
 - design and production organisations' ground internal infrastructure used to manage software/hardware used in the manufacturing and development of products that will be used by aircraft manufacturers, operators or ATM/ANS ground automation systems (hardware/software) information technology assets
 - design and production organisations' information technology assets used by their customers to update systems on an aircraft (software/hardware) used for maintenance operations or ATM/ANS ground automation systems
- **Non-exhaustive summary of potential threats**
 - threat (availability): systems used to store, transmit and exchange information are rendered unavailable for essential operations through DoS attacks
 - threat (integrity): systems used to store, transmit and exchange information are compromised through man-in-the middle attacks
 - threat (confidentiality): systems used to store, transmit and exchange information are accessed by insider or external threats
- **Summary of threats scenarios and their potential harmful impacts on safety**
 - Disruption of systems used to store, transmit and exchange information in a manner that would prevent the proper management of the aircraft and its systems and adversely affect the operations of the aircraft
 - Systems used to store, transmit and exchange information can no longer be considered trusted. If they are not maintained at a level to ensure that all information exchange, data

and software can be considered trusted, both ground and aircraft operations are disrupted.

- Uncontrolled access to systems used to store, transmit and exchange information (including information that is received and exchanged with the supply chain) can provide technical details that could be used to craft more sophisticated attacks targeting safety-critical systems.

Example 5: Training system

— Threat vector assets/domain

- supply chain of all software and hardware that will be used in the training systems or training devices (including flight simulators) used to train pilot or ATM/ANS ground systems personnel
- internal infrastructure used in of all software and hardware that will be used in the design, manufacturing or production of products (hardware or software) that will be used in aircraft or ATM/ANS ground systems
- management of internal operating domains and system of all software and hardware that will be used in the design, manufacturing or production of products (hardware or software) that will be used in aircraft or ATM/ANS ground systems

— Non-exhaustive summary of potential threats

- threat (availability): training systems or training devices are rendered unavailable by means of DoS attacks when they are needed to be used
- threat (integrity): training systems or training devices are compromised through man-in-the middle attacks
- threat (confidentiality): functional models, information and data that are embedded in training systems or training devices are accessed by insider or external threats

— Summary of threats scenarios and their potential harmful impacts on safety

- Disruption of training systems (hardware and software) will have an impact on the organisations' ability to maintain qualified staff. It would also prevent the aircraft and its systems from being properly operated and affect maintenance operations for ATM/ANS ground systems.
- The training model or the failure modes and associated emergency conditions differ from the real aviation system behaviour and therefore induce inappropriate responses. If the training systems cannot be trusted, this will affect the ability of organisations to maintain sufficiently qualified staff for their operations (pilots, maintenance or ATM/ANS ground personnel who have been exposed to improper training should be re-qualified).
- Lack of control and access to training systems affects the ability of organisations to maintain a training system that is known to be in a trusted state. In addition, uncontrolled access to training systems that embed functional models, information and data can provide technical details that could be used to craft more sophisticated attacks on the training system itself or on the real-world safety-critical system.

Example 6: Airport's fuel delivery system and associated infrastructure

- **Threat vector assets/domain**
 - ground fuel storage and distribution infrastructure
 - digital systems used to control fuel pumping and metering
 - supply chain for fuel delivery, including third-party fuel suppliers
 - airport information technology assets used for fuel inventory management and scheduling deliveries
- **Non-exhaustive summary of potential threats**
 - threat (availability): disruption of fuel supply or delivery systems
 - threat (integrity): tampering with fuel control systems or measurement devices
 - threat (confidentiality): unauthorised access to fuel supply and delivery data
- **Summary of threats scenarios and their potential harmful impacts on safety**
 - Disruption to fuel delivery can lead to flight delays or cancellations, causing operational disruptions and potential safety issues if fuel reserves become critically low.
 - Tampering with fuel control systems or measurement devices could lead to incorrect fuel loads being delivered to aircraft, impacting aircraft weight and balance calculations, and potentially causing fuel exhaustion incidents.
 - Unauthorised access to fuel supply data could allow threat actors to manipulate fuel scheduling or inventory data, potentially causing disruptions to airport operations and fuel availability for aircraft.

Example 7: National competent authority's NOTAM system and associated infrastructure

- **Threat vector assets/domain**
 - National NOTAM system infrastructure and digital interface
 - Supply chain for NOTAM system maintenance and updates
 - National competent authority's IT assets used for NOTAM creation, distribution, and storage
- **Non-exhaustive summary of potential threats**
 - threat (availability): disruption of the NOTAM system or its access
 - threat (integrity): tampering with NOTAM data or unauthorised NOTAM creation
 - threat (confidentiality): unauthorised access to NOTAM data
- **Summary of threats scenarios and their potential harmful impacts on safety**
 - Disruption to the NOTAM system could prevent the dissemination of critical aeronautical information to pilots and air traffic controllers, potentially leading to safety issues.
 - Tampering with NOTAM data or unauthorised creation of NOTAMs could lead to incorrect information being disseminated, potentially resulting in pilots making decisions based on false or misleading data.

- Unauthorised access to NOTAM data could lead to information leakage, potentially revealing sensitive operational information.

Example 8: Aviation authority's airworthiness directive (AD) system and associated infrastructure

- **Threat vector assets/domain**
 - EASA AD system infrastructure and digital interface
 - supply chain for AD system maintenance and updates
 - EASA IT assets used for AD creation, distribution, and storage
- **Non-exhaustive summary of potential threats**
 - threat (availability): Disruption of the AD system or its access
 - threat (integrity): tampering with AD data or unauthorised AD creation
 - threat (confidentiality): unauthorised access to AD data
- **Summary of threats and their potential harmful impacts on safety**
 - Disruption to the AD system could prevent the dissemination of critical airworthiness information to aircraft operators and maintenance organisations, potentially leading to safety issues.
 - Tampering with AD data or unauthorised creation of ADs could lead to incorrect information being disseminated, potentially resulting in aircraft operators and maintenance organisations making decisions based on false or misleading data.
 - Unauthorised access to AD data could lead to information leakage, potentially revealing sensitive operational information.

Appendix II — Main tasks stemming from the implementation of Part-IS mapped to the EU e-CF and the NIST CSF 2.0

ED Decision 2025/014/R

Part-IS main task	Activity type	Reference		
		Part-IS	EU e-CF	NIST CSF 2.0
			Competence areas & skills	Functions & categories
Establish and operate an information security management system (ISMS)	Management	IS.D.OR.200(a)	ISM (E.08)	GV – Govern
Establish the scope of the ISMS in accordance with Part-IS requirements	Management	IS.D.OR.205(a)	ISM (E.08)	GV.RM – Risk Management Strategy; ID.AM – Asset Management
Implement and maintain an information security policy	Management	IS.D.OR.200(a)(1)	ISM (E.08)	GV.PO – Policy

Part-IS main task	Activity type	Reference		
	Management, Operational	Part-IS	EU e-CF	NIST CSF 2.0
			Competence areas & skills	Functions & categories
Identify and review information security risks	Management	IS.D.OR.200(a)(2) IS.D.OR.205	ISM (E.08), Risk Management (E.02)	GV.SC – Cybersecurity Supply Chain Risk Management; ID.RA – Risk Assessment; ID.IM – Improvement
Implement information security risk treatment measures	Management	IS.D.OR.200(a)(3) IS.D.OR.210	ISM (E.08), Risk Management (E.02)	ID.RA – Risk Assessment
Set up measures to detect information security events, identify those that may develop to incidents with a potential impact on aviation safety, and respond to, and recover from, such incidents	Management	IS.D.OR.200(a)(5) IS.D.OR.220	Incident Management (C.04)	DE – Detect; RE – Respond; RC – Recover; PR – Protect (as per Risk Assessment)
Implement measures that have been notified by the competent authority	Operational	IS.D.OR.200(a)(6)		
Take appropriate remedial actions to address findings notified by the competent authority (non-compliances)	Both	IS.D.OR.200(a)(7) IS.D.OR.225		
Implement an external information security reporting scheme	Management	IS.D.OR.200(a)(8) IS.D.OR.230	Incident Management (C.04)	RS.CO – Incident Response Reporting and Communication; RC.CO – Incident Recovery Communication
Monitor compliance with this Regulation and report findings to top management	Operational	IS.D.OR.200(a)(12)	Compliance (E.09)	GV.RR – Roles, Responsibilities and Authorities; GV.RM – Risk Management; GV.OV – Oversight
Protect confidentiality of exchanged information	Operational	IS.D.OR.200(a)(13)	Information Security Management (E.08)	PR.DS – Data Security; Other PR – Protect categories as applicable

Part-IS main task	Activity type	Reference		
	Management, Operational	Part-IS	EU e-CF	NIST CSF 2.0
			Competence areas & skills	Functions categories &
Implement and maintain a continuous improvement process to measure the effectiveness and maturity of the ISMS and strive to improve it	Management	IS.D.OR.200(b) IS.D.OR.260	Information Security Management (E.08)	GV.OV – Oversight; ID.IM – Improvement
Document and maintain all key processes, procedures, roles and responsibilities	Management	IS.D.OR.200(c)	ISM (E.08), Compliance (E.09)	GV.RR – Roles, Responsibilities and Authorities; Other functions and categories as applicable
Identify all elements which could be exposed to information security risks	Management	IS.D.OR.205(a)	Risk Management (E.02)	ID.AM – Asset Management
Identify the interfaces with other organisations which could result in exposure to information security risks	Management	IS.D.OR.205(b)	Risk Management (E.02), Business Change Management (E.07)	ID.AM – Asset Management; GV.SC – Cybersecurity Supply Chain Risk Management
Identify information security risks and assign a risk level	Management	IS.D.OR.205(c)	Risk Management (E.02)	GV.RM – Risk Management Strategy; ID.RA – Risk Assessment
Review and update the risk assessment based on certain criteria	Operational	IS.D.OR.205(d)	Risk Management (E.02)	GV.RM – Risk Management Strategy; GV.PO – Policy; GV.OV – Oversight; GV.SC – Cybersecurity Supply Chain Risk Management; ID.IM – Improvement
Develop and implement measures to address risks and verify their effectiveness	Operational	IS.D.OR.210(a)	Risk Management (E.02)	GV.RM – Risk Management Strategy; ID.RA – Risk Assessment

Part-IS main task	Activity type	Reference		
	Management, Operational	Part-IS	EU e-CF	NIST CSF 2.0
			Competence areas & skills	Functions & categories
Communicate the outcome of the risk assessment to management, other personnel and other organisations sharing an interface	Operational	IS.D.OR.210(b)	Risk Management (E.02), ISM (E.08)	GV.RM – Risk Management Strategy; GV.SC – Cybersecurity Supply Chain Risk Management
Establish an internal information security reporting scheme to enable the collection and evaluation of information security events from personnel	Management	IS.D.OR.200(a)(4) IS.D.OR.215 (a) IS.D.OR.215(e)	Incident Management (C.04)	ID.RA – Risk Assessment; DE.AE – Adverse Event Analysis; RS.CO – Incident Response Reporting and Communication; RC.CO – Incident Recovery Communications
Ensure that contracted organisations report information security events	Management	IS.D.OR.215(c)	Supplier Relationship Management (E.10)	GV.SC – Cybersecurity Supply Chain Risk Management; DE.CM – Continuous Monitoring
Analyse internally reported occurrences to identify information security events, incidents, and vulnerabilities	Operational	IS.D.OR.215(b)(1)–(b)(3)	Incident Management (C.04)	DE.AE – Adverse Event Analysis
Implement measures to detect in processes and operations information security events which may have a potential impact on aviation safety	Operational	IS.D.OR.220(a)	ISM (E.08)	DE.CM – Continuous Monitoring; DE.AE – Adverse Event Analysis; ID.RA – Risk Assessment; PR – Protect (selection of relevant controls as per Risk Assessment)

Part-IS main task	Activity type	Reference		
	Management, Operational	Part-IS	EU e-CF	NIST CSF 2.0
			Competence areas & skills	Functions & categories
Implement measures to respond to information security events that may cause an information security incident	Operational	IS.D.OR.220(b)	Incident Management (C.04)	RS.MA – Incident Management; RS.AN – Incident Analysis; RS.MI – Incident Mitigation; RS.CO – Incident Response Reporting and Communication (where applicable); PR – Protect (selection of relevant controls as per Risk Assessment)
Cooperate on investigations with other organisations that contribute to the information security of its own activities	Management	IS.D.OR.215(d)	Incident Management (C.04), Legal Advice and Compliance (E.09)	DE.CM – Continuous Monitoring; RS.CO – Incident Response Reporting and Communication; RC.CO – Incident Recovery Communication
Implement measures to recover from information security incidents	Operational	IS.D.OR.220(c)	Incident Management (C.04)	RC.RP – Incident Recovery Plan Execution; RC.CO – Incident Recovery Communication; PR – Protect (selection of relevant controls as per Risk Assessment)
Manage risks associated with contracted activities with regard to the management of information security	Management	IS.D.OR.235	Supplier Relationship Management (E.10)	GV.SC – Cybersecurity Supply Chain Risk Management

Part-IS main task	Activity type	Reference		
	Management, Operational	Part-IS	EU e-CF	NIST CSF 2.0
			Competence areas & skills	Functions & categories
Create and maintain a process to ensure that there is sufficient personnel to perform all activities regarding information security management	Management	IS.D.OR.240(f)	Personnel Development (D.11)	GV.RR – Roles, Responsibilities, and Authorities
Create and maintain a process to ensure that the personnel have the necessary competence for activities regarding information security management	Management	IS.D.OR.240(g)	Personnel Development (D.11)	GV.RR – Roles, Responsibilities, and Authorities; PR.AT – Awareness and Training (02)
Create and maintain a process to ensure that the personnel acknowledge the responsibilities associated with the assigned roles and tasks	Management	IS.D.OR.240(h)	Personnel Development (D.11)	GV.RR – Roles, Responsibilities, and Authorities
Verify the identity and trustworthiness of personnel who have access to information systems	Management	IS.D.OR.240(i)	ISM (E.08)	GV.RR – Roles, Responsibilities, and Authorities; GV.PO – Policy; PR.AA – entity Management, Authentication, and Access Control
Archive, protect and retain records and ensure they are traceable for a specified time	Operational	IS.D.OR.245	ISM (E.08), Compliance (E.09)	GV.OV – Oversight; GV.RR – Roles, Responsibilities, and Authorities; PR.DS – Data Security; PR.PS – Platform Security; RS.AN – Incident Analysis; GV.SC – Cybersecurity Supply Chain Risk Management; ID.RA – Risk Assessment

Part-IS main task	Activity type	Reference		
	Management, Operational	Part-IS	EU e-CF	NIST CSF 2.0
			Competence areas & skills	Functions & categories
Correct non-compliance findings upon notification by the competent authority within the period agreed with the competent authority	Operational	IS.D.OR.225		
Implement an information security reporting system in accordance with Regulation (EU) No 376/2014	Management	IS.D.OR.230(a)		
Report information security incidents or vulnerabilities to the competent authority and, under certain conditions, to others	Operational	IS.D.OR.230(b) IS.D.OR.230(c)	Incident Management (C.04)	GV.OC – Organisational Context; RS.CO – Incident Response Reporting and Communication; RC.CO – Incident Recovery Communications
Regularly assess the effectiveness and maturity of the ISMS	Operational	IS.D.OR.260(a)	ISM (E.08)	GV.OV – Oversight; ID.IM – Improvement
Take actions to improve the ISMS if required. Reassess the ISMS elements affected by the implemented measures.	Operational	IS.D.OR.260(b)	ISM (E.08)	GV.OV – Oversight; ID.IM – Improvement
Ensure accessibility of the competent authority to the contracted organisation	Management	IS.D.OR.235(b)	ISM (E.08)	GV.OC – Organisational Context
Top management ensures that all necessary resources are available to comply with the Regulation	Management	IS.D.OR.240(a)(1)	ISM (E.08)	GV.RR – Roles, Responsibilities, and Authorities
Top management establishes and promotes the information security policy and demonstrates a basic understanding of the Regulation	Management	IS.D.OR.240(a)(2) IS.D.OR.240(a)(3)	ISM (E.08)	GV.PO – Policy; GV.PO RR – Roles, Responsibilities, and Authorities
Appoint a responsible person or a group of persons with appropriate knowledge to manage compliance with the Regulation	Management	IS.D.OR.240(b) IS.D.OR.240(c) IS.D.OR.240(d)	ISM (E.08), Compliance (E.09)	GV.PO RR – Roles, Responsibilities, and Authorities

Part-IS main task	Activity type	Reference		
	Management, Operational	Part-IS	EU e-CF	NIST CSF 2.0
			Competence areas & skills	Functions categories &
Create and maintain an information security management manual (ISMM)	Management	IS.D.OR.250		
Develop a procedure on how to notify the competent authority upon changes to the ISMS	Management	IS.D.OR.255(a)	Compliance (E.09)	GV.OC – Organisational Context; ID.RA – Risk Assessment; ID.IM – Improvement
Manage changes to the ISMS and notify the competent authority and/or request for approval of changes	Management	IS.D.OR.255(a) IS.D.OR.255(b)	ISM (E.08), Process Improvements (E.05)	GV.OC – Organisational Context; ID.RA – Risk Assessment; ID.IM – Improvement

Appendix III — Examples of aviation services and interfaces

ED Decision 2025/014/R

AVIATION SERVICES

The following is a non-exhaustive and non-complete list of aviation services that can be used as a basis to identify the scope of the risk assessment for the organisation.

- aerodrome & ATM-MET service providers
- aeronautical digital mapping services
- aeronautical information management (AIM) – external, national, regional
- airports
- air traffic control (ATC) – external, superior
- air traffic management (ATM)
- approach (APP) & area control (ACC) Services – ER ACC, APP ACC
- cargo and passenger loading
- civil & state airspace user (AU) operations centres
- communication infrastructure
- flight information services / traffic information services (FIS/TIS) data integrator
- fuel calculation

-
- navigation infrastructure – ground-based, satellite-based
 - non-ATM meteorological (MET) service providers
 - mass & balance calculation
 - non-aviation users (external)
 - regional & sub-regional airspace management (ASM) and air traffic flow & capacity management (ATFCM)
 - static aeronautical data services
 - sub-regional demand & capacity balancing (DCB) common service providers
 - surveillance infrastructure – airport, en-route, terminal manoeuvring area (TMA)
 - route planning
 - time reference services (external)
 - tower (TWR) services

INTERFACES

Below are some examples of data exchange at the interfaces between organisations interacting in different functional chains, which can be used as a basis for identifying the scope of the risk assessment for the organisation.

Note 1: These examples are graphical representations based on the ‘**Examples of ecosystem data exchange**’ provided in **EUROCAE ED-201A, Appendix B - Tables B-14**, which can be consulted for further information.

Note 2: Although it is not an organisation, an aircraft has been included in all these examples for the sake of completeness of the description of the data exchange. The aircraft should be considered as an element within the scope of the ISMS of the organisation to which it belongs (typically the airline). Any data exchange between aircraft and other systems within the organisation should take into account existing security measures that may have been evaluated as part of aircraft certification (see also [GM1 IS.D.OR.205\(c\)](#)).

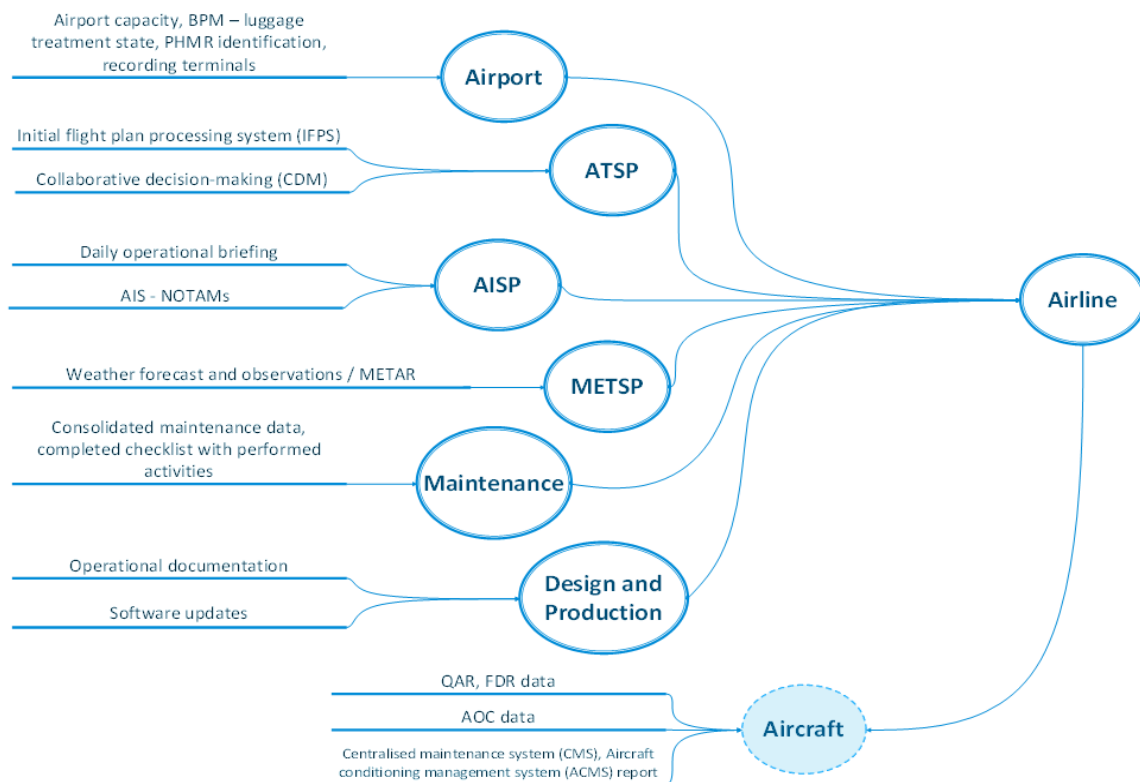


Figure 1: Interfaces of other organisations with an airline operator

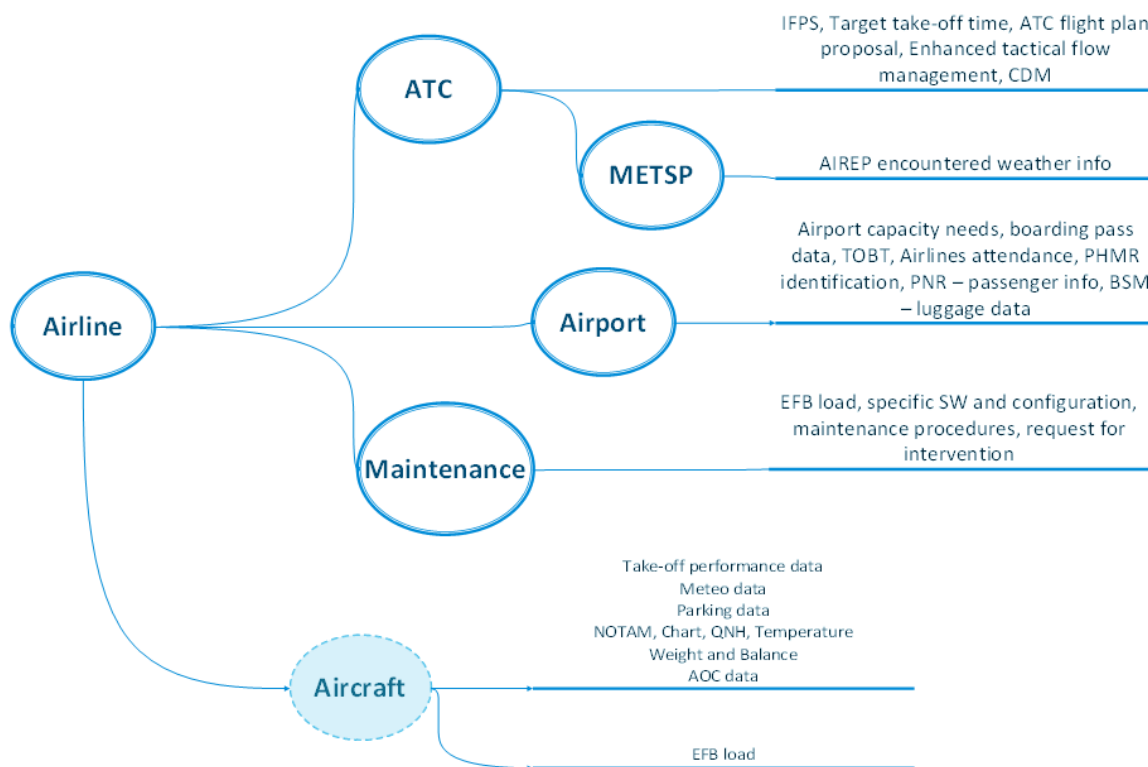


Figure 2: Interfaces of an airline operator with other organisations

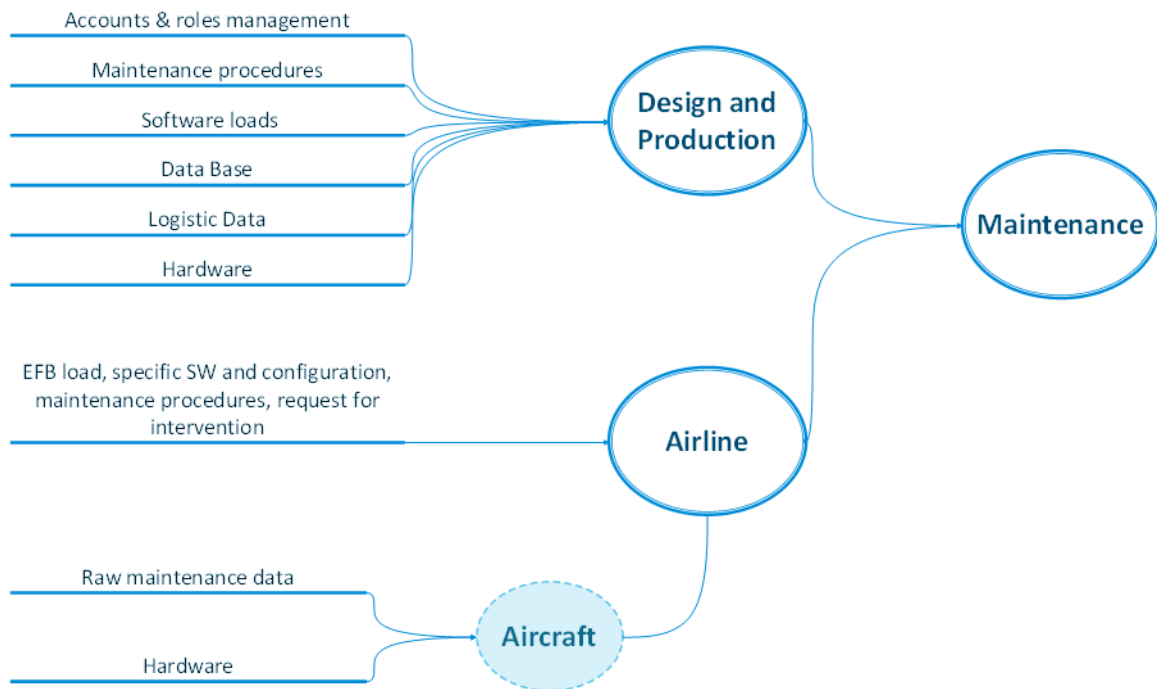


Figure 3: Interfaces of other organisations with a maintenance service provider

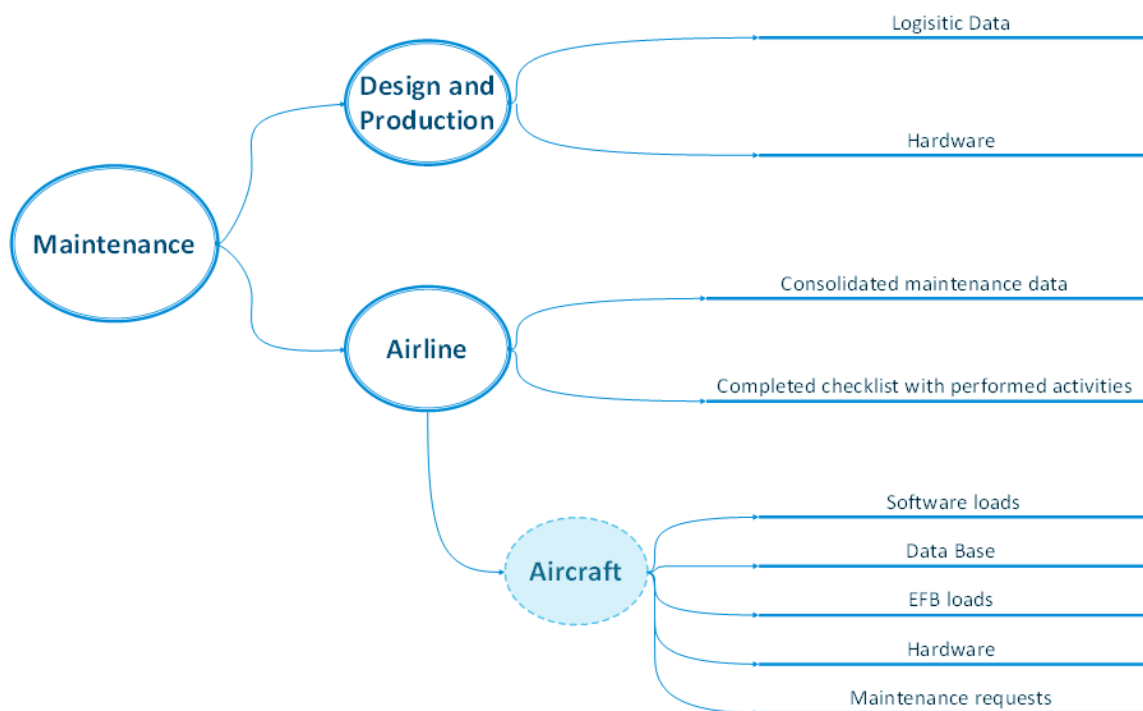


Figure 4: Interfaces of a maintenance service provider with other organisations

Appendix IV — Part-IS requirements mapping to ISO/IEC 27001:2022 clauses and controls, and considerations on differences

ED Decision 2025/014/R

Although Part-IS does not credit ISO/IEC 27001 certification, the practices and methods typically adopted for implementing and maintaining an ISMS under ISO/IEC 27000 largely align with the objectives of this regulation. Therefore, entities that have already implemented an ISMS under ISO/IEC 27001:2022 can use this as a basis for Part-IS compliance.

The following provides guidance on how organisations that have already implemented an ISMS compliant with ISO/IEC 27001:2022 can integrate Part-IS requirements into their existing ISMS. Specifically, the table below illustrates how to incorporate the ‘Part-IS particularity’ of each requirement into an existing ISO/IEC 27001-based ISMS in order to achieve Part-IS compliance. This is referred to as ‘Guidance on Part-IS implementation’.

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
IS.D.OR.200(a)	Related ISO/IEC 27001:2022 clauses and controls
	4. Context of the organisation
	6.1.1 Actions to address risks and opportunities - General
	Part-IS particularity
	An ISMS designed in the context of an ISO/IEC 27001:2022 ISMS, which is currently not connected to the management systems required by the delegated and implementing acts of Regulation (EU) 2018/1139 , including Part-IS, may differ if these different systems do not address the same goals. Part-IS focuses on information security requirements meeting the applicable aviation safety objectives, which have an influence on elements of the ISMS. Also, the ‘interested parties’ and the ‘internal and external issues’ as laid down in Chapter 4 of ISO/IEC 27001:2022 may be adapted to address the requirements of Part-IS for the organisation.
IS.D.OR.200(a)(1)	Guidance on Part-IS implementation
	<i>Please note that the point IS.D.OR.200 requirement points to many other Part-IS requirements that the ISMS has to comply with, namely points 205, 210, 215, 220, 225, 230, 235, 240, 245, 255, and 260. Further details are provided in the specific chapters on the particular requirement.</i>
	Regarding the other remaining requirements, not pointing out to other Part-IS requirements, and comparing them with ISO/IEC 27001:2022, there are four requirements left, namely points IS.D.OR.200(a)(1), IS.D.OR.200(a)(6), IS.D.OR.200 (a)(12) and IS.D.OR.200(a)(13).
IS.D.OR.200(a)(1)	Related ISO/IEC 27001:2022 clauses and controls
	5.2 Policy
	A.5.1 Policies for information securities
	Part-IS particularity

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	An ISMS designed in the context of an ISO/IEC 27001:2022 ISMS, which is currently not connected to the management systems required by the delegated and implementing acts of Regulation (EU) 2018/1139, may differ as these different systems do often not address the same goals. Part-IS focuses on information security requirements influencing the applicable aviation safety objectives, which in their turn have an influence on the elements of the ISMS. In addition, all domain-specific delegated and implementing acts of Regulation (EU) 2018/1139, namely points ORO.GEN.200(a)(2), ORA.GEN.200(a)(2), CAMO.A.200(a)(2), 145.A.200(a)(2), 21.A.139(c)(1), 21.A.239(c)(1), ATM/ANS.OR.B.005(a)(2), ATCO.O.C.C.001(b) and ADR.OR.D.005(b)(2), require a 'safety policy', where information security may be integrated. Guidance on Part-IS implementation The policy on information security established in an ISO/IEC 27001:2022 context has to be updated with regard to the potential impact of the risks on aviation safety. At least the elements of AMC1 IS.D.OR.200(a)(1) have to be mentioned in the policy. Therefore, the following elements may need to be added to an existing ISMS policy. The elements in bold and <i>italics</i> are additional guidance that might also be considered. (a) committing to complying with applicable legislation, considering relevant standards and best practices, <i>including safety- and cybersecurity-related standards and guidance published or prescribed by ICAO, EASA or the relevant civil aviation authority</i>; (b) setting objectives and performance measures for managing information security, <i>updated to ensure meeting</i> the applicable aviation safety objectives; (c) defining general principles, activities, processes for the organisation to appropriately secure information and communication technology systems and data, <i>in relation to the information security / safety risk assessment required by point IS.D.OR.205</i>; (d) committing to applying ISMS requirements into the processes of the organisation; (e) committing to continually improving towards higher levels of information security process maturity as per point IS.D.OR.260; (f) committing to satisfying applicable requirements regarding information security (<i>including requirements stemming from civil aviation authorities</i>) and its proactive and systematic management and to the provision of appropriate resources for its implementation and operation; (g) assigning information security as one of the essential responsibilities for all managers; (h) committing to promoting the information security policy through training or awareness sessions within the organisation to all personnel on a regular basis or upon modifications; (i) encouraging the implementation of a 'just culture' and the reporting of vulnerabilities, suspicious/anomalous events and/or information security incidents;

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	(j) committing to communicating the information security policy to all relevant parties, as appropriate.
IS.D.OR.200(a)(6)	Related ISO/IEC 27001:2022 clauses and controls 10.1 Corrective actions A5.5 Contact with authorities A5.26 Response to information security incidents A8.8 Management of technical vulnerabilities Part-IS particularity This requirement has no specific counterpart in ISO/IEC 27001:2022. Guidance on Part-IS implementation The policies and procedures, defined as means of compliance with the requirements listed above, should be extended to information security measures mandated by the competent authority.
IS.D.OR.200(a)(12)	Related ISO/IEC 27001:2022 clauses and controls 9.2. Internal audit 9.3 Management review 10.2 Non-conformity and corrective action A5.36 Compliance with policies, rules and standards for information security Part-IS particularity This requirement is strongly related to the internal audit system and the independent checking function of ISO/IEC 27001:2022. The required feedback system to the accountable manager or the head of the design organisation fits into the requirement of 9.3. In addition, all delegated and implementing acts for the specific domains require a similar ‘compliance monitoring function’, where information security should be integrated as described in AMC1 IS.D.OR.200(a)(12). Guidance on Part-IS implementation The requirements of ISO/IEC 27001:2022 and the delegated and implementing acts of Regulation (EU) 2018/1139 are compatible. Therefore, it will be easy to integrate Part-IS into the audit scope of the ISO/IEC 27001:2022 internal audit system. The role of the accountable manager or the head of the design organisation as defined under point IS.D.OR.240(a) has to be addressed accordingly in the feedback loop if the role is not already addressed in the management review process. The accountable manager or the head of the design organisation is required to be personally briefed on the key findings so that appropriate decisions can be made. Refer also to GM1 IS.D.OR.200(a)(12). Note: ISO 19011:2018 provides guidance on the establishment of an internal audit system. Specifically, Chapter A.7 ‘Auditing compliance within a management system’

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	<i>provides useful guidance on how to integrate a compliance monitoring function into an internal audit system.</i>
IS.D.OR.200(a)(13)	Related ISO/IEC 27001:2022 clauses and controls
	7.5.3. Control of documented information (Note)
	A5.12 Classification of information
	A5.34 Privacy and protection of personal identifiable information (PII)
	A8.12 Data leakage prevention
	Part-IS particularity
IS.D.OR.200(b)	This requirement is limited to ‘information from other organisations’ and to confidentiality. ISO/IEC 27001:2022 does not differentiate between ‘internal’ or ‘external’ information (as laid down e.g. in ISO 9001:2015 Chapter 8.5.3). The only reference is made in the note in Chapter 7.5.3.
	Part-IS stresses protection of external information received due to the sensitivity it may have regarding incidents and vulnerabilities disclosure. Insufficient confidentiality protection may result in exploitation of vulnerabilities affecting safety that the original provider of information may not have perceived.
	Guidance on Part-IS implementation
	The protection of information, specifically regarding confidentiality (as in ISO/IEC 27002:2022), is related to a set of controls that can be found in Table A.1 (Matrix of controls and attribute values) of ISO/IEC 27002:2022. See also the definition in ISO/IEC 27002:2022:
	<i>3.1.7 Confidential information</i>
	<i>Information that is not intended to be made available or disclosed to unauthorized individuals, entities or processes.</i>
IS.D.OR.200(c)	The organisation having implemented these controls should take special care that they apply to information received from external information that may result in information security threats if known by unauthorised actors. When this kind of information is further shared with other organisations or authorities, appropriate confidentiality procedures must be put in place and followed (TLP marking, for instance).
	Related ISO/IEC 27001:2022 clauses and controls
	10.1 Continual improvement
	Part-IS particularity
	Part-IS and ISO/IEC 27001:2022 are very similar regarding this requirement. See points IS.D.OR.260 (a) and (b) for subtle differences.
	Guidance on Part-IS implementation
IS.D.OR.200(d)	See point IS.D.OR.260 in this table.
	Related ISO/IEC 27001:2022 clauses and controls

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	6.3 Planning of changes
	7.5.3 Control of documented information
	Part-IS particularity
	Control of documented information is one of the key processes in each ISO management system standard, following the ISO ‘high-level structure’ (ISO/IEC Directives part 1 Annex SL), such as ISO/IEC 27001 :2022. For changes, see point IS.D.OR.255. In addition, most of the delegated and implementing acts for the specific domains require a similar need to document, where information security should be integrated.
	Guidance on Part-IS implementation
	See points IS.D.OR.250 and IS.D.OR.255 in this table.
IS.D.OR.200(d)	Related ISO/IEC 27001:2022 clauses and controls
	4.3 Determining the scope of the information security management system
	Part-IS particularity
	The scope statement and the ‘statement of applicability’ (SOA) are the best references to apply the ‘nature and complexity’. In addition, most of the delegated and implementing acts for the specific domains require a similar need to document, where information security should be integrated.
	Guidance on Part-IS implementation
	When determining the scope, it should be noted that Part-IS is delimited to the subject matter as defined in Article 1 of the Regulation(s), which refers to <i>identification and management of information security risks with potential impact on aviation safety</i> . Considering this, the scope of an ISMS under ISO/IEC 27001:2022 may be broader than that required by Part-IS. Some organisational units, processes or locations may fall under what is covered by the ISMS under ISO/IEC 27001:2022, but not within the scope of Part-IS. The opposite may happen too: the scope under ISO/IEC 27001:2022 may be narrower than the one Part-IS would require (e. g. the ISO/IEC 27001:2022 scope covers only the IT department). In both situations, scope definitions must be compared and adjusted when necessary. <u>Note:</u> See also guidance on point IS.D.OR.205(a) in this table. The scope statement in the ISO/IEC 27001:2022 context is the right place where this clarification is made.
IS.D.OR.200(e)	Related ISO/IEC 27001:2022 clauses and controls

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	4.1 Understanding the organisation and its context.
	Part-IS particularity
	This is a ‘derogation’ for organisations falling under the applicability of Article 2 of this Regulation. This process is independent from an ISO/IEC 27001:2022 certification process.
	Guidance on Part-IS implementation
	If an organisation which already has an established ISMS according to ISO/IEC 27001:2022 decides to embark on this process, the full implementation of Part-IS into the ISMS may be put on hold until the decision of the competent authority is made. To demonstrate that an organisation’s activities, facilities and resources, as well as the services it operates, provides, receives and maintains, do not pose any information security risks with a potential impact on aviation safety either to itself or to other organisations, the existing risk assessment methodology according to ISO/IEC 27001:2022 Chapter 6.1.2 may be used if the methodology is enhanced with a focus on the impact on safety. On the other hand, an existing risk assessment methodology used by the existing safety management system (SMS) could be enhanced by addressing potential information security risks. In any case, the competent authority responsible for the organisation will determine which process and methodology shall be used. This demonstration has to be at least verified and reassessed at regular intervals and as a mandatory part of the organisation’s change process. In case of any doubt about the conclusion, the appropriate civil aviation authority must be contacted.
IS.D.OR.205(a)	Related ISO/IEC 27001:2022 clauses and controls
	4.3 Determining the scope of the information security management system
	6.1.2 Information security risk assessment
	Part-IS particularity
	This requirement of Part-IS is in line with ISO/IEC 27001:2022, however ISO/IEC 27001:2022 allows a wider focus, whereas Part-IS puts the focus on safety already from the element’s identification stage. In addition, all of the delegated and implementing acts for the specific domains require a risk assessment process, where information security can be integrated.
	Guidance on Part-IS implementation
	AMC1 IS.D.OR.205(a) explains that when conducting an information security risk assessment, the organisation should ensure that each relevant aviation safety impact is identified and included in the ISMS scope, which might not be the case when using ISO/IEC 27001:2022. On the other hand, an ISO/IEC 27001:2022 ISMS focuses its security risk assessment mainly on the business impact of infringement on confidentiality, integrity and availability, their risks and the impact on assets (e. g. loss of IT infrastructure, breach of data).

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	This means that, starting from an ISMS based on ISO/IEC 27001:2022, a complementary analysis has to be made to take into account all the elements related to aviation safety. To bridge the two approaches of management systems (SMS and ISMS), an identified information security risk may be entered as a ‘cause’ or ‘contributing event’ in the aviation-safety-focused risk assessment required by the domain-specific implementing or delegated act. The figure in GM1 IS.D.OR.205(c) provides a good indication of how this bridge could be built.
IS.D.OR.205(b)	Related ISO/IEC 27001:2022 clauses and controls 4.1 Understanding the organisation and its context 4.3 Determining the scope of the information security management system A5.19 Information security in supplier relationships A5.21 Managing information security in the information and communication technology (ICT) supply chain Part-IS particularity Point IS.D.OR.205(b) focuses on the identification of interfaces with the other organisations. ISO/IEC 27001:2022 4.3 requires considering in point c) the interfaces at and dependencies between activities performed by the organisation and those that are performed by other organisations. So, there is more in Part-IS than that required by ISO/IEC 27001:2022, provided that the scope considered includes safety, as required by point IS.D.OR.205(a). Controls A5.19 and A5.21 are a profound foundation for the requirements of point IS.D.OR.205(b). Guidance on Part-IS implementation ISO/IEC 27001:2022 A5.19 requires the identification of risks associated with the use of suppliers’ products or services. ISO 27002 A5.19 contains additional guidance in points f) to j) on how to manage the risk exposure. ISO/IEC 27001:2022 A5.21 requires the management of information security risks associated with the ICT products and services supply chain. ISO 27002 A5.21 contains additional guidance in points f), k), l) and m) on how to manage risks through the supply chain. The Part-IS notion about interfaces and supply chain goes beyond the respective ISO/IEC 27001:2022 notion. GM1 IS.D.OR.205(b) requests interfacing organisations to share information about mutual risk exposure (including all data flows) and urges organisations to use ED-201A for that. Point IS.D.OR.205(c) also requires accounting for information acquired by interfacing organisations, which underlines the two-way nature of the considerations. Particular attention should be paid to the Part-IS intent to protect the so-called functional chains. The notion is that while organisations may protect themselves well enough, interfaces between organisations may pose risks to each chain when not accounted for.
IS.D.OR.205(c)	Related ISO/IEC 27001:2022 clauses and controls 6.1.2 Information security risk assessment

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	Part-IS particularity
	Point IS.D.OR.205(c) is the ‘heart’ of Part-IS. ISO/IEC 27001:2022 6.1.2 opens a ‘framework’ where the requirements of point IS.D.OR.205 may fit in.
	It has to be assured that the risk management systems of the ISMS and those required by the SMS regulations (see point IS.D.OR.205(a)) do NOT operate independently, as there might be difficulties in connecting the two systems.
	Guidance on Part-IS implementation
	Further to this provision, a proper risk assessment has to be made, taking into account the scope and interfaces described in points IS.D.OR.205(a) and IS.D.OR.205(b). It has to be noted (see also GM1 IS.D.OR.205(c)) that point IS.D.OR.205 does not require the use of any specific information security risk assessment framework, such as ISO 31000, NIST or others, to develop the risk assessment. ISO/IEC 27001:2022 tends to lean towards using ISO 27005 as a risk assessment standard; however, it does not make it mandatory. The key point is that the risk assessment carried out in the application of ISO/IEC 27001:2022 6.1.2 does not necessarily consider safety risks, and may focus on different types of risks.
	With respect to safety, conditions that may lead to safety consequences are identified as hazards . Their materialisation may be either directly triggered or caused by information security threats which have not been successfully prevented. Information security can thus cause or contribute to a safety consequence in four different ways: (1) it can act as a safety threat; (2) it can have a negative effect on a safety barrier, rendering it less effective than before; (3) it can directly trigger the materialisation of an already identified hazard; or (4) it can constitute a new, not yet identified, hazard, which can obviously also materialise. By using e.g. the ‘bow-tie method’ regarding information security, a ‘hazard’ would be replaced by a ‘vulnerability’, which can be exploited resulting in information security consequences (e.g. lack or reduction of confidentiality, integrity, availability, authenticity properties). Hence, from a methodology perspective, both considerations are very similar and can be designed to interact (e. g. consequences of the information security bow-tie may connect as causes of the ‘safety bow-tie’). <u>Guidance on organisations that are NOT required to operate an SMS, including safety risk management</u> Any ISO/IEC 27001:2022 risk assessment has to be reviewed and revised by introducing safety impact (consequence) considerations. Any risk matrix stemming from an ISO/IEC 27001:2022 6.1.2 risk assessment is acceptable, provided that it includes safety impacts (consequences), and the results remain within the limitations of ICAO Annex 19. If two different risk assessment schemes are used, they need to be linked accordingly. <u>Guidance on organisations that are required to operate an SMS, including safety risk management</u>

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	In most of the cases, where an organisation is subject to the domain-specific implementing or delegated acts for SMS and operates an ISMS under voluntary compliance with ISO/IEC 27001:2022, it may operate two risk management systems, one for safety under the oversight of a competent authority, and one for information security. The latter may ultimately be certified by an ISO/IEC 27001:2022 accredited body. Each potential risk identified by the ISMS risk management has to be systematically assessed for its potential impact on safety. To establish the connection between the systems, the following approach should be used: (1) If a safety risk assessment is available, it should be able to provide its context and determined target likelihoods for acceptable information security risks to the information security risk assessment process. The context consists of the system architecture, including its preventative and mitigative barriers, the hazards assessed and the safety risks identified. Based upon the information provided, the information security risk assessment can be conducted. Modifications to the system architecture, or any modifications of properties of the preventative or mitigative barriers, as well as the achieved risk properties need to be communicated back to the safety risk assessment process. Based upon this communication, the safety risk assessment has to be updated. In other words: mitigation measures put in place as a result of the information security risk assessment should also be considered as they may not only mitigate, but possibly also create a negative safety impact. (2) If a safety risk assessment is available, but the information security assessment process identifies a new hazard that was previously unknown to the safety risk assessment, a full hazard assessment of all safety aspects have to be conducted to ensure that the safety risk assessment contains the ‘full picture’ of the newly addressed hazard. (3) The safety risk and the information security risk assessments need to be repeated as described above until all acceptability requirements for all aspects are met.
IS.D.OR.205(d)	Related ISO/IEC 27001:2022 clauses and controls 6.3 Planning of changes 8.2 Information security risk assessment Part-IS particularity Point IS.D.OR.205(d) is about the subsequent changes to the original risk assessment, due to a change of context or interfaces or knowledge about the risks or lessons learnt. This is equivalent to ISO/IEC 27001:2022 8.2. In both frameworks the reviews are planned and documented. Guidance on Part-IS implementation The same process as that already in place in an ISO/IEC 27001:2022 context can be used to implement point IS.D.OR.205(d), provided that this process has been updated to include safety criteria evaluation of changes that trigger an unplanned update of the risk assessment.

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	Those organisations that have most experienced risk assessment updates at planned intervals will need to be proactive to trigger such updates more often in the situations listed in points IS.D.OR.205(d) (1), (2), (3), and (4) that could affect safety. The triggering criteria and the process should be documented and tested before implementation, for example through table-top exercises. The change management process is key to keep a management system in a solid and stable condition. Considering an established ISMS according to ISO/IEC 27001:2022, the regular updates of the risk assessment based on changes and lessons learned should be effective. The essential focus, introduced by Part-IS, is the ‘impact on safety’, which drives the update assessment. Change management processes focusing on changes that may have impact on safety are also set out in all domain-specific implementing and delegated acts. Without the ‘bridge’ of Part-IS, both systems (ISMS and SMS) are implemented independently, often without considering interdependencies. Part-IS implies the need (and provides the opportunity) to interlink the systems to provide a common risk picture for the organisation, with a focus on safety, but also opening the horizon to information security.
IS.D.OR.210(a)	Related ISO/IEC 27001:2022 clauses and controls 6.1.3 Information security risk treatment 8.3 Information security risk treatment Part-IS particularity Point IS.D.OR.210(a) is about information security risk treatment, which is widely covered by ISO/IEC 27001:2022, its Appendix A, and ISO/IEC 27002. Point IS.D.OR.210(a) provides however some additional inputs related to the risks that may have a safety impact. Guidance on Part-IS implementation ISO/IEC 27001:2022 6.1.3 is about the definition of the risk treatment plan, while ISO/IEC 27001:2022 8.3 deals with the implementation of the plan, and both are relevant. ISO/IEC 27001:2022 Annex A contains a list of possible information security controls, and therefore should also be used in addition to the already existing controls, to mitigate information security risks having an impact of safety. All the controls of Annex A are detailed in ISO/IEC 27002. Point IS.D.OR.210(a) specifies that the measures selected in the plan have to reduce the consequences on aviation safety associated with the materialisation of the threat scenario. This is in line with point IS.D.OR.205 since the risk treatment phase is a consequence of the risk assessment phase and has to address all the risks that have been evaluated. Point IS.D.OR.210(a) also stipulates that those (protection) measures shall not introduce any new potential unacceptable risks to aviation safety. This is an area that is not directly covered by either ISO/IEC 27001:2022 or ISO/IEC 27002. The requirement addresses the so-called ‘side effects’ when introducing measures into a system (a well-known issue in software development which is also very relevant for information security measures). Preventive or

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	mitigative measures specifically (e.g. physical security, access control) could lead to unintended side effects. Also, the risk treatment of the identified risks should focus on addressing safety via the same linkage/integration of ISMS and safety management.
IS.D.OR.210(b)	Related ISO/IEC 27001:2022 clauses and controls
	6.1.3.f Information security risk treatment
	7.3 Awareness
	9.3 Management review
	A5.19 Information security in supplier relationships
	A5.21 Managing information security in the ICT supply chain
	Part-IS particularity
	Point IS.D.OR.210(b) requires key personnel in the organisation to be informed about the risks, the corresponding threat scenarios and the security risk treatment measures, which result in specific controls covered by Annex A to ISO/IEC 27001:2022 and ISO/IEC 27002. It partially covers IS.D.OR.210(b) by the following requirement: obtain risk owners' approval of the information security risk treatment plan and acceptance of the residual information security risks. Point IS.D.OR.210(b) has two specific requirements that also have equivalent requirements in ISO/IEC 27001:2022 and ISO/IEC 27002: — Inform the accountable manager or the head of the design organisation of the risk treatment plan — which is a mandatory input to the management review. — Inform the interfacing entities (the same as in point IS.D.OR.205(b)) of all risks shared with them — which is stated in A5.19 Guidance point I).
	Guidance on Part-IS implementation
	In addition to the risk owner's approval requested by ISO/IEC 27001:2022 6.1.3.f, the organisation will need to inform: — the accountable manager or the head of the design organisation of the risk treatment plan. ISO/IEC 27001:2022 9.3. f) defines 'results of risk assessment and status of risk treatment plan' as mandatory input for the management review which is the vehicle to inform the accountable managers/heads of the design organisation; — the interfacing entities (the same as in point IS.D.OR.205(b)) of all risks shared with them. ISO/IEC 27002 A5.21 states in point f) 'defining rules for sharing of information and any potential issues and compromises between the organisations'. GM1 IS.D.OR.205(b) and ED-201A may also be used as guidance on risk sharing.
IS.D.OR.215(a)	Related ISO/IEC 27001:2022 clauses and controls
	A5.24 Information security incident management planning and preparation
	A6.8 Information security event reporting

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	Part-IS particularity
	Fully covered by the requirements of A5.24 and A6.8. However, the linkage to the external reporting scheme for the incidents with relation to safety (unsafe conditions) has to be established.
	Guidance on Part-IS implementation
	The linkage to the external reporting scheme for the incidents with relation to safety could be described under A5.5 (contact with authorities) in the ISO structure.
IS.D.OR.215(b)	Related ISO/IEC 27001:2022 clauses and controls
	A5.25 Assessment and decision on information security events
	A5.26 Response to information security incidents
	A5.27 Learning from information security incidents
	A5.28 Collection of evidence
	A8.8 Management of technical vulnerabilities
	Part-IS particularity
	Fully covered by the requirements from A5.25 to A5.28 and A8.8 with a need to focus on safety impacts.
	Guidance on Part-IS implementation
	The requirements of controls A8.8, A5.25 to A5.28 and the guidance in ISO/IEC 27002:2022 are comprehensive to fulfil the requirements of IS.D.OR.215(b). In accordance with point IS.D.OR.215(b)(1), the impact on safety always needs to be assessed specifically.
	AMC1 IS.D.OR.215(a)&(b) has also to be considered.
IS.D.OR.215(c)	A5.19 Information security in supplier relationships
	A5.20 Addressing information security within supplier agreements
	A5.21 Managing information security in the information and communication technology (ICT) supply chain
	Part-IS particularity
	To be covered under the procedures according to A5.19 and A5.21, as well as under the agreements according to A5.20.
	Guidance on Part-IS implementation
	However, this depends on whether the supplier is also subject to Part-IS or not. In the latter case, the external reporting shall be done by the contracting organisation. GM1 IS.D.OR.215(c) provides guidance on the relationship with contracted organisations.
IS.D.OR.215(d)	Related ISO/IEC 27001:2022 clauses and controls
	A5.6 Contact with special interest groups

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	A5.20 Addressing information security within supplier agreements
	A5.21 Managing information security in the information and communication technology (ICT) supply chain
	A5.28 Collection of evidence
	Part-IS particularity
	The requirements of controls A5.20, A5.21 and A5.28 and the guidance in ISO/IEC 27002:2022 are comprehensive to fulfil the requirements of point IS.D.OR.215(d) in terms of process, but Part-IS will require cooperation with a broader range of organisations.
	Guidance on Part-IS implementation
	As ISO/IEC 27001:2022 only focuses on the supply chain and Part-IS requires a broader focus, the process needs to be highlighted to other relevant stakeholders. This may be covered under A5.6. Nevertheless, ISO/IEC 27002 A5.19 has a clear statement under point (i) of the guidance.
	See also the cooperation in accordance with point IS.D.OR.205(c).
IS.D.OR.215(d)	Related ISO/IEC 27001:2022 clauses and controls
	A5.24 Information security incident management planning and preparation
	A6.8 Information security event reporting
	Part-IS particularity
	Fully covered by the requirements of A5.24 and A6.8.
	Guidance on Part-IS implementation
	However, the linkage to the external reporting scheme for the incidents with relation to safety (unsafe conditions) shall be established. This could be described under A5.5 (contact with authorities) in the ISO structure.
IS.D.OR.220(a)	Related ISO/IEC 27001:2022 clauses and controls
	A5.24 Information security incident management planning and preparation
	A5.25 Assessment and decision on information security events
	A5.26 Response to information security incidents
	A5.27 Learning from information security incidents
	A5.28 Collection of evidence
	A5.29 Information security during disruption
	A7.5 Physical security monitoring
	A8.16 Monitoring activities
	Part-IS particularity
	Fully covered by the requirements of A5.24 to A5.29, and A7.5 for physical security and A8.16 for technical monitoring.

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	Guidance on Part-IS implementation
	The requirements of the controls (both reactive and proactive) mentioned above and the guidance in ISO/IEC 27002:2022 are comprehensive to fulfil the requirements of point IS.D.OR.220(a).
	Again, the impact on safety needs to be assessed, and measures shall be taken to ensure safety. Part-IS refers to ‘unsafe conditions’, which have to be mitigated to an acceptable level. A re-assessment of risks that are related to incidents that have occurred or to a vulnerability that has been identified is mandatory in Part-IS to ensure that no risk becomes unacceptable.
IS.D.OR.220(b)	<i>Note: Due to historical reasons, information security and safety management use different wording when referring to situations which are more or less the same. The term ‘incident’ is used in a similar way (an event which already happened and infringes safety/security). A vulnerability in the sense of information security could be mapped to the term ‘hazard’ in the area of safety (a situation identified, which is possible to happen, but has not happened so far).</i>
	Related ISO/IEC 27001:2022 clauses and controls
	A5.26 Response to information security incidents
	A5.29 Information security during disruption
	A7.5 Physical security monitoring
	A8.8 Management of technical vulnerabilities
	Part-IS particularity
IS.D.OR.220(c)	Fully covered by the requirements of A5.26 and A5.29.
	Guidance on Part-IS implementation
	The requirements of control A5.26 and the guidance in ISO/IEC 27002:2022 are comprehensive to fulfil the requirements of point IS.D.OR.220(b).
IS.D.OR.220(c)	Related ISO/IEC 27001:2022 clauses and controls
	A5.26 Response to information security incidents
	A5.29 Information security during disruption
	Part-IS particularity
	This requirement is covered by the requirements of A5.26 and A5.29, with the difference that the recovery here is not intended to continuously ensure confidentiality, integrity, availability and integrity; instead, it is intended to maintain or return to an acceptable level of safety.
	In addition, some domain-specific implementing and delegated acts of Regulation (EU) 2018/1139 (e.g. points ARO.GEN.200, ATM/ANS.OR.A.070, ADR.OR.B.070) require emergency response planning and/or contingency planning, where information security should be integrated.
	Guidance on Part-IS implementation

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	Coupled with the requirements of controls A5.26 and A5.28 and the guidance in ISO/IEC 27002:2022, AMC1.IS.D.OR.220(c) should be applied in order to revert as quickly as possible to a safe state.
IS.D.OR.225	Related ISO/IEC 27001:2022 clauses and controls 10.2 Non-conformity and corrective action Part-IS particularity This requirement has no specific counterpart in ISO/IEC 27001:2022. Guidance on Part-IS implementation This issue is not covered by the requirements of ISO/IEC 27001:2022, so it is not possible to adapt existing policies and procedures under ISO/IEC 27001:2022 for this requirement. To ensure compliance with this requirement, please refer exclusively to the related AMC and GM.
IS.D.OR.230	Related ISO/IEC 27001:2022 clauses and controls A5.5 Contact with authorities Part-IS particularity This requirement is not directly addressed in ISO/IEC 27001:2022. Guidance on Part-IS implementation This issue is not covered by the requirements of ISO/IEC 27001:2022, so it is not possible to adapt existing policies and procedures under ISO/IEC 27001:2022 for this requirement. To ensure compliance with this requirement, please refer exclusively to the related AMC and GM. The reporting requirement should also be considered if the organisation falls under the NIS 2 Directive.
IS.D.OR.235(a)	Related ISO/IEC 27001:2022 clauses and controls A5.19 Information security in supplier relationships A5.21 Managing information security in the information and communication technology (ICT) supply chain A5.22 Monitoring, review and change management of supplier services Part-IS particularity ISO/IEC 27001:2022 controls A5.19, A5.21 and A5.29 may cover this requirement. The difference in the requirements of point IS.D.OR.235 is that they are limited to those activities directly related to the ISMS (e. g. internal audits, consultancy for risk assessments, etc.). In addition, all domain-specific implementing or delegated acts require procedures to deal with contracted activities in a wider scope, where information security should be integrated. Guidance on Part-IS implementation

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	This requirement relates only to ISMS activities (e.g. internal audits, risk assessments), not to those activities not directly related to ISMS itself (e. g. hardware, software, IT and OT). The difference in the requirements of point IS.D.OR.235 is that they are limited to those activities directly related to the ISMS (e. g. internal audits, consultancy for risk assessments, etc.). The controls in ISO/IEC 27001:2022 do not exclude those kinds of services, but sometimes they will not be in the focus of the organisation. Therefore, there is no need to establish an independent system for those contractors referred to in point IS.D.OR.235(a). The list of suppliers should be reviewed to ensure that the suppliers providing the services mentioned in point IS.D.OR.235 are covered.
IS.D.OR.235(b)	Related ISO/IEC 27001:2022 clauses and controls A5.20 Addressing information security within supplier agreements Part-IS particularity Access provided to the authority is not covered in ISO/IEC 27001:2022. Guidance on Part-IS implementation Organisations subject to Part-IS are required to provide access to the competent authority. If the contracted organisation is approved by an authority of another Member State, the different competent authorities will coordinate on which authority will perform oversight of the organisation according to their authority procedures (e.g. Regulation (EU) No 965/2012, point ARO.GEN.300(e)). For contracted organisations not subject to Part-IS, GM1 IS.D.OR.235(b) provides the content to be introduced either in the ‘general terms and conditions of trade’ of the contracting organisation, or if standard general terms and conditions are used (e. g. for COTS-products), the content of the GM has to be arranged on a contractual basis (e. g. through a side letter). AMC1.IS.D.OR.235(b) should be considered in conjunction with ISO/IEC 27001:2022 A5.20.
IS.D.OR.240(a)	Related ISO/IEC 27001:2022 clauses and controls
IS.D.OR.240(e)	5.1 Leadership and commitment 5.3 Organisational roles, responsibilities and authorities 7.1 Resources A5.2 Information security roles and responsibilities Part-IS particularity ISO/IEC 27001:2022 does not require a specific role such as the ‘accountable manager’ or ‘head of the design organisation’. Guidance on Part-IS implementation The implementation of the requirements of point IS.D.OR.240(a) can be covered by the implementation of ISO/IEC 27001:2022 requirements mentioned above,

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	provided that the role of accountable manager/head of the design organisation is clearly defined and meets the requirements in point IS.D.OR.240(a). The requirement of point IS.D.OR.240(a)(3) has to be set in line with the roles in A5.2 (where an accountable manager or the head of the design organisation is not envisaged). However, the measures in A6.3 should be used to ensure the competency of the accountable manager or the head of the design organisation (point IS.D.OR.240(a)(3)).
IS.D.OR.240(b)	Related ISO/IEC 27001:2022 clauses and controls
IS.D.OR.240(c)	5.3 Organisational roles, responsibilities and authorities 7.1 Resources A5.2 Information security roles and responsibilities A5.3 Segregation of duties
	Part-IS particularity
	This requirement is not directly addressed in ISO/IEC 27001:2022.
	Guidance on Part-IS implementation
	The implementation of the requirements of A5.2 and A5.3 should be used as a basis to fulfil the provisions of points IS.D.OR.240 (b) and (c), but some adaptation may be needed. This issue is covered in A5.2, but A5.3 may also be applicable. In addition, similar requirements for the ‘safety roles’ are laid down in the domain-specific ‘safety’ implementing or delegated acts of Regulation (EU) 2018/1139. AMC1 IS.D.OR.240(b) should be considered.
IS.D.OR.240(d)	Related ISO/IEC 27001:2022 clauses and controls
	4.3 Determining the scope of the information security management system A5.2 Information security roles and responsibilities A5.3 Segregation of duties
	Part-IS particularity
	The implementation of the requirements of A5.2 and A5.3, as well as the guidance of ISO/IEC 27002, allow the delegation of responsibility within organisations.
	Guidance on Part-IS implementation
	This option might be useful for large organisations or groups, where the ISMS is implemented as an ‘umbrella function’ over a group of organisations, where not all of them are subject to Part-IS. The implementation of a ‘group CISO’ or an enterprise-wide ISMS could make use of this option in Part-IS. Nevertheless, the common responsible person has to fulfil the competency requirements of point IS.D.OR.240(a)(3). This might be relevant in cases where the other activities of the organisation or group are not related to aviation.

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
IS.D.OR.240(f)	Related ISO/IEC 27001:2022 clauses and controls
	7.1 Resources
	Part-IS particularity
	The requirements of 7.1 should be implemented.
	Guidance on Part-IS implementation
	A systematic capacity planning of human resources is a key element of any management system. Therefore, such a process should be established in an ISMS. The possible additional requirement stemming from Part-IS has to be assessed, and the capacity planning updated accordingly. The targeted safety levels set in the safety/information security assessment should never be jeopardised by a lack of resources, even temporarily. AMC1 IS.D.OR.240(f) should be considered.
IS.D.OR.240(g)	Related ISO/IEC 27001:2022 clauses and controls
	7.2 Competency
	A6.3 Information security awareness, education and training
	Part-IS particularity
	The implementation of the requirements of 7.2 and A6.3 is sufficient to cover the requirement.
	Guidance on Part-IS implementation A systematic competency management process of staff is a key element of any management system. Therefore, such a process should be established in an ISMS. The possible additional requirement stemming from Part-IS has to be assessed and the competency requirements updated accordingly. AMC1 IS.D.OR.240(g) should be considered.
IS.D.OR.240(h)	Related ISO/IEC 27001:2022 clauses and controls
	A6.2 Terms and conditions of employment
	Part-IS particularity
	The implementation of the requirements of A6.2 with some adaptation would be sufficient to cover the provision of point IS.D.OR.240(h).
	Guidance on Part-IS implementation
	Point IS.D.OR.240(h) is (at least partially) covered by ISO/IEC 27001:2022 A.6.2 ‘The employment contractual agreements should state the personnel’s and the organisation’s responsibilities for information security.’ and A.6.4 ‘disciplinary process’ (see ‘Just Culture’). It depends on the organisational culture and on whether job descriptions or role assignments need to be formally acknowledged. In many organisations, the assigned jobs and roles are mutually acknowledged by performing the tasks assigned.

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
IS.D.OR.240(i)	Related ISO/IEC 27001:2022 clauses and controls
	A5.19 Information security in supplier relationships
	A6.1 Screening
	A7.2 Physical entry
	A8.3 Information access restriction
	A8.5 Secure authentication
	Part-IS particularity
	The implementation of the requirements of A5.19, A6.1, A7.2, A8.3 and A8.5 might be sufficient controls to cover this requirement for the personnel of the organisation, as well as for contractors and suppliers.
	Guidance on Part-IS implementation
	All the controls established in an ISO/IEC 27001:2022-compliant ISMS are designed to ensure the confidentiality and integrity of information. The implementation of those controls will provide sufficient protection to ensure compliance with this requirement.
	AMC1 IS.D.OR.240(i) should be considered.
IS.D.OR.245(a)	Related ISO/IEC 27001:2022 clauses and controls
	7.5 Documented information
	A5.9 Inventory of information and other associated assets
	A5.13 Labelling of information
	A8.10 Information deletion
	A8.13 Information backup
	Part-IS particularity
	Record-keeping and retention are an inherent part of the document control system under 7.5 of ISO/IEC 27001:2022. Controls A5.9, A5.13, A8.10 and A8.13 also apply.
	Guidance on Part-IS implementation
	Chapter 7.5.1 b) states that the ISMS has to include ‘documented information determined by the organisation as being necessary for the effectiveness of the information security management system.’ This includes the records defined in point IS.D.OR.245(a)(1). Chapter 7.5.3 requires, under f), also document control for retention and disposition. Part-IS requirements have to be integrated into the existing system, especially the minimum duration of record-keeping of five years.
	The minimum set of records, as defined in point IS.D.OR.245(a)(1) should be covered in the inventory of assets. For the coverage, the content of GM1 IS.D.OR.245 also applies.
	As records are not only information assets, the requested ‘record retention policy’ may be integrated into a wider policy as recommended by ISO/IEC 27002:2022 above.

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	AMC1 IS.D.OR.245(a)(1)(vi)&(a)(5) should be implemented.
IS.D.OR.245(b)	Related ISO/IEC 27001:2022 clauses and controls
	7.5 Documented information
	A5.9 Inventory of information and other associated assets
	A5.10 Acceptable use of information and other associated assets
	A5.13 Labelling of information
	A5.34 Privacy and protection of personal identifiable information (PII)
	A8.10 Information deletion
	A8.13 Information backup
	Part-IS particularity
	Record-keeping and retention are an inherent part of the document control system under 7.5 of ISO/IEC 27001:2022. Controls A5.9, A5.13, A8.10 and A8.13 will also apply and, due to GDPR issues specifically, also A5.10 and A5.34.
	Guidance on Part-IS implementation
	Chapter 7.5.1 b) states that the ISMS has to include ‘documented information determined by the organisation as being necessary for the effectiveness of the information security management system.’ This includes the records defined in point IS.D.OR.245(a)(1). Chapter 7.5.3 requires, under f), also document control for retention and disposition. Part-IS requirements have to be integrated into the existing system, especially the minimum duration of record-keeping of five years.
	However, whereas there is no retention duration specified in ISO/IEC 27001:2022, point IS.D.OR.245(a) specifies three years after the person has left the organisation.
	As these records fall under the GDPR Regulation, each organisation has to ensure that they are handled accordingly. It is recommended that the procedures are used not only for records related to ISMS, but also for the entire HR personnel files of the staff.
IS.D.OR.245(c)	Related ISO/IEC 27001:2022 clauses and controls
	7.5 Documented information
	A5.13 Labelling of information
	Part-IS particularity
	Record-keeping and retention are an inherent part of the document control system under 7.5 of ISO/IEC 27001:2022 as well as control A5.13.
	Guidance on Part-IS implementation
	Chapter 7.5.3, under a), requires for the information that ‘it is available and suitable for use, where and when it is needed’. Part-IS requirements have to be integrated into the existing system.

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	ISO/IEC 27002:2022 A5.13 states ‘Procedures for information labelling should cover information and other associated assets in all formats.’; therefore, the Part-IS requirement is fulfilled with control A5.13. A series of AMC material to the implementing and delegated acts regarding safety (e.g. AMC1 ARA.GEN.220(a), AMC1 145.A.55) also covers this issue.
IS.D.OR.245(d)	Related ISO/IEC 27001:2022 clauses and controls 7.5 Documented information A5.10 Acceptable use of information and other associated assets A5.12 Classification of information A5.33 Protection of records A8.12 Data leakage prevention Part-IS particularity Record-keeping and retention are an inherent part of the document control system under 7.5 of ISO/IEC 27001:2022. Controls A5.10, A5.12, A5.33 and A8.12 will also apply. Guidance on Part-IS implementation Chapter 7.5.3, under d), requires ‘storage and preservation, including the preservation of legibility’. Part-IS requirements have to be integrated into the existing system. The application of A5.33 and A8.12 has a strong relationship to A7.5 (Protecting against physical and environmental threats), A7.10 (Storage media), A8.3 (Information access restriction), A8.13 (Information backup), A8.14 (Redundancy of information processing facilities), A8.15 (Logging), A8.17 (Clock synchronization) and A8.24 (Use of cryptography).
IS.D.OR.250(a)	Related ISO/IEC 27001:2022 clauses and controls 7.5 Documented information A5.13 Labelling of information Part-IS particularity Document control is an inherent part of the ISMS under 7.5 of ISO/IEC 27001:2022. Control A5.13 is also an ‘anchor point’ for this requirement. ISO/IEC 27001:2022 does not specifically request a document called ‘information security management manual’, made available to the authority. Guidance on Part-IS implementation Chapter 7.5.1 b) states that the ISMS has to include ‘documented information determined by the organisation as being necessary for the effectiveness of the information security management system’ which will allow the inclusion of the ISMS manual in the documentation. Part-IS requires a specific ISMS manual (ISMM), made available to the competent authority.

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	It has to be made clear to the competent authority which set of documented information constitutes the ‘approved manual’. The document ‘statement of applicability’ (SOA), mandatory for all ISO/IEC 27001:2022-certified organisations may be helpful (e.g. by adding an additional column to label specific documents as part of a ‘virtual’ ISMS Manual). GM1 IS.D.OR.250(a) also provides associated guidance. It has to be ensured that all information listed in point IS.D.OR.250(a) is covered.
IS.D.OR.250(b)	Related ISO/IEC 27001:2022 clauses and controls
IS.D.OR.250(c)	7.5 Documented information A5.5 Contact with authorities
	Part-IS particularity
	Document control is an inherent part of the ISMS under 7.5 of ISO/IEC 27001:2022.
	Guidance on Part-IS implementation
	The use of the same procedure as the one implemented for the ‘safety regulations’ (see above) is recommended also for the approval, update and communication processes with the competent authority. Many organisations have their documented information available via document management systems (e.g. MS SharePoint). The access of the competent authority to these systems has to be managed in accordance with the rules of any other external access in respect of A5.15, A5.18, A6.6, A7.9, A8.3, A8.7, A8.11, and A8.24.
IS.D.OR.250(d)	Related ISO/IEC 27001:2022 clauses and controls
	7.5 Documented information
	Part-IS particularity
	This possibility of ISMM integration with other expositions or manuals has no specific counterpart in ISO/IEC 27001:2022. However, following the ISO ‘Annex SL’ structure, ISO/IEC 27001:2022 enables an easy integration of other management system standards.
	Guidance on Part-IS implementation
	There is a tendency in the aviation industry to integrate different management systems, depending on the structure of the organisation.
IS.D.OR.255(a)	Related ISO/IEC 27001:2022 clauses and controls
	6.3 Planning of changes
	A5.5 Contact with authorities
	Part-IS particularity
	Change management is an inherent part of the ISMS under 6.3 of ISO/IEC 27001:2022, but there is no provision for approval of a procedure by a competent authority.

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	Guidance on Part-IS implementation
	The use of the same procedure as the one implemented for the ‘safety regulations’ (see above) is recommended also for the approval of changes not requiring prior approval by the competent authority. This procedure should be extended to Part-IS in agreement with the competent authority.
	<i>Note:</i> <i>This recommendation will only work if the competent authority is the authority as laid down in Article 6(1) of Regulation (EU) 2023/203 or Article 5(1) of Regulation (EU) 2022/1645.</i>
	WARNING: <i>An organisation with a derogation approval in accordance with point IS.D.OR.200(e) needs to assess for all changes (also those not requiring prior approval) whether the criteria for the approved derogation are still valid. If not, the change needs the approval of the competent authority/authorities prior to being implemented.</i>
IS.D.OR.255(b)	Related ISO/IEC 27001:2022 clauses and controls
	6.3 Planning of changes
	A5.5 Contact with authorities
	Part-IS particularity
	Change management is an inherent part of the ISMS under 6.3 of ISO/IEC 27001:2022. However, ISO/IEC 27001:2022 does not require any kind of approval by a competent authority.
	Guidance on Part-IS implementation
IS.D.OR.260 (a)	The use of the same procedure as the one implemented for the ‘safety-regulations’ (see above) is recommended also for the approval of changes in agreement with the competent authority.
	<i>Note:</i> <i>This recommendation will only work if the competent authority is the authority as laid down in Article 6(1) of Regulation (EU) 2023/203 or Article 5(1) of Regulation (EU) 2022/1645.</i>
	Related ISO/IEC 27001:2022 clauses and controls
	9.3 Management review
	10.1 Continual improvement
	A5.35 Independent review of information security
	Part-IS particularity
	This requirement reflects a combination of requirements 9.3 and 10.1 of ISO/IEC 27001:2022 with references to requirements 4.4 and 5.2. While ISO/IEC 27001:2022 focuses on ISMS suitability, adequacy and effectiveness, point IS.D.OR.260(a) requires also a periodical maturity assessment of the ISMS.

Part-IS requirement	ISO/IEC 27001:2022 mapping and specific guidance
	Guidance on Part-IS implementation ISO/IEC 27001:2022, 4.4 shows a clear requirement ('shall') for ISMS maintenance and improvement. The top management has a responsibility for continuous ISMS improvement as per ISO/IEC 27001:2022 5.2(d). The planning section also requires continuous improvement (ISO/IEC 27001:2022 6.1.1(c)). Point IS.D.OR.260(a) requires an assessment of the effectiveness and maturity of the ISMS on a calendar basis or following an information security incident. This assessment should be performed by using indicators. ISO/IEC 27001:2022 Chapter 9.3.1 defines a very similar approach for the management review process. Chapter 10.1 indicates a more independent process to improve the ISMS. The process in Chapter 10.1 is seen as more of a bottom-up approach, whereas that in Chapter 9.3 is intended to be top-down. The results from A5.35 should all be used as inputs for continuous improvement. Point IS.D.OR.260(a) also requires a maturity assessment of the ISMS. Each organisation should establish which maturity model will be followed and which targeted maturity level is expected to be reached and by when. For the maturity assessment, point (b) of AMC1 IS.D.OR.260(a) and GM1 IS.D.OR.260(a) provides guidance on how to ensure compliance with point IS.D.OR.260(a).
	Related ISO/IEC 27001:2022 clauses and controls 10.2 Non-conformity and corrective action A5.7 Threat intelligence
IS.D.OR.260(b)	Part-IS particularity Point IS.D.OR.260(b) addresses the improvement measures, i.e. corrections and corrective actions for the deficiencies detected in point IS.D.OR.260(a) and the continuous improvement process. This requirement reflects mainly requirement 10.2 of ISO/IEC 27001:2022, even if the term used is 'non-conformity', while point IS.D.OR.260(b) uses the term 'deficiencies'. Deficiency has a broader meaning than non-conformity. It encompasses the case of a targeted maturity level that would not be reached at the planned date; that would be a deficiency but not necessarily a non-conformity.
	Guidance on Part-IS implementation The provisions listed in ISO/IEC 27001:2022 10.2 can be used to take corrective actions, to resolve both non-conformities and maturity level gaps.

Appendix V — Proportionality considerations related to safety relevance and aspects of complexity

ED Decision 2025/014/R

The following is a non-exhaustive, non-binding, list of activities related to the implementation of the ISMS under this Regulation. These activities are proposed in association with a set of indicators, with activities suggested at the lower and upper ends of the scale. Organisations are encouraged to assess their own level for each indicator, selecting or adapting the proposed activities based on their specific information security risks and organisational context. This approach helps to keep the activities proportionate to the overall safety relevance and complexity of the organisation.

Indicator of the degree of safety relevance: the organisation's role in the functional chain, and number and criticality of interfacing organisations

The organisation's role in the functional chain and its overall contribution to the safety of related functional processes are key indicators of safety relevance. This should impact the depth of risk assessment required and the level of assurance needed to ensure the effectiveness of measures implemented to mitigate unacceptable risks.

Low safety relevance: organisations whose role in the functional chain and their interfaces do not pose a risk of unsafe conditions.

The following approach may be adopted:

Risk assessment and treatment

- **Simplified risk assessment:** A streamlined risk assessment process that prioritises risks based on their potential impact on safety is used. The assessment focuses on high-impact areas; more detailed assessments are performed only where and if necessary.
- **Risk treatment prioritisation:** A risk treatment plan that prioritises high-impact risks with cost-effective measures is adopted. In such cases, cost-effective controls that reduce risks to acceptable levels may be used. These controls can often leverage existing processes, physical controls or technology.

High safety relevance: organisations whose role in the functional chain and their interfaces may pose a risk of unsafe conditions

The following approach may be adopted:

Risk assessment and treatment

Detailed risk assessments: Detailed and often more frequent risk assessments are carried out for those elements that have been identified as having a relevant safety impact, i.e. an unsafe condition.

Indicator of complexity 1: complexity of the organisational structure and hierarchies

The complexity of an organisation's structure — typically determined by the number of staff, departments and hierarchical layers — directly influences the level of internal coordination required and the extent to which information exchange needs to be formalised and proceduralised.

Low complexity: organisations characterised by a combination of limited number of staff members, few hierarchical layers and departments

The following approaches may be adopted:

(a) Policy and procedure simplification

- **Streamlined documentation:** Policies and procedures can be concise, clear and easy to read. Documents are kept short and simple to make them easily understandable. Templates can be used in order to expedite the creation of the necessary documentation.
- **Focus on key policies:** During the development, the key policies have been prioritised in order to address the most critical aspects of information security, such as management commitment, access control and incident response.

(b) Employee training and awareness

- **Targeted training programmes:** Focused training programmes that target the specific roles and responsibilities of employees are provided. The training is relevant to the organisation's specific risks and operational context.
- **Security culture:** A culture of information security awareness is encouraged throughout the organisation. Short training sessions and awareness campaigns are conducted on a regular basis.

(c) Outsourcing and partnerships

- **Outsourcing:** For areas where the organisation lacks expertise, outsourcing to providers of managed-security services is adopted.
- **Collaboration with peers:** Information-sharing with similar organisations (e.g. through the European Centre for Cyber Security in Aviation (ECCSA)) or industry groups is carried out. Collaboration provides insights to evaluate the evolution of the security environment with limited effort.

(d) Engagement with management

Simplified management reporting: Reports to management are concise and focused on key metrics that demonstrate the effectiveness of the ISMS. Continued support and resource allocation from top management is ensured.

(e) Compliance monitoring and continuous improvement

- **Regular but scaled audits:** Internal audits are regularly conducted, but the effort is scaled to the organisation's size and complexity. The focus is on the most critical areas and the audit results are provided to the accountable manager or the head of the design organisation and utilised to guide continuous improvement.
- **Agile review process:** The ISMS is regularly reviewed and, if necessary, adapted to ensure that it remains aligned with the organisation's evolving needs and threats.

High complexity: organisations characterised by a combination of large number of staff members, hierarchical layers and departments and interfaces

The following approaches may be adopted:

(a) Robust governance structure

- **Information security governance:** Governance implementation to oversee the ISMS are present. This is to ensure alignment with the organisation's safety and security objectives. This governance should operate through formal committees or working groups that

include representatives from senior management, safety, information technology, legal and key business units.

- **Metrics and reporting:** Comprehensive metrics and reporting structures to track the effectiveness of the ISMS are implemented. Report on key performance indicators (KPIs) to senior management and the management board are provided to ensure ongoing support and resource allocation.

(b) Extensive policy and procedure framework

- **Detailed policies and procedures:** Although streamlined documentation is still the overall objective, more complex organisations may require a broader range of policies and procedures to cover different business units and departments, compliance requirements and operational processes.
- **Policy harmonisation:** Policies are harmonised across the organisation to avoid conflicting practices between different departments or regions. This requires a centralised governance model to oversee policy development and enforcement.

(c) Risk assessment and treatment

- **Cross-risk assessments:** Cross-risk assessments include assessing risks across various departments, geographic locations and technological platforms.
- **Risk aggregation and correlation:** With a larger volume of information, risks assessments are aggregated and correlated to identify systemic issues and ensure that risks are managed and escalated at an organisational level, not just within individual silos.

(d) Comprehensive training and awareness programmes

- **Role-based training:** Extensive role-based training programmes tailored to different functions within the organisation are implemented. For example, IT staff, executives and end-users all have different levels of training specific to their roles.
- **Continuous security awareness campaigns:** Security awareness campaigns using various methods (e.g. phishing simulations, workshops and e-learning modules) are continuously deployed to keep security top-of-mind for all employees across the organisation.

(e) Enhanced contracted activities management

- **Supply chain risk management:** Thorough information security assessments of contracted organisations and ongoing monitoring of third-party risks are carried out. Information security requirements are integrated into contracts.

(f) Comprehensive incident management

- **Security monitoring and incident response capability:** In order to monitor security events around the clock, manage incidents and coordinate response efforts across the organisation, structured security operations are established. Depending on the organisation's resources, this can be achieved through a dedicated security operations centre (SOC), a virtual SOC, managed security services or other appropriate solutions that ensure effective coverage.
- **Complex incident response plans:** Detailed incident response plans that cover a variety of scenarios, including cross-departmental coordination, communication strategies and operational continuity planning are developed and maintained.

- **Crisis simulation exercises:** Crisis simulation exercises that involve key stakeholders across the organisation are regularly conducted to test the effectiveness of incident response and operational continuity plans.

(g) Continuous improvement and compliance monitoring programmes

- **Internal audits:** Comprehensive internal audits are regularly conducted to assess compliance with the ISMS and identify areas for improvement.
- **Audits of contracted organisations:** To ensure compliance with the organisation's security and safety objectives, audits of contracted organisations are conducted at a frequency proportionate to the relevance of the contracted activities to security and safety. Using the results of existing relevant audits is also encouraged to reduce the burden.
- **Continuous improvement programmes:** A continuous improvement process to update and refine the ISMS based on audit findings, incident post-mortems and changes in the threat landscape is implemented.

Indicator of complexity 2: complexity of the ICT systems and data used by the organisation

The complexity of the information and communication technology systems and data used by the organisation, and their connection to external parties, directly influences the level of customisation and tailoring required for risk management and incident detection, response and recovery.

Low complexity: organisations characterised by a combination of usage of a few ICT tools and utilisation of standard ICT products

The following approaches may be adopted:

(a) Use of standards and tools

- **Leverage ISO/IEC 27001:2022 controls as a baseline:** ISO/IEC 27001:2022 Annex A provides a catalogue of controls that are selected based on the results of the risk assessment. Similarly, NIST SP 800-53 offers a comprehensive set of controls that can be adapted to specific threats and operational requirements. Aligning control selection with risk assessment outcomes ensures that the controls are suitable for the specific threats and vulnerabilities identified, while reducing the effort involved in designing controls from scratch. Additionally, using the controls as a checklist helps to ensure that critical areas are addressed. To ensure full alignment with aviation-specific information security requirements under Part-IS, it is also recommended to consult the Part-IS versus ISO/IEC 27001:2022 comparison guide.
- **Simplified incident management:** A basic incident management process that allows for quick identification, reporting and response to security incidents is adopted. Lessons learned from incidents are in any case integrated into the ISMS for continuous improvement.
- **Automated tools:** Automated tools for monitoring, logging and managing security incidents are used in order to reduce manual effort while maintaining continuous compliance.

(b) Documentation and record-keeping

- **Essential records:** Only records that are essential to demonstrate compliance and the effectiveness of the ISMS are kept. Excessive documentation that does not add value or is burdensome to maintain is avoided.

- **Use of digital solutions:** Digital tools are used for document management to simplify access and version control, and to ensure the security of records.

High complexity: organisations characterised by a combination of usage of several and diverse ICT tools, amongst which bespoke ICT solutions

The following approaches may be adopted:

(a) Advanced security technologies

- **Integration of advanced security tools:** Security technologies like security information and event management (SIEM), data loss prevention (DLP), and endpoint detection and response (EDR) systems are utilised to help manage the scale and complexity of monitoring, detecting and responding to security incidents across the organisation.
- **Automated threat intelligence:** Automated threat intelligence platforms are used to enable real-time threat detection and response across the broad threat surface.

(b) Documentation and record-keeping

- **Detailed documentation:** Extensive documentation of all ISMS processes, risk assessments, incident reports and compliance activities is carried out.
- **Record retention:** Records and data are widely collected, retained and securely stored, and are accessible over extended periods.

Appendix VI — Adaptation of the EU Cybersecurity Skills Framework (ECSF)

ED Decision 2025/014/R



APPLICATION OF THE EUROPEAN CYBERSECURITY SKILLS FRAMEWORK TO AVIATION

Contents

1. Introduction	2
2. Analysis of the situation and the target environment	3
3. Identification of specific objectives to be achieved	4
4. Selection of the appropriate ECSF components	4
5. Adapting the selected components according to specific needs	7
5.1 Chief Information Security Officer / Responsible Person under Part-IS	8
5.2 Cyber Legal, Policy & Compliance Officer / Compliance monitoring under Part-IS	11
5.3 Cybersecurity Auditor / Cybersecurity Auditor within compliance monitoring function	12
5.4 Cybersecurity Risk Manager / Appointed person under Part-IS	14
5.5 Cybersecurity Incident Responder	16
6. Conclusions	17
7. Possible developments	18



1. Introduction

The European Union Agency for Cybersecurity (ENISA) has developed the European Cybersecurity Skills Framework (ECSF) as a comprehensive tool to address the growing need for cybersecurity expertise across different sectors. The ECSF provides a standardised framework for the assessment and development of cybersecurity skills, knowledge, and competences.

With its increasing reliance on digital technology and interconnected networks, cybersecurity is of paramount importance to ensure the integrity and resilience of aviation system for the safety of the passengers and people on ground. A new aviation regulation, called Part-IS, has recently been introduced in the EU with the aim of implementing a structured approach to managing cybersecurity risks that may have an impact on aviation safety.

Organisations and national authorities subject to this Regulation will need to assess the suitability of their staff to properly apply the Regulation and, where necessary, to adjust staff competences. For this purpose, the ENISA ECSF can provide useful tools and a methodological approach.

In fact, the framework provides a common language and reference point for understanding and categorising cybersecurity roles, facilitating effective recruitment, training, and talent development strategies. By utilising the ECSF, aviation organisations may identify and assess the cybersecurity skills and competencies required for their specific operational needs. It may support the identification of skills gaps and areas for improvement, helping organisations to prioritise training programmes and investments to effectively address cybersecurity challenges.

The objective of this document is to provide a high-level case study of the application of the ECSF in aviation for the purpose of implementing and applying the Part-IS.

2. Analysis of the situation and the target environment

Aviation, like other transport and industrial sectors, is characterised by the coexistence of two primary classes of information technologies within organisations. These classes are:

- **Information and Communication Technologies (ICT):** These are the traditional systems and technologies that support administrative and business functions. ICT systems encompass a wide range of technologies, including computer systems, networks, software applications, databases, and associated infrastructure. They facilitate tasks such as data processing, storage, communication, and information management necessary for the administrative operations within an organisation.
- **Operational Technologies (OT):** OT refers to the specialised technologies and systems designed specifically for the management and control of physical processes and assets. In the context of aviation, OT systems include various components such as manufacturing automation systems, power plant control systems, medical equipment and in the aviation sector aircrafts, air traffic management or even baggage handling, including screening, systems. These technologies are critical to the safe and efficient operation of aviation processes and assets.

While there are technological differences between ICT and OT systems, the gap between them is gradually closing. OT systems are becoming more similar to ICT systems due to technology convergence and the adoption of digitalisation in the aviation sector. This convergence involves the integration of IT practices and technologies into OT systems to improve efficiency, enhance data analysis capabilities and enable better decision making.

However, despite the diminishing technological differences, there are still some distinct characteristics between ICT and OT domains in the aviation industry. These differences have implications for cybersecurity risk policies, availability requirements and change management processes:

- **Cybersecurity Risk Policy:** Risk assessment in the OT domain requires additional considerations due to the critical safety aspects associated with physical processes and assets. In many sectors, including aviation, safety requirements are often incorporated into regulatory frameworks. Therefore, risk assessment for OT systems should include both traditional information security considerations and safety-related risks specific to the aviation industry.
- **Availability requirements:** OT systems are typically required to operate continuously and be resilient to cyber-attacks in order to maintain the availability of safety-critical functions in the event of cyber-security incidents.
- **Change Management Process:** The change management process for OT systems is different from that for ICT systems. In the OT domain, updates, patches, and system changes cannot be implemented in a timely manner as they may affect the safety and operational integrity of aviation processes. Therefore, any changes or updates to OT systems must be carefully planned, extensively tested in advance, and comply with stringent regulatory requirements to ensure safety and reliability.

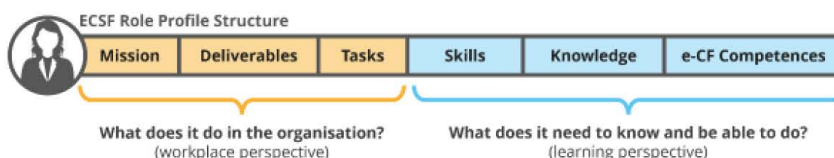
3. Identification of specific objectives to be achieved

OT operations and cybersecurity personnel need to maintain a delicate balance between ensuring robust cybersecurity and maintaining the operational safety of systems. This approach requires a thorough understanding of the specific safety requirements, associated processes, and regulatory standards relevant to the industry in which OT systems are deployed. It involves active engagement with cybersecurity professionals, regulators, and industry experts to ensure that security measures are aligned with safety objectives and comply with applicable safety regulations.

4. Selection of the appropriate ECSF components

The ECSF profiles can be a valid starting point to define the information security competences required in the aeronautical sector, taking into account also the specificity of the OT described above, which characterises this domain.

To this purpose the recently published EU Regulation 2023/203 (Part-IS) for the management of cybersecurity risks with a potential impact on aviation safety will be considered. This Regulation sets out requirements for aviation organisations and relevant competent authorities and allows some roles to be described from a workplace perspective by defining mission, deliverables, and task in accordance with the scheme below.



In particular the aviation regulation and Part-IS delineates some specific roles/functions and their responsibilities, these roles are:

Accountable Manager, or Head of Design, or Responsible Person

The person in this role is responsible for establishing and maintaining the organisational structures, policies, processes, and procedures necessary to meet the requirements of the Regulation. In addition, the person in this role is explicitly required to establish and promote the information security policy.

The role is clearly managerial, and it is expected that a significant degree of delegating to lower management and implementing teams will occur.

Compliance Monitoring (person responsible for)

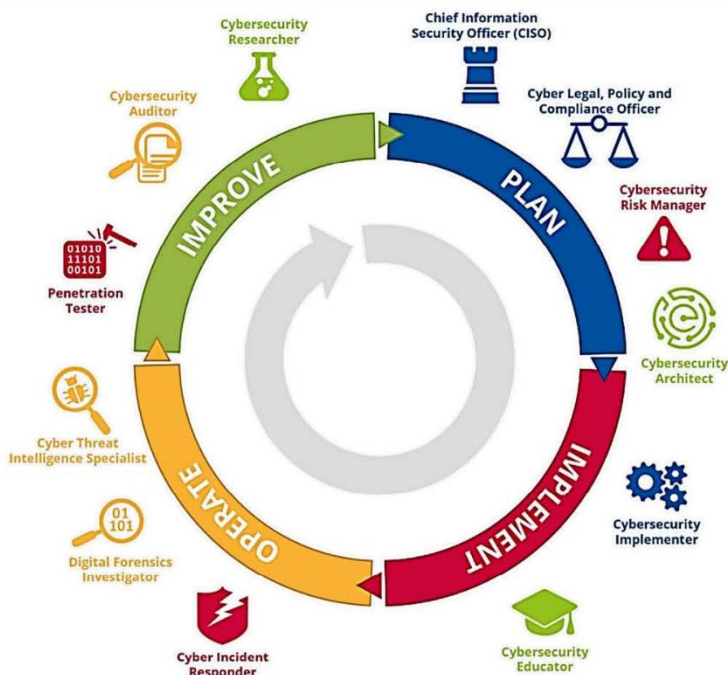
The monitoring of compliance with the requirements of the Regulation is the responsibility of the person(s) in this role.

Appointed person(s)

The Regulation requires the appointment of a person or, more likely, a group of persons, to ensure the compliance of the organisation with the requirements. The extent of authority may vary; however these appointed persons should have responsibilities at management level and in many cases they will coordinate and oversee the activities other staff members.



The ECSF instead proposes 12 standard roles involved in different phases of the management cycle, as illustrated below.



An initial mapping between the ECSF roles and the roles delineated in Part-IS can be performed by **comparing the deliverables expected from the different roles** as reported in the below Table 1. As described above, some roles are well described in Part-IS, others can be considered expected in order to comply with the requirements of the regulation (e.g. incident detection, response and recovery).

The mapping shows that there are different levels of matching between ECSF and Part-IS roles. Four levels have been used, ranging from "high level of match" to "no match". In more details the rationale for the classification of the level of matching is the following:

- **High level of match:** In the Part-IS regulation, both a role and a deliverable can be found that is very close to the one described in the framework.
- **Not Specified, but expected:** In order to comply with the provisions of Part IS, an organisation is expected to produce the deliverable under the ECSF profile, but the Regulation does not mention a specific role associated with this deliverable.
- **Not Specified, may be useful in complex setting:** Same as the previous level of matching, with the addition that this role may only be justified in complex organisations.
- **Not foreseen:** In the Part-IS regulation, both a matching role and a deliverable cannot be found.

According to the level of match between the roles the following colour background has been used in the table rows:

High level of match	Medium level of match	Low level of match	No match
---------------------	-----------------------	--------------------	----------

Table 1 – ECSF and Part-IS roles mapping

Profile Title	Deliverable	Part – IS role considerations
Chief Information Security Officer (CISO)	Cybersecurity Strategy / Policy	Responsible Person
Cyber Legal, Policy & Compliance Officer	Compliance Manual / Compliance Report	Compliance Monitoring
Cybersecurity Auditor	Cybersecurity Audit Plan / Report	Auditor within compliance monitoring function
Cybersecurity Risk Manager	Cybersecurity Risk Assessment Report / Remediation Action Plan	One of the “appointed persons”
Cybersecurity Implementer	Cybersecurity Solutions	Not specified, but expected
Cyber Incident Responder	Incident Response Plan / Incident Report	One of the “appointed persons”
Cyber Threat Intelligence Specialist	Cyber Threat Intelligence Manual / Report	Not specified, but expected
Cybersecurity Architect	Cybersecurity Architecture Diagram / Requirements Report	Not specified, but expected
Cybersecurity Educator	Cybersecurity Awareness Program / Training Material	Not specified, but expected
Cybersecurity Researcher	Publication in Cybersecurity	Not foreseen
Digital Forensics Investigator	Digital Forensics Analysis Results / Electronic Evidence	Not specified, but expected
Penetration Tester	Vulnerability Assessment Results Report / Penetration Testing Report	Not specified, may be useful in complex setting

The resulting mapping applied to the ECSF roles in the phases of the management cycle is depicted in the following figure.



© European Union Aviation Safety Agency. All rights reserved.
Proprietary document. Version 1, July 2023.

Page 6 of 18

5. Adapting the selected components according to specific needs

For the purposes of this exercise, we will focus on the high match roles summarised in the table below. The aim is to take into account the specific objectives arising from the OT considerations described in the earlier section.

Table 2 – ECSF and Part-IS roles mapping – medium and high match

Profile Title	Deliverable	Part – IS role considerations
Chief Information Security Officer (CISO)	Cybersecurity Strategy / Policy	Responsible Person
Cyber Legal, Policy & Compliance Officer	Compliance Manual / Compliance Report	Compliance Monitoring
Cybersecurity Auditor	Cybersecurity Audit Plan / Report	Auditor within the compliance monitoring function
Cybersecurity Risk Manager	Cybersecurity Risk Assessment Report / Remediation Action Plan	One of the "appointed persons"
Cyber Incident Responder	Incident Response Plan / Incident Report	One of the "appointed persons"

The ECSF provides a convenient description of the role profiles through components that include **summary statement, mission, deliverable(s), main task(s) and key skill(s)**. The matching in terms of deliverable(s) have been used in the previous step to identify the appropriate profiles, so this component does not require adaptations. It can also be expected that the summary statement and the mission, being high-level descriptions, may not require significant adaptation, whereas the main tasks associated with the role may need to be adapted with integrations to reflect the specificities of aviation and OT in general.

For the different roles analysed, the modified/added text of the above component is **shown in blue**, removals instead are **shown in red**. The use of the term "safety" in the remainder of this document is in the meaning of "aviation safety".

5.1 Chief Information Security Officer / Responsible Person under Part-IS

Summary statement	Manages an organisation's cybersecurity strategy and its implementation to ensure that digital systems, services and assets are adequately secure and protected, with a strong emphasis on operational safety .
Mission	Defines, maintains and communicates the cybersecurity vision, strategy, policies and procedures. Manages the implementation of the cybersecurity policy across the organisation. Assures information exchange with external authorities and professional bodies.

Main Tasks	
ECSF original	Adapted
Define, implement, communicate and maintain cybersecurity goals, requirements, strategies, policies, aligned with the business strategy to support the organisational objectives	Define, implement, communicate and maintain cybersecurity goals, requirements, strategies and policies that are aligned with the business strategy to support the organisation's objectives ¹ [see note 1], taking into account the safety perspective: In addition to considering cybersecurity objectives, safety perspectives should be integrated into the objectives, requirements, strategies and policies. This will ensure that cybersecurity measures do not compromise the safety of operational systems and processes. Safety considerations should be included in risk assessments, threat modelling and decision-making processes.
Prepare and present cybersecurity vision, strategies and policies for approval by the senior management of the organisation and ensure their execution	Prepare and present cybersecurity vision, strategies and policies for approval by the senior management of the organisation and ensure their execution, considering safety implications: When presenting the cybersecurity vision, strategies and policies to senior management, it is crucial to highlight the safety implications and emphasise the importance of aligning cybersecurity measures with operational safety. This will ensure that senior management understands the potential impact of cybersecurity decisions on the overall safety of the organisation.
Supervise the application and improvement of the Information Security Management System (ISMS)	Supervise the application and improvement of the Information Security Management System (ISMS) with a focus on safety: While supervising the ISMS, OT operations and security personnel should place significant emphasis on the safety aspects. This includes incorporating controls into the ISMS framework, ensuring that safety requirements are met, and monitoring the effectiveness of safety measures implemented alongside cybersecurity practices.

¹ The “business strategy to support the organisation's objectives” could be interpreted as the “entity risk appetite”.

Main Tasks	
ECSF original	Adapted
Educate senior management about cybersecurity risks, threats and their impact to the organisation	Educate senior management about cybersecurity risks, threats and their impact to their own organisation, societal safety and interfaced organisations : During education sessions with senior management, it is essential to provide insights into cybersecurity risks and threats from a safety perspective. This helps senior management understand the potential consequences of cyber incidents on operational safety, making informed decisions regarding resource allocation and risk mitigation strategies.
Ensure the senior management approves the cybersecurity risks of the organisation	Ensure senior management approves the cybersecurity risks of the organization, considering safety aspects: When seeking approval for cybersecurity risks, OT operations and security personnel should explicitly address the safety implications associated with these risks. This will ensure that senior management is fully aware of the potential impact on operational safety and can prioritise risk mitigation efforts accordingly.
Develop cybersecurity plans	Develop cybersecurity plans that integrate safety considerations: Cybersecurity plans should not only focus on protecting against cyber threats, but should also include measures to address operational safety. This may include incorporating safety controls, conducting safety impact assessments, and aligning cybersecurity initiatives with safety objectives and industry-specific safety standards.
Develop relationships with cybersecurity-related authorities and communities	Develop relationships with cybersecurity-related authorities and communities, with a focus on safety aspects: When establishing relationships with cybersecurity-related authorities and communities, OT operations and security personnel should actively seek opportunities to discuss cybersecurity aspects of operational safety.
Report cybersecurity incidents, risks, findings to the senior management	Report cybersecurity incidents, risks, findings to the senior management, emphasizing safety implications: When reporting cybersecurity incidents, risks, and findings to senior management, it is essential to highlight the safety implications and articulate the potential impact on operational safety. This helps senior management make informed decisions regarding incident response, risk mitigation, and resource allocation.
Monitor advancement in cybersecurity	Monitor advancements in cybersecurity with a focus on safety-related technologies and practices
Secure resources to implement the cybersecurity strategy	Secure resources to implement the cybersecurity strategy, considering safety needs: When securing resources to implement the cybersecurity strategy, OT operations and security personnel should ensure that adequate resources are allocated for safety-related measures.

Main Tasks	
ECSF original	Adapted
Negotiate the cybersecurity budget with the senior management	Negotiate the cybersecurity budget with senior management, <i>considering safety requirements</i> : During budget negotiations, OT operations and security personnel should advocate for sufficient funding to address both cybersecurity and safety needs. This includes emphasising the importance of investing in cybersecurity measures to protect operational systems and ensure their continued safe operation.
Ensure the organisation's resiliency to cyber incidents	Ensure the organization's resiliency to cyber incidents, <i>incorporating safety-focused incident response plans and business continuity measures</i> . This involves identifying and addressing potential safety risks during incident response and recovery efforts.
Manage continuous capacity building within the organisation	Manage continuous capacity building within the organisation, <i>promoting training and awareness programmes that encompass both cybersecurity and operational safety aspects</i> . This ensures that employees understand the importance of maintaining a safe and secure operational environment.
Review, plan and allocate appropriate cybersecurity resources	Review, plan, and allocate appropriate cybersecurity resources, <i>considering safety requirements and conducting regular assessments of resource needs to effectively protect systems and maintain operational safety</i> .

5.2 Cyber Legal, Policy & Compliance Officer / Compliance monitoring under Part-IS

Summary statement

Manages compliance with cybersecurity-related standards, legal and regulatory frameworks based on the organisation's strategy and legal requirements.

Mission

Oversees and assures compliance with cybersecurity- and data-related legal, regulatory frameworks and policies in line with the organisation's strategy and legal requirements. **Contributes to the organisation's data protection related actions.** Provides legal advice in the development of the organisation's cybersecurity governance processes and recommended remediation strategies/solutions to ensure compliance.

Main Tasks	
ECSF original	Adapted
Ensure compliance with and provide legal advice and guidance on data privacy and data protection standards, laws and regulations	Ensure compliance with and provide advice and guidance on cybersecurity provisions in aviation regulation
Identify and document compliance gaps	No adaptations
Conduct privacy impact assessments and develop, maintain, communicate and train upon the privacy policies, procedures	Not required by the aviation specific regulation
Enforce and advocate organisation's data privacy and protection program	Not required by the aviation specific regulation
Ensure that data owners, holders, controllers, processors, subjects, internal or external partners and entities are informed about their data protection rights, obligations and responsibilities	Not required by the aviation specific regulation
Act as a key contact point to handle queries and complaints regarding data processing	Not required by the aviation specific regulation
Assist in designing, implementing, auditing and compliance testing activities in order to ensure cybersecurity and privacy compliance	Assist in designing, implementing, auditing and compliance testing activities in order to ensure cybersecurity compliance
Monitor audits and data protection related training activities	Not required by the aviation specific regulation
Cooperate and share information with authorities and professional groups	Cooperate and share information with competent authorities
Contribute to the development of the organisation's cybersecurity strategy, policy and procedures	No adaptations
Develop and propose staff awareness training to achieve compliance and foster a culture of data protection within the organization	Not required by the aviation specific regulation
Manage legal aspects of information security responsibilities and third-party relations	No adaptations

5.3 Cybersecurity Auditor / Cybersecurity Auditor within compliance monitoring function

Summary statement	Perform cybersecurity audits on the organisation's ecosystem. Ensuring compliance with statutory, regulatory, policy information, cybersecurity requirements, industry standards and best practices.
Mission	Conducts independent reviews to assess the effectiveness of processes and controls and the overall compliance with the organisation's legal and regulatory frameworks policies. Evaluates, tests and verifies cybersecurity-related products (systems, hardware, software and services), functions and policies ensuring, compliance with guidelines, standards and regulations.

Main Tasks	
ECSF original	Adapted
Develop the organisation's auditing policy, procedures, standards and guidelines	Develop the organisation's audit policies, procedures, standards and guidelines, taking into account the safety requirements specific to the OT environment . Incorporate safety considerations into the audit framework to assess the effectiveness of cybersecurity controls in maintaining operational safety.
Establish the methodologies and practices used for systems auditing	Establish the methodologies and practices used for systems auditing that consider the safety-critical nature of OT systems. Design audit approaches that assess the information security and safety aspects of OT processes, ensuring that both cybersecurity and operational safety objectives are addressed.
Establish the target environment and manage auditing activities	Establish the target environment and manage auditing activities, focusing on the safety-critical components of OT systems. In accordance with the risk assessment, prioritise audit areas that have the greatest impact on operational safety .
Define audit scope, objectives and criteria to audit against	Define the audit scope, objectives, and criteria to audit against with a particular focus on safety requirements. Consider standards, regulations, and industry best practices to assess the effectiveness of cybersecurity controls in maintaining operational safety.
Develop an audit plan describing the frameworks, standards, methodology, procedures and auditing tests	Develop an audit plan describing the frameworks, standards, methodology, procedures and auditing tests and that aligns them with both cybersecurity and operational safety objectives. Include specific tests and assessments to ensure the integrity and safety of OT systems.
Review target of evaluation, security objectives and requirements based on the risk profile	Review the target of evaluation, security objectives, and requirements based on the risk profile, taking into account safety considerations. Evaluate compliance with safety regulations and standards to ensure the operational safety of OT systems.
Audit compliance with cybersecurity-related applicable laws and regulations	Audit compliance with cybersecurity-related applicable laws, regulations, and safety standards.
Audit conformity with cybersecurity-related applicable standards	Assess adherence to safety regulations that are critical for maintaining operational safety within the OT environment.

Main Tasks	
ECSF original	Adapted
Execute the audit plan and collect evidence and measurements	Execute the audit plan, collecting evidence and measurements that validate the effectiveness of cybersecurity controls from a safety perspective. Evaluate the alignment of security practices with operational safety requirements, ensuring that both aspects are adequately addressed.
Maintain and protect the integrity of audit records	Maintain and protect the integrity of audit records, including safety-related findings and recommendations. Safeguarding the accuracy and confidentiality of audit records ensures the preservation of safety-related findings and supports continuous improvement efforts.
Develop and communicate conformity assessment, assurance, audit, certification and maintenance reports	Develop and communicate conformity assessment, assurance, audit, certification, and maintenance reports that highlight the intersection of cybersecurity and operational safety. Highlight the impact of cybersecurity measures on the operational safety of OT systems, providing insight for risk mitigation and improvement initiatives.
Monitor risk remediation activities	Monitor risk remediation activities to ensure that identified vulnerabilities and safety risks are effectively addressed. Track the progress of remediation activities and verify that safety-critical issues are adequately remediated.

5.4 Cybersecurity Risk Manager / Appointed person under Part-IS

Summary statement

Manage the organisation's cybersecurity-related risks aligned to the organisation's strategy. Develop, maintain and communicate the risk management processes and reports.

Mission

Continuously manages (identifies, analyses, assesses, estimates, mitigates) the cybersecurity-related risks of ICT (IT and OT) infrastructures, systems and services by planning, applying, reporting and communicating risk analysis, assessment and treatment. Establishes a risk management strategy for the organisation and ensures that risks remain at an acceptable level for the organisation, and the entities at the interfaces*, by selecting mitigation actions and controls.

* Very specific to Part-IS requirements, may not be relevant in OT domains other than aviation

Main Tasks	
ECSF original	Adapted
Develop an organisation's cybersecurity risk management strategy	Develop an organisation's cybersecurity risk management strategy, incorporating safety considerations, to identify and assess risks that could affect operational safety. This includes assessing potential safety risks arising from cyber threats and vulnerabilities in OT, and prioritising risk treatment options that effectively address both cybersecurity and operational safety risks.
Manage an inventory of organisation's assets	Maintain an inventory of the organisation's assets, taking into account safety critical systems and their dependencies. This involves identifying and categorising assets based on their safety impact to ensure that appropriate cybersecurity measures are applied to protect the integrity and operational safety of critical assets.
Identify and assess cybersecurity-related threats and vulnerabilities of ICT systems	Identify and assess cybersecurity-related threats and vulnerabilities of ICT (IT and OT) systems, focusing on their potential impact on operational safety. When assessing threats and vulnerabilities, consider safety-critical aspects such as system functionality, information and data integrity and availability.
Identification of threat landscape including attackers' profiles and estimation of attacks' potential	Identify the threat landscape, including adversary profiles and estimation of attacks' potential
Assess cybersecurity risks and propose most appropriate risk treatment options, including security controls and risk mitigation and avoidance that best address the organisation's strategy	Assess cybersecurity risks and propose most appropriate risk treatment options, including security controls and risk mitigation and avoidance that best address the organisation's strategy and safety requirements. This involves recommending security controls and risk mitigation strategies that effectively address both cybersecurity and operational safety objectives, ensuring a comprehensive risk management approach.

Main Tasks	
ECSF original	Adapted
Monitor effectiveness of cybersecurity controls and risk levels	Monitor the effectiveness of cybersecurity controls and continually assess risk levels from a safety perspective. Regularly assess the adequacy of controls in place to maintain operational safety, taking into account evolving threats and vulnerabilities.
Ensure that all cybersecurity risks remain at an acceptable level for the organisation's assets	Ensure that all cybersecurity risks remain at an acceptable level for the organisation and its interfaces, with a specific focus on operational safety. Continuously evaluate and reassess risks to ensure that safety-related risks are within acceptable limits and that cybersecurity measures do not compromise operational safety.
Develop, maintain, report and communicate complete risk management cycle	Develop, maintain, report and communicate the full risk management cycle, emphasising the safety implications of identified risks and risk treatment options. This includes providing clear and concise reports that highlight safety risks, control effectiveness, and ongoing efforts to align cybersecurity practices with operational safety objectives.

5.5 Cybersecurity Incident Responder

Summary statement

Monitor the organisation's cybersecurity state, handle incidents during cyber-attacks and assure the continued operations of ICT (IT and OT) systems.

Mission

Monitors and assesses systems' cybersecurity state. Analyses, evaluates and mitigates the impact of cybersecurity incidents. Identifies cyber incidents root causes and malicious actors. According to the organisation's Incident Response Plan, restores systems' and processes' functionalities to a safe and operational state, collecting evidences and documenting actions taken.

Main Tasks	
ECSF original	Adapted
Contribute to the development, maintenance and assessment of the Incident Response Plan	The safety aspect is crucial in any Incident Response Plan. It is essential to prioritise the return to an acceptable level of safety, preserving the integrity of the operations and minimising the potential harm for all individuals who may be affected by an incident or emergency situation.
Develop, implement and assess procedures related to incident handling	Develop, implement and assess procedures related to incident handling, with a strong focus on safety at every stage of the process.
Identify, analyse, mitigate and communicate cybersecurity incidents	Identify, analyse, mitigate and communicate cybersecurity incidents impacting safety
Assess and manage technical vulnerabilities	Assess and manage technical vulnerabilities with a safety-oriented approach. Address vulnerabilities that may pose risks to safety, and prioritise patching or mitigating those vulnerabilities to protect systems and users from potential harm.
Measure cybersecurity incidents detection and response effectiveness	Measure cybersecurity incident detection and response effectiveness, with a clear focus safety indicators. Evaluate how effectively incidents are detected and resolved while controlling the impact on the level of operational safety.
Evaluate the resilience of the cybersecurity controls and mitigation actions taken after a cybersecurity or data breach incident	Evaluate the resilience of cybersecurity controls and mitigating actions taken after a cybersecurity or data breach incident to ensure they maintain the necessary level of safety. Reassess controls from a safety perspective to prevent future incidents that could have safety impacts.
Adopt and develop incident handling testing techniques	Adopt and develop incident handling testing techniques that simulate real-world operational scenarios, including those that may have safety impacts. Test the effectiveness of safety measures and response procedures to continually improve incident handling capabilities.
Establish procedures for incident results analysis and incident handling reporting	Establish procedures for incident results analysis and incident handling reporting, emphasizing the importance of safety impact and lessons learned. Use incident data to enhance safety risk management and ensure better protection against potential future incidents.

Main Tasks	
ECSF original	Adapted
Document incident results analysis and incident handling actions	Document incident results analysis and incident handling actions, highlighting the impact on safety and lessons learned. Maintain detailed records to continuously improve safety measures and response strategies.
Cooperate with Secure Operation Centres (SOCs) and Computer Security Incident Response Teams (CSIRTs)	Cooperate with Secure Operation Centres (SOCs) and Computer Security Incident Response Teams (CSIRTs), while prioritising safety as a common goal. Collaborate to ensure timely and effective responses to incidents that may have an impact on safety.
Cooperate with key personnel for reporting of security incidents according to applicable legal framework	Cooperate with key personnel for reporting of security incidents according to applicable legal framework, ensuring that incidents with potential safety implications are reported promptly and accurately to the competent authorities.

6. Conclusions

The European Cybersecurity Certification Framework (ECSF) of the European Union Agency for Cybersecurity (ENISA) provides a valuable basis for identifying the cybersecurity profiles required in the aviation industry, as well as in other transport and industrial sectors. These sectors are characterised by the co-existence of IT and OT systems, where societal safety considerations significantly influence an organisation's risk appetite and the functioning of the security operations. In fact, the potential consequences of cyber incidents in the aviation, transport and industrial sectors go beyond financial losses and can directly impact lives, critical infrastructure operations and public confidence in the industry.

This exercise has demonstrated that the ECSF provides a professional framework that can be adapted to meet the unique requirements of the aviation and related sectors. By using the ECSF, organisations operating in these sectors may assess and identify specific cybersecurity profiles tailored to their unique environments. These profiles help to define the necessary security measures and controls, aligning them with the organisation's risk appetite and the overriding objective of ensuring societal safety.

The exercise has also shown that there might be cases of ECSF profiles covering more tasks than those resulting from the sector-specific requirements (e.g. Policy & Compliance Officer vs. Compliance Monitoring in Part IS). Such cases may be due to the need to comply with other requirements applicable at European level (e.g. the General Data Protection Regulation), therefore the organisation may decide to continue to consider these tasks for the role even if they are not sector specific.

In conclusion, the ENISA ECSF proves to be a useful tool in navigating the complex cybersecurity landscape of the aviation, transport and industrial sectors. ENISA may also consider the outcome of this exercise to introduce in future revision of the framework initial considerations on operational and safety related aspects.